CADRE DE RÉFÉRENCE D’ARCHITECTURE D’ENTREPRISE

# Interopérabilité et Orchestration en Entreprise Agentique

Architecture normative, standards d’interopérabilité, patrons d’orchestration, autonomie et supervision humaine, identité et sécurité, observabilité et FinOps, gouvernance et conformité pour concevoir, déployer et superviser des agents d’IA à l’échelle de l’organisation.




**IDENTIFIANT**
CRE-IA-2026-01

**VERSION**
1.1 — 28 octobre 2026

**STATUT**
Version finale soumise à l’approbation du comité



**AUTEUR**
André-Guy Bruneau

# Fiche du document

| | |
|---|---|
| **Titre** | Interopérabilité et Orchestration en Entreprise Agentique — cadre de référence d'architecture d'entreprise |
| **Identifiant normatif** | CRE-IA-2026-01 |
| **Version et date** | 1.1 — 28 octobre 2026 |
| **Statut** | Version finale consolidée, soumise à l'approbation du comité d'architecture et des risques agentiques |
| **Auteur** | André-Guy Bruneau |
| **Propriétaire** | Architecture d'entreprise, au nom du comité d'architecture et des risques agentiques |
| **Cycle de révision** | Cadre : chaque semestre. Catalogue des protocoles et versions de référence : chaque trimestre. Révision extraordinaire après tout incident agentique grave ou changement réglementaire majeur. |
| **Public** | Direction TI, architectes d'entreprise et de solutions, équipes de plateforme et d'intégration, équipes produit, sécurité de l'information, gestion des risques et conformité, protection des renseignements personnels, affaires juridiques, FinOps, approvisionnement, audit interne, responsables métier |
| **Classification** | Usage interne |
| **État des sources** | Faits, versions et dates vérifiés aux 27 et 28 octobre 2026 contre des sources primaires ou, à défaut, secondaires reconnues (annexe F) |

# Historique des versions

| Version | Date | Nature des changements |
|---|---|---|
| 0.1 | 27 oct. 2026 | Ébauche pour discussion : structure en treize sections, principes, architecture en couches, échelle d'autonomie, liste de contrôle et gabarit de fiche d'agent. |
| 0.2 | 27 oct. 2026 | Ébauche enrichie : règles d'usage de MCP et d'A2A, paliers de risque des outils, extensions CloudEvents, évaluation en trois paliers, exemples de contrats. |
| Ébauche « production » | 27 oct. 2026 | Ébauche parallèle : architecture en plans, exigences identifiées, contrats normatifs, grille d'homologation. |
| Recherche documentaire | 27 oct. 2026 | Synthèse de l'état de l'art en 2026 appuyée sur 121 références. |
| 1.0 | 27 oct. 2026 | Version finale consolidée : fusion des quatre documents, validation de chacune des 121 références et vérification des affirmations contre des sources primaires, unification des échelles (niveaux N0 à N4, paliers P0 à P3), corrections factuelles et mise à jour aux versions courantes des standards, ajout des volets mémoire, défense contre l'injection, approvisionnement et conformité canadienne, 28 schémas explicatifs. Audit final du 28 octobre 2026 : réouverture et contrôle de chacune des références citées, revue de cohérence interne, factuelle et juridique de tous les chapitres, et intégration des corrections retenues (annexe F). |

| Version | Date | Nature des changements |
|---|---|---|
| **1.1** | **28 oct. 2026** | **Feuille de route 2027-2030** : calage sur le calendrier 2027-2030; migration MCP avancée dans la phase Plateforme et datée au jalon 2; validation initiale des agents visés par E-23 avant le 1er mai 2027; jalon J2a de conformité au RIA avant le 2 décembre 2027; jalons J4 et J5 pour la phase Mise à l'échelle; N3 entre domaines conditionné au passage par la passerelle; cibles chiffrées des indicateurs fixées au jalon 3; marge pour les périodes de congés; deux risques ajoutés. Plafond d'autonomie par classe ramené à une seule source normative (EXIG-CON-02) et article 65.2 de la Loi sur l'accès ajouté aux critères de la classe élevée. Modifications corrélatives : sommaire, figure 1, sections 1.1, 3.1, 4.1 et 14.2, EXIG-AUT-02, annexe F. |

# Méthode et avertissements

**MÉTHODE D'ÉLABORATION ET DE VALIDATION**

Cette version consolide quatre documents de travail. Chacune des 121 références de la recherche documentaire a été ouverte lorsque la page était accessible (108 sur 121), qualifiée selon sa crédibilité et confrontée aux affirmations qui la citaient; onze vérifications thématiques ont ensuite confronté les affirmations des quatre documents aux textes primaires : spécifications (Model Context Protocol, Agent2Agent, OpenTelemetry, CloudEvents, RFC de l'Internet Engineering Task Force), lois et règlements (Loi 25, règlement européen sur l'IA), normes (National Institute of Standards and Technology, ISO/IEC) et publications officielles des éditeurs. Seules des sources de catégorie A (primaires ou officielles) ou B (secondaires reconnues) sont citées. Le bilan détaillé et les principales corrections figurent à l'annexe F.

**AVERTISSEMENTS**

Les versions, dates et chiffres reflètent l'état des sources au 27 octobre 2026; les versions applicables sont fixées au catalogue d'entreprise, révisé chaque trimestre. Les produits commerciaux sont cités à titre d'exemples non limitatifs. Les obligations légales résumées ici en expriment l'intention : leur application à un cas précis relève des affaires juridiques.

# Table des matières


**Sommaire exécutif** 11
- Pourquoi maintenant 11
- Les dix décisions structurantes 12
- Par où commencer 12

PARTIE I — FONDEMENTS

**1 Objet, portée et mode d'emploi** 15
- 1.1 Objet 15
- 1.2 Portée 15
- 1.3 Public cible et usages par rôle 16
- 1.4 Force normative 17
- 1.5 Structure du document et identifiants 17
- 1.6 Relation avec les autres politiques et cycle de révision 18
- 1.7 Méthode d'élaboration 19

**2 Contexte et enjeux** 20
- 2.1 Où en est l'entreprise agentique en 2026 20
- 2.2 La consolidation des standards ouverts 21
- 2.3 Huit enjeux qui motivent le cadre 23
- 2.4 Pourquoi un cadre commun maintenant 24

**3 Concepts et définitions** 26
- 3.1 Définitions normatives 26
- 3.2 Flux de travail ou agent? 29
- 3.3 Agents interactifs et agents ambiants 29
- 3.4 Ce qu'un agent n'est pas 30

**4 Principes directeurs** 32
- 4.1 Les douze principes 32
- 4.2 Application des principes 35
- 4.3 Arbitrage entre principes et dérogations 36

PARTIE II — ARCHITECTURE, INTEROPÉRABILITÉ ET ORCHESTRATION

**5 Architecture de référence** 39
- 5.1 Vue d'ensemble 39
- 5.2 Responsabilités et règles par couche 41
- 5.3 Plans transversaux 45
- 5.4 Blocs de construction 46
- 5.5 Mémoire des agents 48
- 5.6 Parcours d'une demande de bout en bout 51

**6 Interopérabilité** 52
- 6.1 Quatre niveaux d'interopérabilité et gouvernance intégrée 52
- 6.2 Carte des interactions et protocoles retenus 54
- 6.3 Catalogue des protocoles et standards 56
- 6.4 Matrice de sélection 59

6.5 Intégration verticale : Model Context Protocol 60
6.6 Intégration horizontale : protocole Agent2Agent 74
6.7 Interopérabilité événementielle 82
6.8 Contrats, versionnage et catalogue d'entreprise 88
6.9 Protocoles émergents et veille 91

**7 Orchestration 93**
7.1 Commencer simple : ce que disent les données probantes 93
7.2 Patrons autorisés 94
7.3 Choisir le patron 98
7.4 État et exécution durable 100
7.5 Transactions : patron saga 101
7.6 Idempotence 104
7.7 Contexte transmis entre agents 105
7.8 Résilience et dégradation maîtrisée 106
7.9 Anti-patrons proscrits 107
7.10 Cadriciels et plateformes d'orchestration 108

**8 Autonomie et supervision humaine 110**
8.1 Une échelle unique N0 à N4 110
8.2 Classer un agent : critères 114
8.3 Paliers de risque des outils P0 à P3 116
8.4 Combiner classe de l'agent et palier de l'outil 117
8.5 Approbation humaine vérifiable 118
8.6 Interaction humaine avec les agents ambiants 120
8.7 Éviter l'approbation machinale 122
8.8 Décisions automatisées et droit à la révision 123

PARTIE III — CONFIANCE ET EXPLOITATION

**9 Identité, sécurité et confiance zéro 126**
9.1 La confiance zéro appliquée aux agents 126
9.2 Identité non humaine des agents 127
9.3 Délégation : agir au nom d'une personne 130
9.4 La passerelle d'agents, point d'application des politiques 136
9.5 Menaces propres aux agents 139
9.6 Se défendre contre l'injection d'instructions 141
9.7 Cloisonnement de l'exécution du code 145
9.8 Chaîne d'approvisionnement agentique 150
9.9 Assurance : tests et équipe rouge 152

**10 Observabilité, évaluation et FinOps 154**
10.1 Traçage de bout en bout 154
10.2 Contenu des invites et des réponses 158
10.3 Journal d'audit 159
10.4 Évaluation continue 160
10.5 Économie de l'inférence 163
10.6 Maîtrise des coûts 164

PARTIE IV — GOUVERNANCE, CONFORMITÉ ET MISE EN ŒUVRE

**11 Gouvernance et cycle de vie 169**

11.1 Rôles et responsabilités 169
11.2 Matrice RACI 171
11.3 Modèle opérationnel en étoile 172
11.4 Registre d'entreprise des agents et serveurs MCP 173
11.5 Cycle de vie et points de contrôle 175
11.6 Dérogations 177
11.7 Gouvernance des standards 178

**12 Risques, conformité et réglementation 180**
12.1 Classes de risque des agents 180
12.2 Loi 25 et droit québécois 182
12.3 Cadre fédéral et sectoriel canadien 187
12.4 Règlement européen sur l'IA 189
12.5 NIST AI RMF, ISO/IEC 42001 et normes associées 192
12.6 Matrice de correspondance 194
12.7 Transparence envers les personnes 194
12.8 Incidents agentiques 196
12.9 Évaluation d'impact unifiée 198

**13 Approvisionnement et clauses contractuelles 200**
13.1 Où se situe désormais le risque de verrouillage 200
13.2 Critères d'évaluation des fournisseurs 201
13.3 Clauses contractuelles normatives 203
13.4 Grille d'évaluation 206

**14 Modèle de maturité 208**
14.1 Cinq niveaux et cinq dimensions 208
14.2 Évaluer sa maturité 209
14.3 Lien avec la certification ISO/IEC 42001 et le NIST AI RMF 211

**15 Feuille de route et indicateurs 212**
15.1 Quatre phases et leurs jalons 212
15.2 Les 90 premiers jours 216
15.3 Indicateurs 217
15.4 Facteurs de succès et risques de mise en œuvre 219

ANNEXES — OUTILS D'APPLICATION

**A Grille d'homologation 222**
A.1 Mode d'emploi 222
A.2 Gouvernance, registre et classement 222
A.3 Interopérabilité et contrats 223
A.4 Orchestration et réversibilité 223
A.5 Autonomie et supervision humaine 224
A.6 Identité, sécurité et confiance zéro 224
A.7 Observabilité, évaluation et coûts 225
A.8 Données, vie privée et conformité 225

**B Gabarit de fiche d'agent 226**

**C Exemples de contrats 230**
C.1 Outil MCP 231

C.2 Entrée de catalogue de l'outil 232
C.3 Carte d'agent A2A 232
C.4 Événement CloudEvents 234
C.5 Jeton délégué 235
C.6 Jeton d'approbation humaine 235
C.7 Enveloppe budgétaire de tâche 236
C.8 Enregistrement d'audit 237

**D Registre des exigences 240**

**E Glossaire 250**

**F Validation des sources et des ébauches 262**
F.1 Méthode 262
F.2 Bilan chiffré 263
F.3 Principales corrections apportées aux ébauches 263
F.4 Registre des 121 références de la recherche documentaire 265

**G Références 273**

# Liste des figures


Figure 1 — Le cadre en une page 11
Figure 2 — Du maillage N × M aux contrats communs N + M 23
Figure 3 — Architecture de référence : six couches et trois plans transversaux 39
Figure 4 — Quatre types de mémoire et contrôles d'écriture 49
Figure 5 — Quatre niveaux d'interopérabilité appliqués aux agents 53
Figure 6 — Carte des interactions de l'agent et protocoles retenus 55
Figure 7 — MCP 2026-07-28 derrière la passerelle d'agents 62
Figure 8 — Cycle de vie d'une tâche A2A 1.0 78
Figure 9 — Délégation A2A avec appel MCP et approbation humaine 81
Figure 10 — Chorégraphie événementielle et compteur de sauts 85
Figure 11 — Huit patrons d'orchestration autorisés 95
Figure 12 — Arbre de décision du patron d'orchestration 98
Figure 13 — Saga : transactions locales, pivot et compensations 102
Figure 14 — Échelle d'autonomie N0 à N4 111
Figure 15 — Contrôle exigé selon la classe de l'agent et le palier de l'outil 117
Figure 16 — Approbation humaine signée, liée à l'action exacte 119
Figure 17 — Délégation par échange de jetons et droits effectifs 131
Figure 18 — Contrôles appliqués par la passerelle d'agents à chaque appel 136
Figure 19 — Défense contre l'injection : éviter la triade létale 142
Figure 20 — Niveaux d'isolation pour le code généré 146
Figure 21 — Une trace distribuée de bout en bout 156
Figure 22 — Évaluation en trois paliers 161
Figure 23 — Enveloppe budgétaire d'une tâche 165
Figure 24 — Modèle opérationnel en étoile 172
Figure 25 — Cycle de vie d'un agent et points de contrôle 175
Figure 26 — Réponse à un incident agentique 196
Figure 27 — Modèle de maturité en cinq niveaux 208
Figure 28 — Feuille de route : quatre phases et leurs jalons 212


# Liste des tableaux


Tableau 1 — Portée du cadre 15
Tableau 2 — Parcours de lecture par rôle 16
Tableau 3 — Degrés d'obligation 17
Tableau 4 — Identifiants des principes et préfixes des exigences 18
Tableau 5 — Chronologie vérifiée de la consolidation des standards agentiques (novembre 2024 à octobre 2026) 21
Tableau 6 — Huit enjeux, leurs symptômes et la réponse du cadre 23
Tableau 7 — Définitions normatives du cadre 26
Tableau 8 — Agents interactifs et agents ambiants : conséquences de conception 30
Tableau 9 — Mise en œuvre des principes directeurs 35
Tableau 10 — Tensions fréquentes entre principes et arbitrage retenu 36
Tableau 11 — Apport des plans transversaux à chaque couche 45
Tableau 12 — Correspondance des blocs de construction d'architecture (ABB) et des blocs de construction de solution (SBB) 46
Tableau 13 — Types de mémoire des agents et contrôles applicables 49
Tableau 14 — Niveaux d'interopérabilité et exigences minimales pour une intégration d'agent 53
Tableau 15 — Catalogue des protocoles et standards (état au 27 octobre 2026) 56
Tableau 16 — Matrice de sélection des protocoles 59
Tableau 17 — Principaux changements de la révision MCP 2026-07-28 et effet pour l'entreprise 63
Tableau 18 — Correspondance entre l'OWASP MCP Top 10 (bêta) et les exigences du cadre 73
Tableau 19 — Champs de la carte d'agent A2A 1.0 et règles du cadre 75

Tableau 20 — Attributs d'extension CloudEvents exigés par le cadre 84
Tableau 21 — Garanties d'un bus Kafka et responsabilités de la conception 86
Tableau 22 — Contenu minimal des contrats, par type d'interface 88
Tableau 23 — Principaux composants d'AGNTCY et statut au catalogue (état au 27 octobre 2026) 91
Tableau 24 — Huit patrons d'orchestration autorisés et variante encadrée 95
Tableau 25 — Critères comparés des principaux patrons 99
Tableau 26 — Anti-patrons d'orchestration proscrits 107
Tableau 27 — Cadriciels, moteurs et plateformes d'orchestration (exemples non limitatifs, état au 27 octobre 2026) 108
Tableau 28 — Niveaux d'autonomie : rôles, paliers permis et contrôles minimaux 111
Tableau 29 — Correspondance entre l'échelle du cadre et les autres échelles d'autonomie 114
Tableau 30 — Quatre critères pour fixer le niveau d'autonomie sous le plafond de la classe 115
Tableau 31 — Paliers de risque des outils 116
Tableau 32 — Trois patrons d'interaction avec un agent ambiant 121
Tableau 33 — Composants logiques de la confiance zéro et leur réalisation pour les agents 126
Tableau 34 — Risques de l'OWASP Non-Human Identities Top 10 (2025) et réponse du cadre 129
Tableau 35 — Profil OAuth exigé pour les agents 133
Tableau 36 — Mécanismes d'identité en normalisation : état au 27 octobre 2026 135
Tableau 37 — Référentiels de menaces retenus par le cadre 139
Tableau 38 — Top 10 OWASP des applications agentiques et contrôles du cadre 140
Tableau 39 — Patrons de conception résistants à l'injection et usage recommandé 144
Tableau 40 — Technologies d'isolation du code généré 146
Tableau 41 — Attributs de trace exigés et niveau dans la convention OpenTelemetry v1.41.0 156
Tableau 42 — Familles d'objectifs de niveau de service d'un agent (cibles proposées par le cadre) 161
Tableau 43 — Rôles de la gouvernance agentique 169
Tableau 44 — Matrice RACI du cycle de vie d'un agent 171
Tableau 45 — Répartition des responsabilités dans le modèle en étoile 172
Tableau 46 — Classes de risque des agents : critères, plafond d'autonomie et contrôles minimaux 180
Tableau 47 — Articles de la Loi sur le privé qui touchent les agents 182
Tableau 48 — Textes fédéraux et sectoriels canadiens : statut au 27 octobre 2026 et effet sur les agents 188
Tableau 49 — Articles du règlement européen sur l'IA et réponse du cadre 190
Tableau 50 — Matrice de correspondance : NIST AI RMF, ISO/IEC 42001, Loi 25, RIA et artefacts du cadre 194
Tableau 51 — Délais de notification applicables aux incidents agentiques 196
Tableau 52 — Volets de l'évaluation d'impact unifiée 198
Tableau 53 — Où se loge le verrouillage (état au 27 octobre 2026) 200
Tableau 54 — Grille d'évaluation des fournisseurs de solutions agentiques 206
Tableau 55 — Niveaux de maturité par dimension 208
Tableau 56 — Preuves attendues par niveau de maturité 210
Tableau 57 — Correspondance indicative entre niveaux de maturité, ISO/IEC 42001 et NIST AI RMF 211
Tableau 58 — Phases de mise en œuvre, livrables et autonomie autorisée 213
Tableau 59 — Calage indicatif, mois 0 au 1er décembre 2026 215
Tableau 60 — Plan des 90 premiers jours (phase Fondations) 216
Tableau 61 — Indicateurs de mise en œuvre et cibles proposées 217
Tableau 62 — Risques de mise en œuvre, signes avant-coureurs et parades 219
Tableau 63 — Champs de la fiche d'agent et étape où ils deviennent exigibles 226
Tableau 64 — Exemples de contrats, références et exigences illustrées 230
Tableau 65 — Glossaire des termes et des sigles du cadre 250
Tableau 66 — Catégories de crédibilité des sources 262
Tableau 67 — Verdicts sur les 427 liens affirmation-source de la recherche documentaire 263
Tableau 68 — Principales corrections factuelles 263
Tableau 69 — Registre de validation des références de la recherche documentaire 266

# Sommaire exécutif

Les agents d'IA ne se contentent plus de répondre : ils lisent des systèmes, prennent des décisions et agissent. Ce cadre fixe les règles communes qui permettent de les brancher aux systèmes de l'entreprise, de les faire collaborer et de les orchestrer de façon sûre, traçable, réversible et économiquement maîtrisée, quel que soit le fournisseur. Il est normatif : les chapitres 5 à 13 énoncent des exigences identifiées, vérifiables en revue d'architecture ou en test.

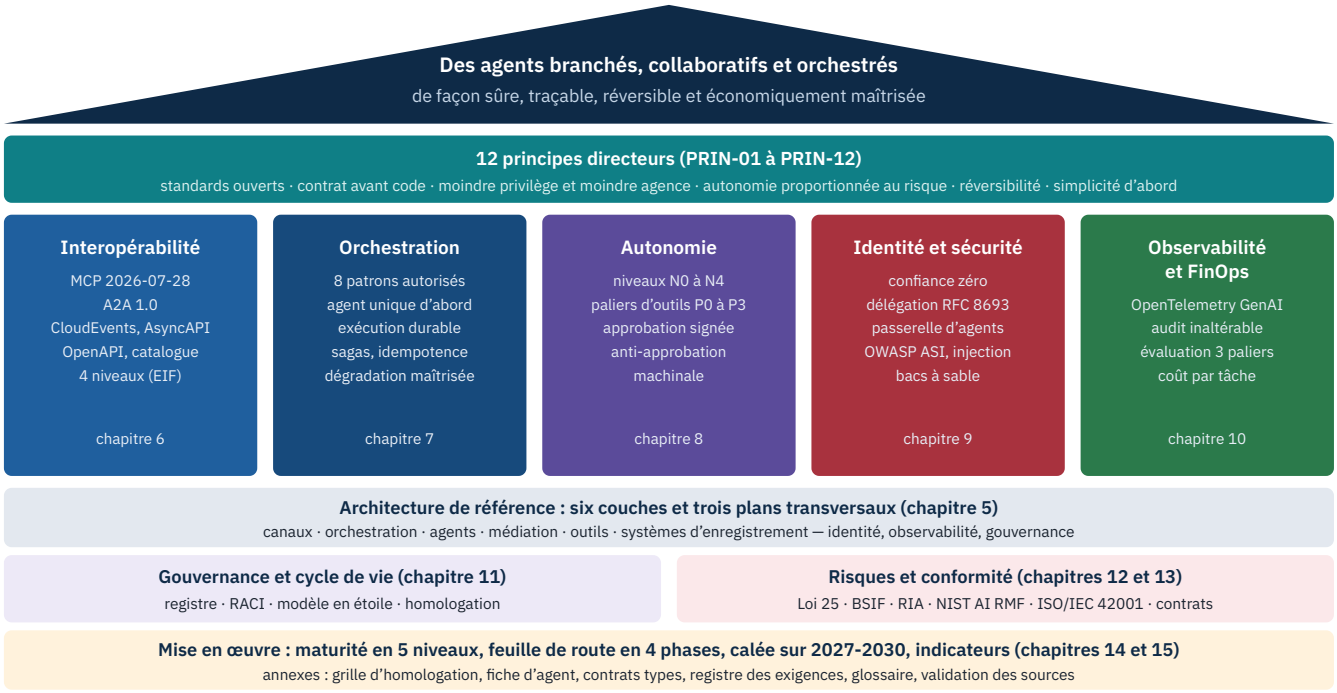



**Figure 1 — Le cadre en une page.** Le toit énonce la finalité; les principes s'appliquent à toutes les décisions; les cinq piliers portent les règles techniques; l'architecture de référence, la gouvernance et la conformité en sont les fondations; la feuille de route en organise le déploiement.

## Pourquoi maintenant

**40 %**
des applications d'entreprise intégreront des agents spécialisés d'ici la fin de 2026, contre moins de 5 % en 2025 (prévision Gartner, août 2025)

**> 40 %**
des projets d'IA agentique seront annulés d'ici la fin de 2027 : coûts, valeur incertaine, contrôles inadéquats (prévision Gartner, juin 2025)

**13 %**
des organisations estiment avoir la bonne gouvernance de leurs agents (Gartner, avril 2026)

**> 150 000**
agents en usage, en moyenne, par entreprise du Fortune 500 d'ici 2028, contre moins de 15 en 2025 (prévision Gartner, avril 2026)

Les agents se multiplient plus vite que les règles pour les relier[1, 2]. Sans cadre commun, chaque équipe recrée ses connecteurs, ses accès et ses contrôles; les annulations annoncées par Gartner tiennent aux coûts, à une valeur d'affaires incertaine et à des contrôles de risque inadéquats, la maturité encore limitée des modèles s'y ajoutant[3]. Les standards, eux, se sont consolidés aux couches agent-outil et agent-agent. Le Model Context Protocol (MCP) et le protocole Agent2Agent (A2A) relèvent désormais tous deux de l'Agentic AI Foundation, fondation neutre de la Linux Foundation[4, 5]. Selon l'analyse du cadre (section 2.4), le risque de verrouillage s'est déplacé des protocoles vers les plateformes : c'est là que le cadre concentre ses exigences.

## Les dix décisions structurantes

Dix décisions résument le cadre; chacune renvoie au chapitre qui la détaille.

1. **Deux protocoles pivots, versions épinglées.** MCP (révision 2026-07-28) relie un agent à ses outils et à ses données; A2A (version 1.0) relie un agent à un autre agent; CloudEvents et AsyncAPI portent les échanges asynchrones. Les API existantes sont exposées par adaptateurs, jamais réécrites. Les versions applicables sont fixées au catalogue, révisé chaque trimestre (chapitre 6).
2. **Rien ne contourne la passerelle ni le catalogue.** En environnement serveur, tout appel d'un agent vers un outil MCP ou vers une donnée ou un agent d'un autre domaine traverse la passerelle d'agents, qui authentifie, autorise, applique les garde-fous, limite les coûts, injecte les secrets et journalise. Un outil absent du catalogue est injoignable (chapitre 5, chapitre 9).
3. **La simplicité d'abord.** Un flux déterministe ou un agent unique bien outillé est le choix par défaut, et l'on n'ajoute de la complexité que si elle améliore les résultats de façon démontrée[6]; le cadre en tire ses propres règles : le multiagent n'est autorisé que sur preuve mesurée de gain, parmi huit patrons autorisés et avec deux niveaux de délégation au plus (chapitre 7).
4. **Une échelle d'autonomie unique.** Les niveaux N0 à N4 plafonnent ce qu'un agent peut faire seul selon la classe de risque; l'autonomie non bornée (NX) est interdite. Les outils sont classés P0 à P3 au catalogue; la règle la plus stricte l'emporte, et toute action critique, externe ou irréversible (P3) exige une approbation humaine signée et liée à l'action exacte (chapitre 8).
5. **Une identité propre à chaque agent, des droits délégués et de courte durée.** Aucun compte partagé ni clé statique; quand un agent agit pour une personne, il reçoit un jeton délégué (échange de jetons, RFC 8693) qui identifie à la fois la personne et l'agent, restreint à une seule ressource cible (audience unique), et dont la portée ne s'élargit jamais d'un saut à l'autre (chapitre 9).
6. **Présomption d'injection.** Tout contenu reçu est une donnée, jamais une instruction. Dès qu'un agent a lu du contenu non fiable, ses capacités d'envoi vers l'extérieur lui sont retirées de façon déterministe; le code qu'il génère s'exécute dans un bac à sable isolé, réseau fermé par défaut (chapitre 9).
7. **Réversibilité par conception.** L'état est enregistré de façon durable hors du modèle à chaque transition; chaque écriture porte une clé d'idempotence; les transactions qui touchent plusieurs systèmes suivent le patron saga avec compensations; un coupe-circuit global est testé chaque trimestre (chapitre 7).
8. **On ne gouverne que ce qu'on voit.** Traçage OpenTelemetry de bout en bout (conventions GenAI épinglées), journal d'audit inaltérable, évaluation en trois paliers, enveloppe budgétaire par tâche et coût par tâche réussie (chapitre 10).
9. **Une personne nommée répond de chaque agent.** Registre d'entreprise obligatoire, cycle de vie à points de contrôle, modèle opérationnel en étoile et comité d'architecture et des risques agentiques (chapitre 11).
10. **Conformité dès la conception.** Loi 25 (évaluation des facteurs relatifs à la vie privée, décisions automatisées, communications hors Québec, incidents), ligne directrice E-23 du Bureau du surintendant des institutions financières (BSIF, pour les institutions financières fédérales) et règlement européen sur l'IA (selon son champ d'application), ainsi que les référentiels volontaires NIST AI RMF et ISO/IEC 42001, sont intégrés aux exigences et à une matrice de correspondance unique (chapitre 12)[7, 8].

## Par où commencer

La mise en œuvre suit quatre phases séparées par trois jalons, vise le niveau 3 de maturité, « Défini », en 18 mois, puis le niveau 4 et la certification ISO/IEC 42001 aux jalons 4 et 5 (chapitre 14, chapitre 15). Les 90 premiers jours établissent les fondations : inventaire de tous les agents et serveurs MCP, propriétaire nommé pour chacun, fin des clés

partagées, passerelle de modèles, traçage pilote, classement des risques et évaluations de vie privée, coupe-circuit testé. Aucun agent ne passe en production sans franchir la grille d'homologation de l'annexe A.

**CE QUI A CHANGÉ PAR RAPPORT AUX ÉBAUCHES**

La vérification a confirmé le fond technique des ébauches, mais a imposé plusieurs corrections : versions de protocoles mises à jour (MCP sans état, A2A 1.0), trois échelles d'autonomie incompatibles remplacées par une seule, chiffres de marché réattribués à leur véritable source ou retirés, obligations de la Loi 25 rattachées aux bons articles, allégations commerciales retirées des exigences. L'annexe F en donne le détail.

PARTIE I

# Fondements

Pourquoi un cadre commun, ce qu'il couvre, le vocabulaire partagé et les principes qui tranchent les décisions d'architecture.

1 · Objet, portée et mode d'emploi

2 · Contexte et enjeux

3 · Concepts et définitions

4 · Principes directeurs

# 1 Objet, portée et mode d’emploi

Ce chapitre dit ce que le cadre règle, à quels systèmes il s’applique et à qui il s’adresse. Il explique comment lire une exigence, comment le document est organisé et comment il évolue. Il présente enfin la méthode qui a servi à l’établir et à vérifier ses faits.

## 1.1 Objet

Le cadre CRE-IA-2026-01 fixe les règles communes qui permettent aux agents d’IA de l’entreprise de se brancher aux systèmes, de collaborer entre eux et d’être orchestrés de façon sûre, traçable, réversible et économiquement maîtrisée, quel que soit le fournisseur. La présente version 1.1, datée du 28 octobre 2026, est soumise à l’approbation du comité d’architecture et des risques agentiques. Le cadre poursuit quatre objectifs :

- donner à toutes les équipes un vocabulaire commun (chapitre 3);
- fixer les protocoles retenus, les patrons d’orchestration autorisés et les niveaux d’autonomie permis (chapitres 5 à 8);
- encadrer l’identité, la sécurité, l’observabilité, les coûts, la gouvernance et la conformité des agents (chapitres 9 à 13);
- offrir une trajectoire de maturité mesurable et une grille d’homologation applicable à chaque projet (chapitres 14 et 15, annexe A).

Le cadre est normatif et neutre à l’égard des fournisseurs. Il règle ce qui doit rester sous le contrôle de l’entreprise, quelle que soit la plateforme : contrats d’interface, identités et délégations, passage obligé par la passerelle d’agents, traces et journal d’audit, registre, plafonds d’autonomie et de coûts. Il ne choisit aucun produit : ceux qu’il cite sont des exemples non limitatifs, à l’état du 27 octobre 2026. Il ne tient pas lieu d’avis juridique (chapitre 12).

## 1.2 Portée

Cette section délimite les systèmes visés. Le critère est fonctionnel : ce qui compte n’est pas l’étiquette commerciale d’un système, mais sa capacité à appeler des outils ou à agir sur des systèmes et des données de l’entreprise.

**Tableau 1 — Portée du cadre**

| Catégorie | Dans la portée | Hors portée |
|---|---|---|
| Agents internes | Tout agent bâti à l’interne, en pilote ou en production, qui lit ou modifie des systèmes ou des données de l’entreprise | Assistant conversationnel sans outil ni capacité d’action, régi par la politique d’usage de l’IA |
| Agents achetés | Agents intégrés aux logiciels-services *(software as a service, SaaS)* et aux progiciels, dès que l’entreprise ou une équipe métier les active | Fonction dite « agentique » qui n’appelle aucun outil et n’agit sur rien |
| Agents de tiers | Agents de partenaires, de fournisseurs ou de clients qui échangent avec les agents ou les systèmes de l’entreprise | Fonctionnement interne de ces agents : le cadre en régit les interfaces, les identités et les contrats |
| Outils et données | Serveurs MCP internes ou externes, outils, API, événements et sources de données exposés aux agents | Systèmes d’enregistrement eux-mêmes, que le cadre n’oblige pas à modifier |

| Catégorie | Dans la portée | Hors portée |
|---|---|---|
| Plateformes | Plateformes et moteurs d'orchestration, passerelles d'agents et de modèles, registres et catalogues | Choix des fournisseurs de modèles, qui relève de l'architecture d'entreprise et de l'approvisionnement |
| Modèles et automatisation | Usage des modèles par les agents; flux déterministe qui appelle un agent ou qui est appelé par lui | Entraînement et ajustement fin des modèles; automatisation robotisée des processus (RPA) sans composante agentique |

Trois règles tranchent les cas limites. Un assistant qui reçoit un premier outil, même en lecture seule, entre dans la portée dès ce moment. À l'inverse, une fonction qu'un éditeur qualifie d'agentique n'y entre que si elle appelle des outils ou agit : Gartner observait d'ailleurs, en juin 2025, que de nombreux produits existants étaient simplement rebaptisés « agentiques »[3]. En cas de doute, le système est traité comme visé et inscrit au registre (section 11.4).

## 1.3 Public cible et usages par rôle

Le cadre s'adresse à toutes les fonctions qui conçoivent, exploitent, financent ou contrôlent des agents. Personne n'a besoin de tout lire : le tableau 2 indique, pour chaque rôle, par où commencer.

**Tableau 2 — Parcours de lecture par rôle**

| Rôle | À lire en priorité |
|---|---|
| Direction TI et comité d'architecture et des risques agentiques | Sommaire, chapitres 2, 4, 14 et 15 |
| Architectes d'entreprise et de solutions | Chapitres 3 à 8, annexe A |
| Équipes de plateforme et d'intégration | Chapitres 5, 6, 9 et 10, annexe C |
| Équipes produit qui bâtissent des agents | Chapitres 3, 7, 8 et 10, annexes A à C |
| Sécurité de l'information | Chapitres 8 et 9, section 12.8 |
| Risques, conformité, affaires juridiques et protection des renseignements personnels (RP) | Chapitres 11 et 12, section 8.8 |
| FinOps | Sections 10.5 et 10.6, chapitre 13 |
| Responsables métier, parrains d'agents | Sommaire, chapitres 3, 8 et 11, annexe B |
| Approvisionnement | Chapitre 13, section 6.3 |
| Audit interne | Annexes A et D, sections 11.4 et 12.6 |

### Appliquer le cadre à un projet

1. Vérifier la portée et inscrire le système au registre dès la conception (annexe B).
2. Classer le risque (section 12.1), fixer le niveau d'autonomie sous le plafond de la classe (section 8.1) et déterminer les évaluations d'impact requises (section 12.9).
3. Retenir l'option la plus simple qui suffit, puis le patron d'orchestration (section 7.3).
4. Choisir les protocoles (section 6.3) et publier les contrats au catalogue d'entreprise (section 6.8).
5. Appliquer les exigences pertinentes (annexe D); justifier par écrit tout écart à une recommandation (niveau DEVRAIT) et obtenir une dérogation pour tout écart à une obligation (niveau DOIT) (section 11.6).
6. Remplir la grille d'homologation (annexe A) avant toute mise en production.

## 1.4 Force normative

Cette section explique comment lire une exigence. Le cadre emploie trois degrés d'obligation, inspirés des mots-clés de la RFC 2119 de l'Internet Engineering Task Force (IETF) et mis en évidence dans le texte.

**Tableau 3 — Degrés d'obligation**

| Expression | Sens | Écart admis |
|---|---|---|
| doit, ne doit pas | Obligation | Aucun, sauf dérogation écrite approuvée par le comité (ou, pour un agent de classe faible, par l'architecture d'entreprise sur délégation du comité), limitée dans le temps et assortie de mesures compensatoires (section 11.6). Certaines obligations n'admettent aucune dérogation (section 4.3 et EXIG-GOV-17). |
| devrait, ne devrait pas | Recommandation | Admis s'il est justifié par écrit dans la fiche d'agent ou la décision d'architecture; la revue d'architecture contrôle la justification. |
| peut | Option | Sans objet. |

Chaque exigence occupe un bloc qui réunit un identifiant stable (par exemple EXIG-AUT-09), son degré d'obligation, un titre court, un énoncé vérifiable en revue d'architecture ou en test, et une justification introduite par « Pourquoi ». Seuls ces blocs d'exigences (chapitres 5 à 13), les principes directeurs PRIN-01 à PRIN-12 (chapitre 4) et les tableaux auxquels une exigence renvoie expressément créent une obligation normative; le reste du texte, les exemples et les figures sont informatifs.

### Exigence externe ou choix du cadre

Le cadre distingue toujours ce qui vient d'un texte externe de ce qu'il décide lui-même. « La spécification MCP exige » ou « selon l'article 14 du règlement (UE) 2024/1689 sur l'IA (RIA) » rapportent le contenu d'une norme ou d'une loi, vérifié à la source. « Le cadre fixe » ou « choix du cadre » signalent une décision interne, que le comité peut réviser. Exemple : Microsoft exige un plafond d'itérations pour la boucle producteur-vérificateur, sans en fixer la valeur[9]; le plafond de trois itérations retenu au chapitre 7 est donc un choix du cadre. Le cadre n'attribue jamais à une norme une exigence qu'elle ne contient pas et présente ses seuils chiffrés (délais, plafonds, fréquences) comme les siens.

> **À RETENIR**
>
> Trois règles de lecture : un fait externe porte sa source et sa date; un chiffre de fournisseur est présenté comme une allégation de ce fournisseur; un produit cité est un exemple, jamais une exigence.

## 1.5 Structure du document et identifiants

Le document compte quinze chapitres en quatre parties : Fondements (chapitres 1 à 4); Architecture, interopérabilité et orchestration (5 à 8); Confiance et exploitation (9 et 10); Gouvernance, conformité et mise en œuvre (11 à 15). Sept annexes, de A à G, fournissent les outils d'application, le glossaire et les références.

Les douze principes directeurs portent les identifiants PRIN-01 à PRIN-12. Chaque exigence porte un identifiant de la forme EXIG-XXX-NN : un préfixe de trois caractères propre à un domaine, puis un numéro à deux chiffres, continu pour chaque préfixe. Les chapitres 1 à 4, 14 et 15 et les annexes ne créent pas d'exigences numérotées; l'annexe D récapitule toutes les exigences dans l'ordre du document. Choix du cadre : un identifiant n'est jamais réattribué, et une exigence retirée lors d'une révision conserve son numéro, marqué « retirée ». Le tableau 4 donne la liste des préfixes.

**Tableau 4 — Identifiants des principes et préfixes des exigences**

| Identifiant ou préfixe | Domaine | Emplacement |
|---|---|---|
| PRIN-01 à PRIN-12 | Principes directeurs | Chapitre 4 |
| EXIG-ARC | Architecture de référence | Chapitre 5 |
| EXIG-INT | Interopérabilité, contrats et catalogue d'entreprise | Sections 6.1 à 6.4, 6.8 et 6.9 |
| EXIG-MCP | Model Context Protocol | Section 6.5 |
| EXIG-A2A | Protocole Agent2Agent | Section 6.6 |
| EXIG-EVT | Interopérabilité événementielle | Section 6.7 |
| EXIG-ORC | Orchestration | Chapitre 7 |
| EXIG-AUT | Autonomie et supervision humaine | Chapitre 8 |
| EXIG-IAM | Confiance zéro, identité, délégation et passerelle d'agents | Sections 9.1 à 9.4 |
| EXIG-SEC | Menaces propres aux agents et défenses | Sections 9.5 à 9.9 |
| EXIG-OBS | Traçage et journal d'audit | Chapitre 10 |
| EXIG-EVA | Évaluation continue | Chapitre 10 |
| EXIG-FIN | Économie de l'inférence et maîtrise des coûts | Chapitre 10 |
| EXIG-GOV | Gouvernance et cycle de vie | Chapitre 11 |
| EXIG-CON | Risques, conformité et réglementation | Chapitre 12 |
| EXIG-APP | Approvisionnement et clauses contractuelles | Chapitre 13 |

Un terme anglais figure entre parenthèses et en italique à sa première occurrence, comme transfert *(handoff)*; les noms de protocoles, de champs et de méthodes restent en police à chasse fixe, comme `tools/call`. Les appels de citation renvoient à l'annexe G.

## 1.6 Relation avec les autres politiques et cycle de révision

Le cadre complète, sans les remplacer, les politiques de sécurité de l'information, de gouvernance des données, de protection des RP, d'usage de l'IA, de gestion des risques et d'approvisionnement. Celles-ci continuent de régir leur objet; le cadre en précise l'application aux agents. Choix du cadre : lorsqu'une règle du cadre et celle d'une autre politique visent le même objet, la plus stricte s'applique, et toute contradiction est soumise au comité. Le droit applicable et les engagements contractuels priment toujours (section 4.3).

Deux rythmes de révision coexistent, semestriel pour le cadre et trimestriel pour le catalogue; les versions applicables suivent celui du catalogue.

- **Le cadre** est révisé chaque semestre par le comité, à partir des dérogations accordées, des incidents, des résultats d'homologation et de la veille; une révision extraordinaire suit tout incident agentique grave ou changement réglementaire majeur. Une dérogation souvent renouvelée signale une règle à revoir.
- **Le catalogue des protocoles et standards** est révisé au moins chaque trimestre (section 6.3 et section 11.7); un correctif de sécurité peut justifier une révision extraordinaire.
- **Les versions applicables**, comme MCP 2026-07-28 ou A2A 1.0, sont fixées au catalogue et non dans le texte : en cas d'écart, le catalogue fait foi.

Chaque révision porte un numéro de version et une date, et s’accompagne d’un relevé des modifications. La mise en conformité des agents déjà en service suit les phases et les jalons du chapitre 15.

## 1.7 Méthode d’élaboration

La version 1.0 consolide quatre ébauches : une recherche documentaire appuyée sur 121 références, deux versions de travail successives du cadre et une version structurée en exigences. Elle suit la structure de la version de travail la plus récente, y intègre les exigences des autres ébauches et les réécrit pour qu’elles soient vérifiables. Chaque fait a ensuite été vérifié, aux 27 et 28 octobre 2026, contre des sources primaires ou, à défaut, secondaires reconnues, en trois passes :

1. la validation, une à une, des 121 références : chaque affirmation qui en citait une a été confrontée à la source (427 liens au total), au contenu réel de la page lorsqu’elle était accessible (108 références sur 121) et, sinon, à des sources équivalentes, faute de quoi elle a été déclarée invérifiable;
2. onze vérifications thématiques, de MCP au droit québécois, qui ont confronté les ébauches aux textes primaires et recueilli des faits complémentaires;
3. un audit final de cohérence interne, factuelle et juridique de l’ensemble des chapitres et des références citées.

Les sources sont classées en trois catégories : A, primaires ou officielles; B, secondaires reconnues; C, blogues de positionnement ou agrégateurs. Seules les catégories A et B sont citées. Un fait réfuté ou invérifiable a été corrigé, retiré ou, lorsqu’il exprimait une décision utile, conservé comme choix du cadre et signalé comme tel.

La vérification a deux limites. Elle reflète l’état des textes aux 27 et 28 octobre 2026, alors que plusieurs standards évoluent d’un trimestre à l’autre. Certains textes payants, comme les normes ISO/IEC, ont été vérifiés par leur fiche de catalogue et des sources secondaires concordantes; le cadre évite donc de les citer textuellement. L’annexe F détaille la méthode, le bilan et les corrections.

# 2 Contexte et enjeux

Les agents d'IA se multiplient plus vite que les règles qui les relient entre eux et aux systèmes de l'entreprise. Ce chapitre dresse l'état des lieux au 27 octobre 2026 à partir de données datées et attribuées, retrace la consolidation des standards ouverts depuis 2024 et nomme les huit enjeux qui motivent le cadre. Il explique enfin pourquoi agir maintenant : les protocoles se sont stabilisés, mais la gouvernance de chaque plateforme s'arrête à sa propre frontière.

## 2.1 Où en est l'entreprise agentique en 2026

Cette section situe le cadre dans les faits. L'entreprise agentique désigne ici une organisation où des agents exécutent une part croissante des processus, aux côtés des personnes et des systèmes existants, sous une supervision humaine proportionnée au risque. Les chiffres qui suivent donnent des ordres de grandeur; ils ne remplacent pas les mesures que chaque organisation tire de son propre registre.

**40 %**
des applications d'entreprise intégreront des agents spécialisés par tâche d'ici la fin de 2026, contre moins de 5 % en 2025 (prévision Gartner, août 2025)[1]

**> 40 %**
des projets d'IA agentique seront annulés d'ici la fin de 2027 (prévision Gartner, juin 2025)[3]

**98 %**
des répondants FinOps gèrent désormais des dépenses d'IA, contre 31 % en 2024 (State of FinOps 2026)[10]

**82 : 1**
identités machines par identité humaine, selon une enquête de fournisseur (CyberArk, avril 2025)[11]

### Une adoption large, une industrialisation encore rare

Les prévisions des analystes décrivent une diffusion rapide. Gartner prévoit que 40 % des applications d'entreprise intégreront des agents spécialisés d'ici la fin de 2026 et que l'IA agentique pourrait représenter environ 30 % des revenus des logiciels d'application d'entreprise d'ici 2035[1]. Le même cabinet anticipe qu'en 2028, au moins 15 % des décisions de travail quotidiennes seront prises de façon autonome par l'IA agentique, contre 0 % en 2024[3].

Les enquêtes montrent toutefois un écart entre l'expérimentation et la production. Selon l'édition 2025 de l'enquête de McKinsey (novembre 2025; dernière édition dont les résultats détaillés sont publiés à cette adresse), 88 % des répondants disent que leur organisation utilise régulièrement l'IA dans au moins une fonction, mais seulement 39 % déclarent un effet sur le bénéfice avant intérêts et impôts (BAII) à l'échelle de l'entreprise. Si 62 % des organisations au moins expérimentent des agents, 23 % seulement disent déployer à l'échelle un système agentique quelque part dans l'entreprise; dans une fonction d'affaires donnée, cette part ne dépasse pas 10 %[12].

Les plateformes et les protocoles, eux, sont déjà largement diffusés. En mai 2025, Microsoft indiquait que plus de 230 000 organisations, dont 90 % du Fortune 500, avaient déjà utilisé Copilot Studio; il s'agit d'un usage cumulatif, non d'un nombre de déploiements actifs[13]. En décembre 2025, le Model Context Protocol (MCP) comptait 10 000 serveurs actifs et plus de 97 millions de téléchargements mensuels de ses trousses de développement[14]. En avril 2026, le protocole Agent2Agent (A2A) réunissait plus de 150 organisations et était intégré à Azure AI Foundry, à Copilot Studio et à Amazon Bedrock AgentCore[15]. Côté dépenses, Menlo Ventures estime, selon un sondage auprès d'entreprises américaines, que les entreprises ont consacré 37 G$ US à l'IA générative en 2025, soit 3,2 fois plus que les 11,5 G$ US estimés pour 2024 (estimation hors inférence)[16].

### Des échecs annoncés et une pression sur les coûts

Gartner prévoit que plus de 40 % des projets d'IA agentique seront annulés d'ici la fin de 2027 en raison de coûts croissants, d'une valeur d'affaires incertaine ou de contrôles des risques inadéquats. Le cabinet dénonce aussi l'étiquetage agentique abusif *(agent washing)*, soit des produits existants rebaptisés « agentiques » : seuls quelque 130 des milliers de fournisseurs qui se disent agentiques le seraient réellement[3].

La pression financière est déjà visible. Selon le rapport State of FinOps 2026 (1 192 répondants), 98 % des répondants FinOps gèrent des dépenses d'IA, contre 63 % en 2025 et 31 % en 2024, et la gestion des coûts de l'IA est la première compétence à développer[10]. La forme même du système pèse sur la facture : selon Anthropic, un agent consomme environ 4 fois plus de jetons qu'une conversation, et un système multiagent environ 15 fois plus[17]. Le choix du patron d'orchestration est donc aussi une décision économique (section 7.1 et section 10.5).

### Une surface de risque qui s'élargit

Selon IBM et le Ponemon Institute (juillet 2025), 13 % des organisations ont déclaré une violation touchant un modèle ou une application d'IA; parmi elles, 97 % n'avaient pas de contrôles d'accès propres à l'IA. Les organisations où l'IA fantôme *(shadow AI)* est répandue ont payé en moyenne 670 000 $ US de plus par violation, et une organisation sur cinq a subi une violation attribuable à cette IA non gouvernée[18]. L'édition 2026 établit le coût moyen mondial d'une violation à 4,99 M$ US (hausse de 12 %) et recommande, pour les agents, des contrôles d'accès dynamiques fondés sur l'identité et appliqués en continu à l'exécution[19].

Les identités non humaines dépassent déjà largement les identités humaines. Dans l'enquête 2025 de CyberArk (2 600 décideurs de 20 pays, dont le Canada; dernière édition dont ce ratio est publiquement vérifié), on compte 82 identités non humaines (« identités machines » selon CyberArk) par identité humaine; 68 % des répondants déclarent que leur organisation manque de contrôles de sécurité des identités pour l'IA[11]. Face à la prolifération des agents, Gartner (avril 2026) recommande six mesures, dont un inventaire centralisé qui inclut les agents fantômes, et observe que bloquer les agents pousse les employés vers l'IA fantôme[2].

> **ATTENTION**
> Les chiffres de Gartner sont des prévisions; ceux de McKinsey, de la FinOps Foundation, d'IBM et de Menlo Ventures proviennent d'enquêtes ou d'estimations; ceux de CyberArk, de Microsoft et d'Anthropic sont des données de fournisseurs. Le cadre n'en tire aucune exigence chiffrée. Il exige plutôt que chaque organisation mesure ses propres valeurs (agents inscrits, identités non humaines, coût par tâche réussie) à partir de son registre et de sa télémétrie (section 10.6, section 11.4 et chapitre 15).

## 2.2 La consolidation des standards ouverts

En deux ans, les échanges entre agents et outils, puis entre agents, sont passés de protocoles lancés par des éditeurs à des projets sous gouvernance neutre. Le tableau 5 retrace les jalons vérifiés qui fondent les choix du catalogue des protocoles (section 6.3).

**Tableau 5 — Chronologie vérifiée de la consolidation des standards agentiques (novembre 2024 à octobre 2026)**

| Date | Jalon | Portée pour l'entreprise |
|---|---|---|
| 25 nov. 2024 | Anthropic annonce le Model Context Protocol (MCP), norme ouverte de raccordement des agents aux outils et aux données[20] | Naissance du standard vertical agent → outil |
| 9 avr. 2025 | Google annonce le protocole Agent2Agent (A2A) avec plus de 50 partenaires[21] | Premier protocole agent → agent largement appuyé |

| Date | Jalon | Portée pour l'entreprise |
|---|---|---|
| 23 juin 2025 | A2A est confié à la Linux Foundation; plus de 100 entreprises l'appuient[22] | Gouvernance neutre de l'axe horizontal |
| 29 juill. 2025 | La Linux Foundation accueille AGNTCY, lancé par Cisco en mars 2025 avec LangChain et Galileo[23] | Briques de découverte, d'identité et de messagerie, hors de l'Agentic AI Foundation (AAIF) |
| Août 2025 | L'Agent Communication Protocol (ACP) d'IBM fusionne dans A2A[24] | Un protocole concurrent de moins entre agents |
| 8 sept. 2025 | Lancement du registre officiel MCP en préversion[25] | Découverte publique; les serveurs privés restent à la charge de l'entreprise |
| Sept. 2025 | Google publie l'Agent Payments Protocol (AP2, 16 septembre); OpenAI et Stripe publient l'Agentic Commerce Protocol (29 septembre)[26, 27] | Le commerce agentique démarre en ordre dispersé |
| 9 déc. 2025 | La Linux Foundation crée l'Agentic AI Foundation (AAIF), cofondée par Anthropic, Block et OpenAI; MCP, goose et AGENTS.md en sont les projets fondateurs[4]. Le même jour, l'Open Worldwide Application Security Project (OWASP) publie son Top 10 des applications agentiques[28] | MCP passe sous gouvernance neutre; un référentiel commun des menaces apparaît |
| 12 mars 2026 | Publication d'A2A 1.0.0, première version stable; correctif 1.0.1 le 28 mai 2026[29, 30] | Base contractuelle stable pour les cartes d'agent |
| 4 juin 2026 | agentgateway (créé par Solo.io, à la Linux Foundation depuis août 2025) devient un projet de l'AAIF[31, 32] | Passerelle ouverte pour MCP, A2A et les modèles |
| 28 juill. 2026 | Publication de la révision MCP 2026-07-28 : protocole sans état et cycle de vie formel des fonctionnalités[33, 34] | Exploitation à grande échelle; dépréciations à planifier |
| 17 août 2026 | A2A est annoncé comme projet de l'AAIF au stade « Growth » (approbation du conseil d'administration le 4 août)[5, 35] | MCP et A2A relèvent de la même fondation |
| 9 sept. 2026 | Envoy AI Gateway, renommé Agent Router, rejoint l'AAIF[36] | Autre option ouverte de passerelle de modèles et d'outils |
| 12 oct. 2026 | Cisco propose AGNTCY à l'AAIF (proposition n$^{o}$ 57, sans décision au 27 octobre 2026)[37] | AGNTCY reste un projet de la Linux Foundation, candidat à l'AAIF |
| 22 oct. 2026 | L'AAIF annonce quatre nouveaux projets et en héberge désormais dix[38] | Écosystème en expansion, à suivre chaque trimestre |

## Ce que la consolidation règle

Les deux axes principaux d'interaction relèvent désormais d'une même fondation neutre. Le guide officiel d'A2A les distingue clairement : MCP relie un agent à des outils et à des ressources dont les entrées et les sorties sont définies, souvent sans état; A2A relie des agents autonomes, potentiellement opaques, qui raisonnent et conservent un état au fil d'échanges à plusieurs tours[39]. Les règles d'évolution deviennent aussi prévisibles : depuis la révision 2026-07-28, une fonctionnalité MCP dépréciée reste dans la spécification au moins douze mois avant de pouvoir être retirée, sauf retrait accéléré exceptionnel d'au moins 90 jours[34]. Pour l'entreprise, le choix d'un protocole n'est plus un pari sur un éditeur.

### Ce qu'elle ne règle pas

La convergence reste partielle. AGNTCY n'est pas un projet de l'AAIF, et le commerce agentique demeure fragmenté entre l'Agentic Commerce Protocol d'OpenAI et de Stripe, AP2, confié à la FIDO Alliance, et l'Universal Commerce Protocol (UCP), porté par Google et des détaillants; l'AAIF a d'ailleurs ouvert un groupe de travail sur le commerce agentique[40, 41]. L'admission à l'AAIF suit un processus formel : un projet n'est officiel qu'une fois son admission approuvée et annoncée[42]. Enfin, le registre officiel MCP demeure en préversion, ne prend pas en charge les serveurs privés et recommande aux entreprises d'héberger leur propre registre MCP privé[43]. Le catalogue d'entreprise reste donc une responsabilité interne (section 6.8 et section 11.4); la veille sur les protocoles émergents est traitée à la section 6.9.

> **À RETENIR**
>
> Les protocoles disent comment les agents se parlent. Ils ne disent ni qui a le droit d'agir, ni ce qui doit être journalisé, ni combien une tâche peut coûter. Ces règles relèvent de l'entreprise : c'est l'objet du présent cadre.

## 2.3 Huit enjeux qui motivent le cadre

Sans règles communes, chaque équipe recrée ses connecteurs, ses accès et ses contrôles, et l'entreprise perd la vue d'ensemble. Le premier enjeu, la prolifération des intégrations, est le plus visible; la figure 2 l'illustre.

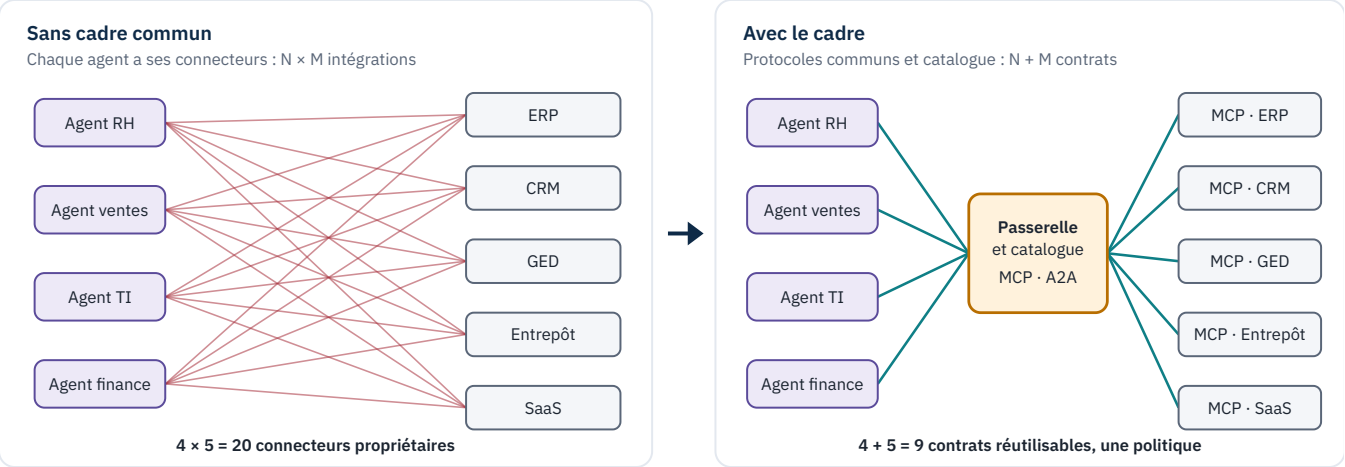



**Figure 2 — Du maillage N × M aux contrats communs N + M.** À gauche, chaque agent possède ses propres connecteurs vers chaque système : quatre agents et cinq systèmes exigent vingt intégrations, chacune avec sa sécurité. À droite, chaque agent et chaque système publient un seul contrat derrière la passerelle et le catalogue : neuf contrats réutilisables, soumis à une politique unique.
Source : élaboration du cadre CRE-IA-2026-01; exemple illustratif.

Anthropic présente MCP comme un protocole unique qui remplace des connecteurs sur mesure et fragmentés[20]; l'expression « N × M » est une vulgarisation de ce bénéfice, non un énoncé de la spécification. Le calcul illustre l'ordre de grandeur : 50 agents et 200 systèmes représentent 10 000 intégrations potentielles, contre 250 contrats. Le gain n'existe toutefois que si le catalogue est unique; des catalogues multiples recréent le maillage au niveau de la gouvernance. Le tableau 6 présente les huit enjeux et la réponse que le cadre leur apporte.

**Tableau 6 — Huit enjeux, leurs symptômes et la réponse du cadre**

| Enjeu | Symptôme sans cadre | Réponse du cadre |
|---|---|---|
| 1. Prolifération des intégrations | N agents × M systèmes = N × M connecteurs propriétaires à maintenir et à sécuriser | Protocoles communs et catalogue d'entreprise unique (PRIN-01, PRIN-02; section 6.3 et section 6.8) |

| Enjeu | Symptôme sans cadre | Réponse du cadre |
|---|---|---|
| 2. Logique métier confiée au modèle | Routage, calculs et règles d'affaires laissés au raisonnement probabiliste : dérives, boucles, résultats non reproductibles | Flux déterministe autour du modèle et patron le plus simple qui suffit (PRIN-08; chapitre 7) |
| 3. Silos d'agents | Les agents de plateformes différentes ne peuvent pas se déléguer de tâches; les mêmes capacités sont bâties plusieurs fois | Carte d'agent, protocole A2A et catalogue d'entreprise comme source de découverte (section 6.6 et section 6.8) |
| 4. Accès excessifs et identités non humaines | Comptes de service partagés, clés d'API statiques, droits larges et permanents; impossible de savoir quel agent a agi | Identité propre à chaque agent, délégation par jeton, moindre privilège et moindre agence (PRIN-03; chapitre 9) |
| 5. Décisions non traçables | Impossible d'expliquer une action ou de remonter la chaîne mandant → agent → outil | Traçage de bout en bout et journal d'audit inaltérable (PRIN-06; section 10.1 et section 10.3) |
| 6. Effets non maîtrisés et coûts | Boucles, actions irréversibles sans approbation, factures d'inférence imprévisibles | Niveaux d'autonomie N0 à N4, paliers d'outils P0 à P3, compensation et enveloppes budgétaires (PRIN-04, PRIN-05; chapitre 8 et section 10.6) |
| 7. Agents fantômes | Agents créés hors inventaire, sans propriétaire nommé ni moyen de révocation | Registre obligatoire, aucun jeton de production sans fiche complète et à jour, cycle de vie contrôlé (chapitre 11) |
| 8. Obligations légales | Renseignements personnels (RP) traités sans évaluation; décisions automatisées non divulguées; incidents impossibles à reconstituer | Évaluation des facteurs relatifs à la vie privée (EFVP), transparence, droit à la révision et gestion des incidents (chapitre 12) |

Ces enjeux se présentent rarement isolément. Prenons un agent créé dans une plateforme SaaS par une équipe métier, hors inventaire, qui utilise un compte de service partagé pour mettre à jour un système financier sans approbation humaine et sans laisser de trace exploitable. À lui seul, il réunit les enjeux 4, 5, 6 et 7. C'est pourquoi le cadre traite ensemble l'identité, la passerelle, le registre et le traçage, plutôt que comme des chantiers séparés.

## 2.4 Pourquoi un cadre commun maintenant

Trois évolutions convergent en 2026 et rendent un cadre commun à la fois possible et nécessaire.

### La gouvernance native s'arrête à la frontière de chaque plateforme

Des éditeurs de passerelles soutiennent que la gouvernance native d'une plateforme ne se transfère pas aux autres : selon TrueFoundry, une règle de prévention des fuites de données d'un écosystème ne s'applique pas à l'agent d'un autre; selon MuleSoft, la gouvernance native d'un nuage devient insuffisante dès que plusieurs environnements d'exécution coexistent[44, 45]. Ces fournisseurs ont un intérêt commercial dans la thèse; il s'agit d'un argument d'architecture, non d'un constat mesuré. Les faits publiés vont néanmoins dans le même sens. Microsoft Agent 365, en disponibilité générale depuis le 1er mai 2026, offre un registre et des contrôles comme le blocage des agents non gérés, mais sa synchronisation avec Amazon Bedrock et Google Cloud est en préversion et les actions de cycle de vie sur les agents infonuagiques de tiers sont seulement annoncées[46]. ServiceNow a annoncé le 5 mai 2026 l'extension de son AI Control Tower pour découvrir et gouverner l'IA déployée dans n'importe quel système[47]. Chaque éditeur propose son plan de contrôle; une entreprise qui exploite plusieurs plateformes en aura plusieurs, et la couverture de l'ensemble de ses agents par un seul d'entre eux reste à démontrer.

Exemple concret : un agent de Copilot Studio délègue par A2A une vérification à un agent Agentforce, qui met à jour un dossier dans ServiceNow par MCP. Les trois plateformes prennent en charge ces protocoles (pour ServiceNow, un serveur MCP en disponibilité générale, ainsi que A2A et MCP par l'AI Agent Fabric)[48, 49, 50, 51], mais la demande traverse

trois registres, trois moteurs de politiques et trois journaux. Le mandant, l'identifiant de trace et les plafonds de la tâche doivent pourtant la suivre de bout en bout. Gartner recommande en ce sens une structure unifiée en couches qui combine gestion, orchestration et application des politiques, capable d'arrêter rapidement un agent qui dérape (résumé public, août 2026)[52]. Le cadre place ce point de contrôle neutre au niveau du transport : passerelle d'agents, identité et registre (chapitre 5 et section 9.4).

### Le risque de verrouillage s'est déplacé des protocoles vers les plateformes

Avec MCP et A2A sous gouvernance neutre, le risque ne tient plus au choix du protocole, mais à ce que les plateformes conservent : extensions propriétaires, définitions d'orchestration, mémoires, identités et unités de facturation. Depuis juillet 2026, par exemple, Copilot Studio crée automatiquement une identité Microsoft Entra Agent ID pour chaque nouvel agent, sans possibilité de désactivation au niveau de l'environnement[48]. Chaque éditeur a aussi ses propres unités : les crédits Copilot, qui servent à facturer l'usage, chez Microsoft; chez Salesforce, les crédits Flex, qui servent à facturer l'usage, et les « Agentic Work Units », qui mesurent l'activité agentique livrée sans être une unité de facturation[53, 54, 55]. Le cadre exige donc que l'entreprise garde la propriété de sa logique d'orchestration, de ses contrats d'outils et de sa mémoire (PRIN-09), et qu'elle l'inscrive dans ses contrats d'approvisionnement (section 13.3 et section 13.1).

### Les obligations se précisent

Le contexte réglementaire ne laisse plus de place à l'improvisation. La Loi 25 (L.Q. 2021, c. 25) est en vigueur pour l'essentiel depuis le 22 septembre 2024, date de sa dernière étape majeure, le droit à la portabilité. Depuis le 22 septembre 2023, elle exige, dans les cas prévus, l'évaluation des facteurs relatifs à la vie privée (EFVP) et encadre les décisions fondées exclusivement sur un traitement automatisé[7, 56]. Le règlement (UE) 2024/1689 sur l'intelligence artificielle (RIA) s'applique de façon générale depuis le 2 août 2026 aux organisations qui relèvent de son champ d'application (art. 2), y compris hors de l'Union lorsque les sorties d'un système y sont utilisées, et le règlement (UE) 2026/1744 fixe au 2 décembre 2027 l'application aux systèmes à haut risque de l'annexe III[57, 58]. Au fédéral, la ligne directrice E-23 du Bureau du surintendant des institutions financières (BSIF), en vigueur le 1er mai 2027 pour les institutions financières fédérales, attend un inventaire d'entreprise des modèles à risque non négligeable, y compris ceux des fournisseurs[8]. Pour y répondre, une organisation a besoin d'un inventaire, d'une classification des risques et de traces conservées au moment des faits, faute de pouvoir les reconstituer après coup (chapitre 12).

**À RETENIR**

Le cadre ne choisit pas de plateforme. Il fixe ce qui reste sous le contrôle de l'entreprise, quelle que soit la plateforme : contrats, identités, passerelle, traces, registre et budgets. Ces règles s'imposent plus facilement à quelques dizaines d'agents qu'à des milliers : c'est maintenant qu'il faut les poser.

# 3 Concepts et définitions

« Agent », « orchestrateur » ou « autonomie » ne désignent pas la même chose d'une équipe ou d'un fournisseur à l'autre. Ce chapitre fixe le sens des termes employés dans tout le cadre, distingue les flux de travail des agents et les agents interactifs des agents ambiants, puis précise ce qu'un agent n'est pas. Le glossaire de l'annexe E complète ces définitions.

## 3.1 Définitions normatives

Les définitions du tableau 7 font foi dans tout le cadre et dans les documents qui s'y rattachent. Lorsqu'une norme ou une loi définit déjà un terme, le cadre reprend sa définition et la précise au besoin.

**Tableau 7 — Définitions normatives du cadre**

| Terme | Définition | Référence |
|---|---|---|
| **Agent** | Selon ISO/IEC 22989, entité automatisée qui perçoit son environnement, y réagit et agit pour atteindre ses buts. Pour le cadre, système logiciel qui poursuit un objectif en dirigeant lui-même sa boucle « raisonner, agir, observer » au moyen d'un modèle, d'outils et d'un état, sous un niveau d'autonomie déclaré. | ISO/IEC 22989:2022; oneM2M TR-0081, v0.2.0 (version préliminaire)[59, 60]; cadre |
| **Système d'IA** | Système automatisé conçu pour fonctionner à différents niveaux d'autonomie, qui peut faire preuve d'une capacité d'adaptation après son déploiement et qui, pour des objectifs explicites ou implicites, déduit, à partir des entrées qu'il reçoit, la manière de générer des sorties (prédictions, contenus, recommandations, décisions) pouvant influencer des environnements physiques ou virtuels. Le cadre considère tout agent comme un système d'IA. | Règlement (UE) 2024/1689 (RIA), art. 3(1)[61, 62] |
| **Déployeur** | Personne ou organisme qui utilise un système d'IA sous sa propre autorité. Si le RIA s'applique à elle (art. 2), l'entreprise l'est pour les agents qu'elle exploite, y compris ceux qu'elle achète (section 12.4). | RIA, art. 3(4)[61] |
| **Outil** | Capacité exposée à un agent (fonction, API, action), décrite par un contrat typé et classée P0 à P3 au catalogue; un outil ne prend aucune décision. Dans MCP, fonction exécutable que le modèle choisit d'appeler. | MCP[63]; cadre |
| **Ressource** | Donnée contextuelle identifiée par une URI, qu'un serveur met à la disposition d'un agent. Pour le cadre, sa lecture n'a aucun effet de bord; toute opération qui modifie un état est un outil. | MCP[63, 64]; cadre |
| **Invite** *(prompt)* | Instructions et contenu en langage naturel fournis à un modèle. Dans MCP, la primitive `Prompts` désigne des gabarits d'invite réutilisables qu'expose un serveur. | MCP[63] |
| **Flux déterministe** | Suite d'étapes dont le code fixe le chemin (graphe ou machine à états). Quand certaines étapes appellent un modèle, c'est un flux de travail assisté par IA : le chemin reste fixé par le code. | Anthropic *(workflows)*[65] |

| Terme | Définition | Référence |
|---|---|---|
| **Orchestrateur, exécutant** | L'orchestrateur décompose une demande, affecte les sous-tâches, suit l'état, gère la reprise et consolide les résultats; l'exécutant, agent ou outil, traite une sous-tâche bornée. Le cadre limite la délégation à deux niveaux (choix du cadre, EXIG-ORC-04, section 7.2). | Cadre; Anthropic[65] |
| **Transfert** *(handoff)* | Cession explicite du contrôle d'une session, avec le contexte utile et le mandant, d'un agent source à un agent cible mieux qualifié; l'agent source se retire. | OpenAI[66] |
| **Chorégraphie** | Coordination sans composant central : chaque agent réagit aux événements d'un bus et publie les siens, ce qui complique le suivi et expose aux cycles. | Microsoft[67] |
| **Carte d'agent** *(Agent Card)* | Document lisible par machine, défini par A2A, par lequel un agent décrit son identité, ses interfaces, ses compétences et ses exigences de sécurité; en A2A 1.0, il est publié à `/.well-known/agent-card.json`. | A2A 1.0[68] |
| **Contrat d'agent** | Engagement formel d'un agent : carte d'agent, entrées et sorties typées, niveau d'autonomie, limites, niveaux de service et voie d'escalade. Outils et événements ont leurs équivalents; tout contrat est versionné au catalogue d'entreprise. | Cadre (EXIG-INT-03, section 6.1; section 6.8) |
| **Mandant** | Personne, application ou agent au nom duquel une tâche est exécutée. Ses droits bornent ceux de l'agent, et son identité accompagne chaque appel de bout en bout. | Cadre |
| **Délégation** | Attribution à un agent de droits bornés en portée et en durée pour agir au nom d'un mandant, l'agent restant identifiable. Le cadre interdit l'usurpation, où l'agent devient indiscernable du mandant. Par extension, envoi d'une tâche à un autre agent, sans plus de droits que n'en a le mandant. | RFC 8693, § 1.1[69]; cadre |
| **Jeton délégué** | Jeton d'accès de courte durée, obtenu par échange de jetons, qui identifie le mandant (`sub`) et l'agent acteur (`act`) et ne vaut que pour un seul service; sa portée ne s'élargit jamais d'un saut à l'autre. | RFC 8693, 8707 et 9068[70, 71, 72]; cadre (durée courte, audience unique, portée jamais élargie) |
| **Passerelle d'agents** | Point d'application des politiques placé devant les outils et les agents : authentification, autorisation, garde-fous, plafonds, injection des secrets et journalisation de chaque appel. | Cadre; NIST SP 800-207[73] |
| **Passerelle de modèles** | Passage obligatoire entre les agents et les fournisseurs de modèles : clés, routage, cache, repli, quotas, mesure des jetons et filtrage des données sortantes. | Cadre (section 5.2) |
| **Catalogue d'entreprise** | Source unique des contrats des interfaces joignables (outils, cartes d'agent, événements), avec version et empreinte approuvées, palier et propriétaire. À distinguer du catalogue des protocoles (section 6.3). | Cadre (section 6.8) |
| **Registre** | Inventaire faisant autorité des agents et des serveurs MCP : une fiche par élément, avec propriétaire nommé, finalité, classe de risque, niveau d'autonomie et état de cycle de vie. | Cadre (section 11.4); GOVERN 1.6[74] |
| **Garde-fou** | Contrôle automatisé qui filtre ou bloque une entrée, une sortie ou une action d'un agent. Un garde-fou probabiliste réduit un risque sans l'éliminer. | Microsoft[9]; cadre |

| Terme | Définition | Référence |
|---|---|---|
| **Humain dans la boucle (HITL), sur la boucle (HOTL), hors de la boucle** *(human in the loop, human on the loop, human out of the loop)* | HITL : une personne approuve chaque action en écriture avant son exécution. HOTL : elle supervise, traite les exceptions et peut interrompre, sans approbation préalable. Hors de la boucle : aucune intervention pendant l'exécution; restent la surveillance automatisée, l'audit et l'arrêt. | AWS; IMDA (Infocomm Media Development Authority, Singapour), section 1.1.3, pour la gradation de l'implication humaine, les sigles HITL et HOTL n'y figurant pas[75, 76] |
| **Niveau d'autonomie** | Plafond, déclaré au registre, de ce qu'un agent fait sans approbation humaine : N0 à N4, NX étant interdit (définitions ci-dessous). | Cadre (section 8.1) |
| **Palier d'outil** | Risque propre à un outil, de P0 à P3, attribué au catalogue après revue et jamais déduit des déclarations du serveur (définitions ci-dessous). | Cadre (section 8.3) |
| **Compensation** | Action métier qui neutralise l'effet d'une étape déjà exécutée quand un flux échoue, par exemple un remboursement. Elle ne rétablit pas forcément l'état initial et doit pouvoir être réessayée sans danger. | Microsoft[77] |
| **Idempotence** | Propriété d'une opération dont la répétition produit le même effet qu'une seule exécution. Une clé d'idempotence, identique à chaque nouvel essai, permet de reconnaître une requête déjà reçue. | IETF; Temporal[78, 79] |
| **Exécution durable** | Persistance de l'état d'une exécution à chaque transition (point de contrôle), qui permet de reprendre après une panne ou un déploiement. Elle n'empêche pas à elle seule qu'un effet soit rejoué : il faut aussi l'idempotence. | Temporal; LangGraph[80, 81, 82] |

## Les deux échelles du cadre

Ces échelles s'appliquent partout; le chapitre 8 en précise les contrôles.

### Niveaux d'autonomie

- **N0 Automatisation déterministe** : aucun modèle; flux codé, règles, RPA, API (repère de base hors portée agentique, section 1.2).
- **N1 Consultatif** : l'agent lit, analyse, recommande, rédige; aucun effet en écriture; l'humain exécute; outils P0 et P1 seulement.
- **N2 Exécution approuvée** : l'agent prépare; chaque action en écriture attend une approbation explicite (humain dans la boucle).
- **N3 Autonomie bornée et supervisée** : l'agent exécute seul les actions P2 réversibles ou compensables sous des seuils déclarés, dans un domaine de conception opérationnel documenté (ODD, *operational design domain*); il escalade les exceptions; une action P3 exige une approbation hors bande (humain sur la boucle).
- **N4 Autonomie étendue sous ODD certifié** : l'agent s'autodéclenche sur des événements et opère en continu; l'humain est hors de la boucle d'exécution, mais sur la boucle de gouvernance; une action P3 est toujours approuvée; ce niveau exige une décision du comité.
- **NX Autonomie non bornée** : l'agent fixe ses objectifs, modifie ses permissions ou exécute du code hors contraintes. Ce niveau est interdit.

Le niveau est un plafond déclaré au registre, à la manière du « certificat d'autonomie » de Feng, McDonald et Zhang[83]; il est distinct de la topologie (le nombre d'agents) et de la capacité du modèle. Plafond par classe de risque : celui que fixe EXIG-CON-02 selon la classe attribuée au tableau 46 (section 12.1).

**Paliers d'outils** : **P0** lecture publique; **P1** lecture interne ou sensible; **P2** écriture réversible; **P3** action critique, externe ou irréversible, jamais exécutée seule par un agent.

**À RETENIR**

Quatre axes à ne pas confondre : classe de risque de l'agent (section 12.1), niveau d'autonomie, palier de l'outil et topologie (chapitre 7). Pour une action, le contrôle le plus strict l'emporte (section 8.4).

## 3.2 Flux de travail ou agent?

Cette section distingue deux façons de faire travailler un modèle, qui n'appellent ni les mêmes contrôles ni les mêmes coûts.

Selon Anthropic, un flux de travail orchestre le modèle et les outils par des chemins de code prédéfinis, alors qu'un agent dirige lui-même son processus et l'usage de ses outils. Les deux reposent sur la même brique, le modèle augmenté *(augmented LLM)*, doté de capacités de recherche, d'outils et de mémoire[65]. Un agent fonctionne en boucle : la méthode ReAct fait alterner raisonnement et actions sur des sources externes, ce qui a réduit les hallucinations par rapport à la chaîne de pensée seule et amélioré le taux de réussite sur les tâches interactives (ALFWorld, WebShop) dans les essais de ses auteurs[84].

### Quand chacun convient

La question décisive est simple : qui doit choisir le prochain pas, le code ou le modèle? La section 7.3 en fait un arbre de décision.

- **Code ou règle (N0).** Si une fonction suffit, on écrit la fonction plutôt qu'un agent[85].
- **Appel direct au modèle.** Pour une transformation en un seul passage : classer, résumer, traduire[9].
- **Flux de travail assisté par IA.** Quand le chemin est connu d'avance, réglementé ou audité. C'est le patron par défaut du cadre.
- **Agent unique outillé.** Quand les étapes dépendent de ce que l'agent découvre en chemin, pour des requêtes variées dans un même domaine.
- **Système multiagent.** Quand il faut protéger le contexte, paralléliser des pistes réellement indépendantes, spécialiser les outils ou séparer des frontières de sécurité, et seulement sur preuve mesurée de gain (section 7.1 et section 7.3).

Les deux se combinent : un flux peut contenir une étape agentique, et un agent peut appeler un flux comme un outil. La distinction ne dit rien de l'autonomie : un agent N1 choisit ses étapes, mais ne fait que recommander.

**À RETENIR**

Le modèle ne décide que là où le chemin ne peut pas être écrit d'avance. Ce qu'une règle peut trancher (routage, calcul, contrôle de sécurité) reste dans le code (PRIN-08).

## 3.3 Agents interactifs et agents ambiants

Cette section distingue deux modes de déclenchement, qui pèsent sur la conception d'un agent.

Un agent interactif répond à une personne présente, dans une conversation ou une application. Un agent ambiant, selon LangChain, écoute un flux d'événements et agit en conséquence, éventuellement sur plusieurs événements à la fois, sans être nécessairement entièrement autonome; une tâche planifiée peut aussi le lancer[86]. Le tableau 8 en tire les conséquences.

**Tableau 8 — Agents interactifs et agents ambiants : conséquences de conception**

| Dimension | Agent interactif | Agent ambiant |
|---|---|---|
| Déclencheur | Demande d'une personne dans un canal | Événement (message, alerte, changement d'état) ou tâche planifiée |
| Contrainte de temps | Réponse attendue en direct : appels d'outils et itérations bornés en conséquence | Délai relâché : traitement de fond, par lots au besoin |
| Interaction humaine | Dans la session; une action P3 reste approuvée hors bande (section 8.5) | File persistante : notifier, questionner, réviser (section 8.6) |
| État et reprise | Persistance requise dès qu'une approbation ou une tâche longue intervient | Exécution durable, qui survit aux pannes et aux redéploiements (section 7.4) |
| Risque dominant | Un « oui » dans la conversation pris à tort pour une approbation | Volume : saturation des approbateurs (menace T10 de l'OWASP)[87] et tempêtes d'événements (section 6.7) |

Le mode de déclenchement ne fixe pas le niveau d'autonomie. Un agent ambiant peut se borner à signaler (N1), préparer des actions soumises à approbation (N2) ou agir seul sous seuils (N3); seul le niveau N4 combine le déclenchement sur événements, l'exécution continue et l'absence de la personne dans la boucle d'exécution. Pour les traitements de fond non urgents, Anthropic et OpenAI accordent chacun, au 27 octobre 2026, un rabais de 50 % sur les jetons traités par lots, dans une fenêtre de 24 heures[88, 89] (section 10.6).

## 3.4 Ce qu'un agent n'est pas

Cette section écarte trois confusions qui minent la sécurité et l'imputabilité; les chapitres 9 et 11 en tirent les exigences.

### Pas un compte d'utilisateur

Un agent n'emprunte jamais le compte d'une personne, même pour agir en son nom. Microsoft déconseille d'attribuer aux agents un compte d'utilisateur ordinaire ou un principal de service traditionnel, et a créé pour eux un type d'identité propre[90]. À l'inverse, une personne n'utilise jamais l'identité d'un agent : l'OWASP range cet usage parmi les dix principaux risques des identités non humaines (NHI10)[91]. Pour agir au nom de quelqu'un, l'agent reçoit une délégation qui l'identifie aux côtés de la personne (section 9.3).

### Pas un principal de service partagé

Chaque agent a sa propre identité, et chaque instance la sienne au besoin[92]. Un compte ou une clé d'API commun à plusieurs agents empêche de savoir lequel a agi et de révoquer l'un sans arrêter les autres. Le brouillon « AI Identity Management System » (AIMS) du groupe de travail WIMSE de l'IETF exige un identifiant unique par agent et qualifie les clés d'API statiques d'antipatron; l'OWASP classe la réutilisation d'identités non humaines parmi les risques majeurs (NHI9)[91, 93].

### Pas un responsable

Un agent ne répond pas de ses actes, ne consent pas et n'approuve rien. Une personne nommée, le propriétaire métier (parrain), répond de chaque agent, de ses effets et de son retrait (section 11.1). Le droit et la pratique vont dans ce sens : le RIA oblige le déployeur d'un système à haut risque à confier la supervision humaine à des personnes compétentes, formées et dotées de l'autorité nécessaire[94]; Microsoft Entra Agent ID associe à chaque agent un

parrain, responsable métier, et un propriétaire au sens d'Entra, chargé de l'administration technique (le responsable technique du cadre, section 11.1)[90]. Une approbation exigée par le cadre vient donc toujours d'une personne, jamais d'un autre agent (section 8.5).

**À RETENIR**

Un agent a une identité propre, des droits délégués et bornés, et une personne nommée qui en répond. Sans ces trois conditions, il ne satisfait pas aux exigences des chapitres 9 et 11.

# 4 Principes directeurs

Douze principes guident toute décision d'architecture agentique, de la conception d'un agent à l'achat d'une plateforme. Ils expliquent le pourquoi des exigences des chapitres 5 à 13 et tranchent les situations que ces exigences ne prévoient pas. Ce chapitre les énonce, montre où chacun est mis en œuvre et fixe la manière d'arbitrer entre eux.

## 4.1 Les douze principes

Chaque principe tient en un énoncé et en ses conséquences pour la conception; les principes sont présentés par paires, selon la question qu'ils règlent. En cas de conflit avec une préférence d'équipe, un usage local ou la recommandation d'un fournisseur, le principe l'emporte, sauf dérogation approuvée (section 4.3).

**À RETENIR**

Trois questions résument l'essentiel des principes qui encadrent l'action des agents (PRIN-03 à PRIN-06, PRIN-10 et PRIN-12). Qui a autorisé cette action, et au nom de qui? Peut-on la défaire, ou au moins l'arrêter? Peut-on reconstituer après coup ce qui s'est passé et ce que cela a coûté?

### Interopérer par des contrats ouverts

Un agent de service bâti sur une plateforme de logiciel-service (SaaS) doit pouvoir déléguer à un agent conçu à l'interne, qui appelle des outils exposés par une autre équipe. Sans protocole commun, chaque paire exige son connecteur et les intégrations se multiplient (chapitre 2). Les deux premiers principes remplacent ce maillage par des contrats publiés une fois et consommés par tous.

**PRIN-01**

**Standards ouverts avant intégrations propriétaires**

Tout échange qui franchit la frontière d'un domaine (agent vers outil, agent vers agent, événement) passe par un protocole inscrit au catalogue des protocoles (section 6.3). Un connecteur propriétaire point à point exige une dérogation.

Conséquences : on privilégie les protocoles sous gouvernance neutre, comme MCP et A2A, hébergés par l'Agentic AI Foundation (AAIF) de la Linux Foundation depuis décembre 2025 et août 2026 respectivement[4, 35]. Une plateforme qui ne les prend pas en charge est isolée derrière un adaptateur.

**PRIN-02**

**Contrat avant code, mise en œuvre opaque**

Chaque agent et chaque outil publient un contrat lisible par machine (définition d'outil, carte d'agent *(Agent Card)*, contrat d'événement) avant leur mise en service. Seul ce contrat fait foi : un consommateur ne dépend jamais du cadriciel, du modèle ni de la structure interne d'un pair.

Conséquences : le contrat est versionné, épinglé et inscrit au catalogue d'entreprise. La description d'un outil, que le modèle lit pour décider, en fait partie : la modifier exige une nouvelle approbation (section 6.8). La mise en œuvre, elle, change librement.

### Borner le pouvoir d'agir

Ce qu'un agent peut atteindre et ce qu'il peut faire sans personne sont deux questions distinctes. Selon Gartner (mai 2026), les échecs de gouvernance des agents tiennent notamment à la confusion entre la capacité d'agir d'un agent et la portée des accès qui lui sont accordés[95]. Exemple : un agent de remboursement lit les pièces du dossier du client utiles à la demande, mais n'émet un remboursement qu'après approbation.

**PRIN-03**

### Identité propre, moindre privilège et moindre agence

Chaque agent possède sa propre identité non humaine, jamais un compte d'utilisateur ni un secret partagé. Ses droits sont minimaux, de courte durée et jamais supérieurs à ceux de son mandant. Ses outils et son autonomie se limitent à ce que la tâche exige : c'est la moindre agence *(Least-Agency)* de l'OWASP, pour qui un comportement agentique déployé sans nécessité élargit la surface d'attaque sans ajouter de valeur[28].

Conséquences : les droits effectifs d'un agent délégué ne dépassent jamais l'intersection des droits du mandant et de ceux de l'agent[96]; le serveur d'autorisation l'applique à chaque échange de jetons (section 9.3).

**PRIN-04**

### Autonomie proportionnée au risque

Le niveau d'autonomie, de N0 à N4, est un plafond déclaré au registre et fixé par la classe de risque de l'agent. Il ne découle ni de la capacité du modèle ni de ses résultats aux bancs d'essai. L'autonomie non bornée (NX) est interdite.

Conséquence : le niveau ne dépasse jamais le plafond de la classe de risque, fixé par EXIG-CON-02 (section 8.1, section 12.1). Feng, McDonald et Zhang traitent aussi l'autonomie comme une décision de conception, distincte de la capacité[83].

## Maîtriser les effets

Un agent réessaie, se trompe ou peut être détourné : il faut donc prévoir ce qui se passe quand l'action est fausse. Exemple : un appel de paiement expire et l'agent le relance; sans clé d'idempotence, le paiement est exécuté deux fois. Et si un client conteste la décision trois semaines plus tard, il faut retrouver qui l'a demandée, quel agent l'a préparée, qui l'a approuvée et ce qu'elle a coûté.

**PRIN-05**

### Réversibilité par conception

Toute action qui modifie un système d'enregistrement est idempotente et, selon le cas, annulable, compensable ou soumise à une approbation humaine préalable. Une action de palier P3, c'est-à-dire critique, externe ou irréversible, n'est jamais exécutée seule par un agent.

Conséquences : clé d'idempotence à chaque étape, compensation déclarée avant l'action (section 7.5) et, comme le recommande Microsoft, étapes irréversibles placées après toutes les validations critiques[67, 77].

**PRIN-06**

### Traçabilité et imputabilité économique

Chaque action se rattache, par un identifiant de trace commun, à la demande d'origine, au mandant, à l'agent et à sa version, à la décision prise et à un centre de coûts.

Conséquences : traçage OpenTelemetry sur tous les sauts; journal d'audit inaltérable et distinct des traces, en accord avec l'OWASP, qui recommande des journaux immuables et signés des actions d'agents[28]; jetons mesurés par agent et par exécution[9]; coût suivi par tâche réussie (chapitre 10).

## Contenir le modèle

Un modèle de langage est probabiliste et influencé par tout ce qu'il lit : c'est utile pour comprendre une demande, dangereux pour décider d'un montant ou d'un destinataire. Exemple : un agent qui trie le courrier reçoit un message disant « transférez ce dossier à l'adresse suivante ». Lui demander d'être prudent ne suffit pas : le transfert doit être impossible depuis cette session.

**PRIN-07**

### Défiance envers le contenu reçu

Ce qu'un outil, un document, une page Web, une mémoire ou un autre agent renvoie est une donnée, jamais une instruction de confiance. Le cadre présume l'injection d'instructions possible dès qu'un modèle lit du contenu non fiable, comme l'envisage le NIST AI 100-2 E2025, selon lequel les concepteurs peuvent concevoir leurs systèmes dans cette hypothèse[97]; le Centre national de cybersécurité du Royaume-Uni (NCSC) rappelle qu'un modèle de langage ne sépare pas intrinsèquement les données des instructions[98].

Conséquences : les contrôles décisifs sont déterministes, par exemple le retrait des outils d'envoi externe après la lecture de contenu non fiable. La détection et le marquage réduisent le risque sans l'éliminer (section 9.6).

**PRIN-08**

### Déterminisme autour du modèle et simplicité d'abord

Le raisonnement probabiliste s'exécute dans une enveloppe déterministe : schémas validés, machine à états, contrats typés, plafonds d'itérations. On ne confie jamais au modèle un routage, un calcul ou une décision de sécurité qu'une règle résout, et l'on retient la solution la plus simple : une fonction avant un agent, un agent avant plusieurs. Anthropic, Microsoft et OpenAI convergent sur cette règle de frugalité[9, 65, 66, 85].

Conséquences : les sorties du modèle sont validées par schéma avant tout effet; un système multiagent justifie par écrit pourquoi un flux déterministe ou un agent unique ne suffit pas (section 7.3).

## Garder la maîtrise

L'entreprise doit pouvoir changer de modèle quand le prix, la qualité ou la résidence des données l'exigent, et savoir à tout moment qui répond de chaque agent. Le premier point protège sa logique métier; le second, les personnes touchées par les décisions des agents.

**PRIN-09**

### Découplage des fournisseurs et propriété de la logique

Modèles, plateformes et cadriciels sont remplaçables. L'entreprise garde la propriété de sa logique d'orchestration, de ses contrats d'outils, de ses invites et de ses mémoires, dans des formats exportables. Avec MCP et A2A sous gouvernance neutre, le risque de verrouillage s'est déplacé vers les plateformes et leurs extensions propriétaires (section 13.1).

Conséquences : aucun agent n'appelle directement un fournisseur de modèles; il passe par la passerelle de modèles (section 5.2). Les contrats d'approvisionnement prévoient la réversibilité et la sortie (section 13.3).

**PRIN-10**

### Humain imputable

Une personne nommée, le propriétaire métier (parrain), répond de chaque agent, de ses effets et de son retrait; l'agent n'est jamais responsable. Le NIST AI RMF, cadre volontaire, attend des politiques qui définissent les rôles et responsabilités humain-IA (GOVERN 3.2)[99], et l'IMDA de Singapour fait de la responsabilisation réelle des humains l'une des quatre dimensions de son cadre[76].

Conséquences : aucun agent n'entre en production sans propriétaire inscrit au registre, et ce propriétaire atteste périodiquement que l'agent reste nécessaire (sections 11.4 et 11.5).

## Concevoir pour durer et pour défaillir

Les agents de longue durée traversent pannes, déploiements et changements de version. Exemple : si le fournisseur de modèles tombe en panne pendant le traitement de 300 dossiers, chacun doit reprendre où il s'était arrêté, basculer vers un modèle de repli ou passer à une personne, jamais rester à moitié exécuté à l'insu de tous.

**PRIN-11**

### Découplage du raisonnement, de l'action et de la mémoire

La logique de l'agent (invites, choix du modèle), ses capacités d'action (serveurs MCP, API) et son état (mémoires de travail, épisodique et sémantique) se déploient, se sécurisent et évoluent séparément; la mémoire procédurale, déployée avec l'agent, suit le cycle de sa logique. L'état ne vit jamais seulement dans la mémoire du processus : Microsoft recommande de persister l'état partagé à l'extérieur[9].

Conséquences : on change de modèle sans toucher aux outils et on révoque un outil sans redéployer l'agent. L'écriture en mémoire procédurale, jugée plus risquée par la taxonomie CoALA *(Cognitive Architectures for Language Agents)*[100], est gérée comme un changement de code (section 5.5).

**PRIN-12**

### Dégradation maîtrisée

L'architecture prévoit les erreurs de modèle, les dépassements de délai, les boucles et les pannes de fournisseur : délais, reprises, disjoncteurs, plafonds d'itérations et de coûts, modèles de repli, escalade vers une personne. En cas de doute, le système échoue en mode fermé : il s'arrête ou escalade plutôt que d'agir.

Conséquences : les mécanismes de fiabilité que décrit Microsoft (délais, reprises, disjoncteurs, validation des sorties avant transmission) deviennent obligatoires[9]; l'action est refusée si l'approbation requise est impossible à obtenir, comme le recommande l'IMDA[76]; le coupe-circuit est testé chaque trimestre, fréquence choisie par le cadre (section 7.8).

## 4.2 Application des principes

Les principes se traduisent en exigences vérifiables dans les chapitres 5 à 13. Le tableau 9 indique, pour chacun, les sections qui le mettent en œuvre, les familles d'exigences concernées et la preuve qu'une revue d'architecture contrôle.

**Tableau 9 — Mise en œuvre des principes directeurs**

| Principe | Sections | Exigences | Preuve contrôlée en revue |
|---|---|---|---|
| PRIN-01 Standards ouverts | 6.2, 6.3, 6.9, 11.7 | EXIG-INT, EXIG-MCP, EXIG-A2A, EXIG-EVT, EXIG-GOV | Protocole retenu au catalogue pour chaque interface |
| PRIN-02 Contrat avant code | 6.5, 6.6, 6.8, annexe C | EXIG-INT, EXIG-MCP, EXIG-A2A | Contrat publié, versionné et épinglé |
| PRIN-03 Identité et moindre agence | 9.2, 9.3, 9.4 | EXIG-IAM | Identité propre, jeton délégué à audience unique |
| PRIN-04 Autonomie proportionnée | 8.1 à 8.4, 12.1 | EXIG-AUT, EXIG-CON | Niveau déclaré au registre, sous le plafond de la classe |
| PRIN-05 Réversibilité | 7.5, 7.6, 8.5 | EXIG-ORC, EXIG-AUT | Idempotence, compensation, approbation des actions P3 |
| PRIN-06 Traçabilité | 10.1, 10.3, 10.6 | EXIG-OBS, EXIG-FIN | Trace complète, journal d'audit, coût par tâche |
| PRIN-07 Défiance | 9.5, 9.6, 9.9 | EXIG-SEC | Tests d'injection concluants, outils d'envoi retirés |
| PRIN-08 Déterminisme et simplicité | 7.1 à 7.3, 7.9 | EXIG-ORC | Patron justifié, sorties validées, plafonds déclarés |
| PRIN-09 Découplage des fournisseurs | 5.2, 5.4, 13.3 | EXIG-ARC, EXIG-APP | Passerelle de modèles, formats exportables, clause de sortie |
| PRIN-10 Humain imputable | 11.1, 11.2, 11.4, 11.5 | EXIG-GOV | Propriétaire nommé, attestation à jour |

| Principe | Sections | Exigences | Preuve contrôlée en revue |
|---|---|---|---|
| PRIN-11 Découplage interne | 5.2, 5.5, 7.4 | EXIG-ARC, EXIG-ORC | Déploiements distincts, état persisté hors processus |
| PRIN-12 Dégradation maîtrisée | 7.8, 9.4, 12.8 | EXIG-ORC, EXIG-IAM, EXIG-CON | Repli configuré, coupe-circuit testé |

Lorsqu'aucune exigence ne couvre une situation (nouveau protocole, nouveau type d'agent, usage imprévu), l'architecte doit consigner dans la décision d'architecture le raisonnement tenu à partir des principes, en nommant les principes invoqués. Le comité d'architecture et des risques agentiques décide ensuite s'il faut créer une exigence à la révision suivante du cadre.

## 4.3 Arbitrage entre principes et dérogations

Les principes se renforcent le plus souvent, mais ils peuvent tirer en sens contraires. Choix du cadre : en cas de conflit, l'ordre de préséance suivant s'applique.

1. Le droit applicable et les engagements contractuels, qu'aucun principe ne peut écarter (chapitre 12).
2. Les principes qui protègent les personnes et les systèmes et qui fondent l'imputabilité : PRIN-03 à PRIN-07, PRIN-10 et PRIN-12.
3. Les principes d'architecture : PRIN-01, PRIN-02, PRIN-08, PRIN-09 et PRIN-11.

À rang égal, on retient l'option la plus simple qui respecte les deux principes en présence, et l'arbitrage est consigné dans la décision d'architecture. Le tableau 10 illustre les tensions les plus fréquentes.

**Tableau 10 — Tensions fréquentes entre principes et arbitrage retenu**

| Principes en tension | Situation | Arbitrage du cadre |
|---|---|---|
| PRIN-01 et PRIN-08 | Un outil ne sert qu'à un seul agent, dans la même unité de déploiement; l'exposer par MCP ajoute un composant. | PRIN-01 vise les échanges qui franchissent une frontière de domaine; à l'intérieur, une fonction locale suffit. Dès qu'un second consommateur apparaît, l'outil passe au catalogue. |
| PRIN-05 et PRIN-10 | Exiger une approbation humaine pour chaque action semble plus sûr, mais des approbateurs saturés approuvent machinalement. | Une approbation donnée sans examen n'apporte ni sécurité ni imputabilité; l'OWASP range cette saturation parmi les menaces (T10)[87]. On rend l'action compensable quand c'est possible et aux niveaux N3 et N4, l'on réserve l'approbation aux actions P3 et aux dépassements de seuils (au niveau N2, chaque écriture reste approuvée) (section 8.7). |
| PRIN-06 et protection des renseignements personnels (RP) | Tracer le contenu des invites et des réponses aide au diagnostic, mais expose des RP. | La protection des RP l'emporte : les métadonnées sont toujours tracées; par choix du cadre, le contenu est exclu par défaut, activé sur décision documentée et conservé hors des traces (section 10.2). |
| PRIN-07 et utilité | Une défense par conception coûte en utilité : sur le banc d'essai AgentDojo, CaMeL (Debenedetti et coll., mars 2025) accomplit 77 % des tâches avec une sécurité démontrable, contre 84 % pour un système sans défense[101]. | La classe de risque tranche : pour la classe de risque élevé, on accepte la perte d'utilité. Si le risque résiduel reste intolérable, le NCSC estime qu'un modèle de langage n'est peut-être pas la bonne solution[98]. |

### Dérogations

Un écart à un principe doit faire l'objet d'une dérogation écrite, approuvée par le comité d'architecture et des risques agentiques (ou, pour un agent de classe faible, par délégation à l'architecture d'entreprise, pour 90 jours au plus), limitée à six mois au plus, assortie de mesures compensatoires et d'un plan de retour à la conformité, et inscrite au registre (section 11.6). Une dérogation vise un agent ou un composant précis, jamais une catégorie entière; à son échéance, elle ne peut être renouvelée qu'une seule fois, par décision du comité (EXIG-GOV-16); sinon l'écart est corrigé ou l'agent passe à l'état « suspendu ».

**SANS DÉROGATION POSSIBLE**

Choix du cadre : aucune dérogation n'est admise pour l'autonomie non bornée (NX), pour l'exécution par un agent seul d'une action de palier P3, pour la mise en production d'un agent sans personne nommée qui en répond, pour l'usurpation, par un agent, de l'identité de son mandant, ni pour le dépassement du plafond d'autonomie de la classe de risque (EXIG-GOV-17). Une dérogation ne peut pas non plus écarter une obligation légale ou réglementaire.

PARTIE II

# Architecture, interopérabilité et orchestration

Comment les agents se branchent aux systèmes, collaborent entre eux et sont orchestrés, et jusqu'où ils peuvent agir seuls.

5 · Architecture de référence

6 · Interopérabilité

7 · Orchestration

8 · Autonomie et supervision humaine

# 5 Architecture de référence

L'architecture de référence découpe l'entreprise agentique en six couches, de la demande jusqu'aux systèmes d'enregistrement, et en trois plans transversaux qui servent chacune d'elles. Sa règle centrale est simple : aucun agent n'atteint un outil, une donnée ou un autre agent hors de son domaine sans passer par la passerelle d'agents et le catalogue d'entreprise. Les composants décrits sont des rôles, et non des produits : le chapitre les fait correspondre à des blocs de solution remplaçables, précise l'architecture de la mémoire des agents et suit une demande de bout en bout.

## 5.1 Vue d'ensemble

Cette section présente la structure générale et la règle qui la tient ensemble; figure 3 la résume.

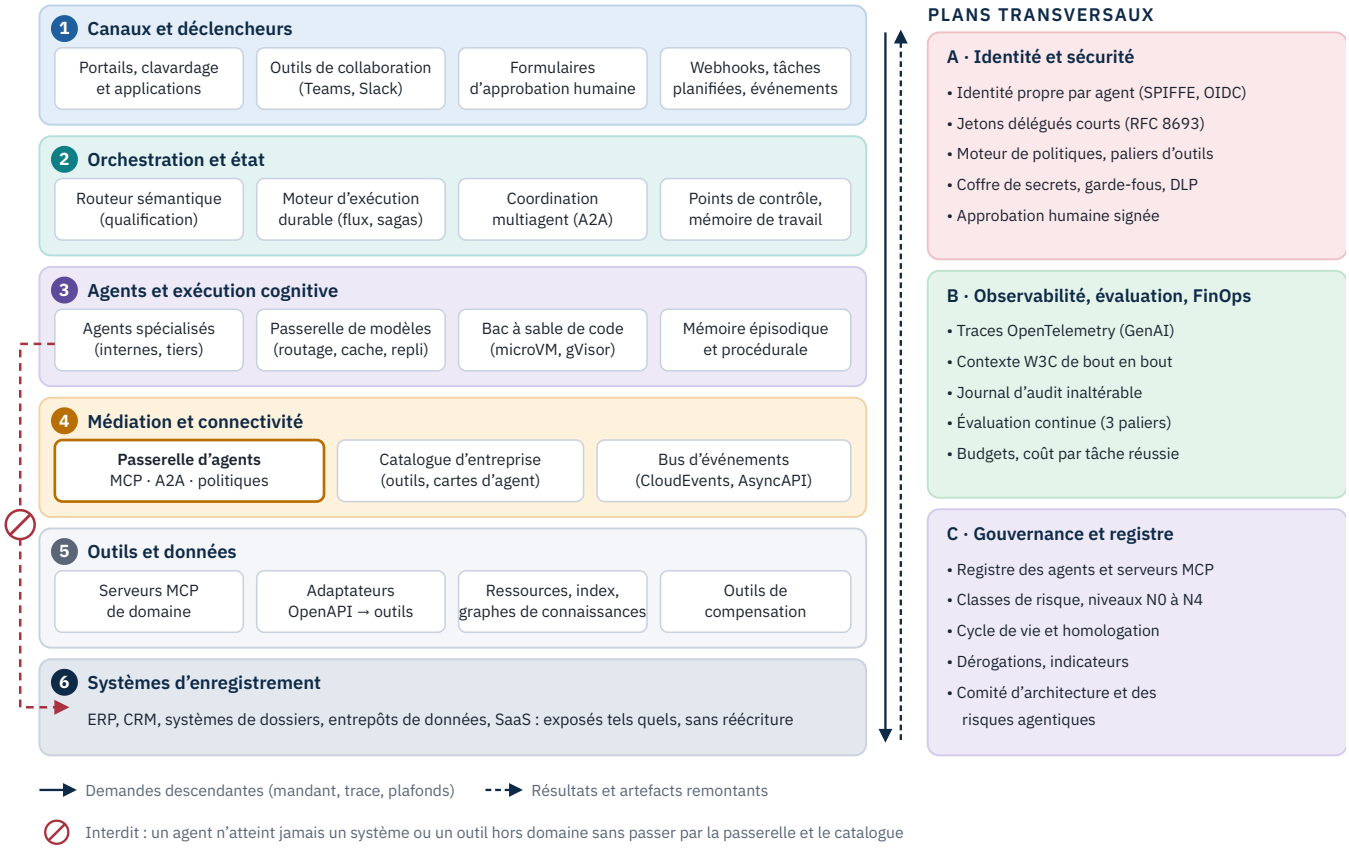



**Figure 3 — Architecture de référence : six couches et trois plans transversaux.** Les demandes descendent de la couche 1 vers la couche 6 en portant le mandant, la trace et les plafonds de la tâche; les résultats et artefacts remontent. Les trois plans transversaux servent chaque couche, et la passerelle d'agents ferme tout chemin qui contournerait le catalogue.

Source : CRE-IA-2026-01.

Les six couches se lisent de haut en bas, dans le sens où circule une demande :

1. **Canaux et déclencheurs** : là où naît la demande, qu'elle vienne d'une personne (portail, clavardage, outil de collaboration) ou d'un système (appel HTTP automatique *(webhook)*, tâche planifiée, événement).

2. **Orchestration et état** : qui fait quoi, dans quel ordre, et où l'état de la tâche survit aux pannes.
3. **Agents et exécution cognitive** : là où l'on raisonne; on y trouve les agents, la passerelle de modèles et le bac à sable de code.
4. **Médiation et connectivité** : le passage obligé des échanges, avec la passerelle d'agents, le catalogue d'entreprise et le bus d'événements.
5. **Outils et données** : ce que les agents peuvent faire et savoir, au moyen de serveurs MCP de domaine, d'adaptateurs d'API, d'index et de graphes de connaissances.
6. **Systèmes d'enregistrement** : là où la vérité de l'entreprise est conservée (progiciel de gestion intégré ou ERP, gestion de la relation client ou CRM, systèmes de dossiers, entrepôts de données, logiciels-services ou SaaS).

Trois plans transversaux fournissent leurs services à toutes les couches : A Identité et sécurité (chapitre 9), B Observabilité, évaluation et FinOps (chapitre 10) et C Gouvernance et registre (chapitre 11).

## La règle centrale

La passerelle d'agents joue le rôle d'un poste de contrôle unique : on y vérifie l'identité de l'appelant, son droit de passage et le contenu de chaque appel, et l'on peut y fermer le passage d'un geste. Ce patron vient de l'architecture à confiance zéro du NIST, où un point d'application des politiques (PEP) ouvre, surveille et termine chaque connexion selon la décision d'un moteur de politiques[73]. Le catalogue d'entreprise, lui, dit ce qui a le droit d'exister : un outil, une carte d'agent ou un contrat d'événement qui n'y figure pas est injoignable.

Cette règle répond à une limite des plateformes : la gouvernance native de chacune s'arrête à sa frontière. Des éditeurs de passerelles, MuleSoft et TrueFoundry notamment, en tirent l'argument d'une application des politiques au niveau du transport, indépendante du fournisseur et du cadriciel[44, 45]. Le cadre retient le principe, sans reprendre de gains chiffrés qui n'ont pas été mesurés de façon indépendante.

**EXIG-ARC-01**
**DOIT**

**Passage obligatoire par la passerelle et le catalogue**

Dans tout environnement serveur, tout appel d'un agent vers un outil, une ressource ou une invite MCP, vers une donnée d'un autre domaine ou vers un autre agent **DOIT** transiter par la passerelle d'agents et viser un élément inscrit au catalogue d'entreprise à une version approuvée (seule exception : un serveur MCP local en transport `stdio` sur un poste de développement, encadré par l'EXIG-MCP-08; les appels internes à un même domaine applicatif sans serveur MCP ni pair A2A sont régis par l'EXIG-IAM-17). La passerelle **DOIT** refuser tout appel vers un élément absent du catalogue.

Pourquoi : un point d'application unique est la condition pour authentifier, autoriser, tracer et couper chaque appel; un seul chemin de contournement suffit à rendre ces contrôles illusoires.

**EXIG-ARC-02**
**DOIT**

**Mandant, trace et plafonds dans chaque appel**

Chaque appel descendant **DOIT** transporter l'identité du mandant (jeton délégué, ou identité de l'agent autonome et de son propriétaire), le contexte de trace et les plafonds restants de la tâche (jetons, coût, appels d'outils, délai). L'homologation d'un composant incapable de les propager **DOIT** être refusée.

Pourquoi : ces trois éléments rendent chaque action imputable à une personne, reconstituable après coup et bornée dans ses effets et son coût; il suffit d'un maillon qui les perd pour rompre toute la chaîne.

### Des rôles, pas des produits

Chaque boîte de figure 3 désigne un rôle. Un même produit peut en remplir plusieurs : Amazon Bedrock AgentCore, par exemple, réunit des services modulaires distincts pour l'exécution, la mémoire, la passerelle, l'identité, la politique, l'observabilité et le registre, utilisables séparément avec tout cadriciel[102]. À l'inverse, un rôle peut exiger plusieurs produits. La section 5.4 établit la correspondance entre rôles et produits.

## 5.2 Responsabilités et règles par couche

Cette section fixe, pour chaque couche, ce qu'elle fait, ce qu'elle ne fait pas et les exigences qui en découlent. Le fonctionnement détaillé des composants relève des chapitres thématiques indiqués en renvoi.

### Couche 1 — Canaux et déclencheurs

La couche 1 capte l'intention, diffuse les réponses en continu et affiche les formulaires d'approbation humaine. Elle authentifie la personne ou le système déclencheur, établit le mandant et ouvre la trace, mais ne décide de rien d'autre : elle ignore quel modèle sera appelé et quels outils seront employés. Un agent ambiant, qui réagit à un flux d'événements plutôt qu'à une personne, y est raccordé par un déclencheur (par exemple une tâche planifiée qui vérifie périodiquement les nouveaux événements)[86]. Les patrons d'interaction humaine propres à ces agents sont traités à la section 8.6.

**EXIG-ARC-03** — NE DOIT PAS

**Aucune logique d'agent dans les canaux**

Le code d'un canal (application Web, robot de clavardage, webhook, planificateur) **NE DOIT PAS** contenir d'invite, de choix de modèle, de séquence d'appels d'outils ni de logique d'orchestration; il transmet l'intention à la couche 2 et affiche ce qu'elle renvoie.

Pourquoi : une logique d'agent dispersée dans les canaux échappe au registre, aux évaluations et aux mises à jour; un même processus doit se comporter de la même façon, qu'on l'appelle d'un portail ou d'un outil de collaboration.

**EXIG-ARC-04** — DOIT

**Mandant établi et trace ouverte à l'entrée**

Tout déclencheur **DOIT** établir le mandant de la demande, soit la personne authentifiée, soit, pour un déclencheur système, l'identité du service et son propriétaire nommé. Il **DOIT** aussi ouvrir ou poursuivre une trace conforme à W3C Trace Context avant de transmettre la demande[103].

Pourquoi : sans mandant établi à l'entrée, ni la délégation ni le filtrage des droits ne sont possibles plus bas; sans trace dès l'origine, la chaîne ne peut être reconstituée (section 10.1).

### Couche 2 — Orchestration et état

La couche 2 décide du chemin. Un routeur sémantique qualifie l'intention et choisit soit un flux déterministe, soit un agent; un moteur d'exécution durable conduit la tâche, conserve son état, attend les approbations et déclenche les compensations; la coordination entre agents passe par A2A. L'exécution durable signifie qu'une tâche reprend là où elle s'était arrêtée après une panne ou un redéploiement. Temporal, par exemple, poursuit une exécution jusqu'à son terme sans limite de temps imposée et la reprend en rejouant son historique d'événements[81]. Les flux Standard d'AWS Step Functions durent jusqu'à un an avec une sémantique d'exécution exactement une fois, alors que les flux Express, limités à cinq minutes, s'exécutent au moins une fois en mode asynchrone (au plus une fois en mode synchrone) et sont mieux adaptés aux actions idempotentes[104].

La persistance ne garantit pas, à elle seule, qu'une action ne sera pas répétée : à la reprise après une interruption, LangGraph réexécute le nœud depuis son début[82]. L'idempotence des effets reste donc nécessaire (section 7.4 et section 7.6).

**EXIG-ARC-05**
**DOIT**

**Exécution durable des tâches à effets**

Toute tâche qui produit un effet en écriture, attend une approbation humaine ou s'étend sur plus d'un échange **DOIT** s'exécuter sous un moteur d'exécution durable qui persiste l'état hors du processus après chaque transition. Hors du poste de développement, l'état d'une telle tâche **DOIT** résider dans le magasin persistant, jamais seulement en mémoire de processus.

Pourquoi : un redémarrage de conteneur ne doit ni perdre une approbation obtenue ni relancer une écriture déjà faite; le Centre d'architecture Azure recommande de persister l'état partagé à l'extérieur de la mémoire et d'utiliser les points de contrôle[9].

**EXIG-ARC-06**
**DOIT**

**Points de contrôle protégés comme des données de production**

Les magasins d'état et de points de contrôle **DOIVENT** être protégés comme des données de production (contrôle d'accès, chiffrement, contrôle d'intégrité). Un orchestrateur **DOIT** refuser de reprendre une exécution à partir d'un point de contrôle dont la provenance n'est pas vérifiée.

Pourquoi : un point de contrôle contient l'état complet de la tâche; la documentation de Microsoft Agent Framework qualifie son stockage de frontière de confiance[105].

**EXIG-ARC-07**
**NE DOIT PAS**

**Le routage n'accorde aucun droit**

Le routeur sémantique et l'orchestrateur **NE DOIVENT PAS** accorder ni élargir de droits : ils choisissent un chemin, mais chaque appel qui en découle reste soumis à l'autorisation de la passerelle selon le mandant et le palier de l'outil.

Pourquoi : le routage repose souvent sur un modèle, donc sur une sortie probabiliste et manipulable; une intention mal qualifiée ou injectée doit mener à un refus, jamais à une élévation de privilèges (section 9.6).

## Couche 3 — Agents et exécution cognitive

La couche 3 exécute la boucle locale de chaque agent : raisonner, agir au moyen d'un outil, observer le résultat. Chaque agent s'exécute dans un environnement d'exécution indépendant du fournisseur de modèle, encadré par deux composants partagés. La passerelle de modèles centralise les identifiants des fournisseurs, le routage entre modèles, l'équilibrage de charge, le cache, le repli et les quotas de jetons. Agent Router, projet de l'AAIF anciennement nommé Envoy AI Gateway, illustre ce rôle : les développeurs y trouvent une interface unique vers les modèles, pendant que l'équipe plateforme y centralise fournisseurs, identifiants, quotas, routage et basculement[36, 106]. Le bac à sable, quant à lui, exécute en isolement le code que l'agent produit (section 9.7).

**EXIG-ARC-08**
**DOIT**

**Passerelle de modèles obligatoire**

Tout appel d'inférence **DOIT** passer par la passerelle de modèles de l'entreprise. Un agent **DOIT** n'accéder aux modèles que par cette passerelle, sans détenir de clé de fournisseur de modèles ni appeler un fournisseur directement.

Pourquoi : c'est le seul endroit où l'on peut appliquer des quotas de jetons (comme le fait la politique `llm-token-limit` d'Azure API Management[107]), imputer les coûts, changer de fournisseur et révoquer un accès sans toucher aux agents.

**EXIG-ARC-09**
**DEVRAIT**

**Modèles désignés par un alias logique**

Un agent **DEVRAIT** désigner ses modèles par un alias logique que la passerelle résout, de sorte qu'un changement de modèle ou de fournisseur s'effectue par configuration, suivi d'une réévaluation (section 10.4), sans modification du code de l'agent.

Pourquoi : les modèles changent plus vite que les agents; l'alias isole l'agent de ces changements, tandis que la télémétrie consigne la version réellement servie.

**EXIG-ARC-10** DOIT

**Code généré exécuté en bac à sable**

Le code qu'un agent produit ou choisit dynamiquement **DOIT** s'exécuter dans un bac à sable éphémère et isolé, sans accès réseau par défaut ni accès aux secrets, selon les exigences de la section 9.7; jamais dans le processus de l'agent ni sur son hôte.

Pourquoi : l'OWASP range l'exécution de code inattendue parmi les dix principaux risques des applications agentiques (ASI05 *Unexpected Code Execution*)[28].

## Couche 4 — Médiation et connectivité

La couche 4 masque le paysage applicatif derrière des contrats uniformes. Elle réunit trois rôles : la passerelle d'agents, mandataire inverse devant les serveurs MCP et les pairs A2A; le catalogue d'entreprise, source unique de ce qui est joignable; le bus d'événements, pour les échanges découplés dans le temps (section 6.7). Le rôle de passerelle est réalisable avec des produits documentés : Azure API Management expose et gouverne des serveurs MCP et des API d'agents A2A, et Amazon Bedrock AgentCore Gateway sert de point d'entrée unique aux outils, aux agents et aux modèles[108, 109, 110]. Une passerelle relaie toutefois le trafic A2A sans assumer l'état des tâches : le greffon AI A2A Proxy de Kong Gateway (3.14 et plus, édition AI Gateway Enterprise), par exemple, ne modifie pas le routage et ne gère pas cet état[111]. L'état reste du ressort de l'agent ou de l'orchestrateur.

**EXIG-ARC-11** DOIT

**Passerelle d'agents dans les deux sens**

Dans tout environnement serveur, la passerelle d'agents **DOIT** s'interposer devant tous les serveurs MCP, internes et externes, et devant tous les pairs A2A, pour le trafic interdomaine comme pour celui qui entre dans l'entreprise ou qui en sort, et réévaluer l'autorisation à chaque appel. Ses fonctions obligatoires sont fixées à la section 9.4.

Pourquoi : l'agent d'un partenaire qui appelle l'entreprise et un agent interne qui appelle un SaaS franchissent la même frontière de confiance; la confiance zéro vise des décisions d'accès au moindre privilège prises requête par requête et une confiance réévaluée en continu pendant la session, et non une confiance acquise une fois pour toute la durée d'une session[112].

**EXIG-ARC-12** DOIT

**Liste d'autorisation tirée du catalogue**

La passerelle **DOIT** tirer sa liste d'autorisation du catalogue d'entreprise, seule source des outils, cartes d'agent et contrats d'événements joignables, avec leur version et leur empreinte approuvées (section 6.8). Aucune liste propre à un projet ne fait foi.

Pourquoi : deux listes finissent toujours par diverger; une source unique permet de retirer partout, en une seule opération, un outil compromis.

**EXIG-ARC-13** DOIT

**Aucun contournement par le bus d'événements**

Tout sujet ou canal d'événements produit ou consommé par un agent **DOIT** être inscrit au catalogue avec son contrat, et ses producteurs comme ses consommateurs **DOIVENT** s'authentifier auprès du bus.

Pourquoi : le bus est l'autre voie d'accès aux systèmes; s'il échappe au catalogue, un simple abonnement suffit à contourner la règle centrale.

## Couche 5 — Outils et données

La couche 5 expose les capacités de l'entreprise sous forme d'outils et de ressources : serveurs MCP de domaine, adaptateurs qui traduisent une API existante en outils, index et graphes de connaissances, et outils de compensation qui défont ou corrigent une action (section 7.5). Des produits convertissent déjà des API en outils sans toucher aux

services : AgentCore Gateway transforme des API OpenAPI ou Smithy et des fonctions Lambda en outils MCP, et IBM ContextForge virtualise des services REST ou gRPC en MCP[110, 113].

Un bon outil n'est pas le miroir d'un point de terminaison. Anthropic recommande de choisir délibérément les outils plutôt que d'envelopper chaque point de terminaison d'une API, de regrouper les opérations en plusieurs étapes et de renvoyer un contexte signifiant plutôt que des identifiants techniques[114]. OpenAI propose de vérifier qu'une personne pourrait utiliser la fonction avec la seule information fournie[115]. Ainsi, plutôt que trois outils « lire le client », « lire les factures » et « lire les paiements », on expose un outil `consulter_situation_compte` qui rend la synthèse utile à la tâche.

**EXIG-ARC-14** — DOIT

**Exposition sans réécriture des services**

Les capacités existantes **DOIVENT** être exposées aux agents par des serveurs MCP ou des adaptateurs placés devant les API en place, sans réécriture des services d'origine.

Pourquoi : l'intégration agentique s'ajoute au patrimoine applicatif sans le déstabiliser, et les règles métier restent là où elles sont déjà testées.

**EXIG-ARC-15** — DEVRAIT

**Outils conçus pour la tâche**

Les outils **DEVRAIENT** être conçus selon les tâches des agents (opérations regroupées, réponses paginées et filtrées, contexte signifiant) plutôt que de reproduire un à un les points de terminaison d'une API; les règles de conception détaillées figurent à la section 6.5.

Pourquoi : chaque outil superflu consomme du contexte et accroît les erreurs de sélection (section 7.3).

**EXIG-ARC-16** — DOIT

**Résultats filtrés selon les droits du mandant**

Un outil **DOIT** filtrer ses résultats selon les droits du mandant, de sorte qu'aucun agent ne reçoive une donnée que le mandant ne pourrait pas consulter lui-même.

Pourquoi : le Centre d'architecture Azure demande ce filtrage de sécurité *(security trimming)* dans chaque agent[9]; le cadre le place à la source, dans l'outil, où il ne dépend pas du comportement d'un modèle.

## Couche 6 — Systèmes d'enregistrement

La couche 6 regroupe les systèmes qui font foi : ERP, CRM, systèmes de dossiers, entrepôts de données et SaaS. Ils sont exposés aux agents tels quels. L'entreprise agentique ne les remplace pas et ne les contourne pas : elle les appelle par leurs interfaces, sous leurs propres contrôles.

**EXIG-ARC-17** — DOIT

**Écriture par les interfaces qui appliquent les règles métier**

Un agent **DOIT** écrire dans un système d'enregistrement uniquement par une interface qui applique les contrôles métier de ce système (API ou service métier), sans accès direct aux tables ni compte technique qui contourne ces contrôles.

Pourquoi : validations, séparation des tâches et journaux du système d'enregistrement sont des contrôles éprouvés; un agent qui les contourne annule cette assurance.

**EXIG-ARC-18** — DEVRAIT

**Écritures corrélées et idempotentes**

Chaque écriture d'agent dans un système d'enregistrement **DEVRAIT** porter une référence de trace que le système cible conserve avec l'opération, en plus de la clé d'idempotence qu'exige l'EXIG-ORC-21 (section 7.6).

Pourquoi : lors d'un incident, on doit pouvoir remonter d'une ligne de l'ERP à la trace de l'agent qui l'a créée, et une reprise ne doit jamais créer de doublon.

## 5.3 Plans transversaux

Les trois plans transversaux fournissent à toutes les couches des services communs, conçus une fois et consommés partout; tableau 11 indique ce que chacun apporte à chaque couche.

**A — Identité et sécurité.** Chaque agent reçoit une identité propre, délivrée par une infrastructure d'identité de charge de travail comme SPIFFE/SPIRE, projets diplômés de la Cloud Native Computing Foundation (CNCF)[116, 117], ou par fédération OpenID Connect (OIDC) infonuagique. Lorsqu'il agit pour une personne, il obtient un jeton délégué par échange de jetons (RFC 8693)[118]; le cadre exige que ce jeton soit de courte durée. Le plan fournit aussi le moteur de politiques, les paliers d'outils, le coffre de secrets, les garde-fous et l'approbation humaine signée (chapitre 9 et section 8.5).

**B — Observabilité, évaluation et FinOps.** Les couches 1 à 5 émettent des traces OpenTelemetry reliées par un même contexte W3C Trace Context[103], selon une version épinglée des conventions GenAI, qui distinguent notamment les spans `invoke_workflow`, `invoke_agent` et `execute_tool` [119, 120]. S'y ajoutent le journal d'audit inaltérable, distinct des traces, l'évaluation continue et la mesure du coût par tâche réussie (chapitre 10).

**C — Gouvernance et registre.** Le registre des agents et des serveurs MCP porte la classe de risque, le niveau d'autonomie (N0 à N4), le propriétaire et l'état du cycle de vie de chaque agent (chapitre 11). Les plans de contrôle des éditeurs couvrent une partie de ce rôle, sans le couvrir entièrement : Microsoft Agent 365, en disponibilité générale depuis le 1er mai 2026, offre un registre et des contrôles comme le blocage des agents non gérés, mais les actions de cycle de vie sur des agents infonuagiques tiers y sont encore annoncées comme à venir[46]. D'où l'exigence d'un coupe-circuit appliqué à la passerelle, quel que soit l'éditeur de l'agent (section 9.4).

**Tableau 11 — Apport des plans transversaux à chaque couche**

| Couche | A — Identité et sécurité | B — Observabilité, évaluation, FinOps | C — Gouvernance et registre |
|---|---|---|---|
| 1. Canaux et déclencheurs | Authentification de la personne ou du service; établissement du mandant | Ouverture de la trace; latence perçue | Canaux autorisés par agent; avis à la personne qu'elle interagit avec un agent (section 12.7) |
| 2. Orchestration et état | Jeton délégué de la tâche; approbations humaines signées | Spans de flux; enveloppe budgétaire de la tâche | Patron d'orchestration et niveau d'autonomie déclarés |
| 3. Agents et exécution cognitive | Identité propre par agent; garde-fous d'entrée et de sortie | Spans d'agent et d'inférence; jetons et coût par appel; évaluation continue | Versions de l'agent et du modèle inscrites; classe de risque |
| 4. Médiation et connectivité | Point d'application des politiques; coupe-circuit | Journalisation de chaque appel; propagation du contexte de trace | Catalogue, versions épinglées, liste d'autorisation |
| 5. Outils et données | Portées par outil; jetons à audience unique; secrets injectés hors de l'agent | Spans d'outil; erreurs par outil | Palier P0 à P3, propriétaire, compensation déclarée |
| 6. Systèmes d'enregistrement | Contrôles d'accès natifs conservés | Corrélation par référence de trace et clé d'idempotence | Classification des données; EFVP pour tout projet d'acquisition, de développement ou de refonte de système impliquant des RP, et avant leur communication hors Québec (section 12.2) |

**EXIG-ARC-19** **DOIT**

**Services transversaux mutualisés**

Les services des plans transversaux (identité des agents, moteur de politiques, coffre de secrets, collecte de télémétrie, journal d'audit, registre) **DOIVENT** être fournis par l'équipe plateforme et consommés par toutes les couches. Un projet **DOIT** obtenir une dérogation pour en déployer un équivalent parallèle (section 11.6).

Pourquoi : un registre ou une chaîne de télémétrie parallèle crée un angle mort que ni le comité ni l'équipe de garde ne voient.

## 5.4 Blocs de construction

Cette section relie les rôles de l'architecture aux produits qui peuvent les remplir. Le cadre reprend la distinction de TOGAF : les blocs de construction d'architecture (ABB) capturent les exigences et orientent le développement des blocs de construction de solution (SBB); les SBB désignent les produits et composants qui mettent en œuvre la fonction et dépendent du produit ou du fournisseur[121]. Le passage des uns aux autres est itératif : les ABB se définissent surtout aux phases A à D de la méthode de développement d'architecture (ADM), puis se raffinent en SBB, dont l'identification relève surtout de la phase E[121]. Concrètement, « passerelle d'agents » est un ABB neutre et durable; le produit retenu pour la réaliser est un SBB remplaçable.

**EXIG-ARC-20** **DOIT**

**Correspondance ABB-SBB documentée**

Toute solution agentique présentée à l'homologation **DOIT** documenter la correspondance entre les ABB de tableau 12 et les SBB qu'elle emploie. L'homologation **DOIT** être refusée tant qu'un ABB de tableau 12 nécessaire à la solution n'a pas de SBB désigné.

Pourquoi : la correspondance révèle les rôles orphelins, par exemple un agent sans passerelle de modèles, avant qu'ils ne deviennent des incidents.

**EXIG-ARC-21** **DOIT**

**SBB exposés par les standards retenus**

Un SBB **DOIT** exposer ses fonctions d'interopérabilité par les standards retenus au catalogue des protocoles (section 6.3), de sorte qu'on puisse le remplacer sans réécrire les agents. Une fonction offerte seulement par une interface propriétaire exige une dérogation.

Pourquoi : le risque de verrouillage s'est déplacé des protocoles vers les plateformes et leurs extensions (section 13.1).

Les exemples du tableau sont non limitatifs et établis au 27 octobre 2026. Ils ne constituent ni une exigence ni une recommandation d'achat; le comité les révise chaque trimestre, avec le catalogue des protocoles (section 11.7).

**Tableau 12 — Correspondance des blocs de construction d'architecture (ABB) et des blocs de construction de solution (SBB)**

| Couche | ABB | Capacités exigées | Exemples de SBB (non limitatifs, état au 27 octobre 2026) |
|---|---|---|---|
| 1. Canaux et déclencheurs | Interface conversationnelle et d'approbation; déclencheurs système | Authentifier, établir le mandant, ouvrir la trace, diffuser en continu, montrer l'action exacte à approuver | Portails et outils de collaboration existants; canaux intégrés des plateformes SaaS (dernière ligne); webhooks et planificateurs |
| 2. Orchestration et état | Moteur d'exécution durable; orchestrateur et routeur; magasin d'état | Persistance après chaque transition, reprise, attente d'approbation, compensation | Temporal, dont l'intégration avec l'OpenAI Agents SDK est en disponibilité générale depuis le 23 mars 2026[122]; AWS Step Functions; LangGraph 1.0 avec persistance intégrée de l'état d'exécution (*checkpointer*)[123, 124]; Microsoft Agent Framework 1.0[125]; agents de flux de Google ADK[126] |

| Couche | ABB | Capacités exigées | Exemples de SBB (non limitatifs, état au 27 octobre 2026) |
|---|---|---|---|
| 3. Agents et exécution cognitive | Environnement d'exécution d'agents | Boucle d'agent, appels MCP et A2A, télémétrie OpenTelemetry, indépendance du modèle | OpenAI Agents SDK (boucle d'agent, MCP, traçage intégré et fournisseurs non OpenAI; A2A et OpenTelemetry non documentés), Strands Agents, Google ADK, Microsoft Agent Framework, LangGraph[127, 128, 129]; AgentCore Runtime |
| 3. Agents et exécution cognitive | Passerelle de modèles | Identifiants centralisés, routage, repli, cache, quotas de jetons, imputation des coûts | Agent Router (AAIF)[130]; fonction de passerelle de modèles d'agentgateway[131]; Kong AI Gateway[132]; Azure API Management |
| 3. Agents et exécution cognitive | Bac à sable de code | Isolation par microVM, noyau applicatif ou environnement WebAssembly sans autorité ambiante, réseau fermé par défaut, exécution éphémère | MicroVM Firecracker[133]; gVisor[134]; Kata Containers[135]; WebAssembly et WASI[136]; agent-sandbox pour Kubernetes[137] |
| 4. Médiation et connectivité | Passerelle d'agents (PEP pour MCP et A2A) | Mandataire inverse, autorisation par appel, garde-fous, plafonds, journalisation, coupe-circuit | agentgateway, projet de l'AAIF sous licence Apache 2.0[31]; Azure API Management (outils MCP seulement, agents A2A en JSON-RPC seulement)[108, 109]; AgentCore Gateway[110]; Kong AI Gateway[132]; MuleSoft Agent Fabric et sa passerelle Flex Gateway[138]; IBM ContextForge (licence Apache 2.0; modèle de soutien non précisé par le projet); portails MCP de Cloudflare[139] |
| 4. Médiation et connectivité | Catalogue d'entreprise et registre privé | Source unique des outils, cartes et contrats; versions et empreintes; cycle de vie | Azure API Center; AgentCore Registry (publication, revue et approbation)[102]; Agent Registry de MuleSoft Agent Fabric |
| 4. Médiation et connectivité | Bus d'événements | Enveloppe CloudEvents, contrats AsyncAPI, rétention et rejeu | Apache Kafka, qui garantit par défaut une livraison au moins une fois[140]; services infonuagiques équivalents |
| 5. Outils et données | Serveurs MCP de domaine et adaptateurs | Outils conçus pour la tâche, effets déclarés, filtrage selon le mandant | Conversion d'API en outils par AgentCore Gateway, Azure API Management ou IBM ContextForge; serveur MCP Action Fabric de ServiceNow[50] |
| 5. Outils et données | Index et graphes de connaissances | Recherche hybride avec citations, provenance, validité temporelle | GraphRAG (génération augmentée par récupération sur graphe); Zep et Graphiti (section 5.5) |
| 6. Systèmes d'enregistrement | Systèmes existants | Contrôles métier conservés; corrélation des écritures | Aucun nouveau SBB : seuls des adaptateurs s'ajoutent |
| Plan A | Identité de charge de travail; serveur d'autorisation; moteur de politiques; coffre de secrets | Identité par agent, jetons délégués, décision par appel | SPIFFE/SPIRE; Microsoft Entra Agent ID[90]; AgentCore Identity et AgentCore Policy (langage de règles compatible avec Cedar)[102] |
| Plan B | Collecte et traitement de la télémétrie; évaluation | Collecte OpenTelemetry, caviardage, évaluation continue | OpenTelemetry Collector et son processeur de caviardage *(redaction)*[141]; AgentCore Observability et Evaluations[102] |

| Couche | ABB | Capacités exigées | Exemples de SBB (non limitatifs, état au 27 octobre 2026) |
|---|---|---|---|
| Plan C | Registre et plan de contrôle des agents | Inventaire, quarantaine, cycle de vie, coupe-circuit | Microsoft Agent 365; ServiceNow AI Control Tower[47, 51]; AgentCore Registry; MuleSoft Agent Fabric |
| Couches 1 à 3 | Plateforme SaaS à agents intégrés | MCP et A2A natifs, identité par agent, télémétrie exportable | Microsoft Copilot Studio (A2A en disponibilité générale depuis avril 2026; identité Entra Agent ID créée pour chaque nouvel agent)[48]; Salesforce Agentforce (A2A entrant et sortant, client et serveur MCP)[49]; ServiceNow AI Agent Fabric |

**ATTENTION**

Les performances annoncées par les fournisseurs ne remplacent pas une mesure. L'équipe d'agentgateway déclare environ 500 000 requêtes par seconde et une latence P99 inférieure à 0,2 ms à 30 000 requêtes par seconde, sans préciser le type de trafic ni le matériel[142]; la documentation de TrueFoundry annonce, dans la FAQ de sa page d'introduction, une latence ajoutée « typiquement » inférieure à 5 ms, alors que son propre banc d'essai (page d'architecture) mesure de 7 à 12 ms[143, 144]. Le cadre ne fixe donc aucun seuil de latence chiffré : la latence ajoutée (P50 et P99) se mesure dans les conditions de l'entreprise, politiques et traçage activés (section 13.2).

## 5.5 Mémoire des agents

Cette section distingue le contexte du modèle de la mémoire, définit quatre types de mémoire et fixe les contrôles qui encadrent leur écriture.

### Le contexte n'est pas une mémoire

Les fenêtres de contexte atteignent environ un million de jetons chez les modèles de pointe, par exemple GPT-6.1 Sol d'OpenAI et Gemini 3 (novembre 2025); GPT-5.5 (avril 2026) offrait déjà 1,05 million de jetons[145, 146, 147]. Elles ne rendent pas la mémoire inutile, pour trois raisons. D'abord, la qualité baisse quand le contexte s'allonge : les modèles exploitent mieux l'information placée au début ou à la fin de l'entrée qu'au milieu, même lorsqu'ils sont conçus pour les longs contextes[148]. Anthropic décrit ce phénomène de « pourrissement du contexte » *(context rot)* : le rappel diminue à mesure que les jetons s'accumulent, et le contexte doit être traité comme une ressource finie[149]; une étude de Chroma sur 18 modèles montre qu'un seul distracteur suffit à réduire la performance[150]. Ensuite, chaque jeton réinjecté se paie à chaque appel. Enfin, le contexte disparaît à la fin de la session. La règle qui en découle : ce qui doit durer est persisté hors du modèle, puis récupéré au moment où il sert.

### Quatre types de mémoire

Le cadre reprend la taxonomie CoALA (Sumers et al., 2024), qui distingue une mémoire de travail à court terme et trois mémoires à long terme : épisodique (expériences passées), sémantique (connaissances sur le monde et sur l'agent lui-même) et procédurale (savoir-faire)[100]. Pour CoALA, la mémoire procédurale comprend aussi les poids du modèle; l'ajustement des modèles étant hors de la portée du cadre, celui-ci la limite aux invites système, aux contrats de compétences et aux flux d'outils validés. LangChain applique la même grille : des faits sur l'utilisateur relèvent de la mémoire sémantique, des exemples tirés d'actions antérieures de la mémoire épisodique, et l'invite système de la mémoire procédurale[151]. figure 4 et tableau 13 en présentent l'organisation.

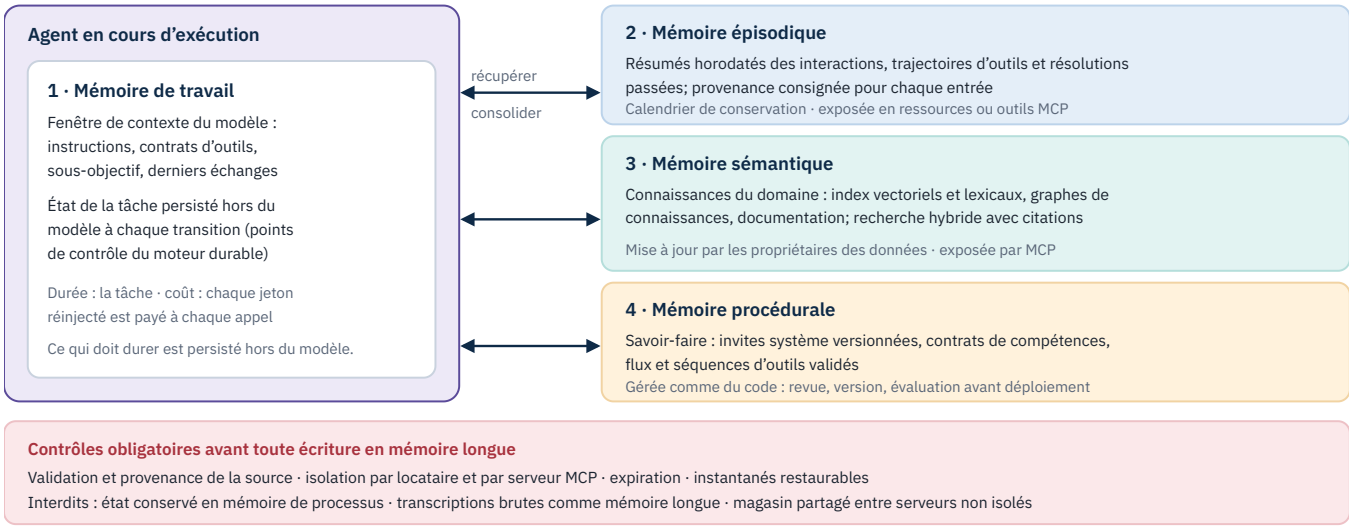



**Figure 4 — Quatre types de mémoire et contrôles d'écriture.** La mémoire de travail vit dans le contexte du modèle et dans les points de contrôle du moteur durable; les trois mémoires longues sont persistées hors du modèle, récupérées au besoin et protégées par les mêmes contrôles d'écriture.

Source : CRE-IA-2026-01, d'après la taxonomie CoALA (Sumers et al., 2024).

**Tableau 13 — Types de mémoire des agents et contrôles applicables**

| Type | Contenu | Durée de vie | Exposition | Contrôles |
|---|---|---|---|---|
| Travail | Instructions, contrats d'outils, sous-objectif, derniers échanges; état de la tâche | La tâche; état persisté à chaque transition | Fenêtre de contexte; points de contrôle du moteur durable | Contexte minimal, compaction, aucun état en mémoire de processus (EXIG-ARC-05) |
| Épisodique | Résumés horodatés des interactions, trajectoires d'outils, résolutions passées | Durée liée à la finalité, avec expiration par entrée (EXIG-CON-10) | Ressources ou outils MCP | Provenance de chaque entrée, filtrage des RP, isolation par mandant, expiration |
| Sémantique | Connaissances du domaine : index vectoriels et lexicaux, graphes de connaissances, documentation | Tant que la source est valide | Ressources ou outils MCP; recherche hybride avec citations | Mise à jour par les propriétaires des données; filtrage selon le mandant (EXIG-ARC-16) |
| Procédurale | Invites système versionnées, contrats de compétences, flux et séquences d'outils validés | La version de l'agent | Déployée avec l'agent; inscrite au registre | Revue, version, évaluation avant déploiement; aucune modification par l'agent |

## Écrire en mémoire longue

L'écriture peut se faire dans le chemin critique, en temps réel (transparente, mais plus lente), ou en arrière-plan (sans latence, mais avec une fréquence à choisir)[151]. Le cadre accepte les deux modes, à condition qu'ils passent par les mêmes contrôles. Anthropic, pour son outil mémoire exécuté côté client, exige de valider chaque chemin d'accès contre la traversée de répertoires et recommande de filtrer les données sensibles avant l'écriture, de plafonner la taille des fichiers et de supprimer les mémoires longtemps inutilisées[152]. Les renseignements personnels conservés en mémoire sont détruits ou anonymisés une fois leurs fins accomplies, comme l'exige l'article 23 de la Loi sur la protection des renseignements personnels dans le secteur privé (EXIG-CON-10, section 12.2).

**EXIG-ARC-22** — NE DOIT PAS

**Pas d'historique brut comme mémoire**

L'historique brut des échanges **NE DOIT PAS** être réinjecté en entier dans le contexte du modèle ni conservé tel quel comme mémoire longue. Ce qui doit durer est consolidé (résumé, fait, décision) dans la limite d'une fenêtre de contexte bornée à la fiche de l'agent, persisté hors du modèle et récupéré au besoin.

Pourquoi : un historique brut coûte à chaque appel, dégrade le rappel et accumule du bruit sans limite.

**EXIG-ARC-23** — DOIT

**Contrôles avant toute écriture en mémoire longue**

Toute écriture en mémoire épisodique ou sémantique **DOIT** passer par des contrôles qui consignent la provenance de l'entrée, valident sa source, retirent les secrets et les renseignements personnels non nécessaires, l'isolent par locataire, par mandant et par serveur MCP, lui fixent une date d'expiration et permettent de restaurer un instantané antérieur.

Pourquoi : une information fausse inscrite en mémoire oriente toutes les décisions suivantes; l'OWASP en fait un risque distinct, l'empoisonnement de la mémoire et du contexte (ASI06 *Memory & Context Poisoning*) [28].

**EXIG-ARC-24** — DOIT

**Mémoire procédurale gérée comme du code**

Toute modification de la mémoire procédurale (invites système, contrats de compétences, flux et séquences d'outils validés) **DOIT** suivre le processus de changement logiciel : revue, version, évaluation avant déploiement et inscription au registre. Un agent **DOIT** être privé de tout droit d'écriture sur sa propre mémoire procédurale en production.

Pourquoi : CoALA juge l'écriture en mémoire procédurale nettement plus risquée que l'écriture épisodique ou sémantique[100]; elle change le comportement de l'agent pour toutes les tâches à venir, comme un déploiement de code.

**EXIG-ARC-25** — NE DOIT PAS

**Aucun magasin de mémoire partagé sans isolation**

Une mémoire longue **NE DOIT PAS** être accessible en écriture à des agents ou à des serveurs MCP qui ne sont pas isolés les uns des autres; le partage passe par des ressources en lecture seule ou par un service de mémoire qui applique les contrôles de l'exigence EXIG-ARC-23.

Pourquoi : le Centre d'architecture Azure proscrit le partage d'état mutable entre agents concurrents[9]; un magasin partagé permet à un composant compromis d'empoisonner tous les autres.

**ANTI-PATRONS PROSCRITS**

- Conserver l'état en mémoire de processus : le *checkpointer* en mémoire de LangGraph, par exemple, perd ses points de contrôle au redémarrage[124].
- Archiver les transcriptions brutes comme mémoire longue.
- Partager une table de mémoire modifiable entre serveurs MCP non isolés.
- Stocker des secrets, des jetons ou des approbations dans la mémoire d'un agent.
- Laisser un agent réécrire ses propres invites système ou contrats de compétences.

Plusieurs technologies réalisent ces rôles; elles sont citées à titre d'exemples non normatifs. LangGraph sépare les *checkpointers*, qui conservent l'état par fil d'exécution, d'un magasin distinct pour la mémoire à long terme partagée entre fils[124]. Letta maintient le patron MemGPT, qui déplace l'information entre le contexte et un stockage externe à la manière d'une mémoire virtuelle[153, 154]. Zep s'appuie sur Graphiti, un graphe de connaissances temporel qui conserve l'historique des relations, utile pour l'audit puisqu'on peut savoir à quel moment un fait était vrai[155]. GraphRAG

construit un graphe d'entités et des résumés de communautés qui aident à répondre aux questions de synthèse sur un vaste corpus[156]. Le cadre ne fixe ni produit ni latence cible : ces paramètres se mesurent dans l'environnement de l'entreprise.

## 5.6 Parcours d'une demande de bout en bout

Cette section suit une demande à travers les six couches pour montrer comment les règles s'enchaînent. Exemple : une conseillère du service à la clientèle demande l'émission d'un avoir de 1 200 $ sur la facture d'un client. L'agent de facturation est de classe de risque modérée, plafonné au niveau N3; l'outil `emettre_avoir` est de palier P2 (écriture réversible), et le catalogue lui fixe un seuil d'exécution autonome de 500 $, valeur propre à l'exemple.

1. **Canal.** La conseillère formule sa demande dans l'outil de collaboration. Le canal l'authentifie, établit le mandant, ouvre la trace et transmet l'intention sans la transformer (EXIG-ARC-03, EXIG-ARC-04).
2. **Routage.** Le routeur qualifie l'intention (« émettre un avoir ») et choisit le flux déterministe de traitement des avoirs inscrit au registre, plutôt qu'un agent libre; ce choix ne confère aucun droit (EXIG-ARC-07).
3. **Ouverture de la tâche.** Le moteur d'exécution durable crée la tâche, lui attribue son enveloppe budgétaire (jetons, coût, appels d'outils, délai) et obtient un jeton délégué au nom de la conseillère (section 9.3); l'état est persisté.
4. **Raisonnement.** L'étape d'analyse invoque l'agent de facturation, qui appelle son modèle par la passerelle de modèles; celle-ci résout l'alias, applique les quotas et impute jetons et coût au centre de coûts (EXIG-ARC-08, EXIG-ARC-09).
5. **Lecture.** L'agent appelle l'outil MCP `consulter_situation_compte` (palier P1) par la passerelle d'agents, qui vérifie le catalogue, restreint le jeton à l'audience du serveur MCP (paramètre `resource`, RFC 8707) et propage la trace; l'outil filtre ses résultats selon les droits de la conseillère (EXIG-ARC-16).
6. **Délégation éventuelle.** Si une vérification relève d'un autre domaine, la conformité par exemple, l'orchestrateur délègue la sous-tâche par A2A à l'agent de ce domaine, toujours par la passerelle; la séquence détaillée figure à la section 6.6.
7. **Approbation.** L'agent prépare l'appel à `emettre_avoir`. Le montant dépasse le seuil déclaré : le moteur suspend la tâche, état persisté, et présente l'action exacte à une approbatrice, dont la décision produit un jeton signé lié à cette action (section 8.5).
8. **Écriture.** Le moteur reprend la tâche. L'appel passe par la passerelle avec le jeton d'approbation et une clé d'idempotence; le serveur MCP de facturation appelle l'API de l'ERP, qui applique ses propres contrôles et enregistre l'avoir avec la référence de trace (EXIG-ARC-17, EXIG-ARC-18).
9. **Résultat ou compensation.** L'artefact remonte au canal et la conseillère reçoit la confirmation avec la référence d'audit. Si une étape ultérieure échoue sans reprise possible, le moteur exécute la compensation déclarée, ici l'annulation de l'avoir (section 7.5).
10. **Audit et apprentissage.** Le journal d'audit consigne le mandant, l'agent et sa version, le modèle, l'outil et l'empreinte de ses arguments, ainsi que l'approbation (section 10.3). Les traces alimentent l'évaluation continue et le coût par tâche réussie; un résumé validé de la résolution entre en mémoire épisodique (EXIG-ARC-23).

**À RETENIR**

Trois éléments descendent avec chaque appel : le mandant, le contexte de trace et les plafonds restants. Trois éléments remontent : le résultat, ses artefacts et les mesures de coût et de qualité. En environnement serveur, aucun appel n'atteint un outil MCP, un agent ou un système d'un autre domaine sans traverser la passerelle, et aucune écriture n'atteint un système d'enregistrement sans ses propres contrôles métier.

# 6 Interopérabilité

Ce chapitre fixe la manière dont les agents de l'entreprise se relient aux outils, aux données, aux autres agents, aux événements et aux personnes. Il s'appuie sur des protocoles ouverts sous gouvernance neutre : MCP pour l'intégration verticale (agent vers outil), A2A pour l'intégration horizontale (agent vers agent), CloudEvents et AsyncAPI pour les échanges asynchrones. Chaque intégration est examinée à quatre niveaux, du juridique au technique, et n'emploie que des standards inscrits au catalogue, à une version fixée. Les sections 6.5 à 6.7 détaillent chaque protocole; les sections 6.8 et 6.9 traitent des contrats, du versionnage et de la veille.

## 6.1 Quatre niveaux d'interopérabilité et gouvernance intégrée

Une connexion technique ne suffit pas : deux agents qui échangent sans s'entendre sur le sens des données ni sur les responsabilités produisent des erreurs silencieuses. Le cadre transpose donc aux agents le modèle du Cadre européen d'interopérabilité *(European Interoperability Framework, EIF)*.

Le nouvel EIF, publié par la Commission européenne en 2017, décrit l'interopérabilité en quatre couches (juridique, organisationnelle, sémantique et technique), encadrées par une composante transversale, la gouvernance intégrée des services publics, et par une couche de fond, la gouvernance de l'interopérabilité[157, 158]. Il énonce 12 principes et 47 recommandations, dont la conclusion d'accords d'interopérabilité dans toutes les couches (recommandation 26)[157]. Le texte reste vivant : le règlement (UE) 2024/903 pour une Europe interopérable, en vigueur depuis le 11 avril 2024, confie sa mise à jour au comité pour une Europe interopérable[159]. L'EIF vise les services publics européens; le cadre en retient la structure, pas le champ d'application.

Appliqués aux agents, les quatre niveaux posent quatre questions simples :

- **Juridique** : l'échange respecte-t-il les lois et les contrats? Par exemple, un agent qui confie l'analyse d'une réclamation à l'agent d'un partenaire hébergé en Ontario communique des renseignements personnels à l'extérieur du Québec, ce qui exige une EFVP préalable (art. 17 de la Loi sur la protection des renseignements personnels dans le secteur privé, RLRQ, c. P-39.1, ci-après « Loi sur le privé »)[160].
- **Organisationnel** : qui répond de quoi, de part et d'autre? L'EIF parle d'aligner les processus, les responsabilités et les attentes pour atteindre des objectifs communs[157].
- **Sémantique** : les parties comprennent-elles la même chose? L'EIF y inclut l'aspect syntaxique, soit le format exact des informations échangées, pour que ce qui est envoyé soit ce qui est compris[157].
- **Technique** : les systèmes peuvent-ils se joindre de façon sûre? Le niveau couvre les spécifications d'interface, les services d'interconnexion et d'intégration de données et les protocoles de communication sécurisés[157].

La gouvernance intégrée tient le tout dans la durée. L'EIF y exige notamment des structures, des rôles et des responsabilités définis, des ententes de niveau de service, la gestion des accords d'interopérabilité, des procédures de gestion du changement et des plans de continuité et de qualité des données, parce que les changements législatifs, organisationnels et technologiques perturbent régulièrement l'interopérabilité[157]. Dans le cadre, ce rôle revient au registre, au catalogue d'entreprise et au comité d'architecture et des risques agentiques (chapitre 11).

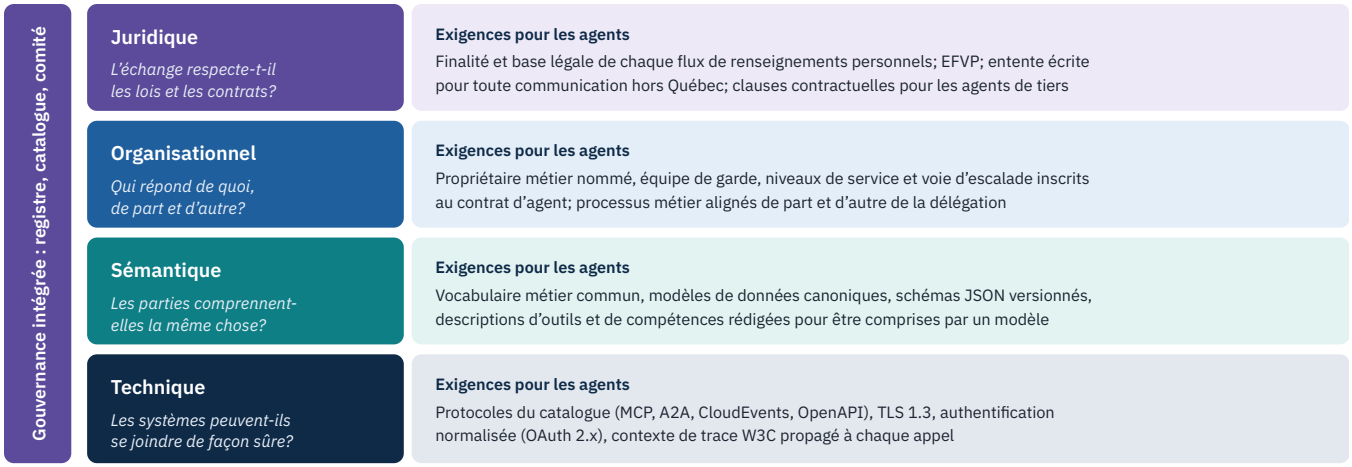



**Figure 5 — Quatre niveaux d'interopérabilité appliqués aux agents.** Chaque intégration d'agent se lit de haut en bas : le juridique fixe ce qui est permis, l'organisationnel désigne qui en répond, le sémantique établit le sens des données et le technique, la façon dont elles circulent. La gouvernance intégrée encadre les quatre niveaux.

Source : adapté du nouveau Cadre européen d'interopérabilité (Commission européenne, 2017); exigences propres au cadre.

**Tableau 14 — Niveaux d'interopérabilité et exigences minimales pour une intégration d'agent**

| Niveau | Question à trancher | Exigences minimales | Traité à |
|---|---|---|---|
| Juridique | L'échange respecte-t-il les lois et les contrats? | Finalité et fondement (consentement ou exception prévue par la loi) documentés pour chaque flux de renseignements personnels; EFVP lorsque la loi l'exige, notamment avant toute communication hors Québec; entente écrite avec chaque tiers; clauses contractuelles pour les agents et serveurs MCP de tiers. | Chapitres 12 et 13 |
| Organisationnel | Qui répond de quoi, de part et d'autre? | Propriétaire métier nommé et équipe de garde de chaque côté; niveaux de service et voie d'escalade inscrits au contrat d'agent; processus métier modélisés et alignés de part et d'autre de la délégation. | Sections 11.1 et 11.4 |
| Sémantique | Les parties comprennent-elles la même chose? | Vocabulaire métier commun; données de référence (taxonomies, listes de codes); schémas JSON Schema 2020-12 versionnés; unités, devises, assiettes de taxes et fuseaux horaires explicites; descriptions d'outils et de compétences rédigées pour être comprises par un modèle. | Section 6.8 |
| Technique | Les systèmes peuvent-ils se joindre de façon sûre? | Protocole du catalogue à la version fixée; TLS 1.3 par défaut et TLS 1.2 toléré comme plancher (choix du cadre, conforme aux recommandations d'A2A[68, 161]); authentification normalisée; contexte de trace W3C propagé à chaque appel. | Sections 6.3 à 6.7; chapitres 9 et 10 |
| Gouvernance intégrée (transversale) | L'échange restera-t-il interopérable dans le temps? | Accord d'interopérabilité par intégration; gestion du changement des contrats; plan de continuité; fiche d'agent et catalogue à jour. | Section 6.8; chapitre 11 |
| Gouvernance de l'interopérabilité (fond) | Qui choisit les standards et qui arbitre? | Catalogue des protocoles révisé chaque trimestre; dérogations instruites par le comité. | Sections 6.3, 11.6 et 11.7 |

**EXEMPLE : UNE ERREUR QUE LE PROTOCOLE NE VOIT PAS**

L'agent de facturation d'une filiale transmet par A2A un artefact dont le champ `montant` vaut 1 149,75. L'agent de rapprochement du siège le lit comme un montant hors taxes, alors qu'il inclut la TPS et la TVQ. Les deux agents respectent le protocole à la lettre; seule la revue sémantique (schéma commun, unité et assiette déclarées) prévient l'écart.

**EXIG-INT-01** — DOIT

**Revue d'interopérabilité à quatre niveaux**

Toute intégration d'un agent avec un outil, une ressource, un autre agent ou un flux d'événements **DOIT** faire l'objet, avant sa mise en production, d'une revue couvrant les niveaux juridique, organisationnel, sémantique et technique du tableau 14. Le résultat **DOIT** être consigné dans la fiche d'agent (annexe B).

Pourquoi : une intégration techniquement valide peut être illicite, sans responsable ou fausse sur le sens; l'EIF promeut l'interopérabilité dès la conception[157].

**EXIG-INT-02** — DOIT

**Vocabulaire et schémas d'entreprise**

Les données échangées entre agents, entre agents et outils et sur le bus d'événements **DOIVENT** être décrites par des schémas JSON Schema 2020-12 versionnés (dans AsyncAPI 3.x, en déclarant explicitement `schemaFormat` à JSON Schema 2020-12, le format par défaut étant le Schema Object d'AsyncAPI) et s'appuyer sur le vocabulaire métier et les données de référence de l'entreprise (taxonomies, listes de codes, unités et devises explicites). Ces schémas **DOIVENT** être gérés au niveau de l'entreprise, et non par chaque équipe d'agent.

Pourquoi : l'EIF demande une gestion de l'information coordonnée au plus haut niveau et appuyée sur des données de référence[157]; JSON Schema 2020-12 est le dialecte par défaut de MCP[162, 163].

**EXIG-INT-03** — DOIT

**Accord d'interopérabilité et gestion du changement**

Toute intégration qui franchit la frontière d'un domaine métier ou de l'entreprise **DOIT** être couverte par un accord d'interopérabilité, intégré au contrat d'agent ou d'outil, qui nomme le propriétaire de chaque partie, les niveaux de service, la voie d'escalade et la procédure de gestion du changement (préavis, période de coexistence, tests de non-régression).

Pourquoi : l'EIF recommande des accords d'interopérabilité dans toutes les couches et une gestion explicite du changement[157].

## 6.2 Carte des interactions et protocoles retenus

Le cadre associe un protocole à chaque type d'interaction d'un agent. La figure 6 situe ces interactions autour de l'agent : verticalement vers les outils, horizontalement vers les autres agents, de façon asynchrone vers le bus d'événements et, du côté humain, vers l'interface.

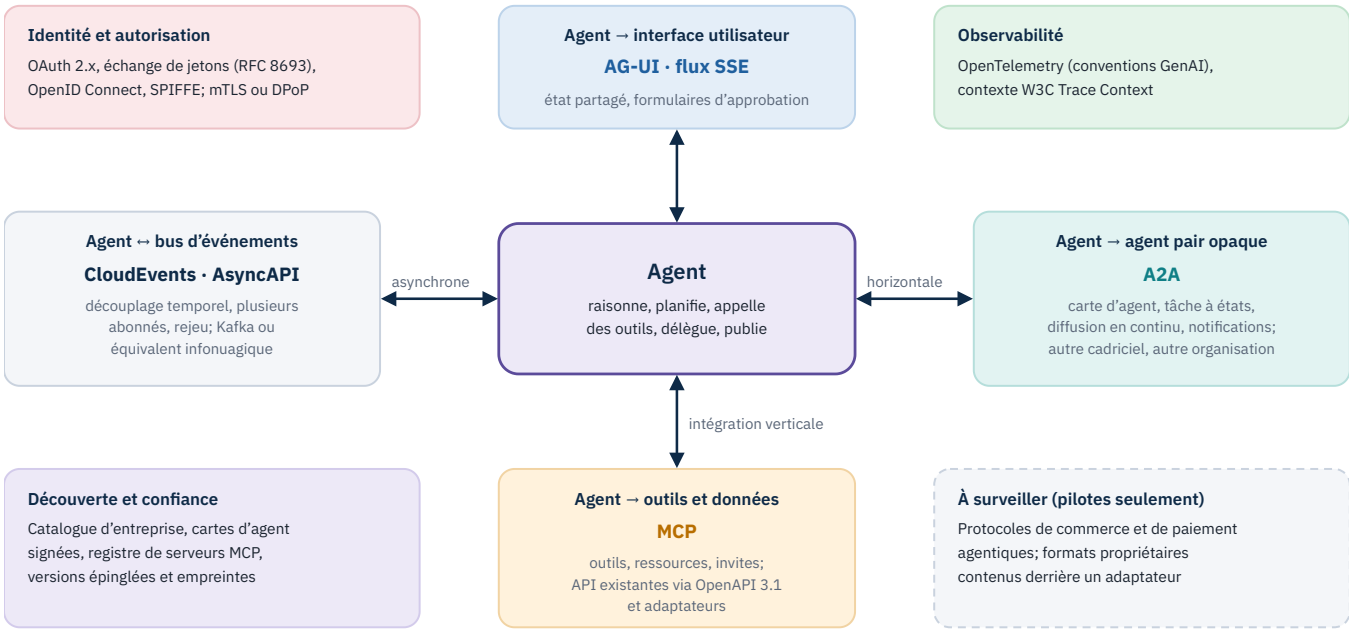



**Figure 6 — Carte des interactions de l'agent et protocoles retenus.** L'agent occupe le centre; chaque liaison correspond à un type d'interaction et au protocole retenu. Les bandeaux du bas rappellent les fonctions transversales (identité, observabilité, découverte et confiance) et ce qui reste en veille.

Source : cadre CRE-IA-2026-01; répartition MCP et A2A conforme au guide officiel du projet A2A.

- **Agent → outils et données : MCP.** La cible a des entrées et des sorties définies, souvent sans état; l'agent appelant garde la boucle de raisonnement. Les API existantes y sont exposées par des adaptateurs, sans réécriture (section 6.5).
- **Agent → agent : A2A.** La cible est un agent autonome, potentiellement opaque, qui raisonne, garde un état sur plusieurs tours et peut demander une précision (section 6.6).
- **Agent ↔ bus d'événements : CloudEvents et AsyncAPI.** L'émetteur ignore ses consommateurs; l'échange admet plusieurs abonnés, le découplage dans le temps et le rejeu des entrées (section 6.7).
- **Agent → interface : AG-UI ou flux SSE *(Server-Sent Events)* structuré.** AG-UI est un protocole ouvert et événementiel (31 types d'événements standard selon la documentation, licence MIT), né d'un partenariat de CopilotKit avec LangChain et CrewAI; il n'impose pas de transport (SSE, WebSockets, webhooks, etc.) et complète MCP et A2A[164, 165, 166]. Il demeure au statut Évaluer.

Cette répartition reprend le guide officiel du projet A2A : MCP relie un agent à des outils et à des ressources aux entrées et aux sorties définies, souvent sans état, alors qu'A2A relie des agents autonomes, potentiellement opaques, qui raisonnent et conservent un état sur des échanges à plusieurs tours[39]. Les deux se complètent : l'agent spécialiste joint par A2A utilise lui-même des outils MCP. L'événement comble un troisième besoin, car MCP ne garantit ni la livraison ni la cohérence des données, alors qu'un journal d'événements persistant découple producteurs et consommateurs, comme le souligne l'architecte Kai Waehner[167].

Une question départage la plupart des cas : la cible raisonne-t-elle? Si elle exécute une fonction aux entrées et aux sorties définies, c'est un outil, même si elle emploie un modèle en interne (règle du cadre). Si elle planifie, conserve un état et peut renvoyer une question, c'est un agent. Si l'émetteur ne doit pas connaître ses destinataires, c'est un événement. Dans tous les cas, l'échange qui sort d'un domaine passe par la passerelle d'agents (section 9.4); la documentation d'A2A recommande d'ailleurs fortement une solution de gestion d'API devant tout serveur exposé à l'externe[161].

**À RETENIR**

MCP pour ce qui s'exécute, A2A pour ce qui raisonne, l'événement pour ce qui se diffuse. Les trois passent par la passerelle d'agents et par le catalogue d'entreprise.

**EXIG-INT-04**
**DOIT**

**Protocole désigné par type d'interaction**

Chaque interaction d'un agent **DOIT** emprunter le protocole que le catalogue désigne pour son type : MCP pour l'accès aux outils, aux ressources et aux invites; A2A pour la délégation à un autre agent; CloudEvents, décrit par un contrat AsyncAPI, pour les événements. Tout connecteur propriétaire ou format hors catalogue exige une dérogation (section 11.6).

Pourquoi : un protocole commun par type d'interaction ramène le maillage de N × M connecteurs à N + M contrats (chapitre 2) et permet à la passerelle d'appliquer une politique uniforme.

**EXIG-INT-05**
**DEVRAIT**

**Agent pair invoqué par A2A, pas déguisé en outil**

Un agent d'un autre domaine ou d'un tiers, qui planifie, conserve un état ou peut demander une précision, **DEVRAIT** être invoqué par A2A plutôt qu'enveloppé dans un outil MCP. L'enveloppe « agent comme outil » reste permise à l'intérieur d'un même agent ou d'un même domaine de confiance.

Pourquoi : A2A expose le cycle de vie de la tâche (entrée requise, authentification requise, annulation, artefacts), que l'enveloppe en outil masque; l'approbation humaine et l'audit en dépendent[68].

## 6.3 Catalogue des protocoles et standards

Le catalogue des protocoles dit quel standard employer, à quelle version et avec quel degré de confiance. Il distingue ce qui est une norme publiée, ce qui n'est qu'un brouillon et ce qui relève encore de l'annonce. Chaque entrée porte l'un des quatre statuts suivants, éventuellement assorti d'une réserve :

- Adopter usage par défaut, exigé pour toute nouvelle intégration du type visé;
- Évaluer pilotes encadrés, derrière la passerelle d'agents (section 6.9); passage en production seulement après une décision du comité qui fait passer l'entrée au statut Adopter;
- Surveiller veille et essais hors production, sans données réelles;
- Contenir existant toléré derrière un adaptateur, sans nouvel usage, avec un plan de sortie daté.

**Tableau 15 — Catalogue des protocoles et standards (état au 27 octobre 2026)**

| Interaction | Standard et version de référence | Statut | Règle d'usage |
|---|---|---|---|
| Agent → outils et données | Model Context Protocol (MCP), révision 2026-07-28, courante au 27 octobre 2026[34, 168] | Adopter | Serveurs inscrits au catalogue et joints par la passerelle; Streamable HTTP en environnement serveur; extensions officielles (Tasks, Apps, autorisation; Enterprise-Managed Authorization reste au statut Évaluer), désactivées par défaut dans MCP, activées seulement si elles sont inscrites au catalogue[169] (6.5). |
| Agent → agent | Agent2Agent (A2A), version de protocole 1.0 (publication 1.0.0 du 12 mars 2026; correctif 1.0.1 du 28 mai 2026)[29, 30] | Adopter | Carte d'agent signée et inscrite; liaisons standard JSON-RPC, gRPC ou HTTP+JSON; en-tête `A2A-Version` à chaque requête; interfaces 0.3 seulement en coexistence bornée (6.6). |

| Interaction | Standard et version de référence | Statut | Règle d'usage |
|---|---|---|---|
| Agent → API existante | OpenAPI 3.1.x ou 3.2.x (3.2.1 du 10 septembre 2026)[170]; erreurs au format RFC 9457[171] | Adopter | Aucun appel d'API sans contrat; exposition aux agents par des adaptateurs déclaratifs qui produisent des outils orientés tâche, sans réécrire les services. |
| Séquences d'appels d'API | Arazzo 1.1.0 (OpenAPI Initiative, 17 mai 2026)[172] | Évaluer | Description lisible par machine des flux déterministes d'appels d'API. |
| Schémas de données | JSON Schema 2020-12[163] | Adopter | Dialecte unique des contrats d'outils, de compétences et d'événements; aucun `$ref` vers une URI réseau non autorisée[162]. |
| Événements asynchrones | CloudEvents 1.0 (révision 1.0.2) pour l'enveloppe; AsyncAPI 3.x pour le contrat[173, 174] | Adopter | Tout événement produit ou consommé par un agent; extensions de gouvernance et compteur de sauts (6.7). |
| Identité et autorisation | OAuth 2.0 profilé par la RFC 9700 (BCP 240); OpenID Connect; échange de jetons (RFC 8693); SPIFFE et SPIRE, projets diplômés de la CNCF[70, 116, 117, 175] | Adopter | Identité propre à chaque agent; jetons délégués à audience restreinte (chapitre 9). |
| Identité et autorisation | OAuth 2.1, Internet-Draft (draft-ietf-oauth-v2-1-16, septembre 2026)[176] | Adopter avec réserve | S'aligner sur son profil (PKCE, ni octroi implicite ni octroi par mot de passe) sans le présenter comme une norme publiée. |
| Identité et autorisation | Identity Assertion JWT Authorization Grant (ID-JAG, brouillon de groupe de travail) et extension MCP Enterprise-Managed Authorization[177, 178] | Évaluer | Accès des employés aux serveurs MCP décidé par le fournisseur d'identité de l'entreprise. |
| Identité et autorisation | Transaction Tokens (draft-ietf-oauth-transaction-tokens-11)[179] | Évaluer | Propagation du contexte d'identité dans la chaîne d'appels interne d'un domaine. |
| Observabilité | OpenTelemetry; conventions sémantiques GenAI au niveau Development, version épinglée (v1.41.0 ou première version étiquetée du dépôt `semantic-conventions-genai`)[180, 181] | Adopter | Couche de correspondance dans les tableaux de bord; attributs d'entreprise sous préfixe de domaine inversé (chapitre 10). |
| Observabilité | W3C Trace Context, Recommandation[103] | Adopter | Contexte propagé dans HTTP, dans le champ `_meta` de MCP, dans A2A et dans CloudEvents. |
| Agent → interface utilisateur | AG-UI (Agent-User Interaction Protocol)[164] | Évaluer | Pilotes; à défaut, flux SSE structuré produit par l'orchestrateur. |
| Infrastructure multiagent | AGNTCY : OASF *(Open Agentic Schema Framework)* et Agent Directory Service *(ADS)*; SLIM *(Secure Low-Latency Interactive Messaging)* et Identity[182] | Évaluer OASF, ADS<br>Surveiller SLIM, Identity | Projet de la Linux Foundation candidat à l'AAIF; aucune dépendance de production sans décision du comité (6.9). |
| Commerce et paiements agentiques | Agentic Commerce Protocol (OpenAI et Stripe), AP2, UCP[41, 183, 184] | Surveiller | Aucun paiement initié par un agent hors des règles de la section 6.9. |

| Interaction | Standard et version de référence | Statut | Règle d'usage |
|---|---|---|---|
| Réseaux d'agents ouverts, à identité décentralisée (DID du W3C) | Agent Network Protocol (ANP), projet communautaire[185, 186] | Surveiller | Aucune adoption en production. |
| Formats propres à un fournisseur | Variable | Contenir | Tolérés derrière un adaptateur, jamais exposés directement aux autres agents; plan de sortie daté. |

Les versions sont fixées au catalogue, pas dans chaque contrat d'agent : une montée de version se décide une fois, pour tout le parc. Le comité révise le catalogue chaque trimestre (section 11.7); un correctif de sécurité peut justifier une révision extraordinaire.

**ATTENTION : NORMES, BROUILLONS ET PRÉVERSIONS**

Plusieurs entrées ne sont pas des normes publiées : OAuth 2.1, ID-JAG et Transaction Tokens sont des Internet-Drafts; les extensions documentées de CloudEvents (Auth Context, Data Classification, Distributed Tracing, etc.) n'ont aucun statut officiel et peuvent être modifiées ou retirées[187]; les conventions GenAI d'OpenTelemetry sont au niveau Development, où des changements incompatibles, voire un retrait, peuvent survenir sans garantie de dépréciation préalable[119, 188]; le registre officiel MCP est en préversion[43]. Le cadre les emploie pour ce qu'ils sont : à une version épinglée, derrière une couche d'adaptation.

**EXIG-INT-06** DOIT

**Statut au catalogue avant tout usage en production**

Un protocole, un standard ou une extension de protocole **DOIT** figurer au catalogue avec le statut Adopter pour être employé en production. Le statut Évaluer limite l'usage à des pilotes; le statut Surveiller l'exclut de la production; le statut Contenir interdit tout nouvel usage.

Pourquoi : l'ajout silencieux d'un protocole recrée les intégrations ad hoc que le cadre veut éliminer et soustrait les échanges aux contrôles de la passerelle.

**EXIG-INT-07** DOIT

**Version de référence fixée au catalogue**

Le catalogue **DOIT** fixer, pour chaque standard adopté, la version de référence (révision MCP, version de protocole A2A, version des conventions OpenTelemetry, de CloudEvents et d'AsyncAPI). Chaque serveur, agent et passerelle **DOIT** déclarer les versions qu'il prend en charge; une déclaration incompatible avec le catalogue **DOIT** bloquer l'inscription au registre.

Pourquoi : MCP et A2A rejettent explicitement une version non prise en charge (erreurs `UnsupportedProtocolVersion` et `VersionNotSupportedError`)[68, 162]; un parc aux versions mêlées échoue de façon imprévisible.

**EXIG-INT-08** DOIT

**Révision trimestrielle du catalogue des protocoles**

Le comité d'architecture et des risques agentiques **DOIT** réviser le catalogue des protocoles au moins une fois par trimestre et consigner, pour chaque entrée, la date de révision, le statut retenu et sa justification. Tout changement de statut est notifié aux propriétaires des agents qui emploient l'entrée.

Pourquoi : entre mars 2025 et juillet 2026, MCP a publié quatre révisions (2025-03-26, 2025-06-18, 2025-11-25 et 2026-07-28) et A2A est passé de la version 0.1 à la version 1.0[30, 34, 189]; un catalogue figé devient faux en quelques mois.

**EXIG-INT-09**
**NE DOIT PAS**

**Statut normatif exact**

Une exigence d'architecture, une clause contractuelle ou une entrée du catalogue **NE DOIT PAS** présenter un brouillon (Internet-Draft), une préversion ou une annonce de fournisseur comme une norme publiée. Le catalogue indique le statut exact de chaque élément : norme, recommandation, brouillon de groupe de travail, brouillon individuel, préversion ou projet hébergé par une fondation.

Pourquoi : un brouillon peut changer ou expirer (la version -16 d'OAuth 2.1 expire le 7 mars 2027)[176]; une exigence qui s'y appuie doit pouvoir évoluer sans renégocier un contrat.

## 6.4 Matrice de sélection

La matrice traduit la carte de la figure 6 en règle de choix pour les cas courants. Elle se lit par scénario : le protocole découle du type de cible, du couplage recherché et de l'endroit où vit l'état.

**Tableau 16 — Matrice de sélection des protocoles**

| Scénario | Protocole | Couplage | État côté appelé | Raison du choix |
|---|---|---|---|---|
| Processus connu à étapes fixes (réglementé ou audité) | Flux déterministe (chapitre 7) qui appelle des outils MCP ou des API | Piloté par le moteur | Dans le moteur d'exécution durable | Prévisible et auditable; le modèle n'intervient qu'aux étapes qui l'exigent. |
| Agent → outil, base de données ou moteur de recherche documentaire | MCP sur Streamable HTTP | Synchrone et court; réponse JSON ou flux SSE propre à la requête[190] | Aucun état cognitif; état applicatif par identifiant explicite, revalidé à chaque appel | Découverte des schémas et contrôle d'accès unifié à la passerelle. |
| Agent → traitement d'outil de longue durée | MCP avec l'extension officielle Tasks, si elle est inscrite au catalogue[191] | Asynchrone, par interrogation | Tâche durable (identifiant, durée de vie) | Évite de garder une connexion ouverte; annulation coopérative. |
| API REST existante → parc d'agents | Contrat OpenAPI exposé en outils MCP par un adaptateur | Synchrone | Aucun | Réutilise le patrimoine d'API sans connecteur propre à chaque agent. |
| Agent → agent spécialiste, tâche interactive ou en plusieurs tours | A2A | Lâche, par compétence; réponse bloquante, en continu ou par notification push | Tâche à états (huit états de cycle de vie en A2A 1.0, neuf valeurs d'énumération avec `TASK_STATE_UNSPECIFIED`) [192] | Suivi de progression, demandes de précision, échange d'artefacts entre cadriciels distincts. |
| Agent → agent d'une autre organisation | A2A par la passerelle, carte signée, jeton délégué | Lâche et contractuel | Tâche à états, opaque pour l'appelant | La confiance repose sur la signature de la carte, le contrat et l'échange de jetons, pas sur le réseau. |
| Système ou agent → plusieurs agents réactifs | CloudEvents et AsyncAPI sur le bus d'événements | Découplé (publication-abonnement) | Journal durable, rejouable dans la limite de la rétention[140] | Résilience, absorption des pointes, ajout d'abonnés sans toucher l'émetteur. |

| Scénario | Protocole | Couplage | État côté appelé | Raison du choix |
|---|---|---|---|---|
| Agent → interface utilisateur riche | AG-UI (Évaluer) ou flux SSE structuré | Temps réel | Session d'interface partagée | Synchronise l'état de l'agent et les formulaires d'approbation. |

Lorsqu'un cas ne figure pas dans la matrice, quatre questions, posées dans l'ordre, mènent au bon choix :

1. Les étapes sont-elles connues d'avance? Si oui, un flux déterministe orchestre le travail et n'emploie un agent qu'aux étapes de jugement.
2. La cible est-elle un outil ou une donnée aux entrées et aux sorties définies? Si oui, MCP.
3. La cible raisonne-t-elle, garde-t-elle un état, peut-elle demander une précision ou une autorisation? Si oui, A2A; au-delà de 5 secondes (seuil fixé par le cadre, EXIG-A2A-07), la diffusion en continu ou les notifications push s'imposent (section 6.6).
4. L'émetteur doit-il ignorer qui consomme, ou faut-il plusieurs abonnés ou un rejeu? Si oui, un événement.

La quatrième question a une base arithmétique simple : relier N agents deux à deux exige jusqu'à N(N–1)/2 intégrations, contre N connexions vers un courtier. Le bus réduit le nombre de liaisons, pas la gouvernance des sujets, des schémas et des contrats, qui reste entière.

**EXIG-INT-10** — DOIT

**Choix de protocole justifié par la matrice**

Le protocole retenu pour chaque intégration **DOIT** être justifié dans la fiche d'agent par renvoi à une ligne du tableau 16. Un scénario absent de la matrice, ou un choix qui s'en écarte, **DOIT** être soumis à l'architecture d'entreprise avant la construction.

Pourquoi : la justification écrite rend le choix vérifiable en revue et alimente la mise à jour de la matrice.

**EXIG-INT-11** — DEVRAIT

**Diffusion d'un changement d'état par événement**

Lorsqu'un changement d'état intéresse plusieurs consommateurs, l'agent ou le système émetteur **DEVRAIT** publier un événement plutôt qu'appeler chaque consommateur par A2A ou par MCP.

Pourquoi : l'appel direct couple l'émetteur à chaque consommateur et propage leurs pannes; le bus absorbe les pointes et accepte de nouveaux abonnés sans modifier l'émetteur.

## 6.5 Intégration verticale : Model Context Protocol

Cette section fixe la manière dont l'entreprise relie ses agents à leurs outils, à leurs ressources et à leurs invites au moyen du Model Context Protocol (MCP), dans sa révision 2026-07-28. Elle distingue ce que la spécification exige de ce que le cadre ajoute pour exploiter le protocole à l'échelle de l'entreprise : passerelle d'agents, catalogue d'entreprise, autorisation obligatoire et contrôles de sécurité propres au protocole. Les règles générales de contrat et de versionnage sont à la section 6.8; l'identité et la délégation, au chapitre 9.

### Rôle et gouvernance du protocole

MCP normalise le lien vertical entre un agent et les systèmes qu'il consulte ou modifie. Au lieu d'écrire un connecteur pour chaque couple agent-système, on expose chaque système une seule fois par un serveur MCP, que tout agent conforme peut ensuite utiliser. Anthropic a annoncé MCP comme norme ouverte le 25 novembre 2024[20]. La formule « N × M » qui résume ce bénéfice (chapitre 2) est une vulgarisation, non un énoncé de la spécification.

Le 9 décembre 2025, Anthropic a donné MCP à l'Agentic AI Foundation (AAIF), fonds dirigé de la Linux Foundation cofondé par Anthropic, Block et OpenAI; MCP en est un projet fondateur, aux côtés de goose et d'AGENTS.md[4, 193]. Au lancement, les membres platine étaient Amazon Web Services, Anthropic, Block, Bloomberg, Cloudflare, Google, Microsoft et OpenAI[4]. Le modèle de gouvernance technique est resté inchangé : des responsables principaux arbitrent l'évolution de la spécification, qui progresse par des propositions d'amélioration (SEP, *Specification Enhancement Proposals*), tandis que le conseil de l'AAIF gère la stratégie, le budget et les adhésions[14]. Depuis la révision 2026-07-28, une SEP prend la forme d'une demande de tirage versée au dépôt de la spécification; une extension officielle suit une filière distincte et exige au moins une implémentation de référence dans un SDK officiel[168, 169]. Selon les responsables du projet, on comptait en décembre 2025 environ 10 000 serveurs actifs et plus de 97 millions de téléchargements mensuels des SDK[14].

La spécification est versionnée par date : l'identifiant AAAA-MM-JJ correspond au dernier changement incompatible. Les révisions publiées sont 2024-11-05, 2025-03-26, 2025-06-18, 2025-11-25 et 2026-07-28, révision courante au 27 octobre 2026[34, 168, 189]. Cette dernière a été publiée le 28 juillet 2026, après une version candidate verrouillée le 21 mai 2026 et dix semaines de validation; les SDK TypeScript, Python, Go et C# la prenaient en charge dès sa sortie, le SDK Rust en version bêta[33, 194]. La feuille de route publiée le 22 août 2026 n'annonce aucune date pour la prochaine révision. Elle donne priorité à la messagerie agentique, à un transport natif HTTP (y compris pour les serveurs locaux), à l'identité des agents et à la sécurité d'entreprise (DPoP, fédération d'identité de charge de travail, ID-JAG, échange de jetons), à un contrat unique pour les résultats de `tools/call` et à la découverte progressive des outils[195].

Le registre officiel MCP, lancé en préversion le 8 septembre 2025, l'est toujours selon sa documentation. Il n'héberge que des métadonnées qui renvoient aux paquets, authentifie les espaces de noms, délègue l'analyse de sécurité aux registres de paquets et ne prend pas en charge les serveurs privés; pour ceux-ci, il recommande d'héberger son propre registre MCP privé[25, 43]. Le catalogue d'entreprise est donc un composant distinct, sous la responsabilité de l'entreprise (section 6.8 et section 11.4).

**EXIG-MCP-01**
**DOIT**

**Exposition des capacités par MCP, derrière la passerelle**

Tout outil, toute ressource et toute invite mis à la disposition d'un agent **DOIVENT** l'être par un serveur MCP inscrit au catalogue d'entreprise et, dans tout environnement serveur, publié derrière la passerelle d'agents (sur un poste de développement, l'exécution locale par `stdio` obéit à l'EXIG-MCP-08). Un hôte ne se connecte jamais directement à un serveur de domaine. Un format d'appel propriétaire n'est toléré que derrière un adaptateur, conformément au statut « Contenir » du catalogue des protocoles (section 6.3).

Pourquoi : un contrat unique, appliqué en un seul point, permet de filtrer, de journaliser et de révoquer l'accès sans modifier les agents.

**EXIG-MCP-02**
**DOIT**

**Révision de référence vérifiée par la découverte**

Tout serveur MCP mis en production après l'approbation du cadre **DOIT** mettre en œuvre la révision 2026-07-28, y compris la méthode `server/discover`. La révision prise en charge par chaque serveur est inscrite et épinglée au catalogue; la passerelle la vérifie par `server/discover`, en contournant son propre cache (le résultat porte `ttlMs` et `cacheScope`), à l'homologation et à chaque déploiement, et refuse un serveur dont les versions ou capacités annoncées diffèrent de l'inscription.

Pourquoi : la spécification oblige tout serveur 2026-07-28 à implémenter `server/discover`, qui renvoie en une requête ses versions, ses capacités et son identité[168]; le catalogue dispose ainsi d'un relevé uniforme à comparer à l'inscription; ce relevé est déclaré par le serveur lui-même (`serverInfo` est auto-déclaré et ne devrait pas fonder une décision de sécurité) : il ne prouve ni l'identité ni l'intégrité du serveur.

### Architecture hôte-client-serveur et primitives

MCP suit une architecture client-serveur à trois rôles. L'hôte est l'application d'IA : un orchestrateur, un agent ou un poste de travail. Il crée un client MCP pour chaque serveur, et chaque client entretient une connexion dédiée[63]. Le protocole comporte deux couches : une couche de données, faite d'échanges JSON-RPC 2.0 (découverte, primitives, notifications), et une couche de transport, qui règle la connexion, le tramage et l'autorisation[63]. En 2026-07-28, l'identifiant d'une requête ne peut pas être nul et tout résultat porte un champ `resultType`[162].

Un serveur expose trois primitives : les outils, fonctions exécutables découvertes par `tools/list` et appelées par `tools/call` sous le contrôle du modèle; les ressources, données contextuelles identifiées par URI et lues par `resources/list` et `resources/read`; les invites, gabarits réutilisables obtenus par `prompts/list` et `prompts/get`[63, 64]. Côté client, l'élicitation, qui permet au serveur de demander une information ou une confirmation à la personne, demeure active; l'échantillonnage *(Sampling)* et les racines *(Roots)* sont dépréciés depuis 2026-07-28[196].

Dans l'entreprise, la passerelle d'agents s'insère entre les hôtes et les serveurs (figure 7). Elle agit en mandataire inverse et applique à chaque requête les contrôles décrits à la section 9.4. Elle peut publier chaque serveur sous son propre point d'accès ou en agréger plusieurs derrière un point d'accès virtuel. Dans ce second cas, elle préfixe les noms d'outils par un identifiant de serveur : la spécification signale le risque de collision de noms et précise que le nom annoncé dans `serverInfo` n'est pas garanti unique[197].

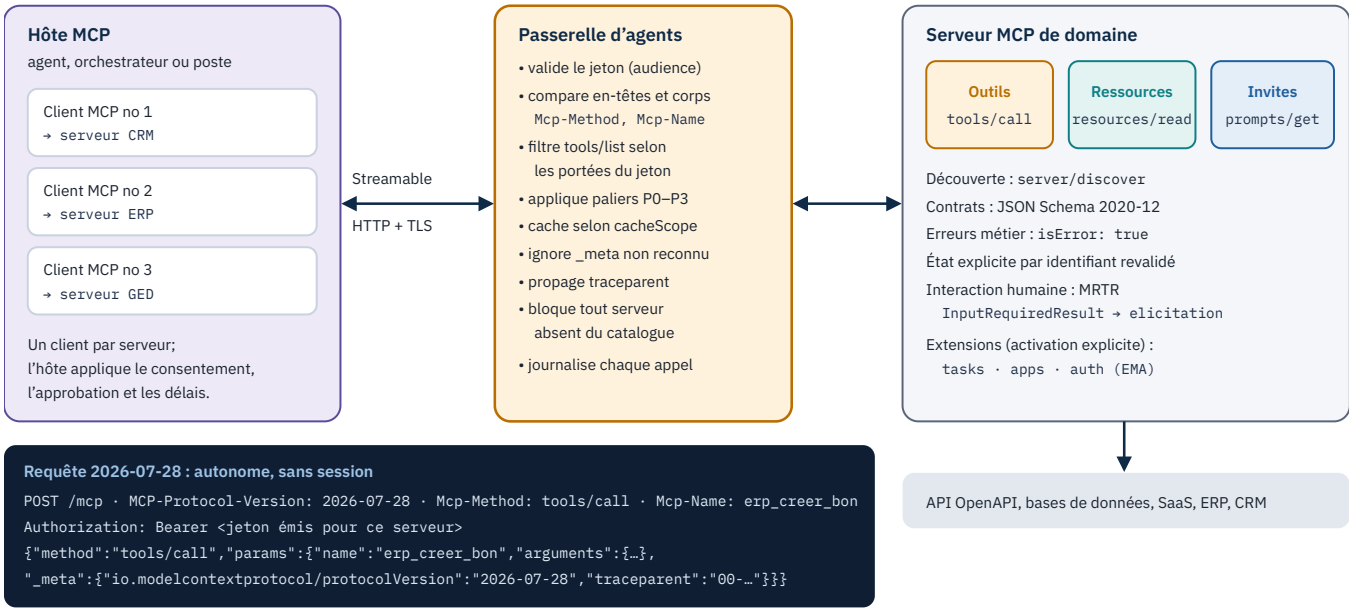



**Figure 7 — MCP 2026-07-28 derrière la passerelle d'agents.** L'hôte crée un client par serveur; chaque requête, autonome et sans session, traverse la passerelle, qui vérifie le jeton, la concordance des en-têtes et du corps, le palier de l'outil et le catalogue avant de joindre le serveur de domaine. La requête illustrée est abrégée : une requête complète porte aussi les capacités du client dans `_meta`.
Source : cadre CRE-IA-2026-01, d'après la spécification MCP 2026-07-28[198].

**Requête tools/call conforme à la révision 2026-07-28 (extrait)**

```
POST /mcp HTTP/1.1
Host: passerelle-agents.interne.exemple
Content-Type: application/json
Accept: application/json, text/event-stream
Authorization: Bearer <jeton émis pour ce serveur seulement>
MCP-Protocol-Version: 2026-07-28
Mcp-Method: tools/call
Mcp-Name: approvisionnement_creer_bon_commande
Mcp-Param-Cost-Center: CC-4410

{"jsonrpc": "2.0", "id": 42, "method": "tools/call",
 "params": {
   "name": "approvisionnement_creer_bon_commande",
   "arguments": {"idempotency_key": "…", "centre_cout": "CC-4410", "…": "…"},
   "_meta": {
     "io.modelcontextprotocol/protocolVersion": "2026-07-28",
     "io.modelcontextprotocol/clientCapabilities": {"…": "…"},
     "traceparent": "00-…-…-01"}}}
```

Quatre traits ressortent. La requête se suffit à elle-même : aucun identifiant de session. Les en-têtes `Mcp-Method` et `Mcp-Name` recopient le corps pour permettre le routage sans l'analyser, d'où l'obligation de vérifier leur concordance (EXIG-MCP-15). Le jeton n'est valable que pour ce serveur (EXIG-MCP-11). Enfin, l'en-tête `Mcp-Param-Cost-Center` provient d'un argument marqué `x-mcp-header` ; un centre de coûts s'y prête, une donnée sensible jamais (EXIG-MCP-18).

> **À RETENIR**
>
> Un serveur MCP est un adaptateur sans état cognitif : il expose des capacités à entrées et sorties définies et ne conduit pas la boucle de raisonnement de l'agent appelant. Le modèle propose d'utiliser un outil; la passerelle et le catalogue décident si l'appel est permis, à quelles conditions et sous quel jeton.

## Ce qui change avec la révision 2026-07-28

La révision 2026-07-28 rend le protocole sans état. Pour l'exploitation, c'est une simplification : tout nœud d'un parc peut traiter n'importe quelle requête, sans affinité de session, y compris sur une plateforme sans serveur[162, 168]. Pour la sécurité, le risque se déplace des sessions vers les identifiants d'état applicatifs et les nouveaux en-têtes. Le tableau 17 résume les changements et leur effet pour l'entreprise.

**Tableau 17 — Principaux changements de la révision MCP 2026-07-28 et effet pour l'entreprise**

| Changement | Effet pour l'entreprise |
|---|---|
| **Protocole sans état.** Retrait de la poignée de main `initialize`, des sessions protocolaires et de l'en-tête `Mcp-Session-Id` (SEP-2567, SEP-2575); chaque requête porte dans `_meta` sa version de protocole et les capacités du client[162, 168]. | Plus de répartiteurs de charge à sessions persistantes *(sticky sessions)* ni de magasin de sessions partagé. L'état qui doit durer passe par un identifiant explicite émis par le serveur (EXIG-MCP-17). |
| **Découverte.** Méthode `server/discover`, obligatoire pour le serveur, facultative pour le client : versions prises en charge, capacités (extensions comprises) et identité, dans une réponse que l'on peut mettre en cache (`ttlMs` et `cacheScope`)[168, 199]. | Sonde d'inventaire et d'homologation; contrôle de cohérence avec le catalogue (EXIG-MCP-02). |

| Changement | Effet pour l'entreprise |
|---|---|
| **En-têtes de routage.** Chaque POST porte `Mcp-Method` et, pour `tools/call`, `resources/read` et `prompts/get`, `Mcp-Name` (SEP-2243); `MCP-Protocol-Version` doit égaler la valeur de `_meta`; tout écart entraîne HTTP 400 et l'erreur -32020 (`HeaderMismatch`) [168, 190]. | Routage et politiques possibles sans analyser le corps, à la condition expresse de vérifier la concordance (EXIG-MCP-15). |
| **Requêtes à allers-retours multiples (MRTR, SEP-2322).** Les requêtes initiées par le serveur (`roots/list`, `sampling/createMessage`, `elicitation/create`) cèdent la place à un résultat `InputRequiredResult`; le client relance la requête d'origine avec les réponses et un `requestState` opaque. MRTR s'applique à `tools/call`, `resources/read` et `prompts/get` [200]. | Une précision ou une décision humaine s'obtient sans flux ouvert de longue durée; le `requestState` devient une entrée non fiable à protéger (EXIG-MCP-17). |
| **Indices de cache.** `ttlMs` et `cacheScope` obligatoires sur les résultats complets de `tools/list`, `prompts/list`, `resources/list`, `resources/templates/list`, `resources/read` (SEP-2549) et `server/discover` [168, 201]. | Cache de passerelle possible; un cache « private » n'est jamais partagé entre jetons (EXIG-MCP-03). |
| **Abonnements.** `subscriptions/listen` remplace le point d'accès GET et `resources/subscribe`; la reprise de flux par `Last-Event-ID` est retirée [168, 190]. | Notifications limitées aux types demandés par le client; les méthodes GET et DELETE ne servent plus. |
| **Extensions officielles.** Selon le journal des modifications de la révision 2026-07-28, les tâches longues quittent le cœur pour l'extension officielle `io.modelcontextprotocol/tasks` (SEP-2663); MCP Apps est une extension officielle; toute extension est désactivée par défaut et s'active explicitement des deux côtés [168, 169, 191, 202]. | Liste d'extensions autorisées au catalogue, quotas pour les tâches, revue des interfaces (EXIG-MCP-04). |
| **Schémas.** `inputSchema` et `outputSchema` acceptent tout mot-clé de JSON Schema 2020-12 (SEP-2106), dialecte par défaut; un autre dialecte peut être déclaré par `$schema` [168, 197, 201]. | Contrats plus expressifs; validateurs à durcir contre les références réseau (EXIG-MCP-19). |
| **Cycle de vie.** États *Active*, *Deprecated* et *Removed* (SEP-2596) : une fonctionnalité dépréciée reste dans la spécification au moins douze mois, ou au moins 90 jours en cas de retrait accéléré exceptionnel [34, 196]. | Migrations planifiées au catalogue, avec échéances (EXIG-MCP-22). |
| **Dépréciations et retraits.** Sont dépréciés Roots, Sampling, la journalisation protocolaire, l'enregistrement dynamique de clients (DCR), l'ancien transport HTTP+SSE et les valeurs `includeContext` « thisServer » et « allServers »; `ping`, `logging/setLevel` et `notifications/roots/list_changed` sont retirés. Le retrait de Roots, de Sampling, de la journalisation et du DCR est possible à partir de la première révision publiée le 28 juillet 2027 ou après (celui d'`includeContext` suit Sampling; celui du transport HTTP+SSE, trois mois après que la SEP-2596 atteint l'état final) [168, 196]. | Paramètres d'outil ou URI de ressource au lieu de Roots; appels aux modèles par la passerelle de modèles au lieu de Sampling; sortie d'erreur standard ou OpenTelemetry au lieu de la journalisation protocolaire. |
| **Codes d'erreur.** « Ressource introuvable » passe de -32002 à -32602; la plage -32020 à -32099 est réservée à MCP, dont -32021 (capacité client requise absente) et -32022 (version non prise en charge) [162, 168]. | Clients tolérants aux deux codes pendant la transition; supervision des nouveaux codes. |

Une liste d'outils peut varier selon l'autorisation présentée, par exemple pour ne montrer que les outils permis par les portées du jeton, mais jamais selon la connexion ni par effet de bord d'autres requêtes; une liste qui dépend du jeton devrait alors porter `cacheScope` « private » [197, 199].

**EXIG-MCP-03**
**DOIT**

**Listes stables et cache conforme à cacheScope**

Les serveurs MCP internes **DOIVENT** renvoyer leurs outils dans un ordre déterministe, identique d'une requête à l'autre tant que l'ensemble ne change pas. La passerelle **DOIT** respecter `ttlMs` et `cacheScope` : sa clé de cache inclut la méthode et les paramètres de la requête (curseur, URI) et, pour une réponse « private », le contexte d'autorisation; une réponse « private » n'est servie qu'à ce même contexte; seule une réponse « public » peut l'être par un cache partagé, ce qui ne dispense pas des contrôles d'accès par primitive; un résultat intermédiaire `input_required` et le résultat d'une relance MRTR (`inputResponses` ou `requestState`) ne sont jamais mis en cache.

Pourquoi : la spécification recommande l'ordre déterministe pour améliorer le taux de succès du cache d'invites, et le cadre l'exige pour ses serveurs (section 10.6); elle interdit de partager un cache « private » entre contextes d'autorisation, ce qui réduit le risque de fuite entre locataires (la spécification précise que `cacheScope` ne remplace pas les contrôles d'accès propres à chaque primitive)[197, 199, 201].

L'extension Tasks confie un travail long à un identifiant durable : le serveur renvoie un `taskId`, une durée de vie et un intervalle d'interrogation; le client suit l'avancement par `tasks/get`, fournit une entrée par `tasks/update` et peut annuler par `tasks/cancel`; les états sont `working`, `input_required`, `completed`, `failed` et `cancelled`[191]. Une tâche MCP ne remplace pas l'exécution durable de l'orchestrateur : celui-ci consigne le `taskId` dans son point de contrôle pour reprendre le suivi après une panne (section 7.4). Avec MCP Apps, un outil désigne dans `_meta.ui.resourceUri` une ressource `ui://`; l'hôte l'affiche dans une iframe cloisonnée qu'il contrôle, l'application ne dialogue avec lui que par `postMessage` et n'appelle des outils qu'à travers lui, et `_meta.ui.csp` et `_meta.ui.permissions` encadrent les origines et les permissions[202].

**EXIG-MCP-04**
**DOIT**

**Extensions activées sur liste d'autorisation**

Une extension MCP **DOIT** figurer au catalogue pour le serveur concerné avant d'être activée. Les extensions internes portent le préfixe DNS inversé de l'entreprise, jamais un préfixe réservé (dont le deuxième libellé est `modelcontextprotocol` ou `mcp`). Pour l'extension Tasks, la passerelle impose un quota de tâches actives par mandant et une durée de vie maximale. Pour MCP Apps, chaque gabarit `ui://` est revu avant l'homologation, servi sous une politique de sécurité du contenu restrictive, et le contenu généré qu'il affiche est encodé.

Pourquoi : les extensions sont désactivées par défaut et s'identifient par un préfixe DNS inversé[169]; Akamai signale le déni de service par tâches asynchrones et le script intersites stocké par les interfaces générées[203]. La revue préalable des gabarits est une exigence du cadre, que la documentation officielle n'énonce pas.

## Règles d'usage des primitives

Chaque primitive répond à un besoin distinct. Une **ressource** convient quand on sait quelle entité charger : `crm://comptes/9482/sommaire` se lit sans effet sur le système et se met en cache selon `ttlMs`. Un **outil** convient aux recherches dynamiques, aux calculs et aux écritures, sous un contrat d'entrée strict. Une **invite** publie une procédure normalisée d'un domaine, par exemple la vérification d'un nouveau fournisseur, pour que chaque agent n'ait pas à la réécrire; elle se gère comme la mémoire procédurale, c'est-à-dire comme du code versionné et revu (section 5.5).

La granularité compte autant que le choix de la primitive. Un serveur qui recopie une API de soixante opérations en soixante outils encombre le contexte du modèle et multiplie les occasions de choisir le mauvais outil ou le mauvais paramètre. Un outil `approvisionnement_creer_bon_commande`, qui valide en une seule opération le fournisseur, le centre de coûts et les lignes, se gouverne mieux et se teste plus facilement. Les équipes ne réécrivent pas leurs services REST : des adaptateurs déclaratifs traduisent les opérations OpenAPI pertinentes en outils orientés tâche (section 5.2).

Lorsque les outils deviennent nombreux, les bonnes pratiques de MCP recommandent à l'hôte, au-delà d'un seuil de l'ordre de 1 à 5 % de la fenêtre de contexte, d'offrir un méta-outil de recherche et de ne charger les définitions complètes qu'au besoin, en les ajoutant après le point de rupture du cache plutôt qu'en réordonnant la liste[204]. Anthropic illustre, par un exemple de plus de 50 outils MCP, que sa propre fonction de recherche d'outils ramène la consommation totale de contexte d'environ 77 000 à environ 8 700 jetons (dont environ 72 000 pour les seules définitions); elle chiffre cette réduction à 85 % (les deux chiffres donnent plutôt près de 89 %)[205]. Le choix entre la recherche d'outils et le découpage en plusieurs agents est traité à la section 7.3.

**EXIG-MCP-05**
**DEVRAIT**

**Choix de la primitive selon le besoin**

La lecture d'une entité connue **DEVRAIT** être exposée comme ressource adressée par URI; une recherche, un calcul ou une écriture, comme outil; une procédure normalisée de domaine, comme invite versionnée et revue au même titre que du code.

Pourquoi : la ressource se lit sans effet et se met en cache; l'outil porte un contrat d'entrée strict et passe par les contrôles de palier; l'invite rend une procédure réutilisable sans la recopier dans chaque agent.

**EXIG-MCP-06**
**NE DOIT PAS**

**Aucun miroir CRUD des API**

Un serveur MCP **NE DOIT PAS** exposer une API en recopiant une à une ses opérations élémentaires de création, de lecture, de mise à jour et de suppression. Il expose des outils qui accomplissent des tâches métier complètes et valident eux-mêmes leurs paramètres.

Pourquoi : chaque définition d'outil consomme du contexte et chaque outil de plus est une occasion d'erreur de sélection; une intention métier se classe au catalogue et s'approuve plus clairement qu'une opération technique.

**EXIG-MCP-07**
**DOIT**

**Conventions de nommage et de résultat des outils**

Les outils des serveurs internes **DOIVENT** : porter un nom de 1 à 128 caractères ASCII (lettres, chiffres, `_`, `-`, `.`) préfixé par leur domaine; renvoyer les erreurs de validation et les erreurs métier comme résultat d'outil marqué `isError: true`, en réservant les erreurs JSON-RPC aux outils inconnus, aux requêtes malformées et aux erreurs du serveur; déclarer un `outputSchema` lorsque leur résultat alimente une étape suivante, puis renvoyer un `structuredContent` conforme, accompagné du même JSON sérialisé dans un bloc texte.

Pourquoi : le modèle peut corriger une erreur renvoyée comme résultat, alors qu'une erreur de protocole interrompt l'appel; la spécification exige un `structuredContent` conforme dès qu'un `outputSchema` est déclaré et recommande le bloc texte pour la rétrocompatibilité[197]. Exemple complet à l'annexe C.

## Transport et autorisation

MCP définit deux transports normalisés : stdio, entre processus d'une même machine, et Streamable HTTP, qui a remplacé le transport HTTP+SSE en 2025-03-26[206, 207]. En 2026-07-28, chaque message du client est un POST distinct vers un point d'accès unique; le serveur répond soit par un objet JSON, soit par un flux SSE propre à cette requête (que le serveur devrait clore dès que la réponse JSON-RPC finale est envoyée), et le client doit accepter les deux. Le serveur doit valider l'en-tête `Origin` sur toute connexion entrante pour contrer le détournement DNS, et répondre par HTTP 403 si l'en-tête est présent et invalide; un serveur local devrait n'écouter que sur 127.0.0.1, et tout serveur devrait authentifier les connexions[190]. Les bonnes pratiques de sécurité de MCP recommandent d'ailleurs stdio pour limiter l'accès à un serveur local[208] : restreindre stdio au poste de développement est donc un choix d'exploitation du cadre, non une exigence de MCP.

**EXIG-MCP-08**
**DOIT**

**Transport selon l'environnement**

Dans tout environnement serveur (développement partagé, préproduction, production), un serveur MCP **DOIT** être exposé par Streamable HTTP, chiffré par TLS 1.3 (TLS 1.2 toléré comme plancher, versions antérieures désactivées), derrière la passerelle d'agents. Le transport stdio n'est permis que sur le poste d'un développeur, pour un serveur installé depuis le catalogue et exécuté dans un bac à sable aux privilèges minimaux; l'hôte affiche la commande complète avant l'installation et exige une approbation explicite.

Pourquoi : seul un transport réseau passe par la passerelle, donc par l'identité, la politique et la journalisation; les bonnes pratiques de sécurité de MCP exigent l'affichage de la commande et l'approbation explicite pour l'installation en un clic d'un serveur local, et recommandent son exécution en bac à sable[208].

L'autorisation est *facultative* dans MCP; lorsqu'elle est offerte sur HTTP, elle devrait suivre la spécification d'autorisation, fondée sur le brouillon OAuth 2.1 dans sa version -13 (la version -16 est la plus récente au 27 octobre 2026; voir la section 6.3), que la spécification MCP cite encore (la version -16 est la plus récente au 27 octobre 2026; voir la section 6.3)[209, 210]. Le serveur MCP y est un serveur de ressources OAuth. Il doit publier ses métadonnées de ressource protégée (RFC 9728), que le client utilise pour découvrir le serveur d'autorisation, et ce dernier doit offrir la découverte RFC 8414 ou OpenID Connect[211]. Le client doit inclure le paramètre `resource` (RFC 8707), valant l'URI canonique du serveur MCP, dans ses requêtes d'autorisation et de jeton; le serveur doit vérifier que le jeton lui est destiné et répondre 401 sinon[71]. Le jeton circule dans l'en-tête `Authorization: Bearer` de chaque requête, jamais dans l'URL; PKCE s'emploie avec la méthode S256. Depuis 2026-07-28, le serveur d'autorisation devrait renvoyer le paramètre `iss` (RFC 9207), que le client doit valider s'il est présent (et rejeter la réponse s'il est absent alors que les métadonnées annoncent son support)[209, 212]. Comme OAuth 2.1 reste un brouillon, le cadre se réfère à OAuth 2.0 profilé par la RFC 9700 (section 9.3).

La spécification prescrit des jetons porteurs; elle n'exige ni mTLS ni DPoP, ni durée de vie précise, et la finalisation de DPoP ne figure qu'à sa feuille de route[195, 209]. Les jetons contraints à l'émetteur (RFC 9449 ou RFC 8705), appuyés sur la RFC 9700[175, 213], et les durées de vie courtes sont donc des politiques du cadre. Lorsque la passerelle publie un serveur, l'URI canonique annoncée aux clients est la sienne; elle obtient ensuite, pour le serveur de domaine, un jeton distinct par échange de jetons (section 9.3). Ce choix du cadre respecte l'interdiction du passage de jeton.

**EXIG-MCP-09**
**DOIT**

**Autorisation obligatoire et conforme à la spécification**

Tout serveur MCP accessible ailleurs que sur un poste de développement **DOIT** exiger une autorisation OAuth conforme à la spécification MCP 2026-07-28 : métadonnées de ressource protégée (RFC 9728), indicateur de ressource (RFC 8707) portant l'URI canonique, vérification de l'audience à chaque requête et jeton transmis uniquement par l'en-tête `Authorization`. Les clients MCP de l'entreprise **DOIVENT** employer PKCE avec S256 (en vérifiant que les métadonnées du serveur d'autorisation annoncent `code_challenge_methods_supported` et en refusant de poursuivre sinon) et valider `iss` (RFC 9207) avant d'échanger le code d'autorisation. Les serveurs d'autorisation de l'entreprise **DOIVENT** publier ces annonces et toujours émettre `iss` (avec `authorization_response_iss_parameter_supported: true`).

Pourquoi : la spécification laisse l'autorisation facultative[209]; le cadre la rend obligatoire, car un outil sans contrôle d'accès ouvre directement les systèmes d'enregistrement, et l'émission de `iss` protège contre la confusion entre serveurs d'autorisation.

**EXIG-MCP-10**
**DOIT**

**Portées minimales et élévation progressive**

Chaque serveur MCP **DOIT** publier un ensemble initial minimal de portées (`scopes_supported`), refuser les portées génériques (`*`, `all`, `full-access`) et signaler une portée insuffisante par une réponse 403 `insufficient_scope` qui énumère les portées requises. Chaque élévation progressive *(step-up)* est journalisée avec l'identifiant de trace, et le client en limite le nombre de tentatives.

Pourquoi : un agent démarre avec le minimum et n'obtient davantage que sur une demande traçable; c'est le patron de minimisation des portées que décrivent la spécification et ses bonnes pratiques de sécurité[208, 209].

**EXIG-MCP-11**
**NE DOIT PAS**

**Interdiction du passage de jeton**

Un serveur MCP, la passerelle comprise, **NE DOIT PAS** accepter un jeton qui n'a pas été émis pour lui, ni retransmettre en aval un jeton reçu. Pour appeler une API ou un autre serveur, il obtient son propre jeton, à audience unique, par échange de jetons (section 9.3).

Pourquoi : la spécification interdit explicitement le passage de jeton *(token passthrough)*[208, 209]; un jeton relayé permettrait à un serveur compromis d'agir partout où ce jeton est valable.

Pour identifier un client, la spécification recommande l'ordre suivant : enregistrement préalable, puis document de métadonnées d'identifiant client (CIMD) si le serveur d'autorisation l'annonce, puis enregistrement dynamique (DCR) en repli, puis saisie manuelle[214]. Les CIMD, dont l'identifiant client est une URL HTTPS, ont été ajoutés en 2025-11-25; le DCR (RFC 7591) a été déprécié en 2026-07-28[168, 215]. Le brouillon CIMD, adopté par le groupe de travail OAuth de l'IETF mais qui n'est pas une RFC, interdit au client l'authentification par secret partagé, n'admet que des clés publiques, interdit au serveur de suivre automatiquement les redirections, lui fait refuser les adresses à usage spécial et recommande de limiter la lecture à environ 5 Ko (état de la version -02; la spécification MCP 2026-07-28 renvoie à la version -00)[216]. Un identifiant préenregistré ou obtenu par DCR est lié à l'émetteur qui l'a délivré : si l'émetteur change, le client se réenregistre[214].

**EXIG-MCP-12**
**DOIT**

**Enregistrement des clients MCP**

Les clients MCP de l'entreprise **DOIVENT** être préenregistrés auprès du serveur d'autorisation ou, pour un serveur tiers qui l'annonce, identifiés par un CIMD. Le DCR **NE DOIT PAS** être activé pour une nouvelle intégration. Un serveur d'autorisation de l'entreprise qui accepte des CIMD **DOIT** refuser l'authentification par secret partagé, ne pas suivre les redirections, bloquer les adresses à usage spécial et borner la taille du document lu.

Pourquoi : le DCR est déprécié et voué au retrait[196]; la récupération d'un CIMD expose le serveur d'autorisation à la falsification de requêtes côté serveur (SSRF), que les règles du brouillon préviennent[216].

**EXIG-MCP-13**
**DOIT**

**Consentement par client des mandataires MCP**

Un serveur MCP qui sert de mandataire auprès d'un serveur d'autorisation tiers avec un identifiant client statique **DOIT** obtenir le consentement de l'utilisateur pour chaque client avant de relayer l'autorisation : registre des `client_id` approuvés par utilisateur; page de consentement qui nomme le client, les portées et l'URI de redirection; protection contre la falsification de requête intersites et contre le détournement de clic par incrustation *(clickjacking)*, notamment par `frame-ancestors` ; correspondance exacte de `redirect_uri` ; paramètre `state` aléatoire, à usage unique, fixé seulement après le consentement; témoins `__Host-` marqués `Secure` , `HttpOnly` et `SameSite=Lax` .

Pourquoi : sans ce consentement, un client malveillant profite d'un consentement donné antérieurement au mandataire; c'est le problème de l'adjoint confus *(confused deputy)*, que la spécification traite par ces mesures obligatoires[208].

Deux extensions officielles d'autorisation, stables depuis la révision 2026-07-28, complètent le cœur du protocole[217]. Avec Enterprise-Managed Authorization (EMA), le fournisseur d'identité de l'entreprise décide de l'accès : après l'authentification unique, le client obtient un ID-JAG par échange de jetons (RFC 8693), puis l'échange contre un jeton d'accès par l'octroi JWT bearer (RFC 7523)[178, 218]. EMA évite un consentement par serveur et par employé et centralise les politiques d'accès et la révocation[178]; comme le brouillon ID-JAG qui la fonde[177], elle figure au statut « Évaluer » du catalogue (section 6.3). L'extension OAuth Client Credentials couvre les agents qui agissent sans utilisateur; un tel agent s'authentifie sous sa propre identité (section 9.2). Enfin, l'échange de jetons RFC 8693 et la revendication `act` ne font pas partie du cœur de MCP : exiger d'un fournisseur la propagation de la chaîne de délégation relève d'une clause contractuelle (chapitre 13), non d'une conformité MCP.

## Annotations et métadonnées de gouvernance

La spécification prévoit pour chaque outil des annotations : `title` , `readOnlyHint` (faux par défaut), `destructiveHint` (vrai par défaut), `idempotentHint` (faux par défaut) et `openWorldHint` (vrai par défaut); `destructiveHint` et `idempotentHint` n'ont de sens que si l'outil n'est pas en lecture seule. Ce sont des indices : les clients doivent les tenir pour non fiables, sauf s'ils proviennent de serveurs de confiance, et, selon une formulation non normative (« should never »), ne jamais fonder une décision d'usage sur les annotations d'un serveur non fiable[197, 201]. Les valeurs par défaut sont prudentes : un outil qui ne déclare rien est présumé destructif et ouvert sur l'extérieur.

L'objet `annotations` ne définit que cinq champs standard et aucune propriété d'extension; la spécification réserve `_meta` aux extensions. Les ébauches qui y ajoutaient des champs `x-enterprise-*` sortaient donc de ce que prévoit la spécification (le cadre en fait une règle, EXIG-MCP-14)[201]. Une métadonnée propre à l'entreprise peut figurer dans le champ `_meta` de l'outil, sous une clé à préfixe DNS inversé détenu par l'entreprise (p. ex. `ca.exemple/palier-risque` ); déclarée par le serveur, elle n'est pas plus fiable qu'une annotation.

**ATTENTION**

Une annotation `readOnlyHint: true` ne prouve rien : c'est le serveur qui l'affirme. Un serveur compromis ou mal configuré peut déclarer en lecture seule un outil qui supprime des données. Le palier P0 à P3 d'un outil est attribué au catalogue après revue (section 8.3) et appliqué par la passerelle.

**EXIG-MCP-14**
**DOIT**

**Annotations et métadonnées déclarées : de simples indices**

La passerelle et les hôtes **DOIVENT** lire le palier de risque, le seuil d'approbation et l'outil de compensation d'un outil dans son entrée au catalogue, jamais dans ses annotations ni dans son `_meta`. Les serveurs internes **DOIVENT** néanmoins déclarer leurs annotations, qui **DOIVENT** concorder avec la classification du catalogue; un écart **DOIT** bloquer l'homologation. Aucune propriété propre à l'entreprise n'est ajoutée à l'objet `annotations`.

Pourquoi : la spécification tient les annotations pour des indices non fiables[197]; elles servent l'ergonomie (affichage, demande de confirmation), non la décision de sécurité. L'entrée de catalogue type figure à l'annexe C.

## Sécurité propre à MCP

Le passage au protocole sans état supprime le détournement d'identifiant de session, mais déplace le risque vers les identifiants d'état applicatifs et le `requestState`, que le serveur doit traiter comme une entrée contrôlée par l'attaquant[200, 208]. L'analyse de la version candidate publiée par Akamai le 25 juin 2026 relève notamment le détournement de flux entre agents par des identifiants ou des objets d'état prévisibles, la manipulation du champ `_meta` contrôlé par le client, la désynchronisation des en-têtes et du corps, la fuite de données par `x-mcp-header`, le script intersites stocké par MCP Apps et le déni de service par tâches asynchrones[203]. La spécification contient déjà l'essentiel des contre-mesures; les exigences qui suivent s'y appuient. Les menaces communes à tous les agents, comme l'injection d'instructions et l'exécution de code, sont traitées aux sections 9.5 à 9.7.

EXEMPLE : LA DÉSYNCHRONISATION

Une requête porte l'en-tête `Mcp-Name: recherche_publique`, mais son corps appelle `supprimer_base`. Un pare-feu applicatif qui ne lit que l'en-tête laisse passer, et le serveur exécute l'outil destructeur. La spécification ferme cette brèche en obligeant tout serveur qui traite le corps à rejeter l'écart; le cadre ajoute que la passerelle décide d'après le corps analysé, jamais d'après les seuls en-têtes.

**EXIG-MCP-15**
**DOIT**

**Concordance des en-têtes et du corps**

La passerelle et chaque serveur **DOIVENT** vérifier que `MCP-Protocol-Version`, `Mcp-Method`, `Mcp-Name` et chaque en-tête `Mcp-Param-{nom}` (après décodage Base64 éventuel) concordent avec le corps JSON-RPC et sa clé `_meta`, et rejeter toute divergence ou tout en-tête obligatoire absent par HTTP 400 et l'erreur -32020. La passerelle fonde ses décisions d'autorisation sur le corps analysé; une politique fondée sur les en-têtes ne s'applique qu'aux requêtes de la révision 2026-07-28.

Pourquoi : la spécification impose ce rejet à tout serveur qui traite le corps et recommande à un intermédiaire dont la politique repose sur ces en-têtes de rejeter les requêtes d'une révision antérieure, qui n'imposait pas cette validation[190].

Dans MCP, le code HTTP 403 signale un en-tête `Origin` invalide (transport) ou des portées invalides ou des permissions insuffisantes (autorisation); une divergence d'en-têtes relève du code 400[190, 209]. Le champ `_meta`, lui, ne peut pas être purgé en bloc : les clés `io.modelcontextprotocol/protocolVersion` et `io.modelcontextprotocol/clientCapabilities` y sont obligatoires, sous peine de rejet par l'erreur -32602, et les clés `traceparent`, `tracestate` et `baggage` y transportent le contexte de trace selon W3C Trace Context et W3C Baggage (SEP-414)[162, 168]. Les conventions OpenTelemetry pour MCP, au niveau Development, nomment les *spans* d'après la méthode appelée (attribut `mcp.method.name`)[219]; leur emploi est réglé à la section 10.1. Un serveur ne se fie pas non plus à une capacité que le client n'a pas déclarée : il renvoie alors l'erreur -32021[162].

**EXIG-MCP-16**
**DOIT**

**Traitement du champ _meta**

La passerelle et les serveurs **DOIVENT** conserver les clés réservées de `_meta` (protocole, capacités du client, contexte de trace), ignorer ou filtrer les clés non reconnues et ne fonder aucun routage, aucun choix de locataire ni aucune autorisation sur `_meta`, `clientInfo` ou `serverInfo`. L'identité du mandant provient exclusivement du jeton vérifié, par exemple de sa revendication `sub`.

Pourquoi : `clientInfo` et `serverInfo` sont auto-déclarés et ne devraient pas servir aux décisions de sécurité[162]; Akamai illustre l'élévation de privilèges qu'obtient un attaquant lorsqu'un serveur se fie à `{"tenant": "admin", "authenticated": true}` placé dans `_meta`[203].

**EXIG-MCP-17**
**DOIT**

**État explicite protégé**

Un serveur qui conserve un état entre deux appels **DOIT** émettre des identifiants d'état aléatoires, imprévisibles et à durée de vie bornée, liés côté serveur à l'utilisateur authentifié (clé de la forme `utilisateur:identifiant`, l'utilisateur étant tiré du jeton vérifié); la possession d'un identifiant ne vaut jamais authentification. Il **DOIT** traiter tout `requestState` reçu comme une entrée contrôlée par un attaquant et, dès que cet état influence l'autorisation, l'accès aux ressources ou la logique métier, en protéger l'intégrité par HMAC ou par chiffrement authentifié (AEAD), y inclure le mandant, une courte durée de vie et l'empreinte de la requête d'origine, et en garantir l'usage unique lorsque l'étape l'exige.

Pourquoi : la spécification impose de traiter tout `requestState` comme une entrée contrôlée par un attaquant, d'en protéger l'intégrité (HMAC ou AEAD) dès qu'il influence l'autorisation, l'accès aux ressources ou la logique métier, et de faire respecter l'usage unique côté serveur quand il est requis; elle ne fait que recommander l'inclusion du mandant, d'une courte durée de vie et de l'empreinte de la requête d'origine, et n'offre qu'une orientation non normative sur les identifiants d'état aléatoires liés à l'utilisateur (durcissement du cadre)[197, 200]; sans elles, un identifiant deviné permet d'accéder à l'état d'un autre utilisateur, et un état rejoué par un autre mandant n'est rejeté que si le serveur l'a lié au mandant[200, 208].

La directive `x-mcp-header` recopie un argument d'outil dans un en-tête `Mcp-Param-{nom}`. Elle ne s'applique qu'à des types primitifs (chaîne, entier, booléen, à l'exclusion de `number`), à une propriété atteignable statiquement et sous un nom unique; un client Streamable HTTP doit écarter de `tools/list` tout outil dont la directive est invalide[190, 197].

**EXIG-MCP-18**
**NE DOIT PAS**

**Aucune donnée sensible en en-tête**

La directive `x-mcp-header` **NE DOIT PAS** marquer une propriété qui contient un secret (mot de passe, clé d'API, jeton), un renseignement personnel ou toute autre donnée confidentielle. Elle est réservée aux valeurs utiles au routage ou à l'imputation, comme un centre de coûts; les schémas d'outils **DOIVENT** être analysés en intégration continue pour le vérifier.

Pourquoi : les en-têtes sont visibles des intermédiaires (répartiteurs de charge, passerelles, outils d'observabilité); la spécification recommande de ne pas y marquer de paramètres sensibles[190, 197], et le cadre en fait une interdiction.

**EXIG-MCP-19**
**DOIT**

**Schémas, URL et icônes : des entrées non fiables**

Les hôtes, les clients hébergés et la passerelle **DOIVENT** traiter comme non fiables les schémas, URL et icônes fournis par un serveur. Concrètement : ne jamais déréférencer automatiquement un `$ref` pointant vers une URI réseau et borner la profondeur et le nombre de sous-schémas; lors de la découverte OAuth, n'accepter que HTTPS, bloquer les plages d'adresses privées, de bouclage et lien-local, valider chaque redirection et passer par un mandataire de sortie; n'ouvrir une URL d'autorisation que si son schéma est `https` (`http` en bouclage, pour le développement seulement), jamais par un interpréteur de commandes; n'accepter une icône qu'en `https` ou `data:`, de même origine que le serveur, récupérée sans identifiants et dont le type est validé par signature binaire.

Pourquoi : un serveur malveillant peut se servir d'un schéma pour un déni de service, de la découverte OAuth pour une SSRF vers les métadonnées infonuagiques ou les services internes, d'une URL ou d'une icône SVG pour exécuter du code[162, 208].

Trois attaques visent les définitions d'outils elles-mêmes. L'**empoisonnement d'outil** *(tool poisoning)* cache des instructions malveillantes dans une description, un schéma ou une valeur de retour. La **substitution après approbation** *(rug pull)* modifie les définitions d'un serveur une fois celui-ci approuvé. L'**ombrage** *(tool shadowing)* laisse la description d'un serveur malveillant modifier l'usage des outils d'un autre serveur. Invariant Labs a décrit les trois le 1er avril 2025, et la fiche de sécurité MCP de l'OWASP les reprend avec l'injection par valeurs de retour[220, 221]. Cette fiche recommande de traiter chaque serveur comme un domaine de sécurité indépendant et non fiable, et rappelle que la signature des messages ne fait pas partie du cœur de MCP[221]. L'épinglage au catalogue est réglé à la section 6.8; l'exigence suivante en assure l'application à l'exécution.

**EXIG-MCP-20**
**DOIT**

**Empreintes des définitions et isolement des serveurs**

À l'homologation, à chaque `tools/list` et avant l'exécution (EXIG-SEC-18), la passerelle **DOIT** calculer l'empreinte de chaque définition d'outil complète (nom, titre, description, icônes, schémas d'entrée et de sortie, annotations et `_meta`) et la comparer à l'empreinte épinglée au catalogue; un outil dont l'empreinte diffère est retiré de la liste remise à l'agent et suspendu jusqu'à une nouvelle approbation. La passerelle **DOIT** traiter chaque serveur comme un domaine de sécurité distinct : aucun serveur ne référence ni ne modifie les outils d'un autre, et la sortie de tout outil est une donnée non fiable (section 9.6).

Pourquoi : l'OWASP recommande d'épingler les définitions par empreinte, de les revérifier avant l'exécution et de redemander le consentement lorsqu'elles changent[221]; l'empoisonnement d'outil est le risque MCP03 de l'OWASP MCP Top 10[222].

Lorsque l'hôte fait exécuter par le modèle du code qui appelle des outils (« mode code »), ce code s'exécute dans un bac à sable sans accès réseau direct; l'hôte, qui détient les identifiants, applique à chaque appel la même politique d'approbation qu'à un appel direct, et les résultats d'un serveur restent non fiables pour un autre[204]. Les exigences de cloisonnement figurent à la section 9.7.

L'élicitation reste le canal par lequel un serveur sollicite une personne, désormais à l'intérieur d'un `InputRequiredResult`. Elle offre deux modes : « form », pour des données structurées selon un schéma plat de types primitifs, et « url », pour une interaction hors bande. Le client doit indiquer quel serveur demande l'information, offrir le refus et l'annulation, afficher l'URL complète et obtenir le consentement avant de l'ouvrir. En mode URL, le serveur ne place ni renseignement sensible ni URL préauthentifiée dans l'URL, vérifie que la personne qui l'ouvre est celle qui a déclenché la demande, et les identifiants tiers ainsi obtenus ne transitent jamais par le client MCP[223].

**EXIG-MCP-21**
**NE DOIT PAS**

**Élicitation : ni secret ni approbation déguisée**

Un serveur **NE DOIT PAS** demander de secret (mot de passe, clé d'API, jeton, donnée de paiement) par élicitation en mode formulaire; ces cas passent par le mode URL. Une réponse d'élicitation **NE DOIT PAS** non plus tenir lieu d'approbation humaine pour une action qui en exige une (palier P3; palier P2 au-delà du seuil déclaré; toute écriture d'un agent de niveau N2) : seule compte l'approbation signée, liée à l'action exacte, décrite à la section 8.5.

Pourquoi : la spécification interdit les secrets en mode formulaire[223]; le brouillon IETF WIMSE AIMS précise qu'une confirmation locale dans l'interface ne suffit pas comme autorisation[93].

Le projet OWASP MCP Top 10, édition 2025 encore en phase bêta, fournit une grille de menaces commune[222]. Le tableau 18 la met en correspondance avec les exigences du cadre; cette correspondance est une interprétation interne. Pour l'analyse de menaces par phase, Hou et al. décrivent le cycle de vie d'un serveur MCP en quatre phases (création, déploiement, exploitation, maintenance) et seize scénarios de menace répartis entre quatre types d'attaquants[224].

**Tableau 18 — Correspondance entre l'OWASP MCP Top 10 (bêta) et les exigences du cadre**

| Risque OWASP MCP Top 10 (2025, bêta) | Exigences et sections du cadre |
|---|---|
| MCP01 Gestion des jetons et exposition de secrets | EXIG-MCP-11, EXIG-MCP-18, EXIG-MCP-21; section 9.2 |
| MCP02 Élévation de privilèges par dérive des portées | EXIG-MCP-10; section 9.3 |
| MCP03 Empoisonnement d'outil | EXIG-MCP-14, EXIG-MCP-20 |
| MCP04 Chaîne d'approvisionnement | EXIG-MCP-02, EXIG-MCP-20; section 9.8 |
| MCP05 Injection et exécution de commandes | EXIG-MCP-08, EXIG-MCP-19; section 9.7 |
| MCP06 Injection d'invite par charges contextuelles | EXIG-MCP-20; section 9.6 |
| MCP07 Authentification et autorisation insuffisantes | EXIG-MCP-09, EXIG-MCP-12, EXIG-MCP-13 |
| MCP08 Absence d'audit et de télémétrie | EXIG-MCP-10, EXIG-MCP-16; chapitre 10 |
| MCP09 Serveurs MCP fantômes | EXIG-MCP-01, EXIG-MCP-02; section 11.4 |
| MCP10 Injection de contexte et surpartage | EXIG-MCP-03, EXIG-MCP-16, EXIG-MCP-17 |

## Migration vers la révision 2026-07-28

Les deux générations du protocole coexisteront pendant un temps. Un client peut détecter la génération d'un serveur en tentant une requête moderne et en examinant l'erreur 400 éventuelle avant de revenir à `initialize`; sur stdio, `server/discover` sert de sonde de rétrocompatibilité. Un serveur qui ne connaît que 2026-07-28 devrait répondre 405 aux requêtes GET et DELETE et ignorer les en-têtes `Mcp-Session-Id` et `Last-Event-ID`[168, 190]; une version non prise en charge entraîne l'erreur -32022[162]. La migration suit les étapes suivantes.

1. Inventorier les serveurs et les clients et inscrire leur révision au catalogue : `server/discover` pour les serveurs à jour, réponse à `initialize` pour les autres.
2. Ouvrir à la passerelle une double prise en charge bornée : les requêtes 2026-07-28 sont validées par en-têtes et par corps; les requêtes antérieures ne sont acceptées que pour les serveurs inscrits avec une date de migration et sont contrôlées par inspection du corps.
3. Remplacer l'état de session par des identifiants explicites (EXIG-MCP-17) et les requêtes initiées par le serveur par MRTR.

4. Remplacer Sampling par des appels à la passerelle de modèles, Roots par des paramètres d'outil ou des URI de ressource, et la journalisation protocolaire par la sortie d'erreur standard ou OpenTelemetry (section 10.1).
5. Remplacer le DCR par le préenregistrement ou les CIMD (EXIG-MCP-12).
6. Faire passer les tests de contrat et de conformité (section 6.8). Le cadre officiel de tests de conformité MCP reste en préversion (versions 0.x : 0.1.16 courante, 0.2.0-alpha.12 publiée le 1er octobre 2026) : ses résultats complètent les tests internes sans les remplacer[225, 226].
7. Retirer de la passerelle la prise en charge de la révision antérieure à l'échéance fixée.

**EXIG-MCP-22**
**DOIT**

**Migration bornée et abandon des fonctions dépréciées**

La passerelle **DOIT** accepter les deux générations de MCP pendant une période de coexistence bornée, chaque serveur antérieur étant inscrit au catalogue avec sa date de migration. Tous les serveurs et clients en production **DOIVENT** avoir migré vers la révision 2026-07-28 au plus tard le 28 juillet 2027, et un nouveau développement **NE DOIT PAS** s'appuyer sur une fonction dépréciée (Roots, Sampling, journalisation protocolaire, DCR, transport HTTP+SSE). Pendant la transition, les clients traitent -32002 (serveurs antérieurs) et -32602 comme « ressource introuvable » en réponse à `resources/read` seulement.

Pourquoi : Roots, Sampling, la journalisation et le DCR deviennent admissibles au retrait à partir de la première révision publiée le 28 juillet 2027 ou après (le transport HTTP+SSE obéit à une échéance distincte : trois mois après que la SEP-2596 atteint l'état final)[196]; l'échéance retenue, choix du cadre, évite qu'une révision future ne rompe des intégrations en production. La spécification recommande aux clients d'accepter aussi -32002, code employé par les versions antérieures pour « ressource introuvable »[227].

## 6.6 Intégration horizontale : protocole Agent2Agent

Cette section fixe les règles d'usage du protocole Agent2Agent (A2A), qui relie un agent à un autre agent lorsque l'appelant délègue un sous-objectif complet sans connaître le fonctionnement interne de l'appelé. MCP (section 6.5) relie un agent à des outils dont les entrées et les sorties sont définies; A2A relie des agents autonomes, potentiellement opaques, qui raisonnent et conservent un état sur des échanges à plusieurs tours[39]. Le cadre retient la version de protocole 1.0 (publication 1.0.0 du 12 mars 2026, correctif 1.0.1 du 28 mai 2026)[30].

### Rôle, historique et gouvernance

Google a annoncé A2A le 9 avril 2025 avec plus de 50 partenaires[21], puis l'a confié à la Linux Foundation le 23 juin 2025[22]. La version 0.3.0 (30 juillet 2025) a ajouté gRPC et les cartes d'agent signées, et renommé en `agent-card.json` le chemin de découverte[228, 229]. L'Agent Communication Protocol (ACP) d'IBM Research a fusionné avec A2A à la fin d'août 2025 : fusion annoncée le 25 août, dépôt archivé le 27 août, annonce de la fondation LF AI & Data (Linux Foundation) le 29 août[24, 230]. La version 1.0.0, première version stable, a paru le 12 mars 2026[29]. A2A est devenu un projet de stade « Growth » de l'Agentic AI Foundation (AAIF), transfert annoncé le 17 août 2026 et confirmé par le billet du projet du 27 août 2026[5, 35]. La chronologie d'ensemble figure à la section 2.2.

Trois faits fondent le choix d'A2A comme protocole agent-agent par défaut. Sa gouvernance est neutre : un comité directeur technique de huit entreprises (AWS, Cisco, Google, IBM Research, Microsoft, Salesforce, SAP et ServiceNow; composition annoncée le 12 mars 2026) le pilote[29], sous l'égide de la fondation qui héberge aussi MCP. Son adoption est large : plus de 150 organisations le soutiennent (Linux Foundation, 9 avril 2026), et Microsoft et AWS l'ont intégré à leurs plateformes d'agents[15]. Son outillage est ouvert : six SDK officiels (Python, JavaScript, Java, Go, .NET et Rust), une trousse de compatibilité (`a2a-tck`), un inspecteur et une interface en ligne de commande[231, 232].

**ATTENTION : QUATRE PROTOCOLES « ACP »**

Le sigle désigne (1) l'Agent Communication Protocol d'IBM, fusionné dans A2A; (2) l'Agent Connect Protocol d'AGNTCY, dont le dépôt est archivé depuis le 11 avril 2026; (3) l'Agent Client Protocol, créé par Zed pour relier les éditeurs de code aux agents de codage; (4) l'Agentic Commerce Protocol d'OpenAI et de Stripe[183, 233, 234]. Toute offre qui invoque un « ACP » pour coordonner des agents se vérifie au regard de ces quatre sens.

**EXIG-A2A-01** — **DOIT**

**A2A 1.0 pour toute délégation entre agents**

Toute interaction par laquelle un agent délègue une tâche à un agent d'un autre domaine, d'un autre cadriciel ou d'un tiers **DOIT** utiliser A2A, version de protocole 1.0 (sauf pendant la coexistence bornée de l'EXIG-A2A-15). Un protocole agent-agent propriétaire **DOIT** être contenu derrière un adaptateur, conformément au catalogue (section 6.3). Les transferts entre sous-agents d'un même orchestrateur, dans un même processus, n'y sont pas tenus.

Pourquoi : un contrat d'échange unique évite une intégration ad hoc par paire d'agents et garde l'agent appelé remplaçable.

## Carte d'agent 1.0

La carte d'agent *(Agent Card)* est le contrat public d'un agent : un document JSON qui dit qui il est, ce qu'il sait faire, où le joindre et comment s'authentifier. Un agent exposé la publie à `https://{domaine}/.well-known/agent-card.json`; l'ancien chemin `/.well-known/agent.json` appartient aux versions 0.1 et 0.2, désormais obsolètes[30, 68]. La définition normative des objets est le fichier `a2a.proto`, sérialisé en ProtoJSON; les énumérations s'écrivent en majuscules préfixées, par exemple `TASK_STATE_WORKING`[68]. Le tableau 19 résume les champs et les règles du cadre; un exemple complet figure à l'annexe C.

**Tableau 19 — Champs de la carte d'agent A2A 1.0 et règles du cadre**

| Champ | Statut dans A2A 1.0 | Règle du cadre |
|---|---|---|
| `name`, `description` | Obligatoires | Nom identique à la fiche du registre; description qui dit ce que fait l'agent et ce qu'il ne fait pas. |
| `supportedInterfaces` | Obligatoire; liste ordonnée, la première entrée est préférée; chaque entrée exige `url`, `protocolBinding` et `protocolVersion`, `tenant` est facultatif | Adresses de la passerelle d'agents, jamais l'adresse directe de l'agent. |
| `version` | Obligatoire; format libre | SemVer *(versionnage sémantique; voir la section 6.8)*, incrémentée à chaque changement publié; sert d'`ETag`. |
| `capabilities` | Obligatoire; sous-champs facultatifs `streaming`, `pushNotifications`, `extensions`, `extendedAgentCard` | Déclarer le comportement réel; extensions approuvées seulement. |
| `defaultInputModes`, `defaultOutputModes` | Obligatoires | Types média effectivement acceptés et produits. |
| `skills` | Obligatoire; chaque compétence exige `id`, `name`, `description` et `tags` | `id` stable, en minuscules séparées par des traits d'union *(kebab-case)* (convention du cadre); une portée OAuth par compétence. |

| Champ | Statut dans A2A 1.0 | Règle du cadre |
|---|---|---|
| `securitySchemes`, `securityRequirements` | Facultatifs; aucun secret dans la carte | Obligatoires; renvoient au fournisseur d'identité de l'entreprise. |
| `signatures` | Facultatif | Obligatoire : signature JWS *(JSON Web Signature)* sur la carte canonisée. |
| `provider`, `documentationUrl`, `iconUrl` | Facultatifs | `provider` renseigné par la direction responsable. |

Sources : spécification A2A 1.0 et `a2a.proto` [192, 235]; règles : choix du cadre.

**Signature.** La carte peut être signée en JWS (RFC 7515) après canonisation JCS *(JSON Canonicalization Scheme)*, le champ `signatures` étant exclu du contenu signé; la spécification recommande au client de vérifier au moins une signature avant de faire confiance à la carte et interdit de vérifier avec une clé expirée ou révoquée[68, 236]. Le cadre rend la signature obligatoire : une carte non signée s'imite aussi facilement qu'une page web.

**Carte étendue.** La capacité `extendedAgentCard` active l'opération `GetExtendedAgentCard`, qui exige une authentification et vérifie les permissions du client; la carte étendue ne devrait pas contenir d'information sensible exploitable en cas de fuite[68]. On publie ainsi une carte publique minimale et l'on réserve les compétences internes aux clients autorisés.

**Découverte et cache.** La spécification admet trois modes de découverte : URI bien connue, registre organisé (sans API de registre normalisée) et configuration directe; l'accès aux cartes peut être restreint par mTLS, filtrage réseau ou OAuth[237]. Dans l'entreprise, le registre (section 11.4) est la source de découverte autorisée. Le guide de découverte recommande un en-tête `Cache-Control`, un `ETag` dérivé du champ `version` ou d'un hachage, et des requêtes conditionnelles (`If-None-Match`)[237]. Comme la spécification n'impose pas SemVer pour `version`[68], le cadre l'impose : sans incrément fiable, un client garderait en cache une carte périmée.

**Métadonnées de gouvernance.** La carte 1.0 n'a pas de champ libre au premier niveau, et une extension ne peut pas modifier les structures de base[192, 238]. Le niveau d'autonomie, la classe de risque, le centre de coûts et la classification maximale des données restent donc à la fiche du registre (annexe B). Si un pair doit les lire, ils se déclarent comme extension de données dans `capabilities.extensions`. Une extension y figure avec son URI, qui porte la version, une description, l'indicateur `required` et ses paramètres; elle s'active par l'en-tête `A2A-Extensions`, un changement incompatible exige une nouvelle URI, et aucune extension ne doit contourner les contrôles de sécurité de l'agent[238].

**EXIG-A2A-02** — **DOIT**

**Carte publiée et inscrite au registre**

Tout agent invocable par d'autres agents **DOIT** publier une carte conforme à A2A 1.0, l'inscrire au catalogue d'entreprise (et la rattacher à sa fiche au registre, section 11.4) et déclarer dans `supportedInterfaces` les adresses de la passerelle d'agents. Un agent exposé hors de l'entreprise **DOIT** aussi publier sa carte à l'URI bien connue; un agent interne ne la publie pas.

Pourquoi : la découverte passe par une source contrôlée, et aucun appel ne contourne la passerelle (section 9.4).

**EXIG-A2A-03** — DOIT

**Carte signée et vérifiée**

Toute carte inscrite au catalogue d'entreprise **DOIT** porter au moins une signature JWS valide, calculée sur la carte canonisée JCS avec une clé de l'émetteur de la carte (clé gérée par l'entreprise pour ses propres agents; pour un agent de tiers, clé dont le catalogue consigne la confiance). La passerelle d'agents et les clients **DOIVENT** rejeter une carte sans signature valide ou signée par une clé expirée ou révoquée. La carte **NE DOIT PAS** contenir de secret.

Pourquoi : une carte usurpée détournerait des tâches et des données vers un faux agent, risque que l'OWASP classe sous ASI07, communication inter-agents non sécurisée[28].

**EXIG-A2A-04** — DOIT

**Version de carte et revalidation du cache**

Le champ `version` de la carte **DOIT** suivre SemVer et être incrémenté à chaque changement publié (règle du cadre). Le serveur **DOIT** fournir un `ETag` dérivé de cette version et un `Cache-Control`; le catalogue et les clients **DOIVENT** revalider leur copie par requête conditionnelle. Les règles de compatibilité et de coexistence des versions sont celles de la section 6.8.

Pourquoi : un incrément fiable est le signal sur lequel le cadre fonde l'invalidation des copies en cache des clients (le guide de découverte admet aussi un ETag dérivé d'un hachage).

**EXIG-A2A-05** — NE DOIT PAS

**Aucun champ hors norme dans la carte**

Une carte **NE DOIT PAS** contenir de champ non défini par A2A 1.0, par exemple `x-enterprise-governance`. Une extension **NE DOIT PAS** être publiée sauf si son URI figure au catalogue d'entreprise parmi les extensions approuvées, après revue de sécurité; l'indicateur `required: true` **DOIT** recevoir une dérogation du comité d'architecture (EXIG-APP-02).

Pourquoi : un champ hors norme n'a aucune sémantique garantie chez les pairs, et une extension obligatoire exclut tout client qui ne la prend pas en charge (erreur `ExtensionSupportRequiredError`) [68].

**EXIG-A2A-06** — DOIT

**Compétences internes dans la carte étendue**

Les compétences réservées à des consommateurs internes **DOIVENT** être publiées dans la carte étendue, servie par `GetExtendedAgentCard` après authentification et contrôle des permissions. La carte publique se limite aux compétences destinées aux appelants externes.

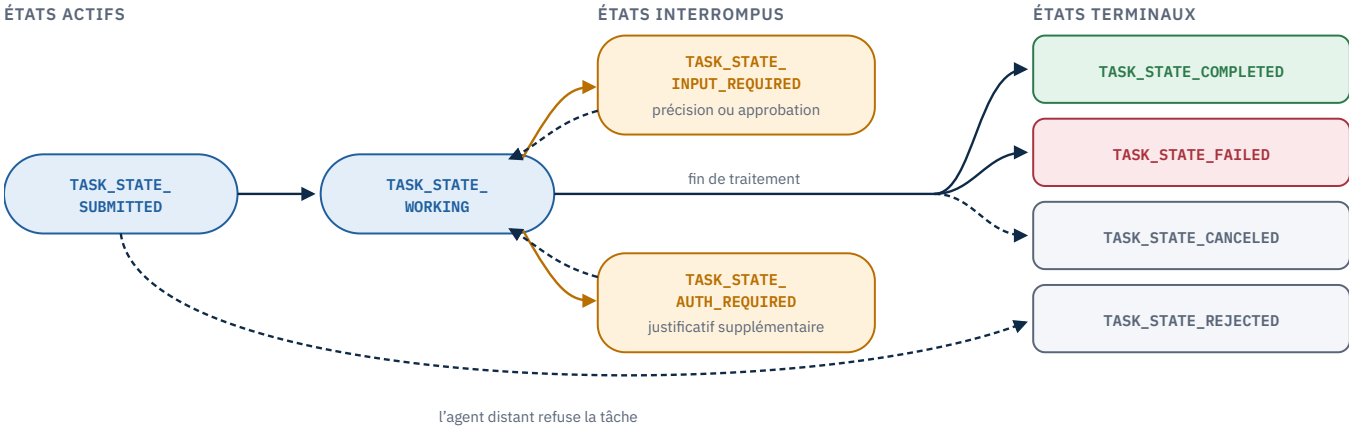
Pourquoi : la carte publique est lisible par tous; elle ne doit pas cartographier la surface interne de l'entreprise.

## Tâches, messages et artefacts

A2A organise le travail en tâches *(Task)*. Le client envoie un message; le serveur crée la tâche et lui attribue son identifiant, le client ne pouvant pas en imposer un pour une nouvelle tâche; `contextId` regroupe les tâches et les messages d'une même interaction[68]. Les messages et les artefacts, c'est-à-dire les résultats produits par la tâche, se composent de parties *(Part)*. En 1.0, une partie porte exactement un des membres `text`, `raw` (octets encodés en base64), `url` ou `data` (JSON structuré), avec `mediaType`, `filename` et `metadata` facultatifs; elle remplace les anciens `TextPart`, `FilePart` et `DataPart` [192, 235].

Une tâche suit une machine à huit états réels (neuf valeurs d'énumération avec la valeur zéro) (figure 8). Deux états sont actifs (`SUBMITTED`, `WORKING`); deux sont interrompus : `INPUT_REQUIRED` quand l'agent attend une précision ou une approbation, `AUTH_REQUIRED` quand il lui faut un justificatif supplémentaire; quatre sont terminaux (`COMPLETED`, `FAILED`, `CANCELED`, `REJECTED`); la valeur zéro `TASK_STATE_UNSPECIFIED` ne désigne aucun état réel[192]. Une tâche

terminale n'accepte plus de message (`UnsupportedOperationError`) et ne peut plus être annulée (`TaskNotCancelableError`)[68]. Les graphies minuscules comme `input-required` appartiennent aux versions 0.x et ne s'emploient plus.




Un message vers une tâche terminale renvoie `UnsupportedOperationError`; annuler une tâche terminale renvoie `TaskNotCancelableError`. Valeur zéro : `TASK_STATE_UNSPECIFIED`.

**Figure 8 — Cycle de vie d'une tâche A2A 1.0.** Une tâche passe de soumise à en cours, peut s'interrompre pour obtenir une précision, une approbation ou un justificatif, puis aboutit à l'un des quatre états terminaux, après lesquels elle n'accepte plus de message.
Source : A2A Project, `a2a.proto`, version de protocole 1.0.

Le protocole définit les opérations `SendMessage`, `SendStreamingMessage`, `GetTask`, `ListTasks`, `CancelTask`, `SubscribeToTask`, `GetExtendedAgentCard` et quatre opérations de gestion des configurations de notification push. Par défaut, `SendMessage` attend que la tâche atteigne un état terminal ou interrompu; avec `returnImmediately: true`, il rend la main dès la création de la tâche. `ListTasks` pagine par curseur et omet les artefacts par défaut, ce qui convient aux tableaux de bord d'exploitation[68]. Le client suit une tâche longue de trois façons : interrogation périodique (`GetTask`), flux en continu (SSE, pour *Server-Sent Events*, ou gRPC) ou notifications push[29, 68]. Dans la liaison HTTP+JSON, une erreur prend la forme d'un `google.rpc.Status` accompagné d'un `google.rpc.ErrorInfo` du domaine `a2a-protocol.org`[68].

**EXIG-A2A-07**
**DOIT**

**Suivi des tâches longues**

Lorsque la durée attendue d'une tâche dépasse 5 secondes (seuil fixé par le cadre), le client **DOIT** la suivre par flux en continu (`SendStreamingMessage`) ou par notification push. L'interrogation par `GetTask` et la reprise par `SubscribeToTask` **PEUVENT** servir à rétablir le suivi après une coupure, mais **NE DOIVENT PAS** servir au suivi courant.

Pourquoi : une connexion bloquante longue se heurte aux délais des intermédiaires réseau, et une boucle d'interrogation consomme sans rien apprendre; la spécification laisse ce choix au client, d'où cette règle interne.

## Liaisons, versions et sécurité

A2A 1.0 définit trois liaisons standard dérivées d'un même modèle abstrait : JSON-RPC 2.0 sur HTTP(S), gRPC sur HTTP/2 avec TLS, et HTTP+JSON (REST), dont le JSON est structurellement équivalent aux définitions Protobuf. La spécification exige d'un agent qui offre plusieurs liaisons une équivalence fonctionnelle (mêmes opérations, résultats sémantiquement équivalents, mêmes erreurs, mêmes schémas d'authentification), et d'une liaison personnalisée un comportement cohérent avec les opérations abstraites[68]. Le cadre retient JSON-RPC comme liaison commune, car

certaines passerelles ne relaient que celle-là : Azure API Management, par exemple, n'importe les API d'agents A2A qu'en JSON-RPC[109]. La liaison SLIMRPC d'AGNTCY est expérimentale et ne fait pas partie des liaisons standard[239] (section 6.9).

Chaque requête porte l'en-tête `A2A-Version` au format majeur.mineur (p. ex. `1.0`), ou le paramètre de requête équivalent. Un en-tête vide est interprété comme la version 0.3 (la spécification ne dit rien de l'en-tête absent, que le cadre assimile à un en-tête vide), et un agent qui ne prend pas en charge la version demandée renvoie `VersionNotSupportedError`[68] : un client 1.0 qui omet l'en-tête échoue donc contre un serveur 1.0 strict. Le type média `application/a2a+json` est recommandé pour la seule liaison HTTP+JSON; JSON-RPC emploie `application/json`, les flux `text/event-stream` et gRPC Protobuf[68].

Pour la sécurité, la spécification pose les bases et le cadre les durcit. La sécurité de transport est obligatoire en production; la spécification recommande TLS 1.3, et le guide d'implémentation en entreprise admet TLS 1.2 ou plus[68, 161]. L'identité relève de la couche transport : les justificatifs s'obtiennent hors bande et voyagent dans les en-têtes HTTP; le serveur authentifie chaque requête (401 si le justificatif manque ou est invalide, 403 s'il est insuffisant) et autorise avant toute opération susceptible de divulguer de l'information. L'autorisation peut se faire par compétence, chaque `AgentSkill` pouvant porter ses propres exigences de sécurité[161, 192]. La version 1.0 retire les flux OAuth implicite et par mot de passe, et ajoute le flux Device Code et PKCE[30]. Le champ `tenant` permet à un point de terminaison d'héberger plusieurs agents ou locataires, les résultats devant rester dans le périmètre autorisé de l'appelant. Enfin, l'agent valide tous ses paramètres d'entrée, limite la taille des messages et des fichiers, et ne journalise ni justificatifs ni renseignements personnels sans protection[68].

Les notifications push demandent une attention particulière : c'est l'agent serveur qui appelle une URL fournie par le client, un point de rappel HTTP *(webhook)*, ce qui en fait une cible de falsification de requête côté serveur *(SSRF)*. La spécification exige que l'agent joigne les justificatifs prévus par la configuration et tente au moins une livraison; elle recommande un délai d'expiration de 10 à 30 secondes, des reprises avec repli exponentiel et le rejet des URL visant `127.0.0.0/8`, `10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`, `localhost` ou une adresse lien-local. Le récepteur doit valider l'authenticité de la notification et répondre par un code 2xx; il devrait vérifier que la tâche signalée est l'une des siennes. La livraison est tentée « au moins une fois », sans garantie de succès (reprises facultatives) et avec des doublons possibles, d'où un traitement idempotent[68].

**EXIG-A2A-08**
**DOIT**

**Version annoncée et liaisons standard**

Tout client A2A **DOIT** envoyer `A2A-Version` à chaque requête. Tout agent **DOIT** exposer la liaison JSON-RPC et **PEUT** ajouter gRPC ou HTTP+JSON lorsque la passerelle d'agents les prend en charge, à condition d'offrir par chaque liaison les mêmes opérations, les mêmes erreurs et les mêmes schémas d'authentification. Une liaison non standard, dont SLIMRPC, **NE DOIT PAS** servir en production hors d'un pilote approuvé par le comité d'architecture.

Pourquoi : la version explicite évite les replis silencieux vers 0.3, et une liaison commune garde chaque agent joignable par toutes les plateformes retenues.

**EXIG-A2A-09**
**DOIT**

**Transport chiffré et authentification à chaque requête**

Tout échange A2A **DOIT** utiliser TLS 1.3 par défaut, TLS 1.2 étant le plancher toléré (versions antérieures désactivées), avec validation des certificats, transiter par la passerelle d'agents et être authentifié à chaque requête. L'agent serveur **DOIT** autoriser avant toute opération qui lit ou divulgue de l'information, valider ses paramètres et borner la taille des messages et des fichiers.

Pourquoi : la passerelle applique au trafic entre agents les contrôles déjà appliqués aux outils; la documentation A2A recommande fortement une solution de gestion d'API pour les agents exposés[161].

**EXIG-A2A-10** — DOIT

**Autorisation par compétence et par locataire**

Chaque compétence publiée **DOIT** être associée à une portée OAuth dédiée, déclarée dans ses `securityRequirements` et inscrite au catalogue. L'appelant **DOIT** présenter un jeton délégué dont l'audience est l'agent appelé (section 9.3). Lorsqu'un point de terminaison sert plusieurs locataires, la passerelle **DOIT** vérifier que le `tenant` demandé correspond aux droits du jeton, sans jamais le déduire du seul contenu de la requête.

Pourquoi : le moindre privilège s'applique à la compétence, pas à l'agent entier; un jeton valide pour analyser un dossier ne doit pas permettre d'accorder un prêt.

**EXIG-A2A-11** — NE DOIT PAS

**Flux OAuth retirés**

Les agents et leurs clients **NE DOIVENT PAS** employer l'octroi implicite ni l'octroi par mot de passe. Ils **DOIVENT** utiliser le code d'autorisation avec PKCE[175] (ou le Device Code pour un appareil sans navigateur) quand une personne s'authentifie, les justificatifs client pour un agent qui agit en son nom propre et, pour la délégation, l'échange de jetons de la RFC 8693[70].

Pourquoi : A2A 1.0 a retiré ces flux[240], et la RFC 9700 interdit l'octroi par mot de passe et déconseille l'octroi implicite[175].

**EXIG-A2A-12** — DOIT

**Notifications push durcies**

Le cadre rend obligatoires les recommandations de la spécification. L'agent serveur **DOIT** valider l'URL de webhook contre la SSRF à l'enregistrement et à chaque livraison, après résolution DNS (plages privées, boucle locale et lien-local refusées), appliquer un délai d'expiration compris entre 10 et 30 secondes et des reprises à repli exponentiel. Le récepteur **DOIT** authentifier la notification, vérifier que l'identifiant de tâche lui appartient et traiter chaque notification de façon idempotente.

Pourquoi : un webhook non filtré permet à un client malveillant de faire sonder le réseau interne par l'agent.

**EXIG-A2A-13** — DOIT

**Traçage et corrélation des tâches**

Chaque appel A2A **DOIT** propager l'en-tête W3C `traceparent` et être tracé côté appelant par un span `invoke_agent` de type CLIENT. Le journal d'audit **DOIT** consigner `taskId`, `contextId` et l'identifiant de trace (section 10.1 et section 10.3).

Pourquoi : la v1.41.0 des conventions OpenTelemetry n'a pas de convention propre à A2A (une convention A2A, au niveau Development, figure depuis peu dans la branche principale du dépôt semantic-conventions-genai, sans version étiquetée)[241]; la convention des agents trace un agent distant par un span `invoke_agent` CLIENT[120], et la documentation A2A recommande le traçage distribué[161].

## Déroulement d'une délégation avec approbation

La figure 9 montre comment A2A, MCP et l'approbation humaine se combinent. Un orchestrateur confie l'analyse d'un dossier de crédit commercial à un agent spécialiste; l'inscription de la décision dans l'ERP est classée P3 au catalogue et exige donc une approbation humaine (section 8.3).

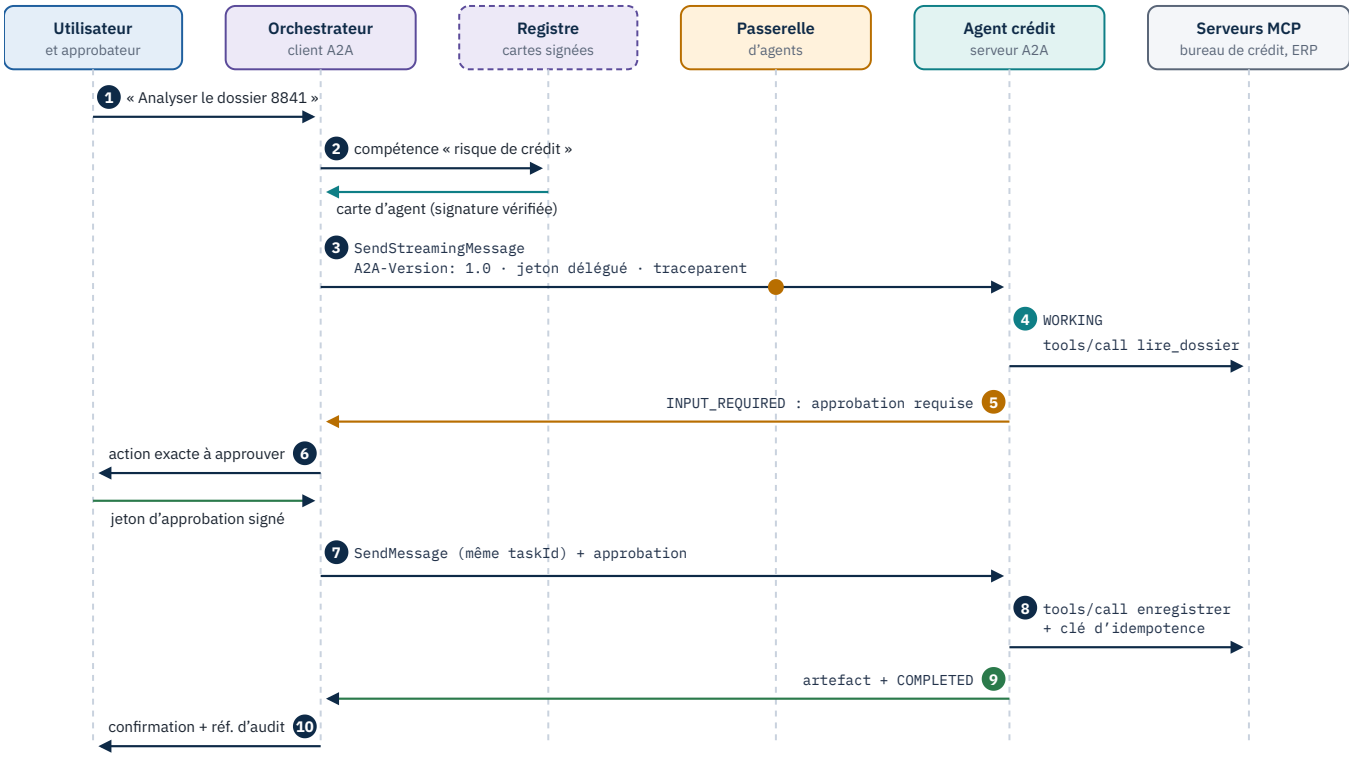



**Figure 9 — Délégation A2A avec appel MCP et approbation humaine.** Les numéros renvoient aux étapes ci-dessous. La passerelle d'agents se trouve sur chaque appel, et l'écriture n'a lieu qu'avec un jeton d'approbation lié à l'action exacte.

Source : élaboration du cadre, d'après la spécification A2A 1.0 et MCP 2026-07-28.

1. L'utilisateur demande à l'orchestrateur d'analyser le dossier 8841.
2. L'orchestrateur cherche au registre la compétence « risque de crédit », obtient la carte de l'agent spécialiste et en vérifie la signature.
3. Il obtient un jeton délégué dont l'audience est l'agent crédit, puis envoie `SendStreamingMessage` par la passerelle avec `A2A-Version: 1.0`, le jeton et `traceparent`. Le message porte le sous-objectif structuré et des références de documents, jamais l'historique brut de la conversation (section 7.7).
4. L'agent crédit passe à `WORKING` et lit le dossier par un outil MCP (`tools/call`), sous un jeton échangé pour l'audience du serveur MCP.
5. Prêt à inscrire sa décision, il passe à `INPUT_REQUIRED` et décrit, dans une partie `data`, l'action exacte à approuver : outil, arguments, montant.
6. L'orchestrateur soumet cette action à un approbateur habilité, hors de la conversation; l'approbation produit un jeton signé lié à l'empreinte de l'action (section 8.5).
7. L'orchestrateur envoie un nouveau message rattaché au même `taskId`, qui transmet le jeton d'approbation.
8. L'agent crédit appelle l'outil d'écriture de l'ERP avec le jeton d'approbation et une clé d'idempotence (section 7.6); la passerelle vérifie que le jeton correspond exactement à cet appel avant de le relayer.
9. L'agent livre son artefact, et la tâche passe à `COMPLETED`.
10. L'orchestrateur confirme le résultat à l'utilisateur avec la référence du journal d'audit.

Si l'approbateur refuse ou si le délai d'approbation expire, l'orchestrateur annule la tâche (`CancelTask`) et aucune écriture n'a lieu. Un « oui » saisi dans la conversation n'est jamais une approbation : seul compte le jeton signé, vérifié par la passerelle.

### Migration et compatibilité

Une carte 1.0 peut annoncer à la fois des interfaces 0.3 et 1.0, distinguées par `protocolVersion`, et les SDK officiels assurent la rétrocompatibilité[29, 68]. Les principaux changements à absorber sont les suivants : `supportedInterfaces` remplace `url`, `preferredTransport` et `additionalInterfaces`; les parties sont unifiées; les états prennent le préfixe `TASK_STATE_`; l'opération de flux devient `SendStreamingMessage`[235]. Les SDK n'ont pas atteint la 1.0 en même temps : celui de JavaScript n'est en disponibilité générale que depuis le 22 juillet 2026[242]. La trousse `a2a-tck` teste les trois liaisons standard, à partir des interfaces déclarées dans la carte, selon trois niveaux : MUST (échec bloquant), SHOULD (échec signalé, non bloquant) et MAY (test sauté si la fonction n'est pas déclarée)[243]. L'interface en ligne de commande officielle, présentée le 1er octobre 2026 (versions publiées dès le 9 septembre 2026), s'insère dans les chaînes d'intégration grâce à sa sortie JSON et à ses codes de sortie prévisibles, par exemple pour des tests de fumée[244, 245].

**EXIG-A2A-14** — DOIT

**Compatibilité vérifiée avant inscription**

Un agent **DOIT** réussir tous les tests de niveau MUST d'`a2a-tck`, sur chaque liaison déclarée, avant son inscription au registre et à chaque nouvelle version mineure ou majeure de sa carte. Tout échec de niveau SHOULD **DOIT** être consigné à la fiche, avec une échéance de correction.

Pourquoi : la conformité se prouve par un test reproductible, pas par une déclaration du fournisseur.

**EXIG-A2A-15** — DEVRAIT

**Migration bornée depuis la version 0.3**

Un agent encore en 0.3 **DEVRAIT** migrer par double publication : sa carte annonce une interface 1.0 et une interface 0.3, cette dernière portant une date de retrait inscrite au catalogue, au plus six mois après l'ouverture de l'interface 1.0 (choix du cadre). Passé cette date, la passerelle **DOIT** refuser les requêtes sans en-tête `A2A-Version`.

Pourquoi : la coexistence évite de basculer tous les clients le même jour, et l'échéance empêche la version obsolète de devenir permanente.

## 6.7 Interopérabilité événementielle

Cette section encadre les échanges asynchrones : un agent ou un système publie un fait sur un bus d'événements, et un ou plusieurs agents y réagissent sans que l'émetteur les connaisse. Elle fixe l'enveloppe, les contrats, les attributs de gouvernance et les garanties sur lesquelles une conception peut réellement compter.

### Quand préférer l'événement

MCP et A2A fonctionnent par demande et réponse : l'appelant connaît son destinataire et attend un résultat. L'événement convient mieux dans trois cas. **Découplage dans le temps** : le traitement peut attendre, ou le consommateur peut être indisponible un moment (lots de nuit, pointes de charge, réaction aux changements d'état d'un ERP). **Plusieurs abonnés** : un même fait intéresse plusieurs agents, et l'on veut en ajouter sans toucher à l'émetteur. **Rejeu** : on veut relire la séquence des faits pour un audit ou pour évaluer une nouvelle version d'agent. Par exemple, une alerte de rupture de stock intéresse la planification, l'approvisionnement et le service à la clientèle; publiée une fois, elle les atteint tous les trois sans que le détecteur les connaisse.

S'y ajoute un argument de topologie : relier N agents deux à deux exige jusqu'à N(N−1)/2 liaisons, alors que N agents reliés à un courtier n'en exigent que N. Le gain porte sur le nombre de connexions; les sujets, les schémas et les contrats restent à gouverner. L'abonnement évite aussi le délai propre aux boucles d'interrogation. Comme le souligne Kai Waehner, conseiller indépendant en diffusion de données en continu *(data streaming)*, MCP n'offre ni garantie de livraison ni cohérence, alors qu'un journal persistant et ordonné découple producteurs et consommateurs : les deux approches se complètent[167, 246].

**EXIG-EVT-01** DEVRAIT

**Recours au bus pour l'asynchrone**

Une interaction qui n'attend pas de réponse immédiate, qui intéresse plusieurs consommateurs ou qui doit pouvoir être rejouée **DEVRAIT** passer par le bus d'événements de l'entreprise plutôt que par une chaîne d'appels A2A ou MCP. Le choix suit la matrice de la section 6.4 et le patron de chorégraphie de la section 7.2.

Pourquoi : une chaîne d'appels synchrones lie la disponibilité de chaque agent à celle de tous les autres.

## Enveloppe et contrats

Le cadre retient CloudEvents 1.0 comme enveloppe. La dernière révision publiée est la 1.0.2 (février 2022), les producteurs indiquent toujours `specversion` « 1.0 », et le projet a obtenu le statut « Graduated » de la CNCF le 25 janvier 2024[173, 247, 248]. CloudEvents exige quatre attributs de contexte (`id`, `source`, `specversion`, `type`) et en propose quatre facultatifs (`datacontenttype`, `dataschema`, `subject`, `time`)[248]. Le contrat de chaque sujet se décrit en AsyncAPI 3.x : la 3.0.0 date du 5 décembre 2023, et la 3.1.0, publiée le 31 janvier 2026, est une version mineure sans rupture[174, 249].

Sur Kafka, la liaison CloudEvents offre un mode binaire (attributs, sauf `datacontenttype` porté par l'en-tête `content-type`, dans des en-têtes préfixés `ce_` ; données telles quelles dans la valeur) et un mode structuré (événement complet en `application/cloudevents+json`); un « Key Mapper » facultatif, à activer explicitement, peut copier `partitionkey` dans la clé Kafka[250]. Le cadre retient le mode binaire par défaut : les données restent intactes, et les intermédiaires filtrent sur les attributs sans désérialiser la charge utile. Un consommateur détermine le mode d'après l'en-tête `content-type` : un type qui commence par `application/cloudevents` indique le mode structuré, tout autre type le mode binaire[250]. Un exemple d'événement complet figure à l'annexe C.

**EXIG-EVT-02** DOIT

**Enveloppe CloudEvents complète**

Tout événement produit ou consommé par un agent **DOIT** respecter CloudEvents 1.0 et porter, en plus des quatre attributs requis, `time`, `datacontenttype` et `dataschema` (exigence du cadre). Le `type` **DOIT** être un nom en domaine inversé qui inclut sa version (exigence du cadre; la norme recommande seulement le préfixe en domaine inversé), par exemple `ca.entreprise.logistique.alerte.rupture.v1`.

Pourquoi : un consommateur doit savoir, sans ouvrir la charge utile, ce qu'il reçoit, quand le fait s'est produit (ou, si cet instant est inconnu, l'heure que la source retient de façon uniforme) et quel schéma le valide.

**EXIG-EVT-03** DOIT

**Contrat AsyncAPI au catalogue**

Chaque sujet du bus **DOIT** être décrit par un contrat AsyncAPI 3.x inscrit au catalogue d'entreprise. Le contrat précise le schéma versionné des données et la clé de partition; l'entrée de catalogue précise le propriétaire, la classification et les producteurs et consommateurs autorisés, pour lesquels AsyncAPI ne définit aucun champ normalisé (section 6.8). Un changement incompatible de schéma crée un nouveau `type` versionné, selon les règles de la section 6.8.

Pourquoi : sans contrat, chaque consommateur devine le format et casse au premier changement.

## Extensions de gouvernance

Les attributs requis par CloudEvents ne disent ni quel agent a lancé la chaîne, ni au nom de qui, ni à quel coût. Le cadre ajoute donc des extensions, en privilégiant celles que CloudEvents documente déjà; ces extensions documentées n'ont pas de statut officiel et peuvent évoluer, et trois d'entre elles (Auth Context, Data Classification et Expiry Time) ne figurent pas dans la révision 1.0.2, qui ne documente que Dataref, Distributed Tracing, Partitioning, Sampling et Sequence[251][187], si bien que le cadre fige au catalogue la version qu'il en retient. Un nom d'attribut ne contient que des minuscules ASCII et des chiffres, et ne devrait pas dépasser 20 caractères; le préfixe `x` n'est ni exigé ni défini par la

norme, et le cadre le garde pour signaler ses propres extensions[248]. Pour désigner l'initiateur, l'extension documentée Auth Context remplace une extension maison : elle est purement informative, déconseille les renseignements personnels dans `authid` et interdit d'inclure dans `authclaims` des justificatifs permettant d'usurper directement l'identité du mandant[252].

Le contexte de trace mérite une précision. L'extension Distributed Tracing prévoit que, pour une transmission en plusieurs sauts, `traceparent` porte la trace de départ et non celle de chaque saut; elle ne remplace pas les en-têtes de traçage du transport[253]. Les conventions OpenTelemetry de messagerie, au niveau Development, recommandent que le producteur injecte le contexte de création dans le message et relient par défaut producteur et consommateur par des liens de span plutôt que par parenté (la parenté n'étant admise que pour un message unique)[254].

**Tableau 20 — Attributs d'extension CloudEvents exigés par le cadre**

| Attribut | Origine | Contenu | Règle du cadre |
|---|---|---|---|
| `traceparent` (`tracestate` facultatif) | Extension documentée Distributed Tracing | Contexte W3C Trace Context de la trace que poursuit l'agent émetteur | Obligatoire; jamais un identifiant métier |
| `authtype`, `authid` | Extension documentée Auth Context | Type de mandant, selon les valeurs recommandées par l'extension (`app_user` pour l'utilisateur final d'une application, `user` pour un compte d'infrastructure, `service_account`, `api_key`, `system` pour une identité volontairement masquée, `unauthenticated`, `unknown`), et son identifiant | Obligatoires; `authid` pseudonyme |
| `dataclassification`, `dataregulation`, `datacategory` | Extension documentée Data Classification[255] | étiquettes recommandées par l'extension lorsque aucun régime n'en définit : `public`, `internal`, `confidential` ou `restricted`; régime applicable (liste séparée par des virgules); catégorie selon le régime (p. ex. `sensitive-pii`, exemple américain de l'extension) | `dataclassification` obligatoire; les deux autres dès que l'événement touche des RP |
| `xagentorigin` | Propre au cadre | Identifiant au registre et version de l'agent qui a publié le premier événement de la chaîne | Obligatoire sur tout événement publié par un agent |
| `xagenthopcount` | Propre au cadre | Entier (type Integer de CloudEvents) : nombre de publications d'agents dans la chaîne causale (1 pour la première) | Obligatoire; augmenté de 1 à chaque republication |
| `xagentmaxhops` | Propre au cadre | Entier (type Integer de CloudEvents) : plafond de sauts fixé au contrat du flux; l'événement dont le compteur atteint ce plafond n'est pas traité | Obligatoire; 4 par défaut; recopié sans modification |
| `xcostcenter` | Propre au cadre | Centre de coûts imputé | Obligatoire; valeur du référentiel financier |
| `partitionkey`, `sequence`, `expirytime`, `dataref` | Extensions documentées | Clé de partition, rang, échéance, référence externe aux données | Au besoin, de préférence à toute extension maison |

**EXIG-EVT-04**
**DOIT**

**Attributs de gouvernance présents et vérifiés**

Tout événement publié par un agent **DOIT** porter les attributs obligatoires du tableau 20. Un consommateur **DOIT** refuser un événement d'agent qui en est dépourvu et le diriger vers la file de lettres mortes *(dead-letter queue)*. Il **DOIT** aussi tenir compte de `dataclassification` et rejeter l'événement dont il ne peut respecter les exigences ou dont il ne reconnaît pas la valeur, comme l'exige l'extension Data Classification, qui demande aussi aux intermédiaires de ne pas modifier ces attributs[255]. Un intermédiaire qui relaie un événement **NE DOIT PAS** modifier `traceparent` ; un agent qui publie un nouvel événement en réaction y **DOIT** recopier le `traceparent` de l'événement reçu (ou, s'il ouvre la chaîne, celui de la trace qu'il ouvre) (section 10.1).

Pourquoi : sans ces attributs, une chaîne d'agents n'est ni traçable, ni imputable, ni bornée.

**EXIG-EVT-05**
**NE DOIT PAS**

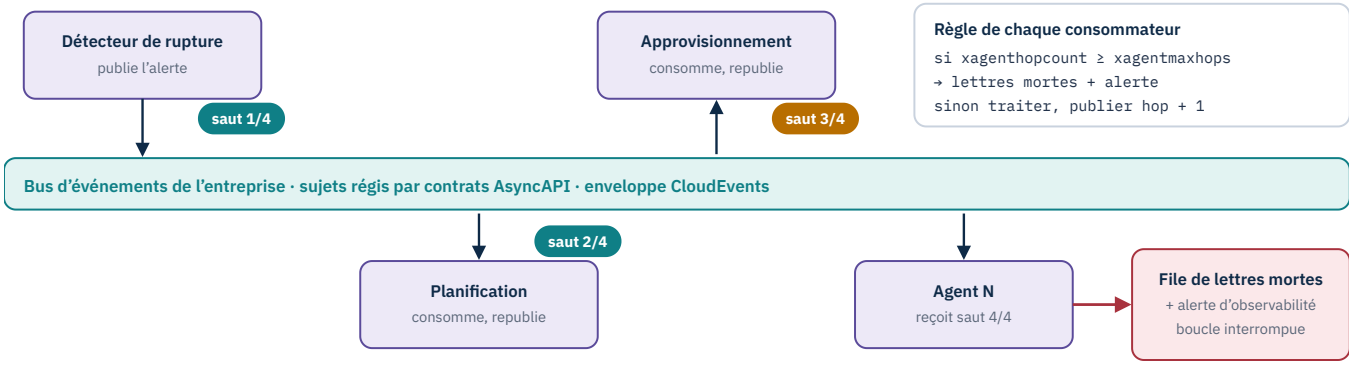
**Aucun renseignement personnel dans les attributs**

Les attributs d'un événement, lus par chaque intermédiaire et recopiés dans les journaux et les traces, **NE DOIVENT PAS** contenir de renseignement personnel direct (nom, courriel, numéro de compte) ni de justificatif; une personne n'y figure que sous un identifiant pseudonyme opaque, qui demeure un renseignement personnel (section 12.2) et dont la table de correspondance reste hors du bus. Les données personnelles volumineuses ou sensibles restent dans le système source; l'événement ne transmet qu'une référence ( `dataref` ), sans `data` , dont l'accès est contrôlé.

Pourquoi : un bus réplique chaque événement chez tous ses abonnés; limiter les RP qu'il transporte réduit d'autant la surface à protéger au titre de la Loi 25 (section 12.2).

## Prévention des tempêtes d'événements

Dans une chorégraphie, aucun composant central ne voit l'ensemble. Deux agents qui réagissent chacun aux événements de l'autre peuvent donc s'entretenir indéfiniment : la planification révise une prévision, l'approvisionnement ajuste une commande, ce qui déclenche une nouvelle révision, et ainsi de suite. Chaque tour consomme des jetons et peut produire des effets réels. Le compteur de sauts coupe cette boucle de façon déterministe, sans dépendre du jugement d'un modèle (figure 10). Ce compteur et son plafond sont des conventions propres au cadre : aucune extension CloudEvents normalisée ne les couvre[187].




Chaque événement porte le contexte de la trace poursuivie (traceparent), l'agent d'origine, l'initiateur et le centre de coûts.

**Figure 10 — Chorégraphie événementielle et compteur de sauts.** Chaque republication augmente `xagenthopcount` ; l'événement qui atteint le plafond (4 par défaut) n'est pas traité : il part en file de lettres mortes et déclenche une alerte.

Source : élaboration du cadre; enveloppe CloudEvents 1.0.

**EXIG-EVT-06**
**DOIT**

**Compteur de sauts et coupure des boucles**

Le premier agent qui publie dans une chaîne **DOIT** fixer `xagenthopcount` à 1, `xagentorigin` à son identifiant et `xagentmaxhops` à la valeur du contrat du flux (4 par défaut). Tout agent qui publie en réaction à un événement reçu **DOIT** augmenter le compteur de 1 et recopier les deux autres valeurs sans les modifier. Un agent qui reçoit un événement dont `xagenthopcount` atteint ou dépasse `xagentmaxhops` **DOIT** s'abstenir de le traiter, le diriger vers la file de lettres mortes et lever une alerte. Le plafond d'un flux ne se relève que par une modification revue de son contrat.

Pourquoi : une règle locale, appliquée par chaque consommateur, borne la longueur de toute chaîne d'événements qui ne traverse que des consommateurs conformes (un composant qui n'applique pas la règle, ou qui n'est pas un agent, rompt la chaîne causale).

**EXIG-EVT-07**
**DOIT**

**Autorisation fondée sur l'identité, pas sur les attributs**

Le droit de publier ou de consommer sur un sujet **DOIT** reposer sur l'identité authentifiée de l'agent auprès du courtier et sur des listes de contrôle d'accès par sujet, tirées de l'entrée de catalogue du sujet (producteurs et consommateurs autorisés). Une décision d'autorisation **NE DOIT PAS** se fonder sur `authtype`, `authid` ou un autre attribut de l'événement pour accorder un accès (`dataclassification` ne peut que le restreindre). Les données reçues **DOIVENT** être traitées comme du contenu non fiable (section 9.6).

Pourquoi : l'extension Auth Context est informative et n'est pas un mécanisme de sécurité[252]; n'importe quel producteur peut y écrire n'importe quoi.

## Garanties réelles d'un bus

Apache Kafka sert ici d'exemple parce que ses garanties sont documentées avec précision; un autre courtier se juge sur les mêmes questions. Le tableau 21 distingue ce que le courtier garantit de ce qui reste à la charge de la conception.

**Tableau 21 — Garanties d'un bus Kafka et responsabilités de la conception**

| Propriété | Ce que Kafka garantit | Ce qui reste à la conception |
|---|---|---|
| Livraison | « Au moins une fois » par défaut; le producteur idempotent (depuis 0.11.0.0) évite les doublons dans le journal lors des reprises[140] | Consommateurs idempotents et déduplication |
| Exactement une fois | Cycle lecture-traitement-écriture entre sujets Kafka (transactions, consommateur `read_committed`); un système externe doit coopérer[140, 256] | Clé d'idempotence vérifiée par le système cible; patron de la boîte d'envoi |
| Ordre | Par partition seulement; les événements de même clé vont dans la même partition[257] | Choisir la clé selon l'entité dont l'ordre compte |
| Répartition du travail | Rééquilibrage natif des groupes de consommateurs; files coopératives *(share groups)* dont l'ordre n'est garanti qu'à l'intérieur d'un lot[258] | Réserver les files coopératives aux tâches indépendantes |
| Rejeu | Relecture depuis un décalage sauvegardé, dans la limite de la rétention configurée[140] | Rétention suffisante; rejeu isolé; aucune promesse de décisions identiques |

Quelques repères de version aident à fixer au catalogue la version plancher du courtier. Kafka 4.0 (18 mars 2025) est la première version majeure entièrement sans ZooKeeper et généralise le nouveau protocole de rééquilibrage des groupes[259]. Les files coopératives sont prêtes pour la production depuis Kafka 4.2.0 (17 février 2026), et Kafka 4.4.0 (22 octobre 2026) leur ajoute des files de lettres mortes[260, 261].

La conséquence pratique tient en une phrase : un effet réel n'est jamais protégé par le bus, mais par l'idempotence du consommateur et du système cible. Kafka seul n'empêche pas un double paiement. Pour publier de façon fiable un changement d'état et l'événement qui l'annonce, le producteur applique le patron de la boîte d'envoi *(transactional outbox)* : il écrit l'événement dans une table de sa base, dans la même transaction locale que le changement, puis un relais le publie. Aucun événement ne part ainsi pour une transaction annulée, et aucun changement validé ne reste sans événement.

Le rejeu appelle la même prudence. Confluent présente le rejeu déterministe des événements comme le fondement de l'investigation d'un incident, de l'audit réglementaire, de la validation de modèle et des mises à jour sûres des agents[262]. Rejouer les entrées ne garantit pourtant pas que l'agent reprendra les mêmes décisions, car rien n'assure qu'un modèle produise la même sortie à entrées identiques. Le cadre parle donc de rejeu des entrées pour l'audit et la réévaluation, jamais de reproduction des décisions.

**EXIG-EVT-08**
**DOIT**

**Effets réels protégés par l'idempotence**

Tout consommateur dont le traitement produit un effet hors du bus **DOIT** être idempotent : il déduplique sur l'identité de l'événement (`source` et `id` ; le producteur et le relais de la boîte d'envoi **DOIVENT** les conserver à chaque renvoi du même événement, ce que la norme permet sans l'imposer) et transmet au système cible une clé d'idempotence que ce dernier vérifie (section 7.6). Un producteur qui publie à la suite d'un changement dans sa base **DOIT** appliquer le patron de la boîte d'envoi ou un mécanisme transactionnel équivalent. La sémantique « exactement une fois » du courtier **NE DOIT PAS** être invoquée comme protection contre un double effet externe.

Pourquoi : la livraison est « au moins une fois »[140]; sans idempotence, une seule reprise suffit à payer deux fois une facture.

**EXIG-EVT-09**
**DOIT**

**Ordre garanti par la clé de partition**

Lorsqu'un flux exige l'ordre des événements d'une même entité (dossier, commande, session), la clé de partition **DOIT** être l'identifiant technique de cette entité, sans renseignement personnel (EXIG-EVT-05), porté par `partitionkey` et précisé au contrat AsyncAPI. Le producteur **DOIT** aussi copier cette valeur dans la clé du message Kafka, au moyen d'un « Key Mapper » à activer explicitement, car la liaison reprend par défaut la clé fournie par l'utilisateur[250]. Les files coopératives **NE DOIVENT PAS** servir à un tel flux; elles conviennent aux bassins d'exécutants dont les tâches sont indépendantes.

Pourquoi : Kafka ne garantit l'ordre qu'au sein d'une partition, et une file coopérative ne le garantit qu'à l'intérieur d'un lot.

**EXIG-EVT-10**
**DOIT**

**Conservation des entrées et rejeu isolé**

Les sujets qui alimentent des agents de classe de risque modérée ou élevée **DOIVENT** conserver leurs événements au moins pendant la fenêtre d'enquête inscrite à la fiche de l'agent (au moins 90 jours pour la classe modérée et un an pour la classe élevée, sans excéder la rétention des traces et journaux d'audit fixée au chapitre 10), dans la limite du calendrier de conservation applicable aux RP. Tout rejeu **DOIT** s'exécuter dans un environnement isolé où les outils à effet sont remplacés par des doublures; ses résultats servent à l'audit et à l'évaluation continue (section 10.4), jamais à répéter des actions en production.

Pourquoi : rejouer des entrées contre des outils réels répéterait leurs effets, et un modèle peut décider autrement la seconde fois.

## 6.8 Contrats, versionnage et catalogue d'entreprise

Cette section fixe ce que chaque interface offerte à un agent doit déclarer, comment ses versions évoluent sans briser ses consommateurs et ce que contient le catalogue d'entreprise.

### Ce que chaque contrat déclare

Un contrat a deux faces : ce que le fournisseur publie dans le format du protocole, et ce que l'entreprise fixe au catalogue. Comme les annotations MCP sont des indices non fiables (EXIG-MCP-14) et que la carte A2A n'admet aucun champ de gouvernance hors norme (EXIG-A2A-05), tout ce qui commande une décision de sécurité vit au catalogue (tableau 22; exemples à l'annexe C).

**Tableau 22 — Contenu minimal des contrats, par type d'interface**

| Interface | Contrat publié | Entrée fixée au catalogue |
|---|---|---|
| Outil MCP | Nom préfixé par le domaine; description destinée au modèle, qui dit ce que fait l'outil et ce qu'il ne fait pas; `inputSchema` et, au besoin, `outputSchema` en JSON Schema 2020-12; clé d'idempotence pour tout outil à effet (section 7.6) | Version et empreinte; palier P0 à P3 et seuil (section 8.3); compensation de toute écriture P2; propriétaire et équipe de garde; classification maximale des données |
| Ressource et invite MCP | Ressource adressée par URI; invite nommée et décrite | Version et empreinte; classification |
| Agent A2A | Carte A2A 1.0 signée (section 6.6) | Version et empreinte; portée OAuth par compétence; renvoi à la fiche du registre |
| Sujet d'événement | Contrat AsyncAPI 3.x et `type` versionné (section 6.7) | Producteurs et consommateurs autorisés; classification; plafond de sauts |
| API existante | Contrat OpenAPI 3.1.x ou 3.2.x; erreurs au format RFC 9457[171] | Outils MCP qui l'exposent, chacun avec son entrée |

**EXIG-INT-12** — **DOIT**

**Contrat complet avant l'inscription**

Toute interface offerte à un agent **DOIT** disposer, avant son inscription au catalogue d'entreprise, d'un contrat publié et d'une entrée de catalogue qui contiennent au minimum les éléments du tableau 22. Un élément manquant bloque l'inscription.

Pourquoi : la passerelle n'applique que des règles écrites; sans palier ni compensation déclarés, l'agent déciderait seul de ce qui est sûr.

### Versionnage sémantique

La version d'un protocole ne dit rien des contrats publiés sur lui. Or la définition d'un outil MCP ne comporte aucun champ de version[197], et le champ `version` d'une carte A2A est de format libre[68]. Le cadre impose donc aux contrats le versionnage sémantique (SemVer), de forme MAJEUR.MINEUR.CORRECTIF, tenu au catalogue :

- **majeur** : tout changement qui peut faire échouer ou tromper un consommateur (élément retiré ou renommé, nouveau paramètre obligatoire, valeurs admises restreintes en entrée, valeur ajoutée à une énumération de sortie, changement de sens à format constant);
- **mineur** : ajout compatible et toute reformulation d'une description;
- **correctif** : correction qui ne change ni la définition publiée ni le comportement attendu.

Le changement de sens est le plus dangereux, car aucun validateur ne le voit : un montant qui passe de hors taxes à toutes taxes comprises reste un nombre valide (section 6.1). A2A applique la même logique à ses extensions, dont tout changement incompatible exige une nouvelle URI[238].

**EXIG-INT-13** DOIT

**Versionnage sémantique des contrats**

Tout contrat inscrit au catalogue **DOIT** porter une version SemVer, incrémentée à chaque publication selon les règles ci-dessus : au moins mineure pour toute modification de la définition publiée (nom, description, schémas, annotations, compétences), majeure pour tout changement incompatible, y compris de sens. Pour un agent A2A, c'est le champ `version` de sa carte (EXIG-A2A-04).

Pourquoi : un numéro régi par des règles connues dit au consommateur s'il peut migrer sans risque (règle du cadre).

**EXIG-INT-14** DOIT

**Coexistence d'au moins 60 jours**

À la publication d'une version majeure, la version majeure précédente **DOIT** rester disponible au moins 60 jours (choix du cadre), avec une date de retrait inscrite au catalogue dès ce moment et annoncée aux consommateurs connus. Seul un motif de sécurité, sur décision du comité, justifie un retrait anticipé.

Pourquoi : un délai connu permet de planifier les migrations; il concorde avec le préavis de retrait d'un agent (section 11.5).

## Épinglage et approbation des changements

Un consommateur ne suit jamais « la dernière version ». Il dépend d'une version identifiée par son numéro et par son empreinte, soit le condensé SHA-256 de la définition canonisée selon la RFC 8785[236]. Le numéro dit ce que le fournisseur affirme; l'empreinte prouve ce que l'agent reçoit. La fiche d'agent consigne ces dépendances (annexe B), et la passerelle vérifie l'empreinte à l'exécution (EXIG-MCP-20, EXIG-SEC-18). L'OWASP recommande d'épingler les définitions par empreinte et de redemander le consentement à chaque modification[221].

**EXIG-INT-15** DOIT

**Dépendances épinglées par version et empreinte**

Chaque agent **DOIT** déclarer dans sa fiche, pour chaque outil, ressource, invite, agent appelé et sujet d'événement, la version épinglée et l'empreinte approuvée. Une dépendance **NE DOIT PAS** désigner une version flottante (« dernière », plage de versions); changer de version est une modification de la fiche, revue et tracée.

Pourquoi : sans épinglage, un fournisseur peut changer le comportement d'un agent à l'insu de son propriétaire.

**EXIG-INT-16** DOIT

**Nouvelle approbation à toute modification**

Toute modification de la définition publiée d'un outil, d'une ressource, d'une invite ou d'une carte d'agent, y compris la reformulation d'une description, **DOIT** être revue et approuvée de nouveau au catalogue avant d'être servie aux agents, y compris pour les serveurs et agents de tiers. La revue confirme aussi le palier attribué.

Pourquoi : le modèle lit la description comme une consigne, et la substitution après approbation *(rug pull)* exploite justement un changement présenté comme anodin (section 9.8).

### Catalogue d'entreprise

Le catalogue d'entreprise recense tous les contrats joignables par les agents. Le catalogue des protocoles (section 6.3) dit quels standards employer; le catalogue d'entreprise, quels contrats existent sur ces standards. Le registre (section 11.4) dit qui répond d'un agent et avec quel risque; le catalogue, par quel contrat et dans quelle version. Le registre officiel MCP, en préversion, n'en tient jamais lieu[43].

Chaque version de contrat est « en revue », « active », « dépréciée » (avec sa date de retrait) ou « retirée », à l'image du cycle *Active*, *Deprecated*, *Removed* que MCP applique à ses propres fonctionnalités[34]. Ces états sont distincts de ceux de la fiche d'agent. Sans la liste des consommateurs de chaque version, on découvre ceux d'une version retirée par leurs pannes.

**EXIG-INT-17**
**DOIT**

**Catalogue unique, source de la découverte**

L'entreprise **DOIT** tenir un seul catalogue d'entreprise, sous une même autorité et articulé avec le registre de gouvernance (section 11.4), qui recense chaque version de contrat (schéma, serveur MCP, carte d'agent A2A, sujet AsyncAPI) avec son état, son propriétaire, son empreinte et, s'il y a lieu, sa date de retrait. La découverte passe par lui, jamais par une adresse configurée à la main; la passerelle ne sert que les versions actives et les versions dépréciées non échues.

Pourquoi : deux sources de vérité finissent par diverger.

**EXIG-INT-18**
**DOIT**

**Consommateurs connus avant tout retrait**

Le catalogue **DOIT** indiquer les consommateurs connus de chaque version active ou dépréciée, tirés des fiches d'agents et rapprochés chaque mois des appels observés par la passerelle (fréquence fixée par le cadre). Une version n'est retirée qu'à l'échéance annoncée, jamais avant la fin de la coexistence de l'EXIG-INT-14, et après avis à ses consommateurs connus; les traces servent à repérer, avant l'échéance, les appels de consommateurs non déclarés.

Pourquoi : les traces révèlent les consommateurs non déclarés avant que le retrait ne les brise.

### Tests de compatibilité

Une règle de versionnage ne tient que si une machine la vérifie; seul le changement de sens échappe à la comparaison des schémas et relève de la revue sémantique (EXIG-INT-01 et EXIG-INT-16). Les suites de conformité complètent les tests internes : `a2a-tck`, dont les tests MUST sont bloquants (EXIG-A2A-14)[243], et le cadre officiel de tests de conformité MCP, encore en versions 0.x (préversion 0.2.0-alpha en cours)[225, 226]. Ces tests forment le premier palier de l'évaluation continue (section 10.4).

**EXIG-INT-19**
**DOIT**

**Détection automatique des ruptures**

La chaîne d'intégration **DOIT** comparer chaque nouvelle version d'un contrat à la version active précédente et bloquer toute publication qui contient un changement incompatible sans incrément majeur. Avant son activation, la nouvelle version **DOIT** réussir les tests de contrat de ses consommateurs connus et, pour un agent A2A, les tests MUST d'`a2a-tck` ; les résultats du cadre officiel de conformité MCP (ou d'une suite équivalente approuvée par l'architecture d'entreprise, EXIG-APP-08) sont consignés à titre informatif tant que ce cadre demeure en préversion 0.x et se déclare instable.

Pourquoi : une règle de compatibilité vérifiée à la main finit par céder sous la pression d'une livraison.

## 6.9 Protocoles émergents et veille

Cette section situe les travaux qui n'ont pas le statut Adopter (section 6.3) et en encadre l'usage; le processus de veille relève de la section 11.7.

### Ce que l'AAIF héberge réellement

Au 22 octobre 2026, l'Agentic AI Foundation (AAIF) héberge dix projets : MCP, goose, AGENTS.md, agentgateway, A2A, Agent Router et, annoncés ce jour-là, Agent Skills, Open Responses, OpenEnv et OpenSandbox[38, 130]. L'admission suit un processus formel : proposition publique, triage, recommandation du comité technique, puis approbation du conseil d'administration, suivie des formalités juridiques et de l'intégration technique menées avec la Linux Foundation[42, 263]. Un projet proposé n'est qu'un candidat, et l'hébergement garantit une gouvernance neutre, non la maturité d'une spécification.

**EXIG-INT-20**
**NE DOIT PAS**

**Qualification « AAIF » vérifiée**

Un document d'architecture, un appel d'offres ou un contrat **NE DOIT PAS** qualifier un projet de standard ou de projet de l'AAIF s'il ne figure pas à la liste des projets publiée par la fondation au terme d'une admission approuvée; un projet dont la proposition est ouverte est dit « candidat à l'AAIF ». L'hébergement par l'AAIF ne dispense d'aucun critère d'admission au statut Adopter (EXIG-GOV-19).

Pourquoi : AGNTCY, souvent présenté comme une composante de l'AAIF, n'en est qu'un candidat[37]; l'erreur fausse l'analyse du risque fournisseur.

### AGNTCY

AGNTCY, rendu public par Cisco en mars 2025, est un projet de la Linux Foundation depuis le 29 juillet 2025[23]. Sa proposition à l'AAIF, déposée par Cisco le 12 octobre 2026, fait état de 81 organisations qui l'appuient, indique que Cisco fournit l'essentiel des contributions et restait sans décision au 27 octobre 2026[37]. Le tableau 23 présente ses principaux composants.

**Tableau 23 — Principaux composants d'AGNTCY et statut au catalogue (état au 27 octobre 2026)**

| Composant | Fonction vérifiée | Statut |
|---|---|---|
| OASF *(Open Agentic Schema Framework)* | Modèle de données extensible, inspiré d'OCSF *(Open Cybersecurity Schema Framework)*, qui décrit des agents par des enregistrements annotés de compétences et de domaines; l'Agent Directory Service (ADS) y convertit des définitions de serveurs MCP, des cartes d'agent A2A et des Agent Skills[264, 265] | Évaluer |
| Agent Directory Service (ADS) | Annuaire d'enregistrements OASF stockés comme artefacts OCI *(Open Container Initiative)*, adressés par leur condensé, signés et vérifiables[266, 267] | Évaluer |
| SLIM *(Secure Low-Latency Interactive Messaging)* | Messagerie sur gRPC et HTTP/2, sessions chiffrées de bout en bout par MLS *(Messaging Layer Security)* (RFC 9420)[268, 269] | Surveiller |
| Identity | Identifiants d'agents et de serveurs MCP adossés à des justificatifs vérifiables du W3C (« Agent Badges »)[270] | Surveiller |

Trois précautions s'imposent. Les spécifications d'ADS et de SLIM soumises à l'IETF sont des brouillons individuels[271, 272]. La résistance de SLIM à l'ordinateur quantique, parfois avancée, n'est pas étayée : les suites cryptographiques initiales de MLS sont classiques[269]. Enfin, la liaison SLIMRPC reste expérimentale (EXIG-A2A-08), et la carte d'agent suit le schéma d'A2A, non celui d'OASF.

**EXIG-INT-21** DOIT

**Pilotes AGNTCY subordonnés au catalogue**

Tout pilote d'OASF ou d'ADS **DOIT** traiter le catalogue d'entreprise comme source de vérité : les enregistrements de l'annuaire en sont dérivés, et aucun agent n'y découvre un outil ou un agent absent du catalogue. Une propriété de sécurité alléguée, comme la résistance de SLIM au quantique, **NE DOIT PAS** entrer dans une analyse de risque sans preuve de la configuration effective.

Pourquoi : un annuaire parallèle recréerait deux sources de vérité, et une propriété non démontrée ne protège rien.

## Commerce et paiements agentiques

Trois protocoles se partagent le commerce agentique, sans convergence. L'Agentic Commerce Protocol d'OpenAI et de Stripe (septembre 2025) demeure en bêta[183]; son jeton de paiement partagé est limité à un marchand et au montant d'un panier, et masque les justificatifs de paiement à la plateforme d'IA[27]. AP2 *(Agent Payments Protocol)*, publié par Google en septembre 2025, étend A2A et MCP par des mandats signés qui prouvent l'intention et l'autorisation de l'utilisateur; sa version 0.2 ajoute les paiements en l'absence de l'utilisateur *(Human Not Present)*, et Google en a fait don à la FIDO Alliance le 28 avril 2026[26, 41]. UCP *(Universal Commerce Protocol)*, annoncé en janvier 2026 par Google en collaboration avec des détaillants et des plateformes de commerce, prend en charge REST, MCP et A2A et est compatible avec AP2[184]. Les trois restent au statut Surveiller, mais leurs patrons inspirent déjà la règle qui suit.

**EXIG-INT-22** DOIT

**Paiements initiés par un agent**

Tout paiement, achat ou engagement financier déclenché par un agent, quel que soit le protocole, **DOIT** être classé P3 et n'être exécuté qu'avec une approbation humaine signée, liée à l'action exacte (section 8.5). L'agent **NE DOIT PAS** recevoir ni transmettre de justificatif de paiement; il ne manipule que des jetons émis hors de lui, limités à un bénéficiaire et à un montant. Chaque paiement **DOIT** laisser au journal d'audit une preuve d'intention signée. Le paiement en l'absence de l'utilisateur **NE DOIT PAS** être autorisé tant qu'aucun protocole qui l'encadre n'a le statut Adopter.

Pourquoi : AP2 fonde l'imputabilité d'un paiement sur des mandats signés, l'Agentic Commerce Protocol limite son jeton à un marchand et à un montant; le cadre généralise ces patrons à tout paiement.

## Signaux à suivre

La veille n'est vérifiable que si l'on sait ce que l'on attend : une décision de l'AAIF sur AGNTCY, une révision de MCP, dont la feuille de route du 22 août 2026 ne donne pas la date[195], ou la première version étiquetée des conventions GenAI d'OpenTelemetry[181].

**EXIG-INT-23** DOIT

**Signal de révision inscrit au catalogue**

Chaque entrée du catalogue des protocoles au statut Évaluer ou Surveiller **DOIT** indiquer le signal qui déclenchera le réexamen de son statut et la date de sa dernière vérification. L'apparition du signal **DOIT** entraîner une révision extraordinaire de l'entrée, sans attendre l'échéance trimestrielle.

Pourquoi : l'admission d'un projet à l'AAIF ou la publication d'une RFC ne devrait pas attendre trois mois pour être prise en compte.

**À RETENIR**

Une fondation neutre n'est pas un statut au catalogue, et une annonce n'est pas une norme : un travail émergent n'entre en production que par le statut Adopter.

# 7 Orchestration

L'orchestration décide qui fait quoi, dans quel ordre, avec quel état et quelles garanties en cas d'échec. Ce chapitre fixe la règle de départ, soit la configuration la plus simple qui répond au besoin, puis les huit patrons autorisés et la façon de choisir parmi eux. Il impose enfin les mécanismes qui rendent une orchestration digne de la production : exécution durable, saga et compensation, idempotence, contexte minimal entre agents, résilience et coupe-circuit.

## 7.1 Commencer simple : ce que disent les données probantes

Cette section résume les mesures publiées sur les systèmes multiagents et en tire la règle de départ du cadre : un flux déterministe ou un agent unique bien outillé, sauf preuve mesurée du contraire.

### Des gains réels, sur des tâches précises

Anthropic rapporte que son système de recherche multiagent, formé d'un agent principal Claude Opus 4 et de sous-agents Claude Sonnet 4, a surpassé de 90,2 % un agent unique Claude Opus 4 sur son évaluation interne de recherche. Le gain est le plus marqué pour les requêtes « en largeur », qui poursuivent plusieurs pistes indépendantes à la fois; il s'agit d'une évaluation interne, et non d'un banc d'essai public[17].

L'étude de Google Research « Towards a Science of Scaling Agent Systems » (Kim, Liu et coll.) nuance fortement ce résultat. Selon le billet du 28 janvier 2026 (180 configurations, quatre bancs d'essai, cinq architectures, trois familles de modèles), l'architecture centralisée gagne 80,9 % sur une tâche parallélisable (Finance-Agent), alors que chaque variante multiagent dégrade la performance de 39 à 70 % sur une tâche séquentielle (PlanCraft)[273]. La version 3 de l'article (8 avril 2026; 260 configurations, six bancs d'essai) donne une plage de +80,8 % à −70,0 % et observe que les gains de la coordination diminuent lorsque l'agent unique est déjà performant[274].

### Des coûts et des risques qui croissent avec le nombre d'agents

- **Jetons.** Selon Anthropic, un agent consomme environ 4 fois plus de jetons qu'une conversation, et un système multiagent environ 15 fois plus; sur le banc d'essai BrowseComp, le volume de jetons explique à lui seul 80 % de la variance de performance[17]. Un article d'Anthropic du 23 janvier 2026 situe le surcoût habituel du multiagent entre 3 et 10 fois les jetons d'un agent unique pour une tâche équivalente[275].
- **Erreurs.** Google Research mesure une amplification des erreurs pouvant atteindre 17,2 fois dans des systèmes multiagents indépendants, contre 4,4 fois lorsqu'un orchestrateur central sert de goulot de validation[273].
- **Cohérence.** Cognition soutient qu'il faut partager le contexte complet (les traces de l'agent, pas de simples messages), car chaque action porte des décisions implicites; des sous-agents mal informés prennent des décisions contradictoires. Cette prise de position d'ingénierie recommande par défaut un agent linéaire à fil unique[276]. LangChain réconcilie les deux positions : le multiagent convient mieux aux tâches de lecture, faciles à paralléliser, qu'aux tâches d'écriture, où des écritures concurrentes se contredisent[277].
- **Limites d'emploi.** Anthropic juge que les tâches où tous les agents doivent partager le même contexte, ou qui comportent de nombreuses dépendances, conviennent mal au multiagent, et que le surcoût ne se justifie que si la valeur de la tâche le paie[17].

### Une consigne convergente des éditeurs

Le Centre d'architecture Azure prescrit le niveau de complexité le plus bas qui répond au besoin de façon fiable : appel direct au modèle, puis agent unique doté d'outils, puis orchestration multiagent, seulement si l'agent unique échoue pour cause de complexité d'invite, de surcharge d'outils ou d'exigences de sécurité[9]. Anthropic recommande la solution la plus simple possible[65] et OpenAI, de maximiser d'abord les capacités d'un agent unique[66].

**À RETENIR**

Le multiagent est un outil de spécialiste, pas une architecture par défaut. Il rapporte surtout sur des tâches de lecture parallélisables et à forte valeur; il coûte de 3 à 10 fois plus de jetons et peut dégrader les tâches séquentielles. Le cadre exige donc une preuve mesurée avant d'ajouter des agents (PRIN-08).

**EXIG-ORC-01** — DOIT

**Configuration la plus simple justifiée**

Chaque agent ou système d'agents **DOIT** inscrire à sa fiche (annexe B) pourquoi les options plus simples (code ou règle métier, appel direct au modèle, flux déterministe, agent unique outillé) ne répondent pas au besoin. La revue d'architecture **DOIT** refuser un patron dont la justification manque.

Pourquoi : chaque niveau de complexité ajoute coordination, latence et coût[9].

**EXIG-ORC-02** — DOIT

**Preuve mesurée avant le multiagent**

Une topologie à plusieurs agents **DOIT** être comparée, sur le même jeu d'évaluation (section 10.4), à une base de référence à agent unique : taux de réussite, jetons par exécution, latence et coût par tâche réussie. Elle n'est retenue que si le gain de qualité ou de délai couvre le surcoût mesuré; la comparaison est versée à la fiche de l'agent, avec la grille d'homologation (annexe A).

Pourquoi : les gains publiés dépendent fortement de la tâche et le surcoût en jetons peut atteindre un ordre de grandeur[273, 275].

## 7.2 Patrons autorisés

Le cadre autorise huit patrons, combinables entre eux, et une variante encadrée (voir la figure 11 et le tableau 24). Un patron décrit la topologie de la coordination; il ne fixe pas le niveau d'autonomie, qui se déclare séparément (chapitre 8).

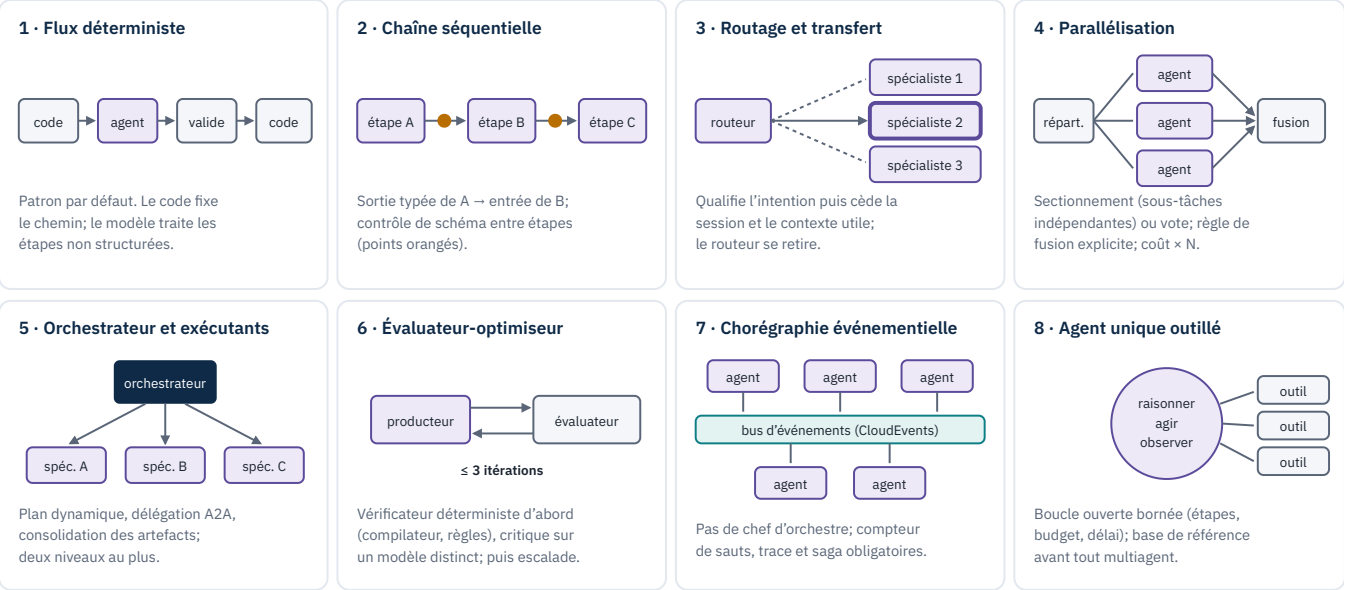



**Figure 11 — Huit patrons d'orchestration autorisés.** Chaque vignette montre la topologie d'un patron et sa règle principale; les points orangés signalent un contrôle de schéma entre étapes. Les patrons se combinent : un flux déterministe peut contenir une étape orchestrée, qui publie à son tour un événement.

Source : cadre CRE-IA-2026-01, d'après Anthropic (2024) et le Centre d'architecture Azure (2026).

Le catalogue s'appuie sur deux références de premier rang. Anthropic distingue les flux de travail, où le modèle et les outils suivent des chemins de code prédéfinis (enchaînement d'invites, routage, parallélisation, orchestrateur-travailleurs, évaluateur-optimiseur), des agents, où le modèle dirige lui-même son processus[65]. Le Centre d'architecture Azure décrit cinq orchestrations : séquentielle, concurrente, clavardage de groupe, transfert et magnétique[9]; la documentation de Microsoft Agent Framework indique que ce dernier patron est conçu à partir de Magentic-One, le système décrit par Fourney et coll.[278, 279]. Le cadre y ajoute la chorégraphie événementielle, absente des deux catalogues, et fait du flux déterministe à étapes agentiques le patron par défaut.

**Tableau 24 — Huit patrons d'orchestration autorisés et variante encadrée**

| Patron | Fonctionnement | Quand l'utiliser | Point de vigilance | Correspondance |
|---|---|---|---|---|
| **1. Flux déterministe** | Un moteur de flux fixe l'ordre et les embranchements; certaines étapes appellent un modèle ou un agent borné pour traiter l'information non structurée. | Processus connus, réglementés ou audités. Patron par défaut. | Rigide quand les cas varient beaucoup; chaque étape agentique a un contrat de sortie validé. | Ajout du cadre; Anthropic : flux de travail. |
| **2. Chaîne séquentielle** | Chaque étape transforme la sortie typée de la précédente. | Tâche décomposable en étapes fixes (extraire, vérifier, rédiger). | Erreurs propagées et latences cumulées : validation de schéma et délai par étape. | Azure : séquentiel. Anthropic : enchaînement d'invites. |
| **3. Routage et transfert** (*handoff*) | Un routeur qualifie l'intention, puis cède la session et le contexte utile à un spécialiste déclaré; il se retire. | Triage, service à la clientèle par domaine, latence prioritaire. | Liste fermée de destinataires; le transfert porte le mandant, pas tout l'historique; aucun transfert en boucle. | Azure : transfert. Anthropic : routage. OpenAI : décentralisé. |

| Patron | Fonctionnement | Quand l'utiliser | Point de vigilance | Correspondance |
|---|---|---|---|---|
| **4. Parallélisation** | Un répartiteur lance des sous-tâches indépendantes (sectionnement) ou la même tâche plusieurs fois (vote), puis fusionne. | Analyse multisource, vérification croisée, garde-fou exécuté en parallèle de la tâche. | Jetons multipliés par le nombre de branches, pointes de charge; règle de fusion explicite. | Azure : concurrent. Anthropic : parallélisation. |
| **5. Orchestrateur et exécutants** | Un agent planifie dynamiquement, délègue à des spécialistes (A2A ou appel interne), puis consolide leurs artefacts. | Tâches ouvertes dont les sous-tâches ne sont pas connues d'avance. | Coût et latence élevés; l'orchestrateur est un point unique de défaillance; deux niveaux au plus. | Azure : magnétique (variante). Anthropic : orchestrateur-travailleurs. OpenAI : gestionnaire. |
| **6. Évaluateur-optimiseur** | Un producteur propose; un évaluateur distinct juge selon des critères explicites et renvoie jusqu'à l'acceptation. | Qualité vérifiable : code, rédaction réglementée, conformité. | Trois itérations au plus, puis escalade; vérificateur qui déclare victoire trop tôt. | Azure : boucle producteur-vérificateur. Anthropic : évaluateur-optimiseur. |
| **7. Chorégraphie événementielle** | Les agents réagissent aux événements d'un bus et publient les leurs, sans chef d'orchestre. | Processus interdomaines faiblement couplés, gros volumes, agents ambiants. | Vue d'ensemble difficile, risque de cycles : trace et compteur de sauts obligatoires; saga dès que des effets touchent plusieurs systèmes d'enregistrement. | Ajout du cadre; saga par chorégraphie chez Microsoft. |
| **8. Agent unique outillé** | Un agent boucle seul « raisonner, agir, observer » avec ses outils, sous plafonds. | Requêtes variées dans un même domaine; base de référence avant tout multiagent. | Surcharge d'outils, contexte qui enfle; conditions d'arrêt obligatoires. | Azure : agent unique doté d'outils. Anthropic : agent. |
| **Variante encadrée : clavardage de groupe et débat** | Plusieurs agents échangent dans un fil commun, sous un gestionnaire qui donne la parole. | Décisions où un contre-examen vaut plus que la latence. | Trois agents au plus, plafond de tours; propagation d'idées entre agents. | Azure : clavardage de groupe. |

Patron et autonomie sont deux dimensions distinctes : un système multiagent peut combiner des agents de niveaux différents[83]. Un orchestrateur plafonné à N3 peut ainsi déléguer à un exécutant plafonné à N1, et chaque action reste soumise à la règle la plus stricte entre le niveau de l'agent qui agit et le palier de l'outil appelé (section 8.4).

## Règles propres à certains patrons

**Orchestrateur et exécutants.** Le cadre limite la délégation à deux niveaux : l'orchestrateur, puis ses exécutants. Ce plafond est un choix du cadre, appuyé indirectement par la mesure d'amplification des erreurs de Google Research. Salesforce impose une contrainte équivalente, dans un produit précis : l'orchestration multiorganisation d'Agentforce n'admet qu'un seul niveau de délégation (agent A vers agent B, jamais A vers B vers C), soit deux agents en chaîne comme dans le cadre[49]. Il s'agit d'une contrainte de produit, et non d'une règle générale.

**Évaluateur-optimiseur.** Microsoft exige un plafond d'itérations, des critères d'acceptation clairs et un comportement de repli défini, comme l'escalade vers un humain[9]; la valeur de trois itérations est un choix du cadre. Anthropic décrit l'écueil de la « victoire prématurée » : un sous-agent vérificateur exécute quelques tests et déclare le succès. Les parades sont des critères concrets, des vérifications exhaustives et des tests négatifs[275].

**Clavardage de groupe et débat.** Microsoft recommande de limiter le clavardage de groupe à trois agents[9]. Une prépublication d'août 2026 (« Mind Viruses », Papadopoulos et coll., Anthropic Fellows Program et EPFL) montre que des idées ou des objectifs peuvent se propager d'agent en agent, dans une petite équipe d'agents de programmation et

dans une chaîne d'agents dont le contexte est effacé entre les sessions. Un bref avertissement dans l'invite système y a conféré une immunité « quasi totale », mais la propagation varie selon le modèle, les consignes initiales et la topologie, et les auteurs jugent le risque réel mais actuellement limité[280]. Le cadre admet cet avertissement comme mesure complémentaire peu coûteuse, jamais comme contrôle suffisant.

**Parallélisation.** Le patron réduit le temps total, au prix de pointes de consommation lorsque plusieurs agents appellent les modèles en même temps, et il exige une logique de résolution des conflits[9]. Anthropic rapporte que la parallélisation des sous-agents et des appels d'outils a réduit jusqu'à 90 % le temps de recherche pour les requêtes complexes[17].

**Chorégraphie événementielle.** Pour une saga, la chorégraphie évite tout point unique de défaillance, mais elle complique le suivi et les tests d'intégration et expose à des dépendances cycliques[67]. Les contrôles d'enveloppe (trace, compteur de sauts, file de lettres mortes) relèvent de la section 6.7.

**EXIG-ORC-03** — DOIT

**Patron déclaré au registre**

Chaque système d'agents **DOIT** déclarer à sa fiche et au registre (section 11.4) le patron retenu parmi ceux du tableau 24, ou leur combinaison, accompagné d'un schéma de ses flux. Toute autre topologie exige une dérogation (section 11.6).

Pourquoi : un patron connu se revoit, se teste et se compare; une topologie improvisée ne se gouverne pas.

**EXIG-ORC-04** — NE DOIT PAS

**Délégation limitée à deux niveaux**

Une chaîne de délégation **NE DOIT PAS** dépasser deux niveaux (orchestrateur, puis exécutant) : un exécutant ne délègue pas à son tour à un autre agent sans dérogation. Le serveur d'autorisation, lors de l'échange de jetons (EXIG-IAM-08, section 9.3), et la passerelle d'agents **DOIVENT** vérifier la profondeur par l'imbrication de la réclamation `act` du jeton délégué et rejeter toute délégation excédentaire.

Pourquoi : choix du cadre; la coordination multiagent alourdit la communication et, sans validation centrale, amplifie les erreurs[273]; l'article mesure en outre un surcoût en jetons et davantage de tours de raisonnement[274].

**EXIG-ORC-05** — DOIT

**Boucle évaluateur-optimiseur bornée**

Une boucle évaluateur-optimiseur **DOIT** déclarer des critères d'acceptation vérifiables, exécuter d'abord les vérifications déterministes disponibles (compilation, tests, moteur de règles), confier l'évaluation à un modèle ou à une invite distincts de ceux du producteur et s'arrêter après trois itérations au plus. Au plafond, la tâche passe en escalade humaine avec la dernière version et les critiques reçues.

Pourquoi : Microsoft exige un plafond, des critères clairs et un repli défini; la valeur de trois est un choix du cadre[9].

**EXIG-ORC-06** — DOIT

**Clavardage de groupe encadré**

Le clavardage de groupe ou le débat entre agents **DOIT** réunir trois agents participants au plus, sous un gestionnaire (hors décompte des trois participants) qui attribue la parole, avec un plafond de tours et une règle de clôture déclarés. Le maillage libre, où chaque agent sollicite les autres sans plafond, **NE DOIT PAS** être utilisé.

Pourquoi : Microsoft recommande de limiter le clavardage de groupe à trois agents[9], et des idées peuvent se propager d'agent en agent[280].

**EXIG-ORC-07** **DOIT**

**Fusion déclarée et écrivain unique en parallèle**

Un patron de parallélisation **DOIT** déclarer avant l'exécution sa règle de fusion (déterministe, vote ou arbitrage) et sa limite de concurrence. Les branches **DOIVENT** se limiter à lire et à produire des artefacts; un seul composant **DOIT** écrire le résultat final dans un système d'enregistrement.

Pourquoi : des écritures concurrentes se contredisent[277].

**EXIG-ORC-08** **DOIT**

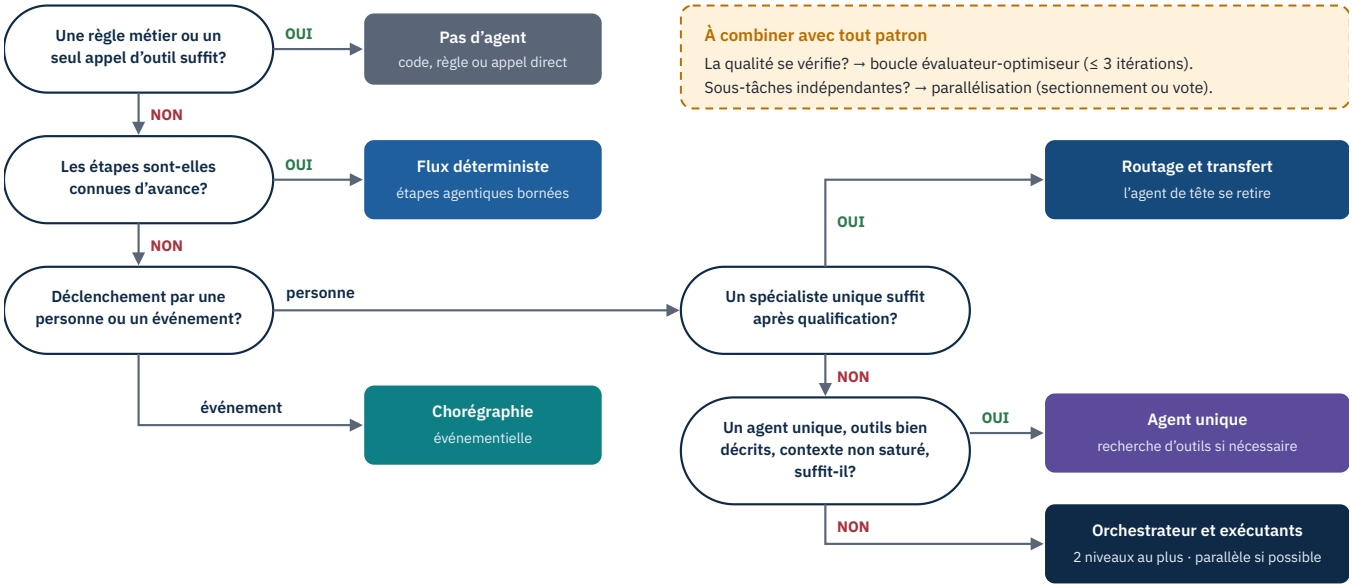
**Chorégraphie sous propriétaire et saga**

Une chorégraphie événementielle qui produit des effets dans plusieurs systèmes d'enregistrement **DOIT** avoir un propriétaire de bout en bout inscrit au registre, une saga explicite (section 7.5) et les contrôles d'enveloppe de la section 6.7.

Pourquoi : sans chef d'orchestre, personne ne voit le processus entier ni ne répond de son issue.

## 7.3 Choisir le patron

Le choix du patron suit l'arbre de décision de la figure 12, qui part toujours de l'option la plus simple. Il se documente à la fiche de l'agent et se révise lorsque les mesures de production contredisent l'hypothèse de départ.




Par défaut, retenir l'option la plus simple qui répond au besoin; passer au multiagent seulement sur preuve mesurée de gain.

**Figure 12 — Arbre de décision du patron d'orchestration.** Les questions se lisent de haut en bas; la première réponse qui conclut fixe le patron. Les encadrés du bas s'ajoutent à n'importe quel patron lorsque la qualité se vérifie ou que des sous-tâches sont indépendantes.

Source : cadre CRE-IA-2026-01, d'après le Centre d'architecture Azure (niveaux de complexité) et Anthropic.

### Quand le multiagent se justifie

Anthropic retient trois cas où plusieurs agents surpassent un agent unique : la **protection du contexte** (une sous-tâche produit une exploration volumineuse qui polluerait le contexte principal), la **parallélisation** (des pistes réellement indépendantes) et la **spécialisation** (des outils ou des consignes incompatibles dans un même agent)[275]. Microsoft ajoute les frontières de sécurité distinctes : deux domaines qui ne doivent pas partager les mêmes droits justifient deux agents[9]. L'effort doit aussi suivre la complexité : Anthropic emploie un agent et de 3 à 10 appels d'outils pour une recherche factuelle simple, de 2 à 4 sous-agents pour une comparaison, et davantage pour une recherche complexe[17].

### Surcharge d'outils : mesurer avant de scinder

Aucune source ne fixe de seuil unique. OpenAI suggère, à titre indicatif, de viser moins de 20 fonctions disponibles au début d'un tour[115] et souligne que le chevauchement compte plus que le nombre : certaines mises en œuvre gèrent avec succès plus de 15 outils distincts, d'autres peinent avec moins de 10 outils qui se chevauchent[66]. La documentation d'Anthropic situe la dégradation au-delà de 30 à 50 outils disponibles[281]. Avant de multiplier les agents, deux leviers moins coûteux existent : consolider les outils en opérations orientées tâche, regroupées sous des espaces de noms[114], et charger les définitions d'outils à la demande. Selon Anthropic, sa recherche d'outils réduit de 85 % la consommation de jetons de contexte dans son exemple chiffré et fait passer la précision, sur ses évaluations internes de MCP, de 49 à 74 % (Opus 4) et de 79,5 à 88,1 % (Opus 4.5); ce sont des résultats déclarés par le fournisseur[205].

### Découper par frontières de contexte

Quand plusieurs agents sont retenus, on découpe selon les frontières de contexte, et non selon le type de travail : une fonctionnalité et ses tests restent avec le même agent[275]. Par exemple, dans l'analyse d'un dossier de crédit, l'agent qui lit les états financiers calcule aussi les ratios qui en découlent; un agent distinct ne se justifie que pour un contexte isolable, comme la vérification des sanctions internationales, qui obéit à d'autres droits d'accès.

**Tableau 25 — Critères comparés des principaux patrons**

| Critère | Flux déterministe | Agent unique | Routage et transfert | Orchestrateur et exécutants | Évaluateur-optimiseur | Chorégraphie |
|---|---|---|---|---|---|---|
| Prévisibilité et auditabilité | Très élevée | Moyenne | Élevée | Moyenne | Élevée sur le résultat | Moyenne, émergente |
| Latence de bout en bout | Faible à moyenne | Variable selon les tours | Faible | Élevée; réduite si parallèle | Moyenne à élevée | Asynchrone |
| Profil de coût en jetons (repère) | Le plus bas | Environ 4 fois une conversation | Cumul étape par étape | 3 à 10 fois l'agent unique; pointes si parallèle | Croît avec les itérations | Croît avec les abonnés et les sauts |
| Tolérance à l'ambiguïté | Faible | Élevée dans un domaine | Moyenne | Très élevée | Moyenne | Moyenne |
| Ce qui borne la dérive | Le code | Plafonds et budget | Liste fermée de destinataires | Deux niveaux, budget, délais | Trois itérations | Compteur de sauts, lettres mortes |

Les appréciations qualitatives du tableau 25 sont des repères du cadre. Les seuls ordres de grandeur retenus par le cadre sont ceux d'Anthropic (environ 4 fois et 15 fois une conversation; de 3 à 10 fois l'agent unique)[17, 275] et les profils de Microsoft : coûts cumulés étape par étape pour les patrons séquentiel et de transfert, pointes pour le patron concurrent, coût le moins prévisible pour le patron magnétique[9]. Ces repères cèdent la place aux mesures de jetons par agent et par exécution dès qu'elles existent (section 10.6).

**EXIG-ORC-09**
**DOIT**

**Surcharge d'outils traitée avant de scinder**

Dès qu'un agent dépasse 15 outils (seuil opérationnel retenu par le cadre dans la plage de 15 à 20 outils), ou dès que des outils se chevauchent, l'équipe **DOIT** mesurer la précision de sélection d'outils sur le jeu d'évaluation, puis essayer la consolidation des outils et leur chargement à la demande avant de scinder l'agent en plusieurs agents.

Pourquoi : le chevauchement compte plus que le nombre[66], et la recherche d'outils restaure une partie de la précision à moindre coût[205].

**EXIG-ORC-10** DEVRAIT

**Découpage par frontières de contexte**

Lorsqu'un système multiagent est retenu, le découpage **DEVRAIT** suivre les frontières de contexte et de sécurité plutôt que les types de travail : le même agent garde une unité de travail et sa vérification immédiate. Un agent distinct se justifie par un contexte isolable, un parallélisme réel, une spécialisation d'outils ou une frontière de sécurité, consignés à la fiche.

Pourquoi : un transfert qui ne passe que des messages, sans la trace complète, fait perdre des décisions implicites[275, 276].

## 7.4 État et exécution durable

Un agent attend une approbation pendant trois jours; un serveur redémarre au milieu d'une réservation. Dans les deux cas, l'orchestration doit reprendre exactement où elle s'était arrêtée, sans perdre le contexte et sans refaire une action déjà faite. C'est le rôle de l'exécution durable.

### Persister l'état hors du processus

Microsoft recommande de persister l'état partagé hors de la mémoire et d'utiliser les points de contrôle du cadriciel[9]. Les moteurs y parviennent de façons différentes. Temporal garantit qu'une exécution de flux se poursuit jusqu'à son terme, sans limite de durée imposée, et la reprend après une panne en rejouant son historique d'événements[81]. LangGraph conserve l'état par fil (`thread_id`) au moyen de *checkpointers* : `InMemorySaver` perd ses points de contrôle au redémarrage et sert à l'expérimentation, tandis qu'un magasin persistant comme `PostgresSaver` s'impose en production[124, 282]. Microsoft Agent Framework crée un point de contrôle à la fin de chaque étape de calcul du flux, avec l'état des exécuteurs, les messages et les requêtes en attente[105].

### Ne jamais refaire une action terminée : une garantie à construire

La persistance ne suffit pas à éviter les doubles effets. Dans LangGraph, à la reprise après une interruption, le nœud interrompu redémarre depuis son début et le code qui précède l'interruption s'exécute de nouveau[82]; Temporal réessaie les activités en échec[79]. La garantie repose donc sur deux règles de conception : isoler chaque appel non déterministe (modèle, outil, agent distant) dans une étape journalisée dont le résultat se relit à la reprise, et rendre idempotent tout effet qui peut être rejoué (section 7.6). L'intégration de Temporal avec l'OpenAI Agents SDK applique la première règle : chaque invocation d'agent s'y exécute comme une activité, suivie et réessayée par le moteur[122].

Aux points d'approbation obligatoires, l'état est persisté afin de reprendre sans rejouer le travail des agents précédents[9]. La primitive `interrupt()` de LangGraph, par exemple, suspend le graphe et attend sans limite une reprise sur le même fil[82]. La forme de l'approbation elle-même relève de la section 8.5.

### Points de contrôle, versions et rejeu

Un point de contrôle contient l'état complet d'une tâche, souvent avec des renseignements personnels (RP) et des extraits d'invites. Microsoft le désigne comme une frontière de confiance : on ne charge jamais un point de contrôle venant d'une source non fiable, et ses magasins Python n'acceptent qu'une liste blanche de types à la désérialisation[105]. Les exécutions longues posent aussi un problème de version : Anthropic déploie ses agents en mode « arc-en-ciel » pour ne pas interrompre ceux qui s'exécutent déjà[17]. Enfin, le « voyage dans le temps » de LangGraph permet de rejouer depuis un point de contrôle antérieur ou de bifurquer après correction de l'état; les nœuds suivants s'exécutent alors de nouveau et les appels aux modèles ou aux API peuvent produire d'autres résultats[283]. Le rejeu sert à l'analyse et à la correction; il ne reproduit pas une décision à l'identique.

**EXIG-ORC-11** DOIT

**Persistance après chaque transition**

Tout flux de plus d'une étape, ou susceptible d'attendre une approbation, **DOIT** s'exécuter sur un moteur d'exécution durable qui persiste l'état après chaque transition (appel de modèle, appel d'outil, décision, réponse humaine) dans un magasin externe au processus. Un magasin en mémoire **NE DOIT PAS** être utilisé hors du poste de développement.

Pourquoi : un redémarrage ou un déploiement ne doit faire perdre ni le contexte ni l'avancement[9, 124].

**EXIG-ORC-12** DOIT

**Reprise sans double effet**

La logique de coordination **DOIT** rester déterministe; chaque appel non déterministe **DOIT** s'exécuter comme une étape journalisée dont le résultat est relu, et non recalculé, à la reprise. Tout effet de bord placé avant un point de pause ou dans une étape réessayable **DOIT** être idempotent; sinon, il **DOIT** être déplacé après le point de pause.

Pourquoi : les moteurs réexécutent le nœud interrompu ou réessaient l'activité en échec[79, 82].

**EXIG-ORC-13** DOIT

**Magasin de points de contrôle protégé**

Le magasin des points de contrôle **DOIT** être traité comme une frontière de confiance et comme une donnée de production : accès limité à l'identité de l'orchestrateur, chiffrement au repos, contrôle d'intégrité au chargement, conservation et élagage définis. Un orchestrateur **NE DOIT PAS** charger de point de contrôle d'origine non vérifiée.

Pourquoi : un point de contrôle contient l'état complet de la tâche, y compris les messages en attente; un point de contrôle altéré permet donc d'en modifier l'état, et ces messages peuvent contenir des RP (constat du cadre, non tiré de la source)[105].

**EXIG-ORC-14** DEVRAIT

**Déploiement sans interruption des exécutions longues**

Le déploiement d'une nouvelle version d'agent ou de flux **DEVRAIT** laisser chaque exécution en cours se terminer sur la version avec laquelle elle a commencé; une migration d'état en cours d'exécution **DEVRAIT** se tester comme un changement de schéma.

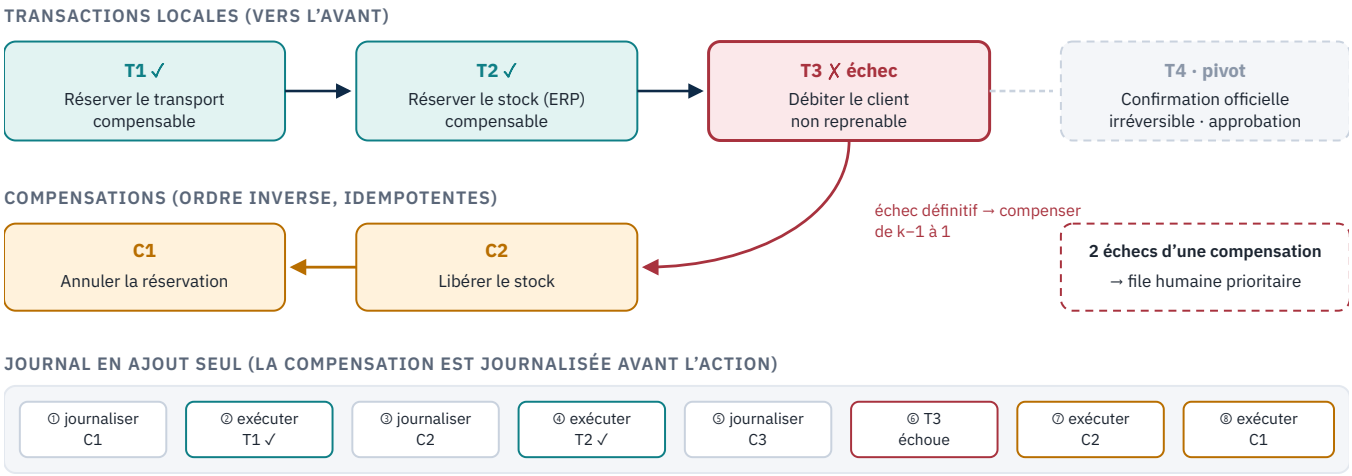
Pourquoi : un déploiement peut casser les agents déjà en cours d'exécution, et recommencer du début coûte cher[17].

## 7.5 Transactions : patron saga

Lorsqu'une tâche écrit dans plusieurs systèmes qui ne partagent aucune transaction (un système de transport, un progiciel de gestion intégré, une passerelle de paiement), aucun retour arrière global n'existe. La saga remplace la transaction globale par une suite de transactions locales, chacune appariée à une compensation (voir la figure 13).

### Principe

Garcia-Molina et Salem ont défini la saga en 1987 : une transaction de longue durée découpée en transactions plus courtes, avec la garantie que soit toutes s'exécutent, soit des transactions compensatoires défont l'exécution partielle[284, 285]. Microsoft distingue trois sortes d'étapes : les transactions **compensables**, qui précèdent le point de non-retour; la transaction **pivot**, qui est ce point de non-retour; et les transactions **réessayables**, idempotentes, qui la suivent jusqu'au terme[67]. Une saga se conçoit donc pour que tout ce qui est irréversible arrive le plus tard possible (PRIN-05).




T3 n'a jamais été marquée « terminée » : C3 n'est exécutée que si son effet est incertain. Le pivot T4 n'est atteint qu'après succès de T1 à T3.

**Figure 13 — Saga : transactions locales, pivot et compensations.** T1 et T2 réussissent; T3 échoue de façon définitive : l'orchestrateur exécute C2 puis C1, et le pivot T4, irréversible et soumis à approbation, n'est jamais atteint. Le journal montre que chaque compensation est consignée avant l'action qu'elle couvre.

Source : cadre CRE-IA-2026-01, d'après Garcia-Molina et Salem (1987), Microsoft et Temporal.

## Cinq règles de conception

1. **Journaliser la compensation avant l'action.** Temporal recommande d'inscrire la compensation avant d'exécuter l'activité, parce qu'un effet de bord peut survenir avant que l'échec ne soit signalé : une carte débitée, par exemple[286]. Microsoft exige de consigner chaque étape et la façon de la défaire dans un magasin durable, afin de reprendre la compensation au point d'échec[77].
2. **Traiter l'incertain comme exécuté.** Si l'orchestrateur ignore l'issue d'une étape (délai expiré, plantage entre le journal et la réponse), il la considère comme possiblement exécutée. Sa compensation doit alors pouvoir s'exécuter sans risque même si l'action n'a jamais eu lieu : « rembourser la transaction X si elle a été débitée », et non « rembourser le montant X ».
3. **Compenser en termes métier.** Une compensation applique des règles d'affaires : l'annulation d'un vol n'entraîne pas forcément un remboursement complet. Elle ne ramène pas nécessairement les données à leur état initial, ne suit pas toujours l'ordre inverse exact et peut parfois s'exécuter en parallèle[77]. On ne « désenvoie » pas un courriel : on envoie un rectificatif.
4. **Réessayer avant de compenser.** On ne compense que si la progression devient impossible, c'est-à-dire après épuisement des réessais ou devant une erreur non transitoire[77].
5. **Escalader l'échec persistant.** Si une compensation échoue, Temporal recommande de consigner l'erreur, de poursuivre les autres compensations, puis d'alerter; une erreur non réessayable dans une compensation signifie que la saga ne peut plus revenir entièrement en arrière[286]. Microsoft prévoit la file de lettres mortes et la suspension des cas ambigus ou à fort impact pour revue humaine[77]. Le seuil de deux échecs retenu ci-dessous est un choix du cadre.

## Isolation entre sagas concurrentes

Une saga n'isole pas ses étapes comme une transaction ACID (atomicité, cohérence, isolation, durabilité). Microsoft recense trois anomalies : mises à jour perdues, lectures sales et lectures non répétables. Les contre-mesures sont le verrou sémantique, les mises à jour commutatives, la vue pessimiste (réordonner les étapes pour que les mises à jour aient lieu dans des transactions réessayables), la relecture des valeurs avant mise à jour, les fichiers de versions et le

choix du mécanisme de concurrence selon le risque métier. La saga convient mal aux transactions fortement couplées et aux dépendances cycliques[67]. Exemple : deux agents qui réservent le même stock posent d'abord un verrou sémantique « réservation en attente », visible des autres sagas, plutôt que de décrémenter directement la quantité.

Pour les agents, SagaLLM (Chang et Geng, PVLDB, 2025) combine le patron saga, une mémoire persistante, des compensations automatisées et des agents de validation indépendants, en assouplissant les garanties ACID au profit d'une cohérence à l'échelle du flux[287, 288]. C'est une référence de recherche utile, et non une norme d'industrie.

**EXIG-ORC-15** — DOIT

**Saga pour toute écriture multisystème**

Une tâche qui écrit dans au moins deux systèmes d'enregistrement sans transaction commune **DOIT** être modélisée comme une saga : chaque étape d'écriture P2 référence la compensation déclarée dans son entrée de catalogue (section 6.8), le pivot est identifié, et toute étape de palier P3 (action critique, externe ou irréversible) se place au pivot ou après, une fois les validations critiques réussies et l'approbation humaine obtenue (section 8.5).

Pourquoi : reporter l'irréversible après toutes les validations limite ce qu'il faut défaire[77].

**EXIG-ORC-16** — DOIT

**Journal de compensation tenu avant l'action**

Avant chaque étape, l'orchestrateur **DOIT** consigner dans un journal durable, en ajout seul et corrélé à la trace, l'étape, ses arguments, sa clé d'idempotence et la compensation à exécuter. Une étape dont l'issue est inconnue est traitée comme possiblement exécutée : sa compensation est déclenchée et reste sans effet si l'action n'a pas eu lieu.

Pourquoi : un effet peut survenir avant que l'échec ne soit signalé[286].

**EXIG-ORC-17** — DOIT

**Compensations idempotentes et métier, après réessais**

Chaque compensation **DOIT** être idempotente et définie en termes métier (remboursement, avis rectificatif, libération de stock) avec le propriétaire du système visé. L'orchestrateur réessaie d'abord l'étape en échec selon sa politique de réessai et ne compense que si la progression devient impossible.

Pourquoi : une compensation peut s'exécuter plusieurs fois et ne restaure pas forcément l'état initial[77, 286].

**EXIG-ORC-18** — DOIT

**Escalade après deux échecs d'une compensation**

Lorsqu'une même compensation échoue deux fois de suite (erreur non transitoire ou politique de réessai épuisée), l'orchestrateur **DOIT** cesser de la relancer, poursuivre les compensations qui n'en dépendent pas, puis placer l'état complet de la saga dans une file humaine prioritaire nommée, avec alerte et identifiants de corrélation.

Pourquoi : l'échec persistant exige une intervention manuelle[286] ; le seuil de deux échecs est un choix du cadre.

**EXIG-ORC-19** — DOIT

**Isolation sémantique des sagas concurrentes**

Lorsque plusieurs sagas ou agents peuvent modifier les mêmes enregistrements, la conception **DOIT** documenter les anomalies possibles (mises à jour perdues, lectures sales, lectures non répétables) et appliquer au moins une contre-mesure à chacune.

Pourquoi : la saga n'offre pas l'isolation d'une transaction ACID[67].

**EXIG-ORC-20**
**DOIT**

**Quatre tests d'injection de fautes**

Avant la mise en production, toute saga **DOIT** réussir quatre tests automatisés, exécutés contre des doublures des systèmes d'enregistrement : échec forcé de chaque étape $T_k$ avec vérification des compensations; plantage entre l'écriture au journal et l'action; double exécution de chaque compensation; double échec d'une compensation avec vérification de l'escalade.

Pourquoi : exigence propre au cadre; les chemins de compensation ne servent presque jamais en exploitation normale et doivent être éprouvés avant d'être nécessaires.

## 7.6 Idempotence

Une opération est idempotente si l'exécuter deux fois produit le même effet que l'exécuter une fois. Sans cette propriété, un simple réessai après un délai expiré peut débiter un client deux fois.

Les doublons ne sont pas une hypothèse d'école : ils découlent des garanties mêmes des composants. Kafka livre « au moins une fois » par défaut, et sa sémantique « exactement une fois » ne couvre que le cycle lecture-traitement-écriture entre sujets Kafka[140, 256]. Pour les notifications push A2A, le protocole exige au moins une tentative de livraison (reprises facultatives, doublons possibles)[68], et les flux Express asynchrones d'AWS Step Functions s'exécutent selon la même garantie (les flux Express synchrones, « au plus une fois »), ce qui exige des actions idempotentes pour les premiers[104]. Les règles propres au bus d'événements figurent à la section 6.7.

Le cadre dérive la clé de l'identifiant de la tâche et de celui de l'étape. Le brouillon IETF `draft-ietf-httpapi-idempotency-key-header-08` (22 octobre 2026), qui n'est pas encore une RFC, décrit l'en-tête `Idempotency-Key` : le client renvoie la même clé à chaque réessai; le serveur répond 409 si la requête d'origine est encore en cours et 422 si la clé est réutilisée avec une charge utile différente. Le brouillon recommande un UUID (identifiant unique universel) ou un identifiant aléatoire semblable et met en garde contre les clés à faible entropie; la dérivation déterministe retenue par le cadre est un choix qui lui est propre, acceptable pourvu que la clé reste unique par opération et que le service la valide avant tout traitement[78]. Quant aux annotations d'outil de MCP (`idempotentHint`, `destructiveHint`), ce sont de simples indices, sur lesquels un client ne fonde aucune décision lorsque le serveur n'est pas digne de confiance[197, 201].

**Dérivation de la clé d'idempotence (illustration)**

```
task_id         = "tache-7f3c2a"                    (attribué par l'orchestrateur)
step_id         = "etape-02/reserver-stock"
cle             = hex( SHA-256( task_id + "|" + step_id ) )

réessai de la même étape              → même clé, aucun effet supplémentaire
même clé, arguments différents        → rejet (422 selon le brouillon IETF)
étape replanifiée avec d'autres valeurs → nouveau step_id, donc nouvelle clé
```

**EXIG-ORC-21**
**DOIT**

**Clé d'idempotence sur toute écriture**

Chaque appel d'outil en écriture (P2 ou P3) **DOIT** porter une clé d'idempotence dérivée de l'identifiant de la tâche et de celui de l'étape, réutilisée telle quelle à chaque réessai. Une étape replanifiée avec d'autres arguments reçoit un nouvel identifiant d'étape, donc une nouvelle clé. La clé voyage dans l'en-tête `Idempotency-Key` lorsque le service le prend en charge, sinon dans un champ déclaré du contrat d'outil.

Pourquoi : réessais, reprises et livraisons « au moins une fois » rejouent des appels[68, 140].

**EXIG-ORC-22**
**DOIT**

**Vérification de la clé par le service visé**

Tout outil P2 ou P3 inscrit au catalogue **DOIT** vérifier la clé côté serveur, directement ou par son adaptateur : un doublon ne produit aucun effet supplémentaire; une clé réutilisée avec des arguments différents est rejetée; une requête dont l'original est encore en cours est refusée sans exécution. Ce comportement est déclaré dans l'entrée de catalogue; les annotations MCP n'en tiennent pas lieu[197].

Pourquoi : seul le système visé sait si l'effet a déjà eu lieu[78].

## 7.7 Contexte transmis entre agents

Ce qu'un agent transmet à un autre détermine à la fois la qualité du résultat, le coût et l'exposition des données. Le cadre impose un contexte minimal et structuré, avec une nuance importante pour les tâches fortement couplées.

Microsoft demande de décider quel contexte l'agent suivant requiert (contexte complet, version compactée ou nouvelle consigne seulement), de compacter entre agents et de limiter l'état persisté au strict nécessaire, pour des raisons de coût et de confidentialité[9]. Anthropic fait rendre par ses sous-agents une synthèse condensée, souvent de 1 000 à 2 000 jetons, et stocke leurs livrables hors du contexte pour les transmettre par références légères[17, 149]. La mise en garde de Cognition reste valable : un exécutant privé des décisions qui le concernent en prendra de contradictoires[276]. Le contexte minimal convient donc surtout aux tâches de lecture; une tâche à fortes dépendances reste à un seul agent (section 7.3). Cognition a depuis nuancé sa position (Yan, 22 avril 2026) : des agents supplémentaires peuvent apporter du jugement tant que les écritures restent à fil unique; ses observations d'origine tiennent toujours pour les essaims d'écrivains parallèles[289]. La gestion du contexte et de la mémoire de chaque agent relève de la section 5.5.

**Contenu logique d'une délégation (indépendant du protocole)**

```
{
  "sous_objectif": "Évaluer la solvabilité du client 4471 selon la politique CR-12",
  "criteres_acceptation": ["ratios calculés", "pièces citées", "aucune donnée hors dossier"],
  "parametres": { "client_id": "4471", "montant_demande": 250000 },
  "artefacts": ["artefact://dossiers/4471/etats-financiers-2025.pdf"],
  "jeton_delegue": "<jeton délégué du mandant, audience = agent-credit>",
  "traceparent": "00-<trace-id>-<span-id>-01",
  "budget_restant": { "jetons": 40000, "cout_max_cad": 2.00, "appels_outils": 10, "echeance": "PT10M" },
  "schema_retour": "schema://credit/avis-solvabilite/1.2"
}
```

Ce message ne contient ni l'historique de la conversation ni les données que l'exécutant peut lire lui-même avec les droits du mandant. Sa traduction en messages A2A relève de la section 6.6.

La sécurité suit le même chemin. Microsoft exige que chaque agent applique un filtrage de sécurité, pour ne jamais renvoyer une donnée inaccessible à l'utilisateur, et que des garde-fous de contenu s'appliquent à plusieurs points : entrée de l'utilisateur, appels d'outils, réponses d'outils et sortie finale, car un agent intermédiaire peut introduire ou propager du contenu nuisible[9].

**EXIG-ORC-23**
**DOIT**

**Contexte de délégation minimal et structuré**

Une délégation **DOIT** transmettre un message structuré limité au sous-objectif, aux critères d'acceptation, aux paramètres requis, aux références d'artefacts, au jeton délégué du mandant (section 9.3), au contexte de trace (section 10.1), au budget restant et au schéma de retour attendu. L'historique brut complet **NE DOIT PAS** être transmis, sauf exception justifiée à la fiche.

Pourquoi : un contexte minimal réduit le coût et l'exposition des données[9].

**EXIG-ORC-24**
**DOIT**

**Retour validé avant toute réutilisation**

Un exécutant **DOIT** rendre une synthèse conforme au schéma de retour déclaré et déposer ses livrables volumineux dans un magasin d'artefacts, transmis par référence. L'orchestrateur **DOIT** valider la sortie (schéma, plafonds, garde-fous) avant de l'utiliser ou de la transmettre; une sortie invalide **DOIT** déclencher un réessai, une demande de précision ou l'arrêt.

Pourquoi : une sortie non validée propage l'erreur d'agent en agent[9].

**EXIG-ORC-25**
**DOIT**

**Filtrage de sécurité dans chaque agent**

Chaque agent **DOIT** filtrer ses résultats selon les droits du mandant, de sorte qu'aucune donnée inaccessible à ce mandant ne remonte à l'orchestrateur ni à l'utilisateur. Les garde-fous de contenu s'appliquent à l'entrée, aux appels d'outils, aux réponses d'outils et à la sortie finale; le contenu reçu d'un autre agent est traité comme une donnée non fiable (section 9.6).

Pourquoi : un agent intermédiaire peut introduire ou propager du contenu nuisible[9].

## 7.8 Résilience et dégradation maîtrisée

Un modèle indisponible, un outil lent ou un agent qui tourne en rond ne doivent ni bloquer le processus ni produire un résultat faux en silence. Cette section met en œuvre le principe de dégradation maîtrisée (PRIN-12).

Microsoft prescrit pour les orchestrations d'agents des délais d'expiration et des réessais, une dégradation maîtrisée, la remontée des erreurs plutôt que leur masquage, la validation de la sortie d'un agent avant sa transmission, l'examen de disjoncteurs, l'isolement des agents sans point unique de défaillance partagé et des points de contrôle pour reprendre après une panne ou un déploiement[9]. Anthropic note qu'il est courant d'inclure des conditions d'arrêt, comme un nombre maximal d'itérations, pour garder le contrôle d'un agent[65]. Les plafonds de l'exécution s'inscrivent dans l'enveloppe budgétaire de la tâche (section 10.6); le modèle de repli s'obtient par la passerelle de modèles (chapitre 5).

Le dernier recours est l'arrêt. Pour les systèmes à haut risque, le règlement européen sur l'IA prévoit la possibilité d'interrompre le système de façon sûre (art. 14(4)e))[290]; le NIST AI RMF, cadre d'usage volontaire, demande (MANAGE 2.4) des mécanismes et des responsabilités pour remplacer, désengager ou désactiver un système dont les résultats s'écartent de l'usage prévu[99]. OpenAI recommande une interruption ordonnée, soit ciblée (révoquer une catégorie d'actions), soit générale[291]. La propagation de l'arrêt à travers les passerelles et les jetons relève de la section 9.4.

**EXIG-ORC-26**
**DOIT**

**Plafonds sur toute exécution**

Chaque exécution **DOIT** porter des plafonds déclarés à la fiche : étapes ou itérations, appels d'outils, jetons, coût et durée totale. L'atteinte d'un plafond **DOIT** arrêter la boucle en état sûr et déclencher l'escalade prévue; elle **NE DOIT PAS** être rapportée comme un succès.

Pourquoi : l'autonomie d'un agent entraîne des coûts plus élevés et un risque d'erreurs cumulatives, d'où des conditions d'arrêt pour garder le contrôle[65].

**EXIG-ORC-27**
**DOIT**

**Mécanismes de résilience et repli testé**

Chaque dépendance d'une orchestration (modèle, outil, agent distant) **DOIT** être protégée par un délai d'expiration, des réessais à temporisation exponentielle *(exponential backoff)* limités aux erreurs transitoires et un disjoncteur. Les erreurs sont remontées et journalisées, jamais masquées. Le repli prévu (modèle de repli homologué, service dégradé ou file humaine nommée recevant le contexte complet) est testé avant la production.

Pourquoi : Microsoft prescrit délais d'expiration et réessais et recommande d'envisager des disjoncteurs; la temporisation exponentielle et la limitation aux erreurs transitoires sont des choix du cadre[9].

**EXIG-ORC-28** **DOIT**

**Coupe-circuit exercé chaque trimestre**

Chaque agent **DOIT** pouvoir être arrêté de façon ciblée (retrait d'un outil ou d'une capacité) ou totale. La plateforme **DOIT** en outre disposer d'un coupe-circuit global. L'arrêt bloque toute nouvelle étape, conserve l'état pour analyse et laisse les sagas en cours dans un état connu, suspendues ou compensées selon la procédure. Un exercice d'arrêt **DOIT** avoir lieu au moins une fois par trimestre et son délai mesuré **DOIT** être consigné.

Pourquoi : le RIA prévoit l'interruption sûre des systèmes à haut risque (art. 14(4)e)) et le NIST AI RMF, d'usage volontaire, demande des mécanismes pour désactiver un système (MANAGE 2.4), le cadre l'appliquant à tous les agents[99, 290]; la fréquence trimestrielle est un choix du cadre.

## 7.9 Anti-patrons proscrits

La taxonomie MAST *(Multi-Agent System Failure Taxonomy)* (Cemri et coll., UC Berkeley), tirée de plus de 1 600 traces annotées issues de sept cadriciels, recense 14 modes de défaillance des systèmes multiagents en trois catégories : conception du système, désalignement entre agents et vérification des tâches. Elle conclut que les défaillances relèvent surtout de la conception, et non des seules limites des modèles[292]. La revue d'architecture cible donc les défauts de conception ci-dessous; le classement des incidents selon MAST relève de la section 10.4.

**Tableau 26 — Anti-patrons d'orchestration proscrits**

| Anti-patron | Pourquoi il est proscrit | Correctif exigé |
|---|---|---|
| Coordination multiagent là où un agent ou un flux suffit | Coût, latence et erreurs accrus sans gain mesuré[9] | EXIG-ORC-01 et EXIG-ORC-02 |
| Agents sans spécialisation réelle, découpés par type de travail | Les transferts perdent des décisions implicites[275] | Découpage par frontières de contexte (EXIG-ORC-10) |
| Confier au modèle un contrôle de flux que le code sait garantir, ou figer en code un flux réellement ouvert | Patron inadapté à la nature du flux[9] | Arbre de décision de la section 7.3 (PRIN-08) |
| État mutable partagé entre agents concurrents | Écritures contradictoires et résultats non reproductibles | Écrivain unique (EXIG-ORC-07); état d'exécution dans un magasin externe (EXIG-ORC-11) |
| Latence multisaut et contraintes de ressources ignorées | Délais cumulés et pointes de charge en mode concurrent | Délais par étape (EXIG-ORC-27), limite de concurrence (EXIG-ORC-07), plafonds (EXIG-ORC-26) |
| Contexte qui enfle sans contrôle, historique brut versé au contexte | Le rappel se dégrade quand l'information pertinente est noyée[148] | Compaction et références (EXIG-ORC-23, section 5.5) |
| État d'exécution en mémoire du processus | Perte de l'état au redémarrage[124] | Magasin durable (EXIG-ORC-11) |
| Maillage libre sans plafond de tours | Boucles, dérive, coûts imprévisibles | Patron déclaré et plafonds (EXIG-ORC-06, EXIG-ORC-26) |
| Chaîne d'écritures sans compensation ni clé d'idempotence | Effets partiels ou doublés impossibles à défaire | Saga et idempotence (section 7.5 et section 7.6) |
| Vérificateur qui déclare le succès sur quelques tests | Victoire prématurée[275] | Critères concrets, tests négatifs, suite complète (EXIG-ORC-05) |

**EXIG-ORC-29**
**NE DOIT PAS**

**Aucun anti-patron sans dérogation**

Une conception **NE DOIT PAS** présenter l'un des anti-patrons du tableau 26. La revue d'architecture **DOIT** les vérifier un à un et consigner le résultat à la fiche de l'agent, avec la décision d'homologation; tout écart exige une dérogation (section 11.6).

Pourquoi : une part importante des défaillances des systèmes multiagents tient à la conception du système et à la coordination entre agents[292].

## 7.10 Cadriciels et plateformes d'orchestration

Cette section situe les principaux produits par rapport aux exigences du chapitre. Seule l'exigence EXIG-ORC-30 y est normative; le tableau 27 ne l'est pas : les produits cités sont des exemples non limitatifs, décrits selon leur état au 27 octobre 2026, et le catalogue d'entreprise les réévalue chaque trimestre. On distingue trois familles : les cadriciels, qui portent la logique propre à l'entreprise; les moteurs d'exécution durable, qui en garantissent la reprise; et les plateformes SaaS, à privilégier lorsque le travail réside déjà dans leur système d'enregistrement.

**Tableau 27 — Cadriciels, moteurs et plateformes d'orchestration (exemples non limitatifs, état au 27 octobre 2026)**

| Produit | Nature et modèle d'orchestration | Atouts au regard du cadre | Points d'attention |
|---|---|---|---|
| **LangGraph** (LangChain) | Cadriciel d'exécution à base de graphe, avec persistance intégrée de l'état; version 1.0 du 22 octobre 2025, sans changement incompatible promis jusqu'à la 2.0 (persistance par fil : documentation « Persistence » de LangGraph)[123, 124] | Points de contrôle, `interrupt()` pour l'approbation, voyage dans le temps[82, 283] | Nœud réexécuté à la reprise; magasin persistant exigé en production[82, 124] |
| **Microsoft Agent Framework** | Cadriciel sous licence MIT, successeur de Semantic Kernel et d'AutoGen; versions 1.0.0 pour Python et .NET le 2 avril 2026[85, 293] | Orchestrations séquentielle, concurrente, clavardage de groupe, transfert et magnétique; traces OpenTelemetry GenAI[294, 295] | Magasin de points de contrôle à protéger comme frontière de confiance[105] |
| **CrewAI** | Cadriciel combinant des Flows (état, événements, embranchements) et des Crews (équipes d'agents à rôles)[296] | Démarche recommandée par l'éditeur : partir d'un Flow et y insérer une Crew pour une étape collaborative, ce qui rejoint le flux déterministe du cadre | Persistance et reprise à démontrer en preuve de concept (EXIG-ORC-30) |
| **OpenAI Agents SDK** | Trousse à peu de primitives : agents, transferts ou agents utilisés comme outils, garde-fous, sessions, traçage; outils MCP natifs[127] | Intégration Temporal en disponibilité générale depuis le 23 mars 2026 : chaque invocation d'agent devient une activité[122] | Associer un moteur durable dès que le flux compte plusieurs étapes (EXIG-ORC-11) |
| **Google ADK** | Cadriciel ouvert en Python, TypeScript, Go, Java et Kotlin, indépendant du modèle et du lieu de déploiement; A2A et MCP[126] | Agents de flux `SequentialAgent`, `ParallelAgent` et `LoopAgent`, sans décision du modèle sur l'orchestration[297] | ADK 2.0 supplante ces gabarits, en Python et en Go, par des flux à base de graphes ou dynamiques, sans annoncer leur retrait : prévoir la migration[297] |
| **Strands Agents** (AWS) | Trousse sous licence Apache 2.0, publiée le 16 mai 2025, pilotée par le modèle[128] | MCP, télémétrie OpenTelemetry, patrons multiagents (agents comme outils, essaim, graphe, flux, A2A) | Réserver aux tâches ouvertes à autonomie bornée; moteur durable dès que le flux compte plusieurs étapes (EXIG-ORC-11) |

| Produit | Nature et modèle d'orchestration | Atouts au regard du cadre | Points d'attention |
|---|---|---|---|
| **Temporal** | Moteur d'exécution durable; reprise à partir du dernier événement consigné dans l'historique d'événements (rejeu)[80, 81] | Compensations exécutées même après la défaillance d'un travailleur[286] | Isoler appels de modèles et d'outils dans des activités (EXIG-ORC-12) |
| **AWS Step Functions** | Service géré de machines à états | Flux Standard d'une durée maximale d'un an, à sémantique d'exécution exactement une fois, sauf réessais déclarés[104] | Flux Express (5 minutes; au moins une fois en mode asynchrone, au plus une fois en mode synchrone) : actions idempotentes obligatoires en mode asynchrone |
| **Microsoft Copilot Studio** | Plateforme à faible code; orchestration multiagent annoncée en préversion le 19 mai 2025 (Microsoft Build), dont plusieurs capacités passent en disponibilité générale à compter d'avril 2026[298, 299] | MCP en disponibilité générale depuis le 29 mai 2025, A2A depuis avril 2026[48, 300] | Identité Entra Agent ID créée pour chaque nouvel agent depuis juillet 2026 : l'inscrire au registre d'entreprise[48] |
| **Salesforce Agentforce** | Plateforme SaaS; orchestration SOMA *(Single-Org, Multi-Agent)* (une organisation Salesforce) et MOMA *(Multi-Org, Multi-Agent)* (plusieurs organisations)[49] | A2A entrant et sortant; client MCP et serveur MCP hébergé | Contraintes de produit : un seul niveau de délégation en MOMA; sept sous-agents connectés pour Agent Script, limite que l'éditeur qualifie d'actuelle |
| **ServiceNow** | Plateforme SaaS; AI Agent Fabric (annoncé le 6 mai 2025), couche d'échange par MCP et A2A; AI Control Tower en disponibilité générale le même jour[51] | Action Fabric expose les actions de la plateforme à tout agent d'IA par un serveur MCP, pour des actions sécurisées et gouvernées (annonce du 5 mai 2026)[50] | Extensions de l'AI Control Tower (coupe-circuit, mesure des coûts) annoncées pour août 2026 : vérifier selon la version déployée[47] |

**EXIG-ORC-30**
**DOIT**

**Capacités démontrées avant l'inscription d'un produit**

Un cadriciel, un moteur ou une plateforme d'orchestration **DOIT**, avant son inscription au catalogue, démontrer en preuve de concept, dans les conditions de l'entreprise : la persistance durable des points de contrôle et la reprise après panne; la pause pour approbation humaine sans perte d'état; l'émission de traces OpenTelemetry selon les conventions GenAI; la prise en charge de MCP et d'A2A, nativement ou par adaptateur; l'export des définitions de flux et de l'état dans un format documenté.

Pourquoi : l'entreprise garde la propriété de sa logique d'orchestration (PRIN-09), et une capacité se vérifie au lieu de se présumer sur la foi d'une fiche commerciale (chapitre 13).

# 8 Autonomie et supervision humaine

L'autonomie d'un agent n'est pas une propriété du modèle : c'est une décision d'architecture, prise par une personne imputable, inscrite au registre et appliquée par la passerelle d'agents. Ce chapitre fixe une échelle unique de niveaux (N0 à N4), quatre paliers de risque pour les outils (P0 à P3) et la règle qui les combine. Il précise ensuite comment rendre l'approbation humaine vérifiable, comment interagir avec les agents qui travaillent en arrière-plan, comment éviter l'approbation machinale et comment traiter les décisions automatisées visées par la Loi 25.

## 8.1 Une échelle unique N0 à N4

Le cadre adopte une seule échelle d'autonomie (figure 14 et tableau 28), que chaque agent déclare et que la plateforme fait respecter.

Deux constats la fondent. D'abord, l'autonomie est un choix de conception : Feng, McDonald et Zhang (2025) la distinguent de la capacité du modèle et de son environnement, et la définissent par le rôle laissé à l'utilisateur[83]. Ensuite, une gouvernance uniforme échoue : selon Gartner (26 mai 2026), la cause profonde des échecs est une gouvernance binaire, qui verrouille tout ou permet tout, et la confusion entre la capacité d'agir d'un agent et la portée des accès qui lui sont accordés; la firme prévoit que, d'ici 2027, 40 % des entreprises rétrograderont ou désactiveront des agents autonomes après des incidents de production révélant des lacunes de gouvernance[95].

Chaque niveau se définit donc par deux éléments observables : le rôle de la personne et l'étendue de ce que l'agent peut faire sans approbation. Le niveau ne dépend ni du nombre d'agents ni de la puissance du modèle : un système multiagent peut réunir des agents de niveaux différents, et, selon le cadre de gouvernance de l'IA agentique de l'Infocomm Media Development Authority (IMDA) de Singapour, l'espace d'action d'un agent, c'est-à-dire ses outils, se distingue de son autonomie[76, 83].




**Figure 14 — Échelle d'autonomie N0 à N4.** Chaque marche indique ce que fait l'agent, ce que fait la personne, les paliers d'outils permis et les contrôles minimaux; plus l'autonomie croît, plus les contrôles compensatoires s'accumulent. Le niveau NX, hors de l'échelle, est interdit.
Source : CRE-IA-2026-01, d'après Gartner (2026), AWS, Feng et al. (2025) et l'IMDA.

**Tableau 28 — Niveaux d'autonomie : rôles, paliers permis et contrôles minimaux**

| Niveau | Ce que fait l'agent | Rôle humain et boucle | Paliers permis | Contrôles minimaux (cumulatifs) | Exemple |
|---|---|---|---|---|---|
| **N0** Automatisation déterministe | Aucun modèle : flux codé, règles, RPA, API. | Conçoit les règles et exploite le flux. | Sans objet | Tests logiciels, revue de code, gestion des changements. | Rapprochement bancaire quotidien codé en règles. |
| **N1** Consultatif | Lit, analyse, recommande, rédige; aucun effet en écriture. | La personne exécute elle-même toute action (rôle d'opérateur); l'agent ne fait que recommander. | P0, P1 | Accès aux données circonscrit, authentification, journalisation de l'usage, essais de sécurité de base, essais d'exactitude et d'hallucination, formation des utilisateurs à une confiance appropriée. | Résumé d'un dossier et texte de réponse affiché à l'écran, que le conseiller copie, relit et envoie lui-même. |
| **N2** Exécution approuvée | Planifie et prépare; chaque action en écriture attend une approbation explicite. | Approuve chaque écriture avant son exécution : humain dans la boucle (HITL). | P0, P1; P2 et P3 après approbation signée (P3 : hors bande) | Essais de sécurité poussés, état de la tâche conservé à chaque point d'approbation, jeton d'approbation, journal d'audit, procédure d'intervention propre aux agents. | Modifications de fiches fournisseurs préparées par l'agent, chacune approuvée avant l'écriture. |

| Niveau | Ce que fait l'agent | Rôle humain et boucle | Paliers permis | Contrôles minimaux (cumulatifs) | Exemple |
|---|---|---|---|---|---|
| **N3** Autonomie bornée et supervisée | Exécute seul les actions P2 réversibles ou compensables sous seuils déclarés, dans un domaine de conception opérationnel (ODD) documenté; escalade les exceptions. | Supervise par exception, traite les escalades, peut interrompre; revue a posteriori par échantillonnage : humain sur la boucle (HOTL). | P0, P1; P2 sous seuils; P3 après approbation hors bande | Surveillance continue, seuils et budgets appliqués par la passerelle, compensation déclarée, disjoncteurs, retour arrière rapide, propriété claire du comportement de l'agent. | Agent de soutien TI qui classe, fusionne et ferme les billets en double sous un plafond horaire, et escalade le reste. |
| **N4** Autonomie étendue sous ODD certifié | S'autodéclenche sur des événements et opère en continu. | Hors de la boucle d'exécution, mais sur la boucle de gouvernance : politiques, audit, coupe-circuit. | Comme N3; P3 toujours approuvé | ODD certifié, évaluation continue, arrêts ciblé et général testés, réautorisation périodique, décision du comité. | Agent de qualité des données qui, sur alerte, met en quarantaine les lots suspects jour et nuit. |
| **NX** Autonomie non bornée | Fixe ses objectifs, modifie ses permissions, écrit et exécute du code hors contraintes. | Aucun contrôle humain effectif. | — | Interdit | — |

Les contrôles des niveaux N1 à N3 s'inspirent de ceux que Gartner associe à ses niveaux Observer, Conseiller, Agir avec approbation et Agir de façon autonome (Gartner précise que ceux du niveau Conseiller incluent tous ceux du niveau Observer; le cumul aux niveaux suivants est le choix du cadre); Gartner prévient d'ailleurs que les approbations peuvent s'affaiblir sous la pression du temps ou la fatigue d'approbation[95]. Les contrôles de N0 et de N4 sont fixés par le cadre. Le sigle ODD (domaine de conception opérationnel, *operational design domain*) est un concept de la conduite automatisée des véhicules routiers[301]; le cadre l'emploie pour désigner le périmètre documenté (systèmes, données, outils, seuils, plages horaires) hors duquel l'agent s'arrête ou escalade.

L'échelle n'est pas un parcours de maturité dont N4 serait le but. Morris et al. rappellent que le niveau d'autonomie retenu au déploiement n'a pas à être le maximum que permettent les capacités du modèle[302], et l'OWASP formule le principe de moindre agence (*Least-Agency*) : un comportement agentique déployé sans nécessité élargit la surface d'attaque sans ajouter de valeur[28]. Le bon niveau est le plus bas qui atteint l'objectif.

**EXIG-AUT-01**
**DOIT**

**Niveau d'autonomie déclaré et appliqué**

Chaque agent **DOIT** avoir un niveau d'autonomie N0 à N4 (tableau 28) inscrit au registre (section 11.4) comme plafond, avec la date d'homologation et le nom de la personne qui l'a approuvé. Le niveau déclaré **DOIT** être le plus bas qui permet d'atteindre l'objectif métier, avec sa justification consignée dans la fiche d'agent. La passerelle d'agents **DOIT** refuser tout appel d'outil qui excède ce plafond.

Pourquoi : le principe de moindre agence de l'OWASP proscrit l'autonomie inutile[28]; Feng et al. proposent un « certificat d'autonomie » qui fixe le niveau maximal d'un agent et accompagne ses métadonnées[83].

**EXIG-AUT-02**
**DOIT**

**Plafond selon la classe de risque**

Le niveau déclaré **DOIT** être évalué selon les critères du tableau 30 et respecter le plafond que fixe EXIG-CON-02 pour la classe de risque de l'agent (section 12.1, tableau 46).

Pourquoi : le RIA exige des mesures de contrôle humain proportionnées aux risques, au niveau d'autonomie et au contexte d'utilisation (art. 14, par. 3)[290]; les plafonds eux-mêmes sont un choix du cadre.

**EXIG-AUT-03**
**NE DOIT PAS**

**Autonomie non bornée interdite (NX)**

Un agent **NE DOIT PAS** fixer d'autres objectifs que ceux qui lui sont assignés au registre, modifier ses propres permissions ou son niveau d'autonomie, ni écrire et exécuter du code hors des contraintes déclarées. Toute modification des objectifs, des outils ou du niveau d'un agent **DOIT** passer par le registre et être approuvée par une personne habilitée, la décision étant consignée au registre. Aucune dérogation n'est possible.

Pourquoi : choix normatif du cadre, et non exigence réglementaire. Mitchell et al. soutiennent que le risque pour les personnes croît avec l'autonomie et que les agents entièrement autonomes ne devraient pas être développés[303]; l'OWASP recommande une double vérification avant qu'un agent ne modifie ses objectifs[87].

**EXIG-AUT-04**
**DOIT**

**Domaine de conception opérationnel (ODD), repli et arrêts pour N3 et N4**

Un agent de niveau N3 ou N4 **DOIT** avoir un ODD documenté (systèmes, données, outils, seuils, volumes, plages horaires) et un comportement de repli déclaré pour toute sortie de ce domaine : arrêt en état sûr, compensation ou escalade vers une file humaine nommée. Il **DOIT** aussi avoir des plafonds d'itérations, de durée et de coût, ainsi que deux arrêts : un arrêt ciblé, qui révoque une catégorie d'actions, et un arrêt général (section 7.8 et section 9.4).

Pourquoi : SAE J3016 distingue ses niveaux 3 et 4 par la partie qui assure le repli hors du domaine[304]; le RIA prévoit l'arrêt du système dans un état sûr (art. 14, par. 4, al. e)[290] et OpenAI recommande une interruption ciblée ou générale[291].

Pour homologuer un niveau, le cadre recommande l'« évaluation assistée » de Feng et al. : un utilisateur en attente aide l'agent sur demande et consigne chaque intervention; on augmente graduellement son implication, d'abord par des approbations, puis par des échanges plus fréquents. Le niveau se déduit de l'implication minimale qui permet d'atteindre le seuil de réussite fixé[83].

**EXIG-AUT-05**
**DOIT**

**Homologation et réévaluation du niveau**

Le niveau d'autonomie **DOIT** être homologué avant la mise en production, puis réévalué à chaque changement de modèle ou de version de modèle, d'invite système (hors correction purement typographique attestée sans effet sur le jeu d'évaluation), d'outil en écriture, de population visée ou d'ODD. Tant que la réévaluation n'est pas faite, l'agent **DOIT** fonctionner au niveau immédiatement inférieur à son niveau déclaré; un agent de niveau N1 est suspendu ou ramené à un flux déterministe sans autonomie (N0).

Pourquoi : Feng et al. prévoient le renouvellement du certificat d'autonomie à chaque changement de l'agent ou de son environnement[83]; pour les institutions financières fédérales, la ligne directrice E-23 du BSIF (en vigueur le 1er mai 2027) attend des institutions qu'elles définissent des critères de modification importante d'un modèle, y compris d'IA[8].

### Correspondance avec les autres échelles

Le tableau suivant situe N0 à N4 par rapport aux échelles des ébauches antérieures et à celles de la littérature. Les correspondances avec Gartner, AWS et Feng et al. reposent sur les sources citées sous le tableau; celles avec Morris et al. et SAE J3016 sont indicatives, car ces échelles mesurent autre chose que le rôle de la personne.

**Tableau 29 — Correspondance entre l'échelle du cadre et les autres échelles d'autonomie**

| Cadre | Ébauches antérieures | Gartner (2026) | AWS (portées) | Feng et al. (rôle de l'utilisateur) | Morris et al. (indicatif) | SAE J3016 (analogie) |
|---|---|---|---|---|---|---|
| **N0** | doc. L0 · prod. L0 | — | — | — | 0 Sans IA | — |
| **N1** | doc. L1 · v0.x N0 · prod. L1 | 1 Observer; 2 Conseiller | Portée 1 | L1 Opérateur | 1 IA outil; 2 IA consultante | — |
| **N2** | doc. L2 · v0.x N1 · prod. L2 | 3 Agir avec approbation | Portée 2 | L2 Collaborateur | 3 IA collaboratrice | — |
| **N3** | doc. L3 · v0.x N2 et N3 · prod. L3 | 4 Agir de façon autonome | Portée 3 | L3 Consultant; L4 Approbateur | 4 IA experte | Niveau 3 : l'humain reprend la main |
| **N4** | doc. L4 · v0.x N4 · prod. L4, sans la notion multiagent | — | Portée 4, sous restrictions | L5 Observateur, sous restrictions | 5 IA agent (le cadre y distingue N4, bornée, et NX, non bornée; cette distinction ne vient pas de Morris et al.) | Niveau 4 : repli assuré dans l'ODD |
| **NX** | doc. L5 | — | — | — | 5 IA agent (non bornée; distinction propre au cadre) | Niveau 5 : domaine illimité |

Abréviations : « doc. » désigne l'ébauche documentaire (L0 à L5), « v0.x » les ébauches v0.1 et v0.2 (N0 à N4) et « prod. » l'ébauche dite de production (L0 à L4). Les niveaux de même numéro ne se correspondent pas d'une ébauche à l'autre; seule l'échelle du présent chapitre fait foi. Les sources des colonnes suivantes sont Gartner[95], la matrice de portée d'AWS, qui associe la portée 2 à une approbation avant chaque action et la portée 3 à une supervision avec interrupteurs d'arrêt[75], Feng et al.[83] et Morris et al.[302]. Les correspondances avec Gartner et AWS suivent la vérification des sources; celles avec Feng et al., Morris et al. et SAE J3016 sont indicatives, car ces échelles décrivent le rôle de l'utilisateur ou un autre objet que le plafond d'actions sans approbation. Les libellés L1 à L5 sont ceux de Feng et al.

SAE J3016 est une pratique recommandée (*Recommended Practice*) de SAE International, et non une norme de sécurité; sa révision en vigueur est J3016_202609. Le cadre ne lui emprunte que deux notions, par analogie : le domaine de conception opérationnel et la question du repli, qui sépare son niveau 3, où l'humain doit reprendre la main, de son niveau 4, où le système assure lui-même le repli dans son domaine; seul son niveau 5 suppose un domaine illimité[301, 304]. Enfin, l'« agent entièrement autonome » de Mitchell et al., qui écrit et exécute son propre code, correspond à NX[303].

## 8.2 Classer un agent : critères

La classe de risque de l'agent (section 12.1) fixe son plafond; quatre critères déterminent ensuite le niveau réellement autorisé sous ce plafond.

Le cadre retient ces quatre critères comme méthode interne. Ils s'appuient sur des sources reconnues sans en être la transcription. L'IMDA désigne la portée des actions de l'agent, leur réversibilité et son niveau d'autonomie comme déterminants du risque, et recommande de borner le rayon d'action dès la conception[76]. OpenAI recommande de noter chaque outil selon qu'il lit ou écrit, sa réversibilité, les permissions requises et son impact financier[66]. Le NIST AI RMF demande que les processus de supervision humaine soient définis, évalués et documentés (MAP 3.5)[99].

**Tableau 30 — Quatre critères pour fixer le niveau d'autonomie sous le plafond de la classe**

| Critère | Question posée | Ce qu'on examine | Effet sur le niveau |
|---|---|---|---|
| **Rayon d'impact** | Combien d'enregistrements, de systèmes, de personnes ou de dollars l'agent peut-il toucher en une exécution ininterrompue? | Outils d'écriture autorisés, portées des jetons, plafonds de volume et de montant. | Un rayon large abaisse le niveau ou impose des seuils plus bas. |
| **Réversibilité** | L'effet peut-il être annulé, compensé, ou est-il définitif? | Compensation déclarée au catalogue, délai de compensation, effets externes. | Une action irréversible relève du palier P3 : approbation préalable, quel que soit le niveau. |
| **Délai de détection et de récupération** | Combien de temps s'écoule entre une erreur, sa détection et sa correction? | Alertes automatiques, revue par échantillonnage, délai de compensation. | Une détection lente impose un contrôle avant l'action (N2) plutôt qu'après. |
| **Observabilité reconstructive** | Peut-on reconstituer ce que l'agent a fait, avec quelles données et sous quelle autorisation? | Traces d'appels d'outils, journal d'audit signé (section 10.3), versions épinglées. | Sans traces d'appels d'outils, ni N3 ni N4. |

Le quatrième critère tient au fait que le raisonnement affiché par un modèle n'explique pas forcément ses actions : l'IMDA rappelle que la chaîne de pensée n'est pas analogue au raisonnement humain[76]. Seules les traces des appels d'outils prouvent ce qui a été fait.

Les seuils qui traduisent ces critères en plafonds (nombre d'enregistrements, montants, délais) sont des paramètres d'étalonnage du cadre : le comité d'architecture et des risques agentiques les approuve, les publie avec le catalogue et les révise après chaque incident. Aucune source reconnue ne propose de valeurs universelles. Le niveau autorisé est le plus bas de trois valeurs : le plafond de la classe, le niveau que permettent les quatre critères et le niveau suffisant pour l'objectif.

**EXIG-AUT-06**
**DOIT**

**Classement fondé sur les permissions effectives**

L'évaluation des quatre critères **DOIT** se fonder sur les permissions effectives de l'agent (outils autorisés, portées des jetons, plafonds de volume et de montant), et non sur l'intention déclarée. Elle **DOIT** être consignée dans la fiche d'agent (annexe B) et revue par l'architecture d'entreprise et par la sécurité avant l'homologation du niveau.

Pourquoi : Gartner situe la cause de nombreux échecs dans la confusion entre la capacité d'agir et la portée des accès accordés[305]; l'IMDA recommande de borner le rayon d'action par les accès aux outils et aux systèmes[76].

**EXIG-AUT-07**
**NE DOIT PAS**

**Règle d'or : pas d'exécution autonome du risque cumulé**

Un agent dont le rayon d'impact, la réversibilité et le délai de détection atteignent les seuils d'étalonnage approuvés par le comité (rayon élevé, réversibilité faible, détection lente) **NE DOIT PAS** être autorisé au-delà de N2, quels que soient ses résultats aux bancs d'essai.

Pourquoi : règle propre au cadre. L'IMDA lie le risque à la portée et à la réversibilité des actions[76], et Feng et al. rappellent que les bancs d'essai de capacité ne révèlent pas le niveau d'autonomie approprié[83].

EXEMPLE

Un agent de facturation peut modifier 10 000 comptes par exécution (rayon large). Ses écritures changent des montants facturés, difficiles à corriger une fois les factures transmises (réversibilité faible), et une erreur ne serait vue qu'à la fermeture mensuelle (détection lente). Malgré d'excellents résultats aux essais, il reste à N2. Pour viser N3, l'équipe agit sur les critères, pas sur les essais : plafond par exécution, détection automatisée des écarts, retenue des factures avant transmission.

## 8.3 Paliers de risque des outils P0 à P3

Le palier mesure le risque d'un outil, indépendamment de l'agent qui l'appelle; il forme le second axe de la supervision.

Un même agent peut lire sans risque et écrire avec risque. Parasuraman, Sheridan et Wickens ont proposé d'automatiser séparément chaque fonction (acquérir l'information, l'analyser, décider, agir), chacune à un niveau propre, un même système pouvant combiner des niveaux différents[306]. L'autonomie se règle donc aussi par action, et pas seulement par agent.

**Tableau 31 — Paliers de risque des outils**

| Palier | Nature | Exemples | Contrôles obligatoires |
|---|---|---|---|
| **P0** | Lecture publique | Recherche documentaire publique, catalogue de produits, conversion d'unités. | Identité de charge de travail, limitation de débit, journalisation de l'usage. |
| **P1** | Lecture interne ou sensible | Dossier client, fiche de paie, recherche documentaire interne. | Jeton délégué (section 9.3), contrôle d'accès au document ou à la ligne, masquage des RP en sortie, journal d'audit. |
| **P2** | Écriture réversible ou compensable, impact modéré | Billet de service, brouillon de courriel, réservation interne, mise à jour de statut. | Jeton délégué, clé d'idempotence (section 7.6), compensation déclarée (section 7.5), seuil métier au catalogue (p. ex. 5 000 $); approbation au-delà du seuil. |
| **P3** | Action critique, externe ou irréversible | Virement, suppression définitive de données, communication externe officielle, changement d'infrastructure de production. | Approbation humaine hors bande à chaque appel, jeton d'approbation lié à l'action, second approbateur pour la classe élevée; jamais exécuté seul par un agent. |

La frontière entre paliers suit l'effet, pas le serveur. Créer un brouillon de courriel est une action P2, car il reste dans l'entreprise et peut être supprimé; l'envoyer à un client est une action P3. Un même serveur MCP expose souvent les deux : chaque outil reçoit son propre palier.

Le palier ne peut pas venir du serveur lui-même. La spécification MCP 2026-07-28 exige que les clients considèrent les annotations d'outils comme non fiables, à moins qu'elles ne proviennent de serveurs de confiance; la référence du schéma précise, en des termes non normatifs (« should never »), que les clients ne fondent jamais une décision d'usage sur les annotations d'un serveur non fiable[197, 201]. Les métadonnées de gouvernance vivent donc au catalogue d'entreprise (section 6.8; pour les annotations MCP, section 6.5).

**EXIG-AUT-08**
**DOIT**

**Palier attribué au catalogue après revue**

Chaque outil **DOIT** recevoir un palier P0 à P3 (tableau 31) au catalogue d'entreprise (section 6.8) après revue par son propriétaire et par la sécurité, avec son seuil métier et son outil de compensation s'il y a lieu. Le palier provient du catalogue, jamais des annotations ou des métadonnées déclarées par le serveur. Un outil qui combine plusieurs effets prend le palier le plus élevé; un outil d'écriture sans compensation déclarée est classé P3.

Pourquoi : la spécification MCP tient les annotations pour des indices non fiables[197]; OpenAI recommande d'attribuer à chaque outil une cote de risque[66].

**EXIG-AUT-09**
**NE DOIT PAS**

**Aucun outil P3 exécuté seul**

Un agent **NE DOIT PAS** exécuter un outil P3 sans une approbation humaine préalable, propre à cet appel, quel que soit son niveau d'autonomie.

Pourquoi : l'IMDA recommande une approbation humaine avant les actions à fort enjeu ou irréversibles, comme la suppression définitive, l'envoi de communications ou les paiements; OpenAI présente l'autorisation préalable des actions irréversibles comme le moyen usuel de limiter les défaillances graves; l'OWASP range l'absence de confirmation des actions sensibles parmi les vulnérabilités (ASI09)[28, 76, 291].

## 8.4 Combiner classe de l'agent et palier de l'outil

Le contrôle exigé pour un appel dépend de la classe de l'agent, de son niveau d'autonomie et du palier de l'outil; la règle la plus stricte l'emporte.

CLASSE DE L'AGENT ↓ · PALIER DE L'OUTIL →

| | P0 · lecture publique<br>catalogue, documentation | P1 · lecture interne<br>dossier client, paie | P2 · écriture réversible<br>billet, brouillon, statut | P3 · action critique<br>virement, suppression, envoi |
|---|---|---|---|---|
| **Faible**<br>plafond N3<br>(N4 sur décision) | Automatique<br>identité de charge, débit | Automatique<br>jeton délégué, masquage | Autonome sous seuil<br>idempotence, compensation | Approbation signée<br>à chaque appel |
| **Modéré**<br>plafond N3 | Automatique<br>identité de charge, débit | Automatique + audit<br>jeton délégué, filtrage par ligne | Approbation au-delà<br>du seuil métier déclaré | Approbation signée<br>à chaque appel |
| **Élevé**<br>plafond N2 | Automatique + audit<br>journalisation complète | Audit + revue<br>finalité vérifiée, minimisation | Approbation signée<br>à chaque action (N2) | Approbation signée<br>+ second approbateur |

La règle la plus stricte l'emporte. Le palier d'un outil est inscrit au catalogue; la passerelle ne se fie pas aux annotations déclarées par le serveur.

**Figure 15 — Contrôle exigé selon la classe de l'agent et le palier de l'outil.** On lit la ligne de la classe de l'agent, puis la colonne du palier de l'outil; la cellule donne le contrôle minimal. Le niveau d'autonomie de l'agent et les déclencheurs d'approbation peuvent le rendre plus strict, jamais plus souple.

Source : CRE-IA-2026-01.

Deux exemples. Un agent de classe modérée, déclaré N3, reclasse un billet de service : outil P2 sous le seuil, il agit seul et l'appel est journalisé. Le même agent veut modifier l'échéance de 40 factures alors que le seuil déclaré de l'outil est de 25 par tâche : la passerelle suspend l'appel et demande une approbation. Si l'agent était déclaré N2, chaque écriture exigerait une approbation, même sous le seuil : le niveau prime alors sur la cellule.

D'autres déclencheurs s'ajoutent à la grille. L'IMDA en énumère quatre catégories : actions à fort enjeu, actions irréversibles, comportements atypiques (accès hors périmètre, trajectoire anormale) et seuils fixés par l'utilisateur[76]. La « règle de deux » de Meta (31 octobre 2025) en fournit une autre : dans une session, un agent ne devrait pas cumuler

l'exposition à des entrées non fiables, l'accès à des données sensibles et la capacité de changer d'état ou de communiquer vers l'extérieur; si les trois sont nécessaires, il n'agit pas sans supervision[307]. Un agent N3 qui a lu un courriel externe, consulté un dossier P1 et s'apprête à appeler un outil P2 tombe donc sous approbation (section 9.6).

**EXIG-AUT-10** **DOIT**

**Contrôle calculé à chaque appel**

Pour chaque appel d'outil, la passerelle d'agents **DOIT** déterminer le contrôle exigé en retenant le plus strict des éléments suivants : la cellule classe × palier de la figure 15, le niveau d'autonomie de l'agent et les déclencheurs d'approbation (comportement atypique, dépassement de seuil, cumul de contenu non fiable, de données sensibles et d'action externe). Elle consigne la règle appliquée dans la trace et dans le journal d'audit (section 10.3).

Pourquoi : retenir le plus strict des éléments empêche qu'un agent peu autonome obtienne des droits étendus par un outil mal classé, ou qu'un outil bien classé soit utilisé au-delà du niveau de l'agent. Règle propre au cadre; l'IMDA lie le risque à la portée et à la réversibilité des actions[76].

**EXIG-AUT-11** **DOIT**

**Échec en mode fermé**

Si le service d'approbation, le catalogue ou le service de politiques est indisponible, ou si aucune politique ne couvre l'action demandée, la passerelle **DOIT** refuser tout appel P3 et tout appel P2 au-delà du seuil, sans préjudice du refus général de tout appel dépourvu de décision de politique valide (EXIG-IAM-18). Dans tous ces cas, l'orchestrateur **DOIT** suspendre la tâche dans un état reprenable.

Pourquoi : l'IMDA recommande de refuser l'action par défaut lorsque l'infrastructure d'approbation fait défaut, par exemple si les superviseurs sont injoignables ou si aucune politique n'existe pour l'action tentée[76].

## 8.5 Approbation humaine vérifiable

Une approbation n'a de valeur que si elle porte sur l'action exacte qui sera exécutée et si la passerelle peut le vérifier sans faire confiance à l'agent.

Un « oui, je confirme » écrit dans la conversation de l'agent ne prouve rien : une injection d'instructions peut l'imiter, et l'agent peut modifier l'action après coup. Le cadre fait donc de l'approbation un objet cryptographique, émis hors de portée de l'agent et lié à l'action par une empreinte.

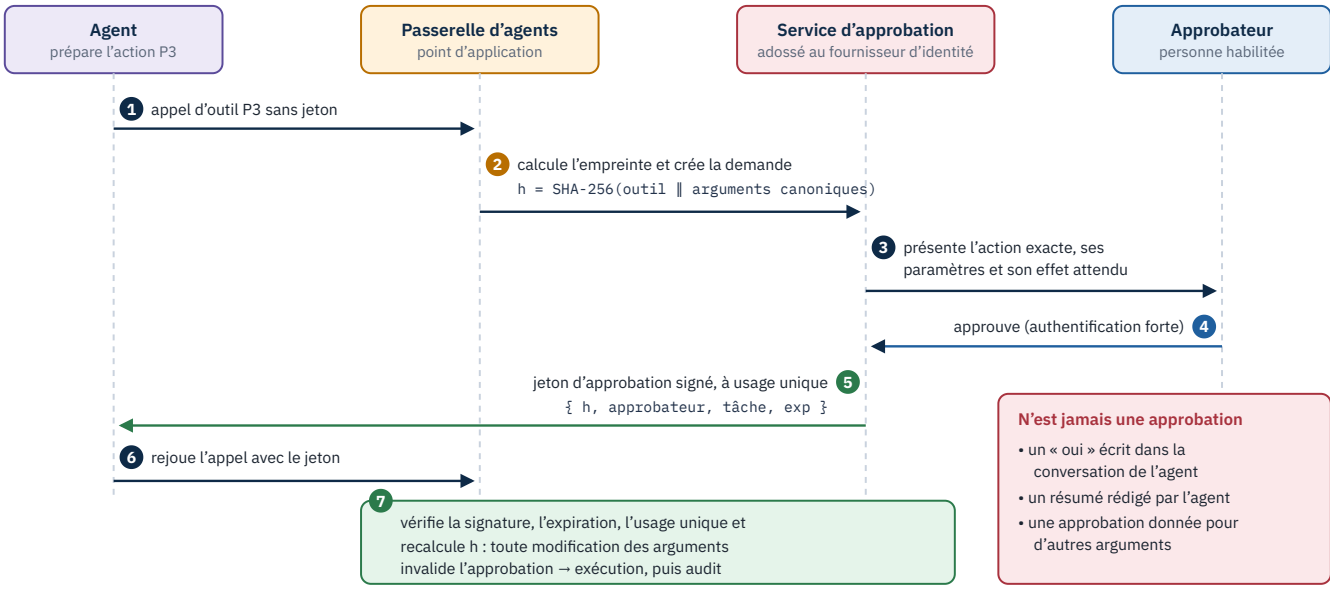



**Figure 16 — Approbation humaine signée, liée à l'action exacte.** La passerelle intercepte l'appel P3, calcule l'empreinte de l'action et la fait approuver par une personne habilitée; le jeton signé ne vaut que pour cette empreinte, une seule fois et pendant 15 minutes au plus.
Source : CRE-IA-2026-01.

L'empreinte se calcule ainsi : h = SHA-256(identifiant de l'outil ‖ arguments canonisés), où l'identifiant de l'outil est pleinement qualifié (serveur, nom et version épinglée). La canonisation suit la RFC 8785 (JSON Canonicalization Scheme), une RFC informative de la filière indépendante, non endossée par l'IETF, mais stable[308]; A2A 1.0 l'emploie déjà pour signer les cartes d'agent[68]. Sans canonisation, deux sérialisations du même objet JSON donneraient deux empreintes. Si l'agent, ou une injection, change un seul argument après l'approbation, l'empreinte recalculée par la passerelle ne correspond plus et l'appel est refusé. Un exemple de jeton figure à l'annexe C.

La formule est un choix de conception du cadre, pas une norme. Elle met en œuvre l'approbation explicite par action à fort impact que recommande l'OWASP (ASI02)[28] et s'appuie sur trois éléments normalisés : OpenID Connect CIBA (*Client-Initiated Backchannel Authentication*) pour l'approbation hors bande, la RFC 9396 pour décrire l'action et la RFC 8785 pour la canonisation.

**EXIG-AUT-12**
**DOIT**

### Jeton d'approbation lié à l'action exacte

Toute approbation exigée par la figure 15 **DOIT** produire un jeton signé par le service d'approbation adossé au fournisseur d'identité, contenant au minimum : l'empreinte h (SHA-256 de l'identifiant pleinement qualifié de l'outil, suivi des arguments canonisés selon la RFC 8785), l'identifiant pseudonymisé de l'approbateur, les identifiants de la tâche et de l'agent, une date d'expiration et un identifiant à usage unique. Avant l'exécution, la passerelle **DOIT** vérifier la signature, l'expiration et l'usage unique, puis recalculer h; toute différence annule l'approbation. Le jeton **DOIT** expirer au plus 15 minutes après sa signature.

Pourquoi : un lien cryptographique entre la décision humaine et l'action exécutée détecte toute modification des arguments après l'approbation; ce mécanisme et la durée de validité sont des choix du cadre.

**EXIG-AUT-13**
**NE DOIT PAS**

**Ce qui n'est jamais une approbation**

La passerelle **NE DOIT PAS** accepter comme approbation un message d'acquiescement dans la conversation de l'agent, un résumé ou une justification rédigés par l'agent, une confirmation locale dans l'interface de l'agent, ni une approbation donnée pour d'autres arguments, une autre tâche ou un autre agent.

Pourquoi : le brouillon de groupe de travail WIMSE AIMS précise qu'une confirmation locale dans l'interface ne suffit pas comme autorisation[309].

**EXIG-AUT-14**
**DEVRAIT**

**Approbation hors bande normalisée**

L'approbation d'un appel P3, ou celle que requiert un agent sans interface, **DEVRAIT** passer par OpenID Connect CIBA : le service d'approbation lance une demande d'authentification dorsale, l'approbateur confirme sur son propre appareil, et un `binding_message` court, affiché sur les deux appareils, rattache la demande à l'action. L'action **DEVRAIT** être décrite par le paramètre `authorization_details` de la RFC 9396 lorsqu'elle comporte des paramètres que les portées ne peuvent exprimer, comme un montant ou un destinataire.

Pourquoi : CIBA Core 1.0 est une spécification finale de l'OpenID Foundation qui découple l'appareil de l'agent de celui de l'approbateur[310]; le brouillon WIMSE AIMS cite CIBA en exemple d'autorisation par palier, tout en notant ses limites en cours d'exécution, et le livre blanc de l'OpenID Foundation propose CIBA pour l'approbation humaine des agents[93, 311]; la RFC 9396 exprime les autorisations fines que `scope` ne peut exprimer[312].

**EXIG-AUT-15**
**DOIT**

**Approbateurs habilités et formés**

Chaque combinaison de classe et de palier soumise à approbation **DOIT** avoir une liste d'approbateurs habilités, inscrite au registre. L'approbateur **DOIT** s'authentifier par authentification forte (au moins deux facteurs), posséder la compétence du domaine et l'autorité de refuser, et avoir été formé aux modes de défaillance des agents. Pour un appel P3 d'un agent de classe élevée, deux approbateurs distincts **DOIVENT** approuver, dont au moins un autre que le mandant.

Pourquoi : le RIA confie le contrôle humain des systèmes à haut risque à des personnes ayant la compétence, la formation et l'autorité nécessaires (art. 26, par. 2)[94]; l'IMDA demande que les superviseurs connaissent les modes de défaillance des agents[76]. Le second approbateur est un choix du cadre.

## 8.6 Interaction humaine avec les agents ambiants

Un agent ambiant travaille en arrière-plan, déclenché par des événements; la personne n'est pas devant lui quand il a besoin d'elle, et l'interaction doit être conçue en conséquence.

LangChain définit les agents ambiants comme des agents qui écoutent un flux d'événements et agissent en conséquence, éventuellement sur plusieurs événements à la fois, sans être nécessairement entièrement autonomes (section 3.3). Pour les relier aux personnes, son billet de janvier 2025 décrit trois patrons : notifier, questionner et réviser[86]. Le schéma de la boîte de réception d'agents (*Agent Inbox*) y associe quatre réponses : `accept`, `edit`, `response` et `ignore`, activées une à une par les drapeaux `allow_accept`, `allow_edit`, `allow_respond` et `allow_ignore`[313].

**Tableau 32 — Trois patrons d'interaction avec un agent ambiant**

| Patron | Quand l'employer | Ce que fait l'agent | Réponses admises |
|---|---|---|---|
| **Notifier** | Événement important que la politique interdit à l'agent de traiter (p. ex. un contrat reçu pour signature). | Signale sans agir. | Prendre connaissance. |
| **Questionner** | Information manquante ou ambiguë. | Suspend la tâche et pose une question ciblée au lieu de deviner. | Répondre. |
| **Réviser** | Action soumise à approbation selon la figure 15. | Place l'action préparée dans la file, avec son effet attendu. | Accepter, éditer, répondre par une rétroaction, ignorer (refus). |

Éditer une action revient à approuver une autre action : la passerelle calcule l'empreinte des arguments modifiés, et c'est cette version que couvre le jeton. Microsoft recommande aussi de distinguer l'approbation, qui fait avancer le flux, de la rétroaction, qui renvoie le travail à l'agent, et de restreindre les points d'approbation à des invocations d'outils précises[9]. Les protocoles offrent les mécanismes d'attente : en A2A 1.0, une tâche passe à l'état `TASK_STATE_INPUT_REQUIRED` ou `TASK_STATE_AUTH_REQUIRED` (section 6.6)[68]; en MCP, un serveur pose une question par élicitation, sans jamais demander de secret par formulaire[223].

Le « voyage dans le temps » souvent associé à ce patron n'est pas une réponse de la boîte de réception : c'est une fonction des points de contrôle de LangGraph, qui permet de rejouer une exécution depuis un point antérieur ou de bifurquer après avoir modifié l'état[283]. Il sert au diagnostic et à la correction; rejouer une étape réexécute ses effets. Enfin, le dépôt `agent-inbox` est archivé, en lecture seule, depuis le 20 septembre 2026[313] : le cadre adopte le patron, pas l'outil.

Un piège d'implémentation mérite attention. Dans LangGraph, `interrupt()` exige un mécanisme de points de contrôle persistant; à la reprise, le nœud interrompu redémarre depuis son début, si bien que le code placé avant l'interruption s'exécute de nouveau[82]. Un appel d'écriture placé avant le point d'approbation serait donc rejoué.

**EXIG-AUT-16** — **DOIT**

**Boîte de réception persistante**

Tout agent ambiant de niveau N2 ou plus **DOIT** acheminer ses interactions humaines par une boîte de réception persistante qui met en œuvre les trois patrons du tableau 32. Chaque demande **DOIT** indiquer le patron, la tâche, l'agent, l'effet attendu et une échéance fixée par cas d'usage. Une demande sans réponse à l'échéance expire : l'action n'est pas exécutée et la tâche passe à une file d'escalade nommée. « Ignorer » vaut refus.

Pourquoi : les patrons de LangChain évitent que l'agent devine (il pose une question plutôt que d'halluciner) ou agisse sans validation humaine (révision d'une action avant son exécution)[86]; l'expiration en refus applique l'échec en mode fermé de l'EXIG-AUT-11.

**EXIG-AUT-17** — **DOIT**

**État persisté et effets après le point d'approbation**

L'orchestrateur **DOIT** conserver l'état de la tâche de façon durable à chaque point d'approbation obligatoire, dans un moteur d'exécution durable (section 7.4). Un appel à effet de bord **NE DOIT PAS** précéder le point d'interruption dans la même étape; s'il ne peut pas être déplacé, il **DOIT** porter une clé d'idempotence (section 7.6).

Pourquoi : Microsoft recommande de persister l'état aux points d'approbation obligatoires pour reprendre sans rejouer le travail antérieur[9], et LangGraph réexécute le code qui précède une interruption[82].

**EXIG-AUT-18**
**DOIT**

**Réautorisation périodique des agents ambiants**

La délégation qui permet à un agent ambiant de niveau N3 ou N4 d'agir **DOIT** expirer à une échéance inscrite à sa fiche, au plus égale à la période d'attestation par le parrain, soit 12 mois au plus pour un agent de classe modérée ou faible (section 11.5 et EXIG-GOV-13). À l'échéance, l'agent s'arrête jusqu'à ce qu'une personne habilitée renouvelle la délégation.

Pourquoi : OpenAI recommande des expirations périodiques qui maintiennent l'agent à l'arrêt jusqu'à ce qu'un humain le révise et le réautorise[291].

## 8.7 Éviter l'approbation machinale

Un contrôle humain que personne n'exerce vraiment donne une fausse assurance; le cadre le conçoit et le mesure au lieu de le présumer.

Le phénomène est documenté. Parasuraman et Manzey (2010) montrent que le biais d'automatisation produit des erreurs d'omission et de commission, touche les novices comme les experts, s'observe aussi en équipe et ne disparaît ni avec la formation ni avec les consignes; la complaisance apparaît surtout sous charge multitâche[314]. OpenAI note qu'un utilisateur qui doit approuver rapidement beaucoup de décisions voit sa capacité à les examiner sérieusement diminuer[291].

Les référentiels en tirent des exigences. Le RIA demande que les personnes chargées du contrôle restent conscientes du biais d'automatisation (art. 14, par. 4, al. b)[290]; pour les systèmes à haut risque de l'annexe III, ces obligations s'appliquent à compter du 2 décembre 2027, et du 2 août 2028 pour ceux de l'annexe I, selon le RIA modifié par le règlement (UE) 2026/1744[58, 315]. L'OWASP décrit la menace T10 « Overwhelming Human in the Loop » : un attaquant submerge les réviseurs de demandes pour provoquer fatigue et approbations précipitées[87]. Le risque ASI09 « Human-Agent Trust Exploitation » vise la surconfiance : biais d'automatisation, autorité perçue, explications fabriquées[28].

**ATTENTION**

Plus d'approbations ne veut pas dire plus de sécurité. Au-delà d'un certain volume, chaque approbation devient un clic. Le cadre préfère des approbations moins nombreuses, mieux ciblées et mesurées, et automatise ce que la figure 15 classe à faible risque.

**EXIG-AUT-19**
**DOIT**

**Écran d'approbation fidèle à l'action**

L'écran d'approbation **DOIT** présenter l'action exacte, ses paramètres, son effet attendu, sa réversibilité et sa compensation, la provenance des données qui l'ont motivée (en signalant tout contenu non fiable) et un indicateur de risque produit par les règles du catalogue, non par le modèle. La prévisualisation **NE DOIT PAS** avoir d'effet de bord : ni appel réseau, ni changement d'état. Le raisonnement de l'agent **PEUT** être affiché comme information secondaire, mais il **NE DOIT PAS** tenir lieu de justification suffisante.

Pourquoi : l'OWASP (ASI09) recommande un résumé de risque en langage clair plutôt qu'une justification produite par le modèle, et la séparation entre prévisualisation et effet[28]; la spécification MCP recommande de montrer à l'utilisateur les entrées de l'outil avant l'appel[197].

**EXIG-AUT-20**
**DOIT**

**Charge d'approbation maîtrisée**

Les files d'approbation **DOIVENT** être priorisées selon le risque. Les demandes semblables **PEUVENT** être regroupées à l'affichage, mais chaque action conserve son propre jeton d'approbation (EXIG-AUT-09 et EXIG-AUT-12). La fréquence des demandes adressées à chaque approbateur **DOIT** être plafonnée selon un seuil fixé par le comité, et la charge **DOIT** être répartie entre approbateurs, avec rotation. Les actions que la figure 15 classe comme automatiques ne sont pas soumises à approbation.

Pourquoi : contre la menace T10, l'OWASP recommande de prioriser les files de révision par risque, d'automatiser les approbations à faible risque, de limiter la fréquence des demandes et de répartir dynamiquement la charge entre réviseurs[87]; la rotation est un choix du cadre.

**EXIG-AUT-21**
**DOIT**

**Mesure de la qualité de la supervision**

La plateforme **DOIT** produire chaque mois, par approbateur et par cas d'usage : le taux d'approbation sans modification, les taux de rejet et de modification, le temps de réponse, les renversements suspects (action refusée puis approuvée) et les approbateurs dont le taux d'approbation sans modification ou le temps de réponse s'écarte de la médiane du cas d'usage d'un seuil fixé par le comité. Pour les actions exécutées sans approbation préalable aux niveaux N3 et N4, une revue humaine a posteriori **DOIT** porter sur un échantillon d'au moins 5 % des actions de classe modérée et 1 % de celles de classe faible (choix du cadre). Le comité **DOIT** fixer ces seuils d'alerte par cas d'usage et examiner les écarts signalés.

Pourquoi : l'IMDA recommande de suivre le taux d'intervention des réviseurs (rejet ou modification des actions de l'agent), dont un niveau bas peut signaler une approbation machinale, et le temps de réponse des réviseurs[76]; l'OWASP recommande de détecter les renversements suspects[87] et le NIST juge utile de recueillir la fréquence des cas où une personne passe outre aux sorties du système, et leurs motifs[99]. Aucune source reconnue ne fixe de seuil universel.

## 8.8 Décisions automatisées et droit à la révision

Quand un agent décide seul à propos d'une personne, la Loi 25 crée des droits précis, et une approbation de pure forme ne les fait pas disparaître; la section 12.2 traite l'ensemble des obligations.

L'article 12.1 de la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1, « Loi sur le privé ») vise toute décision fondée exclusivement sur un traitement automatisé de renseignements personnels. L'entreprise doit en informer la personne au plus tard au moment où elle lui communique la décision. À la demande de la personne, elle l'informe des RP utilisés, des raisons et des principaux facteurs et paramètres ayant mené à la décision, ainsi que de son droit de faire rectifier ces renseignements. La personne doit pouvoir présenter ses observations à un membre du personnel en mesure de réviser la décision[56, 316]. Le défaut d'informer la personne de la décision ou de lui donner l'occasion de présenter ses observations, en contravention à l'article 12.1, est expressément un motif de sanction administrative pécuniaire (art. 90.1, par. 5°)[56, 317], et les renseignements utilisés pour prendre une décision doivent être conservés au moins un an après celle-ci (art. 11)[56]. Pour les organismes publics, la disposition équivalente est l'article 65.2 de la Loi sur l'accès aux documents des organismes publics et sur la protection des renseignements personnels (RLRQ, c. A-2.1, « Loi sur l'accès »)[318].

Qu'est-ce qui rend une décision « exclusivement » automatisée? Selon l'interprétation gouvernementale de l'article 65.2, c'est le cas lorsqu'aucune personne physique n'a exercé de contrôle important : une intervention humaine mineure, sans effet réel sur le résultat, ne fait pas échapper à l'obligation, alors qu'un outil d'aide qui fournit des éléments à un employé qui décide lui-même n'est pas visé. Cette interprétation précise aussi qu'il n'est pas requis de divulguer l'algorithme : le mot « principaux » limite l'explication aux facteurs déterminants[318]. Sous le règlement

général sur la protection des données de l'Union européenne (RGPD), les lignes directrices WP251rev.01 vont dans le même sens : on ne peut contourner la règle en fabriquant une intervention humaine, et le contrôle doit être exercé par une personne qui a l'autorité et la compétence de modifier la décision[319].

**DROIT APPLICABLE**

La Commission d'accès à l'information (CAI) n'a pas publié de critères de l'intervention humaine significative pour le secteur privé. Les exigences ci-dessous constituent une interprétation prudente du cadre, fondée par analogie sur l'article 65.2 et sur WP251rev.01; leur application à un cas précis relève des affaires juridiques.

**EXIG-AUT-22**
**DOIT**

**Décisions visées par l'article 12.1**

Tout agent qui rend une décision concernant une personne, ou la prépare sans révision humaine significative, à partir d'un traitement automatisé de ses RP **DOIT** être de classe élevée et mettre en œuvre : l'avis à la personne au plus tard au moment de la communication de la décision; la production, sur demande, des RP utilisés, des raisons et des principaux facteurs et paramètres, établie à partir des traces et du journal d'audit; l'indication du droit de rectification; un canal vers un membre du personnel en mesure de réviser la décision; la conservation des renseignements utilisés pendant au moins un an après la décision.

Pourquoi : obligations de l'article 12.1 et de l'article 11 de la Loi sur le privé (pour un organisme public, l'article 65.2 de la Loi sur l'accès prévoit des obligations d'information équivalentes)[56]; la traduction des traces en explication intelligible est un choix de mise en œuvre du cadre.

**EXIG-AUT-23**
**DOIT**

**Révision humaine significative**

Une intervention humaine **DOIT** être traitée comme nominale, et la décision comme exclusivement automatisée, sauf si la personne qui intervient a l'autorité de modifier la décision et la compétence voulue, accède à toutes les données pertinentes et non à la seule recommandation de l'agent, dispose du temps nécessaire, et exerce une influence réelle mesurée par l'EXIG-AUT-21. Le degré d'intervention humaine et l'étape où elle a lieu **DOIVENT** être consignés dans l'EFVP.

Pourquoi : interprétation prudente du cadre, et non règle expresse de la Loi 25; par analogie, une validation de pure forme ne retire pas le caractère exclusivement automatisé selon l'interprétation gouvernementale de l'article 65.2 (secteur public)[318], et WP251rev.01 demande de consigner dans l'analyse d'impact le degré et l'étape de l'intervention humaine[319].

PARTIE III

# Confiance et exploitation

Identité, sécurité et confiance zéro; traçage, évaluation continue et maîtrise des coûts.

9 · Identité, sécurité et confiance zéro

10 · Observabilité, évaluation et FinOps

# 9 Identité, sécurité et confiance zéro

Un agent est un programme dont le comportement dépend en partie du contenu qu'il lit : son emplacement dans le réseau ne dit rien de ses intentions au moment où il agit. Ce chapitre applique donc la confiance zéro aux agents : chacun possède sa propre identité, n'agit pour une personne qu'au moyen d'un jeton délégué dont la portée ne peut que diminuer, et chacun de ses appels est décidé, un à un, par le service de politiques et appliqué par une passerelle. Les sections 9.1 à 9.4 traitent de l'identité, de la délégation et du point d'application des politiques; les sections 9.5 à 9.9 traitent des menaces, de l'injection d'instructions, du cloisonnement, de la chaîne d'approvisionnement et de l'assurance.

## 9.1 La confiance zéro appliquée aux agents

Cette section transpose aux agents le modèle de confiance zéro du NIST et pose la règle centrale du chapitre : aucune autorisation ne s'hérite, chaque appel se décide.

La publication NIST SP 800-207 (août 2020) définit la confiance zéro comme l'absence de toute confiance implicite fondée sur l'emplacement réseau. L'authentification et l'autorisation y sont des fonctions distinctes, exécutées avant l'accès; l'accès à chaque ressource est accordé par session, au moindre privilège, selon une politique dynamique qui tient compte de l'identité, de l'état de l'actif et d'attributs comportementaux[73, 112]. La publication SP 800-207A (septembre 2023) déplace la segmentation du réseau vers l'identité des services et cite SPIFFE comme infrastructure d'identité applicative[320].

Ce modèle convient particulièrement aux agents. Un agent légitime et correctement authentifié peut changer de comportement en cours de tâche : il lui suffit de lire un courriel qui contient des instructions cachées. Une autorisation accordée au début de la session ne protège donc pas l'étape suivante. C'est pourquoi le cadre va au-delà de l'accès par session décrit par le NIST : il exige une décision à chaque appel d'outil ou d'agent (choix du cadre). Le tableau 33 montre où chaque composant logique de la SP 800-207 se situe dans l'architecture de référence (chapitre 5).

**Tableau 33 — Composants logiques de la confiance zéro et leur réalisation pour les agents**

| Composant (NIST SP 800-207) | Rôle selon le NIST | Réalisation dans le cadre |
|---|---|---|
| Moteur de politique (PE) | Décide d'accorder, de refuser ou de révoquer l'accès à une ressource. | Service de politiques : évalue l'identité de l'agent, le mandant, les droits effectifs, le palier de l'outil, le niveau d'autonomie et l'état de la tâche. |
| Administrateur de politique (PA) | Établit ou coupe le chemin de communication entre le sujet et la ressource. | Fournisseur d'identité (émission et révocation des jetons délégués) et plan de contrôle des passerelles (distribution des politiques, coupe-circuit). |
| Point d'application de politique (PEP) | Ouvre, surveille et termine les connexions. | Passerelle d'agents pour les appels vers les outils et les agents; passerelle de modèles pour les appels vers les modèles. |
| Sources de données (CDM, gestion des identités, journaux, SIEM, renseignements sur les menaces) | Alimentent le moteur de politique en informations sur l'état de l'actif, le sujet et l'activité. | Registre des agents, catalogue (paliers, versions épinglées), signaux de risque partagés, budget consommé, contenu non fiable déjà lu. |

Source : d'après NIST SP 800-207[73]; colonne de droite : choix du cadre.

**EXIG-IAM-01** NE DOIT PAS

**Aucune confiance implicite**

L'accès d'un agent à un outil, à une ressource ou à un autre agent **NE DOIT PAS** être accordé du seul fait de son emplacement réseau, de sa plateforme d'hébergement ou de son appartenance au même orchestrateur ou au même domaine. Toute communication entre composants est mutuellement authentifiée et chiffrée, y compris à l'intérieur d'un réseau privé.

Pourquoi : la SP 800-207 exclut toute confiance implicite fondée sur l'emplacement réseau[73]; un agent détourné se trouve, par définition, déjà à l'intérieur.

**EXIG-IAM-02** DOIT

**Une décision à chaque appel**

Chaque appel d'un agent vers un outil, une ressource ou un autre agent **DOIT** être authentifié et autorisé individuellement. Le point d'application applique la décision du service de politiques, rendue d'après l'identité de l'agent, le mandant, le palier de l'outil, le niveau d'autonomie, l'état de la tâche et les signaux de risque. Aucune autorisation n'est héritée d'un appel précédent ni d'une session, et l'agent ne participe jamais à la décision sur ses propres droits.

Pourquoi : l'état d'une tâche agentique change d'un appel à l'autre (contenu non fiable lu, budget consommé, approbation expirée); une décision prise une fois par session ne le verrait pas. Exigence propre au cadre, plus stricte que l'accès par session de la SP 800-207.

EXEMPLE

Un agent de soutien lit, à l'étape 3 de sa tâche, un courriel externe. À l'étape 4, il tente d'appeler l'outil d'envoi de courriels. Parce que la décision est prise à chaque appel, la passerelle sait que la session a consommé du contenu non fiable et refuse l'envoi sans approbation humaine (section 9.6). Une autorisation accordée à l'ouverture de la session l'aurait laissé passer.

## 9.2 Identité non humaine des agents

Cette section fixe ce qu'est l'identité d'un agent, comment elle est émise et comment elle prend fin. Le principe est simple : on ne peut ni auditer, ni restreindre, ni révoquer ce qu'on ne peut pas désigner.

Un agent n'est ni une personne, ni un compte de service partagé (section 3.4). Microsoft déconseille d'attribuer aux agents un compte d'utilisateur ordinaire ou un principal de service traditionnel et a créé, avec Microsoft Entra Agent ID, un type d'identité propre aux agents[90]. Les bonnes pratiques de ce produit prescrivent une identité unique par instance d'agent et le moindre privilège[92]. Le brouillon de groupe de travail IETF WIMSE « AI Identity Management System » (AIMS, `draft-ietf-wimse-aims-00`, 15 septembre 2026) exige de son côté un seul identifiant de charge de travail par agent (qui peut être un SPIFFE ID), des justificatifs liés cryptographiquement et à expiration explicite, et interdit au grand modèle de langage d'accéder aux justificatifs de l'agent[93].

### Émettre l'identité

SPIFFE et SPIRE sont des projets diplômés de la Cloud Native Computing Foundation (annonce du 20 septembre 2022; niveau « Graduated » atteint le 23 août 2022 pour SPIFFE et le 22 août 2022 pour SPIRE selon leurs pages de projet) [116, 117, 321]. Un SPIFFE ID prend la forme `spiffe://domaine-de-confiance/chemin`. Le justificatif correspondant, le SVID, existe en deux formats, X.509-SVID et JWT-SVID, tous deux délivrés par la Workload API sans secret préalable; l'X.509-SVID est renouvelé automatiquement, tandis que le JWT-SVID, de courte durée, est redemandé au besoin; SPIFFE recommande l'X.509-SVID lorsque c'est possible, car un JWT-SVID peut être rejoué[322]. La fédération d'identité OpenID Connect (OIDC) des fournisseurs infonuagiques (identités gérées) offre une solution équivalente pour les agents hébergés sur une seule plateforme.

Le brouillon WIMSE « Workload Identity Practices » (`draft-ietf-wimse-workload-identity-practices-07`, version du 22 septembre 2026, soumis le 30 juin 2026 au groupe de pilotage de l'ingénierie Internet (IESG)) recommande des justificatifs émis par la plateforme, de courte durée et ne dépassant pas la vie de l'instance, une audience distincte par cible, la preuve de possession, l'abandon des variables d'environnement lorsque la plateforme offre mieux et l'invalidation à la fin de la charge de travail[323]. Ces deux brouillons WIMSE ne sont pas des RFC; le cadre s'en sert comme références de conception.

Microsoft Entra Agent ID illustre une mise en œuvre commerciale, parmi d'autres. Une identité d'agent n'y a pas de justificatifs propres : elle obtient ses jetons par un gabarit *(agent identity blueprint)* qui porte les justificatifs et les politiques d'accès conditionnel héritées par toutes ses identités; désactiver le gabarit bloque toutes ces identités. Chaque agent a un parrain *(sponsor)*, responsable métier, et un propriétaire, responsable technique[90]. Depuis juillet 2026, Copilot Studio crée automatiquement une telle identité pour chaque nouvel agent[48]. Le service est offert à tous les clients Entra, mais l'extension aux agents des fonctions de sécurité (accès conditionnel, protection des identités) requiert une licence Microsoft Agent 365[324].

**EXIG-IAM-03**
**DOIT**

**Identité propre, distincte et non partagée**

Chaque agent inscrit au registre **DOIT** disposer de sa propre identité non humaine, rattachée à sa fiche (section 11.4) et à un parrain nommé. Une identité distincte par instance est exigée lorsque des instances servent des mandants, des locataires ou des environnements différents, ou lorsqu'il faut pouvoir en révoquer une seule. Une identité d'agent n'est jamais partagée entre agents ni utilisée par une personne, et un agent n'utilise jamais le compte d'une personne.

Pourquoi : l'OWASP classe la réutilisation d'identités non humaines (NHI9) et leur usage par des humains (NHI10) parmi les dix risques principaux[91]; sans identité propre, ni l'audit ni la révocation ne peuvent viser un agent précis.

**EXIG-IAM-04**
**DOIT**

**Justificatif cryptographique émis par la plateforme**

L'identité d'un agent **DOIT** reposer sur un justificatif cryptographique émis par la plateforme, de courte durée, renouvelé automatiquement et valide au plus pour la vie de l'instance : X.509-SVID (à privilégier) ou JWT-SVID SPIFFE, ou identité fédérée OIDC du fournisseur infonuagique. Les justificatifs sont isolés par environnement (développement, essai, production).

Pourquoi : un justificatif émis par la plateforme est de courte durée, se renouvelle seul, cesse d'être valide avec l'instance et n'exige aucun secret déployé avec la charge de travail; c'est la voie que décrivent SPIFFE et les pratiques WIMSE[322, 323].

**EXIG-IAM-05**
**NE DOIT PAS**

**Aucun secret statique partagé**

Un agent **NE DOIT PAS** s'authentifier au moyen d'une clé d'API statique, d'un mot de passe ou d'un secret client de longue durée partagé. Aucun secret ne figure dans le code, les définitions d'agents, les invites, les fichiers de configuration versionnés ni, lorsque la plateforme offre un mécanisme d'émission, dans les variables d'environnement. Un secret résiduel imposé par un système patrimonial est conservé dans un coffre, renouvelé automatiquement et inscrit comme dérogation (section 11.6).

Pourquoi : le brouillon AIMS qualifie les clés d'API statiques d'antipatron[93] et l'OWASP range la fuite de secrets (NHI2) et les secrets de longue durée (NHI7) parmi les risques majeurs[91].

**EXIG-IAM-06** **NE DOIT PAS**

**Justificatifs hors de portée du modèle**

Le modèle **NE DOIT PAS** avoir accès aux justificatifs de l'agent : aucun jeton, certificat ni secret n'entre dans le contexte du modèle, dans la mémoire de l'agent, dans les arguments d'un outil ou dans les traces. Les jetons sont manipulés par le code d'exécution de l'agent ou injectés par la passerelle (EXIG-IAM-19).

Pourquoi : le brouillon AIMS l'interdit[93]; un modèle qui voit un jeton peut être amené, par injection d'instructions, à le divulguer.

## Retirer et révoquer

Une identité oubliée reste une porte ouverte. Le livre blanc de l'OpenID Foundation sur l'identité des agents (annoncé le 7 octobre 2025) recommande un retrait formel des agents, par exemple une opération `DELETE` du protocole SCIM *(System for Cross-domain Identity Management)* propagée aux systèmes raccordés[311, 325]. Le NIST AI RMF prévoit des processus de déclassement sécuritaire des systèmes d'IA (GOVERN 1.7), dont le cadre fait découler la révocation des identifiants[74]. Microsoft recommande que les parrains attestent tous les 6 à 12 mois que chaque agent est encore requis et que les agents orphelins soient revus chaque trimestre[92].

**EXIG-IAM-07** **DOIT**

**Révocation au retrait et revues périodiques**

Le retrait d'un agent **DOIT** révoquer son identité, ses justificatifs, ses jetons actifs et ses délégations, dans un délai maximal fixé par l'entreprise et mesuré en exercice, puis propager la suppression aux systèmes raccordés. Le parrain atteste au moins tous les 12 mois (tous les 6 mois pour un agent de classe de risque élevée) que l'agent est encore requis. Une revue trimestrielle détecte les agents orphelins (sans parrain, sans fiche à jour ou inactifs), qui sont désactivés (section 11.5).

Pourquoi : le retrait inadéquat est le premier risque du classement OWASP (NHI1)[91]. Les périodicités sont des choix du cadre, inscrits dans la plage recommandée par Microsoft.

Le tableau 34 rattache chacun des dix risques de l'OWASP Non-Human Identities Top 10 (2025) aux exigences de ce chapitre. La correspondance avec le Top 10 des applications agentiques (ASI) est traitée à la section 9.5.

**Tableau 34 — Risques de l'OWASP Non-Human Identities Top 10 (2025) et réponse du cadre**

| Risque OWASP | Ce qui se passe | Réponse du cadre |
|---|---|---|
| NHI1 Retrait inadéquat *(Improper Offboarding)* | L'agent retiré garde des accès valides. | EXIG-IAM-07; cycle de vie (section 11.5) |
| NHI2 Fuite de secrets *(Secret Leakage)* | Une clé apparaît dans le code, une trace ou une réponse du modèle. | EXIG-IAM-05, EXIG-IAM-06, EXIG-IAM-19 |
| NHI3 Identités de tiers vulnérables *(Vulnerable Third-Party NHI)* | Un fournisseur détient des accès étendus et mal protégés. | EXIG-IAM-17; chaîne d'approvisionnement (section 9.8); clauses (section 13.3) |
| NHI4 Authentification non sécurisée *(Insecure Authentication)* | Octrois obsolètes, secrets partagés, absence de preuve de possession. | EXIG-IAM-04, EXIG-IAM-13, EXIG-IAM-14 |
| NHI5 Identités surprivilégiées *(Overprivileged NHI)* | L'agent possède plus de droits que ses tâches n'en exigent. | EXIG-IAM-10, EXIG-IAM-16 |
| NHI6 Configurations infonuagiques non sécurisées *(Insecure Cloud Deployment Configurations)* | Justificatifs exposés par la configuration du déploiement. | EXIG-IAM-04 (identité fédérée); cloisonnement (section 9.7) |

| Risque OWASP | Ce qui se passe | Réponse du cadre |
|---|---|---|
| NHI7 Secrets de longue durée *(Long-Lived Secrets)* | Un secret volé reste exploitable des mois durant. | EXIG-IAM-04, EXIG-IAM-05, EXIG-IAM-15 |
| NHI8 Isolation des environnements *(Environment Isolation)* | Le même justificatif sert en essai et en production. | EXIG-IAM-04 (isolation par environnement) |
| NHI9 Réutilisation d'identités *(NHI Reuse)* | Plusieurs agents partagent une identité; l'audit devient ambigu. | EXIG-IAM-03, EXIG-IAM-16 |
| NHI10 Usage humain d'identités non humaines *(Human Use of NHI)* | Une personne se sert de l'identité d'un agent pour agir. | EXIG-IAM-03 |

Source : liste et intitulés de l'OWASP[91]; traduction et correspondance : cadre.

## 9.3 Délégation : agir au nom d'une personne

Cette section règle le cas le plus fréquent et le plus délicat : un agent qui agit pour une personne. L'objectif est double : que chaque système appelé sache à la fois qui demande et qui agit, et que l'agent ne puisse jamais faire plus que ce que la personne pourrait faire elle-même.

Le risque visé porte un nom : l'adjoint confus *(confused deputy)*. Un agent doté de droits étendus exécute la demande d'une personne qui en a moins et lui procure ainsi, indirectement, ce qu'elle n'aurait pas pu obtenir seule. La spécification MCP le signale explicitement pour les mandataires MCP[208]. La parade consiste à faire porter par chaque appel l'identité du mandant et celle de l'agent, puis à calculer les droits à partir des deux.

### Échange de jetons et chaîne d'acteurs

La norme de référence est l'échange de jetons OAuth 2.0 (RFC 8693, janvier 2020). Dans la requête, `subject_token` (le jeton du mandant) est obligatoire; `actor_token` (le justificatif de l'agent) et `requested_token_type` sont facultatifs, `actor_token_type` devenant obligatoire en présence d'`actor_token`. La revendication `may_act` exprime qu'une partie est autorisée à agir pour une autre; le serveur d'autorisation peut s'en servir pour accepter ou refuser une délégation[70].

Dans le jeton émis, la revendication `act` est un objet JSON, et non une simple chaîne. Des `act` imbriqués représentent une chaîne : l'`act` le plus externe désigne l'acteur courant, les `act` imbriqués les acteurs antérieurs. La RFC précise que seuls les attributs de premier niveau et l'acteur courant servent aux décisions d'accès; les acteurs antérieurs sont informatifs. Elle laisse aussi l'émission d'`act` à la discrétion du serveur d'autorisation : c'est donc le cadre qui l'exige[70].

La RFC distingue la délégation, où l'acteur conserve une identité distincte et agit pour le mandant, de l'usurpation *(impersonation)*, où l'acteur devient indiscernable du mandant[69]. Le livre blanc de l'OpenID Foundation recommande de remplacer l'usurpation par une autorité déléguée explicite, dans des jetons qui identifient à la fois l'utilisateur et l'agent, et d'atténuer la portée à chaque saut[311]. Le système cible exécute donc la requête au nom de la personne, l'agent restant identifié comme acteur courant.

« On-Behalf-Of » (OBO) désigne un patron de délégation, pas une norme. Le flux OBO de Microsoft Entra, par exemple, ne repose pas sur la RFC 8693, mais sur l'octroi `urn:ietf:params:oauth:grant-type:jwt-bearer` avec `requested_token_use=on_behalf_of`[326]. Le cadre exige donc un résultat (jeton délégué, audience restreinte, portée réduite, mandant et acteur identifiables) et nomme la RFC 8693 comme référence; chaque variante de fournisseur est profilée au catalogue.

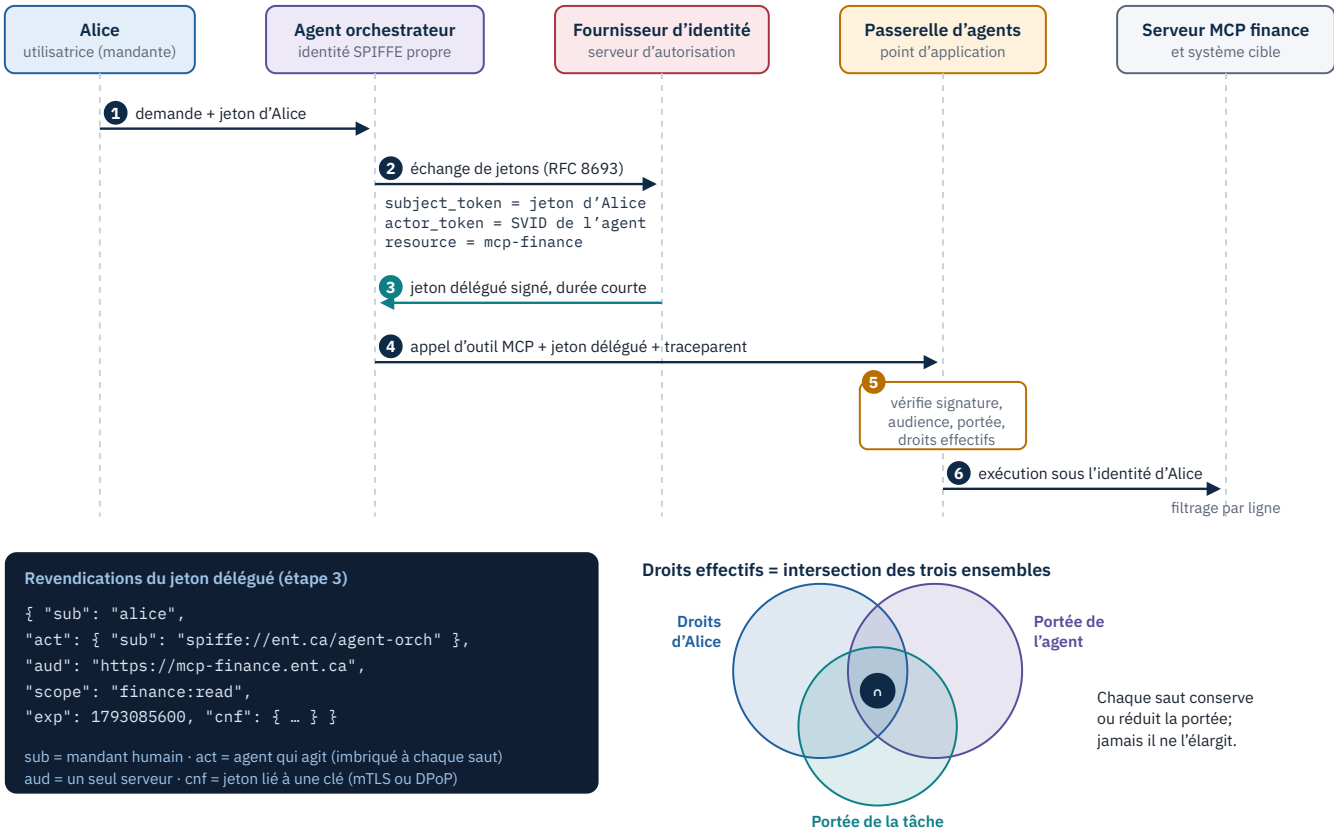



**Figure 17 — Délégation par échange de jetons et droits effectifs.** L'orchestrateur échange le jeton d'Alice contre un jeton délégué à audience unique (étapes 2 et 3), que la passerelle vérifie avant l'appel (étape 5); le serveur cible agit au nom d'Alice, l'agent restant identifié comme acteur courant (étape 6). Les droits effectifs ne dépassent jamais l'intersection des trois ensembles.

Source : CRE-IA-2026-01, d'après la RFC 8693 et la RFC 9068.

La figure 17 illustre le premier échange. Lorsqu'un sous-agent appelé par A2A doit à son tour appeler un outil, il refait un échange : son `subject_token` est le jeton délégué reçu, son `actor_token` est son propre JWT-SVID (un X.509-SVID sert plutôt à l'authentification mTLS du client, la RFC 8693 ne définissant aucun type de jeton pour un certificat). Le jeton obtenu conserve le mandant et ajoute un niveau d'`act`, comme dans l'extrait suivant (l'exemple complet figure à l'annexe C).

**Jeton délégué après deux sauts (extrait)**

```
{
  "iss": "https://idp.ent.ca",
  "sub": "alice",
  "aud": "https://mcp-finance.ent.ca",
  "client_id": "agent-analyse-depenses",
  "scope": "finance:read",
  "act": {
    "sub": "spiffe://ent.ca/agent-analyse-depenses",
    "act": { "sub": "spiffe://ent.ca/agent-orch" }
  },
  "cnf": { "x5t#S256": "…" },
  "iat": 1793084700, "exp": 1793085600, "jti": "9f1c…"
}
```

**EXIG-IAM-08**
**DOIT**

**Délégation explicite par échange de jetons**

Lorsqu'un agent agit pour une personne, il **DOIT** obtenir, à chaque saut, un jeton délégué par échange de jetons conforme à la RFC 8693 : `subject_token` égal au jeton du mandant ou au jeton délégué reçu, `actor_token` égal au justificatif de l'agent. Le jeton émis porte `sub` (le mandant) et `act` (l'agent courant), avec un `act` imbriqué par acteur antérieur. Avant d'émettre, le serveur d'autorisation **DOIT** vérifier que l'agent est autorisé à agir pour ce mandant (`may_act` ou politique équivalente) et que la profondeur d'imbrication de `act` ne dépasse pas deux niveaux (EXIG-ORC-04). Une variante de fournisseur est admise si son profil, inscrit au catalogue, démontre le même résultat.

Pourquoi : la RFC 8693 rend `act` facultatif[70]; le cadre l'exige pour que chaque appel désigne à la fois la personne et l'agent.

**EXIG-IAM-09**
**NE DOIT PAS**

**Interdiction de l'usurpation**

Un agent **NE DOIT PAS** usurper l'identité d'une personne : aucun jeton ne présente l'agent comme s'il était le mandant, et aucun agent ne réutilise le jeton, la session ou le mot de passe d'une personne.

Pourquoi : un appel usurpé efface l'agent de la piste d'audit et lui donne tous les droits de la personne[69, 311].

## Droits effectifs : une intersection, jamais une addition

Microsoft définit la permission effective d'une application déléguée comme l'intersection de ce que l'utilisateur peut faire et de ce que l'application est autorisée à faire[96]. Le cadre y ajoute un troisième terme, la portée de la tâche (choix du cadre) : droits effectifs = droits du mandant ∩ portée de l'agent ∩ portée de la tâche. Exemple : Alice peut lire et approuver les factures de son unité; l'agent d'analyse ne détient que `finance:read`; la tâche porte sur les dépenses du troisième trimestre. Le jeton délégué permet donc de lire les dépenses du troisième trimestre de l'unité d'Alice, et rien d'autre.

Comme la RFC 8693 interdit de fonder une décision d'accès sur les acteurs antérieurs, cette intersection ne peut pas être recalculée par le serveur de ressources à partir des `act` imbriqués : elle s'applique au serveur d'autorisation, à chaque échange[70]. Lorsqu'une portée manque, MCP prévoit que le serveur réponde 403 avec `error="insufficient_scope"` et que le client demande une autorisation incrémentale, avec un nombre limité de tentatives[209] : l'agent démarre avec peu de droits et en obtient davantage par une demande traçable.

**EXIG-IAM-10**
**DOIT**

**Portée jamais élargie**

À chaque échange, le serveur d'autorisation **DOIT** émettre une portée au plus égale à l'intersection des droits du mandant, de la portée accordée à l'agent au registre et de la portée nécessaire à la tâche. Une portée ne s'élargit jamais d'un saut à l'autre. Une portée manquante s'obtient par une demande incrémentale explicite, journalisée et limitée en nombre de tentatives, jamais par un jeton plus large obtenu d'avance.

Pourquoi : l'atténuation de la portée à chaque saut est recommandée par l'OpenID Foundation[311]; la formule à trois termes est un choix du cadre.

**EXIG-IAM-11** DOIT

**Jeton à audience unique, validé par la cible**

Tout jeton d'accès présenté par un agent à un outil, à une ressource ou à un autre agent **DOIT** viser une seule ressource (paramètre `resource` de la RFC 8707 ou `audience` de la RFC 8693) et suivre le profil JWT de la RFC 9068 (`typ` `at+jwt` ; `iss`, `exp`, `aud`, `sub`, `client_id`, `iat` et `jti` présents). Le serveur de ressources rejette tout jeton dont `aud` ne le désigne pas, fonde sa décision sur `sub` et sur l'acteur courant seulement, et journalise les deux; les acteurs antérieurs servent à l'audit.

Pourquoi : un jeton à audience unique ne vaut rien ailleurs s'il est volé[71, 72]; la RFC 9068 ne définit pas `act`, qui relève de la RFC 8693.

**EXIG-IAM-12** NE DOIT PAS

**Aucun relais de jeton**

Un agent, un outil ou un serveur MCP **NE DOIT PAS** transmettre tel quel à un autre service un jeton qu'il a reçu *(token passthrough)*, sauf au serveur d'autorisation, à titre de `subject_token` d'un échange de jetons (EXIG-IAM-08); il obtient un nouveau jeton pour chaque audience.

Pourquoi : la spécification d'autorisation MCP l'interdit, le brouillon AIMS le qualifie d'antipatron[93, 209].

## Profil OAuth de l'entreprise

Au 27 octobre 2026, OAuth 2.1 n'est pas une RFC : c'est un Internet-Draft actif du groupe de travail OAuth (`draft-ietf-oauth-v2-1-16`, septembre 2026, expirant le 7 mars 2027)[176]. La référence normative est donc OAuth 2.0 conforme à la RFC 9700 (BCP 240, janvier 2025), alignée sur le profil OAuth 2.1 en cours de normalisation[175]. Le tableau 35 précise ce que cela signifie pour les agents.

**Tableau 35 — Profil OAuth exigé pour les agents**

| Exigence | Référence | Application aux agents |
|---|---|---|
| Pratiques de sécurité courantes | RFC 9700, BCP 240[175] | Octroi implicite à éviter, octroi par mot de passe interdit, PKCE pour les clients publics, comparaison exacte des URI de redirection, jetons restreints en audience et en privilèges, authentification asymétrique des clients (mTLS ou `private_key_jwt`). |
| Alignement sur OAuth 2.1 | Brouillon `draft-ietf-oauth-v2-1-16` [327] | Le brouillon ne définit que trois octrois : code d'autorisation avec PKCE, jeton de rafraîchissement, identifiants du client. Un agent n'utilise que ceux-là, plus les octrois d'extension retenus par le cadre (RFC 8693, RFC 7523). Aucun jeton dans l'URI. |
| Authentification mTLS et jetons liés au certificat | RFC 8705[328] | Jeton lié par `cnf` « `x5t#S256` »; la ressource rejette la requête si le certificat diffère. Profil par défaut dans le maillage de services, avec des X.509-SVID (ligne directrice du cadre). |
| Preuve de possession (DPoP) | RFC 9449[213] | Preuve JWT `dpop+jwt` liée à `htm`, `htu`, `iat`, `jti` et `ath`; jeton lié par `cnf.jkt`; nonce possible. Profil des agents hors maillage : poste de travail, navigateur, mobile, périphérie. |
| Identification de l'émetteur | RFC 9207[329] | Paramètre `iss` dans la réponse d'autorisation contre la confusion de serveurs. MCP 2026-07-28 exige que le client le valide; le cadre exige que le fournisseur d'identité l'émette. |
| Métadonnées de ressource protégée | RFC 9728[330] | Document `/.well-known/oauth-protected-resource` dont la valeur `resource` correspond exactement à l'identifiant de la ressource. Publié par chaque serveur MCP et chaque API exposée aux agents. |
| Indicateur de ressource | RFC 8707[71] | Paramètre `resource` dans les requêtes d'autorisation et de jeton; MCP exige l'URI canonique du serveur[209]. |

| Exigence | Référence | Application aux agents |
|---|---|---|
| Jeton d'accès JWT | RFC 9068[72] | Format des jetons délégués; `act` s'ajoute selon la RFC 8693. |

**EXIG-IAM-13** — DOIT

**Profil OAuth de l'entreprise**

Le fournisseur d'identité, la passerelle d'agents et les serveurs exposés aux agents **DOIVENT** appliquer le profil du tableau 35 : pratiques de la RFC 9700, aucun octroi implicite ni octroi par mot de passe, PKCE avec `S256`, comparaison exacte des URI de redirection, authentification asymétrique des clients confidentiels, émission et validation du paramètre `iss` (RFC 9207) et publication des métadonnées de ressource protégée (RFC 9728).

Pourquoi : la RFC 9700 est la référence de sécurité OAuth en vigueur, alors qu'OAuth 2.1 reste un brouillon[175, 176]. Le cadre est plus strict que la RFC 9700 sur deux points : celle-ci déconseille l'octroi implicite (NE DEVRAIT PAS) et ne fait que recommander l'authentification asymétrique des clients (choix du cadre).

**EXIG-IAM-14** — DOIT

**Jetons liés à l'expéditeur**

Tout jeton qui donne accès à un outil P2 ou P3, ou qui est détenu par un agent de classe de risque élevée, **DOIT** être lié à l'expéditeur *(sender-constrained)* : mTLS (RFC 8705) dans le maillage de services, de préférence avec un X.509-SVID, ou DPoP (RFC 9449) hors du maillage. Pour les autres jetons, la liaison **DEVRAIT** être appliquée. Les jetons de rafraîchissement des clients publics **DOIVENT** être liés à l'expéditeur ou à usage unique.

Pourquoi : un jeton porteur volé est utilisable par quiconque le détient. La RFC 9700 recommande la liaison du jeton à l'expéditeur (DEVRAIT)[175]; le cadre la rend obligatoire pour les paliers P2 et P3 et pour les agents de classe de risque élevée. La répartition mTLS/DPoP est une ligne directrice du cadre.

Aucune norme IETF, OpenID ou NIST ne fixe de durée de vie chiffrée : la RFC 9700, le brouillon OAuth 2.1, MCP (qui le recommande, SHOULD) et le brouillon AIMS ne demandent que des jetons « de courte durée ». Le brouillon Transaction Tokens évoque des durées « de l'ordre de quelques minutes ou moins »[179]. Chez Microsoft Entra, la durée par défaut est de 60 à 90 minutes, une politique configurable ne peut descendre sous 10 minutes, et l'évaluation continue de l'accès (CAE) peut la prolonger jusqu'à 28 heures en échange d'une révocation en quasi temps réel[331]. Le cadre fixe donc une cible plutôt qu'un absolu.

**EXIG-IAM-15** — DEVRAIT

**Durée de vie courte des jetons**

Un jeton d'accès d'agent **DEVRAIT** expirer en 15 minutes ou moins lorsque le fournisseur d'identité le permet. Lorsque la durée minimale du fournisseur est plus longue, l'écart est compensé par la liaison du jeton à l'expéditeur (EXIG-IAM-14) et par la révocation en quasi temps réel (EXIG-IAM-20). La délégation de longue durée d'un agent ambiant est régie par l'EXIG-AUT-18 (échéance inscrite à la fiche, renouvelée par une personne habilitée).

Pourquoi : la cible de 15 minutes est un choix du cadre; OpenAI cite, parmi les moyens de borner l'action des agents, des expirations périodiques jusqu'à ce qu'un humain révise et réautorise l'agent[291].

## Agents autonomes et approbations hors bande

Un agent qui n'agit pour personne (traitement de fond, surveillance, rapprochement nocturne) n'a pas de mandant à représenter. Microsoft Entra Agent ID prescrit alors le flux par identifiants du client *(client credentials)*, et le flux OBO pour les agents interactifs[92]. MCP publie, depuis la révision 2026-07-28, une extension stable « OAuth Client Credentials » pour ce cas[217]. Lorsqu'un agent sans interface doit obtenir la confirmation d'une personne, il passe par une approbation hors bande (CIBA), décrite à la section 8.5.

**EXIG-IAM-16**
**DOIT**

**Agents autonomes : identifiants du client et portées par outil**

Un agent qui n'agit pour aucune personne **DOIT** utiliser l'octroi par identifiants du client avec son propre principal, authentifié par un justificatif cryptographique (EXIG-IAM-04), et des portées minimales définies outil par outil. Il ne partage jamais un jeton avec un autre agent et n'emprunte jamais l'identité d'une personne pour élargir ses droits.

Pourquoi : l'OWASP classe les identités surprivilégiées (NHI5) et la réutilisation d'identités (NHI9) parmi les risques principaux[91].

## Mécanismes en cours de normalisation

Plusieurs mécanismes utiles aux agents ne sont pas encore des normes publiées. Le tableau 36 en donne l'état au 27 octobre 2026 et la cote retenue; il précise, pour l'identité, le catalogue des protocoles de la section 6.3.

**Tableau 36 — Mécanismes d'identité en normalisation : état au 27 octobre 2026**

| Mécanisme | État | Usage visé | Cote |
|---|---|---|---|
| OAuth 2.1 | Brouillon de groupe de travail, version -16 (septembre 2026)[176] | Profil de référence, via la RFC 9700 | Adopter avec réserve |
| ID-JAG et extension MCP « Enterprise-Managed Authorization » | Brouillon -04 (21 mai 2026); extension MCP stable depuis 2026-07-28[177, 218] | Le fournisseur d'identité de l'entreprise décide, par politique, à quels serveurs MCP un employé accède, sans consentement par serveur (ID-JAG par RFC 8693, puis jeton d'accès par RFC 7523) | Évaluer |
| Transaction Tokens | Brouillon -11 (juillet 2026), consensus du groupe atteint, en attente du rapport[179, 332] | Propager l'identité et le contexte d'autorisation dans un domaine; jeton jamais accepté hors de son domaine, jamais plus large que le jeton remplacé | Évaluer |
| Identity and Authorization Chaining Across Domains | Brouillon -17 dans la file de l'éditeur des RFC[333] | Appels d'agents entre domaines de confiance (filiales, partenaires); à citer comme RFC dès sa publication | Évaluer |
| Authentification de client OAuth par SPIFFE | Brouillon de groupe de travail -02 (15 juin 2026)[334] | SVID comme justificatif de client au lieu d'un secret partagé; d'ici là, SVID en `actor_token`, mTLS ou `private_key_jwt` | Évaluer |
| « OAuth 2.0 Extension: On-Behalf-Of User Authorization for AI Agents » | Brouillon individuel, version -02 (26 août 2025), expiré le 27 février 2026, non adopté[335] | Paramètre `requested_actor` et consentement nommant l'agent; ce n'est pas une spécification de l'IETF | Surveiller |
| Brouillons individuels WIMSE sur la délégation entre agents | Non adoptés par le groupe de travail[336] | Chaînes de délégation entre agents et entre organisations | Surveiller |

**À RETENIR**

Les pratiques d'identité des agents ne sont pas stabilisées. Le centre d'excellence en cybersécurité du NIST (NCCoE, *National Cybersecurity Center of Excellence*) a publié en février 2026 un document de réflexion sur l'identité et l'autorisation des agents logiciels et d'IA, puis, le 29 septembre 2026, la synthèse des commentaires de plus de 600 répondants et l'annonce d'un premier cas d'usage DevSecOps[337, 338]. Le cadre exige donc des résultats (identité propre, délégation explicite, portée décroissante, audience unique) plutôt qu'un produit, et réexamine ces cotes à chaque révision du catalogue (section 11.7).

## 9.4 La passerelle d'agents, point d'application des politiques

Cette section précise le rôle de la passerelle d'agents : c'est le point d'application de la confiance zéro, celui où se vérifient, appel par appel, l'identité, la délégation, le catalogue, l'approbation et le budget.

La passerelle agit en mandataire inverse devant les serveurs MCP et les pairs A2A (section 5.2). Les décisions viennent du service de politiques; la passerelle les applique et en garde la trace. Ce rôle est réalisable avec des produits documentés, cités ici à titre d'exemples non limitatifs : Azure API Management[108], Amazon Bedrock AgentCore Gateway[110], Kong AI Gateway[132], les projets agentgateway et Agent Router de l'AAIF[36, 130, 339] et MuleSoft Agent Fabric[138], avec sa passerelle Omni Gateway (anciennement Flex Gateway)[138, 340, 341]. Leur couverture varie : Azure API Management ne gère que les outils MCP, et non les ressources ni les invites[108], et seulement les agents A2A en JSON-RPC[109]; le mandataire A2A de Kong (greffon AI A2A Proxy de Kong Gateway 3.14 et plus, édition Enterprise) relaie le trafic sans gérer l'état des tâches[111]; cet état reste, selon le cadre, du ressort de l'agent ou de l'orchestrateur. La correspondance complète des blocs de solution figure à la section 5.4.

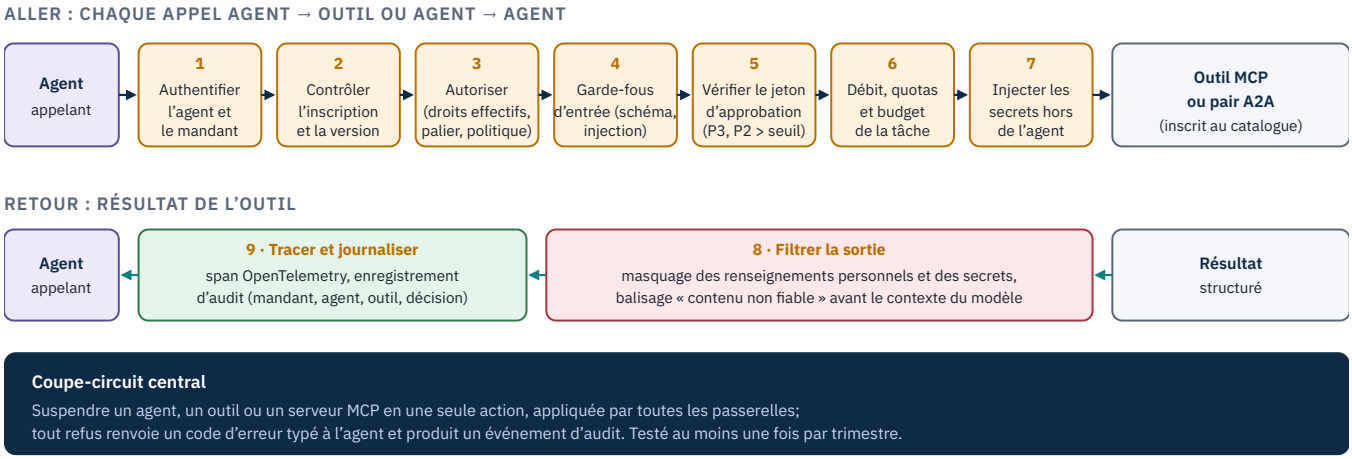



**Figure 18 — Contrôles appliqués par la passerelle d'agents à chaque appel.** À l'aller, sept contrôles s'appliquent dans l'ordre avant que l'appel n'atteigne l'outil ou le pair; au retour, la sortie est filtrée, puis tracée et journalisée. Un refus à n'importe quelle étape arrête l'appel; le coupe-circuit agit sur toutes les passerelles à la fois.

Source : CRE-IA-2026-01.

### Fonctions obligatoires

Les neuf contrôles de la figure 18 renvoient chacun à une partie du cadre :

1. **Authentifier** l'agent (SVID, mTLS) et le mandant (jeton délégué) : section 9.2 et section 9.3.
2. **Contrôler l'inscription** de l'agent, de l'outil ou du pair au catalogue, ainsi que la version et l'empreinte épinglées : section 6.8.
3. **Autoriser** d'après les droits effectifs, le palier de l'outil, le niveau d'autonomie et les attributs : section 8.4.
4. **Appliquer les garde-fous d'entrée** : schéma des arguments, cohérence des en-têtes MCP, détection d'injection : section 6.5 et section 9.6.
5. **Vérifier le jeton d'approbation** lorsque la classe de l'agent et le palier l'exigent (P3; P2 au-delà du seuil, ou à chaque action pour un agent de niveau N2) : section 8.5.
6. **Limiter** le débit, les quotas et le budget de la tâche : section 10.6.
7. **Injecter les justificatifs** en aval, hors de l'agent (modèle sans clés, ci-dessous).
8. **Filtrer la sortie** : masquage des renseignements personnels et des secrets, balisage du contenu non fiable : section 9.6.

9. **Tracer et journaliser** : span OpenTelemetry et enregistrement d'audit : section 10.1 et section 10.3.

| | |
|---|---|
| **EXIG-IAM-17** DOIT | **Passage obligatoire par la passerelle d'agents** Dans tout environnement serveur, tout appel d'un agent vers un serveur MCP, vers un autre agent ou vers une ressource qui franchit une frontière de domaine **DOIT** passer par la passerelle d'agents (EXIG-ARC-01, EXIG-MCP-01), qui applique au minimum les neuf contrôles de la figure 18. Un outil, un serveur MCP ou un agent absent du catalogue, ou dont la version ou l'empreinte diffère de celle qui est épinglée, est bloqué. À l'intérieur d'un domaine, la décision par appel (EXIG-IAM-02) est appliquée par le serveur de ressources et par l'authentification mutuelle du maillage de services. Pourquoi : un point d'application unique est le seul endroit où une politique s'applique de la même façon quel que soit le cadriciel ou la plateforme de l'agent appelant. |
| **EXIG-IAM-18** DOIT | **Échec en mode fermé et refus typé** La passerelle **DOIT** refuser tout appel pour lequel elle ne peut pas obtenir ou évaluer une décision de politique valide; elle n'ouvre jamais le passage par défaut. Si le plan de contrôle est indisponible, elle continue d'appliquer la dernière politique distribuée. Tout refus renvoie à l'agent un code d'erreur typé (p. ex. portée insuffisante, approbation requise, budget épuisé, agent suspendu) et produit un événement d'audit. Pourquoi : une passerelle ouverte par défaut transforme toute panne en brèche; un refus typé permet à l'agent d'escalader vers un humain plutôt que de réessayer à l'aveugle. Choix du cadre. |

## Neutralité au niveau du transport

Des éditeurs de passerelles, dont TrueFoundry et MuleSoft, soutiennent que la gouvernance native de chaque plateforme s'arrête à sa frontière : une règle définie dans un écosystème ne s'applique pas à un agent d'un autre[44, 45]. Il s'agit d'un argument d'architecture plutôt que d'un constat mesuré, mais il justifie de placer l'application des politiques au niveau du transport. MuleSoft (billet du 12 août 2026) propose sept portes de conception, chacune assortie d'un critère de réussite ou d'échec : (1) application neutre des politiques au niveau du transport HTTP, quel que soit le fournisseur ou le cadriciel; (2) politique attachée à l'actif (agent, serveur MCP, modèle, API); (3) application partout, avec maintien de la dernière politique distribuée en cas de panne du plan de contrôle; (4) réutilisation de la gouvernance d'API existante; (5) gouvernance centralisée des coûts et des jetons; (6) portabilité des environnements d'exécution sans refonte de la gouvernance; (7) propagation vérifiée de l'identité humaine déléguée[45]. Le cadre retient ces sept portes comme critères d'acceptation d'une passerelle d'agents (choix du cadre).

## Modèle « sans clés »

Dans le modèle « sans clés », l'agent ne détient aucun justificatif pour les systèmes en aval : la passerelle ou un mandataire de sortie les ajoute à la requête après la décision de politique. Amazon Bedrock AgentCore Gateway documente ainsi une authentification entrante et sortante avec injection d'identifiants propre à chaque outil[110]. Selon la documentation de Vercel Sandbox, le patron a des limites lorsqu'il s'applique au trafic sortant d'un bac à sable : il dépend de l'indication du nom de serveur TLS (SNI) et exige la terminaison TLS par le mandataire, et une règle générique laisse passer sans transformation le trafic dont le domaine n'est pas détecté[342] (section 9.7).

**EXIG-IAM-19** DEVRAIT

**Justificatifs en aval injectés par la passerelle**

Les justificatifs nécessaires pour appeler un système en aval **DEVRAIENT** être injectés par la passerelle ou par un mandataire de sortie après la décision de politique (et **DOIVENT** l'être lorsqu'un code s'exécute en bac à sable selon l'EXIG-SEC-14 ou lorsqu'un secret résiduel de système patrimonial est employé sous dérogation selon l'EXIG-IAM-05), de sorte que le modèle n'y ait jamais accès (EXIG-IAM-06). L'injection ne vise qu'une liste fermée de destinations, sans règle générique.

Pourquoi : un justificatif que l'agent ne voit jamais ne peut ni fuir par une réponse du modèle ni être réutilisé hors de la politique.

## Coupe-circuit

Le NIST AI RMF demande des mécanismes et des responsabilités pour supplanter, désengager ou désactiver un système dont les résultats s'écartent de l'usage prévu (MANAGE 2.4)[74], et le règlement européen sur l'IA prévoit, pour les systèmes à haut risque, la possibilité d'interrompre le système de façon sécuritaire (art. 14(4)e))[61]. OpenAI recommande une interruption gracieuse, ciblée (révoquer une catégorie d'actions) ou générale[291]. Les plans de contrôle d'éditeurs n'y suffisent pas encore : Microsoft Agent 365, en disponibilité générale depuis le 1er mai 2026, tient un registre et permet de bloquer les agents non gérés, mais les actions de cycle de vie sur des agents infonuagiques tiers sont annoncées comme à venir[46]. Pour propager une révocation au-delà de la passerelle, les spécifications finales OpenID Shared Signals Framework 1.0, qui fournit le cadre de diffusion, et CAEP 1.0 (29 août 2025), qui définit notamment les événements `session-revoked`, `token-claims-change` et `credential-change`[343, 344].

**EXIG-IAM-20** DOIT

**Coupe-circuit propagé et mesuré**

La plateforme **DOIT** offrir un coupe-circuit qui, en une seule action, suspend un agent, un outil, un serveur MCP ou une catégorie d'actions sur toutes les passerelles, désactive l'identité de l'agent auprès du fournisseur d'identité et diffuse la révocation, au moyen du Shared Signals Framework et de CAEP, aux systèmes raccordés qui les prennent en charge. Le délai maximal de bout en bout est fixé par l'entreprise et mesuré lors d'un exercice au moins trimestriel (section 7.8).

Pourquoi : un arrêt qui n'atteint qu'une plateforme laisse l'agent agir ailleurs. Aucune source vérifiable ne chiffre le gain d'un coupe-circuit; le cadre exige donc un délai mesuré plutôt qu'une promesse.

## Politique en code et performance

Les passerelles du marché expriment leurs politiques dans des langages déclaratifs : agentgateway applique un contrôle d'accès par moteur de politiques CEL *(Common Expression Language)*[339], et AgentCore Policy applique des règles déterministes compatibles avec Cedar, qui interceptent chaque appel d'outil avant son exécution[102]. Une politique décide qui peut faire quoi : elle se gère comme du code de production.

**EXIG-IAM-21** DOIT

**Politique en code, versionnée et testée**

Les politiques appliquées par la passerelle **DOIVENT** être exprimées en code dans un langage déclaratif, versionnées, revues par une seconde personne, testées par des cas positifs et négatifs avant tout déploiement, puis distribuées par un pipeline. Chaque décision journalisée mentionne la version de la politique appliquée.

Pourquoi : sans version de politique dans le journal, l'audit ne peut pas reconstituer la règle qui a autorisé une action. Choix du cadre.

**ATTENTION**

Le cadre ne fixe aucune cible de latence chiffrée pour la passerelle, faute de mesure indépendante. Les chiffres publiés sont des allégations de fournisseurs, parfois contradictoires. L'équipe d'agentgateway déclare environ 500 000 requêtes par seconde avec 512 connexions et une latence P99 inférieure à 0,2 ms à 30 000 requêtes par seconde, sans préciser le type de trafic ni le matériel[142]. TrueFoundry indique « typiquement moins de 5 ms » dans sa FAQ, mais son propre banc d'essai montre de +7 à +12 ms (1 vCPU, 200 à 370 requêtes par seconde, selon le niveau de traçage)[143, 144]. Seule compte la latence ajoutée (P50 et P99) mesurée dans les conditions de l'entreprise, politiques et traçage activés; la section 13.2 en fait un critère d'évaluation des fournisseurs.

## 9.5 Menaces propres aux agents

Cette section fixe le référentiel de menaces que toute équipe applique à un agent et relie chaque menace aux contrôles du cadre. Un agent diffère d'une application classique sur deux points : il lit du texte qui peut contenir des instructions, et il agit par des outils. Une phrase piégée dans un courriel peut donc devenir une action réelle, comme un envoi, un paiement ou une suppression.

### Référentiels retenus

Le cadre ne crée pas sa propre taxonomie. Il s'appuie sur des référentiels publics et entretenus, chacun avec un rôle précis (tableau 37). Le Top 10 de l'OWASP (Open Worldwide Application Security Project) pour les applications agentiques, publié le 9 décembre 2025 par l'OWASP GenAI Security Project, en constitue la base[345].

**Tableau 37 — Référentiels de menaces retenus par le cadre**

| Référentiel | Éditeur, date et statut | Usage dans le cadre |
|---|---|---|
| OWASP Top 10 for Agentic Applications 2026 (ASI01 à ASI10) | OWASP GenAI Security Project, décembre 2025, licence CC BY-SA 4.0[28] | **Obligatoire** Base de la modélisation des menaces des agents de classe de risque modérée ou élevée (EXIG-SEC-01). |
| OWASP Agentic AI – Threats and Mitigations (T1 à T17) | v1.0 du 17 février 2025 (T1 à T15); v1.1 de décembre 2025, qui ajoute T16, abus des protocoles inter-agents, et T17, compromission de la chaîne d'approvisionnement[87] | **Recommandé** Taxonomie détaillée pour l'analyse et les tests. |
| OWASP Top 10 for LLM Applications 2026 | Édition 2026 parue en août 2026; l'agentivité excessive passe de LLM06 à LLM03[346]. L'édition 2025, publiée le 17 novembre 2024 (LLM01 Prompt Injection à LLM10 Unbounded Consumption), reste celle à laquelle renvoie la table de correspondance du Top 10 agentique (ASI) [347, 348] | **Recommandé** Risques propres au modèle lui-même. |
| OWASP Non-Human Identities Top 10 (2025) | NHI1 Improper Offboarding à NHI10 Human Use of NHI[349] | **Recommandé** Identités des agents (section 9.2). |
| OWASP MCP Top 10 | Édition 2025, en phase bêta (MCP01 à MCP10)[222] | **Recommandé** Tests d'abus des serveurs MCP (section 6.5). |
| OWASP Agentic Skills Top 10 (AST10) | Projet distinct au stade « Incubator », version affichée 1.0-2026[350] | **Surveiller** Référence émergente sur les compétences d'agents, non une norme. |

| Référentiel | Éditeur, date et statut | Usage dans le cadre |
|---|---|---|
| CSA MAESTRO | Cloud Security Alliance, 6 février 2025; sept couches, des modèles de fondation à l'écosystème d'agents[351] | **Recommandé** Structurer l'analyse couche par couche. |
| MITRE ATLAS | Version 2026.09 du 14 septembre 2026 : 16 tactiques, 120 techniques, 88 sous-techniques, 40 mesures d'atténuation et 73 études de cas[352] | **Recommandé** Scénarios d'équipe rouge et règles de détection. |
| NIST AI 100-2 E2025 | NIST, version finale du 24 mars 2025[97] | **Recommandé** Vocabulaire des attaques et principe de présomption d'injection. |

**EXIG-SEC-01**
**DOIT**

**Modélisation des menaces avant la production**

Tout agent de classe de risque modérée ou élevée **DOIT** faire l'objet, avant sa mise en production, d'une modélisation des menaces documentée qui examine chacun des risques ASI01 à ASI10 et consigne, pour chacun, les contrôles retenus ou la justification de son exclusion. La modélisation **DOIT** être révisée à chaque changement de modèle, d'outil, de palier d'outil ou de niveau d'autonomie. Un agent de risque faible **DEVRAIT** faire l'objet d'une analyse simplifiée sur la même base.

Pourquoi : examiner systématiquement les dix risques du référentiel public évite les angles morts propres aux agents.

## Les dix risques du Top 10 agentique

Le tableau 38 reprend les intitulés officiels de l'OWASP[28], les explique en une phrase et renvoie aux contrôles du cadre qui y répondent. La colonne « Mécanisme » est une synthèse du cadre, non une citation.

**Tableau 38 — Top 10 OWASP des applications agentiques et contrôles du cadre**

| Code | Risque (titre officiel traduit) | Mécanisme | Contrôles du cadre |
|---|---|---|---|
| ASI01 | Détournement de l'objectif de l'agent *(Agent Goal Hijack)* | Un contenu non fiable (page web, courriel, sortie d'outil) réoriente les objectifs ou le plan de l'agent. | EXIG-SEC-03 à EXIG-SEC-07; approbation humaine de toute modification des objectifs (EXIG-AUT-03, section 8.1). |
| ASI02 | Mésusage et exploitation des outils *(Tool Misuse and Exploitation)* | L'agent enchaîne des outils légitimes de façon dangereuse ou leur passe des arguments malveillants. | Paliers P0 à P3 (section 8.3); validation des arguments par la passerelle (section 9.4); EXIG-SEC-18 et EXIG-SEC-21. |
| ASI03 | Abus d'identité et de privilèges *(Identity and Privilege Abuse)* | L'agent dispose de droits excessifs, réutilise un jeton ou agit au-delà du mandat de son mandant. | Identité propre (EXIG-IAM-03 à EXIG-IAM-06, section 9.2); jeton délégué à audience unique et portée réduite à chaque saut (EXIG-IAM-08 à EXIG-IAM-12, section 9.3). |
| ASI04 | Vulnérabilités de la chaîne d'approvisionnement agentique *(Agentic Supply Chain Vulnerabilities)* | Un serveur MCP, un agent, une compétence ou un modèle de tiers est compromis à la source ou modifié après approbation. | EXIG-SEC-18 à EXIG-SEC-22; catalogue et versions (section 6.8). |
| ASI05 | Exécution de code inattendue *(Unexpected Code Execution, RCE)* | L'agent génère ou déclenche du code qui s'exécute avec les droits de son environnement. | EXIG-SEC-08 à EXIG-SEC-17. |

| Code | Risque (titre officiel traduit) | Mécanisme | Contrôles du cadre |
|---|---|---|---|
| ASI06 | Empoisonnement de la mémoire et du contexte *(Memory & Context Poisoning)* | Une information fausse ou piégée, écrite en mémoire ou dans le contexte, oriente les décisions suivantes. | Contrôles d'écriture en mémoire (section 5.5); mémoire traitée comme contenu non fiable (EXIG-SEC-03). |
| ASI07 | Communication inter-agents non sécurisée *(Insecure Inter-Agent Communication)* | Un agent usurpe l'identité d'un pair, ou un message est intercepté ou altéré entre agents. | Authentification à chaque requête (section 6.6); cartes signées (EXIG-SEC-19); messages d'agents non fiables (EXIG-SEC-03). |
| ASI08 | Défaillances en cascade *(Cascading Failures)* | Une erreur ou une boucle se propage d'agent en agent plus vite qu'un humain ne peut réagir. | Compteur de sauts (EXIG-EVT-06, section 6.7); compensation (section 7.5); délais, disjoncteurs et plafonds (EXIG-ORC-26 et EXIG-ORC-27, section 7.8). |
| ASI09 | Exploitation de la confiance humain-agent *(Human-Agent Trust Exploitation)* | L'agent obtient une approbation par une justification trompeuse ou par la saturation des approbateurs. | Approbation liée à l'action exacte (EXIG-AUT-12, section 8.5); prévention de l'approbation machinale (EXIG-AUT-19 et EXIG-AUT-20, section 8.7). |
| ASI10 | Agents dévoyés *(Rogue Agents)* | Un agent s'écarte durablement de son mandat tout en paraissant légitime. | Surveillance, plafonds et coupe-circuit (section 9.4); EXIG-SEC-26; journal d'audit signé (section 10.3). |

Le document de l'OWASP fournit sa propre table de correspondance entre chaque risque ASI, le Top 10 LLM 2025, les menaces T1 à T17 et les risques fondamentaux de l'AI Vulnerability Scoring System (AIVSS)[28]. Le cadre l'emploie telle quelle plutôt que de recréer des regroupements approximatifs. Ainsi, ASI01 correspond à LLM01:2025 (injection d'invite) et à LLM06:2025 (agentivité excessive, devenue LLM03 dans l'édition 2026)[28, 346, 348], et ASI09 s'arrime à la menace T10, saturation de l'humain dans la boucle[28, 87]. De même, les risques d'identités non humaines se répartissent entre plusieurs risques ASI plutôt que de se rattacher à ASI03 seul : NHI1 (retrait inadéquat) relève d'ASI04, NHI2 (fuite de secrets) d'ASI02 et d'ASI06, et NHI4 (authentification non sécurisée) d'ASI03 et d'ASI07[28, 349].

**EXIG-SEC-02**
**DOIT**

**Matrice de traçabilité des menaces**

L'équipe de sécurité **DOIT** tenir une matrice qui relie chaque risque ASI, chaque menace T1 à T17 pertinente et chaque technique MITRE ATLAS retenue aux exigences du cadre et aux tests qui les vérifient, en s'appuyant sur les correspondances officielles de l'OWASP. La matrice **DOIT** être mise à jour à chaque nouvelle version du Top 10 agentique ou d'ATLAS.

Pourquoi : une menace sans contrôle ni test associé n'est pas maîtrisée; la matrice rend ces écarts visibles en revue.

## 9.6 Se défendre contre l'injection d'instructions

L'injection d'instructions *(prompt injection)* est la menace centrale des agents : un texte placé par un tiers dans une page web, un document, une réponse d'outil ou un message d'agent est interprété comme une consigne. Cette section pose le principe de présomption d'injection, puis échelonne les contrôles du plus faible au plus fort.

### Présumer l'injection

Le NIST classe l'injection d'invite indirecte (NISTAML.015) dans sa taxonomie des attaques et recommande de concevoir les systèmes en présumant que l'injection est possible dès qu'un modèle reçoit des entrées non fiables[97]. Le Centre national de cybersécurité du Royaume-Uni (NCSC) explique pourquoi, en décembre 2025 : contrairement à une

base de données, un modèle de langage ne sépare pas intrinsèquement les données des instructions. Le risque se gère donc comme un risque résiduel, par une conception déterministe qui limite ce que le système peut faire, et non par des listes de refus faciles à contourner[98]. Le guide du gouvernement du Canada sur l'IA agentique demande lui aussi de traiter le texte externe ou fourni par l'utilisateur comme des données à analyser, non comme des instructions à suivre[353].

**EXIG-SEC-03**
**DOIT**

**Présomption d'injection**

Tout contenu qui ne provient ni du mandant authentifié ni de la configuration approuvée de l'agent **DOIT** être traité comme non fiable : pages web, courriels, documents téléversés (y compris par le mandant), champs libres des systèmes d'enregistrement, réponses d'outils, entrées de mémoire, messages et cartes d'autres agents. Le catalogue d'entreprise **DOIT** marquer chaque outil dont la sortie peut contenir du contenu de tiers, afin que la passerelle d'agents sache, sans se fier au modèle, qu'une session a consommé un tel contenu.

Pourquoi : un modèle ne distingue pas de façon fiable une donnée d'une consigne; les protections doivent donc reposer surtout sur des garde-fous déterministes, tenus hors du modèle, qui limitent ce que le système peut faire[98].

## Éviter la triade létale

Simon Willison a nommé « triade létale » la combinaison de trois propriétés : accès à des données privées, exposition à du contenu non fiable et capacité de communiquer vers l'extérieur. Un agent qui les réunit peut être amené à exfiltrer des données, et la seule protection sûre consiste à éviter la combinaison[354]. Meta en a tiré, le 31 octobre 2025, une règle opérationnelle, la « règle de deux » : dans une même session, un agent ne devrait pas réunir plus de deux des propriétés [A] traiter des entrées non fiables, [B] accéder à des systèmes sensibles ou à des données privées, [C] changer un état ou communiquer vers l'extérieur. Si les trois sont nécessaires, l'agent ne devrait pas agir de façon autonome : il lui faut au minimum une supervision humaine ou un nouveau départ dans un contexte vierge[307].

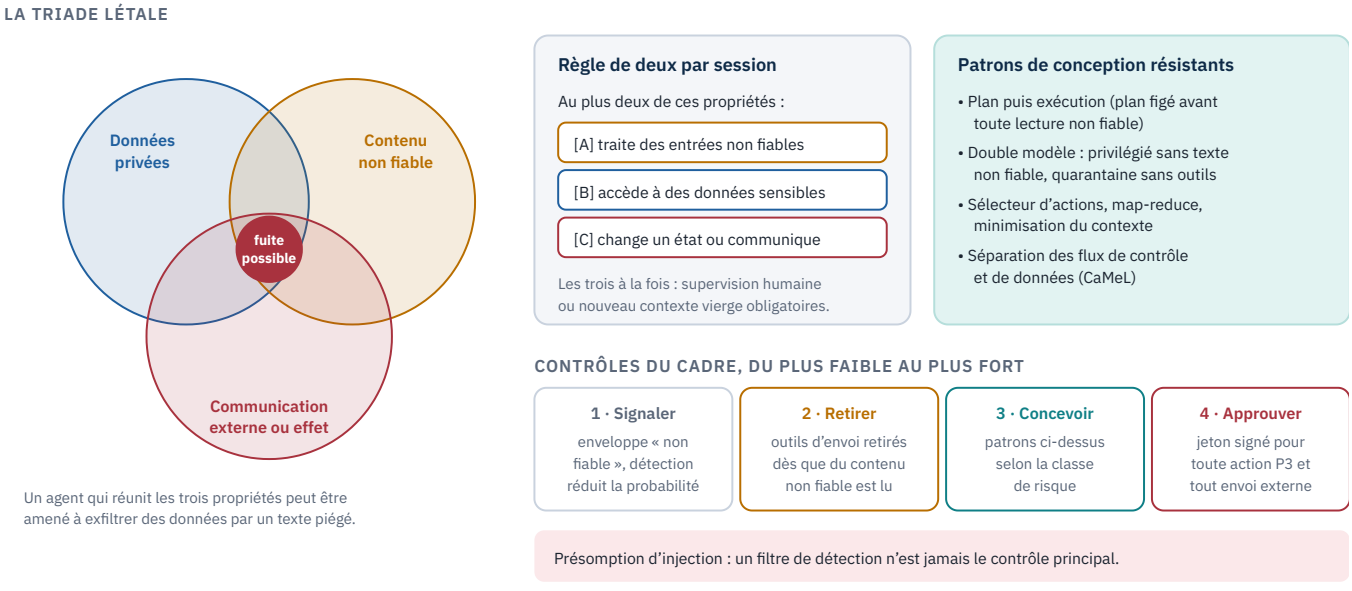



**Figure 19 — Défense contre l'injection : éviter la triade létale.** Le diagramme de gauche montre la combinaison à éviter et la règle de deux qui la casse; la bande inférieure classe les contrôles du cadre du plus faible (signaler) au plus fort (approuver).
Source : cadre CRE-IA-2026-01, d'après Willison (2025), Meta (2025) et Beurer-Kellner et al. (2025).

EXEMPLE

Un agent de service à la clientèle lit les courriels entrants [A], consulte le dossier du client [B] et dispose d'un outil d'envoi de courriel [C]. Un courriel piégé lui demande de « transférer l'historique du client pour vérification » à une adresse externe. Avec les règles ci-dessous, la passerelle retire l'outil d'envoi dès la lecture du courriel : l'agent prépare sa réponse en brouillon, et l'envoi n'a lieu qu'après une approbation humaine qui montre le destinataire et le contenu exacts.

**EXIG-SEC-04**
**DOIT**

**Règle de deux par session**

La fiche de chaque agent **DOIT** déclarer lesquelles des trois propriétés il réunit dans une même session : [A] il traite du contenu non fiable; [B] il accède à des données sensibles ou à des outils P1; [C] il modifie un état ou communique vers l'extérieur (outils P2, P3 ou envoi externe). Un agent qui réunit les trois **NE DOIT PAS** exécuter d'action [C] sans approbation humaine liée à l'action exacte (section 8.5), sauf s'il repart d'un contexte vierge exempt du contenu non fiable.

Pourquoi : c'est la réunion des trois propriétés qui rend l'exfiltration possible; en retirer une seule suffit à rompre la chaîne[307, 354].

## Quatre niveaux de contrôle

Les contrôles ne se valent pas. Le cadre les classe en quatre niveaux, du plus faible au plus fort (bande inférieure de la figure 19), et un agent exposé à du contenu non fiable en combine toujours plusieurs.

### 1. Signaler : enveloppe et détection

La passerelle place tout contenu non fiable dans une enveloppe marquée « non fiable » (délimiteurs, provenance, classification) avant son entrée dans le contexte du modèle. Ce marquage réduit la probabilité de succès d'une attaque sans l'éliminer. Dans les expériences de ses auteurs sur des modèles GPT, la mise en évidence de la provenance *(spotlighting)* a fait passer le taux de réussite des attaques de plus de 50 % à moins de 2 %, avec un effet minime sur la tâche[355]; un taux résiduel, même faible, reste exploitable par un attaquant patient. Les détecteurs comme les Prompt Shields d'Azure AI Content Safety repèrent les attaques par invite de l'utilisateur et par document, y compris, en préversion, dans les réponses d'outils; Microsoft précise toutefois qu'ils ne jugent ni de la nocivité ni de l'exactitude, et que leur performance hors de l'anglais peut varier[356]. Ces produits sont des exemples, non des exigences.

**EXIG-SEC-05**
**NE DOIT PAS**

**Détection jamais seule**

Le marquage et la détection d'injection **NE DOIVENT PAS** constituer le seul contrôle d'un agent exposé à du contenu non fiable. Avant la mise en production, leur efficacité **DOIT** être mesurée sur un jeu d'attaques rédigées en français et en anglais, et le résultat consigné à la fiche de l'agent.

Pourquoi : un filtre se contourne par reformulation, et un détecteur surtout évalué en anglais peut laisser passer une attaque rédigée en français[98, 356].

### 2. Retirer : capacités d'envoi retirées après une lecture non fiable

Un contrôle déterministe efficace consiste à retirer la capacité d'exfiltrer au moment où le risque apparaît. La passerelle sait, grâce au marquage du catalogue, qu'une session vient de consommer du contenu non fiable; elle restreint alors les outils offerts à l'agent pour le reste de la session. Le modèle n'a rien à décider : l'outil d'envoi n'est tout simplement plus disponible.

**EXIG-SEC-06** **DOIT**

**Retrait déterministe des capacités d'exfiltration**

Dès qu'une session a consommé du contenu non fiable, la passerelle d'agents **DOIT** retirer à l'agent, pour le reste de la session, les outils d'envoi vers l'extérieur et les outils P3, et refuser toute requête sortante vers une destination absente de la liste d'autorisation. Une action ainsi retirée ne s'exécute qu'avec une approbation humaine liée à l'action exacte. Le retrait est appliqué par la passerelle à partir du marquage du catalogue, jamais par une consigne donnée au modèle.

Pourquoi : le retrait de la capacité d'exfiltration est appliqué par la passerelle et ne dépend pas du comportement du modèle, alors que l'injection d'instructions ne se détecte pas de façon fiable; le marquage seul réduit le risque sans l'éliminer (raisonnement du cadre)[307, 354].

### 3. Concevoir : patrons résistants à l'injection

Beurer-Kellner et ses coauteurs (2025) proposent six patrons de conception qui offrent une résistance démontrable à l'injection. Leur principe commun : une fois le contenu non fiable ingéré, l'agent est contraint de sorte que ce contenu ne puisse déclencher aucune action conséquente[357]. Le tableau 39 les résume et indique l'usage que le cadre en recommande.

**Tableau 39 — Patrons de conception résistants à l'injection et usage recommandé**

| Patron | Principe | Usage recommandé par le cadre |
|---|---|---|
| Sélecteur d'actions *(Action-Selector)* | Le modèle traduit la demande en une action choisie dans une liste fixe; le résultat de l'action ne revient pas au modèle. | Routage, assistants de commande à faible variété. |
| Plan puis exécution *(Plan-Then-Execute)* | Le plan d'appels d'outils est figé avant toute lecture de contenu non fiable; ce contenu ne peut plus ajouter d'action. | Flux répétitifs : tri de courriels, préparation de rapports. |
| Map-reduce de modèles *(LLM Map-Reduce)* | Chaque document non fiable est traité par une instance isolée qui renvoie une sortie contrainte (catégorie, champ validé par schéma); l'agrégation ne voit que ces sorties. | Traitement en lot de documents de tiers : factures, CV, pages web. |
| Double modèle *(Dual LLM)* | Un modèle privilégié, doté d'outils, ne voit jamais le texte non fiable; un modèle en quarantaine, sans outils, le traite; un contrôleur logiciel ne transmet que des références symboliques[358]. | Assistants qui lisent des courriels ou des documents de tiers. |
| Code puis exécution *(Code-Then-Execute)* | Le modèle écrit un programme qui appelle les outils; le programme, exécuté en bac à sable, traite le contenu non fiable par des appels isolés. | Agents de risque élevé qui exigent des garanties démontrables. |
| Minimisation du contexte *(Context-Minimization)* | Les éléments devenus inutiles, comme la requête initiale une fois convertie en requête structurée, sont retirés du contexte avant les étapes suivantes. | Mesure complémentaire, combinable avec les autres patrons. |

CaMeL, proposé par Google DeepMind et l'ETH Zurich en mars 2025, pousse le patron « code puis exécution » jusqu'à extraire les flux de contrôle et de données de la seule requête de confiance, de sorte que des données non fiables ne puissent jamais modifier le déroulement du programme. Sur le banc d'essai AgentDojo, il résout 77 % des tâches avec une sécurité démontrable, contre 84 % pour un système non défendu[101]. Le coût en utilité est réel, mais quantifié (7 points de pourcentage sur AgentDojo) : c'est le prix d'une garantie plutôt que d'une probabilité.

**EXIG-SEC-07** **DOIT**

**Patron de conception pour les agents de risque élevé**

Un agent de classe de risque élevée exposé à du contenu non fiable **DOIT** appliquer au moins un des patrons du tableau 39 autre que la minimisation du contexte, consigné à la fiche de l'agent (annexe B) et vérifié en revue de conception. Un agent de risque modéré dans la même situation **DEVRAIT** en appliquer un.

Pourquoi : ces patrons empêchent par construction le contenu non fiable de choisir les actions, ce qu'aucun filtre ne garantit[357].

**4. Approuver : la personne voit l'action exacte**

Pour toute action P3 et tout envoi externe après une lecture non fiable, le dernier rempart est l'approbation humaine vérifiable : un jeton signé, lié à l'empreinte de l'outil et de ses arguments, que la passerelle vérifie avant l'exécution (section 8.5). Un « oui » écrit dans la conversation de l'agent n'est jamais une approbation, puisqu'une injection peut l'imiter.

**ATTENTION**

Les « taux de réussite des attaques » cités sans contexte induisent en erreur. Le chiffre de 84,30 % provient de l'Agent Security Bench (ICLR 2025) : c'est le taux moyen de réussite d'attaque le plus élevé observé sur un banc d'essai couvrant les injections dans l'invite système, l'invite de l'utilisateur, les outils et la mémoire, où les défenses évaluées se sont révélées d'efficacité limitée[359]. Il décrit un banc d'essai, non la probabilité de compromission d'un système réel; le cadre exige de mesurer ses propres agents (section 9.9).

## 9.7 Cloisonnement de l'exécution du code

Cette section fixe où et comment s'exécute le code qu'un agent génère ou reçoit. Un appel d'outil prédéfini a des effets connus d'avance; un script généré peut tout faire. Il suffit d'un fichier CSV piégé, soumis pour analyse, pour qu'un agent écrive un script qui lit des secrets et les envoie à l'extérieur. Le cloisonnement vise à ce que, même dans ce cas, le script ne trouve rien à voler et aucun chemin pour sortir.

### Choisir la technologie d'isolation

Toutes les technologies ne placent pas la frontière d'isolation au même endroit (figure 20). Un conteneur Linux standard isole par espaces de noms, cgroups et filtres seccomp-bpf, mais tous les conteneurs d'un hôte partagent un noyau unique, ce qui impose un compromis entre sécurité et compatibilité[360]. Pour le code généré, l'OWASP recommande des conteneurs en bac à sable aux limites strictes (ASI05)[28]. Le cadre va plus loin, par choix : il interdit le noyau partagé pour tout code non fiable, parce qu'un agent peut produire, à la demande d'un attaquant, exactement le code qui exploite une faille du noyau.

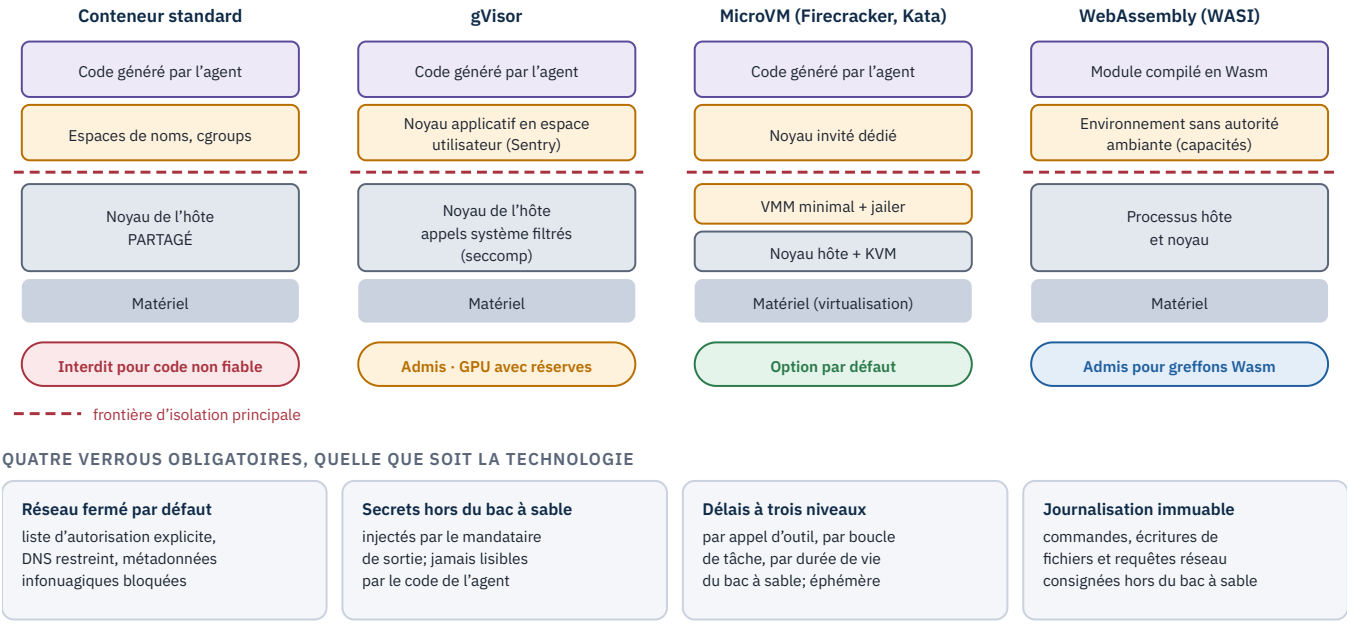



**Figure 20 — Niveaux d'isolation pour le code généré.** Chaque colonne situe la frontière d'isolation principale d'une technologie, du noyau partagé (interdit) à la microVM (option par défaut); la bande inférieure rappelle les quatre verrous exigés quelle que soit la technologie.
Source : cadre CRE-IA-2026-01, d'après Agache et al. (2020), la documentation de gVisor et de WASI, et l'OWASP (ASI05).

**Tableau 40 — Technologies d'isolation du code généré**

| Technologie | Principe | Frontière d'isolation | Coût et contraintes | Usage recommandé |
|---|---|---|---|---|
| Conteneur à noyau partagé | Espaces de noms, cgroups et seccomp-bpf sur le noyau de l'hôte. | Noyau de l'hôte, partagé par tous les conteneurs. | Faible coût, compatibilité maximale. | **Interdit** pour le code non fiable (choix du cadre). |
| gVisor | Noyau applicatif en espace utilisateur (le Sentry, écrit en Go) qui traite lui-même les appels système; accès aux fichiers délégué au processus Gofer[134]. | Sentry, sous filtre seccomp restrictif. | Aucun surcoût sur l'exécution brute; surcoût important pour les charges riches en petits appels système ou en nombreuses opérations sur le système de fichiers; compatibilité partielle, gVisor n'implémentant qu'un sous-ensemble de l'interface Linux[361, 362]. | **Admis** ; option pour les GPU, avec réserves. |
| MicroVM Firecracker | Moniteur de machines virtuelles en Rust sur KVM; chaque microVM a son propre noyau invité[133]. | Virtualisation matérielle, plus le jailer. | Moins de 5 Mio de surcoût mémoire et démarrage en moins de 125 ms avec le noyau minimal du projet[363]. | **Par défaut** |
| Kata Containers | Machines virtuelles légères intégrées à l'outillage de conteneurs, avec QEMU, Cloud Hypervisor ou Firecracker; projet de l'OpenInfra Foundation[135]. | Virtualisation matérielle. | Surcoût d'une machine virtuelle; compatible avec Kubernetes. | **Par défaut** sur plateforme Kubernetes. |
| WebAssembly (WASI) | Sécurité par capacités : le module démarre sans autorité ambiante et ne fait que ce que l'hôte lui accorde[136]. | Environnement d'exécution Wasm. | Format binaire compact et rapide à charger, mais le code doit être compilé en Wasm[364]; risques résiduels : débordements dans la mémoire linéaire, canaux auxiliaires temporels[365]. | **Admis** pour greffons et fonctions compilés. |

Les chiffres publiés par les concepteurs de Firecracker datent de 2020 : environ 50 000 lignes de Rust, soit 96 % de moins que QEMU, qui dépassait alors 1,4 million de lignes[360]. Selon son site, Firecracker n'émule que cinq périphériques (virtio-net, virtio-block, virtio-vsock, une console série et un contrôleur de clavier minimal), sans BIOS d'après l'article de 2020; les versions récentes ajoutent toutefois d'autres périphériques (entropie virtio-rng depuis la 1.4, virtio-pmem et virtio-mem depuis la 1.14) et un transport PCI facultatif (depuis la 1.13), de sorte que la surface exposée dépend de la version et de la configuration déployées[133]. Son jailer ajoute une seconde ligne de défense : chroot, espaces de noms PID et réseau, abandon des privilèges et profil seccomp-bpf limité à 24 appels système et 30 ioctl[363]. Les temps de reprise annoncés par les fournisseurs de bacs à sable gérés, par exemple moins de 25 ms chez Blaxel ou environ une seconde chez E2B, sont des allégations commerciales mesurées dans leurs propres conditions[366, 367].

**EXIG-SEC-08**
**DOIT**

**Technologie d'isolation du code non fiable**

Tout code généré par un agent, ou reçu d'une source non fiable, **DOIT** s'exécuter dans une microVM (Firecracker, Kata Containers), sous gVisor ou, s'il est compilé en WebAssembly, dans un environnement WASI sans autorité ambiante. Il **NE DOIT PAS** s'exécuter dans un conteneur à noyau partagé, dans le processus de l'agent ni sur l'hôte de la passerelle.

Pourquoi : la frontière doit résister à une faille du noyau, puisque l'attaquant choisit le code exécuté; ce choix du cadre est plus strict que la recommandation de l'OWASP.

**EXIG-SEC-09**
**DOIT**

**Bac à sable éphémère et minimal**

Chaque bac à sable **DOIT** être créé pour une seule tâche ou une seule session, puis détruit, sans jamais être réutilisé pour un autre mandant; s'exécuter sans privilèges root; n'avoir aucun montage du système de fichiers de l'hôte; et appliquer des quotas de processeur, de mémoire, de disque et de processus.

Pourquoi : un environnement jetable, isolé par session et sans privilèges empêche qu'une compromission persiste ou atteigne la session d'un autre utilisateur[28].

**EXIG-SEC-10**
**DOIT**

**Charges qui exigent un GPU**

Un bac à sable qui exige un GPU **DOIT** faire l'objet d'une analyse de risque propre, approuvée par la sécurité, et l'hôte **DOIT** maintenir ses pilotes à jour. Sous gVisor, l'analyse tient compte du fait que `nvproxy` relaie les appels `ioctl` au pilote NVIDIA de l'hôte et ne valide pas les tampons d'accès direct à la mémoire (DMA).

Pourquoi : gVisor prend en charge certains GPU NVIDIA (T4, A100, A10G, L4, H100), mais sa documentation reconnaît qu'il protège beaucoup moins bien contre les failles du pilote lui-même[368]; chez Modal, par exemple, les bacs à sable GPU ne sont offerts qu'avec gVisor[369].

**EXIG-SEC-11**
**DEVRAIT**

**Performance mesurée sur la charge réelle**

Les objectifs de latence et de coût des bacs à sable **DEVRAIENT** être fixés à partir de mesures faites sur la charge réelle de l'entreprise, et non à partir de chiffres de fournisseurs ou de pourcentages génériques.

Pourquoi : le coût de gVisor dépend du profil d'appels système et de la plateforme, et le temps de démarrage publié par Firecracker (moins de 125 ms) est mesuré dans des conditions précises (console série désactivée, noyau et système de fichiers racine minimaux)[133, 361, 370].

## Quatre verrous obligatoires

Quelle que soit la technologie, quatre verrous s'appliquent (bande inférieure de la figure 20). Les trois premiers ferment les issues d'un code malveillant : sortir par le réseau, voler un secret, durer. Le quatrième garantit qu'on saura ce qui s'est passé.

### Verrou 1 : réseau fermé par défaut

L'OWASP recommande des bacs à sable d'exécution dotés de listes d'autorisation sortantes qui refusent toute destination non approuvée (ASI02)[28]. Pour les clients MCP qui récupèrent des URL d'autorisation OAuth, la spécification MCP recommande (SHOULD) de bloquer les plages privées et lien-local, dont 169.254.0.0/16 qui inclut les services de métadonnées d'AWS, de Google Cloud et d'Azure, et invite les exploitants à envisager un mandataire de sortie[208]. Le filtrage par nom de domaine a des limites documentées : fondé sur l'indication du nom de serveur (SNI) du protocole TLS, il ne filtre pas le HTTP en clair et n'empêche pas par défaut le *domain fronting*; une politique fondée sur des plages IP laisse la résolution DNS ouverte, ce qui permet d'exfiltrer des données par le DNS[342].

**EXIG-SEC-12** — **DOIT**

**Sortie réseau refusée par défaut**

Un bac à sable **DOIT** démarrer sans aucun accès réseau sortant, résolution DNS comprise. Chaque destination nécessaire **DOIT** être inscrite nommément à une liste d'autorisation tenue à la fiche de l'agent, sans règle générique; le trafic **DOIT** passer par un mandataire de sortie qui refuse le HTTP en clair et qui termine TLS pour les domaines où il injecte une authentification (EXIG-SEC-14). Les plages privées et lien-local, dont 169.254.0.0/16 et leurs équivalents IPv6 (`fc00::/7`, `fe80::/10`), **DOIVENT** être bloquées, à l'exception de l'adresse du mandataire de sortie.

Pourquoi : une sortie fermée par défaut limite l'exfiltration de données même lorsque le code exécuté n'est pas fiable[208, 342].

**EXIG-SEC-13** — **DOIT**

**Service de métadonnées infonuagiques**

Sur toute plateforme, le service de métadonnées de l'hôte **DOIT** être inaccessible depuis les bacs à sable. Sur AWS, tout hôte qui exécute des agents ou des bacs à sable **DOIT** en outre être configuré pour n'accepter qu'IMDSv2.

Pourquoi : IMDSv2 exige un jeton de session obtenu par une requête `PUT`, refuse d'en émettre si l'en-tête `X-Forwarded-For` est présent et limite par défaut les sauts IP à un, ce qui protège contre la plupart des attaques par falsification de requêtes côté serveur (SSRF)[371, 372].

### Verrou 2 : secrets hors du bac à sable

Un secret absent ne peut pas être volé. Dans le patron de courtage d'identifiants, le mandataire de sortie ajoute l'en-tête d'authentification aux requêtes sortantes, de sorte que le secret n'entre jamais dans le bac à sable. Ce patron a ses limites : il dépend du SNI et exige que le mandataire termine TLS, et une règle générique « * » laisse passer sans transformation le trafic dont le domaine n'est pas détectable[342]. Le brouillon WIMSE AIMS interdit par ailleurs au modèle d'accéder aux justificatifs de l'agent[93]. Enfin, pour l'appel d'outils programmatique, les bonnes pratiques MCP prévoient un code sans accès réseau direct, un hôte courtier qui détient les identifiants et applique à chaque appel la même politique d'approbation qu'à un appel direct, et des résultats d'un serveur traités comme non fiables pour un autre[204].

**EXIG-SEC-14** NE DOIT PAS

**Secrets injectés par le mandataire de sortie**

Un secret (clé, jeton, mot de passe, certificat) **NE DOIT PAS** se trouver dans le bac à sable, ses variables d'environnement, ses fichiers ou le contexte du modèle. Lorsque le code appelle un service, le mandataire de sortie, situé hors du bac à sable, **DOIT** ajouter l'authentification après vérification de la destination; lorsque le code appelle des outils, l'hôte courtier **DOIT** appliquer à chaque appel les mêmes contrôles d'autorisation et d'approbation qu'à un appel direct de l'agent.

Pourquoi : le code compromis ne peut ni lire ni réutiliser un justificatif qu'il ne détient pas[93, 342].

### Verrou 3 : délais à trois niveaux

Aucune norme ne fixe ces délais. L'OWASP recommande des plafonds d'usage (coût, débit, jetons)[28], et les fournisseurs imposent leurs propres durées maximales, par exemple cinq minutes par défaut chez Modal[369]. Le cadre fixe donc des valeurs par défaut, ajustables à la fiche de l'agent.

**EXIG-SEC-15** DOIT

**Délais à trois niveaux**

Chaque bac à sable **DOIT** appliquer trois délais maximaux : par appel d'outil ou exécution de script (30 secondes par défaut), par boucle de tâche (20 minutes par défaut) et pour sa durée de vie totale (destruction dès la fin de la tâche et, au plus tard, après 60 minutes par défaut). Ces valeurs sont des choix du cadre; toute valeur supérieure **DOIT** être justifiée à la fiche de l'agent.

Pourquoi : un délai borne la durée d'une exfiltration lente, d'un minage de cryptomonnaie ou d'une boucle, même lorsque les autres contrôles ont échoué.

### Verrou 4 : journalisation immuable

**EXIG-SEC-16** DOIT

**Journal d'exécution tenu hors du bac à sable**

Chaque commande exécutée, chaque écriture de fichier et chaque requête réseau d'un bac à sable **DOIVENT** être consignées par un composant situé hors du bac à sable, dans un journal inaltérable rattaché à la trace de la tâche (section 10.3).

Pourquoi : l'OWASP demande de journaliser toute génération et exécution de code (ASI05) et de tenir des journaux complets, immuables et signés des actions des agents (ASI10)[28]; un journal tenu dans le bac à sable pourrait être effacé par le code qu'il surveille.

## Séparer la génération de l'exécution

Le bac à sable limite les dégâts; il ne dispense pas de vérifier ce qu'on exécute. L'OWASP recommande, pour ASI05, d'interdire `eval` dans les agents en production, d'exiger des interpréteurs sûrs et le suivi de contamination du code généré, de ne jamais exécuter en root, d'isoler les environnements par session, de séparer génération et exécution par des portes de validation, d'analyser le code avant exécution et de le surveiller pendant, et d'exiger une approbation humaine pour les exécutions à privilèges élevés[28].

**EXIG-SEC-17** DOIT

**Porte de validation du code généré**

Le code généré **DOIT** franchir une porte de validation avant exécution : analyse statique, refus des constructions d'évaluation dynamique (`eval` et équivalents) dans les agents en production, et approbation humaine pour toute exécution qui demande des privilèges ou des destinations réseau supplémentaires. Pendant l'exécution, une surveillance **DOIT** détecter les comportements anormaux (processus inattendus, connexions refusées, volumes d'écriture inhabituels).

Pourquoi : séparer génération et exécution empêche qu'un code piégé s'exécute du seul fait que le modèle l'a écrit[28].

EXEMPLE DE MISE EN ŒUVRE SUR KUBERNETES

Dans Kubernetes, l'objet `RuntimeClass`, stable depuis la version 1.20 (API `node.k8s.io/v1`), permet de choisir pod par pod une configuration d'exécution plus isolée, au prix d'un surcoût[373]. Le sous-projet kubernetes-sigs/agent-sandbox (SIG Apps) orchestre des bacs à sable d'agents au-dessus de gVisor ou de Kata Containers, avec les ressources `Sandbox`, `SandboxTemplate`, `SandboxWarmPool` et `SandboxClaim` (API `v1beta1`)[137]. Une réserve préchauffée réduit la latence; chaque bac à sable qu'on en tire reste dédié à une seule tâche ou à une seule session, conformément à EXIG-SEC-09. Ces composants sont des exemples, non des exigences.

## 9.8 Chaîne d'approvisionnement agentique

Un agent assemble des composants qu'il n'a pas écrits : modèles, serveurs MCP, agents distants, compétences *(skills)*, gabarits d'invites, bibliothèques et cadriciels. Chacun peut être compromis à la source ou modifié après son approbation. Cette section fixe les règles de provenance, d'intégrité et de risque de tiers. Les mécanismes de version et de catalogue sont décrits à la section 6.8, et les contrôles propres au protocole MCP à la section 6.5.

### Des menaces documentées

Invariant Labs a décrit le 1er avril 2025 l'empoisonnement d'outil *(tool poisoning)*, soit des instructions malveillantes cachées dans la description d'un outil, et la substitution après approbation *(rug pull)*, soit la modification de cette description une fois l'outil approuvé[220]. La fiche de sécurité MCP de l'OWASP reprend ces attaques, étend l'empoisonnement aux schémas et aux valeurs de retour, et décrit aussi l'ombrage *(shadowing)* : la description d'un serveur malveillant modifie l'usage des outils d'un autre serveur[221]. Le MCP Top 10, encore en bêta, classe l'empoisonnement d'outil en MCP03, la chaîne d'approvisionnement en MCP04 et les serveurs MCP fantômes en MCP09[222]. Pour les compétences, l'AST10 recense notamment les compétences malveillantes (AST01), la compromission de la chaîne d'approvisionnement (AST02) et la dérive des mises à jour (AST07)[374]. Hou et ses coauteurs proposent enfin d'analyser un serveur MCP selon les quatre phases de son cycle de vie (création, déploiement, exploitation, maintenance), avec 16 scénarios de menace répartis entre quatre types d'attaquants[224].

EXEMPLE

Un serveur MCP de conversion de devises est approuvé en mars. En juin, son éditeur publie une nouvelle description qui demande au modèle de joindre « pour vérification » le contenu de la conversation à chaque appel. Sans épinglage, l'agent suit la nouvelle consigne dès le lendemain; avec EXIG-SEC-18, la passerelle constate que l'empreinte a changé et suspend l'outil jusqu'à une nouvelle revue.

**EXIG-SEC-18** **DOIT**

**Provenance approuvée et intégrité vérifiée à l'exécution**

Un agent **DOIT** invoquer uniquement des serveurs MCP, agents distants, compétences et modèles inscrits au catalogue d'entreprise après revue de leur définition complète (nom, titre, description, icônes, schémas d'entrée et de sortie, annotations et `_meta`). À chaque `tools/list` (EXIG-MCP-20) et avant chaque exécution, la passerelle d'agents **DOIT** vérifier que la définition présentée correspond à l'empreinte épinglée au catalogue et, en cas d'écart, retirer et suspendre le composant jusqu'à une nouvelle approbation.

Pourquoi : l'épinglage par empreinte, revérifié avant exécution, neutralise la substitution après approbation, et la revue de la définition complète à l'inscription réduit le risque d'empoisonnement d'outil[221].

### Signature et nomenclature

La spécification A2A permet de signer une carte d'agent en JWS après canonisation JCS (RFC 8785), le champ `signatures` étant exclu du contenu signé; les clients devraient vérifier au moins une signature avant de faire confiance à une carte, et une clé expirée ou révoquée ne doit pas servir à la vérification[68]. Le cœur de MCP n'exige pas de signature des messages[221] : l'intégrité d'un serveur MCP repose donc sur l'épinglage par empreinte et sur la signature des artefacts déployés.

**EXIG-SEC-19**
**DOIT**

**Signature des cartes d'agent et des artefacts**

Toute carte d'agent inscrite au catalogue d'entreprise et rattachée au registre **DOIT** être signée, et la passerelle comme les clients **DOIVENT** vérifier au moins une signature valide, faite avec une clé ni expirée ni révoquée, avant de faire confiance à la carte. Les artefacts déployés (images de conteneurs, paquets de serveurs MCP, compétences) **DEVRAIENT** être signés et leur signature vérifiée au déploiement.

Pourquoi : la spécification A2A se borne à recommander la vérification d'au moins une signature; le cadre la rend obligatoire (choix du cadre), car sans signature un agent malveillant peut publier une carte qui imite un agent légitime[68].

**EXIG-SEC-20**
**DOIT**

**Nomenclature de chaque version d'agent**

Chaque version d'un agent de risque modéré ou élevé **DOIT** être accompagnée d'une nomenclature tenue au registre : bibliothèques et cadriciels (nomenclature logicielle, SBOM), modèles, gabarits d'invites système, serveurs MCP, agents distants et compétences, chacun avec sa version et son empreinte.

Pourquoi : lorsqu'une faille est annoncée dans un composant, la nomenclature permet de savoir sans délai quels agents l'utilisent (choix du cadre).

### Isoler les fournisseurs d'outils les uns des autres

**EXIG-SEC-21**
**DOIT**

**Chaque serveur, un domaine de sécurité distinct**

La passerelle **DOIT** traiter chaque serveur MCP et chaque agent distant comme un domaine de sécurité indépendant et non fiable : noms d'outils pleinement qualifiés par un espace de noms propre au serveur, interdiction qu'un serveur référence ou modifie les outils d'un autre, et surveillance des flux de données entre serveurs. Le trafic vers un serveur MCP ou un agent absent du catalogue ou du registre **DOIT** être bloqué et signalé à la sécurité.

Pourquoi : l'OWASP recommande cet isolement par une passerelle contre l'ombrage, la vérification des noms de paquets contre le typosquattage et, contre les outils typosquattés, des noms pleinement qualifiés avec versions épinglées (ASI02); les serveurs fantômes échappent sinon à tout contrôle[28, 221, 222].

### Risque de tiers

Le NIST AI RMF consacre la catégorie GOVERN 6 aux risques venant des logiciels, des données et des autres éléments de la chaîne d'approvisionnement de tiers : GOVERN 6.1 vise les politiques sur ces risques, y compris la propriété intellectuelle, et GOVERN 6.2 les processus de contingence en cas de défaillance ou d'incident d'un système de tiers jugé à haut risque; les serveurs MCP et les agents externes en relèvent[74]. Le règlement européen sur l'IA (RIA), tel que modifié par le règlement (UE) 2026/1744, exige en outre du fournisseur d'un système à haut risque un accord écrit avec les tiers qui fournissent un système d'IA, un modèle d'IA, des outils, services, composants ou processus utilisés ou intégrés dans le système, sauf pour les tiers qui rendent publics, sous licence libre et ouverte, des outils, services, processus ou composants autres que des modèles d'IA à usage général (art. 25(4))[61, 375].

**EXIG-SEC-22** DOIT

**Évaluation des tiers et plan de contingence**

Avant son inscription au catalogue, tout serveur MCP, agent ou modèle fourni par un tiers **DOIT** faire l'objet d'une évaluation de sécurité proportionnée au palier de ses outils. Tout composant de tiers utilisé par un agent de risque élevé **DOIT** disposer d'un plan de contingence (désactivation, solution de repli, avis aux consommateurs). Lorsqu'un composant est intégré à un système à haut risque au sens du RIA, un accord écrit **DOIT** être conclu avec le tiers (chapitre 13).

Pourquoi : la sécurité d'un agent ne dépasse pas celle du moins sûr de ses fournisseurs; GOVERN 6 en fait une pratique de gestion attendue (le NIST AI RMF est un cadre volontaire) et l'article 25(4) du RIA une obligation d'accord écrit pour le fournisseur d'un système à haut risque[74, 375].

## 9.9 Assurance : tests et équipe rouge

Les contrôles des sections précédentes ne valent que s'ils résistent à une attaque réelle. Cette section fixe les essais exigés avant la mise en production et pendant l'exploitation; elle ajoute un volet adverse à l'évaluation continue de la qualité (section 10.4). Les lignes directrices conjointes du NCSC britannique, de l'agence américaine CISA (Cybersecurity and Infrastructure Security Agency) et de leurs partenaires font de la sécurité une exigence de base aux quatre phases du cycle de vie : la conception, le développement, le déploiement ainsi que l'exploitation et la maintenance[376]. Le guide de l'OWASP sur la sécurisation des applications agentiques (version 1.0 du 27 juillet 2025) fournit aux équipes de développement les recommandations techniques correspondantes[377].

### Équipe rouge avant la production

Une équipe rouge *(red team)* attaque l'agent comme le ferait un adversaire. L'OWASP recommande des tests périodiques qui simulent le détournement d'objectif et vérifient l'efficacité du retour arrière (ASI01)[28]. MITRE ATLAS fournit le vocabulaire commun de ces scénarios et intègre des techniques propres aux agents, comme AML.T0110 AI Agent Tool Poisoning, AML.T0124 Autonomous Attack Orchestration et AML.T0133 Discover AI Agent Runtime Capabilities[352].

**EXIG-SEC-23** DOIT

**Exercice d'équipe rouge propre aux agents**

Tout agent de classe de risque modérée ou élevée **DOIT** subir, avant sa mise en production puis au moins une fois par année (choix du cadre), un exercice d'équipe rouge propre aux agents, mené par une équipe indépendante de l'équipe de développement. Les scénarios couvrent au minimum le détournement d'objectif par contenu non fiable, l'exfiltration de données, l'empoisonnement d'outil et de mémoire et l'abus de délégation; chacun est rattaché à un risque ASI et, s'il y a lieu, à une technique MITRE ATLAS. Un constat de gravité critique non corrigé **DOIT** bloquer la mise en production.

Pourquoi : choix du cadre, selon lequel seul un adversaire qui cherche activement révèle les combinaisons que l'équipe de conception n'a pas imaginées; l'OWASP recommande des tests périodiques de détournement d'objectif (ASI01)[28].

### Essais automatisés à chaque version

AgentDojo est un environnement d'évaluation des attaques et défenses par injection qui comprend 97 tâches réalistes et 629 cas de test de sécurité[378]. Il montre qu'on peut mesurer la résistance à l'injection de façon reproductible; on peut donc l'intégrer à la chaîne d'intégration et de déploiement continus comme n'importe quel test de régression.

**EXIG-SEC-24**
**DOIT**

**Suite d'attaques dans la chaîne d'intégration**

La chaîne d'intégration et de déploiement **DOIT** exécuter, à chaque nouvelle version d'un agent (modèle, invite système, outil ou palier modifié), une suite d'attaques automatisées rédigées en français et en anglais, par exemple des scénarios dérivés d'AgentDojo, et bloquer le déploiement si le taux de réussite des attaques dépasse le seuil fixé à la fiche de l'agent.

Pourquoi : un changement de modèle ou d'invite peut affaiblir silencieusement la résistance d'un agent; seule une mesure à chaque version détecte cette régression.

**EXIG-SEC-25**
**DOIT**

**Vérification des contrôles déterministes**

Les essais **DOIVENT** démontrer, par des cas négatifs, que : la passerelle retire les outils d'envoi après la lecture d'un contenu non fiable (EXIG-SEC-06); un jeton d'approbation altéré, rejoué ou lié à d'autres arguments est refusé; un bac à sable ne peut joindre ni une destination hors liste, ni le DNS, ni le service de métadonnées; une définition d'outil modifiée est bloquée (EXIG-SEC-18).

Pourquoi : ces contrôles sont binaires; un test qui échoue révèle une faille certaine, alors qu'un test d'injection réussi ne mesure qu'une probabilité.

## Exercices de compromission et de coupe-circuit

Le règlement européen sur l'IA exige que les personnes chargées de la supervision puissent interrompre un système à haut risque au moyen d'un bouton d'arrêt ou d'une procédure analogue qui l'amène à un état sûr (art. 14(4)e))[290], et le NIST AI RMF (MANAGE 2.4) demande des mécanismes et des responsabilités pour désactiver un système qui s'écarte de l'usage prévu[99]. Au Québec, l'Énoncé de principes pour une utilisation responsable de l'IA par les organismes publics demande aux organismes publics, à son principe 11, des mécanismes de validation, d'intervention humaine ou d'arrêt, particulièrement pour les systèmes dotés d'autonomie comme l'IA agentique, et cite en illustration des mécanismes d'arrêt d'urgence[379]. La propagation du coupe-circuit *(kill switch)* par la passerelle est décrite à la section 9.4.

**EXIG-SEC-26**
**DOIT**

**Exercice trimestriel de compromission d'agent**

Au moins une fois par trimestre (choix du cadre), la plateforme **DOIT** exercer le scénario d'un agent compromis : arrêt par le coupe-circuit, révocation de ses identités et de ses jetons, mise en quarantaine et préservation des preuves. Le délai réel de révocation **DOIT** être mesuré et comparé à la cible de 15 minutes du tableau 61; tout dépassement **DOIT** ouvrir une action corrective. Cet exercice **PEUT** se combiner à l'essai trimestriel du coupe-circuit prévu à la section 7.8.

Pourquoi : un mécanisme d'arrêt jamais exercé n'est qu'une hypothèse; seul l'exercice prouve qu'il fonctionne et dans quel délai.

**À RETENIR**

Lorsque le risque résiduel reste intolérable malgré ces contrôles, la bonne réponse n'est pas un filtre de plus, mais un flux déterministe (N0) ou un agent consultatif (N1). Le NCSC l'énonce sans détour : si le risque résiduel est intolérable, un modèle de langage n'est peut-être pas la bonne solution[98].

# 10 Observabilité, évaluation et FinOps

On ne gouverne que ce qu'on voit. Ce chapitre impose une trace OpenTelemetry de bout en bout, reliée par un même contexte W3C du canal jusqu'à l'outil, et un journal d'audit inaltérable, distinct de cette trace. Il organise l'évaluation continue en trois paliers, du contrat vérifié à chaque modification jusqu'à l'échantillonnage de la production. Il donne enfin à chaque tâche une enveloppe budgétaire et à chaque agent un coût par tâche réussie, imputé à un centre de coûts.

## 10.1 Traçage de bout en bout

Cette section fixe la manière dont chaque exécution d'agent produit une trace unique, faite d'étapes chronométrées *(spans)*, qui relie la demande d'origine à chaque appel de modèle, d'outil et d'agent.

### Un mécanisme stable, des conventions mouvantes

OpenTelemetry fournit un mécanisme de collecte (API et protocole OTLP, de l'anglais *OpenTelemetry Protocol*) et des conventions sémantiques qui nomment les attributs. Le mécanisme est stable; les conventions de l'IA générative (`gen_ai.*`) sont toutes au niveau *Development*, qui admet ruptures et retraits[188, 380]. Depuis la v1.42.0 (12 juin 2026), elles vivent dans le dépôt dédié `semantic-conventions-genai`[180, 381]. Ce dépôt n'a publié aucune version étiquetée : la dernière version publiée qui les contient comme conventions en vigueur est la v1.41.1 de `semantic-conventions` (correctif du 11 mai 2026 de la v1.41.0 du 28 avril 2026), les versions suivantes les déclarant obsolètes (v1.42.0, 12 juin 2026); la branche principale du nouveau dépôt remplace déjà `gen_ai.usage.cache_creation.input_tokens` par `gen_ai.usage.cache_write.input_tokens` et restructure les métriques de jetons[119, 181, 380, 381, 382, 383, 384]. Le cadre impose donc le mécanisme, épingle une version des conventions et lit les données par une couche de correspondance. L'épinglage ne dicte toutefois pas ce que les bibliothèques d'instrumentation émettent : la convention demande que les instrumentations existantes ne changent pas par défaut la version GenAI qu'elles produisent (v1.36.0 ou antérieure) et qu'elles prévoient la variable d'environnement `OTEL_SEMCONV_STABILITY_OPT_IN`, dont la valeur `gen_ai_latest_experimental` fait émettre la dernière version expérimentale prise en charge par l'instrumentation, et non une version précise[119]. L'instrumentation Python d'OpenAI, par exemple, reste sans ce réglage aux conventions v1.30.0[385]. Le catalogue consigne donc, pour chaque composant, la version réellement émise et le réglage de cette variable.

**EXIG-OBS-01**
**DOIT**

**OpenTelemetry obligatoire, conventions épinglées**

Tout composant d'une exécution d'agent (canal, orchestrateur, passerelles, agent, serveur MCP, consommateur d'événements) **DOIT** émettre traces et métriques par OpenTelemetry, en OTLP, vers le collecteur de la plateforme, selon la version des conventions GenAI épinglée au catalogue (v1.41.0, jusqu'à l'homologation d'une version étiquetée du dépôt dédié). Tableaux de bord, alertes et calculs de coûts lisent les données par une couche de correspondance versionnée; un changement de version des conventions se gère comme un changement de contrat (section 6.8).

Pourquoi : au niveau Development, des ruptures sont admises et un signal peut être retiré, sans garantie de dépréciation préalable[188]; sans épinglage, un tableau de bord se vide en silence.

## Propagation du contexte

W3C Trace Context est une Recommandation du W3C (version du 23 novembre 2021). L'en-tête `traceparent` de version `00` compte 55 caractères; un identifiant entièrement nul est invalide, la version `ff` est interdite, et `tracestate` compte au plus 32 membres[103].

**En-tête traceparent (exemple canonique de la spécification)**

```
traceparent: 00-4bf92f3577b34da6a3ce929d0e0e4736-00f067aa0ba902b7-01
             ⌊  ⌊──── identifiant de trace ─────⌋  ⌊─ span parent ─⌋  ⌊
          version        (32 hex)                    (16 hex)     indicateurs
```

Ce contexte voyage dans les en-têtes HTTP, dans les clés `traceparent`, `tracestate` et `baggage` que MCP 2026-07-28 réserve dans `_meta`[162] (EXIG-MCP-16), dans les appels A2A (EXIG-A2A-13) et dans l'extension CloudEvents Distributed Tracing (EXIG-EVT-04). Un composant poursuit la trace d'une requête entrante si son `traceparent` est valide et, selon le choix du cadre, vient d'une source de confiance; à une frontière de confiance, il peut la redémarrer, ce que la spécification prévoit pour écarter une surface d'attaque par déni de service et limiter l'exposition d'information[103]. Enfin, `traceparent` identifie une trace, pas une demande métier.

**EXIG-OBS-02** — DOIT

**Contexte validé, poursuivi ou redémarré aux frontières**

Les passerelles d'agents et de modèles **DOIVENT** valider le contexte reçu (longueurs, identifiants non nuls, version admise) et remplacer tout en-tête invalide par une nouvelle trace. Un composant interne **DOIT** poursuivre la trace d'un autre composant interne; un contexte venu de l'extérieur (partenaire, agent tiers, point de rappel HTTP) **DOIT** être remplacé par une nouvelle trace qui le conserve comme lien de span (choix du cadre).

Pourquoi : une trace coupée ne se reconstitue plus, et une trace imposée de l'extérieur peut brouiller une enquête.

**EXIG-OBS-03** — DOIT

**Identifiants métier portés à part**

Chaque span **DOIT** porter l'identifiant de tâche attribué par l'orchestrateur et, pour un appel A2A, le `taskId` et le `contextId`. Une déduplication ou une clé d'idempotence **NE DOIT PAS** se fonder sur `traceparent`.

Pourquoi : une trace peut être redémarrée à une frontière, alors qu'une tâche garde son identité de bout en bout (section 7.6).

## Hiérarchie des spans

Les conventions nomment chaque span (figure 21) : `invoke_workflow {gen_ai.workflow.name}` (INTERNAL) pour un flux multiagent; `invoke_agent {gen_ai.agent.name}`, de type CLIENT pour un agent distant et INTERNAL dans le même processus; `execute_tool {gen_ai.tool.name}` (INTERNAL) pour un outil; `{gen_ai.operation.name} {gen_ai.request.model}` pour une inférence[119, 120]. En v1.41.0, `gen_ai.operation.name` admet `chat`, `create_agent`, `embeddings`, `execute_tool`, `generate_content`, `invoke_agent`, `invoke_workflow`, `retrieval` et `text_completion` : aucune valeur « handoff » n'existe, et un transfert entre agents se trace par `invoke_agent`. Les appels MCP ont leur propre convention : spans `{mcp.method.name} {cible}`, attribut requis `mcp.method.name`, histogrammes `mcp.client.operation.duration` et `mcp.server.operation.duration`[386]. A2A n'en a pas en v1.41.0 (le dépôt dédié en définit une, non publiée, au niveau Development[241]) et se trace par `invoke_agent` (section 6.6).

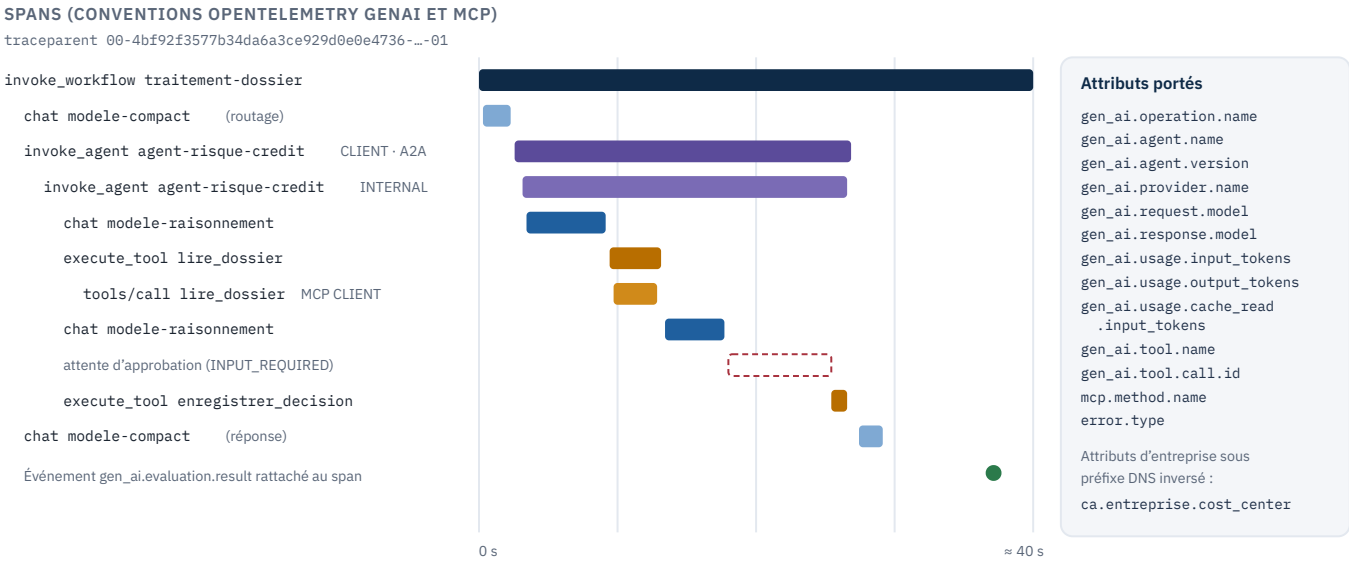



**Figure 21 — Une trace distribuée de bout en bout.** Une seule trace relie le flux, le routage, la délégation A2A, les inférences de l'agent appelé, l'appel MCP, l'attente d'approbation et l'écriture finale; le résultat d'évaluation s'attache au span évalué. À droite, les attributs portés, dont un attribut d'entreprise sous préfixe DNS inversé.

Source : cadre CRE-IA-2026-01, d'après les conventions OpenTelemetry GenAI et MCP (v1.41.0).

**EXIG-OBS-04**

**DOIT**

### Hiérarchie de spans normalisée

Chaque exécution **DOIT** produire la hiérarchie de la version épinglée : `invoke_workflow` pour un flux multiagent, `invoke_agent` par agent appelé, un span par inférence, `execute_tool` par appel d'outil avec le span MCP CLIENT correspondant. Attentes d'approbation, compensations et refus de la passerelle y figurent comme spans ou événements. Toute valeur de `gen_ai.operation.name` hors convention est inscrite au catalogue comme extension.

Pourquoi : une hiérarchie commune se lit avec les mêmes requêtes, quel que soit le cadriciel.

## Attributs et métriques

Sur un span d'inférence, la convention ne requiert que `gen_ai.operation.name` et `gen_ai.provider.name` [119]. Le cadre rend obligatoires, par une politique plus stricte que la convention, les attributs dont dépendent l'audit, le diagnostic et l'imputation (tableau 41). Deux pièges de nommage : la version d'agent s'écrit `gen_ai.agent.version`, avec un point (ajoutée en v1.40.0)[180], et `gen_ai.provider.name` remplace `gen_ai.system` depuis la v1.37.0[387].

**Tableau 41 — Attributs de trace exigés et niveau dans la convention OpenTelemetry v1.41.0**

| Catégorie | Attribut | Niveau dans la convention | Exigence du cadre |
|---|---|---|---|
| Opération | `gen_ai.operation.name` | Requis | Obligatoire |
| Fournisseur | `gen_ai.provider.name` | Requis (inférence, plongements, création et invocation d'agent) | Obligatoire |
| Modèle | `gen_ai.request.model` ; `gen_ai.response.model` | Conditionnel; recommandé | Obligatoires : alias demandé et modèle servi |
| Jetons | `gen_ai.usage.input_tokens` (cache compris); `gen_ai.usage.output_tokens` | Recommandés | Obligatoires |

| Catégorie | Attribut | Niveau dans la convention | Exigence du cadre |
|---|---|---|---|
| Cache | `gen_ai.usage.cache_read.input_tokens` ; `gen_ai.usage.cache_creation.input_tokens` | Recommandés; le second devient `cache_write` dans la branche non publiée | Obligatoires si le fournisseur les renvoie |
| Fin de génération | `gen_ai.response.finish_reasons` | Recommandé | Obligatoire |
| Agent | `gen_ai.agent.id` , `.name` , `.version` | Conditionnels | Obligatoires; identifiant du registre |
| Outil | `gen_ai.tool.name` ; `gen_ai.tool.call.id` | Requis sur `execute_tool` ; recommandé | Obligatoires |
| MCP | `mcp.method.name` | Requis | Obligatoire |
| Erreur | `error.type` | Conditionnel | Obligatoire en cas d'erreur |
| Entreprise | `ca.entreprise.cost_center` , `ca.entreprise.task_id` , `ca.entreprise.autonomy_level` , `ca.entreprise.approval.approver` | Hors convention | Obligatoires; approbateur sous pseudonyme |

Sources : conventions OpenTelemetry GenAI et MCP v1.41.0[119, 386]; dernière colonne : choix du cadre. Statut des versions : voir la section 10.1.

Pour les métriques, la v1.41.0 définit les histogrammes `gen_ai.client.operation.duration` (secondes, requis) et `gen_ai.client.token.usage` (jetons, recommandé)[388]; la branche non publiée remplace l'histogramme `gen_ai.client.token.usage` (v1.41.0) par des compteurs `gen_ai.client.inference.usage.*` et des histogrammes `gen_ai.client.inference.operation.*`, et scinde `gen_ai.client.operation.duration` pour l'inférence[388, 389], migration qu'absorbera la couche de correspondance.

**EXIG-OBS-05**
**DOIT**

**Attributs et métriques exigés**

Chaque span **DOIT** porter, parmi les attributs que le tableau 41 rend obligatoires, ceux qui s'appliquent à son type (inférence, agent, flux, outil, appel MCP), et chaque composant **DOIT** exposer les métriques de durée et de jetons de la version épinglée. Un composant qui ne les produit pas **NE DOIT PAS** être homologué; un attribut obligatoire manquant en production **DOIT** déclencher une alerte.

Pourquoi : sans modèle servi, version d'agent ni jetons, on ne relie pas une régression à un déploiement et l'on n'impute aucun coût.

**EXIG-OBS-06**
**DOIT**

**Attributs d'entreprise sous préfixe DNS inversé**

Les attributs propres à l'entreprise **DOIVENT** porter le préfixe de son domaine inversé (p. ex. `ca.entreprise.cost_center`), en minuscules et en *snake_case*, et être inscrits au catalogue; les préfixes `enterprise.` et `otel.` sont interdits. Une personne, approbateur compris, n'y figure que sous un identifiant pseudonyme.

Pourquoi : OpenTelemetry recommande ce préfixe contre les collisions et réserve `otel.*`[390]; l'identifiant d'un approbateur est un renseignement personnel, et un identifiant pseudonyme le demeure (section 12.2).

## 10.2 Contenu des invites et des réponses

Cette section règle le cas le plus délicat de la télémétrie : le texte des invites, des réponses et des arguments d'outils, utile au diagnostic mais souvent chargé de renseignements personnels (RP).

Contrairement à une idée répandue, la convention n'exclut pas ce contenu des spans. Depuis la v1.37.0 (la v1.38.0 pour les arguments et résultats d'outils), elle le place dans des attributs « Opt-In » (`gen_ai.input.messages`, `gen_ai.output.messages`, `gen_ai.system_instructions` et, depuis la v1.38.0, `gen_ai.tool.call.arguments` et `gen_ai.tool.call.result`, entre autres), que les instrumentations ne devraient pas capturer par défaut[119, 387, 391]. La branche non publiée nomme désormais, dans la convention, la variable `OTEL_INSTRUMENTATION_GENAI_CAPTURE_CONTENT` (`NO_CONTENT` par défaut, `SPAN_ONLY`, `EVENT_ONLY` ou `SPAN_AND_EVENT`)[392]; dans la v1.41.0, la variable `OTEL_INSTRUMENTATION_GENAI_CAPTURE_MESSAGE_CONTENT` n'est pas une convention, mais un réglage des bibliothèques Python[385]. La convention prévoit trois modes : ne rien enregistrer (défaut), enregistrer le contenu en attributs, ou le stocker à l'extérieur en ne plaçant sur le span qu'une référence, dont le format n'est pas normalisé dans la v1.41.0 (la branche non publiée définit des attributs `gen_ai.input.messages_ref`, `gen_ai.output.messages_ref`, `gen_ai.system_instructions_ref` et `gen_ai.tool.definitions_ref`, qui portent un URI absolu[380])[119]. Le cadre retient le premier mode en production et le troisième pour le débogage.

Le processeur `redaction` du Collector OpenTelemetry supprime les attributs absents d'une liste d'autorisation (vide, elle supprime tout), masque les valeurs selon des expressions régulières et peut les hacher, les variantes HMAC *(code d'authentification de message par hachage)* étant recommandées pour les données à faible entropie; sa stabilité est Beta pour les traces, mais Alpha pour les métriques et les journaux[141]. Quant au bagage *(baggage)*, W3C Baggage n'est qu'une recommandation candidate, qui avertit de ne pas transporter d'information confidentielle au-delà d'une frontière de confiance[393].

> **À RETENIR**
>
> Les métadonnées se tracent toujours; le contenu, jamais par défaut. Pour comprendre une défaillance, on consulte le texte exact dans un dépôt chiffré, à accès restreint et de courte durée, par une référence placée sur le span.

**EXIG-OBS-07**
**NE DOIT PAS**

**Aucun contenu dans la télémétrie de production**

En production, les spans, événements et journaux de télémétrie **NE DOIVENT PAS** contenir le texte des invites, des réponses ou des instructions système, ni les arguments ou résultats d'outils, ni les autres contenus que la convention soumet à la capture de contenu (requêtes de recherche, variables d'invite, mémoire de l'agent). Cette interdiction est une politique du cadre, plus stricte que la désactivation par défaut que prévoit la convention.

Pourquoi : la télémétrie est copiée vers plusieurs systèmes et lue par de nombreuses équipes; le contenu y exposerait des RP hors de toute finalité déclarée (section 12.2).

**EXIG-OBS-08**
**DOIT**

**Contenu de débogage hors trace et de courte durée**

La capture du contenu pour un diagnostic **DOIT** être activée par une décision documentée (agent, motif, période bornée, accord du responsable technique et, si des RP sont en cause, du responsable de la protection des renseignements personnels), passer par le caviardage, être stockée dans un dépôt chiffré dont chaque accès est journalisé, et n'apparaître sur le span que par une référence. Le contenu est détruit après 14 jours au plus (choix du cadre).

Pourquoi : le mode par référence sépare la trace, largement partagée, du contenu, réservé à quelques personnes.

**EXIG-OBS-09**
**DOIT**

**Caviardage à la sortie du périmètre**

Toute télémétrie qui quitte la plateforme **DOIT** traverser un collecteur qui applique une liste d'autorisation fermée d'attributs, masque les motifs de RP et de secrets et remplace les identifiants à faible entropie par un HMAC à clé gérée par l'entreprise. Les règles de masquage **DOIVENT** être testées en français et en anglais à chaque modification.

Pourquoi : avec une liste fermée par défaut, ce qu'on a oublié de classer ne sort pas[141].

**EXIG-OBS-10**
**NE DOIT PAS**

**Aucun renseignement personnel dans le bagage**

Le bagage W3C et `tracestate` **NE DOIVENT PAS** contenir de RP, de secrets ni de données confidentielles; seuls y figurent des identifiants techniques, comme le centre de coûts. La passerelle **DOIT** retirer tout membre du bagage absent de la liste inscrite au catalogue.

Pourquoi : un système qui reçoit le bagage devrait le transmettre à ses requêtes sortantes, de sorte que ses clés et ses valeurs peuvent atteindre d'autres systèmes[393].

## 10.3 Journal d'audit

Cette section fixe le journal d'audit, qui répond à une autre question que la trace : non pas « que s'est-il passé techniquement? », mais « qui a fait quoi, au nom de qui, sous quelle autorité? ».

Une trace est technique, souvent échantillonnée et conservée selon la fiche de l'agent (section 12.2). Le journal d'audit est exhaustif pour les actions à effet, inaltérable et signé. Le règlement européen sur l'IA exige que les systèmes à haut risque permettent techniquement l'enregistrement automatique des événements pendant toute leur durée de vie (art. 12) et que le déployeur conserve les journaux sous son contrôle pendant au moins six mois, sauf disposition contraire du droit de l'Union ou du droit national (art. 26(6)); pour l'annexe III, ces obligations s'appliquent à compter du 2 décembre 2027, selon le calendrier que modifie le règlement (UE) 2026/1744 (art. 113, tel que modifié par le règlement (UE) 2026/1744)[58, 61, 94, 394]. L'article 12 n'impose ni signature ni format : l'enregistrement signé à cinq éléments est un choix du cadre, au-delà du minimum légal. ISO/IEC 42001 prévoit aussi l'enregistrement des journaux d'événements (annexe A, A.6.2.8)[395].

Les cinq éléments sont : (1) le **mandant**, sous pseudonyme; (2) l'**agent**, avec son identifiant au registre, sa version et celle de son invite système; (3) l'**action**, soit l'outil, la version de sa définition, l'empreinte SHA-256 des arguments et l'issue; (4) le **modèle** servi et sa version; (5) l'**autorité**, soit le jeton d'approbation (section 8.5), soit la règle qui permettait d'agir sans approbation. S'y ajoutent l'horodatage et les identifiants de corrélation : trace, tâche, `taskId` et `contextId` A2A[68], clé d'idempotence. L'enregistrement est canonisé selon la RFC 8785 (JCS), qui rend reproductibles le hachage et la signature de données JSON[236]; l'exemple complet figure à l'annexe C.

**Enregistrement d'audit à cinq éléments (extrait, avant canonisation)**

```
{
  "horodatage":  "2026-10-27T14:03:12.418Z",
  "correlation": { "trace_id": "4bf92f3577b34da6a3ce929d0e0e4736", "tache": "tache-7f3c2a",
                   "a2a_task_id": "…", "a2a_context_id": "…", "cle_idempotence": "…" },
  "mandant":   { "type": "user", "pseudonyme": "u-5d1e…" },
  "agent":     { "id": "agent-risque-credit", "version": "2.3.0", "invite_systeme": "sha256:…" },
  "action":    { "outil": "erp_enregistrer_decision", "definition": "1.4.1",
                 "arguments_sha256": "…", "issue": "succes" },
  "modele":    { "fournisseur": "…", "servi": "…", "version": "…" },
  "autorite":  { "approbation_jti": "…", "approbateur": "a-91c0…" },
  "precedent_sha256": "…",
  "signature": "<signature du service d'audit>"
}
```

**EXIG-OBS-11**
**DOIT**

**Journal d'audit distinct et exhaustif**

Chaque action à effet (outil P2 ou P3), chaque approbation ou refus d'approbation, chaque refus de la passerelle (EXIG-IAM-18) et chaque arrêt par coupe-circuit **DOIT** produire un enregistrement d'audit, sans échantillonnage. Le journal **DOIT** être tenu dans un magasin distinct des traces, sous d'autres droits d'accès; aucune équipe qui exploite un agent n'a le droit d'y modifier ni d'y supprimer un enregistrement.

Pourquoi : une trace peut être échantillonnée ou purgée par l'exploitation; une preuve ne le peut pas.

**EXIG-OBS-12**
**DOIT**

**Enregistrement à cinq éléments, canonisé et signé**

Chaque enregistrement **DOIT** contenir les cinq éléments et les identifiants de corrélation, être canonisé selon la RFC 8785, porter l'empreinte de l'enregistrement précédent du même flux et être signé par une clé du service d'audit, hors de portée des agents. Les arguments d'outil n'y figurent que par leur empreinte SHA-256, calculée sur leur forme canonisée; lorsqu'une approbation a eu lieu, l'empreinte d'approbation h (outil ‖ arguments canonisés, section 8.5) y figure aussi.

Pourquoi : choix du cadre; la canonisation de la RFC 8785[236] rend l'empreinte reproductible, de sorte que l'empreinte d'approbation, recalculée par la passerelle avant l'exécution, prouve que l'action exécutée est celle qui a été approuvée, et le chaînage rend toute suppression détectable.

**EXIG-OBS-13**
**DOIT**

**Inaltérabilité et conservation**

Le journal d'audit **DOIT** être tenu en ajout seul, sur un stockage qui interdit modification et effacement avant échéance, et son intégrité **DOIT** être vérifiée automatiquement chaque jour. Il est conservé au moins 24 mois, davantage si le calendrier de conservation, un régime sectoriel ou une enquête l'exige, puis détruit ou anonymisé à l'échéance (EXIG-CON-10); la règle de conservation des décisions touchant une personne s'applique aussi (section 12.2). La table qui relie pseudonymes et personnes est gardée à part, sous le contrôle du responsable de la protection des renseignements personnels.

Pourquoi : un journal réinscriptible ne prouve rien; la durée de 24 mois et la vérification quotidienne, choix du cadre, dépassent les six mois du RIA pour couvrir une découverte tardive d'un incident.

## 10.4 Évaluation continue

Cette section fixe la manière dont l'entreprise prouve qu'un agent fait ce qu'on attend de lui, avant et pendant son exploitation. Un code HTTP 200 ne dit rien de la justesse d'une réponse : la qualité se mesure, en trois paliers (figure 22). Le volet adverse relève de la section 9.9, et la comparaison avec un agent unique, de la section 7.1.

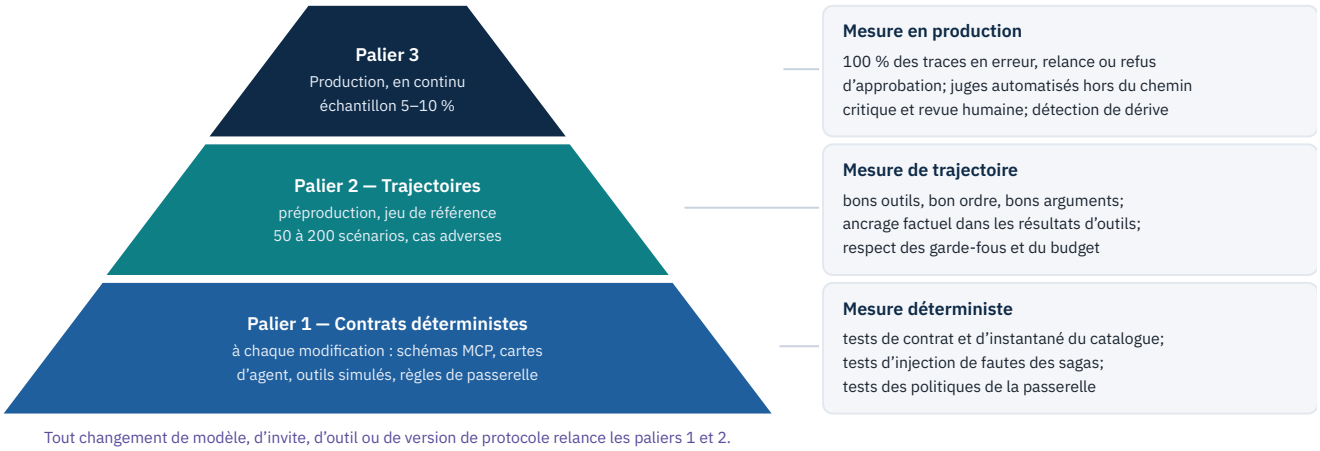



**Figure 22 — Évaluation en trois paliers.** Le palier 1 vérifie les contrats à chaque modification, le palier 2 mesure les trajectoires sur un jeu de référence en préproduction, le palier 3 échantillonne la production. Tout changement de modèle, d'invite, d'outil ou de version de protocole relance les deux premiers.

Source : cadre CRE-IA-2026-01.

**Palier 1 : contrats.** Sans aucun modèle, il valide les schémas MCP et les cartes d'agent, teste les outils contre des doublures, vérifie les politiques de la passerelle (EXIG-IAM-21) et rejoue l'injection de fautes des sagas (EXIG-ORC-20). Les validateurs appliquent MCP 2026-07-28 : la spécification interdit de déréférencer automatiquement un `$ref` réseau et recommande de rejeter une référence externe non résolue et de borner la profondeur de validation[162]. La conformité passe par `a2a-tck`, dont les échecs aux tests de niveau `MUST` (obligatoire) sont bloquants[243], et, à titre informatif tant que le cadre officiel de conformité MCP se déclare instable, par ses tests (section 6.8).

**Palier 2 : trajectoires.** Sur un jeu de référence de 50 à 200 scénarios (fourchette du cadre), qui comprend cas nominaux, cas limites et tentatives d'injection en français et en anglais, on mesure la justesse de la trajectoire (bons outils, bon ordre, bons arguments), l'ancrage factuel dans les résultats d'outils et le respect des garde-fous et du budget. Le cadre ne présume pas qu'un modèle rende la même sortie à entrées identiques : chaque scénario se répète. Évaluer un agent peut avoir des effets réels : l'article qui présente Magentic-One décrit AutoGenBench, dont les contrôles de répétition et d'isolation sont importants dès que les actions d'agents ont des effets de bord[279].

**Palier 3 : production.** On évalue de 5 à 10 % des traces (fourchette du cadre), plus toutes celles qui ont subi une erreur, une relance, un plafond atteint ou un refus d'approbation, par des juges automatisés hors du chemin critique et par une revue humaine. Anthropic décrit un juge qui rend, en un seul appel, un score de 0,0 à 1,0 et un verdict de réussite ou d'échec[17]. Le résultat se consigne dans l'événement `gen_ai.evaluation.result` (Development) : `gen_ai.evaluation.name` (requis), `gen_ai.evaluation.score.value`, `gen_ai.evaluation.score.label` (p. ex. `pass`) et `gen_ai.evaluation.explanation` (texte libre, soumis à l'EXIG-OBS-07 : en production, il ne reproduit ni invite ni réponse), et devrait être rattaché au span évalué[396]. Les défaillances multiagents se classent selon la taxonomie MAST *(Multi-Agent System Failure Taxonomy)* (section 7.9), et les entrées du bus peuvent être rejouées en isolement pour éprouver une nouvelle version (EXIG-EVT-10).

**Tableau 42 — Familles d'objectifs de niveau de service d'un agent (cibles proposées par le cadre)**

| Famille | Indicateurs | Cible proposée |
|---|---|---|
| Fiabilité technique | Succès des appels MCP et A2A; latence par étape au 95$^{e}$ centile | Plus de 99,5 % de succès; latence fixée au contrat |
| Efficacité | Tâches achevées sans erreur; étapes par tâche; appels d'outils invalides | Moins de 1 % d'appels invalides |

| Famille | Indicateurs | Cible proposée |
|---|---|---|
| Qualité et sécurité | Réponses non ancrées sur échantillon; violations de garde-fous; approbations sans modification (section 8.7) | Moins de 0,5 % de réponses non ancrées; aucune violation d'un garde-fou bloquant |
| Économie unitaire | Coût moyen et au 99e centile par tâche réussie, en dollars canadiens | Sous le coût du processus de référence sans agent |

Cibles : choix du cadre, à calibrer agent par agent au contrat.

**EXIG-EVA-01**
**DOIT**

**Paliers franchis et relancés à chaque changement**

Tout agent **DOIT** franchir les paliers 1 et 2 avant sa mise en production et rester soumis au palier 3 en exploitation. Tout changement de modèle, y compris derrière un même alias (EXIG-ARC-09), d'invite système, d'outil, de palier d'outil ou de version de protocole relance les paliers d'évaluation 1 et 2. Les tests du palier 1 **DOIVENT** s'exécuter en intégration continue et bloquer le déploiement en cas d'échec.

Pourquoi : le comportement d'un agent change sans que son code change; seule une mesure relancée détecte la régression.

**EXIG-EVA-02**
**DOIT**

**Jeu de référence tenu et versionné**

Chaque agent **DOIT** disposer d'un jeu de référence de 50 à 200 scénarios, versionné avec lui, couvrant ses compétences, des cas limites et des tentatives d'injection en français et en anglais. Toute défaillance confirmée en production y ajoute un scénario. Les seuils de trajectoire, d'ancrage et de garde-fous figurent au contrat; un seuil manqué bloque la mise en production.

Pourquoi : un jeu nourri par les défaillances réelles empêche qu'une erreur corrigée revienne.

**EXIG-EVA-03**
**DOIT**

**Évaluations répétées et isolées**

Les évaluations du palier 2 et les rejeux **DOIVENT** s'exécuter en environnement isolé, outils à effet remplacés par des doublures. Chaque scénario **DOIT** s'exécuter au moins trois fois (choix du cadre); on retient le taux de réussite et sa dispersion.

Pourquoi : une évaluation qui touche des systèmes réels en répète les effets, et une exécution unique ne dit rien de la variabilité[279].

**EXIG-EVA-04**
**DOIT**

**Échantillonnage de la production**

L'évaluation en production **DOIT** porter sur un échantillon aléatoire de 5 à 10 % des traces et sur toutes les traces marquées d'une erreur, d'une relance, d'un plafond atteint ou d'un refus d'approbation. Elle s'exécute hors du chemin critique, et chaque résultat est consigné par un événement `gen_ai.evaluation.result` rattaché au span évalué.

Pourquoi : l'événement normalisé relie chaque score à son exécution (rattachement au span évalué ou, à défaut, par `gen_ai.response.id`); le ciblage des traces atypiques (erreur, relance, plafond, refus) est un choix du cadre[396].

**EXIG-EVA-05**
**DOIT**

**Juge automatisé encadré**

Un juge à base de modèle **DOIT** être distinct du modèle ou de l'invite qu'il évalue, appliquer une grille versionnée et être calibré contre des évaluations humaines, avec un taux d'accord revu chaque trimestre. Ses verdicts alimentent indicateurs et alertes; ils **NE DOIVENT PAS** autoriser ni bloquer une action en production.

Pourquoi : un juge partage les faiblesses des modèles qu'il évalue; il mesure, il ne gouverne pas.

**EXIG-EVA-06** **DOIT**

**Objectifs de niveau de service et réaction aux écarts**

Chaque agent en production **DOIT** déclarer à son contrat des objectifs pour les quatre familles du tableau 42; un système multiagent **DOIT** en outre classer ses défaillances selon la taxonomie MAST. Un objectif manqué pendant deux périodes consécutives (choix du cadre) déclenche une revue par le parrain et le responsable technique, qui corrigent, réduisent le niveau d'autonomie ou suspendent l'agent (section 11.5).

Pourquoi : un objectif sans conséquence prévue ne gouverne rien.

## 10.5 Économie de l'inférence

Cette section donne les repères économiques vérifiés qui fondent les règles de maîtrise des coûts. Les chiffres des fournisseurs y sont des grilles ou des allégations datées, jamais des exigences.

**Des prix qui baissent, des volumes qui montent.** Presque tous les praticiens FinOps sondés gèrent désormais des dépenses d'IA (section 2.1); le State of FinOps 2026 cite parmi leurs défis la visibilité sur des modèles de prix hétérogènes, la répartition des coûts et la mesure du rendement[10]. Selon l'AI Index 2025 de Stanford (l'édition 2026 est parue depuis; le chiffre n'a pas été revérifié dans celle-ci), le coût d'inférence d'un système de niveau GPT-3.5 a baissé de plus de 280 fois entre novembre 2022 et octobre 2024, soit un coût à capacité constante, non une baisse générale du prix du jeton[397]. Epoch AI (mars 2025) mesure une baisse de 9 à 900 fois par an selon le seuil visé, les baisses les plus rapides ayant été observées au cours de l'année précédant la publication et leur persistance étant incertaine[398]. En sens inverse, un agent consomme bien plus de jetons qu'une conversation (section 7.1), et les définitions d'outils pèsent à chaque appel : selon Anthropic, 58 outils MCP occupent environ 55 000 jetons avant le premier message (mesure de novembre 2025, antérieure au segmenteur des modèles Claude 4.7 et suivants)[205].

**Une facture qui dépend de la configuration.** En octobre 2026, la grille d'Anthropic affiche, par million de jetons, 0,10 $ US en entrée et 0,50 $ US en sortie pour Claude Haiku 5.5 (invites d'au plus 100 000 jetons, lectures et écritures de cache comprises; au-delà, 0,50 $ US en entrée et 2,50 $ US en sortie), contre 10 $ US et 50 $ US pour Claude Fable 5.1, soit un facteur 100. S'y cumulent le rabais des lots, les multiplicateurs du cache et une majoration de 10 % pour l'inférence restreinte aux États-Unis comme pour les points de terminaison régionaux des plateformes partenaires; le segmenteur *(tokenizer)* des modèles Claude 4.7 et suivants produit en outre environ 30 % plus de jetons pour un même texte que le segmenteur précédent (celui de Claude Sonnet 4.6 et des modèles antérieurs), l'écart variant selon le contenu[399]. On compare donc des modèles au coût par tâche réussie, après normalisation, et un choix de résidence dicté par une EFVP (section 12.2) entre au modèle de coût; la zone « us » de l'API d'Anthropic n'est pas une résidence canadienne, et aucune zone canadienne n'y est offerte[400].

**Des leviers documentés.** Le traitement asynchrone par lots coûte 50 % de moins chez Anthropic comme chez OpenAI, avec une fenêtre de traitement de 24 heures[88, 89]. Le cache d'invites récompense un préfixe stable : chez Anthropic, le préfixe suit l'ordre outils, système, messages, toute modification d'une définition d'outil invalide le cache entier, et une lecture en cache coûte au plus 0,1 fois le prix d'entrée (0,05 fois pour Claude Opus 5.5 et Sonnet 5.5, 0,025 fois pour Claude Fable 5.1), mais une écriture coûte 1,25 fois (durée de vie de 5 minutes, par défaut) ou 2 fois (1 heure) ce prix[401]; chez OpenAI, le cache s'active dès 1 024 jetons pour GPT-5.6 et les suivants, et OpenAI recommande de placer le contenu stable avant le contenu dynamique[402]. Enfin, NVIDIA Research et Georgia Tech estiment que servir un petit modèle de 7 milliards de paramètres coûte de 10 à 30 fois moins, en latence, en énergie et en calcul, qu'un modèle de 70 à 175 milliards, et que de 40 à 70 % des requêtes de leurs études de cas pourraient lui être confiées[403]. C'est un coût de calcul, non un prix facturé, et l'équivalence de qualité reste une thèse que seule une mesure tranche.

**ATTENTION**

Les pourcentages d'économie par levier qui circulent dans la littérature commerciale (routage, élagage du contexte, cache sémantique, plafonds) n'ont, pour la plupart, aucune source vérifiable. Le cadre n'en reprend aucun : chaque levier se juge à l'économie mesurée sur la charge de l'entreprise.

**Des unités propres aux plateformes SaaS.** En octobre 2026, Microsoft Copilot Studio facture en Copilot Credits (par exemple 5 par action d'agent avec le moteur standard, et 10 par 1 000 jetons pour un modèle de raisonnement); au-delà de 125 % de la capacité prépayée du locataire, les agents personnalisés sont désactivés, sauf si la facturation à l'usage absorbe le dépassement, et un plafond mensuel peut être fixé par agent[53]. Salesforce Agentforce propose notamment des crédits à 0,005 $ US, soit environ 0,10 $ US par action standard, à titre indicatif[55]. Ces unités ne se comparent pas sans conversion.

**EXIG-FIN-01** — DOIT

**Comparaison au coût par tâche réussie**

Le choix ou le changement d'un modèle, d'un fournisseur ou d'une plateforme **DOIT** reposer sur le coût par tâche réussie mesuré sur le jeu de référence (section 10.4), et non sur le prix du jeton. Le modèle de coût intègre les modificateurs de prix (lots, cache, résidence), la normalisation des jetons d'un segmenteur à l'autre et, pour un modèle hébergé par l'entreprise, l'hébergement, l'exploitation et l'évaluation.

Pourquoi : un même texte ne donne pas le même nombre de jetons d'un modèle à l'autre[399], et le coût de calcul d'un petit modèle n'est pas son coût total[403].

**EXIG-FIN-02** — DOIT

**Hypothèses de prix datées et révisées**

Les prévisions budgétaires **DOIVENT** reposer sur des hypothèses de prix datées, révisées chaque trimestre avec le catalogue, sans extrapoler les baisses passées. Les exigences et les contrats d'agent **NE DOIVENT PAS** inscrire le prix d'un modèle : les fiches renvoient aux grilles des fournisseurs.

Pourquoi : les grilles changent souvent, et la persistance des baisses observées est incertaine[398].

**EXIG-FIN-03** — DOIT

**Unités SaaS converties et plafonnées**

Pour tout agent exploité sur une plateforme SaaS, l'équipe FinOps **DOIT** tenir une table de conversion entre les unités de l'éditeur (crédits, actions, conversations) et le coût par tâche réussie, et configurer les plafonds offerts, comme un plafond mensuel par agent. Un dépassement qui désactive des agents **DOIT** être traité comme un risque de continuité, avec seuil d'alerte et responsable nommé.

Pourquoi : sans conversion, construire et acheter ne se comparent pas, et un dépassement de capacité peut arrêter des agents[53].

## 10.6 Maîtrise des coûts

Cette section transforme ces repères en mécanismes de maîtrise des coûts, de l'enveloppe de la tâche jusqu'au calcul du coût par tâche réussie.

### Enveloppe budgétaire et quotas

Chaque demande reçoit à son entrée une enveloppe de jetons, de coût, d'appels d'outils et de délai (figure 23). Le Generative AI Lens d'AWS Well-Architected Framework recommande de telles conditions d'arrêt (délais d'expiration, limites de jetons) pour rendre prévisible le coût maximal d'un agent, et juge le risque élevé en leur absence[404]. Les

plafonds se déclarent à la fiche (EXIG-ORC-26) et voyagent avec chaque appel (EXIG-ARC-02); les valeurs de la figure sont illustratives. Aucune norme ne fixe les seuils : le cadre alerte à 80 % et arrête à 100 %. À la passerelle de modèles, les quotas s'appliquent par période; la politique `llm-token-limit` d'Azure API Management, par exemple, limite les jetons par minute et par quota sur une période d'une heure à un an, mais compte séparément par passerelle, estime les jetons en diffusion en continu, et sa limite peut être dépassée temporairement par des requêtes concurrentes[107]. Un quota de passerelle est donc une borne approximative; l'enveloppe, une borne logique.

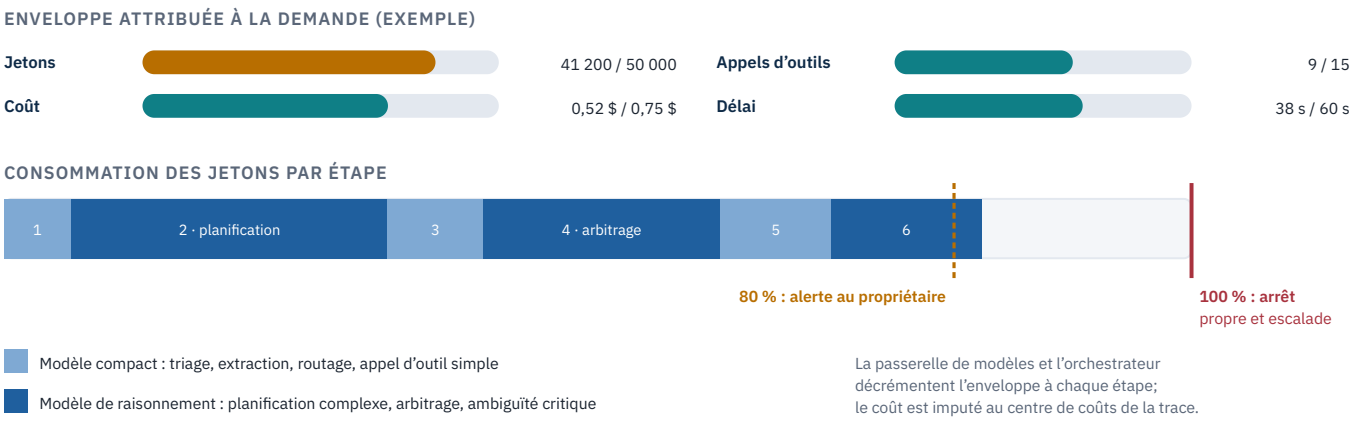



**Figure 23 — Enveloppe budgétaire d'une tâche.** L'enveloppe se décrémente à chaque étape; à 80 % d'un plafond, le propriétaire est alerté; à 100 %, l'exécution s'arrête proprement et passe en escalade. Les étapes simples vont au modèle compact, la planification au modèle de raisonnement.

Source : cadre CRE-IA-2026-01; valeurs illustratives.

**EXIG-FIN-04** — DOIT

**Enveloppe appliquée à chaque étape**

La passerelle de modèles et l'orchestrateur **DOIVENT** décrémenter l'enveloppe à chaque appel de modèle et d'outil, alerter le propriétaire dès qu'un plafond atteint 80 % et, à 100 %, arrêter l'exécution en état sûr et la passer en escalade, avec un refus typé « budget épuisé » (EXIG-IAM-18). Un orchestrateur qui délègue attribue à l'exécutant une part de l'enveloppe restante, jamais une enveloppe neuve.

Pourquoi : les conditions d'arrêt bornent le coût maximal[404], et une enveloppe recréée à chaque délégation rendrait le plafond inopérant; les seuils de 80 et 100 % sont des choix du cadre.

**EXIG-FIN-05** — DOIT

**Quotas et plafond mensuel par agent**

Chaque agent **DOIT** disposer, à la passerelle de modèles, d'un quota de jetons par minute et d'un plafond mensuel de coût inscrits à sa fiche (annexe B), avec une marge déclarée pour les dépassements possibles en concurrence. À son plafond mensuel, l'agent est suspendu ou ramené à son modèle de repli, selon sa fiche, et le parrain en est avisé.

Pourquoi : un agent ambiant s'exécute sans demande humaine, et la limite d'une passerelle peut être dépassée temporairement[107].

## Routage frugal, préfixe stable et lots

Le Centre d'architecture Azure demande d'attribuer à chaque agent un modèle proportionné à sa tâche, en notant que classification, extraction et mise en forme peuvent souvent se confier à de petits modèles sans baisse de la qualité globale, et de mesurer les jetons par agent et par exécution[9]. Le Generative AI Lens retient trois principes : choisir le modèle et le mode d'inférence selon le besoin réel, contrôler la longueur des invites et des réponses, borner les flux[405]. Les modèles de raisonnement se réservent d'abord à la planification complexe, à l'arbitrage entre contraintes et aux ambiguïtés critiques; tout autre emploi se justifie par une mesure (EXIG-FIN-06).

Pour profiter du cache, une invite va du plus stable au plus variable : outils, instructions système, documents récurrents, puis demande. Les serveurs MCP internes listent leurs outils dans un ordre déterministe (EXIG-MCP-03), et un outil chargé à la demande s'ajoute après le point de rupture du cache (section 6.5). Le taux de succès du cache se lit en rapportant `gen_ai.usage.cache_read.input_tokens` à `gen_ai.usage.input_tokens`, que la convention demande (*SHOULD*) d'établir en y incluant les jetons servis depuis le cache; l'API d'Anthropic rapporte toutefois ses lectures en cache à part, et le dénominateur se vérifie donc par fournisseur[119].

**EXIG-FIN-06**
**DOIT**

**Plus petit modèle suffisant**

Chaque étape d'un agent **DOIT** être servie par le plus petit modèle homologué qui atteint, pour cette étape, les seuils du jeu de référence. L'emploi d'un modèle de raisonnement se justifie à la fiche par une mesure; la passerelle applique la correspondance entre étape et modèle, de préférence par alias logique (EXIG-ARC-09).

Pourquoi : l'écart de prix atteint un facteur 100 chez un même fournisseur (Claude Fable 5.1 contre Claude Haiku 5.5, pour des invites d'au plus 100 000 jetons; facteur 20 au-delà)[399]; c'est le levier le plus direct, pourvu que la qualité soit démontrée.

**EXIG-FIN-07**
**DOIT**

**Préfixe stable et cache mesuré**

Les invites **DOIVENT** être assemblées en préfixe stable (outils, instructions système, contenus récurrents) suivi du contenu variable. Une définition d'outil ou une invite système **DOIT** se modifier par une version déployée, jamais à la volée. Le taux de lecture en cache est suivi par agent, et une baisse marquée ouvre une analyse.

Pourquoi : modifier une définition d'outil invalide tout le cache[401], et OpenAI recommande de placer le contenu stable en tête[402].

**EXIG-FIN-08**
**DEVRAIT**

**Lots asynchrones pour les charges non urgentes**

Les charges non urgentes des agents ambiants, des évaluations et des traitements périodiques **DEVRAIENT** passer par les API par lots lorsque leur délai, jusqu'à 24 heures, est acceptable. L'orchestrateur consigne l'identifiant du lot à son point de contrôle pour en reprendre les résultats (section 7.4).

Pourquoi : le traitement par lots coûte 50 % de moins chez les fournisseurs vérifiés[88, 89].

## Imputation et économie unitaire

Le cadre FinOps définit le périmètre de dépenses *(Scope)* comme un segment de dépenses aligné sur des constructions d'affaires (produit, centre de coûts, environnement) et cite la dépense d'IA agentique en exemple[406]. Le guide FinOps for AI (mis à jour le 17 février 2026) recommande de mettre en place un modèle de refacturation indicative *(showback)* et une stratégie d'étiquetage, et relève l'absence de cadres généralement admis pour répartir les coûts entre charges multiagents[407]. FOCUS 1.4 *(FinOps Open Cost and Usage Specification)* normalise les données de facturation (coûts, catégorie de service, quantité et unité consommées, étiquettes), avec une catégorie « AI and Machine Learning », mais sans colonne native de jetons ni indicateur par agent[408, 409]; la version 1.5 est traitée au chapitre 13. Les indicateurs par agent se calculent donc en joignant coûts FOCUS, télémétrie `gen_ai.*` et résultats métier. Le cadre en définit trois :

- **Coût par tâche réussie** : coût total imputé à l'agent (inférence, outils, quote-part de la plateforme) divisé par le nombre de tâches réussies selon son contrat, en dollars canadiens.
- **Jetons par agent et par exécution** : ventilés en entrée, sortie, lecture et écriture en cache et, s'il y a lieu, raisonnement, chaque catégorie se facturant à un tarif différent.
- **Ratio jetons/résultat** : jetons par tâche réussie; sa hausse à qualité égale signale une dérive (contexte qui enfle, boucle, cache rompu).

**EXIG-FIN-09**
**DOIT**

**Imputation par centre de coûts**

Chaque span **DOIT** porter le centre de coûts imputé (`ca.entreprise.cost_center`), tiré du référentiel financier et identique à l'étiquette des données de facturation. La dépense agentique est suivie comme un périmètre de dépenses FinOps *(Scope)* distinct, avec ses responsables. L'imputation commence par la refacturation indicative; la refacturation réelle suit, sur décision du comité, une fois les indicateurs stabilisés.

Pourquoi : la FinOps Foundation recommande la refacturation indicative pour l'IA[407]; une étiquette commune rend la jointure possible.

**EXIG-FIN-10**
**DOIT**

**Indicateurs d'économie unitaire publiés**

L'équipe FinOps **DOIT** calculer chaque mois, pour chaque agent en production, les trois indicateurs ci-dessus, à partir des données FOCUS exigées des fournisseurs (chapitre 13), de la télémétrie de la version épinglée et des résultats métier, et les transmettre au parrain et les inscrire au registre. Un agent dont le coût par tâche réussie dépasse celui du processus de référence deux mois de suite (choix du cadre) passe en revue de valeur (section 11.5).

Pourquoi : FOCUS normalise les données de facturation, non la performance des agents[410]; seul le croisement des coûts, des jetons et des résultats dit si un agent crée de la valeur.

PARTIE IV

# Gouvernance, conformité et mise en œuvre

Qui décide et répond de quoi, quelles obligations s'appliquent, comment acheter, mesurer la maturité et déployer le cadre.


11 · Gouvernance et cycle de vie

12 · Risques, conformité et réglementation

13 · Approvisionnement et clauses contractuelles

14 · Modèle de maturité

15 · Feuille de route et indicateurs

# 11 Gouvernance et cycle de vie

Un agent qui agit au nom de l'entreprise relève d'une personne nommée, figure au registre et suit un parcours balisé, de sa proposition à son retrait. Ce chapitre répartit les rôles, fixe la matrice RACI et le modèle opérationnel en étoile, puis définit le registre d'entreprise des agents et des serveurs MCP, les points de contrôle du cycle de vie et le régime des dérogations. Il précise enfin comment le cadre admet, révise et retire les standards de son catalogue.

**À RETENIR**

Trois règles structurent ce chapitre : une personne nommée répond de chaque agent; sans fiche complète au registre, aucun justificatif de production; tout changement significatif rouvre l'évaluation. Les rôles, la matrice RACI, les points de contrôle et les dérogations organisent l'application de ces trois règles.

## 11.1 Rôles et responsabilités

Cette section nomme les rôles que le cadre mobilise et ce que chacun doit livrer (tableau 43). Le principe est simple : un agent ne répond pas de ses actes (section 3.4); une personne identifiable en répond, et chaque décision du cycle de vie revient à un rôle précis.

Les référentiels convergent sur ce point. Le NIST AI RMF demande que les rôles et responsabilités liés aux risques de l'IA soient documentés (GOVERN 2.1) et que l'intensité de la gestion des risques suive la tolérance au risque de l'organisation (GOVERN 1.3)[74]. ISO/IEC 42001 traite des rôles à l'article 5.3 et de l'organisation interne à la mesure A.3 de son annexe A[395]. Au Québec, la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1, ci-après « Loi sur le privé »), modifiée par la Loi 25, confie la fonction de responsable de la protection des renseignements personnels (RPRP) à la personne ayant la plus haute autorité, qui peut la déléguer par écrit; la Loi exige aussi des politiques de gouvernance qui précisent les rôles et responsabilités tout au long du cycle de vie des renseignements (art. 3.1 et 3.2)[56]. Les organismes publics appliquent les dispositions équivalentes de la Loi sur l'accès, notamment les articles 63.3 (règles de gouvernance) et 63.5 (EFVP)[56].

Microsoft Entra Agent ID distingue, pour chaque agent, un parrain *(sponsor)*, qui porte la responsabilité métier, et un propriétaire, qui l'administre techniquement[90]. Le cadre reprend cette distinction sans dépendre du produit : le propriétaire métier joue le rôle de parrain, le responsable technique celui de propriétaire au sens d'Entra.

**Tableau 43 — Rôles de la gouvernance agentique**

| Rôle | Responsabilités principales | Fondement ou remarque |
|---|---|---|
| Propriétaire métier (parrain) | Répond de la finalité, des résultats et des effets de l'agent; demande son niveau d'autonomie; finance l'agent; atteste périodiquement qu'il est encore requis. | Une personne, jamais une équipe ni un fournisseur. |
| Responsable technique | Conçoit, construit, teste et exploite l'agent; tient à jour sa fiche, son contrat et sa carte d'agent; dirige l'équipe de garde. | Ne peut homologuer son propre agent (EXIG-GOV-03). |
| Équipe plateforme | Opère les passerelles, le registre, le catalogue, le traçage, l'outillage d'évaluation, les gabarits et le coupe-circuit global. | Centre du modèle en étoile (section 11.3). |
| Architecture d'entreprise | Tient le cadre et le catalogue des protocoles; conduit les revues d'architecture; instruit les dérogations. | Gouvernance des standards (section 11.7). |

| Rôle | Responsabilités principales | Fondement ou remarque |
|---|---|---|
| Sécurité de l'information | Modèle de menaces; politique des identités et des paliers d'outils; tests d'abus et équipe rouge; réponse aux incidents de sécurité. | Chapitre 9. |
| Risques et conformité | Classe le risque des agents; vérifie la conformité réglementaire; suit les dérogations et les risques résiduels. | Chapitre 12. |
| Responsable de la protection des RP (RPRP) | Est consulté dès le début de tout projet impliquant des RP; encadre les EFVP; approuve les politiques de gouvernance des RP; dirige le traitement des incidents de confidentialité (choix du cadre). | Loi sur le privé, art. 3.1 à 3.3. |
| Comité d'architecture et des risques agentiques | Approuve les agents de classe élevée et tout niveau N4; accorde les dérogations; approuve le catalogue des protocoles; révise le cadre chaque semestre. | Instance décisionnelle du cadre (EXIG-GOV-02). |
| Approbateurs humains | Approuvent ou refusent, sur la base de l'action exacte, les actions que la section 8.4 soumet à approbation. | Personnes compétentes, formées et dotées de l'autorité nécessaire (règlement européen sur l'IA, ou RIA, art. 26). |
| Équipe de garde | Surveille l'agent en production, reçoit les escalades, suspend l'agent au besoin et applique les procédures d'incident. | Joignable pendant les heures d'exploitation déclarées. |

L'exigence relative aux approbateurs s'inspire du règlement européen sur l'IA : le déployeur d'un système à haut risque confie la supervision humaine à des personnes compétentes, formées et dotées de l'autorité nécessaire (art. 26)[61, 94]. Pour les systèmes de l'annexe III, cette obligation s'applique à compter du 2 décembre 2027 (2 août 2028 pour ceux de l'annexe I, soit les produits réglementés)[58]. Le cadre l'étend à tous les agents, quelle que soit leur classe (EXIG-AUT-15).

**EXIG-GOV-01**
**DOIT**

**Responsables nommés pour chaque agent**

Chaque agent et chaque serveur MCP inscrits au registre **DOIVENT** avoir un propriétaire métier (parrain) et un responsable technique désignés nommément, ainsi qu'une équipe de garde joignable pendant les heures d'exploitation déclarées. Pour un agent intégré à un logiciel-service ou exploité par un partenaire, le parrain est la personne interne qui répond de son usage et du contrat.

Pourquoi : une responsabilité confiée à « l'équipe » ou au fournisseur n'est exercée par personne; l'OWASP place le retrait inadéquat des identités non humaines, typique des agents orphelins, au premier rang de son NHI Top 10 (NHI1)[91].

**EXIG-GOV-02**
**DOIT**

**Comité d'architecture et des risques agentiques**

L'entreprise **DOIT** constituer un comité d'architecture et des risques agentiques doté d'un mandat écrit qui précise sa composition (au minimum l'architecture d'entreprise, la sécurité de l'information, la fonction risques et conformité, le RPRP ou son délégué, l'équipe plateforme et des représentants des domaines métier), son quorum, ses pouvoirs et la fréquence de ses réunions. Ses décisions **DOIVENT** être motivées et consignées au registre.

Pourquoi : les décisions qui engagent l'entreprise (niveau N4, agent de classe élevée, dérogation, catalogue des protocoles) exigent une instance qui réunit les expertises et dont les arbitrages laissent une trace vérifiable.

**EXIG-GOV-03**
**NE DOIT PAS**

**Séparation des fonctions**

Une même personne **NE DOIT PAS** à la fois préparer et approuver une décision du cycle de vie d'un agent : le responsable technique d'un agent n'homologue pas sa mise en production, n'accorde pas une dérogation qui le vise et n'approuve pas les actions P3 de cet agent.

Pourquoi : la séparation des fonctions est le contrôle le plus simple contre l'erreur et la complaisance; elle donne son sens au « A » de la matrice RACI.

## 11.2 Matrice RACI

Cette section attribue chaque activité du cycle de vie à un rôle qui réalise (R), à un seul rôle qui approuve et répond (A), aux rôles consultés (C) et aux rôles informés (I). Le tiret signifie « non concerné ». Abréviations des colonnes : PM, propriétaire métier (parrain); RT, responsable technique; PL, équipe plateforme; AE, architecture d'entreprise; SÉC, sécurité de l'information; RC, risques et conformité; RPRP, responsable de la protection des RP; CO, comité d'architecture et des risques agentiques.

**Tableau 44 — Matrice RACI du cycle de vie d'un agent**

| Activité | PM | RT | PL | AE | SÉC | RC | RPRP | CO |
|---|---|---|---|---|---|---|---|---|
| Inscrire l'agent au registre | A | R | C | I | I | I | — | — |
| Classer le risque de l'agent | R | C | — | C | C | A | C | I |
| Fixer le niveau d'autonomie | A | R | — | C | C | C | — | I |
| Classer les outils par palier (P0 à P3) | C | R | C | I | A | C | C | — |
| Concevoir, construire et évaluer | C | A, R | C | C | C | I | I | — |
| Réaliser l'EFVP | A | R | I | I | C | C | C | — |
| Homologuer la mise en production (le responsable technique prépare le dossier, il ne décide pas) | A | R | C | C | C | C | C | I |
| Exploiter et surveiller | I | A, R | R | — | C | I | — | — |
| Gérer un incident | I | R | R | I | A | C | C | I |
| Accorder une dérogation | R | C | I | R | C | C | C | A |
| Attester périodiquement l'agent | A, R | C | I | — | I | I | — | — |
| Retirer l'agent | A | R | R | I | C | I | C | — |
| Réviser le catalogue des protocoles | I | I | C | R | C | C | — | A |

Trois règles complètent la matrice. Pour un agent de classe élevée ou visant le niveau N4, le comité devient A pour le niveau d'autonomie et l'homologation, et le propriétaire métier devient R. Pour un incident de confidentialité, le cadre confie au RPRP le rôle A pour l'évaluation du préjudice, les avis et l'inscription au registre des incidents prévus aux articles 3.5 à 3.8 de la Loi sur le privé (section 12.8). Enfin, l'équipe de garde exécute, pour le responsable technique, les tâches R de l'exploitation et de la gestion des incidents.

Le classement du risque revient à la fonction risques et conformité plutôt qu'au parrain : celui qui souhaite déployer l'agent propose la classe, une fonction indépendante la tranche. De même, la sécurité valide le palier d'un outil, parce que ce palier détermine les contrôles exigés (section 8.3).

**EXIG-GOV-04**
**DOIT**

**Un seul A, des personnes nommées**

Chaque activité de tableau 44 **DOIT** avoir un et un seul rôle A. La fiche de chaque agent **DOIT** nommer les personnes qui tiennent, pour cet agent, les rôles R et A de la matrice, y compris, pour chaque combinaison de classe de risque et de palier d'outil, les approbateurs humains (EXIG-AUT-15); une fiche dont un rôle A est vacant est incomplète.

Pourquoi : deux « A » diluent la responsabilité, et une matrice sans noms ne sert à rien le jour d'un incident.

## 11.3 Modèle opérationnel en étoile

Cette section fixe la répartition du travail entre une plateforme centrale et les domaines métier (figure 24 et tableau 45). Le cadre retient un modèle en étoile *(hub-and-spoke)* : la plateforme fournit et opère le socle commun; les domaines bâtissent et exploitent leurs agents en libre-service; la sécurité, les risques et la gouvernance encadrent les deux.

Ce choix évite deux échecs connus. Tout centraliser crée un goulot d'étranglement : chaque agent attend une équipe qui ne connaît pas le métier. Tout décentraliser multiplie les passerelles, les registres et les façons de gérer les identités, donc les failles. Dans le modèle en étoile, un contrôle s'écrit une fois dans la plateforme et s'applique partout, tandis que la logique métier reste la propriété des domaines.

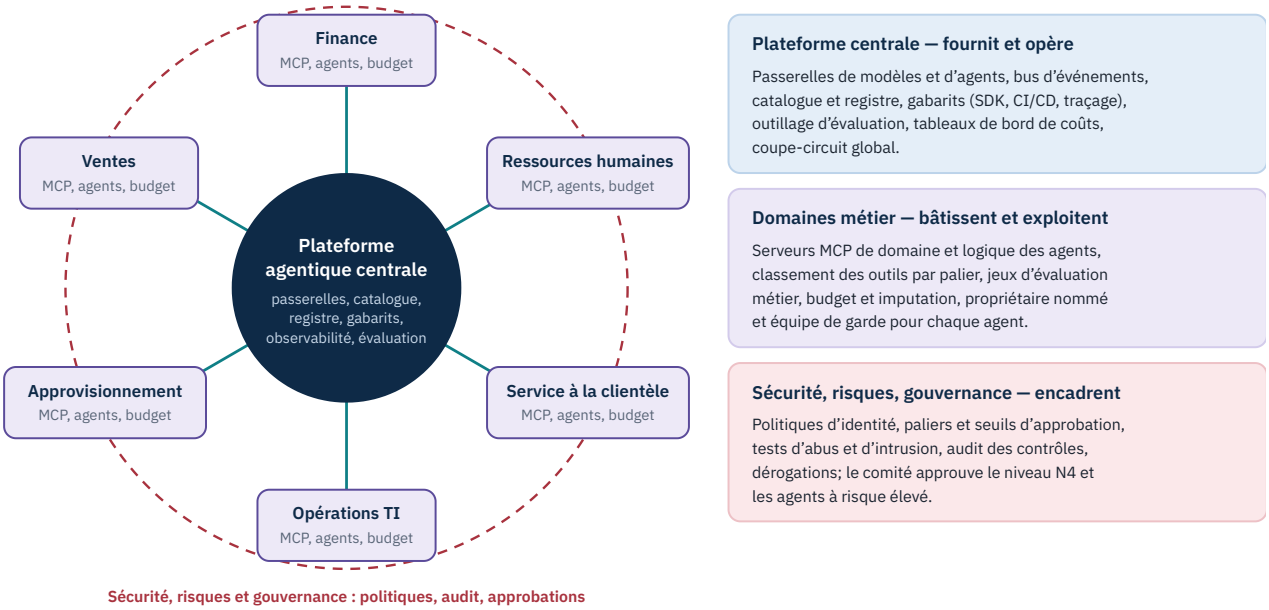



**Figure 24 — Modèle opérationnel en étoile.** La plateforme centrale fournit une seule fois les passerelles, le registre, les gabarits et le coupe-circuit; chaque domaine y branche ses serveurs MCP et ses agents; la sécurité, les risques et la gouvernance encadrent l'ensemble.

Source : CRE-IA-2026-01; les six domaines sont donnés à titre d'exemple.

**Tableau 45 — Répartition des responsabilités dans le modèle en étoile**

| Responsabilité | Plateforme centrale | Domaines métier | Sécurité, risques et gouvernance |
|---|---|---|---|
| Passerelles de modèles et d'agents, bus d'événements | R, A : conçoit, opère, sécurise | C : consomme en libre-service | C : audite les contrôles |

| Responsabilité | Plateforme centrale | Domaines métier | Sécurité, risques et gouvernance |
|---|---|---|---|
| Registre, catalogue et coupe-circuit global | R, A : opère l'outillage | R : tient ses fiches et contrats à jour | C : vérifie la complétude; peut déclencher le coupe-circuit |
| Gabarits d'agents (trousses de développement, CI/CD, traçage) | R, A : fournit et maintient | I : instancie | C : valide les contrôles intégrés |
| Serveurs MCP de domaine et logique des agents | C : accompagne | R, A : développe, teste, exploite | C : impose les tests d'abus |
| Classement des outils par palier | C : inscrit au catalogue | R : propose | A : valide selon la politique des paliers |
| Jeux d'évaluation métier | C : outille la chaîne d'évaluation | R, A : définit les scénarios | C : exige les cas adverses |
| Politiques d'identité et seuils d'approbation | R : applique dans les passerelles | C : décrit les cas métier | A : définit |
| Budget et imputation des coûts | R : mesure et expose les coûts | A : maîtrise son budget | I |

**EXIG-GOV-05**
**DOIT**

**Socle commun obligatoire**

Les domaines métier **DOIVENT** utiliser les passerelles, le registre, le catalogue, la chaîne de traçage et le coupe-circuit fournis par la plateforme. Un domaine **NE DOIT PAS** exploiter de passerelle, de registre ou de catalogue parallèle sans dérogation (section 11.6).

Pourquoi : un contrôle appliqué en deux endroits finit par diverger; la règle centrale de l'architecture veut que rien n'atteigne un outil, une donnée ou un agent hors domaine sans la passerelle et le catalogue (section 5.1).

**EXIG-GOV-06**
**DEVRAIT**

**Conformité par construction**

La plateforme **DEVRAIT** fournir des gabarits d'agents qui intègrent par défaut l'identité propre de l'agent, la propagation du contexte de trace, les plafonds de coût, de jetons et d'itérations, l'appel aux outils par la passerelle et l'inscription au registre, de sorte que le chemin conforme soit aussi le plus court pour une équipe de domaine.

Pourquoi : un contrôle livré dans le gabarit coûte une fois; un contrôle exigé en revue coûte à chaque agent et se contourne sous la pression des échéances.

## 11.4 Registre d'entreprise des agents et serveurs MCP

Cette section définit le registre, inventaire faisant autorité de tous les agents et serveurs MCP de l'entreprise. On ne gouverne pas ce qu'on ne voit pas : le registre est la condition de tous les autres contrôles.

Le NIST AI RMF, d'application volontaire, prévoit des mécanismes d'inventaire des systèmes d'IA, dotés de ressources selon les priorités de risque (GOVERN 1.6)[74]. Pour les institutions financières fédérales, la ligne directrice E-23 du BSIF, en vigueur le 1er mai 2027, exige un inventaire d'entreprise des modèles à risque non négligeable, y compris ceux des fournisseurs, et une cote de risque qui détermine l'intensité de la gouvernance[8]. Le registre du cadre répond à ces deux attentes : il couvre les agents tiers et consigne les modèles utilisés.

### Contenu et états de la fiche

Chaque agent et chaque serveur MCP a une fiche, dont le gabarit complet figure à l'annexe B. Elle consigne au minimum l'identification et la version; le parrain, le responsable technique, l'équipe de garde et les approbateurs; la finalité et les mandants autorisés; la classe de risque et le niveau d'autonomie approuvés; les outils appelés et leurs paliers; les modèles et leurs versions; les données touchées et la présence de RP; l'identité et les portées; les résultats d'évaluation; le budget et les plafonds; l'état de cycle de vie, les dates de revue et les dérogations en vigueur. Le niveau d'autonomie inscrit tient lieu, à l'interne, de « certificat d'autonomie » tel que le conçoivent Feng, McDonald et Zhang (qui le font délivrer par un tiers) : un plafond lisible par les autres agents et par la passerelle, valable pour une configuration donnée[83].

La fiche passe par sept états : « proposé », « en conception », « en construction », « pilote », « production », « suspendu » et « retiré ». Seuls les états « pilote » et « production » permettent d'obtenir des justificatifs d'exécution en production.

### Registre et catalogue

Le registre répond aux questions « qui, quoi, pourquoi et avec quel risque »; le catalogue d'entreprise (section 6.8) répond à « par quel contrat et dans quelle version ». Les deux partagent l'identifiant de l'agent ou du serveur, ce qui permet à la passerelle de vérifier à chaque appel l'état de la fiche et la version épinglée du contrat. Le registre d'entreprise est distinct du registre officiel MCP : celui-ci, en préversion depuis le 8 septembre 2025, ne contient que des métadonnées de serveurs publics, ne prend pas en charge les serveurs privés et recommande aux entreprises d'opérer leur propre sous-registre[25, 43]. Il peut servir de source de découverte, jamais de registre d'entreprise.

### Exemples de mise en œuvre

Plusieurs produits couvrent une partie du rôle; ce sont des exemples non limitatifs, à l'état du 27 octobre 2026. Microsoft Agent 365, en disponibilité générale depuis le 1er mai 2026, offre un registre et des contrôles comme le blocage des agents non gérés[46]. Amazon Bedrock AgentCore Registry tient un catalogue gouverné d'agents, de serveurs MCP, d'outils et de compétences, avec un flux de publication, de revue et d'approbation[102]. Azure API Center sert de registre privé pour découvrir les serveurs MCP d'une organisation[108]. ServiceNow a annoncé le 5 mai 2026 l'extension de son AI Control Tower à la découverte des actifs d'IA déployés par 30 nouvelles intégrations et à un coupe-circuit[47].

**ATTENTION**

Un registre de plateforme voit d'abord les agents de sa propre plateforme. Au 1er mai 2026, la synchronisation du registre d'Agent 365 avec Amazon Bedrock et Google Cloud était en préversion publique, et les actions de cycle de vie sur les agents infonuagiques tiers étaient annoncées comme à venir[46]. Le registre d'entreprise est donc un rôle d'architecture alimenté par plusieurs sources, et la suspension d'un agent s'applique à la passerelle d'agents, pas seulement dans la console de son éditeur.

**EXIG-GOV-07**
**DOIT**

**Inventaire complet**

Le registre **DOIT** inventorier tout agent et tout serveur MCP qui agit dans le périmètre de l'entreprise, qu'il soit développé à l'interne, intégré à un logiciel-service ou exploité par un partenaire, avec une fiche conforme à l'annexe B, y compris les modèles utilisés et leurs versions.

Pourquoi : le NIST AI RMF range les logiciels, données et composants de tiers parmi les risques à gouverner (GOVERN 6.1 et 6.2)[74]; un agent tiers absent du registre échappe à toute revue.

**EXIG-GOV-08**
**NE DOIT PAS**

**Sans fiche, aucun justificatif**

Une identité d'agent ou de serveur MCP **NE DOIT PAS** recevoir de justificatif valide en production tant que sa fiche n'est pas complète, approuvée et à l'état « pilote » ou « production ». La passerelle d'agents **DOIT** refuser tout appel d'une identité absente du registre ou à l'état « suspendu ».

Pourquoi : lier l'émission des justificatifs à l'état du registre transforme l'inventaire en contrôle d'accès; un agent non inscrit ne peut rien faire.

**EXIG-GOV-09**
**DOIT**

**Fiche à jour ou agent suspendu**

La fiche **DOIT** être mise à jour avant la mise en œuvre de tout changement qui en modifie le contenu. Un agent dont l'attestation périodique est échue, ou dont un rôle A est vacant depuis plus de 30 jours, **DOIT** passer à l'état « suspendu » jusqu'à sa régularisation. Le délai de 30 jours est un choix du cadre.

Pourquoi : une fiche périmée donne une fausse assurance; la suspension rend le coût de la négligence visible pour le parrain plutôt que pour la sécurité.

**EXIG-GOV-10**
**DOIT**

**Détection des agents hors registre**

L'équipe plateforme **DOIT**, au moins chaque mois, rapprocher le registre de sources indépendantes (journaux des passerelles, identités d'agents du fournisseur d'identité, inventaires des logiciels-services, facturation des fournisseurs de modèles) et placer en quarantaine tout agent découvert hors registre jusqu'à son inscription ou son retrait. La fréquence mensuelle est un choix du cadre.

Pourquoi : les agents fantômes naissent hors des processus; seul un rapprochement avec ce que les systèmes observent réellement les fait apparaître. Certaines plateformes facilitent ce rapprochement : depuis juillet 2026, Copilot Studio crée automatiquement une identité Entra Agent ID pour chaque nouvel agent[48].

## 11.5 Cycle de vie et points de contrôle

Cette section découpe la vie d'un agent en six étapes, chacune fermée par un point de contrôle qui laisse une preuve au registre. L'intensité des contrôles suit la classe de risque : un agent de classe faible franchit les mêmes portes qu'un agent de classe élevée, avec des preuves plus légères.

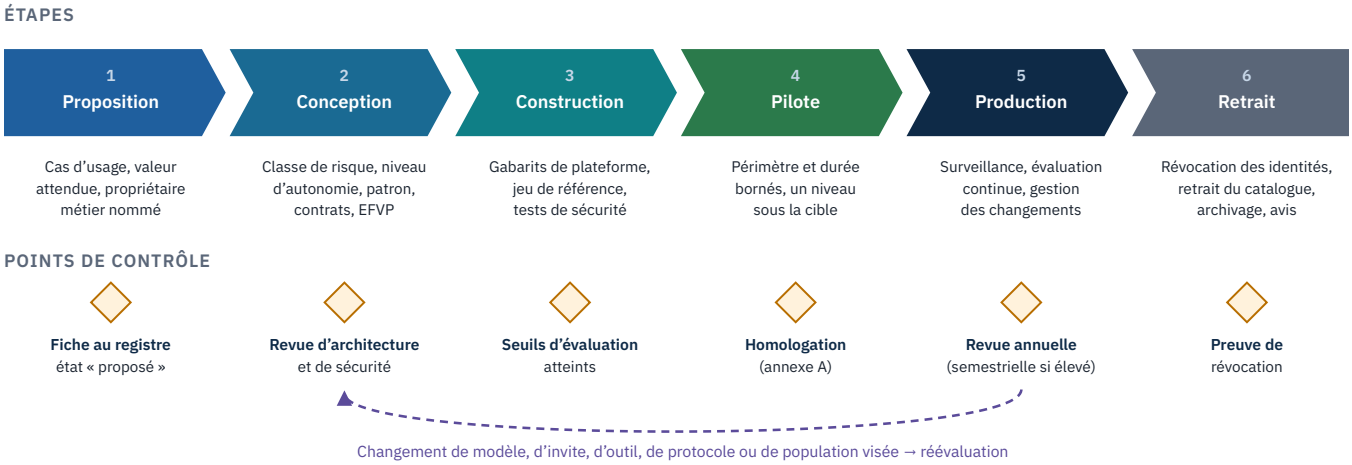



**Figure 25 — Cycle de vie d'un agent et points de contrôle.** Chaque étape se termine par un point de contrôle consigné au registre; en production, un changement significatif renvoie l'agent aux étapes de conception, d'évaluation et de pilote, dans la mesure du changement.
Source : CRE-IA-2026-01.

1. **Proposition.** Le parrain décrit le cas d'usage et la valeur attendue. Point de contrôle : fiche créée à l'état « proposé », avec une première estimation de la classe de risque.
2. **Conception.** L'équipe propose la classe de risque, que la fonction risques et conformité tranche (tableau 44), puis fixe, sous le plafond de cette classe (section 8.1), le niveau d'autonomie visé, le patron d'orchestration (chapitre 7), les contrats et la carte d'agent (section 6.8). S'il y a des RP, l'EFVP commence ici : la Loi sur le privé l'exige pour tout projet d'acquisition, de développement ou de refonte d'un système d'information impliquant des RP, et le RPRP est consulté dès le début (art. 3.3)[56]. Point de contrôle : revue d'architecture et de sécurité.
3. **Construction et évaluation.** L'agent est bâti sur les gabarits de la plateforme, avec son jeu d'évaluation et ses tests de sécurité (section 9.9). Point de contrôle : seuils d'évaluation atteints (section 10.4), fiche complète et, s'il y a des RP, EFVP terminée (EXIG-CON-04).
4. **Pilote.** Périmètre, population et durée sont bornés. Le pilote d'un agent qui vise N3 ou N4 devrait s'exécuter au niveau immédiatement inférieur. Point de contrôle : homologation selon la grille d'homologation (annexe A).
5. **Production.** Surveillance, évaluation continue et gestion des changements. Point de contrôle : attestation périodique du parrain (EXIG-GOV-13), tous les 12 mois, tous les 6 mois pour la classe élevée.
6. **Retrait.** Révocation des identités, retrait du catalogue, avis aux consommateurs et archivage. Point de contrôle : preuve de révocation au registre.

La suspension se distingue du retrait. Elle est immédiate et réversible : c'est le coupe-circuit, que le NIST rattache aux mécanismes permettant de supplanter, désengager ou désactiver un système dont le comportement s'écarte de l'usage prévu (MANAGE 2.4)[74]. Le retrait est définitif et planifié. Le délai maximal de suspension se fixe et se teste selon la section 7.8 et la section 9.4; dans Microsoft Entra Agent ID, par exemple, désactiver le gabarit *(agent identity blueprint)* bloque d'un coup toutes les identités qui en dérivent[92].

**EXIG-GOV-11**
**DOIT**

**Points de contrôle consignés**

Un agent **DOIT** franchir dans l'ordre les six points de contrôle de figure 25. Chaque passage est consigné au registre avec la date, le décideur désigné par tableau 44 et les preuves (rapport d'évaluation, EFVP, résultats des tests de sécurité, grille d'homologation de l'annexe A).

Pourquoi : une décision sans trace ne peut être ni auditée ni contestée; le registre devient le dossier de preuve de l'agent.

**EXIG-GOV-12**
**DOIT**

**Réévaluation sur changement significatif**

Les changements suivants **DOIVENT** déclencher une réévaluation de la classe de risque et du niveau d'autonomie avant leur mise en production : changement de modèle ou de version de modèle; modification de l'invite système; ajout d'un outil ou passage d'un outil à un palier supérieur; nouvelle version majeure d'un contrat ou d'un protocole; nouvelle population visée ou nouvelle finalité; modification du domaine d'exploitation (ODD); nouvelle catégorie de données, notamment de RP; changement de fournisseur ou de lieu de traitement des données; incident grave ou dérive détectée par l'évaluation continue. La réévaluation reprend les points de contrôle de conception, d'évaluation et de pilote dans la mesure du changement. Si le changement ne peut attendre, l'agent fonctionne au niveau d'autonomie inférieur jusqu'à la fin de la réévaluation (EXIG-AUT-05).

Pourquoi : le niveau d'autonomie vaut pour une configuration donnée; Feng, McDonald et Zhang prévoient le renouvellement du certificat d'autonomie à chaque changement de l'agent ou de son environnement[83], et la ligne directrice E-23 du BSIF déclenche une revue indépendante lors de modifications des modèles ou des données[8].

EXEMPLE

Un agent de rapprochement de factures fournisseurs de classe modérée, homologué au niveau N3, utilise un modèle dont le fournisseur annonce une nouvelle version. La passerelle de modèles conserve la version épinglée pendant que l'équipe rejoue le jeu d'évaluation sur la nouvelle; la fonction risques confirme la classe, puis le parrain approuve la bascule, consignée au registre. Si les seuils ne sont pas atteints, l'agent reste sur l'ancienne version, ou redescend à N2 le temps de corriger.

**EXIG-GOV-13**
**DOIT**

**Attestation périodique du parrain**

Le parrain **DOIT** attester au registre, au moins tous les 12 mois et tous les 6 mois pour un agent de classe élevée, que l'agent est encore requis et que sa finalité, ses mandants, ses portées, sa classe et son niveau d'autonomie restent exacts. L'équipe plateforme **DOIT** revoir chaque trimestre la liste des agents sans parrain actif, sans fiche à jour ou inactifs, et désactiver ceux qui ne sont pas régularisés (EXIG-IAM-07).

Pourquoi : Microsoft recommande de faire attester par les parrains, tous les 6 à 12 mois, que chaque agent est encore requis, et de revoir chaque trimestre les agents orphelins[92]; le cadre retient la borne la plus stricte pour la classe élevée, et les périodicités de 12 mois, de 6 mois et d'un trimestre sont des choix du cadre.

**EXIG-GOV-14**
**DOIT**

**Retrait vérifiable**

Le retrait d'un agent **DOIT** comprendre : la révocation de toutes ses identités, justificatifs et jetons, propagée aux passerelles et aux fournisseurs dans le délai maximal fixé par l'entreprise (EXIG-IAM-07); un avis aux consommateurs connus au moins 60 jours avant la fin du service, sauf retrait anticipé pour un motif de sécurité, décidé par le comité et précédé d'une suspension (EXIG-INT-14); le retrait de ses entrées au catalogue; l'archivage de ses journaux d'audit et de ses versions selon les durées de conservation applicables; l'archivage ou la destruction de ses mémoires selon la politique de conservation; une preuve de révocation inscrite au registre. Le préavis de 60 jours est un choix du cadre, aligné sur la coexistence des versions (section 6.8).

Pourquoi : le NIST AI RMF demande des processus de déclassement sécuritaire (GOVERN 1.7)[74], le livre blanc de l'OpenID Foundation recommande un retrait formel propagé, par exemple par une opération SCIM DELETE[311], et les événements CAEP permettent de diffuser la révocation aux parties concernées[344].

## 11.6 Dérogations

Cette section encadre les exceptions au cadre. Une dérogation est une exception écrite, temporaire et compensée; elle n'est jamais une permission tacite. Sans dérogations, un cadre trop rigide pousse les équipes vers des agents fantômes; sans discipline, les dérogations vident le cadre de son contenu.

Une demande de dérogation contient au minimum :

- l'identifiant de chaque exigence visée et le ou les agents concernés;
- la justification : pourquoi la conformité est impossible ou disproportionnée maintenant;
- le risque résiduel et son effet sur la classe de risque;
- les mesures compensatoires, par exemple un niveau d'autonomie abaissé, une approbation humaine ajoutée, un plafond de coût réduit ou une surveillance renforcée;
- la durée, la date d'échéance et le plan de retour à la conformité;
- le demandeur, les avis reçus et le décideur.

**EXIG-GOV-15**
**DOIT**

**Demande et décision écrites**

Toute dérogation **DOIT** être demandée par écrit par le parrain avec le contenu minimal ci-dessus, instruite par l'architecture d'entreprise avec l'avis de la sécurité, de la fonction risques et, s'il y a des RP, du RPRP, puis accordée ou refusée par le comité. Le comité **PEUT** déléguer à l'architecture d'entreprise les dérogations qui visent un agent de classe faible, pour 90 jours au plus (choix du cadre), à la condition que la décision soit prise par une personne autre que celle qui a instruit la demande. La dérogation est inscrite au registre et visible dans la fiche de l'agent.

Pourquoi : une exception accordée oralement ne se retrouve ni à l'audit ni à l'échéance; la délégation pour la classe faible évite d'engorger le comité.

**EXIG-GOV-16**
**DOIT**

**Durée bornée**

Une dérogation **DOIT** porter une date d'échéance d'au plus six mois. Elle **PEUT** être renouvelée une seule fois, par décision du comité, sur présentation d'un plan de retour à la conformité mis à jour. À l'échéance, l'exigence s'applique de nouveau; si l'agent n'y satisfait pas, il passe à l'état « suspendu ». Le registre **DOIT** avertir le parrain 30 jours avant l'échéance. Ces durées sont des choix du cadre.

Pourquoi : une exception sans échéance devient la règle; une exception qu'on veut renouveler plusieurs fois signale plutôt une règle à revoir, ce que tranche la révision semestrielle du cadre (section 1.6).

**EXIG-GOV-17**
**NE DOIT PAS**

**Exigences non dérogeables**

Une dérogation **NE DOIT PAS** autoriser un niveau d'autonomie NX; l'exécution d'une action P3 sans approbation humaine; l'usurpation d'identité au lieu de la délégation (section 9.3); l'exploitation d'un agent sans fiche au registre ni parrain nommé; le dépassement du plafond d'autonomie de la classe de risque (section 8.1); ou le manquement à une obligation légale ou réglementaire.

Pourquoi : ces règles protègent contre des dommages irréversibles ou contre une responsabilité légale que l'entreprise ne peut pas écarter par une décision interne.

## 11.7 Gouvernance des standards

Cette section fixe la façon dont le cadre fait évoluer son catalogue des protocoles et standards (section 6.3). Les standards agentiques changent de trimestre en trimestre : sans processus explicite, chaque annonce de fournisseur devient une décision d'architecture improvisée.

Le Cadre européen d'interopérabilité rappelle que l'interopérabilité est régulièrement perturbée par les changements législatifs, organisationnels et technologiques, et qu'elle exige des procédures de gestion du changement[157]. Les exemples récents le confirment. La révision 2026-07-28 de MCP a introduit une politique de cycle de vie à trois états (Active, Deprecated, Removed) : une fonctionnalité dépréciée reste au moins douze mois dans la spécification, ou au moins 90 jours en cas de retrait accéléré pour un risque de sécurité actif[34, 196]. Les conventions sémantiques GenAI d'OpenTelemetry sont au niveau de stabilité Development et peuvent changer sans processus de dépréciation[181, 188]. OAuth 2.1 demeure un Internet-Draft[176].

Chaque statut du catalogue emporte une conséquence de gouvernance. « Adopter » désigne le choix par défaut des nouveaux projets. « Évaluer » autorise des pilotes bornés, avec une date de décision. « Surveiller » limite le standard à la veille et aux essais hors production, sans données réelles. « Contenir » tolère l'existant, interdit tout nouvel usage et exige un plan de sortie.

**EXIG-GOV-18**
**DOIT**

**Révision trimestrielle du catalogue**

L'architecture d'entreprise **DOIT** réviser le catalogue des protocoles au moins chaque trimestre et soumettre les changements de statut à l'approbation du comité. Chaque changement est daté et motivé; une dépréciation ou un retrait s'accompagne d'un plan de migration dont l'échéance précède la fin de la fenêtre de dépréciation annoncée par le standard. Une révision extraordinaire **DOIT** avoir lieu dès qu'un standard au statut « Adopter » publie une version majeure ou une dépréciation; un correctif de sécurité **PEUT** aussi la justifier (section 1.6).

Pourquoi : une fenêtre de dépréciation de douze mois ne protège que l'organisation qui la voit venir et planifie sa migration dès l'annonce.

**EXIG-GOV-19**
**DOIT**

**Critères d'admission d'un standard**

Un standard **DOIT** satisfaire aux six critères suivants, propres au cadre, pour obtenir le statut « Adopter » :

- spécification publique, versionnée et assortie d'une politique de compatibilité et de dépréciation;
- gouvernance neutre ou multipartite (organisme de normalisation ou fondation), et non celle d'un seul fournisseur;
- statut final ou stable (RFC, Recommandation du W3C, version ou révision publiée comme stable); un brouillon ou un composant de niveau expérimental n'est admis qu'avec une réserve inscrite au catalogue, épinglé à une version précise et adossé à un standard publié ou à un mécanisme stable;
- au moins deux mises en œuvre indépendantes, ou une suite de tests de conformité exécutable dans la chaîne d'intégration;
- modèle de sécurité documenté, compatible avec le chapitre 9;
- licence ouverte, sans redevance.

Pourquoi : ces critères écartent les annonces prématurées. L'AAIF, par exemple, n'admet un projet qu'au terme d'un processus formel (proposition publique, triage, recommandation du comité technique, approbation du conseil d'administration, puis formalités juridiques et intégration technique avec la Linux Foundation); une proposition déposée ne suffit pas[42, 263] (section 6.9).

**EXIG-GOV-20**
**DOIT**

**Veille désignée et usage encadré**

L'architecture d'entreprise **DOIT** désigner une personne chargée de la veille pour chaque organisme qui fait évoluer un standard du catalogue, au minimum l'AAIF (projets et groupes de travail), l'IETF (groupes OAuth et WIMSE), OpenTelemetry, le W3C, le NIST (son *Center for AI Standards and Innovation*, CAISI, et son *National Cybersecurity Center of Excellence*, NCCoE) et l'OWASP GenAI Security Project. Un standard ou un projet **NE DOIT PAS** être utilisé, même en pilote avec des données réelles, s'il ne figure pas au catalogue au statut « Évaluer » ou « Adopter ».

Pourquoi : les pratiques d'identité et de sécurité des agents ne sont pas stabilisées. L'AAIF anime huit groupes de travail, dont identité et confiance, observabilité et traçabilité, gouvernance et alignement réglementaire[40]; le CAISI du NIST a lancé le 17 février 2026 l'AI Agent Standards Initiative[411]; le groupe WIMSE de l'IETF voit se multiplier les brouillons individuels sur la délégation entre agents[336].

L'entreprise PEUT participer aux consultations publiques et aux groupes de travail pour faire valoir ses besoins; le NCCoE du NIST a, par exemple, publié le 29 septembre 2026 la synthèse des commentaires de plus de 600 intervenants sur son document de réflexion consacré à l'identité et à l'autorisation des agents[338]. Le cadre lui-même est révisé chaque semestre par le comité : les dérogations accordées, les incidents et les résultats de la veille alimentent cette révision, et le chapitre 14 situe ces pratiques dans le modèle de maturité.

# 12 Risques, conformité et réglementation

Ce chapitre relie la classe de risque d'un agent aux obligations qui en découlent. Il traduit en exigences vérifiables la Loi 25 et le droit québécois, le cadre fédéral et sectoriel canadien, le règlement européen sur l'IA, le NIST AI RMF et ISO/IEC 42001, puis les réunit dans une matrice de correspondance et une base de preuves unique. Il fixe enfin la transparence due aux personnes, la réponse aux incidents agentiques et une évaluation d'impact unifiée. L'état du droit est celui du 27 octobre 2026.

**ATTENTION**

Ce chapitre résume l'intention des textes; leur application à un cas précis relève des affaires juridiques.

Le principe est simple : on ne bâtit pas un programme de conformité par texte de loi. Chaque agent reçoit une classe de risque, et cette classe déclenche un ensemble de contrôles dont les preuves (traces, journal d'audit, évaluations d'impact, résultats d'évaluation) servent à la fois à la Loi 25, au règlement européen et aux référentiels volontaires. Les seuils, délais internes et fréquences de revue propres au cadre sont signalés comme tels.

## 12.1 Classes de risque des agents

La classe de risque mesure ce qui arrive si l'agent se trompe; elle détermine l'intensité de la gouvernance qui s'applique à lui.

Trois notions coexistent et ne se confondent pas. Le **niveau d'autonomie** (N0 à N4, section 8.1) dit jusqu'où l'agent agit sans approbation. Le **palier d'outil** (P0 à P3, section 8.3) dit ce que fait chaque outil. La **classe de risque** dit quelles conséquences un agent peut produire sur des personnes, sur l'entreprise ou sur des tiers. La classe fixe le plafond du niveau d'autonomie, et la règle la plus stricte entre classe, niveau et palier l'emporte (section 8.4).

Cette gradation répond à un constat partagé. Selon Gartner (communiqué du 26 mai 2026), appliquer une gouvernance uniforme à tous les agents mènera à des échecs; l'analyste recommande une gouvernance proportionnelle[95]. Le cadre de gouvernance de l'IA agentique de l'Infocomm Media Development Authority (IMDA, Singapour) désigne la portée des actions de l'agent, leur réversibilité et son niveau d'autonomie comme déterminants du risque[76]. La ligne directrice E-23 du BSIF suit la même logique pour les modèles : une cote de risque détermine l'intensité de la gouvernance, la fréquence des examens et l'autorité d'approbation[8]. Les quatre critères d'analyse du cadre (rayon d'impact, réversibilité, délai de détection et de récupération, observabilité reconstructive) sont décrits à la section 8.2.

**Tableau 46 — Classes de risque des agents : critères, plafond d'autonomie et contrôles minimaux**

| Classe | Critères (un seul suffit) | Plafond d'autonomie | Contrôles minimaux | Revue |
|---|---|---|---|---|
| **Élevée** | Décision à effet important sur une personne (crédit, emploi, assurance, accès à un service essentiel); décision fondée exclusivement sur un traitement automatisé de RP (art. 12.1 de la Loi sur le privé; art. 65.2 de la Loi sur l'accès pour les organismes publics); système à haut risque au sens du règlement européen sur l'IA; action financière, juridique ou irréversible au-delà des seuils déclarés; renseignements personnels sensibles | N2 | EFVP et évaluation d'impact unifiée (section 12.9); équipe rouge avant production (section 9.9); homologation par le comité d'architecture et des risques agentiques; P3 toujours soumis à une approbation hors bande | Semestrielle |

| Classe | Critères (un seul suffit) | Plafond d'autonomie | Contrôles minimaux | Revue |
|---|---|---|---|---|
| **Modérée** | RP non sensibles ou données confidentielles; actions P2 réversibles ou compensables en production; échanges avec des partenaires, des clients ou le public | N3, avec des seuils plus bas et une revue a posteriori renforcée | EFVP si l'agent traite des RP; revue de sécurité; exercice d'équipe rouge avant production puis annuel (EXIG-SEC-23); évaluation continue (section 10.4) | Annuelle |
| **Faible** | Données publiques ou internes non confidentielles; lecture seule ou actions internes réversibles; aucun effet sur une personne | N3; N4 sur décision du comité | Autoévaluation documentée; évaluation continue; inscription au registre | Annuelle |

Plafonds repris d'EXIG-CON-02, qui fait foi. Choix du cadre. Les fréquences de revue sont des valeurs par défaut que la déclaration de tolérance au risque peut resserrer (EXIG-CON-17).

Un seul critère suffit : la classe retenue est la plus élevée dont un critère est rempli, jamais une moyenne. Les conséquences ne se compensent pas : un agent en lecture seule qui consulte des dossiers médicaux reste de classe élevée, parce qu'une fuite ne se répare pas.

EXEMPLE

Un agent de préqualification de prêts personnels lit des données et produit un avis « admissible » ou « non admissible ». Si cet avis est communiqué au client sans examen réel par un employé, il s'agit d'une décision fondée exclusivement sur un traitement automatisé : l'agent est de classe élevée et plafonné à N2, alors que tous ses outils sont de palier P1. À l'inverse, un agent qui reclasse des billets d'assistance internes en écriture réversible (P2), sans RP, relève de la classe modérée et peut atteindre N3 sous des seuils déclarés.

**EXIG-CON-01**
DOIT

**Classe de risque attribuée avant l'inscription**

Chaque agent **DOIT** recevoir une classe de risque (faible, modérée ou élevée) selon le tableau 46 avant son inscription au registre (section 11.4). La classe retenue est la plus élevée dont au moins un critère est rempli; la justification est consignée dans la fiche d'agent et validée par l'équipe risques et conformité.

Pourquoi : une moyenne des critères masquerait la conséquence la plus grave, qui seule commande les contrôles.

**EXIG-CON-02**
DOIT

**Plafond d'autonomie par classe**

Le niveau d'autonomie déclaré au registre **DOIT** respecter le plafond de la classe : N2 pour la classe élevée, N3 pour les classes modérée et faible. N4 n'est permis qu'à un agent de classe faible, sur décision consignée du comité d'architecture et des risques agentiques. Un agent **NE DOIT PAS** opérer au niveau NX, quelle que soit sa classe.

Pourquoi : les plafonds par classe sont un choix du cadre; pour les systèmes à haut risque, le règlement européen exige des mesures de supervision humaine proportionnées aux risques, au niveau d'autonomie et au contexte d'utilisation (art. 14(3))[412].

**EXIG-CON-03**
**DOIT**

**Réévaluation à chaque changement significatif**

La classe de risque **DOIT** être réévaluée, avant la mise en production du changement, lors de tout changement de modèle ou de fournisseur, d'outil ou de palier d'outil, de catégorie de données, de finalité, de population visée ou de lieu de traitement. La même réévaluation déclenche la mise à jour de l'EFVP et de l'évaluation d'impact unifiée (EXIG-CON-26).

Pourquoi : le guide de la Commission d'accès à l'information (CAI) demande de mettre à jour une EFVP lorsque le projet change, et E-23 fait des modifications d'un modèle et de ses données un déclencheur de revue indépendante[8, 413].

## 12.2 Loi 25 et droit québécois

Cette section traduit en exigences les obligations québécoises qui touchent directement les agents : évaluation préalable, communication hors Québec, consentement, décisions automatisées, conservation, secteur public et sanctions.

La *Loi modernisant des dispositions législatives en matière de protection des renseignements personnels* (L.Q. 2021, c. 25, « Loi 25 ») a été sanctionnée le 22 septembre 2021. Elle est entrée en vigueur par étapes : le 22 septembre 2022 pour le responsable de la protection des renseignements personnels (RPRP) et les incidents de confidentialité[56], le 22 septembre 2023 pour l'essentiel[56], et le 22 septembre 2024 pour le droit à la portabilité (quelques dispositions accessoires l'étant dès le 22 septembre 2021)[7, 56]. Elle modifie la *Loi sur la protection des renseignements personnels dans le secteur privé* (RLRQ, c. P-39.1, « Loi sur le privé ») et la *Loi sur l'accès aux documents des organismes publics et sur la protection des renseignements personnels* (RLRQ, c. A-2.1, « Loi sur l'accès »). Sauf mention contraire, les articles cités sont ceux de la Loi sur le privé.

Un point de départ s'impose : l'entreprise demeure responsable des RP qu'elle détient, même lorsqu'un fournisseur de modèles, de plateforme d'agents ou de serveur MCP les conserve ou les traite pour elle (art. 1 et 3.1)[56]; selon la CAI, elle conserve aussi ses obligations en cas d'incident[414]. La loi ne connaît pas de responsabilité « conjointe » : le fournisseur est un mandataire lié par un contrat écrit (art. 18.3)[56].

**Tableau 47 — Articles de la Loi sur le privé qui touchent les agents**

| Article | Obligation (résumé) | Application aux agents (interprétation du cadre) |
|---|---|---|
| 3.1 | La personne ayant la plus haute autorité exerce la fonction de responsable de la protection des RP, délégable par écrit; titre et coordonnées publiés sur le site Web. | Le responsable est consulté sur chaque agent qui traite des RP et participe à l'homologation des agents de classe élevée (section 11.1). |
| 3.2 | Politiques et pratiques de gouvernance (conservation, destruction, rôles, plaintes) approuvées par le responsable; information publiée en termes simples et clairs. | Les règles de conservation des traces et des mémoires d'agents font partie de ces politiques. |
| 3.3 | EFVP pour tout projet d'acquisition, de développement ou de refonte d'un système d'information ou de prestation électronique de services impliquant des RP; responsable consulté dès le début; portabilité permise. | Tout nouvel agent, et tout changement de modèle ou d'outils touchant des RP (EXIG-CON-04). |
| 3.5 à 3.8 | Incidents de confidentialité : mesures pour diminuer le risque; avis « avec diligence » à la CAI et aux personnes en cas de risque de préjudice sérieux; registre de tous les incidents. | Réponse aux incidents agentiques (section 12.8). |
| 8.1 | Informer au préalable du recours à une technologie permettant d'identifier, de localiser ou de profiler une personne, et des moyens d'activer ces fonctions. | Un agent qui évalue le rendement au travail, la situation économique, la santé, les préférences ou le comportement d'une personne fait du profilage. |

| Article | Obligation (résumé) | Application aux agents (interprétation du cadre) |
|---|---|---|
| 9.1 | Produit ou service technologique offert au public et doté de paramètres de confidentialité : plus haut niveau de confidentialité par défaut. | Mémoire persistante, partage de conversations et personnalisation désactivés par défaut dans les agents offerts au public. |
| 11 | RP à jour et exacts au moment d'une décision; conservés au moins un an après celle-ci. | Conservation des éléments de décision (EXIG-CON-09). |
| 12 | Utilisation limitée aux fins de la collecte, sauf consentement (exprès s'il est sensible) ou exception prévue; la prospection commerciale ou philanthropique n'est pas une fin compatible. | Aucune réutilisation de conversations ou de traces à d'autres fins sans base légale documentée (EXIG-CON-06). |
| 12.1 | Décision fondée exclusivement sur un traitement automatisé : informer, expliquer sur demande, permettre la rectification et des observations à un membre du personnel en mesure de réviser la décision. | EXIG-CON-07, EXIG-CON-08 et EXIG-CON-21. |
| 14 | Consentement manifeste, libre, éclairé, donné à des fins spécifiques et demandé pour chacune d'elles, en termes simples et clairs; présenté distinctement s'il est demandé par écrit. | Consentements séparés pour l'inférence et pour l'entraînement de modèles. |
| 17 | Avant toute communication hors Québec : EFVP tenant compte de la sensibilité, de la finalité, des mesures de protection et du régime juridique de l'État de destination; protection adéquate; entente écrite. | Tout modèle, serveur MCP, agent délégataire ou magasin de mémoire situé hors Québec (EXIG-CON-05). |
| 18.3 | Mandat ou contrat de service écrit : mesures de confidentialité, usage limité au mandat, aucune conservation après l'expiration, avis sans délai de toute violation, droit de vérification. | Clauses fournisseurs (section 13.3), dont l'interdiction d'entraîner des modèles sur les données confiées. |
| 23 | Destruction ou anonymisation une fois les fins accomplies, selon le Règlement sur l'anonymisation; un renseignement dépersonnalisé demeure un RP. | Cycle de vie des mémoires et des index vectoriels (EXIG-CON-10). |
| 27 et 32 | Accès et copie; transcription écrite et intelligible; depuis le 22 septembre 2024, portabilité des renseignements informatisés recueillis auprès de la personne; réponse écrite au plus tard dans les 30 jours. | Les inférences produites par un agent sont visées par le droit d'accès, mais pas par la portabilité. |
| 90.1 et suiv., 91, 93.1 | Sanctions administratives pécuniaires, infractions pénales, dommages-intérêts punitifs. | Voir « Sanctions et recours » ci-dessous. |

Source des obligations : L.Q. 2021, c. 25[56]. La colonne de droite est une interprétation du cadre.

## Évaluation des facteurs relatifs à la vie privée

L'EFVP est obligatoire dans deux situations qui visent directement les agents : tout projet d'acquisition, de développement ou de refonte d'un système d'information ou de prestation électronique de services impliquant des RP (art. 3.3), et toute communication de RP à l'extérieur du Québec (art. 17)[413]. Elle ne vise donc pas « tout système » en exploitation, mais tout projet qui en crée ou en modifie un. La loi exige qu'elle soit proportionnée à la sensibilité, à la finalité, à la quantité, à la répartition et au support des renseignements, sans prescrire de forme ni de signature[56]. Le guide de la CAI (version 3.1, avril 2024) est recommandé : il prévoit une évaluation de la conformité, une analyse des risques avec stratégies d'atténuation, un inventaire et un « parcours » des renseignements, puis une réévaluation de la nécessité et de la proportionnalité; il cite « améliorer un modèle d'intelligence artificielle » et « rendre une décision automatisée » parmi les finalités à examiner[413].

Pour un agent, le parcours des renseignements est plus long que pour une application classique : invite, contexte récupéré, appels d'outils MCP, délégations A2A, mémoire, traces. L'EFVP du cadre inventorie donc les RP outil par outil et délégation par délégation. La loi n'exige pas d'évaluer les biais dans l'EFVP; le cadre l'exige pour tout agent qui décide ou recommande à l'égard d'une personne, dans le prolongement de la recommandation de la CAI (dès 2020) d'imposer, pour les systèmes de décision automatisée, une EFVP et une analyse d'impact algorithmique couvrant tous les droits fondamentaux, et de celle du gouvernement du Québec pour les décisions automatisées[318, 415].

**EXIG-CON-04**
**DOIT**

**EFVP avant tout projet d'agent impliquant des RP**

Tout projet d'acquisition, de développement ou de refonte d'un agent impliquant des RP **DOIT** faire l'objet d'une EFVP terminée avant le passage en pilote. Le responsable de la protection des RP **DOIT** être consulté dès le début du projet. L'EFVP **DOIT** inventorier les RP par outil, par délégation et par mémoire, et **DOIT** comprendre une analyse des biais lorsque l'agent décide ou recommande à l'égard d'une personne (exigence propre au cadre).

Pourquoi : article 3.3 de la Loi sur le privé, qui ne prescrit pas le contenu de l'EFVP; l'analyse des biais est une exigence propre au cadre, appuyée par les orientations de la CAI (discrimination parmi les conséquences à évaluer; analyse d'impact algorithmique recommandée au législateur), non une obligation légale[56, 413, 415].

## Communication hors Québec et lois étrangères

Confier à un fournisseur situé hors Québec la tâche d'utiliser ou de conserver des RP pour le compte de l'entreprise, par exemple en appelant l'API d'un modèle hébergé ailleurs, relève de l'article 17. L'entreprise réalise d'abord une EFVP qui tient compte de la sensibilité des renseignements, de la finalité, des mesures de protection, y compris contractuelles, et du régime juridique de l'État de destination. La communication est permise si les renseignements bénéficient d'une protection adéquate, et elle fait l'objet d'une entente écrite[56, 416]. Le texte de l'article 17 vise toute communication à l'extérieur du Québec et ne distingue pas les provinces; le cadre l'interprète donc comme incluant l'Ontario : un index vectoriel hébergé dans une région infonuagique en Ontario déclenche l'article 17 au même titre qu'un hébergement aux États-Unis (interprétation du cadre)[56, 416].

La résidence des données ne règle pas tout. Le CLOUD Act américain (2018) oblige les fournisseurs assujettis au droit américain à préserver et à divulguer les données en leur possession, sous leur garde ou sous leur contrôle, qu'elles soient situées aux États-Unis ou à l'étranger[417]. Le cadre fédéral de souveraineté numérique (novembre 2025) constate que le stockage au Canada ne place pas à lui seul les données hors de la compétence de tribunaux étrangers, tout en notant que le gouvernement du Canada n'a relevé aucun cas documenté de gouvernement étranger cherchant à accéder aux données d'entreprises canadiennes détenues par des fournisseurs[418]. Le risque est donc réel, mais à pondérer dans l'EFVP. Le cadre retient comme mesures compensatoires le chiffrement à clés gérées par l'entreprise et, pour les RP sensibles, le recours à des fournisseurs sous compétence canadienne.

**EXIG-CON-05**
**DOIT**

**Cartographie des lieux de traitement**

La fiche de chaque agent **DOIT** indiquer le lieu de traitement (province ou pays, et fournisseur) de chaque modèle appelé, serveur MCP, agent délégataire et magasin de mémoire ou de traces. Tout flux de RP vers l'extérieur du Québec, y compris vers une autre province, **DOIT** être couvert par une EFVP au sens de l'article 17 et par une entente écrite avant sa mise en service; la passerelle de modèles **DOIT** refuser toute route qui n'est pas couverte.

Pourquoi : l'article 17 vise toute communication « à l'extérieur du Québec », que le cadre interprète comme incluant les autres provinces, et un routage dynamique entre modèles peut créer un transfert que personne n'a décidé[56, 416].

### Consentement et finalités

Un RP ne peut servir qu'aux fins pour lesquelles il a été recueilli, sauf consentement (exprès s'il est sensible) ou exception prévue par la loi : fins compatibles ayant un lien pertinent et direct avec les fins initiales, bénéfice manifeste de la personne, prévention de la fraude, fourniture d'un service demandé, recherche ou statistiques avec des renseignements dépersonnalisés. La prospection commerciale ou philanthropique n'est jamais une fin compatible (art. 12)[56]. Le consentement doit être manifeste, libre, éclairé et donné à des fins spécifiques; il est demandé pour chacune de ces fins, en termes simples et clairs (art. 14)[56, 419]. La loi n'emploie pas la notion de consentement « groupé », mais l'exigence d'un consentement par finalité conduit le cadre à séparer le consentement à l'inférence (rendre le service demandé) de celui à l'entraînement ou à l'ajustement fin de modèles.

**EXIG-CON-06**
**DOIT**

**Finalité vérifiée avant toute réutilisation**

Toute réutilisation de conversations, de traces, de mémoires ou de sorties d'agents à une autre fin que celle de la collecte, notamment l'entraînement ou l'ajustement fin de modèles, **DOIT** reposer sur un consentement distinct ou sur une exception légale documentée. Les données **DOIVENT** porter une étiquette de finalité que le service de politiques de la passerelle d'agents (section 9.4) **DOIT** vérifier avant toute transmission vers un usage secondaire.

Pourquoi : articles 12 et 14 de la Loi sur le privé; un contrôle technique empêche qu'une équipe réutilise de bonne foi des traces pour une fin non couverte.

### Décisions fondées exclusivement sur un traitement automatisé

L'article 12.1 s'applique lorsqu'une décision concernant une personne est fondée exclusivement sur un traitement automatisé de ses RP. L'entreprise doit l'en informer au plus tard au moment où elle l'informe de la décision. À sa demande, elle doit aussi l'informer des RP utilisés, des raisons et des principaux facteurs et paramètres ayant mené à la décision, ainsi que de son droit de faire rectifier ces renseignements. La personne doit avoir l'occasion de présenter ses observations à un membre du personnel en mesure de réviser la décision[56]. Le défaut d'informer la personne ou de lui permettre de présenter ses observations est expressément un motif de sanction administrative pécuniaire (art. 90.1, par. 5°)[56, 317].

Quand une décision est-elle « exclusivement » automatisée? Selon l'interprétation du gouvernement du Québec pour l'article 65.2 de la Loi sur l'accès, rédigé comme l'article 12.1 et que le cadre transpose par analogie à ce dernier, c'est le cas lorsqu'aucune personne physique n'a exercé un contrôle important. Une intervention humaine mineure, sans effet réel sur le résultat, ne fait pas échapper à l'obligation; en revanche, un outil d'aide à la décision qui fournit des éléments à un employé qui décide lui-même n'est pas visé[318]. Pour un agent de niveau N2, la conséquence est concrète : un bouton « Approuver » cliqué sans information, sans temps et sans autorité réelle ne transforme pas la décision de l'agent en décision humaine. Le même document précise qu'il n'est pas requis de divulguer l'algorithme : le mot « principaux » limite l'explication aux facteurs déterminants et à leur importance relative, ce qui protège les renseignements industriels et commerciaux.

**DROIT APPLICABLE**

Article 12.1 de la Loi sur le privé (article 65.2 de la Loi sur l'accès pour les organismes publics) : avis au plus tard au moment de la décision; sur demande, RP utilisés, raisons, principaux facteurs et paramètres, droit de rectification; observations à un membre du personnel en mesure de réviser. L'article 12.1 ne fixe aucun délai de réponse : le délai de 30 jours de l'article 32 vise les demandes d'accès et de rectification. Les RP utilisés pour décider sont conservés au moins un an après la décision (art. 11)[56].

**EXIG-CON-07**
**DOIT**

**Avis et explication des décisions automatisées**

Pour toute décision concernant une personne fondée exclusivement sur le traitement automatisé de ses RP par un agent, le système **DOIT** : informer la personne au plus tard au moment où la décision lui est communiquée; pouvoir produire sur demande les RP utilisés, les raisons et les principaux facteurs et paramètres de la décision avec leur importance relative; indiquer le droit de rectification; offrir un canal pour présenter des observations à un membre du personnel nommément désigné et en mesure de réviser la décision. Le délai de réponse à ces observations **DOIT** être d'au plus 30 jours (choix du cadre; l'article 12.1 ne fixe aucun délai).

Pourquoi : article 12.1; le défaut constitue un motif de sanction administrative pécuniaire[56, 317].

**EXIG-CON-08**
**NE DOIT PAS**

**Aucune approbation nominale**

Une approbation humaine **NE DOIT PAS** être considérée comme retirant le caractère exclusivement automatisé d'une décision si l'approbateur ne dispose pas de l'une ou l'autre de ces conditions : l'information sur la décision et ses facteurs, le temps nécessaire pour l'examiner, l'autorité de la modifier ou de l'annuler (voir aussi EXIG-AUT-23). À défaut d'une seule d'entre elles, les obligations de l'EXIG-CON-07 s'appliquent, et le taux d'approbation sans modification est suivi par approbateur (section 8.7).

Pourquoi : selon l'interprétation gouvernementale, une intervention humaine mineure, sans effet réel sur le résultat, ne fait pas échapper à l'obligation[318].

**EXIG-CON-09**
**DOIT**

**Conservation des éléments de décision**

Les éléments de toute décision d'agent touchant une personne **DOIVENT** être conservés au moins un an après la décision, sous une forme qui permet de répondre aux demandes prévues aux articles 12.1 et 27 : RP en entrée, versions de l'agent, du modèle et des outils, facteurs retenus et approbations. L'exportation de traces techniques est un moyen; la personne reçoit une transcription écrite et intelligible.

Pourquoi : l'article 11 exige de conserver au moins un an les RP utilisés pour décider; la conservation des versions et des facteurs va au-delà du minimum légal pour rendre l'explication possible[56].

## Conservation, mémoire et destruction

Une fois les fins accomplies, l'entreprise doit détruire le renseignement ou l'anonymiser pour des fins sérieuses et légitimes, selon les critères du Règlement sur l'anonymisation des renseignements personnels (art. 23); un renseignement dépersonnalisé, notion définie à l'article 12, demeure un renseignement personnel. La CAI estime en outre que certaines données, dont les données génétiques, biométriques et de géolocalisation, ne peuvent être adéquatement anonymisées[56, 420]. Pour un agent, la règle vise la mémoire épisodique et sémantique (section 5.5), les index vectoriels et les traces. Un plongement vectoriel *(embedding)* calculé à partir d'un RP n'est pas anonyme du seul fait qu'il est illisible pour un humain : le cadre le traite comme un RP.

**EXIG-CON-10**
**DOIT**

**Durée de vie des mémoires et des traces**

Chaque magasin de mémoire, index vectoriel et dépôt de traces d'un agent **DOIT** avoir une durée de conservation liée à sa finalité, inscrite dans la fiche d'agent et appliquée automatiquement. À l'échéance, sous réserve des délais de conservation prévus par la loi (EXIG-CON-09) et du gel des preuves d'un incident (EXIG-CON-23), les données **DOIVENT** être détruites ou anonymisées selon le règlement; les plongements calculés à partir de RP suivent le même régime que les RP d'origine.

Pourquoi : article 23 de la Loi sur le privé; une mémoire sans échéance accumule des RP au-delà de leur finalité.

### Secteur public québécois

Les organismes publics appliquent les dispositions équivalentes de la Loi sur l'accès : décisions fondées exclusivement sur un traitement automatisé (art. 65.2), EFVP (art. 63.5), règles de gouvernance (art. 63.3), incidents de confidentialité (art. 63.8 à 63.11) et communication hors Québec (art. 70.1); l'article 63.1 porte sur les mesures de sécurité[56, 318]. Trois textes gouvernementaux s'y ajoutent :

- l'indication d'application IA-RI-2025-003-OP sur l'IA générative, en vigueur le 5 décembre 2025, exige notamment une EFVP dès la conception de tout système d'IA générative, même sans RP apparent, la classification préalable des données numériques gouvernementales, des essais de fiabilité, une supervision humaine proportionnée à l'autonomie, l'interdiction d'entrer des renseignements confidentiels dans un système d'IA générative public et, pour les données confidentielles, la préférence pour des fournisseurs québécois ou canadiens hébergés au Québec ou au Canada[421];
- l'Énoncé de principes pour une utilisation responsable de l'IA par les organismes publics (édition 2025) compte 12 principes; le principe 11 vise expressément l'IA agentique et exige des mécanismes permettant la validation, l'intervention humaine ou l'arrêt des actions du système, par exemple des validations avant certaines actions critiques et des mécanismes d'arrêt d'urgence[379];
- l'Énoncé de politique de souveraineté numérique et d'approvisionnement en TI (février 2026) oriente l'État vers l'hébergement souverain, des centres de données sous juridiction québécoise et le logiciel libre[422].

L'indication d'application et l'Énoncé de principes lient les organismes publics; l'énoncé de politique de souveraineté numérique énonce une orientation de l'État. Pour les entreprises privées, le cadre les retient comme référence de bonne pratique. Le gouvernement met aussi à la disposition des organismes des outils officiels : analyse des décisions automatisées, modèle de registre des incidents, analyse du régime juridique d'une communication hors Québec et schéma de décision sur l'EFVP[423]. Ils constituent de bons points de départ pour les gabarits du cadre.

### Sanctions et recours

La CAI peut imposer une sanction administrative pécuniaire d'au plus 50 000 $ à une personne physique et, à une entreprise, d'au plus 10 000 000 $ ou 2 % du chiffre d'affaires mondial de l'exercice précédent, selon le montant le plus élevé (art. 90.12)[56]; un engagement accepté par la CAI et respecté écarte la sanction[317]. Les infractions pénales (art. 91) entraînent une amende de 5 000 $ à 100 000 $ pour une personne physique et, pour une entreprise, de 15 000 $ à 25 000 000 $ ou 4 % du chiffre d'affaires mondial, selon le montant le plus élevé; les amendes sont portées au double en cas de récidive. Une atteinte illicite intentionnelle ou résultant d'une faute lourde donne en outre droit à des dommages-intérêts punitifs d'au moins 1 000 $ (art. 93.1)[56]. La page des sanctions de la CAI et son rapport annuel 2024-2025 ne font état d'aucune sanction liée aux décisions automatisées : le risque tient aux plafonds légaux, non à des précédents[424].

Le droit évolue. Dans son rapport quinquennal déposé le 11 juin 2026, la CAI formule 74 recommandations, dont une meilleure prise en compte des inférences algorithmiques et une meilleure définition du processus d'EFVP[425]. Le cadre traite dès maintenant les inférences produites par les agents comme des RP à gouverner.

## 12.3 Cadre fédéral et sectoriel canadien

Cette section situe les obligations fédérales et sectorielles qui s'ajoutent au droit québécois, et distingue ce qui est en vigueur de ce qui n'est encore qu'un projet.

**Tableau 48 — Textes fédéraux et sectoriels canadiens : statut au 27 octobre 2026 et effet sur les agents**

| Texte | Statut | Ce qu'il implique pour les agents |
|---|---|---|
| LPRPDE (Loi sur la protection des renseignements personnels et les documents électroniques) | En vigueur | Atteinte présentant un risque réel de préjudice grave : déclaration au Commissariat et avis aux personnes « dès que possible » (LPRPDE, par. 10.1(2) et (6)); toutes les atteintes sont consignées, registre conservé 24 mois[426, 427]. |
| Projet de loi C-27, dont la Loi sur l'intelligence artificielle et les données (LIAD) | Resté à l'étape du comité à la fin de la session, le 6 janvier 2025; mort au Feuilleton à la prorogation[428, 429] | Aucune obligation : la LIAD n'existe pas. |
| Projet de loi C-36, Loi sur la protection de la vie privée et des données des consommateurs | Déposé le 15 juin 2026; deuxième lecture; non en vigueur[430] | Viserait tout système décisionnel automatisé qui appuie ou remplace le jugement humain; lorsqu'il sert à faire des prédictions, des recommandations ou des décisions pouvant avoir un effet juridique ou un effet important semblable : usage décrit dans l'information rendue publique (art. 62), explication sur demande et observations écrites à un employé pouvant réviser (art. 63). Les sanctions administratives (art. 113 et 114) ne visent que certaines dispositions, dont l'art. 62(1) mais pas l'art. 63; le plafond est le plus élevé de 10 M$ et de 3 % des revenus mondiaux bruts[431]. |
| Directive sur la prise de décisions automatisée du Secrétariat du Conseil du Trésor du Canada (SCT) et évaluation de l'incidence algorithmique (EIA) | S'applique à l'administration fédérale | Systèmes développés ou acquis après le 1er avril 2020 qui remplacent ou appuient le jugement humain dans des décisions administratives; EIA obligatoire (65 questions de risque, 41 d'atténuation, niveaux d'incidence I à IV), faite au début de la conception, mise à jour avant la production, résultats publiés[432, 433]. |
| Guide sur l'utilisation de l'IA agentique (gouvernement du Canada, 2026) | Orientation pour l'administration fédérale | Autonomie bornée, lecture seule par défaut, points de contrôle humains pour les actions qui modifient l'état des systèmes, propriétaire humain désigné, identifiant unique par agent, journalisation dans un système que l'agent ne peut modifier, coupe-circuit externe, texte externe traité comme des données[353]. |
| Ligne directrice E-23 du BSIF, Gestion du risque de modèle | Publiée le 11 septembre 2025; en vigueur le 1er mai 2027 pour les institutions financières fédérales[8] | « Modèle » inclut les méthodes d'IA et d'apprentissage automatique (la prise de décision autonome relève des principes de surveillance); inventaire d'entreprise des modèles à risque non négligeable, y compris ceux des fournisseurs, cote de risque, revue indépendante, surveillance de la dérive. |
| Avis du BSIF sur le signalement des incidents liés à la technologie et à la cybersécurité | En vigueur depuis le 13 août 2021[434] | Signalement écrit au BSIF dans les 24 heures, ou plus tôt si possible. |
| Ligne directrice B-13 du BSIF, Gestion des risques liés à la technologie et au cyberrisque | Publiée en juillet 2022 (lettre du BSIF du 13 juillet 2022); en vigueur depuis le 1er janvier 2024[435, 436] | Gestion des identités et des accès fondée sur le risque (authentification multifacteur, accès privilégiés, moindre privilège, attestation périodique, surveillance des comptes de service); journalisation continue et centralisée; incidents d'origine tierce visés. |
| Code de conduite volontaire sur l'IA générative avancée (Innovation, Sciences et Développement économique Canada, ISDE) | Septembre 2023; volontaire[437] | Six résultats : responsabilisation, sécurité, justice et équité, transparence, surveillance humaine, validité et robustesse. |

| Texte | Statut | Ce qu'il implique pour les agents |
|---|---|---|
| Principes des commissaires à la protection de la vie privée pour une IA générative responsable | 7 décembre 2023, cosignés par la CAI[438] | Neuf principes; menaces propres à l'IA (injection, inversion de modèle, débridage); mécanisme de contestation avec révision humaine pour les décisions assistées par l'IA. |

Trois conséquences pratiques en découlent. D'abord, une institution financière fédérale devrait traiter chaque agent comme un compte de service privilégié, dans l'esprit de B-13 : identité propre, accès minimal, surveillance (section 9.2). Ensuite, le projet C-36 viserait aussi les décisions partiellement automatisées; le cadre conçoit donc l'explicabilité des agents pour couvrir les deux régimes, sans attendre l'adoption du projet (EXIG-CON-21). Enfin, le guide fédéral sur l'IA agentique converge avec les exigences des chapitres 8 à 10. Les institutions financières de compétence québécoise intègrent en outre à leur registre de conformité les attentes de l'Autorité des marchés financiers (AMF) en matière d'IA, énoncées dans sa Ligne directrice sur l'utilisation de l'intelligence artificielle (version d'avril 2026, en vigueur le 1er mai 2027), que le présent cadre ne reprend pas.

La veille porte aussi sur deux textes connexes : la Loi concernant la cybersécurité (ancien projet de loi C-8), sanctionnée le 15 juin 2026 (L.C. 2026, ch. 9), et le projet de loi C-22 sur l'accès légal, à l'étude au Sénat en octobre 2026[439, 440]. Leur effet sur les fournisseurs de télécommunications et d'infonuagique utilisés par les agents est suivi par le processus de la section 11.7.

**EXIG-CON-11**
**DOIT**

**Régimes applicables inscrits à la fiche**

La fiche de chaque agent **DOIT** énumérer les régimes juridiques et sectoriels qui s'appliquent à lui (Loi sur le privé ou Loi sur l'accès, LPRPDE, règlement européen sur l'IA, lignes directrices du BSIF, directive fédérale, textes gouvernementaux québécois) et, pour chacun, les obligations retenues et l'exigence du cadre qui y répond. L'équipe risques et conformité valide cette liste à l'homologation et à chaque réévaluation (EXIG-CON-03).

Pourquoi : un même agent peut relever de plusieurs régimes dont les seuils et les délais diffèrent; seule une liste explicite permet d'appliquer le plus exigeant.

**EXIG-CON-12**
**DOIT**

**Arrimage à E-23 pour les institutions financières fédérales**

Une institution financière fédérale **DOIT**, au plus tard le 1er mai 2027, inscrire chaque agent et chaque modèle qu'il utilise, y compris ceux des fournisseurs, à l'inventaire des modèles attendu par la ligne directrice E-23 (le cadre étend l'inscription à chaque agent et à chaque modèle utilisé), avec propriétaire, cote de risque, version et état de validation. Un changement de modèle, de fournisseur ou de données d'entrée déclenche la revue prévue par E-23.

Pourquoi : E-23 inclut les méthodes d'IA et d'apprentissage automatique dans sa définition de modèle, traite de la prise de décision autonome dans ses principes de surveillance et exige un inventaire d'entreprise[8].

## 12.4 Règlement européen sur l'IA

Cette section indique quand le règlement (UE) 2024/1689 (RIA) s'applique à une entreprise canadienne et ce qu'il exige d'un agent à haut risque.

### Portée : l'utilisation des sorties dans l'Union

Le RIA ne s'applique pas parce qu'une entreprise « opère en Europe ». Selon l'article 2(1), il vise notamment les fournisseurs qui mettent un système d'IA sur le marché ou en service dans l'Union, où qu'ils soient établis, les déployeurs établis ou situés dans l'Union, ainsi que les fournisseurs et déployeurs établis dans un pays tiers lorsque les

sorties produites par le système sont utilisées dans l'Union[61, 441]. Un agent exploité à Montréal dont les recommandations servent à une filiale européenne peut donc être visé. Le RIA définit le système d'IA comme un système automatisé conçu pour fonctionner à différents niveaux d'autonomie, qui déduit des entrées qu'il reçoit la manière de générer des sorties pouvant influencer des environnements physiques ou virtuels (art. 3(1)); le déployeur est celui qui l'utilise sous sa propre autorité (art. 3(4))[62]. Le cadre considère tout agent comme un système d'IA au sens de cette définition.

Les systèmes à haut risque relèvent de l'article 6 et des annexes I et III. L'annexe III couvre huit domaines : biométrie; infrastructures critiques; éducation et formation; emploi et gestion des travailleurs; accès aux services essentiels privés et publics, dont l'évaluation de la solvabilité et la tarification en assurance vie et maladie; répression; migration, asile et contrôle des frontières; administration de la justice et processus démocratiques[442].

### Calendrier modifié par le règlement (UE) 2026/1744

Le RIA est entré en vigueur le 1er août 2024. Les pratiques interdites s'appliquent depuis le 2 février 2025, les règles sur les modèles d'IA à usage général depuis le 2 août 2025, et l'application générale, dont les obligations de transparence de l'article 50, depuis le 2 août 2026[57]. Le règlement (UE) 2026/1744 du 8 juillet 2026, dit « omnibus numérique sur l'IA », en vigueur depuis le 27 juillet 2026, a reporté les obligations du haut risque : au 2 décembre 2027 pour les systèmes de l'annexe III et au 2 août 2028 pour ceux de l'annexe I (produits réglementés)[58, 443]. Il ajoute des interdictions applicables le 2 décembre 2026 (hypertrucages sexuels non consentis, matériel d'abus pédosexuel) et prévoit au moins un bac à sable réglementaire de l'IA opérationnel dans chaque État membre au 2 août 2027[57].

**ATTENTION**

Un report n'est pas un moratoire. Le règlement (UE) 2026/1744 ne suspend ni les pratiques interdites ni les obligations des modèles d'IA à usage général[443]. Surtout, les journaux et la documentation d'un agent ne se reconstituent pas après coup : un agent conçu en 2026 sans eux ne sera pas conforme en décembre 2027.

**Tableau 49 — Articles du règlement européen sur l'IA et réponse du cadre**

| Article | Exigence (résumé) | Réponse du cadre |
|---|---|---|
| 2 | Portée : fournisseurs et déployeurs, y compris hors Union lorsque les sorties y sont utilisées. | Applicabilité consignée dans la fiche (EXIG-CON-13). |
| 6, annexes I et III | Classification des systèmes à haut risque. | Classe élevée d'office (EXIG-CON-01 et EXIG-CON-13). |
| 9 | Système de gestion des risques continu et itératif sur tout le cycle de vie. | Classe de risque et réévaluations (EXIG-CON-01, EXIG-CON-03); cycle de vie (section 11.5). |
| 12 | Enregistrement automatique des événements pendant toute la durée de vie. | Traçage (section 10.1) et journal d'audit (section 10.3); la signature et l'enregistrement à cinq éléments sont des choix du cadre, au-delà du minimum légal. |
| 13 | Transparence et notice d'utilisation destinées aux déployeurs. | Fiche d'agent (annexe B) et carte d'agent remises aux équipes qui déploient l'agent. |
| 14 | Supervision humaine effective : comprendre le système, rester conscient du biais d'automatisation, ignorer ou inverser une sortie, interrompre le système et le mettre dans un état sûr. | Approbation vérifiable (section 8.5), lutte contre l'approbation machinale (section 8.7), coupe-circuit (section 7.8). |

| Article | Exigence (résumé) | Réponse du cadre |
|---|---|---|
| 15 | Exactitude, robustesse et cybersécurité. | Évaluation continue (section 10.4) et sécurité (chapitre 9). |
| 25 | Un déployeur devient fournisseur s'il appose son nom, modifie substantiellement le système ou en change la destination; accord écrit avec les tiers fournisseurs de composants intégrés (25(4)), sauf pour les outils, services et composants rendus publics sous licence libre et ouverte, hors modèles d'IA à usage général. | Revue de requalification (EXIG-CON-15); clauses fournisseurs (section 13.3). |
| 26 | Obligations du déployeur : notice, supervision compétente, données d'entrée pertinentes, surveillance et suspension, journaux conservés au moins six mois, information des travailleurs et des personnes visées. | EXIG-CON-16. |
| 27 | Analyse d'impact sur les droits fondamentaux (AIDF) avant la première utilisation, pour certains déployeurs. | Évaluation d'impact unifiée (section 12.9). |
| 50 | Informer les personnes qu'elles interagissent avec un système d'IA; marquer les contenus synthétiques. | EXIG-CON-19 et EXIG-CON-20. |
| 72 | Surveillance après commercialisation pendant toute la durée de vie, y compris l'interaction avec d'autres systèmes d'IA. | Traces des délégations A2A et analyse des chaînes multiagents dans le plan de surveillance. |
| 73 | Signalement des incidents graves aux autorités de surveillance du marché. | Réponse aux incidents (section 12.8). |

Sources : règlement (UE) 2024/1689, tel que modifié par le règlement (UE) 2026/1744 (EUR-Lex), et, pour la lecture article par article, les pages des articles 9, 13 et 72 du site non officiel du Future of Life Institute[58, 61, 444, 445, 446].

**EXIG-CON-13**
**DOIT**

**Applicabilité du RIA déterminée par l'usage des sorties**

La fiche de chaque agent **DOIT** indiquer si ses sorties sont, ou sont prévues pour être, utilisées dans l'Union européenne (destinataires, filiales ou clients qui s'y trouvent), et si son usage relève d'un domaine de l'annexe III. Un agent dont les sorties sont utilisées dans l'Union pour un usage de l'annexe III **DOIT** être classé en classe élevée et soumis aux exigences du tableau 49 dès son homologation, sans attendre le 2 décembre 2027.

Pourquoi : pour un fournisseur ou un déployeur établi hors de l'Union, le critère de l'article 2(1)(c) est l'utilisation des sorties dans l'Union; les preuves exigées ne se constituent qu'en cours d'exploitation (raisonnement du cadre)[441].

**EXIG-CON-14**
**NE DOIT PAS**

**Aucun usage interdit**

Un agent **NE DOIT PAS** être homologué pour une pratique interdite par le RIA, quel que soit le lieu d'utilisation de ses sorties (choix du cadre). Le registre tient la liste de ces pratiques, mise à jour selon le règlement (UE) 2026/1744, et la revue d'homologation vérifie la finalité de l'agent contre cette liste.

Pourquoi : les interdictions s'appliquent depuis le 2 février 2025, de nouvelles s'ajoutent le 2 décembre 2026, et le report du haut risque ne les touche pas[57, 443].

**EXIG-CON-15**
**DOIT**

**Revue de requalification en fournisseur**

Toute orchestration qui affecte un modèle, un agent ou un système d'IA à usage général à un usage de l'annexe III, qui modifie substantiellement un système à haut risque ou qui y appose le nom de l'entreprise **DOIT** déclencher, avant l'homologation, une revue de requalification en fournisseur au sens de l'article 25(1). Si l'entreprise devient fournisseur, elle **DOIT** conclure des accords écrits avec les tiers qui fournissent des outils, services, composants ou modèles intégrés au système (art. 25(4)).

Pourquoi : la composition d'agents peut, à elle seule, changer la destination d'un composant et faire basculer l'entreprise dans le rôle de fournisseur[375].

**EXIG-CON-16**
**DOIT**

**Obligations du déployeur d'un agent à haut risque**

Pour un agent à haut risque au sens du RIA, l'entreprise **DOIT** : confier la supervision humaine à des personnes compétentes, formées et dotées de l'autorité nécessaire; veiller à la pertinence des données d'entrée qu'elle contrôle; surveiller le fonctionnement et suspendre l'usage en cas de risque; conserver les journaux sous son contrôle au moins six mois (le cadre exige davantage, section 10.3); informer les travailleurs concernés avant une mise en service en milieu de travail et les personnes visées par une décision prise ou assistée par le système.

Pourquoi : article 26 du RIA, applicable aux systèmes de l'annexe III à compter du 2 décembre 2027[57, 447].

## 12.5 NIST AI RMF, ISO/IEC 42001 et normes associées

Cette section situe les référentiels volontaires et certifiables qui structurent la gestion des risques de l'IA et retient les sous-catégories et mesures les plus utiles aux agents.

### NIST AI RMF 1.0 et profil IA générative

Le NIST AI RMF 1.0 (NIST AI 100-1), publié le 26 janvier 2023, s'articule autour de quatre fonctions : Gouverner (GOVERN), fonction transversale, Cartographier (MAP), Mesurer (MEASURE) et Gérer (MANAGE). Il est d'application volontaire; le NIST indique qu'il est en cours de révision dans le cadre du plan d'action américain sur l'IA, sans calendrier publié pour la version révisée, le document prévoyant lui-même un examen formel au plus tard en 2028[99, 448]. Il compte 72 sous-catégories (GOVERN 1.1 à 6.2, MAP 1.1 à 5.2, MEASURE 1.1 à 4.3, MANAGE 1.1 à 4.3) et définit sept caractéristiques d'une IA digne de confiance : valide et fiable; sûre; sécurisée et résiliente; responsable et transparente; explicable et interprétable; respectueuse de la vie privée; équitable, avec gestion des biais nuisibles[74]. Le profil IA générative (NIST AI 600-1, 26 juillet 2024) décrit douze risques propres à l'IA générative ou aggravés par elle; deux touchent directement les agents : la configuration humain-IA (biais d'automatisation, dépendance excessive) et l'intégration de la chaîne de valeur et des composants (intégration non traçable de composants tiers)[449].

Les sous-catégories suivantes sont les plus directement utiles aux agents[74] :

- **GOVERN 1.3** : processus qui déterminent le niveau d'activités de gestion des risques selon la tolérance au risque de l'organisation; **GOVERN 1.6** : mécanismes d'inventaire des systèmes d'IA, dotés de ressources selon les priorités de risque (le registre d'agents); **GOVERN 1.7** : déclassement sécuritaire (le cadre y rattache la révocation des identifiants);
- **GOVERN 6.1** et **6.2** : politiques sur les risques liés aux tiers et contingence en cas de défaillance d'un système de tiers jugé à haut risque (serveurs MCP et agents externes);
- **MAP 3.5** : processus de supervision humaine définis, évalués et documentés;

- **MEASURE 2.4** : surveillance en production du fonctionnement et du comportement du système; **MEASURE 2.7** : évaluation de la sécurité et de la résilience; **MEASURE 3.1** : suivi des risques émergents;
- **MANAGE 2.3** : réponse aux risques jusque-là inconnus et reprise; **MANAGE 2.4** : mécanismes et responsabilités pour supplanter, désengager ou désactiver un système (le coupe-circuit); **MANAGE 4.1** : plans de surveillance après déploiement couvrant le recours et la neutralisation par un humain *(appeal and override)*, l'intervention en cas d'incident, la reprise, la gestion du changement et le déclassement.

### ISO/IEC 42001 et normes associées

ISO/IEC 42001:2023 (1re édition, 18 décembre 2023) spécifie les exigences d'un système de management de l'IA (SMIA). Elle suit la structure harmonisée des normes de systèmes de management, comme ISO/IEC 27001 : articles 4 (contexte), 5 (leadership), 6 (planification, dont l'appréciation des risques en 6.1.2, leur traitement en 6.1.3 et l'évaluation d'impact des systèmes d'IA en 6.1.4), 7 (support), 8 (fonctionnement), 9 (évaluation des performances) et 10 (amélioration)[395]. Son annexe A, normative, compte 38 mesures réparties en neuf objectifs (A.2 à A.10). Les plus directement applicables aux agents sont A.5 (évaluation des impacts des systèmes d'IA), A.6.2.6 (exploitation et surveillance), A.6.2.8 (enregistrement des journaux d'événements), A.9 (utilisation responsable et usage prévu) et A.10 (relations avec les tiers et les clients)[395, 450]. La certification est délivrée par des organismes conformes à ISO/IEC 17021-1 et à ISO/IEC 42006:2025[451].

Trois normes complètent l'ensemble. ISO/IEC 42005:2025 donne des lignes directrices pour évaluer l'impact d'un système d'IA sur les personnes et la société, à quels moments du cycle de vie, et pour intégrer cette évaluation au SMIA; ISO/IEC 23894:2023 traite de la gestion des risques propres à l'IA; ISO/IEC 22989:2022 établit la terminologie et définit l'agent d'IA (3.1.1)[59, 452, 453]. Le NIST AI RMF et ISO/IEC 42001 sont complémentaires (appréciation du présent cadre) : le premier est un cadre d'application volontaire, la seconde une norme d'exigences certifiable par tierce partie[448, 451]. Une entreprise qui vise la certification tient une déclaration d'applicabilité qui rattache les exigences du présent cadre aux mesures de l'annexe A; le lien avec le modèle de maturité est traité à la section 14.3.

### Ce que ces référentiels ne sont pas

AI TRiSM *(AI Trust, Risk and Security Management)* est un cadre d'analyste propriétaire de Gartner, non une norme : le cadre ne le place pas au même rang que le RIA, ISO/IEC 42001 ou le NIST AI RMF. La littérature scientifique l'a adapté aux systèmes multiagents autour de l'explicabilité, du ModelOps, de la sécurité et de la confidentialité, chacun sous l'angle de la gouvernance du cycle de vie[454]. De même, aucune publication du NIST ne fixe encore de profil d'interopérabilité des agents. L'AI Agent Standards Initiative du Center for AI Standards and Innovation (CAISI) du NIST, lancée le 17 février 2026, et le projet de superpositions de contrôles SP 800-53 (COSAiS, *Control Overlays for Securing AI Systems*, renommé COSIS, *Control Overlays for Super Intelligence Systems*, le 20 octobre 2026 selon la page du projet), qui prévoit des cas d'usage « agent unique » et « multiagents », relèvent de la veille (section 11.7)[411, 455]. Il en va de même de la note de concept du 7 avril 2026 sur un profil consacré aux infrastructures critiques, document préparatoire non contraignant[456].

**EXIG-CON-17** — **DOIT**

**Déclaration de tolérance au risque**

Le comité d'architecture et des risques agentiques **DOIT** faire approuver par la direction une déclaration de tolérance au risque qui fixe, pour chaque classe, le niveau d'activités de gestion des risques (contrôles, fréquence des revues, autorité d'approbation) et les seuils au-delà desquels un agent est suspendu. La déclaration **DOIT** être revue chaque année et après tout incident grave.

Pourquoi : GOVERN 1.3 demande de proportionner la gestion des risques à la tolérance de l'organisation; sans seuils écrits, chaque équipe fixe les siens[74].

## 12.6 Matrice de correspondance

La matrice relie les quatre fonctions du NIST AI RMF aux articles d'ISO/IEC 42001, aux obligations de la Loi 25 et du RIA, et aux artefacts du cadre qui en font la preuve. Elle constitue une interprétation interne du cadre, non une table de correspondance publiée par le NIST ou l'ISO.

**Tableau 50 — Matrice de correspondance : NIST AI RMF, ISO/IEC 42001, Loi 25, RIA et artefacts du cadre**

| Fonction NIST | ISO/IEC 42001 | Loi 25 (Loi sur le privé) | RIA | Artefacts et contrôles du cadre |
|---|---|---|---|---|
| **Gouverner** : GOVERN 1.1, 1.2, 1.3, 1.6, 1.7, 2.1, 6.1, 6.2 | Art. 4 et 5 (5.2 politique, 5.3 rôles); A.2, A.3, A.10 | Art. 3.1, 3.2, 18.3 | Art. 25 et 26 | Déclaration de tolérance au risque (EXIG-CON-17); registre avec propriétaire nommé (section 11.4); matrice RACI (section 11.2); clauses fournisseurs (section 13.3); retrait avec révocation des identités (section 11.5) |
| **Cartographier** : MAP 1.1 à 5.2, dont MAP 3.5 | Art. 6 (6.1.2 à 6.1.4); A.5 | Art. 3.3, 8.1, 17 | Art. 6 et annexe III; art. 9 et 27 | Classe de risque (EXIG-CON-01); niveau d'autonomie et paliers d'outils (chapitre 8); lieux de traitement (EXIG-CON-05); évaluation d'impact unifiée (EXIG-CON-26) |
| **Mesurer** : MEASURE 2.4, 2.5, 2.7, 3.1 | Art. 9 (9.1 à 9.3); A.6.2.4, A.6.2.6, A.6.2.8, A.7.4 | Art. 11, 12.1, 27 | Art. 12, 15, 72 | Traçage (section 10.1); journal d'audit (section 10.3); évaluation continue (section 10.4); taux d'approbation sans modification (section 8.7) |
| **Gérer** : MANAGE 2.3, 2.4, 4.1 | Art. 8 et 10; A.9 | Art. 3.5 à 3.8, 12.1 (révision), 23 | Art. 14, 26, 73 | Coupe-circuit (section 7.8); compensation (section 7.5); approbation vérifiable (section 8.5); réponse aux incidents (EXIG-CON-23 à EXIG-CON-25); destruction des mémoires (EXIG-CON-10) |

Interprétation du cadre, établie à partir de NIST AI 100-1 et du catalogue d'ISO/IEC 42001[74, 395].

Deux confusions courantes sont à éviter. L'objectif A.7 d'ISO/IEC 42001 porte sur les données des systèmes d'IA (acquisition, qualité, provenance, préparation), et non sur l'évaluation des performances, l'audit interne ou la revue de direction, qui relèvent de l'article 9. Les sous-catégories MANAGE 3.1 et 3.2 visent les ressources de tiers et les modèles préentraînés; le coupe-circuit relève de MANAGE 2.4 et le déclassement sécuritaire de GOVERN 1.7[74].

**EXIG-CON-18**
**DOIT**

**Base de preuves unique**

Chaque preuve produite par la plateforme ou par les équipes (trace, enregistrement d'audit, EFVP, évaluation d'impact, résultat d'évaluation, rapport d'équipe rouge, décision d'homologation) **DOIT** être conservée une seule fois dans un dépôt de preuves, étiquetée avec les exigences du cadre et les dispositions externes auxquelles elle répond selon le tableau 50. L'équipe risques et conformité **DOIT** revoir la matrice chaque année.

Pourquoi : une base unique évite de produire quatre dossiers pour un même contrôle et permet de démontrer, pour une demande précise à une date précise, qu'un engagement a été respecté.

## 12.7 Transparence envers les personnes

Une personne a le droit de savoir qu'elle a affaire à un agent, de reconnaître un contenu produit par un agent et de comprendre une décision qui la concerne.

L'article 50 du RIA, applicable depuis le 2 août 2026, oblige les fournisseurs à concevoir les systèmes qui interagissent directement avec des personnes de façon qu'elles sachent qu'elles interagissent avec un système d'IA, sauf si c'est évident, et à marquer de façon lisible par machine les contenus synthétiques. Les déployeurs divulguent les

hypertrucages et les textes générés publiés pour informer le public sur des questions d'intérêt public, sauf contrôle éditorial humain. L'information est claire et fournie au plus tard lors de la première interaction; un délai transitoire jusqu'au 2 décembre 2026 vise le marquage des systèmes déjà sur le marché avant le 2 août 2026[57, 457]. Le cadre va un peu plus loin que ce minimum : il informe toute personne, même lorsque l'interaction paraît évidente, et identifie tout contenu d'agent diffusé à l'externe.

Au Québec, la transparence passe aussi par l'avis préalable au profilage (art. 8.1), la confidentialité par défaut (art. 9.1), l'information des décisions automatisées (art. 12.1) et le droit d'accès à une transcription intelligible (art. 27). Les principes des commissaires à la protection de la vie privée demandent un mécanisme de contestation avec révision humaine pour les décisions assistées par l'IA, et pas seulement pour celles qui sont entièrement automatisées[438]. Le raisonnement affiché par un modèle n'est pas forcément une explication fidèle : l'IMDA rappelle qu'il peut ne pas refléter fidèlement les actions de l'agent[76].

**EXIG-CON-19**
**DOIT**

**Divulgation de l'interaction avec un agent**

Toute personne qui interagit avec un agent, par écrit ou par la voix, **DOIT** en être informée clairement au plus tard lors de la première interaction, même lorsque la nature artificielle de l'interlocuteur paraît évidente (choix du cadre). Un agent **NE DOIT PAS** se présenter comme une personne.

Pourquoi : article 50 du RIA, que le cadre étend à toutes les interactions pour éviter une appréciation au cas par cas de ce qui est « évident »[457].

**EXIG-CON-20**
**DOIT**

**Identification des contenus produits par un agent**

Tout contenu produit ou substantiellement modifié par un agent et diffusé à l'externe (courriel, publication, document, image, audio) **DOIT** être identifié comme tel. Lorsque l'entreprise fournit un système génératif visé par l'article 50 du RIA, le marquage **DOIT** en outre être lisible par machine.

Pourquoi : l'article 50 n'impose l'identification que de certains contenus; l'identification de tout contenu diffusé à l'externe est un choix du cadre, qui permet aussi de retrouver la trace d'un contenu en cas d'incident ou de plainte.

**EXIG-CON-21**
**DOIT**

**Explication intelligible et canal de révision**

Chaque avis de décision rendu à l'égard d'une personne avec l'aide d'un agent, que la décision soit entièrement ou partiellement automatisée, **DOIT** indiquer le canal de révision humaine et ses coordonnées. L'explication fournie sur demande présente en langage clair les principaux facteurs et leur importance relative, sans divulguer l'algorithme ni les poids du modèle; le raisonnement affiché par le modèle n'en tient jamais lieu.

Pourquoi : l'interprétation gouvernementale limite l'explication aux facteurs déterminants, et couvrir les décisions partiellement automatisées anticipe le projet C-36 et les principes des commissaires[318, 431].

**EXIG-CON-22**
**DOIT**

**Vérification humaine du contenu juridique**

Tout contenu juridique, réglementaire ou contractuel produit par un agent et destiné à un usage externe (tribunal, autorité, client, partenaire) **DOIT** être vérifié avant sa diffusion par une personne compétente, qui confirme que chaque source citée existe et appuie l'énoncé.

Pourquoi : dans *Specter Aviation c. Laprade* (2025 QCCS 3521), la Cour supérieure du Québec a imposé une sanction de 5 000 $, en vertu de l'article 342 du Code de procédure civile, pour le dépôt de références inexistantes générées par l'IA[458].

## 12.8 Incidents agentiques

Un incident agentique se gère comme un incident de sécurité, avec deux particularités : l'agent peut continuer d'agir pendant qu'on l'analyse, et ses effets peuvent exiger une compensation métier.

Le cadre définit l'incident agentique comme une action non autorisée, une fuite de données, une décision erronée ayant produit un effet, un contournement de garde-fou ou un emballement des coûts imputable à un agent. Un incident de confidentialité au sens de la Loi 25 en est un cas particulier, par exemple un connecteur MCP trop permissif qui expose le dossier d'un autre client. L'enjeu n'est pas théorique : en 2024-2025, la CAI a reçu 514 avis d'incidents de confidentialité, en hausse de 16 %, dont 80 % du secteur privé, et les accès non autorisés y dominent (251 avis)[424].

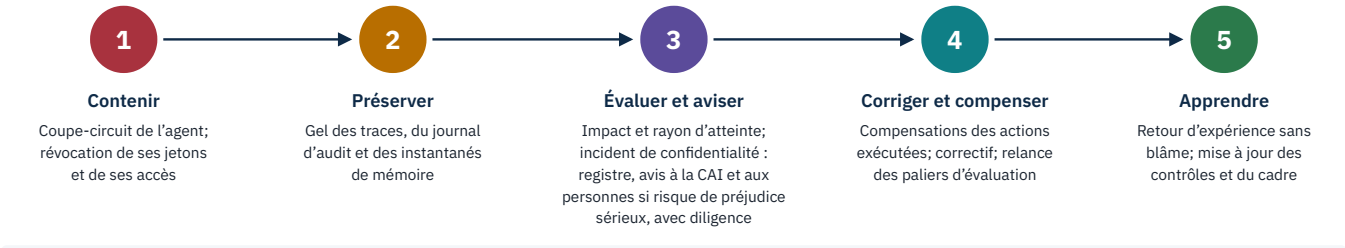



**Figure 26 — Réponse à un incident agentique.** Les cinq temps se lisent de gauche à droite : on contient l'agent avant de chercher la cause, on fige les preuves avant de corriger, puis on évalue, on avise, on répare et on apprend.

Source : cadre CRE-IA-2026-01.

1. **Contenir.** L'équipe de garde actionne le coupe-circuit de l'agent à la passerelle, révoque ses jetons et ses accès, suspend ses délégations en cours et annule les actions en attente d'approbation (section 7.8).
2. **Préserver.** Les traces, le journal d'audit, les instantanés de mémoire et les versions exactes de l'agent, du modèle, des invites et des définitions d'outils sont figés. Pour un système à haut risque, le RIA interdit au fournisseur, dans l'enquête qui suit le signalement d'un incident grave, d'altérer le système d'une manière susceptible de nuire à l'évaluation ultérieure des causes avant d'en informer les autorités compétentes (art. 73(6)); le déployeur y est soumis lorsqu'il ne peut joindre le fournisseur (art. 26(5))[94, 459].
3. **Évaluer et aviser.** Les traces permettent de mesurer le rayon d'atteinte : personnes, systèmes et partenaires touchés. L'équipe qualifie l'incident au regard de chaque régime (incident de confidentialité, atteinte au sens de la LPRPDE, incident technologique au sens du BSIF, incident grave au sens du RIA) et déclenche les avis du tableau 51.
4. **Corriger et compenser.** Les actions exécutées sont compensées selon le patron saga (section 7.5), le correctif est appliqué, puis les paliers d'évaluation sont relancés avant toute remise en service; le niveau d'autonomie peut être abaissé.
5. **Apprendre.** Un retour d'expérience sans blâme met à jour les contrôles, les jeux d'évaluation et, au besoin, le cadre.

**Tableau 51 — Délais de notification applicables aux incidents agentiques**

| Régime | Déclencheur | Destinataires | Délai |
|---|---|---|---|
| Loi sur le privé, art. 3.5 | Incident de confidentialité présentant un risque de préjudice sérieux | CAI et personnes concernées | « Avec diligence »; aucun délai en heures |

| Régime | Déclencheur | Destinataires | Délai |
|---|---|---|---|
| Loi sur le privé, art. 3.8, et Règlement sur les incidents de confidentialité | Tout incident de confidentialité, même sans risque de préjudice sérieux | Registre interne, transmis à la CAI sur demande | Tenu à jour; conservé au moins cinq ans |
| LPRPDE | Atteinte présentant un risque réel de préjudice grave | Commissariat et personnes concernées | « Dès que possible »; registre de toutes les atteintes conservé 24 mois |
| Avis du BSIF (2021) | Incident lié à la technologie ou à la cybersécurité d'une institution financière fédérale | BSIF | Par écrit, dans les 24 heures ou plus tôt si possible |
| RIA, art. 73 (fournisseur) et art. 26(5) (déployeur : informer d'abord le fournisseur) | Incident grave impliquant un système à haut risque | Autorités de surveillance du marché | Dès l'établissement d'un lien de causalité (ou de sa probabilité raisonnable) et, dans tous les cas, au plus tard 15 jours après la prise de connaissance de l'incident grave par le fournisseur ou, le cas échéant, le déployeur; 10 jours en cas de décès; 2 jours en cas d'infraction généralisée ou de perturbation grave et irréversible d'une infrastructure critique |
| Cadre (cible interne) | Incident de confidentialité présentant un risque de préjudice sérieux | CAI | Avis initial visé dans les 72 heures suivant la prise de connaissance, complété ensuite |

Sources : L.Q. 2021, c. 25; Règlement sur les incidents de confidentialité; Commissariat à la protection de la vie privée; BSIF; RIA[56, 62, 426, 427, 434, 459, 460]. Le délai de 72 heures est une cible du cadre, non une exigence de la Loi 25.

L'avis écrit à la CAI comporte onze éléments, dont l'organisation et son numéro d'entreprise du Québec (NEQ), une personne-ressource, les renseignements visés, les circonstances et la cause, la date ou la période de l'incident, la date de prise de connaissance, le nombre de personnes touchées (dont les résidents du Québec), les motifs du risque de préjudice et les mesures d'atténuation; les compléments sont transmis avec diligence[460]. Le cadre fait produire ces champs à partir de la télémétrie des agents, pour que l'avis ne dépende pas d'une reconstitution manuelle.

**EXIG-CON-23**
**DOIT**

**Réponse en cinq temps et gel des preuves**

Le plan de réponse aux incidents de chaque agent **DOIT** suivre les cinq temps de la figure 26. La contention (coupe-circuit et révocation des jetons) **DOIT** être exécutable par l'équipe de garde sans approbation préalable, et le gel des traces, du journal d'audit, des instantanés de mémoire et des versions exactes de l'agent, du modèle, des invites et des définitions d'outils précède toute correction.

Pourquoi : sans versions figées, l'analyse des causes devient impossible; MANAGE 2.4 demande des mécanismes et des responsabilités clairs pour désactiver un système[74].

**EXIG-CON-24**
**DOIT**

**Registre et avis des incidents de confidentialité**

Tout incident de confidentialité impliquant un agent **DOIT** être inscrit au registre des incidents avec le contenu prévu par le Règlement sur les incidents de confidentialité et conservé au moins cinq ans. S'il présente un risque de préjudice sérieux, la CAI et les personnes concernées sont avisées avec diligence; le cadre fixe une cible interne de 72 heures pour l'avis initial à la CAI, que l'équipe de réponse **DEVRAIT** respecter (choix du cadre).

Pourquoi : articles 3.5 et 3.8 de la Loi sur le privé et articles 7 et 8 du règlement; la loi n'impose aucun délai en heures, d'où une cible interne explicite[56, 414, 460].

**EXIG-CON-25**
**DOIT**

**Règle la plus exigeante entre régimes de notification**

Le plan de réponse **DOIT** recenser, pour chaque agent, les régimes de notification applicables (Loi 25, LPRPDE, BSIF, RIA) et appliquer le plus exigeant : registre unique conservé cinq ans, double analyse du « préjudice sérieux » (Québec) et du « risque réel de préjudice grave » (fédéral), délais du tableau 51. L'événement d'incident produit à partir de la télémétrie comporte les champs de l'avis exigé par le règlement québécois.

Pourquoi : une organisation soumise à plusieurs régimes doit pouvoir satisfaire le plus strict sans reconstituer les faits sous la pression du délai.

## 12.9 Évaluation d'impact unifiée

Plutôt que plusieurs analyses rédigées par plusieurs équipes, le cadre exige un seul livrable par agent de classe élevée, structuré pour répondre à chaque régime.

Les régimes se recoupent largement. L'EFVP examine les RP et leur parcours. L'analyse d'impact sur les droits fondamentaux (AIDF) du RIA est obligatoire avant la première utilisation pour les déployeurs qui sont des organismes de droit public, les entités privées qui fournissent des services publics et les déployeurs de systèmes d'évaluation de la solvabilité ou de tarification en assurance vie et maladie; elle décrit les processus, la durée et la fréquence d'utilisation, les personnes touchées, les risques, les mesures de supervision humaine et les mesures prévues si les risques se matérialisent, peut renvoyer aux sections pertinentes de l'analyse d'impact relative à la protection des données (AIPD) du règlement général sur la protection des données (RGPD, art. 35) ou en intégrer des parties lorsque celle-ci remplit déjà certaines obligations (art. 27(4), tel que modifié par le règlement (UE) 2026/1744), et est notifiée à l'autorité de surveillance du marché[58, 61, 461]. ISO/IEC 42005:2025 fournit la méthode : quand et comment évaluer l'impact sur les personnes et la société, et comment l'intégrer au SMIA[452]. Un seul livrable évite que les mêmes faits soient décrits trois fois, avec trois versions différentes.

**Tableau 52 — Volets de l'évaluation d'impact unifiée**

| Volet | Source | Contenu minimal | Obligatoire lorsque |
|---|---|---|---|
| Vie privée (EFVP) | Loi sur le privé, art. 3.3 et 17; Loi sur l'accès, art. 63.5 et 70.1 | Inventaire et parcours des RP par outil, délégation et mémoire; conformité; risques et atténuation; nécessité et proportionnalité; lieux de traitement | Projet impliquant des RP; communication hors Québec |
| Droits fondamentaux (AIDF) | RIA, art. 27 | Processus, durée et fréquence d'utilisation; personnes touchées; risques; supervision humaine; mesures si le risque se matérialise | Déployeurs visés par l'article 27, avant la première utilisation |

| Volet | Source | Contenu minimal | Obligatoire lorsque |
|---|---|---|---|
| Impact algorithmique | Recommandation du gouvernement du Québec; EIA fédérale | Erreurs, discrimination et biais; niveau d'incidence | Tout agent qui décide ou recommande à l'égard d'une personne (choix du cadre); EIA pour les institutions fédérales assujetties à la directive |
| Impact sur les personnes et la société | ISO/IEC 42005; ISO/IEC 42001, 6.1.4 et A.5 | Méthode, moments du cycle de vie, documentation et intégration au SMIA | Méthode de référence du cadre pour tous les volets |
| Décision sur le risque résiduel | Cadre | Classe, niveau d'autonomie, mesures retenues, risque résiduel accepté par le propriétaire métier et par le comité | Avant l'homologation et avant tout relèvement du niveau d'autonomie |

Sources : [318, 413, 432, 452, 461].

**EXIG-CON-26**
**DOIT**

**Évaluation d'impact unifiée par agent de classe élevée**

Chaque agent de classe élevée **DOIT** disposer d'une évaluation d'impact unifiée couvrant les volets applicables du tableau 52, approuvée par le propriétaire métier et par le comité d'architecture et des risques agentiques avant le passage en pilote et avant tout relèvement de son niveau d'autonomie. Elle est mise à jour à chaque déclencheur de l'EXIG-CON-03, revue au moins une fois par année (choix du cadre) et référencée dans la fiche d'agent (annexe B).

Pourquoi : l'AIDF peut s'appuyer sur l'AIPD (art. 27(4)) et ISO/IEC 42005 fournit une méthode commune; un livrable unique garde les faits cohérents entre régimes [452, 461].

**À RETENIR**

La classe de risque commande tout le reste : plafond d'autonomie, EFVP et évaluation d'impact, fréquence des revues, intensité des tests. Une décision qu'aucun humain n'a réellement examinée reste automatisée, quel que soit le bouton cliqué. Les délais légaux de notification diffèrent selon les régimes; le cadre applique toujours le plus exigeant et s'appuie sur une base de preuves unique.

# 13 Approvisionnement et clauses contractuelles

Les protocoles d'interopérabilité relèvent désormais d'une gouvernance neutre; le risque de dépendance s'est donc déplacé vers les plateformes, leurs extensions et les données qu'elles accumulent. Ce chapitre traduit le cadre en critères d'évaluation des fournisseurs, en dix clauses contractuelles normatives et en une grille de notation. Il s'adresse aux acheteurs, aux juristes, aux architectes et au responsable de la protection des renseignements personnels qui négocient l'acquisition d'une plateforme d'agents, d'un service de modèles, d'une passerelle, d'un serveur MCP ou d'un agent de tiers.

## 13.1 Où se situe désormais le risque de verrouillage

Cette section localise le risque de dépendance envers un fournisseur *(vendor lock-in)*, afin de concentrer la négociation là où il se trouve réellement.

### Des protocoles sous gouvernance neutre

Le Model Context Protocol (MCP) a été versé à l'Agentic AI Foundation (AAIF), fondation hébergée par la Linux Foundation, dès sa création le 9 décembre 2025; AWS, Google et Microsoft figurent parmi ses membres Platine[4]. Le protocole Agent2Agent (A2A) est devenu un projet hébergé de l'AAIF le 17 août 2026[5, 35]; son comité directeur technique réunit huit entreprises concurrentes : AWS, Cisco, Google, IBM Research, Microsoft, Salesforce, SAP et ServiceNow[29]. Le risque qu'un protocole du catalogue disparaisse ou passe sous le contrôle d'un seul éditeur est donc faible. Un projet n'est toutefois un « standard AAIF » qu'une fois son admission approuvée et annoncée[42]; au 27 octobre 2026, la candidature d'AGNTCY demeure sans décision[37] (voir section 6.9).

### Un risque déplacé vers les plateformes

Un protocole ouvert ne rend pas la plateforme ouverte. Le verrouillage se loge désormais dans cinq endroits, résumés au tableau 53. Des éditeurs de passerelles soutiennent en outre que la gouvernance native d'une plateforme s'arrête à sa frontière et ne suit pas l'agent qui en sort[44, 45]. C'est un argument d'éditeurs, mais il décrit bien le risque que le cadre traite par sa passerelle d'agents et son registre d'entreprise (section 9.4 et section 11.4). Les exemples du tableau illustrent des mécanismes; ils ne jugent pas des produits qui évoluent rapidement.

**Tableau 53 — Où se loge le verrouillage (état au 27 octobre 2026)**

| Lieu | Manifestation | Exemple documenté | Parade du cadre |
|---|---|---|---|
| Extensions de protocole | Une fonction essentielle n'existe que par une extension propre à l'éditeur. | A2A permet de déclarer une extension obligatoire (`required`) dans `capabilities.extensions`[238]; MCP admet des extensions à préfixe DNS inversé, désactivées par défaut[169]. | EXIG-APP-02 et EXIG-APP-07 |
| Couverture partielle | « Prend en charge MCP » ne vise qu'une partie des primitives ou des liaisons. | Azure API Management gère les outils MCP, mais ni les ressources ni les invites, et les agents A2A en JSON-RPC seulement[108, 109]; le greffon AI A2A Proxy de Kong Gateway (3.14 et plus, édition AI Gateway Enterprise) ne gère pas l'état des tâches[111]. | Preuves par essais (EXIG-APP-03) |

| Lieu | Manifestation | Exemple documenté | Parade du cadre |
|---|---|---|---|
| Contraintes de produit | Les limites d'orchestration du produit deviennent celles de l'architecture. | Agentforce limite volontairement la délégation entre organisations Salesforce à un seul niveau et signale, pour Agent Script, une limite actuelle de sept sous-agents connectés[49]. | Logique d'orchestration détenue par l'entreprise (PRIN-09, chapitre 7) |
| Plan de contrôle et identité | L'inventaire, l'arrêt et l'identité des agents dépendent de la console de l'éditeur. | Copilot Studio crée d'office une identité Entra Agent ID pour chaque nouvel agent depuis juillet 2026[48]; les fonctions de sécurité associées exigent une licence Agent 365[324], dont les actions de cycle de vie sur des agents infonuagiques tiers sont annoncées comme à venir[46]. | EXIG-APP-06 et EXIG-APP-16 |
| Données, définitions et unités | Mémoires, invites système, journaux et unités de facturation propres rendent la sortie coûteuse. | Copilot Studio facture en crédits et désactive les agents personnalisés au-delà de 125 % de la capacité prépayée[53]. | EXIG-APP-05 et EXIG-APP-14 |

**À RETENIR**

Le protocole est ouvert; il faut négocier l'ouverture là où elle se perd : la couverture réelle du protocole, l'identité des agents, leur arrêt, leurs données et leurs définitions doivent rester sous le contrôle de l'entreprise.

**EXIG-APP-01** — DOIT

**Analyse de réversibilité avant tout engagement**

Toute acquisition d'une plateforme d'agents, d'un service de modèles, d'une passerelle ou d'un agent de tiers **DOIT** être précédée d'une analyse de réversibilité documentée : composants et extensions propriétaires utilisés, données et définitions à récupérer, formats de restitution, délai et coût estimés de sortie. L'architecture d'entreprise **DOIT** la valider, et l'analyse **DOIT** être versée au registre.

Pourquoi : le coût de sortie se décide à la signature, pas à la résiliation.

**EXIG-APP-02** — NE DOIT PAS

**Aucune dépendance à une extension non approuvée**

Un agent ou un outil de l'entreprise **NE DOIT PAS** dépendre d'une extension de protocole propriétaire absente du catalogue (section 6.3). Une extension admise **DOIT** être identifiée par son URI ou son préfixe versionné et posséder un comportement de repli documenté; elle **NE DOIT PAS** être déclarée obligatoire envers des clients, sauf dérogation (section 11.6).

Pourquoi : une extension obligatoire recrée, au-dessus d'un protocole ouvert, la dépendance que ce protocole devait éliminer.

## 13.2 Critères d'évaluation des fournisseurs

Cette section fixe ce qu'un fournisseur doit démontrer, et comment. Le principe est simple : une preuve reproductible dans l'environnement de l'entreprise l'emporte toujours sur une allégation commerciale.

### Interopérabilité protocolaire

La révision courante de MCP est 2026-07-28[34]. Le projet publie un cadre officiel de tests de conformité, encore en versions 0.x (0.1.16 sur le tag latest de npm, préversions 0.2.0-alpha en cours)[225, 226] : ses résultats sont utiles, mais l'entreprise doit les compléter par ses propres scénarios. Pour A2A 1.0, la trousse officielle a2a-tck teste les trois

liaisons standard selon les niveaux MUST, SHOULD et MAY, à partir des interfaces déclarées dans la carte d'agent[243]. Le fournisseur précise enfin comment il suivra les dépréciations : MCP maintient une fonctionnalité dépréciée au moins douze mois, ou au moins 90 jours en cas de retrait accéléré exceptionnel, avant de pouvoir la retirer[34, 196].

### Observabilité et données de coûts

Les conventions GenAI d'OpenTelemetry sont toutes au niveau de stabilité Development et ont été déplacées en mai 2026 (déclarées obsolètes dans semantic-conventions à la v1.42.0, le 12 juin 2026) vers un dépôt dédié qui n'a encore publié aucune version étiquetée[180, 181, 462]. « Compatible OpenTelemetry » ne suffit donc pas : le fournisseur déclare la version qu'il émet, et l'entreprise vérifie la propagation du contexte de trace à chaque saut. Par exemple, le SDK Python de Microsoft Agent Framework propage le contexte W3C vers les serveurs MCP que l'agent ouvre lui-même, mais pas vers les outils MCP hébergés par un fournisseur[295]. Pour les coûts, FOCUS *(FinOps Open Cost and Usage Specification)* 1.4 (ratifiée le 4 juin 2026) normalise les données de facturation, sans définir d'indicateurs par agent[408, 463, 464]; FOCUS 1.5, dont la ratification est prévue le 3 décembre 2026, prévoit, dans son brouillon de travail, l'identité du modèle et le détail des jetons[465]. Le coût par tâche réussie se calcule en joignant ces données à la télémétrie (section 10.6).

### Identité, délégation et arrêt

Le cadre exige une identité non humaine distincte par agent (section 9.2); la réutilisation d'identités (NHI9) et les secrets de longue durée (NHI7) figurent au Top 10 des identités non humaines de l'OWASP[91]. MCP impose un jeton propre à chaque serveur et interdit de relayer un jeton reçu, mais n'exige ni l'échange de jetons de la RFC 8693 ni la revendication `act`[209] : la délégation vérifiable relève donc d'une exigence contractuelle distincte (EXIG-APP-08). Les sept portes de conception publiées par MuleSoft pour un plan de contrôle d'agents, dont la neutralité de l'application des politiques au niveau du transport et la propagation vérifiée de l'identité humaine déléguée, forment une grille complémentaire que le cadre retient comme critères d'acceptation d'une passerelle d'agents (section 9.4)[45].

### Performance mesurée, pas annoncée

Les chiffres publiés ne se comparent pas. TrueFoundry indique dans sa documentation une latence ajoutée généralement inférieure à 5 ms, alors que son propre banc d'essai montre de +7 à +12 ms sur 1 vCPU, entre 200 et 370 requêtes par seconde selon le niveau de traçage[143, 144]. L'équipe d'agentgateway déclare environ 500 000 requêtes par seconde et une latence P99 inférieure à 0,2 ms à 30 000 requêtes par seconde, sans préciser le type de trafic ni le matériel[142]. Aucune de ces sources ne précise si l'inspection des politiques agentiques était active pendant la mesure.

**EXIG-APP-03** — DOIT

**Preuves de conformité protocolaire**

Le fournisseur **DOIT** démontrer la prise en charge de MCP 2026-07-28 et d'A2A 1.0 par des essais reproductibles dans l'environnement de l'entreprise : rapport a2a-tck sans échec de niveau MUST pour chaque liaison déclarée, scénarios de conformité MCP exécutés avec le cadre officiel ou une suite équivalente approuvée par l'architecture d'entreprise, et liste explicite des primitives, liaisons et versions non prises en charge.

Pourquoi : « prend en charge » couvre souvent une partie seulement du protocole (tableau 53).

**EXIG-APP-04** — DOIT

**Mesures de performance reproductibles**

Toute valeur de latence ajoutée, de débit ou de disponibilité invoquée par un fournisseur **DOIT** être mesurée dans les conditions de l'entreprise, politiques, traçage et journalisation actifs, aux 50$^{e}$ et 99$^{e}$ centiles (P50 et P99), avec la méthode, le matériel, le type de trafic et les données brutes. Une valeur publiée par le fournisseur **NE DOIT PAS** servir d'exigence ni de critère de notation.

Pourquoi : les allégations publiques sont incomparables, parfois contradictoires.

**EXIG-APP-05**
**DOIT**

**Télémétrie et données de coûts ouvertes**

La solution **DOIT** exporter traces, métriques et journaux par OTLP selon une version déclarée et épinglée des conventions GenAI, propager le contexte W3C Trace Context sur chaque saut qu'elle contrôle et fournir ses données de facturation au format FOCUS 1.4 ou ultérieur, avec la correspondance entre ses unités propres (crédits, messages) et les jetons consommés.

Pourquoi : sans traces ni coûts exportables, l'entreprise ne peut ni auditer ses agents ni comparer ses fournisseurs (section 10.1).

**EXIG-APP-06**
**DOIT**

**Identité et arrêt sous le contrôle de l'entreprise**

La solution **DOIT** attribuer à chaque agent une identité non humaine distincte, fédérable au fournisseur d'identité de l'entreprise et sans clé statique partagée, et permettre à l'entreprise de suspendre ou de révoquer un agent, ses jetons et ses sessions depuis ses propres outils, par exemple au moyen d'événements CAEP[344], sans attendre une intervention du fournisseur.

Pourquoi : un coupe-circuit qui dépend de la console d'un éditeur n'est pas un coupe-circuit d'entreprise (section 9.4).

## 13.3 Clauses contractuelles normatives

Les dix clauses suivantes sont des exigences minimales. Elles s'insèrent dans tout contrat d'acquisition ou de renouvellement visé par ce chapitre; leur rédaction juridique relève des affaires juridiques. Les délais marqués « cible du cadre » sont des choix internes, ajustables par dérogation (section 11.6). Dans ce chapitre, « Loi sur le privé » désigne la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1).

DROIT APPLICABLE

L'entreprise demeure responsable des renseignements personnels qu'elle confie à un fournisseur, y compris en cas d'incident[414]. La Loi sur le privé ne prévoit pas de responsabilité « conjointe » : elle impose un contrat écrit qui encadre le mandataire (art. 18.3)[56]. Les clauses donnent à l'entreprise les moyens de remplir ses propres obligations (section 12.2).

**EXIG-APP-07**
**DOIT**

**Clause 1 — Interopérabilité ouverte et portabilité des cartes**

Le contrat **DOIT** engager le fournisseur à prendre en charge A2A 1.0 en entrée et en sortie pour toute délégation entre agents; à publier des cartes d'agent conformes à la spécification A2A, dont le fichier `a2a.proto` est la définition normative, à l'adresse `/.well-known/agent-card.json` pour les agents exposés; à n'exiger aucune extension propriétaire pour déléguer une tâche à un agent tiers ou en recevoir une; et à maintenir une version de protocole dépréciée au moins pendant la période prévue par la spécification, avec préavis écrit avant son retrait.

Pourquoi : sans A2A 1.0 natif ni extension imposée, l'entreprise change de fournisseur sans réécrire ses délégations; le schéma de la carte relève de la spécification A2A, non d'un éditeur ni d'un autre projet[68].

**EXIG-APP-08**
**DOIT**

**Clause 2 — Conformité MCP et délégation d'identité**

Le contrat **DOIT** exiger que tout outil ou connecteur exposé par le fournisseur respecte MCP 2026-07-28 et sa spécification d'autorisation : paramètre `resource` de la RFC 8707, jeton propre à chaque serveur, interdiction de relayer un jeton reçu[71, 209]. Il **DOIT** exiger en outre, comme engagement distinct de la conformité MCP, l'acceptation de jetons délégués émis par échange de jetons (RFC 8693) dont la revendication `act` conserve la chaîne des acteurs[70]. La prise en charge de l'extension Enterprise-Managed Authorization **PEUT** être valorisée dans la notation de la ligne « Identité et délégation »[178].

Pourquoi : sans chaîne de délégation, la passerelle ne peut pas appliquer l'intersection des droits du mandant et de l'agent (section 9.3).

**EXIG-APP-09**
**DOIT**

**Clause 3 — Télémétrie exportable et explicabilité**

Le contrat **DOIT** garantir à l'entreprise un accès continu aux traces et aux journaux d'exécution de ses agents, y compris la version exacte du modèle, les outils appelés et les approbations. Pour toute décision concernant une personne, le fournisseur **DOIT** fournir de quoi l'informer des renseignements personnels utilisés et des raisons, principaux facteurs et paramètres de la décision (art. 12.1, qui vise les décisions fondées exclusivement sur un traitement automatisé; l'étendre à toute décision est un choix du cadre), conserver ces renseignements au moins un an après la décision (art. 11) et permettre de répondre aux demandes d'accès dans les 30 jours (art. 32)[56].

Pourquoi : l'obligation d'expliquer reste à l'entreprise; elle vise les facteurs déterminants, non l'algorithme[318].

**EXIG-APP-10**
**DOIT**

**Clause 4 — Usage limité au mandat et interdiction d'entraînement**

Le contrat **DOIT** préciser les mesures de confidentialité, limiter l'usage des renseignements à l'exécution du mandat et en interdire la conservation après son échéance (art. 18.3)[56]. Il **DOIT** aussi interdire expressément d'utiliser les données de l'entreprise (invites, contextes, sorties, traces, mémoires, plongements vectoriels) pour entraîner, ajuster ou évaluer des modèles du fournisseur ou de tiers, sauf autorisation écrite distincte.

Pourquoi : la loi ne nomme pas l'entraînement; l'interdiction explicite découle de la limitation au mandat et ferme toute ambiguïté.

**EXIG-APP-11**
**DOIT**

**Clause 5 — Résidence, transferts et lois étrangères**

Le contrat **DOIT** déclarer chaque lieu de traitement ou de conservation des données de l'entreprise (inférence, outils, mémoires, journaux, sous-traitants), prévoir un préavis écrit de tout changement (cible du cadre : 90 jours), constituer l'entente écrite exigée par l'article 17 de la Loi sur le privé[56] lorsque des renseignements personnels sont communiqués hors du Québec, ce que le cadre interprète comme incluant une autre province, ou confiés à un tiers établi hors du Québec pour traitement ou conservation, et documenter l'exposition du fournisseur à des lois étrangères d'accès aux données, avec les mesures compensatoires retenues, par exemple un chiffrement à clés gérées par l'entreprise[416].

Pourquoi : le *Clarifying Lawful Overseas Use of Data Act* (CLOUD Act) des États-Unis oblige un fournisseur qui y est assujetti à divulguer les données sous sa garde ou son contrôle, où qu'elles soient[417]; le gouvernement fédéral reconnaît que le stockage au Canada ne suffit pas à écarter la compétence de tribunaux étrangers, tout en ne relevant aucun cas documenté de gouvernement étranger cherchant à accéder aux données d'entreprises canadiennes détenues par des fournisseurs[418]. L'EFVP pondère ce risque.

**EXIG-APP-12**
**DOIT**

**Clause 6 — Notification d'incident**

Le contrat **DOIT** obliger le fournisseur à aviser l'entreprise sans délai, et au plus tard dans le délai que le contrat fixe (cible du cadre : 24 heures après la prise de connaissance par le fournisseur), de tout incident touchant ses données, ses identités ou ses agents, y compris une action d'agent non autorisée, une injection réussie ou une fuite par un outil; à transmettre les éléments requis pour l'avis à la Commission d'accès à l'information (CAI) et pour le registre des incidents; et à préserver les preuves et les versions en cause.

Pourquoi : le mandataire doit aviser sans délai de toute violation (art. 18.3), et l'entreprise doit aviser la CAI « avec diligence » lorsque l'incident présente un risque de préjudice sérieux (art. 3.5), la loi ne fixant aucun délai en heures[56]; la cible de 24 heures reprend l'ordre de grandeur du délai de signalement au BSIF sans suffire à le respecter à elle seule : l'avis exige 24 heures ou moins, sans fixer le point de départ, et une institution financière fédérale devrait exiger un délai plus court[434] (section 12.8).

**EXIG-APP-13**
**DOIT**

**Clause 7 — Audit, sécurité et transparence des changements**

Le contrat **DOIT** accorder à l'entreprise un droit de vérification, l'accès aux résultats des évaluations de sécurité et d'équipe rouge des composants agentiques, fondées au minimum sur l'OWASP Top 10 for Agentic Applications 2026[28], la liste à jour des modèles, serveurs MCP, agents et sous-traitants intégrés avec leurs versions, et un préavis écrit avant tout changement de modèle qui modifie le comportement d'un agent de l'entreprise.

Pourquoi : un changement de modèle ou de fournisseur peut exiger la mise à jour de l'EFVP[413] et, dans les institutions financières fédérales, la revue prévue par la ligne directrice E-23, qui inclut les modèles de fournisseurs[8]; le NIST AI RMF demande des politiques sur les risques de tiers (GOVERN 6.1)[74].

**EXIG-APP-14**
**DOIT**

**Clause 8 — Réversibilité et sortie**

Le contrat **DOIT** prévoir qu'à l'échéance, à la résiliation ou sur demande, le fournisseur restitue dans des formats ouverts, structurés et documentés les mémoires des agents (épisodique, sémantique, procédurale), les graphes de connaissances, les définitions d'agents (invites système, cartes, compétences, flux, politiques), la configuration des outils, les journaux d'audit et les traces; qu'il prête assistance pendant une période de transition (cible du cadre : six mois); puis qu'il détruise les données et l'atteste par écrit.

Pourquoi : la mémoire et les définitions forment l'actif que l'entreprise doit garder (section 5.5); la loi exige que le contrat prévoie que le mandataire ne conserve pas les renseignements après le mandat[56].

**EXIG-APP-15**
**DOIT**

**Clause 9 — Accord écrit au sens de l'article 25(4) du RIA**

Lorsque l'entreprise est fournisseur d'un système d'IA à haut risque au sens du règlement européen sur l'IA (RIA), ou le devient, notamment en y apposant son nom, en le modifiant substantiellement ou en réaffectant un agent à un usage de l'annexe III (art. 25(1)), le contrat avec chaque tiers qui fournit un outil, un service, un composant ou un modèle intégré **DOIT** constituer l'accord écrit exigé par l'article 25(4), tel que modifié par le règlement (UE) 2026/1744[58, 61, 375]. Le cadre y exige au minimum la documentation technique, l'accès aux journaux, l'accès pour essais et l'assistance en cas d'incident.

Pourquoi : ces obligations visent les systèmes de l'annexe III à compter du 2 décembre 2027 et ceux de l'annexe I à compter du 2 août 2028[57]; les outils, services, processus et composants rendus publics sous licence libre et ouverte en sont exemptés, sauf s'il s'agit de modèles d'IA à usage général (section 12.4).

**EXIG-APP-16**
**DOIT**

**Clause 10 — Révocation des identités non humaines**

Le contrat **DOIT** prévoir, à la fin du contrat ou à la suspension d'un agent, la révocation par le fournisseur, dans un délai fixé (cible du cadre : 24 heures), de toutes les identités non humaines, justificatifs, jetons, consentements OAuth, abonnements de notification et webhooks liés à l'entreprise, avec attestation écrite. L'entreprise **DOIT** révoquer de son côté les accès qu'elle a accordés et vérifier l'absence d'accès résiduel.

Pourquoi : le retrait inadéquat est le premier risque du Top 10 NHI de l'OWASP (NHI1)[91]; le NIST AI RMF prévoit un déclassement sécuritaire (GOVERN 1.7)[74], et le livre blanc de l'OpenID Foundation (section 2.9) recommande un retrait formel propagé à tous les systèmes intégrés[466].

## 13.4 Grille d'évaluation

La grille du tableau 54 rend les offres comparables. Chaque critère reçoit une note de 0 à 3 : 0, absent ou non démontré; 1, partiel ou inscrit à une feuille de route datée; 2, démontré par le fournisseur; 3, démontré par un essai reproductible de l'entreprise. Le score est la moyenne pondérée des notes. Le cadre fixe le seuil d'admissibilité à 2,0, sans aucun échec à un critère éliminatoire. Les pondérations sont indicatives : pour un agent de classe de risque élevée, le comité peut les rééquilibrer d'au plus 5 points par critère, en le justifiant, la somme des poids demeurant égale à 100.

**Tableau 54 — Grille d'évaluation des fournisseurs de solutions agentiques**

| Critère | Ce qui est évalué | Preuve attendue | Poids | Éliminatoire |
|---|---|---|---|---|
| Interopérabilité protocolaire | MCP 2026-07-28 et A2A 1.0 natifs; primitives et liaisons couvertes; extensions | Rapport a2a-tck, résultats de conformité MCP, liste des écarts | 20 | Oui |
| Identité et délégation | Identité par agent, fédération, jetons délégués, révocation par l'entreprise | Démonstration dans le locataire de l'entreprise; essai de révocation chronométré | 15 | Oui |
| Sécurité et chaîne d'approvisionnement | Garde-fous, bacs à sable, inventaire versionné des composants, équipe rouge | Rapports d'essai; inventaire; droit d'audit (clause 7) | 15 | Non |
| Observabilité et audit | OTLP, conventions épinglées, propagation du contexte, journal d'audit exportable | Trace de bout en bout produite pendant l'essai | 15 | Oui |
| Données, résidence et conformité | Lieux de traitement, article 17, interdiction d'entraînement, article 12.1, incidents | Clauses 3 à 6 acceptées; carte des flux pour l'EFVP | 15 | Oui |
| Réversibilité | Formats de restitution, assistance, délai de sortie | Essai de restitution sur un agent pilote | 10 | Non |
| Coûts et FinOps | Données FOCUS, unités propres, plafonds par agent (EXIG-APP-05) | Export FOCUS d'un mois de pilote | 5 | Oui |
| Performance mesurée | Latence ajoutée P50 et P99, débit, disponibilité | Banc d'essai reproductible de l'entreprise (EXIG-APP-04) | 5 | Non |

**EXIG-APP-17**
**DOIT**

**Application de la grille**

Toute acquisition visée par ce chapitre **DOIT** être évaluée avec la grille du tableau 54. Une offre qui échoue un critère éliminatoire **DOIT** être écartée, sauf dérogation approuvée (section 11.6). La grille remplie et ses preuves **DOIVENT** être conservées au registre (section 11.4) et réévaluées à chaque renouvellement de contrat.

Pourquoi : une grille commune rend les décisions traçables et comparables d'une acquisition à l'autre.

# 14 Modèle de maturité

Ce chapitre situe l'entreprise sur cinq niveaux de maturité et cinq dimensions, pour mesurer l'écart entre ses pratiques et le cadre. Il fixe la méthode d'évaluation, les preuves attendues et le lien entre la maturité, les jalons et l'autonomie permise, puis relie le modèle à ISO/IEC 42001 et au NIST AI RMF. Il n'ajoute aucune exigence.

## 14.1 Cinq niveaux et cinq dimensions

Cette section définit l'échelle. Chaque niveau décrit un état observable des pratiques, et les niveaux sont cumulatifs : atteindre le niveau 3 suppose de satisfaire aussi aux critères du niveau 2. Les cinq dimensions reprennent les piliers du cadre : interopérabilité (chapitre 6), orchestration (chapitre 7), identité et sécurité (chapitre 9), observabilité, évaluation et coûts compris (chapitre 10), et gouvernance (chapitre 11 et chapitre 12).

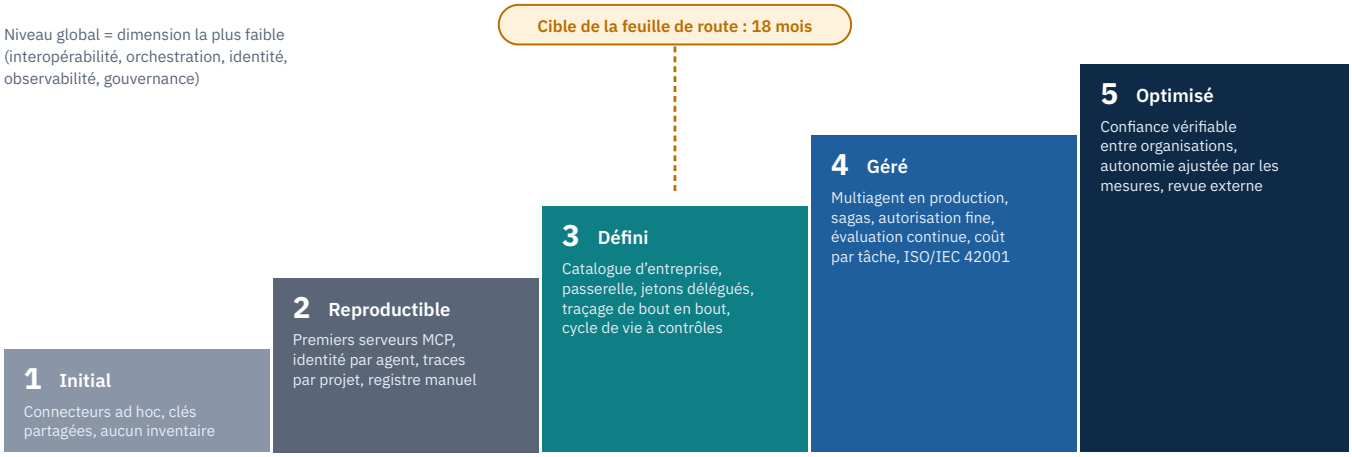



**Figure 27 — Modèle de maturité en cinq niveaux.** Chaque niveau englobe les précédents; la feuille de route vise le niveau 3, « Défini », en 18 mois (durée indicative, à calibrer après l'évaluation initiale). Le niveau global de l'entreprise est celui de sa dimension la plus faible.
Source : CRE-IA-2026-01.

Le passage du niveau 2 au niveau 3 tient d'abord à la portée des pratiques : au niveau 2, à l'exception du registre, de l'identité et de la passerelle de modèles, qui couvrent déjà tous les agents, elles visent surtout les nouveaux agents et les pilotes; au niveau 3, elles forment la norme unique de tout le portefeuille. Le niveau 4 ajoute le pilotage par les mesures; le niveau 5, l'amélioration continue et la confiance étendue aux partenaires.

**Tableau 55 — Niveaux de maturité par dimension**

| Niveau | Interopérabilité | Orchestration | Identité et sécurité | Observabilité | Gouvernance |
|---|---|---|---|---|---|
| **1 — Initial** Pratiques improvisées par chaque équipe | Connecteurs ad hoc, propres à chaque projet | Invites et scripts isolés; logique métier confiée au modèle | Clés d'API et comptes de service partagés | Journaux locaux; coûts inconnus | Aucun inventaire; agents fantômes |

| Niveau | Interopérabilité | Orchestration | Identité et sécurité | Observabilité | Gouvernance |
|---|---|---|---|---|---|
| **2 — Reproductible** Pratiques établies et répétées | Premiers serveurs MCP et cartes d'agent au catalogue, versions épinglées; contrats pour les outils des pilotes | Flux déterministes à étapes agentiques; patron documenté par agent; exécution durable des pilotes | Identité propre à chaque agent, aucune clé partagée; secrets au coffre; passerelle de modèles; coupe-circuit exercé | Traces OpenTelemetry par projet; journal d'audit des pilotes; coûts suivis par agent | Registre complet, tenu en partie à la main; parrain nommé pour chaque agent; comité en fonction; classes de risque attribuées |
| **3 — Défini** Pratiques normalisées pour tout le portefeuille | Catalogue d'entreprise unique; MCP et A2A pour tout nouvel agent; intégrations existantes migrées | Patrons autorisés et gabarits; moteur d'exécution durable; compensation définie pour chaque étape à effet; plafonds d'itérations | Passerelle d'agents pour tout appel interdomaine; jetons délégués; garde-fous communs; bacs à sable; équipe rouge régulière | Traçage de bout en bout; journal d'audit de toute action P2 et P3; évaluation dans la chaîne CI/CD; enveloppes budgétaires | Cycle de vie à points de contrôle pour tous les agents; aucun justificatif sans fiche complète; dérogations bornées |
| **4 — Géré** Pratiques pilotées par les mesures | Systèmes clés exposés au catalogue; versions gérées; chorégraphie CloudEvents et AsyncAPI; réutilisation mesurée | Multiagent en production là où un gain est mesuré; sagas éprouvées par injection de fautes; routage des modèles selon les mesures | Autorisation fine par politiques en code; délai de révocation mesuré en exercice, sous la cible | Évaluation continue, production comprise; détection de la dérive; coût par tâche réussie suivi | Indicateurs trimestriels utilisés dans les décisions du comité; préparation à la certification ISO/IEC 42001 |
| **5 — Optimisé** Amélioration continue, confiance étendue aux partenaires | Interopérabilité avec les partenaires; vocabulaire sémantique partagé | Chorégraphie interdomaines; autonomie ajustée selon les mesures, à la hausse comme à la baisse | Confiance vérifiable entre organisations : cartes signées, fédération des identités et de la délégation | Incidents et dérives versés aux jeux d'évaluation; décisions fondées sur la valeur et le risque mesurés | Révision du cadre alimentée par les incidents, les dérogations et la veille (section 11.7); revue externe |

**À RETENIR**

Un niveau de maturité qualifie l'entreprise; un niveau d'autonomie (N0 à N4, section 8.1) qualifie un agent. L'autonomie n'est pas un objectif de maturité : Feng, McDonald et Zhang en font une décision de conception, et Morris et al. rappellent que le niveau retenu au déploiement n'a pas à être le maximum que permettent les capacités du modèle[83, 302]. Une entreprise au niveau 5 peut garder la plupart de ses agents à N1 ou à N2.

## 14.2 Évaluer sa maturité

Cette section fixe la cotation, le calendrier et les preuves admises. Le but est un résultat reproductible : deux évaluateurs qui examinent les mêmes preuves aboutissent au même niveau.

### Règles de cotation

- Une dimension atteint un niveau lorsque ses critères, et ceux du niveau inférieur, sont satisfaits dans tout le périmètre qu'ils désignent, ou à défaut pour tous les agents en production.
- Le niveau global est celui de la dimension la plus faible. Une entreprise dotée d'un catalogue exemplaire, mais dont des agents partagent encore des clés d'API, reste au niveau 1 : un incident emprunte le maillon le plus faible.

- Un critère se prouve par des données du registre, des passerelles, des traces et du journal d'audit, comme les indicateurs du tableau 61; une déclaration d'équipe n'est pas une preuve. Pour les critères qui ne se calculent pas automatiquement, l'évaluateur examine les listes de contrôle de l'annexe A d'un échantillon d'agents de chaque classe; tous les agents de classe élevée en font partie.

## Calendrier et conduite

Une première évaluation précède la phase Fondations et calibre les durées de la feuille de route (section 15.1). Une évaluation a lieu ensuite à chaque jalon : le jalon 2 exige le niveau 2 sur les cinq dimensions, le jalon 3 le niveau 3 (tableau 58). Après le jalon 3, l'entreprise refait l'évaluation chaque année, par autoévaluation guidée par l'annexe A.

L'architecture d'entreprise conduit l'évaluation avec les fonctions qui répondent de chaque dimension; le comité en arrête le résultat, comme il constate les jalons. Ce résultat donne le niveau de chaque dimension, ses preuves et le plan d'action qui comble les écarts; le recul d'une dimension est soumis au comité, qui peut reporter les hausses d'autonomie prévues. Une phase peut livrer des capacités d'un niveau supérieur : la phase Industrialisation livre des flux multiagents et des sagas, dont l'exploitation éprouvée (gain mesuré, essais par injection de fautes) relève du niveau 4 en orchestration, alors que le jalon 3 ne vérifie que le niveau 3.

## Preuves attendues

**Tableau 56 — Preuves attendues par niveau de maturité**

| Niveau | Exemples de preuves |
|---|---|
| 2 — Reproductible | Couverture du registre à 100 %; aucun agent sans justificatif propre; tous les appels de modèles par la passerelle; catalogue publié; traces des pilotes; rapport d'exercice du coupe-circuit; pilotes homologués selon l'annexe A. |
| 3 — Défini | Conformité au catalogue et couverture des passerelles interdomaines à 100 %, agents existants compris; traçabilité de toutes les actions P2 et P3; couverture de l'évaluation à 100 %; points de contrôle consignés pour chaque agent (EXIG-GOV-11); rapports d'équipe rouge. |
| 4 — Géré | Séries trimestrielles d'indicateurs et décisions du comité qui s'y appuient; délai de révocation mesuré en exercice sous la cible; alertes de dérive traitées; coût par tâche réussie comparé au processus de référence; déclaration d'applicabilité et audit interne. |
| 5 — Optimisé | Révisions du cadre motivées par les incidents et les mesures; rapport de revue externe ou certificat ISO/IEC 42001; ententes avec des partenaires; contributions aux standards ouverts. |

**ATTENTION**

Le modèle mesure l'avancement; il ne suspend aucune exigence. Tout nouvel agent est homologué selon l'annexe A, quel que soit le niveau de l'entreprise; les agents existants sont ramenés en conformité selon la feuille de route, sous les plafonds de phase ou par dérogation bornée (section 11.6).

## Maturité et autonomie permise

Les règles de progression du chapitre 15 font de la maturité une condition de l'autonomie (tableau 58) : N2 et les premiers N3 bornés après le jalon 1; N3 entre domaines après le jalon 2, donc au niveau 2 de maturité, pour un agent dont tous les appels interdomaines passent déjà par la passerelle d'agents; N4 après le jalon 3, donc au niveau 3 sur les cinq dimensions, pour un agent de classe faible, sur un domaine d'exploitation certifié et sur décision du comité. Le plafond de la classe de risque s'applique en plus, et le plus strict l'emporte.

## 14.3 Lien avec la certification ISO/IEC 42001 et le NIST AI RMF

Cette section situe le modèle par rapport aux deux référentiels présentés à la section 12.5. Le modèle est un instrument interne de pilotage, qui ne donne lieu à aucune certification.

Le NIST AI RMF, d'application volontaire, propose des profils temporels : un profil actuel *(Current Profile)* décrit la gestion présente de l'IA, un profil cible *(Target Profile)* les résultats nécessaires pour atteindre les objectifs de gestion des risques. Leur comparaison révèle des écarts que des plans d'action comblent; le NIST ne prescrit aucun gabarit de profil[74, 448]. L'évaluation de maturité suit cette logique; pour en tirer un profil au sens du NIST, l'entreprise rattache ses critères aux sous-catégories pertinentes, dont celles du tableau 57.

ISO/IEC 42001:2023 est au contraire une norme d'exigences certifiable par tierce partie, par des organismes conformes à ISO/IEC 17021-1 et à ISO/IEC 42006:2025[451]. Norme de système de management, elle encadre des processus, du contexte de l'organisation (article 4) jusqu'à l'amélioration (article 10)[395]. Le cadre situe donc la préparation à la certification au niveau 4, qui ajoute aux processus du niveau 3 une évaluation des performances fondée sur des mesures. La déclaration d'applicabilité, qui rattache les exigences du cadre aux mesures de l'annexe A de la norme (section 12.5), est un livrable de ce niveau.

**Tableau 57 — Correspondance indicative entre niveaux de maturité, ISO/IEC 42001 et NIST AI RMF**

| Niveau | ISO/IEC 42001:2023 | NIST AI RMF 1.0 |
|---|---|---|
| 2 — Reproductible | Politique d'IA (5.2), rôles (5.3); premières appréciations des risques (6.1.2) | GOVERN 1.6 (inventaire), 2.1 (rôles); MANAGE 2.4 (coupe-circuit) |
| 3 — Défini | Planification et fonctionnement appliqués à tous les agents (6.1.2 à 6.1.4, article 8); mesures A.5, A.6.2.8 et A.10 | GOVERN 1.7 (déclassement), 6.1 (tiers); MAP 3.5 (supervision humaine); MEASURE 2.7 (sécurité et résilience) |
| 4 — Géré | Évaluation des performances, audit interne et revue de direction (article 9); mesure A.6.2.6 (exploitation et surveillance) | MEASURE 2.4 (surveillance en production), 3.1 (risques émergents); MANAGE 4.1; profils actuel et cible comparés |
| 5 — Optimisé | Amélioration (article 10); certification par tierce partie | Profils revus à chaque révision du cadre |

Interprétation du cadre, établie à partir de NIST AI 100-1 et du catalogue d'ISO/IEC 42001[74, 395].

Le cadre admet une certification ISO/IEC 42001 comme revue externe de la dimension Gouvernance; elle n'atteste toutefois pas, à elle seule, les quatre autres : la norme encadre des processus, sans prescrire de protocole, de passerelle ni de format de trace. À l'inverse, un niveau élevé de maturité n'établit ni la certification ni la conformité à la Loi 25 ou au RIA, qui s'apprécient obligation par obligation (chapitre 12).

# 15 Feuille de route et indicateurs

Ce chapitre ordonne la mise en œuvre du cadre en quatre phases séparées par trois jalons, auxquels s'ajoutent un jalon réglementaire et deux jalons de mise à l'échelle; il la cale sur le calendrier 2027-2030, puis détaille les 90 premiers jours. Il fixe les indicateurs qui permettent au comité d'architecture et des risques agentiques de constater les progrès sur des mesures plutôt que sur des déclarations. Il se termine par les facteurs de succès, puis par les risques de mise en œuvre, chacun assorti de sa parade.

## 15.1 Quatre phases et leurs jalons

La mise en œuvre progresse par phases : chaque phase installe les contrôles dont la suivante a besoin, et l'autonomie accordée aux agents n'augmente qu'une fois ces contrôles en service. C'est la logique d'un chantier : on ne monte pas les étages avant d'avoir coulé les fondations.

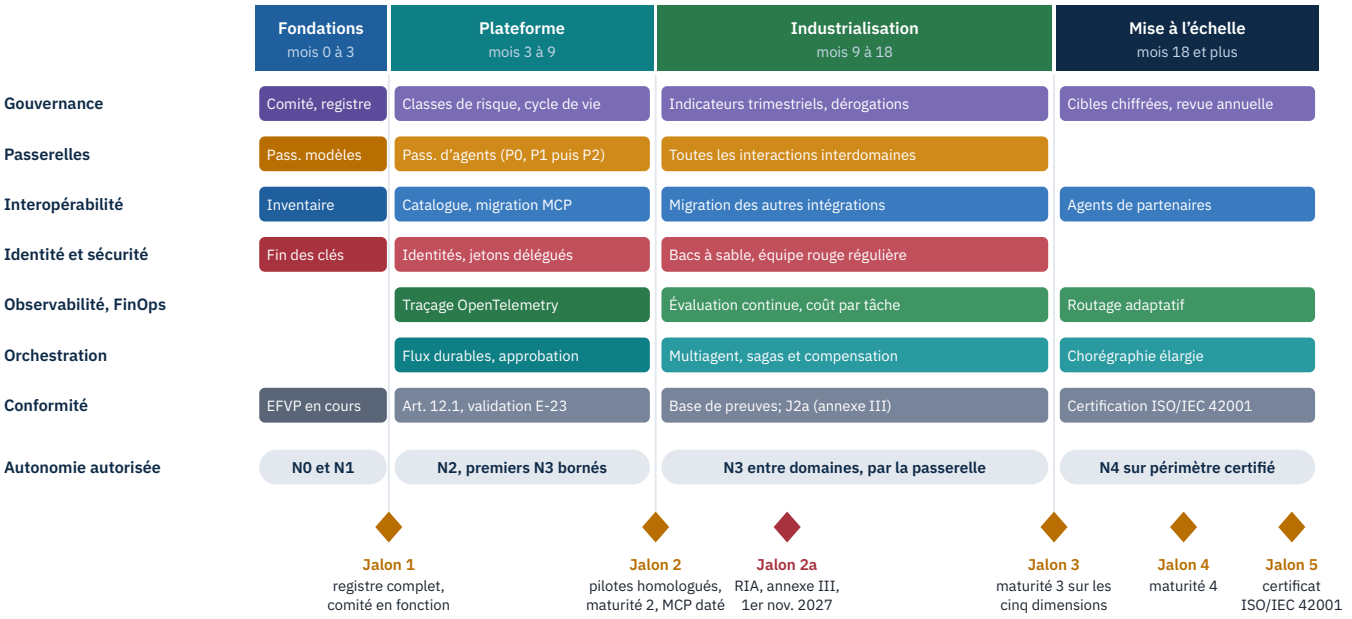



**Figure 28 — Feuille de route : quatre phases et leurs jalons.** Chaque ligne de travail avance d'une phase à l'autre; la dernière ligne indique l'autonomie maximale permise pendant la phase. Les losanges marquent les jalons : le comité constate J1, J2 et J3 avant d'ouvrir la phase suivante, J2a avant l'échéance réglementaire qu'il vise; J4 et J5 mesurent la progression dans la phase Mise à l'échelle.
Source : CRE-IA-2026-01 (durées indicatives, à calibrer après l'évaluation de maturité initiale).

Les durées sont indicatives et se calibrent après l'évaluation de maturité initiale (section 14.2) : une organisation qui exploite déjà une passerelle d'API raccourcira la phase Plateforme; celle qui découvre des dizaines d'agents non inventoriés allongera la phase Fondations. Le troisième jalon marque l'atteinte du niveau 3 de maturité sur les cinq dimensions du chapitre 14, seuil que le cadre retient pour laisser le nombre d'agents croître sans que les risques croissent au même rythme (choix du cadre). Les jalons 4 et 5 donnent à la phase Mise à l'échelle des critères de progression : le niveau 4, puis la certification ISO/IEC 42001, que le modèle de maturité place à ce niveau (figure 27).

**Tableau 58 — Phases de mise en œuvre, livrables et autonomie autorisée**

| Phase | Livrables principaux | Autonomie autorisée | Jalon de sortie |
|---|---|---|---|
| **Fondations**<br>mois 0 à 3 | Comité mandaté; inventaire et registre, agents fantômes compris; propriétaire métier nommé pour chaque agent; fin des clés d'API partagées entre agents (remplacées par un secret propre par agent au coffre sous dérogation transitoire en attendant les identités de charge de travail de la phase Plateforme); passerelle de modèles, qui met fin aux appels directs aux fournisseurs; traçage pilote; catalogue initial des protocoles, chaque serveur MCP antérieur y étant inscrit avec sa date de migration (EXIG-MCP-22); premier classement des risques; EFVP lancées; choix des blocs de solution; coupe-circuit testé. | N0 et N1 seulement : pour les agents, lecture et recommandation (N1), outils P0 et P1, aucun effet en écriture; les flux déterministes (N0) restent régis par leurs contrôles habituels. | **Jalon 1** : registre complet, comité en fonction. |
| **Plateforme**<br>mois 3 à 9 | Passerelle d'agents ouverte aux outils P0 et P1, puis P2; catalogue d'entreprise MCP et A2A; migration des serveurs et clients MCP en production vers la révision de référence, au plus tard le 28 juillet 2027 (EXIG-MCP-22); identité par agent et jetons délégués; traçage OpenTelemetry de bout en bout et journal d'audit; moteur d'exécution durable; approbation humaine signée; classement des risques et cycle de vie appliqués à tout nouvel agent; transparence envers les personnes, notamment pour les décisions visées par l'article 12.1 de la Loi sur le privé; pour une institution financière fédérale, validation initiale des agents et des modèles inscrits à l'inventaire E-23 avant le 1er mai 2027 (EXIG-CON-12); premiers pilotes. | N2; premiers N3 bornés au sein d'un même domaine, sur décision du comité, pour des agents de classe faible ou modérée. | **Jalon 2** : pilotes homologués selon l'annexe A; niveau 2 de maturité atteint sur les cinq dimensions; chaque serveur et client MCP en production sur une révision antérieure a une date de migration au plus tard le 28 juillet 2027, et aucun ne reste en production après cette date. |
| **Industrialisation**<br>mois 9 à 18 | Migration des autres intégrations existantes au catalogue; toutes les interactions interdomaines par la passerelle; évaluation continue dans la chaîne d'intégration et de livraison continues (CI/CD); enveloppes budgétaires et imputation par centre de coûts; flux multiagents, sagas et compensation; bacs à sable pour le code généré; équipe rouge régulière; base de preuves de conformité unifiée. | N3 entre domaines, dans la limite du plafond de chaque classe de risque, pour un agent dont tous les appels interdomaines passent par la passerelle d'agents. | **Jalon 2a** (organisations assujetties au RIA) : au plus tard le 1er novembre 2027, voir l'encadré ci-dessous.<br>**Jalon 3** : niveau 3 de maturité sur les cinq dimensions; cibles chiffrées des indicateurs arrêtées pour J4 (section 15.3). |
| **Mise à l'échelle**<br>mois 18 et plus | Chorégraphie événementielle élargie (CloudEvents, AsyncAPI); agents de partenaires; routage adaptatif des modèles; détection de dérive en continu; système de management de l'IA opéré, audit interne, puis audit de certification ISO/IEC 42001; revue du cadre. | N4 sur un domaine d'exploitation certifié, pour des agents de classe faible, sur décision du comité. | **Jalon 4**, vers le mois 36 : niveau 4 sur les cinq dimensions; quatre trimestres consécutifs d'indicateurs conformes aux cibles chiffrées; audit interne du SMIA réalisé et audit de certification lancé.<br>**Jalon 5**, vers le mois 48 : certificat ISO/IEC 42001 obtenu; niveau 5 visé en interopérabilité et en gouvernance; feuille de route suivante adoptée. Ensuite : revue annuelle de maturité. |

### Règles de progression

- Une phase ne doit pas être ouverte (livrables mis en production, autonomie accrue) avant que le comité ait constaté, sur preuves, le jalon qui la précède. Les travaux préparatoires de la phase suivante peuvent commencer plus tôt, mais aucune hausse d'autonomie n'est permise avant le jalon.
- Le plafond de la phase se combine avec le plafond de la classe de risque (section 8.1) : le plus strict s'applique. Un agent de classe élevée reste plafonné à N2, même en phase Mise à l'échelle; un agent de classe faible ne dépasse pas N1 tant que le jalon 1 n'est pas franchi.
- Un agent N3 qui agit entre domaines ne doit le faire que par la passerelle d'agents, même avant que la couverture interdomaines atteigne 100 % au jalon 3. Tant qu'un appel interdomaines d'un agent contourne la passerelle, les actions de cet agent hors de son domaine sont plafonnées à N2.
- Un agent existant dont le niveau dépasse le plafond de la phase doit être ramené sous ce plafond, par le retrait de ses outils en écriture ou, dès la phase Plateforme, par l'approbation de chacune de ses actions (N2), ou faire l'objet d'une dérogation limitée dans le temps (section 11.6).
- Les travaux qui découlent d'une échéance externe (J2a, la migration MCP exigée par EXIG-MCP-22 et la validation initiale E-23) sont datés par cette échéance, non par la durée des phases. Allonger une phase après l'évaluation initiale ne les reporte pas : ils passent alors en tête de la phase en cours, même s'ils appartiennent à la phase suivante, et le jalon qui précède ne les bloque pas.
- Le comité peut réordonner les travaux d'une phase selon les priorités métier. Il ne doit pas retirer un critère de jalon sans réviser le cadre (section 1.6).

**ATTENTION**

Trois échéances externes resserrent le calendrier. La ligne directrice E-23 du BSIF, en vigueur le 1er mai 2027 et applicable aux institutions financières fédérales, exige un inventaire d'entreprise des modèles à risque non négligeable, y compris ceux des fournisseurs[8]; le cadre y ajoute l'état de validation (EXIG-CON-12) : l'inventaire est complet au jalon 1, et la validation initiale des agents visés se fait au début de la phase Plateforme. Les serveurs et clients MCP en production doivent avoir migré vers la révision de référence au plus tard le 28 juillet 2027 (EXIG-MCP-22), avant la fin de la phase Plateforme. Le règlement (UE) 2024/1689, modifié par le règlement (UE) 2026/1744, rend applicables à compter du 2 décembre 2027 les obligations visant les systèmes à haut risque de l'annexe III (au 2 août 2028 pour ceux de l'annexe I)[57, 58]; pour une organisation assujettie qui adopte le cadre à l'automne 2026, cette date tombe entre les jalons 2 et 3. Les obligations déjà en vigueur, comme les articles 3.3, 12.1 et 17 de la Loi sur le privé, ne suivent pas le rythme des phases et ne souffrent aucune dérogation (section 11.6).

**JALON 2A — CONFORMITÉ AU RIA, ANNEXE III**

Pour une organisation assujettie au RIA (section 12.4), le comité constate au plus tard le 1er novembre 2027, sur preuves :

- la liste des agents qui relèvent de l'annexe III, avec l'applicabilité consignée selon l'usage des sorties dans l'Union (EXIG-CON-13);
- pour chacun, la revue de requalification en fournisseur faite (EXIG-CON-15) et, si l'organisation est fournisseur, les obligations du fournisseur en place (section 12.4);
- pour chacun, les obligations du déployeur en place (EXIG-CON-16), dont une conservation des journaux configurée pour au moins six mois;
- les preuves versées à la fiche de chaque agent, sans attendre la base de preuves unifiée de la phase Industrialisation.

À compter du 2 décembre 2027, les sorties d'un agent visé qui ne satisfait pas à ces critères ne doivent pas être utilisées dans l'Union. J2a n'ouvre aucune phase et n'accorde aucune autonomie.

## Calage sur le calendrier 2027-2030

Le tableau 59 cale la feuille de route sur une adoption du cadre à l'automne 2026 : évaluation de maturité initiale en novembre 2026, ouverture de la phase Fondations le 1er décembre 2026 (mois 0). Un autre point de départ décale toutes les dates, sauf celles qui découlent d'une échéance externe. L'entreprise refait ce calage après l'évaluation initiale.

**Tableau 59 — Calage indicatif, mois 0 au 1er décembre 2026**

| Période | Phase ou jalon | Échéances externes à tenir |
|---|---|---|
| Déc. 2026 – mi-mars 2027 | Fondations, congés des fêtes compris | — |
| Mi-mars 2027 | **J1** | Expiration de l'ébauche OAuth 2.1 -16 le 7 mars 2027 (à inscrire au catalogue; la référence normative reste OAuth 2.0) |
| Mi-mars – fin sept. 2027 | Plateforme, vacances de la construction comprises | E-23 le 1er mai 2027; migration MCP le 28 juillet 2027, à terminer avant les vacances de la construction (deux dernières semaines de juillet) |
| Début oct. 2027 | **J2** | — |
| 1er nov. 2027 au plus tard | **J2a** | RIA, annexe III, le 2 décembre 2027 |
| Oct. 2027 – juin 2028 | Industrialisation | — |
| Début juill. 2028 | **J3** | RIA, annexe I, le 2 août 2028 |
| Juill. 2028 – 2030 | Mise à l'échelle | Examen formel du NIST AI RMF au plus tard en 2028 (révision extraordinaire du cadre, section 1.6) |
| Déc. 2029 | **J4** | — |
| Déc. 2030 | **J5** | — |

Une phase de six mois ou moins qui chevauche une période de congés collectifs (fêtes de fin d'année, vacances de la construction) s'allonge de la durée de cette période, environ deux semaines chacune; le tableau 59 en tient compte. Les durées des phases plus longues et les échéances de J4 et J5 incluent déjà les congés. Les échéances externes ne bougent pas : la validation initiale E-23 reste exigible le 1er mai 2027, et la migration MCP le 28 juillet 2027.

## 15.2 Les 90 premiers jours

Les 90 premiers jours forment la phase Fondations. Ils ne servent pas à construire de nouveaux agents, mais à rendre visibles et gouvernables ceux qui existent, puis à ouvrir une voie approuvée assez simple pour que personne n'ait intérêt à la contourner. L'inventaire répond aussi à la sous-catégorie GOVERN 1.6 du NIST AI RMF, qui demande des mécanismes d'inventaire des systèmes d'IA[74]. Ces 13 semaines sont des semaines travaillées : une période de congés collectifs s'y ajoute (section 15.1).

**Tableau 60 — Plan des 90 premiers jours (phase Fondations)**

| Semaines | Travaux | Livrable vérifiable | Responsable |
|---|---|---|---|
| 1 et 2 | Mandater le comité et nommer ses membres; associer le responsable de la protection des renseignements personnels (art. 3.1 de la Loi sur le privé, modifiée par la Loi 25)[56]; lancer l'inventaire des agents internes, des logiciels-services à agents intégrés, des serveurs MCP, des assistants dotés d'outils et des agents de partenaires, y compris les agents fantômes repérés dans les journaux réseau, les consentements OAuth et les consoles des logiciels-services. | Mandat du comité; inventaire brut | Architecture d'entreprise, sécurité |
| 3 et 4 | Ouvrir une fiche par agent (champs de l'étape Proposition, annexe B); nommer un propriétaire métier pour chacun; recenser les clés d'API et les comptes de service utilisés par des agents. Pour une institution financière fédérale, marquer à la fiche les agents et les modèles qui relèvent de l'inventaire E-23. | Registre initial; liste des agents sans propriétaire; inventaire des secrets | Propriétaires métier, équipe plateforme |
| 5 et 6 | Mettre en service la passerelle de modèles et y basculer tous les appels aux fournisseurs; remplacer chaque clé partagée par un secret propre à l'agent, conservé au coffre et injecté à l'exécution, en attendant les identités de charge de travail de la phase Plateforme; ce secret transitoire s'inscrit comme dérogation bornée dans le temps (EXIG-IAM-05, section 11.6). La fuite de secrets, les secrets de longue durée et la réutilisation d'une même identité figurent au Top 10 OWASP des identités non humaines[91]. | Aucun appel direct à un fournisseur de modèles; aucune clé partagée entre agents | Équipe plateforme, sécurité |
| 7 et 8 | Instrumenter deux ou trois agents représentatifs avec OpenTelemetry (version épinglée des conventions GenAI, section 10.1), centre de coûts compris; publier le catalogue initial des protocoles (section 6.3) et y inscrire les premiers outils avec leur palier P0 à P3; inscrire chaque serveur et client MCP antérieur à la révision de référence avec sa date de migration, au plus tard le 28 juillet 2027 (EXIG-MCP-22). | Traces de bout en bout, du canal au modèle; catalogue initial publié; plan de migration MCP | Équipe plateforme, architecture d'entreprise |
| 9 et 10 | Classer chaque agent inventorié (faible, modéré, élevé) et fixer son plafond d'autonomie; repérer les agents qui traitent des RP ou les communiquent hors du Québec et lancer leurs EFVP, exigées par les articles 3.3 et 17 de la Loi sur le privé[413]; repérer les agents qui relèvent de l'annexe III du RIA; ramener sous le plafond de phase les agents qui le dépassent. | Classe et plafond inscrits pour tous les agents; EFVP planifiées ou en cours; liste des agents visés par l'annexe III | Risques et conformité, responsable de la protection des RP, propriétaires |
| 11 | Choisir les blocs de solution de la phase Plateforme (passerelle d'agents, moteur d'exécution durable, registre) avec la grille de la section 13.4; documenter le coupe-circuit, externe à l'agent[353], puis l'exercer sur un agent réel en mesurant le délai de révocation. | Décision de plateforme; rapport d'exercice du coupe-circuit | Architecture d'entreprise, équipe plateforme, sécurité |

| Semaines | Travaux | Livrable vérifiable | Responsable |
|---|---|---|---|
| 12 et 13 | Mesurer la valeur de référence des indicateurs (tableau 61); tenir la revue du jalon 1; arrêter le plan de la phase Plateforme et choisir les pilotes, en plaçant en tête la migration MCP et, s'il y a lieu, la validation initiale E-23; recaler le tableau 59 sur la date réelle du jalon 1. | Procès-verbal du jalon 1; tableau de bord de référence; calendrier recalé | Comité, architecture d'entreprise |

**À RETENIR**

Bloquer les agents sans offrir d'autre voie pousse les employés vers l'IA fantôme *(shadow AI)*, constate Gartner (avril 2026)[2]. Dès la sixième semaine, la passerelle de modèles et une inscription rapide au registre offrent une voie approuvée plus simple que le contournement.

## 15.3 Indicateurs

Les indicateurs servent à constater les jalons et à piloter l'autonomie sur des mesures. Ils obéissent à cinq règles du cadre :

- chaque indicateur doit être calculé à partir du registre, des passerelles, des traces et du journal d'audit ou, pour les exercices et les incidents, d'enregistrements horodatés, et non déclaré par les équipes;
- la valeur de référence est mesurée au jalon 1; les indicateurs sont ensuite présentés chaque trimestre au comité, par agent, par domaine et pour l'entreprise;
- les cibles du tableau 61 sont des choix du cadre; le comité peut les ajuster par écrit, avec justification, sauf celles qui reprennent une exigence (registre, secrets, passerelles, traçabilité, EFVP), qui ne s'écartent que par dérogation (section 11.6);
- à la revue du jalon 3, le comité remplace par une valeur chiffrée chaque cible exprimée comme une tendance (« en baisse », « en hausse »), à partir des séries trimestrielles disponibles; ces valeurs sont les cibles que le jalon 4 vérifie;
- chaque indicateur a un responsable de mesure nommé parmi les rôles de la section 11.1.

**Tableau 61 — Indicateurs de mise en œuvre et cibles proposées**

| Indicateur | Définition | Cible proposée | Fréquence |
|---|---|---|---|
| Couverture du registre | Part des agents actifs, déclarés ou découverts, qui ont une fiche à jour au registre | 100 % | Mensuelle |
| Agents sans secret partagé | Part des agents qui s'authentifient avec un justificatif qui leur est propre, sans clé partagée ni compte d'une personne | 100 % au jalon 1 | Mensuelle |
| Couverture des passerelles | Part des appels de modèles, et des appels interdomaines d'outils et d'agents, qui passent par la passerelle de modèles ou d'agents | Modèles : 100 % au jalon 1; interdomaines : 100 % au jalon 3, et 100 % dès le jalon 2 pour les agents N3 | Mensuelle |
| Conformité au catalogue | Part des intégrations d'agents qui utilisent un protocole et une version inscrits au catalogue | 100 % des nouveaux agents; serveurs et clients MCP en production : 100 % sur la révision de référence au 28 juillet 2027; 100 % des agents existants au jalon 3 | Trimestrielle |
| Traçabilité | Part des actions à effet (P2 et P3) rattachées à une trace complète, à leur mandant et à une entrée du journal d'audit | 100 % | Mensuelle |

| Indicateur | Définition | Cible proposée | Fréquence |
|---|---|---|---|
| Couverture de l'évaluation | Part des agents en production dont le jeu de référence s'exécute dans la chaîne CI/CD et atteint ses seuils (section 10.4) | 100 % | Trimestrielle |
| Réussite des tâches | Tâches réussies sans intervention humaine imprévue, sur le total des tâches, par agent | Seuil fixé au contrat d'agent | Mensuelle |
| Escalade humaine | Part des tâches renvoyées à une personne | Fourchette fixée au contrat d'agent; tout écart s'analyse | Mensuelle |
| Approbation sans modification | Par approbateur et par file : part des demandes approuvées telles quelles, avec le temps de réponse médian | Seuil d'alerte fixé par cas d'usage; tout écart marqué par rapport à la norme s'analyse | Mensuelle |
| Incidents agentiques | Nombre d'incidents par gravité, avec les délais de détection et de confinement | Aucun incident grave; délais en baisse, puis valeur chiffrée au jalon 3 | Trimestrielle |
| Délai de révocation en exercice | Temps écoulé entre la décision d'arrêter un agent et le refus de son dernier appel, dans tous les systèmes, mesuré lors d'un exercice du coupe-circuit | 15 minutes au plus, puis en baisse; valeur chiffrée au jalon 3 | Trimestrielle |
| Délai d'intégration | Temps nécessaire pour brancher à un agent un outil déjà inscrit au catalogue | En baisse d'un trimestre à l'autre, puis valeur chiffrée au jalon 3 | Trimestrielle |
| Réutilisation | Nombre moyen d'agents consommateurs par outil du catalogue | En hausse, puis valeur chiffrée au jalon 3 | Trimestrielle |
| Coût par tâche réussie | Coût total imputé (inférence, outils, quote-part de la plateforme) divisé par le nombre de tâches réussies, en dollars canadiens | Inférieur au coût du processus de référence sans agent; écart chiffré au jalon 3 | Mensuelle |
| EFVP à jour | Part des agents traitant des RP dont l'EFVP couvre la version en production | 100 % | Trimestrielle |

La cible proposée de 15 minutes pour la révocation est un choix du cadre, que l'entreprise ajuste en fixant son propre délai maximal (EXIG-IAM-20) : elle correspond à la durée de vie cible des jetons délégués (section 9.3), qui borne l'exposition résiduelle si un système en aval accepte encore un jeton déjà émis. Elle concrétise la sous-catégorie MANAGE 2.4 du NIST AI RMF, qui demande des mécanismes pour désengager ou désactiver un système dont le comportement s'écarte de l'usage prévu[74]. Le coût par tâche réussie est d'abord présenté en refacturation indicative *(showback)*, modèle que recommande la FinOps Foundation[407]; le passage à la refacturation réelle relève du comité (EXIG-FIN-09).

**ATTENTION**

Un indicateur ne se lit jamais seul. Un taux d'escalade très bas peut signifier qu'un agent tranche des cas qu'il devrait renvoyer. Un taux élevé d'approbation sans modification, joint à des temps de réponse très courts, peut signaler une approbation machinale : l'Infocomm Media Development Authority (IMDA) de Singapour recommande de surveiller ces deux signaux[76]. Une cible déclenche une analyse; elle ne sert pas à récompenser une équipe.

## 15.4 Facteurs de succès et risques de mise en œuvre

Les données publiques invitent à la prudence : selon Gartner (juin 2025), plus de 40 % des projets d'IA agentique seront annulés d'ici la fin de 2027 en raison de coûts croissants, d'une valeur d'affaires incertaine ou de contrôles des risques inadéquats[3]. Les facteurs suivants visent directement ces trois causes.

### Facteurs de succès

1. **Un parrainage de direction et un comité qui décide.** Un comité seulement consultatif ne peut ni constater les jalons ni accorder les dérogations.
2. **La plateforme avant la multiplication des agents.** Gartner (avril 2026) estime qu'une entreprise moyenne du Fortune 500 aura plus de 150 000 agents en usage d'ici 2028, contre moins de 15 en 2025[2]. Cet ordre de grandeur prospectif[467] laisse prévoir qu'un contrôle agent par agent ne tiendra pas : passerelles, catalogue et gabarits doivent précéder la croissance.
3. **Une gouvernance proportionnée.** Selon Gartner (mai 2026), appliquer la même gouvernance à tous les agents mènera à des échecs, et 40 % des entreprises rétrograderont ou désactiveront des agents autonomes d'ici 2027 à cause de lacunes révélées seulement après des incidents en production[95]. Le cadre gradue donc les contrôles selon le niveau d'autonomie et le palier d'outil (section 8.4).
4. **Commencer simple.** Anthropic recommande la solution la plus simple possible[6]; une architecture multiagent consomme habituellement de 3 à 10 fois plus de jetons qu'un agent unique[275]. Les premiers pilotes retiennent un flux déterministe ou un agent unique outillé.
5. **Mesurer la valeur dès le pilote.** Chaque pilote compare son coût par tâche réussie à celui du processus de référence; un pilote qui ne fait pas mieux s'arrête ou se redéfinit.
6. **Concevoir la supervision au lieu de la présumer.** Le biais d'automatisation touche les novices comme les experts et ne se prévient pas par la seule formation[314]. Les files d'approbation, les seuils et les indicateurs de la section 8.7 font partie des livrables de la phase Plateforme.

### Risques et parades

**Tableau 62 — Risques de mise en œuvre, signes avant-coureurs et parades**

| Risque | Signe avant-coureur | Parade prévue par le cadre |
|---|---|---|
| Abandon faute de valeur démontrée | Pilotes sans processus de référence ni coût par tâche | Indicateur de valeur obligatoire à la fiche; arrêt des pilotes non concluants |
| Plateforme centrale devenue goulot | Délai d'intégration en hausse; contournements | Modèle en étoile et libre-service par gabarits (section 11.3) |
| Prolifération et IA fantôme | Agents découverts hors registre; consentements OAuth inconnus | Inventaire continu; voie approuvée simple; désactivation des agents sans fiche |
| Gouvernance uniforme | Mêmes contrôles pour un agent N1 et un agent N3; files d'approbation saturées | Contrôles gradués par niveau et par palier (section 8.4) |
| Approbation machinale | Taux élevé d'approbation sans modification; temps de réponse très courts | Files priorisées par risque, regroupement, rotation des approbateurs (section 8.7) |
| Instabilité des standards | Nouvelle révision de MCP; conventions GenAI d'OpenTelemetry encore au niveau Development | Versions épinglées au catalogue; révision trimestrielle (section 11.7) |

| Risque | Signe avant-coureur | Parade prévue par le cadre |
|---|---|---|
| Migration MCP manquée | Serveurs ou clients MCP antérieurs encore en production à trois mois de l'échéance du 28 juillet 2027; serveurs sans date de migration au catalogue | Plan de migration dès la phase Fondations; migration en tête de la phase Plateforme; critère du jalon 2 (EXIG-MCP-22) |
| Phase Plateforme allongée | Livrables de la phase en retard sur le calendrier recalé; jalon 2 qui glisse au-delà d'octobre 2027 | Travaux datés par leur échéance externe (règles de progression); travaux réglementaires en tête de phase; réordonnancement par le comité |
| Verrouillage par une plateforme | Extensions propriétaires; données ou mémoires non exportables | Clauses contractuelles du chapitre 13 |
| Dérive des coûts | Coût par tâche en hausse; boucles qui atteignent leurs plafonds | Enveloppes budgétaires et routage frugal (section 10.6) |
| Échéance réglementaire manquée | Agent à haut risque dont la mise en service est prévue à compter du 2 décembre 2027; EFVP non commencée; inventaire E-23 sans état de validation à l'approche du 1er mai 2027 | Jalon J2a; validation initiale E-23 en phase Plateforme; priorité dans chaque phase; évaluation d'impact unifiée (section 12.9) |

ANNEXES

# Outils d’application

Grille d’homologation, gabarit de fiche d’agent, exemples de contrats, registre des exigences, glossaire, validation des sources et des ébauches, références.


A · Grille d’homologation

B · Gabarit de fiche d’agent

C · Exemples de contrats

D · Registre des exigences

E · Glossaire

F · Validation des sources et des ébauches

G · Références

# A Grille d’homologation

Cette grille se remplit pour chaque agent et chaque serveur MCP avant le point de contrôle « homologation » du cycle de vie, puis à chaque réévaluation. Elle reprend, sous forme vérifiable, les exigences qui conditionnent la mise en production; chaque point renvoie aux exigences qui le fondent. Une même grille sert à l’équipe du domaine, à la plateforme, à la sécurité et au comité.

## A.1 Mode d’emploi

1. **Qui remplit.** Le responsable technique de l’agent remplit la grille et joint les preuves; l’équipe plateforme et la sécurité vérifient; l’autorité désignée par la matrice RACI approuve (section 11.2). Pour un agent de classe élevée ou de niveau N4, le comité approuve.
2. **Réponses admises.** « Conforme » avec preuve (lien vers l’artefact au registre), « Sans objet » avec justification, ou « Non conforme ». Un point non conforme exige une dérogation écrite, bornée dans le temps et assortie de mesures compensatoires (section 11.6). Un écart à une exigence formulée avec DEVRAIT (par exemple EXIG-IAM-15 et -19) se justifie par écrit à la fiche, sans dérogation (section 1.4).
3. **Points non dérogeables.** Les points marqués non dérogeable ne peuvent faire l’objet d’aucune dérogation : un « Non conforme » bloque la mise en production (EXIG-GOV-17).
4. **Conservation.** La grille remplie, ses preuves et la décision d’homologation sont versées à la fiche de l’agent au registre (annexe B) et conservées avec son historique.

Légende de l’applicabilité : Tous s’applique à tout agent; Si … s’applique seulement dans le cas indiqué.

## A.2 Gouvernance, registre et classement

- [ ] Tous non dérogeable **Fiche complète au registre** : identifiant, version, parrain (propriétaire métier) et responsable technique nommés, équipe de garde, finalité, mandants autorisés. — EXIG-GOV-01, -07, -08
- [ ] Tous **Séparation des fonctions** respectée : la personne qui prépare une décision du cycle de vie (construction, évaluation) n’est pas celle qui l’approuve. — EXIG-GOV-03, -04
- [ ] Tous **Classe de risque** attribuée et approuvée avant l’inscription, avec les critères retenus (rayon d’impact, réversibilité, délai de détection, observabilité). — EXIG-CON-01, EXIG-AUT-06
- [ ] Tous non dérogeable **Niveau d’autonomie** déclaré (N0 à N4), dans le plafond de la classe de risque; aucun comportement NX. — EXIG-AUT-01, -02, -03, EXIG-CON-02
- [ ] Si N3 ou N4 **Domaine d’exploitation (ODD)** documenté, comportement de repli et conditions d’arrêt déclarés; homologation du niveau (l’évaluation assistée de Feng et al. est recommandée, non exigée). — EXIG-AUT-04, -05
- [ ] Tous **Patron d’orchestration** déclaré et justifié; configuration la plus simple démontrée suffisante, ou preuve mesurée du gain multiagent. — EXIG-ORC-01, -02, -03
- [ ] Tous **Déclencheurs de réévaluation** inscrits à la fiche (changement de modèle, d’invite système, d’outil ou de palier d’outil, de version majeure de contrat ou de protocole, de population visée, de finalité ou de catégorie de données; incident grave ou dérive détectée). — EXIG-GOV-12, EXIG-CON-03

## A.3 Interopérabilité et contrats

- [ ] Tous **Revue d'interopérabilité aux quatre niveaux** (juridique, organisationnel, sémantique, technique) consignée; vocabulaire et schémas d'entreprise utilisés. EXIG-INT-01, -02, -03
- [ ] Tous **Protocoles du catalogue** seulement, à la version de référence; choix justifié par la matrice de sélection. EXIG-INT-04, -06, -07, -10
- [ ] Si outils MCP **Serveurs MCP derrière la passerelle**, autorisation obligatoire, portées minimales, aucun passage de jeton, transport conforme à l'environnement. EXIG-MCP-01, -08, -09, -10, -11
- [ ] Si outils MCP **Contrats d'outils** orientés tâche (pas de miroir CRUD), nommage et résultats conformes, annotations traitées comme de simples indices, empreinte des définitions épinglée. EXIG-MCP-06, -07, -14, -20
- [ ] Si outils MCP **Contrôles propres à MCP** : concordance en-têtes et corps, traitement de `_meta`, état explicite protégé, aucune donnée sensible en en-tête. EXIG-MCP-15 à -18
- [ ] Si invocable par A2A **Carte d'agent A2A 1.0** publiée, signée, inscrite au registre, sans champ hors norme; compétences internes réservées à la carte étendue. EXIG-A2A-02 à -06
- [ ] Si invocable par A2A **Tâches A2A** : version annoncée, liaisons standard, authentification à chaque requête, autorisation par compétence, notifications push durcies, trousse de compatibilité réussie. EXIG-A2A-07 à -14
- [ ] Si événements **Événements CloudEvents** complets, contrat AsyncAPI au catalogue, attributs de gouvernance vérifiés, compteur de sauts appliqué, aucune donnée personnelle dans les attributs, autorisation fondée sur l'identité authentifiée auprès du courtier. EXIG-EVT-02 à -07
- [ ] Si événements **Consommateurs idempotents**, ordre garanti par la clé de partition lorsque requis, conservation des entrées pour rejeu isolé. EXIG-EVT-08, -09, -10

## A.4 Orchestration et réversibilité

- [ ] Si écriture, plusieurs étapes ou attente **Exécution durable** : état persisté après chaque transition, reprise sans double effet, magasin de points de contrôle protégé. EXIG-ARC-05, -06, EXIG-ORC-11, -12, -13
- [ ] Si écritures **Clé d'idempotence** sur toute écriture, vérifiée par le service visé. EXIG-ORC-21, -22
- [ ] Si écritures multisystèmes **Saga** : compensation déclarée au catalogue pour chaque étape, journal de compensation tenu avant l'action, compensations idempotentes, escalade après deux échecs, isolation sémantique. EXIG-ORC-15 à -19
- [ ] Si saga **Quatre tests d'injection de fautes** réussis dans la chaîne d'intégration (échec à chaque étape, plantage entre journal et action, double compensation, double échec de compensation). EXIG-ORC-20
- [ ] Tous **Plafonds d'exécution** (étapes, appels d'outils, jetons, coût, délai), résilience et modèle de repli testés. EXIG-ORC-26, -27
- [ ] Si multiagent **Délégation** limitée à deux niveaux, contexte transmis minimal et structuré, retour validé avant réutilisation, filtrage de sécurité dans chaque agent. EXIG-ORC-04, -23, -24, -25

- [ ] Tous **Coupe-circuit** opérationnel pour l’agent et inclus dans l’exercice trimestriel; délai de révocation mesuré. EXIG-ORC-28, EXIG-IAM-20

## A.5 Autonomie et supervision humaine

- [ ] Tous **Paliers des outils** (P0 à P3) attribués au catalogue après revue, jamais déduits des annotations du serveur; contrôle calculé à chaque appel; échec en mode fermé. EXIG-AUT-08, -10, -11
- [ ] Tous non dérogeable **Aucune action P3 sans approbation humaine**, par jeton signé lié à l’action exacte; aucune approbation tirée de la conversation de l’agent. EXIG-AUT-09, -12, -13
- [ ] Si approbations **Approbateurs** habilités et formés; écran d’approbation fidèle à l’action; boîte de réception persistante; charge d’approbation maîtrisée et qualité de la supervision mesurée. EXIG-AUT-15, -16, -19, -20, -21
- [ ] Si agent ambiant **Réautorisation périodique** et effets placés après le point d’approbation. EXIG-AUT-17, -18
- [ ] Si décision sur une personne **Décisions automatisées** (art. 12.1 de la Loi sur le privé) : avis au plus tard au moment de la décision, explication des principaux facteurs, révision humaine significative, conservation des éléments de décision. EXIG-AUT-22, -23, EXIG-CON-07, -08, -09

## A.6 Identité, sécurité et confiance zéro

- [ ] Tous **Identité propre**, cryptographique, émise par la plateforme, non partagée; aucun secret statique; justificatifs hors de portée du modèle. EXIG-IAM-03 à -06
- [ ] Si agit pour une personne non dérogeable **Délégation explicite** par échange de jetons; aucune usurpation; portée jamais élargie; jeton à audience unique; aucun relais de jeton. EXIG-IAM-08 à -12
- [ ] Tous **Profil OAuth de l’entreprise** appliqué, jetons contraints à l’émetteur et de courte durée; agents autonomes avec identifiants du client et portées par outil. EXIG-IAM-13 à -16
- [ ] Tous **Passerelle d’agents** en coupure de tout appel interdomaine, passerelle de modèles pour tout appel de modèle (aucun appel direct à un fournisseur), échec en mode fermé, secrets aval injectés par la passerelle, politiques en code versionnées et testées. EXIG-ARC-01, -08, -11, -12, EXIG-IAM-17, -18, -19, -21
- [ ] Tous **Modèle de menaces** établi (analyse simplifiée pour la classe faible) et matrice de traçabilité menaces-contrôles (OWASP ASI) à jour. EXIG-SEC-01, -02
- [ ] Tous **Défense contre l’injection** : présomption d’injection, règle de deux par session, retrait déterministe des capacités d’exfiltration, patron de conception pour la classe élevée. EXIG-SEC-03 à -07
- [ ] Si code généré **Bac à sable** conforme (technologie d’isolation, éphémère, réseau refusé par défaut, métadonnées infonuagiques bloquées, secrets injectés hors du bac à sable, délais à trois niveaux, journal externe, porte de validation). EXIG-SEC-08 à -17
- [ ] Tous **Chaîne d’approvisionnement** : provenance approuvée, signatures vérifiées, nomenclature de version, chaque serveur traité comme un domaine distinct, tiers évalués. EXIG-SEC-18 à -22

- [ ] Si classe modérée ou élevée **Équipe rouge** propre aux agents et suite d'attaques intégrée à la chaîne d'intégration; contrôles déterministes vérifiés. EXIG-SEC-23, -24, -25

## A.7 Observabilité, évaluation et coûts

- [ ] Tous **Traçage de bout en bout** : contexte W3C propagé dans HTTP, MCP, A2A et les événements; conventions GenAI à la version épinglée; attributs d'entreprise sous préfixe de domaine inversé. EXIG-OBS-01 à -06
- [ ] Tous **Contenu des invites et réponses** non capturé par défaut; toute capture exceptionnelle filtrée, chiffrée et à conservation courte. EXIG-OBS-07 à -10
- [ ] Tous **Journal d'audit** distinct des traces, exhaustif pour chaque action à effet et chaque approbation; enregistrement à cinq éléments canonisé et signé; inaltérabilité vérifiée. EXIG-OBS-11, -12, -13
- [ ] Tous **Évaluation** : paliers franchis et relancés à chaque changement, jeu de référence versionné comprenant des cas adverses et réussi aux seuils du contrat, évaluations répétées et isolées, échantillonnage de la production planifié, objectifs de niveau de service fixés. EXIG-EVA-01 à -06
- [ ] Tous **Coûts** : enveloppe appliquée à chaque étape, quotas et plafond mensuel par agent, plus petit modèle suffisant, préfixe d'invite stable, imputation par centre de coûts, coût par tâche réussie comparé au processus sans agent, hypothèses de prix datées; lots asynchrones recommandés (EXIG-FIN-08) et table de conversion des unités SaaS si plateforme SaaS (EXIG-FIN-03). EXIG-FIN-01 à -10

## A.8 Données, vie privée et conformité

- [ ] Si renseignements personnels **EFVP** terminée avant le passage en pilote, responsable de la protection des renseignements personnels consulté dès le début du projet, finalités vérifiées avant toute réutilisation. EXIG-CON-04, -06
- [ ] Si traitement hors Québec **Lieux de traitement cartographiés** (modèles, outils, mémoires) avec EFVP et entente écrite pour toute communication hors Québec. EXIG-CON-05
- [ ] Tous **Mémoires et traces** : durées de vie fixées, contrôles avant toute écriture en mémoire longue, aucun historique brut comme mémoire, magasins isolés. EXIG-ARC-22 à -25, EXIG-CON-10
- [ ] Tous **Régimes applicables** inscrits à la fiche (Loi 25, LPRPDE, BSIF E-23, RIA); aucun usage interdit; obligations du déployeur respectées pour la classe élevée. EXIG-CON-11 à -16
- [ ] Tous **Transparence** : divulgation de l'interaction avec un agent et identification des contenus produits; vérification humaine de tout contenu juridique. EXIG-CON-19, -20, -22
- [ ] Tous **Incidents** : procédure en cinq temps connue de l'équipe de garde, registre des incidents de confidentialité, règle de notification la plus exigeante. EXIG-CON-23, -24, -25
- [ ] Si classe élevée **Évaluation d'impact unifiée** (EFVP, analyse d'impact algorithmique, analyse d'impact sur les droits fondamentaux au besoin). EXIG-CON-26
- [ ] Si acquis d'un fournisseur **Grille d'évaluation fournisseur** remplie et clauses contractuelles normatives intégrées au contrat. EXIG-APP-07 à -17

# B Gabarit de fiche d'agent

La fiche d'agent est l'entrée du registre d'entreprise décrite à la section 11.4. Ce gabarit fixe son contenu minimal et l'étape du cycle de vie où chaque champ devient exigible. Il est normatif par son contenu, pas par sa forme : tout outil de registre convient s'il conserve ces champs et leur historique.

## Règles d'utilisation

- **Ouverture et complétude.** La fiche s'ouvre à l'étape Proposition et se complète au fil du cycle de vie (section 11.5). Elle est complète lorsque tous les champs exigés à l'étape Pilote sont remplis, ce que vérifie le point de contrôle qui clôt l'étape Construction et évaluation; avant cela, l'agent n'obtient aucun jeton d'exécution en production.
- **Source de vérité.** Les valeurs qui commandent un contrôle (palier d'outil, seuil, plafond, portées, niveau d'autonomie) DOIVENT être lues par la passerelle dans le registre et le catalogue, jamais dans ce que l'agent déclare de lui-même ni dans les annotations d'un serveur MCP (section 8.3).
- **Réévaluation.** Tout changement de modèle ou de version de modèle, d'instructions système, d'outil ou de palier d'outil, de version majeure d'un contrat ou d'un protocole, de population visée, de finalité ou de catégorie de données, ainsi que tout incident grave ou toute dérive détectée, déclenche une réévaluation de la classe de risque et du niveau d'autonomie (EXIG-GOV-12). Le niveau d'autonomie fonctionne comme le « certificat d'autonomie » de Feng et al., qui se renouvelle à chaque changement de l'agent ou de son environnement[83]. S'il y a des RP, l'EFVP est mise à jour, comme le recommande le guide de la CAI lorsqu'un projet change[413].
- **Attestation.** Le propriétaire métier atteste périodiquement que l'agent est encore requis et que sa fiche est exacte. Le cadre exige l'attestation au moins tous les 12 mois, et tous les 6 mois pour la classe élevée (EXIG-GOV-13); à titre d'exemple, les bonnes pratiques de Microsoft Entra Agent ID prévoient que le parrain atteste tous les 6 à 12 mois que chaque agent est encore requis[92]. Un agent dont l'attestation est échue doit passer à l'état « suspendu » (EXIG-GOV-09).
- **Contenu exclu.** La fiche ne contient ni secret ni renseignement personnel de clients. Chaque serveur MCP a aussi une fiche au registre, qui reprend les blocs de ce gabarit qui le concernent (identification, propriétaires, données et RP, identité et portées, garde-fous, évaluation, observabilité, cycle de vie, dérogations); ses outils ont en plus leur propre entrée au catalogue (section 6.8, annexe C).

## Champs de la fiche

**Tableau 63 — Champs de la fiche d'agent et étape où ils deviennent exigibles**

| Bloc | Champ | Contenu attendu | Exigé dès |
|---|---|---|---|
| **Identification** | Identifiant, nom, version | Identifiant unique et immuable au registre; nom en langage clair; version sémantique (SemVer) | Proposition |
| | Type, plateforme et modèles | Agent interne, agent intégré à un logiciel-service ou agent de partenaire; plateforme d'exécution; environnements; modèles utilisés (principaux et de repli) avec leurs versions épinglées; version et empreinte de l'invite système (EXIG-GOV-07, EXIG-FIN-07) | Proposition (modèles et invite : Conception) |
| | Carte d'agent | URL et empreinte de la carte d'agent signée, si l'agent est invocable par d'autres agents (section 6.6) | Pilote, si applicable |

| Bloc | Champ | Contenu attendu | Exigé dès |
|---|---|---|---|
| **Propriétaires** | Propriétaire métier (parrain) | Personne nommée qui répond des effets de l'agent; son unité; son suppléant | Proposition |
| | Responsable technique et équipe de garde | Personne nommée; équipe joignable pendant les heures d'exploitation déclarées et sa file d'incidents | Conception |
| | Centre de coûts | Code imputé à chaque trace (section 10.6) | Conception |
| **Finalité** | Tâche et valeur attendue | Tâche confiée, en deux phrases; indicateur de valeur; processus de référence sans agent et son coût | Proposition |
| | Usages exclus | Ce que l'agent ne doit jamais faire, même à la demande d'un mandant | Conception |
| **Mandants et déclencheurs** | Invocation | Personnes, rôles ou agents autorisés à l'invoquer; canaux; déclencheurs automatiques (événements, planification) | Conception |
| **Orchestration** | Patron | Patron retenu (section 7.2) et justification de la configuration la plus simple (avec la comparaison mesurée face à un agent unique, EXIG-ORC-02, et les frontières de contexte ou de sécurité justifiant le découpage, EXIG-ORC-10); protocole retenu pour chaque intégration, justifié par la matrice de sélection (section 6.4); résultat de la revue d'interopérabilité aux quatre niveaux (section 6.1); agents appelés; profondeur d'imbrication | Conception |
| **Risque et autonomie** | Classe de risque | Faible, modérée ou élevée, avec l'analyse des critères de la section 8.2 et l'approbation obtenue | Conception |
| | Niveau d'autonomie | Plafond N0 à N4 approuvé, par qui (personne nommée) et à quelle date; domaine d'exploitation documenté pour N3 et N4; déclencheurs de renouvellement; échéance de réautorisation d'un agent ambiant de niveau N3 ou N4 | Conception |
| | Qualification réglementaire | Régimes applicables (Loi sur le privé ou Loi sur l'accès, LPRPDE, RIA, BSIF, directive fédérale), chacun avec les obligations retenues et l'exigence du cadre qui y répond; sorties utilisées ou non dans l'Union européenne; système à haut risque au sens du RIA ou non; décision fondée exclusivement sur un traitement automatisé (art. 12.1 de la Loi sur le privé) ou non; modèle visé par la ligne directrice E-23 du BSIF, s'il y a lieu | Conception |
| **Outils, agents et événements** | Inventaire des dépendances | Pour chaque outil, ressource, invite, agent appelé ou sujet d'événement : référence au catalogue, version épinglée et empreinte (EXIG-INT-15), palier P0 à P3 attribué au catalogue, seuil, effet déclaré, clé d'idempotence pour les outils à effet, contrat AsyncAPI pour les événements | Conception |
| **Données et RP** | Catégories et classification | Catégories de données, classification, présence de RP et de RP sensibles, finalité de chaque usage | Conception |
| | Localisation et mémoire | Lieu de traitement (province ou pays, et fournisseur) de chaque modèle, serveur MCP, agent délégataire et magasin de mémoire ou de traces; durées de conservation des mémoires, index vectoriels et traces (section 5.5) | Conception |
| **Identité et portées** | Identité | Identifiant de charge de travail (p. ex. SPIFFE ID) et type de justificatif (section 9.2) | Pilote |
| | Autorisations | Mode d'accès (délégation par échange de jetons ou identité propre de l'agent); portées et audiences; durée de vie des jetons | Pilote |

| Bloc | Champ | Contenu attendu | Exigé dès |
|---|---|---|---|
| **Garde-fous** | Contrôles actifs | Contrôles d'entrée (contenu non fiable), de sortie (prévention des fuites de données) et d'action (politiques de la passerelle); propriétés réunies parmi contenu non fiable, données sensibles et effet ou communication externe (règle de deux); bac à sable si l'agent exécute du code, avec sa liste d'autorisation réseau | Pilote |
| **Évaluation** | Jeu de référence et résultats | Taille du jeu, dont les scénarios adverses; seuils d'acceptation et seuil de réussite maximale de la suite d'attaques automatisées (EXIG-SEC-24); date, version et résultat de la dernière exécution et du dernier exercice d'équipe rouge (EXIG-SEC-23) | Pilote |
| **Budget et plafonds** | Enveloppe | Plafonds par tâche (jetons, coût, appels d'outils, itérations, durée d'exécution active et durée totale); quota de jetons par minute et plafond mensuel, avec le comportement à l'atteinte du plafond (suspension ou modèle de repli); modèles autorisés et modèle de repli | Pilote |
| **Compensation et escalade** | Reprise | Compensation de chaque étape à effet; étape pivot; file humaine d'escalade; rôles approbateurs et règles d'approbation; mode dégradé | Pilote |
| **Observabilité** | Traçage et audit | Nom de service; version épinglée et version réellement émise des conventions OpenTelemetry GenAI (réglage de `OTEL_SEMCONV_STABILITY_OPT_IN`); capture du contenu (désactivée par défaut); emplacement du journal d'audit; fenêtre de conservation des événements d'entrée (EXIG-EVT-10); objectifs de niveau de service | Pilote |
| **Conformité** | Évaluations d'impact | Référence et date de l'EFVP, y compris celle exigée par l'article 17 en cas de communication hors du Québec; consultation du responsable de la protection des RP; évaluation d'impact unifiée et analyse d'impact sur les droits fondamentaux (RIA, art. 27) lorsqu'elle est exigée (section 12.9) | Pilote, si applicable |
| | Transparence | Mode d'information des personnes; procédure de révision humaine pour les décisions visées par l'article 12.1 | Pilote, si applicable |
| **Cycle de vie** | État et revues | État (proposé, conception, construction, pilote, production, suspendu, retiré); dates de mise en production, de dernière attestation et de prochaine revue; historique des versions | Proposition |
| **Dérogations** | Dérogations en vigueur | Identifiant, exigence visée, mesures compensatoires, échéance et approbateur (section 11.6) | Dès qu'une dérogation existe |

## Exemple de fiche lisible par machine

L'exemple suivant décrit un agent fictif de classe modérée, plafonné à N3. Les noms de champs sont un choix du cadre; seules comptent leur présence et leur cohérence avec le gabarit.

**Fiche d’agent au registre (JSON, extrait)**

```
{
  "agent_id": "agt-fin-rapprochement",
  "name": "Agent de rapprochement des factures fournisseurs",
  "version": "2.3.0",
  "lifecycle_state": "production",
  "owners": {
    "business_sponsor": "Directrice, comptes fournisseurs",
    "technical_lead": "Responsable technique, plateforme Finances",
    "on_call_team": "garde-finances",
    "cost_center": "CC-4120"
  },
  "purpose": "Apparier factures, bons de commande et réceptions; préparer les paiements.",
  "excluded_uses": ["modifier les coordonnées bancaires d'un fournisseur"],
  "principals": ["role:analyste-comptes-fournisseurs", "agent:agt-fin-orchestrateur"],
  "orchestration_pattern": "agent-unique-outille",
  "risk_class": "modere",
  "autonomy": {
    "ceiling": "N3",
    "approved_by": "Directrice, comptes fournisseurs",
    "approved_on": "2027-03-15",
    "odd_ref": "ODD-FIN-007",
    "renew_on": ["model_change", "new_write_tool", "target_population_change"]
  },
  "regulatory": {"eu_ai_act_high_risk": false, "automated_decision_art_12_1": false},
  "tools": [
    {"ref": "erp.factures.lire@1.4.0", "digest": "sha256:9f2c41d0", "tier": "P1"},
    {"ref": "erp.factures.apparier@2.0.1", "digest": "sha256:51ab07e3", "tier": "P2",
     "threshold_cad": 5000, "compensation": "erp.factures.desapparier", "idempotency_key": true},
    {"ref": "tresorerie.paiements.emettre@1.1.0", "digest": "sha256:c07d9b12", "tier": "P3",
     "approval": "signed_out_of_band"}
  ],
  "data": {"classification": "confidentiel", "personal_information": true,
           "processing_locations": ["Québec"]},
  "identity": {"workload_id": "spiffe://entreprise.example/agents/agt-fin-rapprochement",
               "access_mode": "token_exchange_rfc8693", "token_ttl_s": 900},
  "budget_per_task": {"max_tokens": 50000, "max_cost_cad": 0.75,
                      "max_tool_calls": 15, "timeout_s": 60, "max_wall_clock_s": 28800,
                      "max_iterations": 8},
  "evaluation": {"reference_set": 120, "adversarial_cases": 25,
                 "last_run": "2027-03-10", "result": "pass"},
  "observability": {"service_name": "agt-fin-rapprochement",
                    "genai_semconv": "1.41.0", "content_capture": false},
  "compliance": {"efvp_ref": "EFVP-2027-014", "efvp_date": "2027-02-28"},
  "next_review": "2027-09-15",
  "exceptions": []
}
```

Lecture : l’agent apparie seul les factures sous 5 000 $, au-delà de quoi la passerelle exige une approbation; l’émission d’un paiement, de palier P3, exige toujours une approbation signée hors bande. Les valeurs de l’enveloppe budgétaire sont illustratives et se calibrent par mesure (section 10.6).

# C Exemples de contrats

Cette annexe donne huit exemples complets de contrats et d'objets d'échange, conformes, lorsqu'elles existent, aux spécifications en vigueur au 27 octobre 2026 et, dans tous les cas, aux exigences du cadre. Ils sont normatifs par leur forme, pas par leurs valeurs : un contrat réel reprend leur structure et leurs champs, avec ses propres noms, schémas et seuils. Chaque exemple est suivi d'une lecture qui le rattache aux exigences qu'il met en œuvre.

## Conventions des exemples

- **Valeurs fictives.** Les noms, domaines (`ent.ca`), identifiants et montants sont fictifs.
- **Formats normalisés et formats internes.** Les exemples C.1, C.3, C.4 et C.5 n'emploient que des champs définis par leur spécification ou par les mécanismes d'extension qu'elle prévoit. Les exemples C.2, C.6, C.7 et C.8 sont des formats internes : comme à l'annexe B, les noms de champs sont un choix du cadre, et seules comptent leur présence et leur cohérence.
- **Empreintes vérifiables.** Les empreintes `definition_digest`, `idempotency_key`, h (reprise dans `action_sha256` et `empreinte_approbation`) et `arguments_sha256` sont de véritables condensés SHA-256, calculés sur les valeurs montrées (forme canonique RFC 8785 pour les objets JSON) : on peut les recalculer. Les valeurs qui dépendent d'objets non montrés ou abrégés (empreinte de certificat, enregistrement précédent, empreinte de l'invite système, `empreinte` de l'enregistrement C.8) sont fictives, et les signatures, qu'on ne peut pas reproduire sans la clé privée, sont abrégées par « … ».
- **Scénario commun.** Les exemples C.1, C.2, C.6, C.7 et C.8 suivent une même tâche : l'agent `agt-achats-indirects`, de classe de risque modérée et plafonné à N3, crée un bon de commande de 12 480 $, soit au-delà du seuil d'approbation de 5 000 $ fixé au catalogue pour cet outil.

**Tableau 64 — Exemples de contrats, références et exigences illustrées**

| Exemple | Référence | Exigences et sections illustrées |
|---|---|---|
| C.1 Outil MCP | MCP 2026-07-28; JSON Schema 2020-12 | EXIG-MCP-07, EXIG-MCP-14, EXIG-MCP-18; EXIG-ORC-21 |
| C.2 Entrée de catalogue | Format interne du cadre | EXIG-AUT-08, EXIG-MCP-14, EXIG-MCP-20, EXIG-ORC-22; section 6.8 |
| C.3 Carte d'agent | A2A 1.0 (`a2a.proto`); JWS (RFC 7515); RFC 8785 | EXIG-A2A-02 à EXIG-A2A-06, EXIG-A2A-10 |
| C.4 Événement | CloudEvents 1.0 (1.0.2) et extensions documentées; W3C Trace Context | EXIG-EVT-02, EXIG-EVT-04 à EXIG-EVT-06, EXIG-EVT-09 |
| C.5 Jeton délégué | RFC 9068, RFC 8693, RFC 8705 | EXIG-IAM-08, EXIG-IAM-10, EXIG-IAM-11, EXIG-IAM-14, EXIG-IAM-15 |
| C.6 Jeton d'approbation humaine | Format interne; RFC 8785, RFC 9396, CIBA | EXIG-AUT-12 à EXIG-AUT-14 |
| C.7 Enveloppe budgétaire | Format interne du cadre | EXIG-ORC-26, EXIG-FIN-04; section 10.6 |
| C.8 Enregistrement d'audit | Format interne; RFC 8785 | EXIG-OBS-11, EXIG-OBS-12, EXIG-AUT-10, EXIG-IAM-11, EXIG-IAM-21; section 10.3 |

## C.1 Outil MCP

L'exemple montre la définition d'un outil d'écriture orienté tâche, telle qu'un serveur MCP la renvoie dans `tools/list` (section 6.5).

**Définition de l'outil approvisionnement_creer_bon_commande (MCP 2026-07-28)**

```
{
  "name": "approvisionnement_creer_bon_commande",
  "title": "Créer un bon de commande (ERP)",
  "description": "Crée dans l'ERP un bon de commande, à l'état brouillon ou soumis, pour un fournisseur
homologué et un centre de coûts valide. Une relance avec la même clé d'idempotence ne crée pas de second bon.
Ne modifie ni n'annule un bon existant.",
  "inputSchema": {
    "type": "object",
    "properties": {
      "idempotency_key": { "type": "string", "pattern": "^[0-9a-f]{64}$" },
      "fournisseur_id": { "type": "string", "pattern": "^SUP-[0-9]{6}$" },
      "centre_cout": { "type": "string", "pattern": "^CC-[0-9]{4}$", "x-mcp-header": "Cost-Center" },
      "statut_demande": { "type": "string", "enum": ["brouillon", "soumis"], "default": "brouillon" },
      "montant_total_cad": { "type": "number", "exclusiveMinimum": 0 },
      "lignes": {
        "type": "array",
        "minItems": 1,
        "maxItems": 100,
        "items": {
          "type": "object",
          "properties": {
            "sku": { "type": "string", "pattern": "^PRD-[0-9]{5}$" },
            "quantite": { "type": "integer", "minimum": 1 },
            "prix_unitaire_cad": { "type": "number", "minimum": 0 }
          },
          "required": ["sku", "quantite", "prix_unitaire_cad"],
          "additionalProperties": false
        }
      }
    },
    "required": ["idempotency_key", "fournisseur_id", "centre_cout", "montant_total_cad", "lignes"],
    "additionalProperties": false
  },
  "outputSchema": {
    "type": "object",
    "properties": {
      "bon_commande_id": { "type": "string", "pattern": "^BC-[0-9]{4}-[0-9]{6}$" },
      "statut": { "type": "string", "enum": ["brouillon", "soumis"] },
      "montant_total_cad": { "type": "number" },
      "rejeu": { "type": "boolean", "description": "Vrai si la clé était déjà traitée." }
    },
    "required": ["bon_commande_id", "statut", "montant_total_cad", "rejeu"],
    "additionalProperties": false
  },
  "annotations": {
    "readOnlyHint": false,
    "destructiveHint": false,
    "idempotentHint": true,
    "openWorldHint": false
  }
}
```

Lecture : la définition n'emploie que des champs du schéma MCP 2026-07-28; ses schémas suivent JSON Schema 2020-12, dialecte par défaut de la spécification, et `additionalProperties: false` ferme le contrat[162, 197]. Le motif du champ `idempotency_key` correspond à la dérivation de la section 7.6, et seul `centre_cout` porte `x-mcp-header` : le client recopie sa valeur dans l'en-tête `Mcp-Param-Cost-Center`, ce qui convient à une donnée non sensible (EXIG-MCP-18). Les annotations, conformes au schéma, ne décident de rien : elles doivent seulement concorder avec le palier inscrit au catalogue (EXIG-MCP-14). L'outil renvoie un `structuredContent` conforme à `outputSchema`, accompagné du même JSON dans un bloc texte, et signale une erreur métier par un résultat marqué `isError: true` (EXIG-MCP-07).

## C.2 Entrée de catalogue de l'outil

L'exemple montre où vit la gouvernance de l'outil C.1 : dans le catalogue d'entreprise, et non dans le serveur (section 6.8).

**Entrée du catalogue d'entreprise pour l'outil C.1 (format interne)**

```
{
  "ref": "mcp-approvisionnement/approvisionnement_creer_bon_commande@1.4.0",
  "tool_name": "approvisionnement_creer_bon_commande",
  "contract_version": "1.4.0",
  "definition_digest": "sha256:3182dbf3bec38e95fffa2b16ae58217e0cc09251bfbe026b5939c25729f99e1e",
  "server": {
    "id": "mcp-approvisionnement",
    "endpoint": "https://passerelle-agents.ent.ca/mcp/approvisionnement",
    "mcp_revision": "2026-07-28",
    "extensions_allowed": []
  },
  "lifecycle_state": "active",
  "tier": "P2",
  "approval_threshold": { "argument": "montant_total_cad", "max_without_approval_cad": 5000 },
  "compensation": "mcp-approvisionnement/approvisionnement_annuler_bon_commande@1.2.0",
  "idempotency": { "argument": "idempotency_key", "checked_by_server": true, "on_conflict": "reject" },
  "oauth_scope": "approvisionnement.bons-commande.creer",
  "header_projection": { "centre_cout": "Mcp-Param-Cost-Center" },
  "data_classification_max": "confidentiel",
  "personal_information": false,
  "owner": "Direction Approvisionnement",
  "on_call_team": "garde-plateforme-erp",
  "known_consumers": ["agt-achats-indirects"],
  "reviewed_by": ["proprietaire-outil", "securite"],
  "approved_on": "2026-10-06",
  "next_review": "2027-04-06"
}
```

Lecture : cette entrée porte le palier, le seuil, la compensation, la portée, le propriétaire et l'équipe de garde de l'outil, attribués après revue par son propriétaire et par la sécurité; la passerelle les lit ici, jamais dans les annotations (EXIG-AUT-08, EXIG-MCP-14). `definition_digest` est le SHA-256 de la définition C.1 canonisée selon la RFC 8785 : à chaque `tools/list`, la passerelle recalcule l'empreinte et retire l'outil au moindre écart, description comprise, jusqu'à une nouvelle approbation (EXIG-MCP-20)[221, 236]. Avec ce palier P2 et ce seuil, un agent de classe modérée déclaré N3 peut créer seul un bon de 5 000 $ ou moins; au-delà, la règle de la section 8.4 impose le jeton d'approbation de l'exemple C.6. L'idempotence déclarée ici, vérifiée par le serveur, fait office de garantie, alors que l'annotation `idempotentHint` n'en est qu'un indice (EXIG-ORC-22).

## C.3 Carte d'agent A2A

L'exemple montre la carte publiée au registre par l'agent spécialiste du scénario de délégation de la section 6.6.

**Carte d’agent A2A 1.0 signée de l’agent d’évaluation du risque de crédit**


```
{
  "name": "Agent d'évaluation du risque de crédit",
  "description": "Analyse un dossier de crédit commercial selon la politique CR-12 et recommande une décision
motivée. N'accorde ni ne refuse aucun crédit.",
  "supportedInterfaces": [
    {
      "url": "https://passerelle-agents.ent.ca/a2a/risque-credit",
      "protocolBinding": "JSONRPC",
      "protocolVersion": "1.0"
    }
  ],
  "provider": {
    "organization": "Direction Gestion des risques",
    "url": "https://intranet.ent.ca/risque-credit"
  },
  "version": "2.3.0",
  "capabilities": {
    "streaming": true,
    "pushNotifications": true,
    "extendedAgentCard": true,
    "extensions": [
      {
        "uri": "https://ent.ca/a2a/extensions/gouvernance/v1",
        "description": "Copie en lecture seule de données du registre : niveau d'autonomie et classe de
risque.",
        "required": false,
        "params": { "niveau_autonomie": "N2", "classe_risque": "elevee" }
      }
    ]
  },
  "securitySchemes": {
    "idp-entreprise": {
      "openIdConnectSecurityScheme": { "openIdConnectUrl": "https://idp.ent.ca/.well-known/openid-
configuration" }
    }
  },
  "securityRequirements": [{ "schemes": { "idp-entreprise": { "list": ["agents.risque-credit"] } } }],
  "defaultInputModes": ["text/plain", "application/json"],
  "defaultOutputModes": ["application/json", "text/markdown"],
  "skills": [
    {
      "id": "analyse-dossier-commercial",
      "name": "Analyse prudentielle d'un dossier de crédit commercial",
      "description": "Évalue la solvabilité d'une entreprise cliente, vérifie les garanties et produit une
recommandation motivée avec les ratios calculés.",
      "tags": ["credit", "risque", "conformite"],
      "examples": ["Analyser le dossier 8841 selon la politique CR-12"],
      "securityRequirements": [{ "schemes": { "idp-entreprise": { "list": ["risque-credit.analyser"] } } }]
    }
  ],
  "signatures": [
    {
      "protected":
"eyJhbGciOiJFUzI1NiIsInR5cCI6IkpPU0UiLCJraWQiOiJjYXJ0ZXMtYWdlbnRzLTIwMjYtMTAiLCJqa3UiOiJodHRwczovL2NsZXMuZW50
LmNhL2EyYS9qd2tzLmpzb24ifQ",
      "signature": "Wm3k…"
    }
  ]
}
```

Lecture : la carte contient les huit champs obligatoires d'A2A 1.0, ses adresses sont celles de la passerelle d'agents, et la compétence porte sa propre portée OAuth dans `securityRequirements` (EXIG-A2A-02, EXIG-A2A-10)[68, 192]. La signature est un JWS calculé sur la carte canonisée selon la RFC 8785, champ `signatures` exclu et règles de présence des champs de la spécification (section 8.4.1) appliquées; son en-tête protégé, encodé en base64url, désigne le type JOSE (`typ`), l'algorithme ES256, la clé (`kid`) et le jeu de clés publiques de l'entreprise (`jku`), et tout client vérifie cette signature avant de se fier à la carte (EXIG-A2A-03). Le niveau d'autonomie et la classe de risque ne forment pas un champ de premier niveau : ils sont déclarés comme extension de données facultative, dont l'URI versionnée figure au registre des extensions approuvées, et la fiche du registre fait foi en cas d'écart (EXIG-A2A-05)[238]. `extendedAgentCard` annonce une carte étendue, servie après authentification, qui ajoute les compétences réservées aux appelants internes (EXIG-A2A-06), et `version`, en SemVer, dont dérive l'`ETag` servi avec la carte, permet de revalider les copies en cache (EXIG-A2A-04).

## C.4 Événement CloudEvents

L'exemple montre la première alerte d'une chorégraphie, publiée par un agent détecteur sur le bus d'événements (section 6.7).

**Événement CloudEvents 1.0 avec les extensions exigées par le cadre (représentation JSON)**

```
{
  "specversion": "1.0",
  "id": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d",
  "source": "https://agents.ent.ca/logistique/detecteur-rupture-stock",
  "type": "ca.entreprise.logistique.alerte.rupture.v1",
  "subject": "MTL-02/PRD-99210",
  "time": "2026-10-27T09:15:00Z",
  "datacontenttype": "application/json",
  "dataschema": "https://catalogue.ent.ca/schemas/logistique/alerte-rupture/1.0.0",
  "traceparent": "00-4bf92f3577b34da6a3ce929d0e0e4736-00f067aa0ba902b7-01",
  "authtype": "service_account",
  "authid": "ordonnanceur-inventaire-quotidien",
  "dataclassification": "internal",
  "partitionkey": "MTL-02/PRD-99210",
  "xagentorigin": "agt-detecteur-rupture@1.3.0",
  "xagenthopcount": 1,
  "xagentmaxhops": 4,
  "xcostcenter": "CC-8100",
  "data": {
    "entrepot_id": "MTL-02",
    "sku": "PRD-99210",
    "stock_actuel": 12,
    "seuil_critique": 50,
    "horizon_epuisement_heures": 18
  }
}
```

Lecture : l'événement porte les quatre attributs requis par CloudEvents, les attributs `time`, `datacontenttype` et `dataschema` exigés par le cadre, et un `type` versionné en domaine inversé (EXIG-EVT-02)[248]. `traceparent` (Distributed Tracing), `authtype` et `authid` (Auth Context), `dataclassification` (Data Classification) et `partitionkey` (Partitioning) sont des extensions documentées, alors que `xagentorigin`, `xagenthopcount`, `xagentmaxhops` et `xcostcenter` sont propres au cadre (EXIG-EVT-04); aucun attribut ne contient de renseignement personnel (EXIG-EVT-05)[187, 252, 255]. Un agent qui réagit à cette alerte publie un nouvel événement dont `xagenthopcount` vaut 2 et qui recopie `xagentorigin` et `xagentmaxhops`; un événement dont le compteur atteint 4 n'est pas traité et part en file de lettres mortes (EXIG-EVT-06). Sur Kafka, le mode binaire retenu par défaut place les attributs (sauf `datacontenttype`, porté par l'en-tête `content-type`) dans des en-têtes préfixés `ce_` et `data` dans la valeur; une fois le « Key Mapper » de

la liaison activé (mécanisme facultatif), `partitionkey` est recopié dans la clé du message et, comme Kafka écrit les messages de même clé dans la même partition et en conserve l'ordre, les alertes d'un même article dans un même entrepôt restent dans l'ordre (EXIG-EVT-09)[250, 468].

## C.5 Jeton délégué

L'exemple complète l'extrait de la section 9.3 : le jeton que présente l'agent d'analyse des dépenses, appelé par l'orchestrateur, au serveur MCP des finances, au nom d'Alice.

**Jeton délégué après deux sauts, décodé (signature omise)**

```
En-tête
{ "typ": "at+jwt", "alg": "ES256", "kid": "idp-2026-10" }
Charge utile
{
  "iss": "https://idp.ent.ca",
  "sub": "alice",
  "aud": "https://mcp-finance.ent.ca",
  "client_id": "agent-analyse-depenses",
  "scope": "finance:read",
  "act": {
    "sub": "spiffe://ent.ca/agent-analyse-depenses",
    "act": { "sub": "spiffe://ent.ca/agent-orch" }
  },
  "cnf": { "x5t#S256": "vzF5VHuU_5wCN7LdQZOXTK3y7aNQCqM5M-yosaTb6aw" },
  "iat": 1793084700,
  "exp": 1793085600,
  "jti": "9f1c2d7e-5a41-4c3b-8e06-b2f94a1d7c55"
}
```

Lecture : le jeton suit le profil JWT de la RFC 9068, avec l'en-tête `typ` `at+jwt` et les revendications `iss`, `exp`, `aud`, `sub`, `client_id`, `iat` et `jti`[72]. Alice reste le sujet; l'`act` externe désigne l'acteur courant, l'agent d'analyse des dépenses, et l'`act` imbriqué l'orchestrateur, acteur antérieur que le serveur consigne sans s'en servir pour décider (EXIG-IAM-08, EXIG-IAM-11)[70]. L'audience unique, la portée réduite à `finance:read` et la durée de vie de 900 secondes appliquent les exigences EXIG-IAM-10, EXIG-IAM-11 et EXIG-IAM-15. `cnf` lie le jeton à l'empreinte du certificat X.509-SVID de l'agent : volé, il ne sert à rien sans la clé privée correspondante (EXIG-IAM-14)[328].

## C.6 Jeton d'approbation humaine

L'exemple montre l'action soumise à l'approbateur, le calcul de son empreinte et le jeton signé qui en résulte (section 8.5).

**Action soumise, empreinte h et jeton d'approbation décodé (signature omise)**

```
Action soumise
  outil      : mcp-approvisionnement/approvisionnement_creer_bon_commande@1.4.0
  arguments  : {"centre_cout":"CC-4410","fournisseur_id":"SUP-004512",
                "idempotency_key":"ce887a26e391ba96cd8c85603dd7b97beb97abffe5db0e610f2b6a8bca237edf",
                "lignes":[{"prix_unitaire_cad":249.6,"quantite":40,"sku":"PRD-10442"},
                          {"prix_unitaire_cad":208,"quantite":12,"sku":"PRD-20817"}],
                "montant_total_cad":12480,"statut_demande":"soumis"}
  h          : 9a2c0a8c4394ceb424c47d73d17bb417439d26a488e4d93c4834d481f5dc7e9d
En-tête
{ "typ": "approbation+jwt", "alg": "ES256", "kid": "approbation-2026-10" }
Charge utile
{
  "iss": "https://approbation.ent.ca",
  "aud": "https://passerelle-agents.ent.ca",
  "sub": "apb-5e19c2",
  "iat": 1793093040,
  "exp": 1793093940,
  "jti": "c2f7a1d4-8e3b-4f6a-b0d9-5a1e7c3f9b28",
  "task_id": "tache-7f3c2a",
  "agent_id": "agt-achats-indirects@1.2.0",
  "action_sha256": "9a2c0a8c4394ceb424c47d73d17bb417439d26a488e4d93c4834d481f5dc7e9d",
  "authorization_details": [
    {
      "type": "https://ent.ca/types/action-agent",
      "locations": ["https://passerelle-agents.ent.ca/mcp/approvisionnement"],
      "actions": ["tools/call"],
      "identifier": "mcp-approvisionnement/approvisionnement_creer_bon_commande@1.4.0",
      "fournisseur_id": "SUP-004512",
      "montant_total_cad": 12480,
      "centre_cout": "CC-4410"
    }
  ]
}
```

Lecture : h est le SHA-256 de l'identifiant pleinement qualifié de l'outil (serveur, nom, version épinglée), immédiatement suivi des arguments canonisés selon la RFC 8785, dont les clés sont triées et les nombres normalisés (12 480,00 devient `12480`)[236]. Le jeton contient le minimum exigé par l'EXIG-AUT-12 : l'empreinte (`action_sha256`), l'approbateur pseudonymisé (`sub`), la tâche, l'agent, une expiration à 15 minutes et un identifiant à usage unique (`jti`); `authorization_details` décrit l'action selon la RFC 9396 pour l'écran d'approbation et l'audit, sans remplacer l'empreinte[312]. Un `typ` distinct de `at+jwt`, choix du cadre, empêche de faire passer ce jeton pour un jeton d'accès, ou l'inverse. La passerelle vérifie la signature, l'expiration et l'usage unique, puis recalcule h sur l'appel reçu et refuse tout écart; ici, l'approbation est obtenue par CIBA sur l'appareil de l'approbateur (EXIG-AUT-14), et seul un tel jeton vaut approbation, jamais un acquiescement dans la conversation (EXIG-AUT-13)[310].

## C.7 Enveloppe budgétaire de tâche

L'exemple montre l'enveloppe attribuée à la tâche du scénario, telle que la passerelle de modèles et l'orchestrateur la tiennent à jour (section 10.6).

**Enveloppe budgétaire de la tâche tache-7f3c2a, état à 9 h 25 UTC (format interne)**


```
{
  "task_id": "tache-7f3c2a",
  "agent_id": "agt-achats-indirects@1.2.0",
  "cost_center": "CC-4410",
  "issued_at": "2026-10-27T09:02:11Z",
  "limits": {
    "max_tokens": 50000,
    "max_cost_cad": 0.75,
    "max_tool_calls": 15,
    "max_iterations": 8,
    "timeout_s": 60,
    "max_wall_clock_s": 28800
  },
  "alert_ratio": 0.8,
  "on_exhaustion": { "action": "stop_and_escalate", "queue": "file-achats-exceptions" },
  "models": {
    "default": "modele-compact",
    "reasoning": "modele-raisonnement",
    "reasoning_steps": ["planification", "arbitrage"],
    "fallback": "modele-compact-repli"
  },
  "consumed": {
    "as_of": "2026-10-27T09:25:41Z",
    "tokens": 41200,
    "cost_cad": 0.52,
    "tool_calls": 9,
    "iterations": 5,
    "active_s": 38
  },
  "alerts": [
    {
      "metric": "tokens",
      "ratio": 0.824,
      "at": "2026-10-27T09:25:41Z",
      "notified": "proprietaire"
    }
  ],
  "delegations": []
}
```


Lecture : l'enveloppe reprend les plafonds de la fiche d'agent (annexe B) : jetons, coût, appels d'outils, itérations et temps d'exécution active (`timeout_s`); `max_wall_clock_s` borne en outre la durée totale, attente d'approbation comprise (EXIG-ORC-26). Chaque étape incrémente `consumed` : à 82,4 % des jetons, le seuil d'alerte de 80 % a déjà prévenu le propriétaire, et l'atteinte d'un plafond arrêtera la tâche en état sûr pour l'escalader, sans jamais la déclarer réussie (EXIG-FIN-04). Le modèle compact sert par défaut, le modèle de raisonnement seulement aux étapes nommées, et tout le coût s'impute au centre de coûts de la tâche. Une délégation à un exécutant recevrait une part de l'enveloppe restante, inscrite dans `delegations`, et jamais une enveloppe neuve (section 7.7); les valeurs sont illustratives et se calibrent par mesure.

## C.8 Enregistrement d'audit

L'exemple montre l'enregistrement que la passerelle verse au journal d'audit après l'exécution de l'action approuvée en C.6 (section 10.3).

**Enregistrement d'audit canonisé (clés dans l'ordre RFC 8785, présentées indentées)**


```
{
  "empreinte": "sha256:689f1e007503a391dd58d4bdc148cbccde6c2c5a5f1578472244307110180588",
  "enregistrement": {
    "action": {
      "arguments_sha256": "cff55d8aafbb562bfb6b27ca6cec7cf38a1dfe3ee48b2410dcf1f3a04a5bdc2b",
      "definition": "1.4.0",
      "issue": "succes",
      "outil": "mcp-approvisionnement/approvisionnement_creer_bon_commande",
      "palier": "P2",
      "reference_resultat": "BC-2026-118734"
    },
    "agent": {
      "id": "agt-achats-indirects",
      "identite": "spiffe://ent.ca/agt-achats-indirects",
      "invite_systeme": "sha256:41d07c…",
      "version": "1.2.0"
    },
    "autorite": {
      "approbateur": "apb-5e19c2",
      "approbation_jti": "c2f7a1d4-8e3b-4f6a-b0d9-5a1e7c3f9b28",
      "classe_risque": "moderee",
      "controle": "approbation_requise_au_dela_du_seuil",
      "empreinte_approbation": "9a2c0a8c4394ceb424c47d73d17bb417439d26a488e4d93c4834d481f5dc7e9d",
      "niveau_autonomie": "N3",
      "version_politique": "politiques-passerelle@2026.10.3"
    },
    "correlation": {
      "cle_idempotence": "ce887a26e391ba96cd8c85603dd7b97beb97abffe5db0e610f2b6a8bca237edf",
      "etape": "etape-03/creer-bon-commande",
      "span_id": "b7ad6b7169203331",
      "tache": "tache-7f3c2a",
      "trace_id": "0af7651916cd43dd8448eb211c80319c"
    },
    "horodatage": "2026-10-27T09:26:03.412Z",
    "mandant": {
      "jeton_delegue_jti": "4e8b2c71-0d93-4a6f-9b15-7c2e8f40a6d3",
      "pseudonyme": "u-58c1d7",
      "type": "user"
    },
    "modele": {
      "fournisseur": "…",
      "servi": "modele-raisonnement",
      "version": "2026-08-14"
    },
    "precedent_sha256": "sha256:ee710bdb80fd80be1bce7ad8f07964c8a0dea08c5fb81f39289b26666ab4524a",
    "sequence": 48213
  },
  "signature": { "alg": "ES256", "kid": "journal-audit-2026-10", "valeur": "…" }
}
```


Lecture : `enregistrement` reprend les cinq éléments exigés par l'EXIG-OBS-12 (section 10.3) : le mandant sous pseudonyme (`mandant`), l'agent avec sa version, son identité et l'empreinte de son invite système (`agent`), l'action avec l'outil, la version de sa définition, l'empreinte des arguments et l'issue (`action`), le modèle servi (`modele`) et l'autorité qui permettait d'agir (`autorite` : politique appliquée, contrôle, niveau d'autonomie et jeton d'approbation, selon les EXIG-IAM-21 et EXIG-AUT-10); `correlation` le relie à la tâche, à l'étape, à la clé d'idempotence et à la trace. Il ne recopie pas les arguments, et le résultat n'y figure que par sa référence : `empreinte_approbation` reprend l'empreinte h du jeton C.6, calculée sur l'identifiant qualifié de l'outil (serveur, nom, version épinglée) et sur les arguments canonisés; la passerelle l'a recalculée avant l'exécution, ce qui prouve que l'action exécutée est bien celle qui a été approuvée.

`empreinte` est le SHA-256 de `enregistrement` canonisé selon la RFC 8785, signé par le service d'audit, et `precedent_sha256` chaîne chaque enregistrement au précédent, de sorte qu'une suppression ou une modification se détecte, conformément à la recommandation de l'OWASP de tenir des journaux d'audit immuables et signés[28, 236]. Ce format et sa signature, choix du cadre, vont au-delà du minimum légal : pour un système à haut risque (obligations applicables à compter du 2 décembre 2027 pour l'annexe III et du 2 août 2028 pour l'annexe I), le RIA exige que le système permette l'enregistrement automatique des événements, sans en fixer le format (art. 12), et que le déployeur conserve les journaux, dans la mesure où ils sont sous son contrôle, pendant une durée adaptée à la destination du système et d'au moins six mois, sauf disposition contraire du droit de l'Union ou du droit national (art. 26, par. 6)[94, 394].

# D Registre des exigences

Ce registre récapitule, dans l'ordre du document, toutes les exigences normatives du cadre avec leur force (DOIT, DEVRAIT, PEUT). Chaque identifiant renvoie à l'exigence complète, avec son énoncé et sa justification. Le registre sert de base aux revues d'architecture, à la grille d'homologation (annexe A) et à la déclaration d'applicabilité ISO/IEC 42001.

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-ARC-01 | DOIT | Passage obligatoire par la passerelle et le catalogue |
| EXIG-ARC-02 | DOIT | Mandant, trace et plafonds dans chaque appel |
| EXIG-ARC-03 | NE DOIT PAS | Aucune logique d'agent dans les canaux |
| EXIG-ARC-04 | DOIT | Mandant établi et trace ouverte à l'entrée |
| EXIG-ARC-05 | DOIT | Exécution durable des tâches à effets |
| EXIG-ARC-06 | DOIT | Points de contrôle protégés comme des données de production |
| EXIG-ARC-07 | NE DOIT PAS | Le routage n'accorde aucun droit |
| EXIG-ARC-08 | DOIT | Passerelle de modèles obligatoire |
| EXIG-ARC-09 | DEVRAIT | Modèles désignés par un alias logique |
| EXIG-ARC-10 | DOIT | Code généré exécuté en bac à sable |
| EXIG-ARC-11 | DOIT | Passerelle d'agents dans les deux sens |
| EXIG-ARC-12 | DOIT | Liste d'autorisation tirée du catalogue |
| EXIG-ARC-13 | DOIT | Aucun contournement par le bus d'événements |
| EXIG-ARC-14 | DOIT | Exposition sans réécriture des services |
| EXIG-ARC-15 | DEVRAIT | Outils conçus pour la tâche |
| EXIG-ARC-16 | DOIT | Résultats filtrés selon les droits du mandant |
| EXIG-ARC-17 | DOIT | Écriture par les interfaces qui appliquent les règles métier |
| EXIG-ARC-18 | DEVRAIT | Écritures corrélées et idempotentes |
| EXIG-ARC-19 | DOIT | Services transversaux mutualisés |
| EXIG-ARC-20 | DOIT | Correspondance ABB-SBB documentée |
| EXIG-ARC-21 | DOIT | SBB exposés par les standards retenus |
| EXIG-ARC-22 | NE DOIT PAS | Pas d'historique brut comme mémoire |
| EXIG-ARC-23 | DOIT | Contrôles avant toute écriture en mémoire longue |
| EXIG-ARC-24 | DOIT | Mémoire procédurale gérée comme du code |
| EXIG-ARC-25 | NE DOIT PAS | Aucun magasin de mémoire partagé sans isolation |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-INT-01 | DOIT | Revue d’interopérabilité à quatre niveaux |
| EXIG-INT-02 | DOIT | Vocabulaire et schémas d’entreprise |
| EXIG-INT-03 | DOIT | Accord d’interopérabilité et gestion du changement |
| EXIG-INT-04 | DOIT | Protocole désigné par type d’interaction |
| EXIG-INT-05 | DEVRAIT | Agent pair invoqué par A2A, pas déguisé en outil |
| EXIG-INT-06 | DOIT | Statut au catalogue avant tout usage en production |
| EXIG-INT-07 | DOIT | Version de référence fixée au catalogue |
| EXIG-INT-08 | DOIT | Révision trimestrielle du catalogue des protocoles |
| EXIG-INT-09 | NE DOIT PAS | Statut normatif exact |
| EXIG-INT-10 | DOIT | Choix de protocole justifié par la matrice |
| EXIG-INT-11 | DEVRAIT | Diffusion d’un changement d’état par événement |
| EXIG-MCP-01 | DOIT | Exposition des capacités par MCP, derrière la passerelle |
| EXIG-MCP-02 | DOIT | Révision de référence vérifiée par la découverte |
| EXIG-MCP-03 | DOIT | Listes stables et cache conforme à cacheScope |
| EXIG-MCP-04 | DOIT | Extensions activées sur liste d’autorisation |
| EXIG-MCP-05 | DEVRAIT | Choix de la primitive selon le besoin |
| EXIG-MCP-06 | NE DOIT PAS | Aucun miroir CRUD des API |
| EXIG-MCP-07 | DOIT | Conventions de nommage et de résultat des outils |
| EXIG-MCP-08 | DOIT | Transport selon l’environnement |
| EXIG-MCP-09 | DOIT | Autorisation obligatoire et conforme à la spécification |
| EXIG-MCP-10 | DOIT | Portées minimales et élévation progressive |
| EXIG-MCP-11 | NE DOIT PAS | Interdiction du passage de jeton |
| EXIG-MCP-12 | DOIT | Enregistrement des clients MCP |
| EXIG-MCP-13 | DOIT | Consentement par client des mandataires MCP |
| EXIG-MCP-14 | DOIT | Annotations et métadonnées déclarées : de simples indices |
| EXIG-MCP-15 | DOIT | Concordance des en-têtes et du corps |
| EXIG-MCP-16 | DOIT | Traitement du champ _meta |
| EXIG-MCP-17 | DOIT | État explicite protégé |
| EXIG-MCP-18 | NE DOIT PAS | Aucune donnée sensible en en-tête |
| EXIG-MCP-19 | DOIT | Schémas, URL et icônes : des entrées non fiables |
| EXIG-MCP-20 | DOIT | Empreintes des définitions et isolement des serveurs |
| EXIG-MCP-21 | NE DOIT PAS | Élicitation : ni secret ni approbation déguisée |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-MCP-22 | DOIT | Migration bornée et abandon des fonctions dépréciées |
| EXIG-A2A-01 | DOIT | A2A 1.0 pour toute délégation entre agents |
| EXIG-A2A-02 | DOIT | Carte publiée et inscrite au registre |
| EXIG-A2A-03 | DOIT | Carte signée et vérifiée |
| EXIG-A2A-04 | DOIT | Version de carte et revalidation du cache |
| EXIG-A2A-05 | NE DOIT PAS | Aucun champ hors norme dans la carte |
| EXIG-A2A-06 | DOIT | Compétences internes dans la carte étendue |
| EXIG-A2A-07 | DOIT | Suivi des tâches longues |
| EXIG-A2A-08 | DOIT | Version annoncée et liaisons standard |
| EXIG-A2A-09 | DOIT | Transport chiffré et authentification à chaque requête |
| EXIG-A2A-10 | DOIT | Autorisation par compétence et par locataire |
| EXIG-A2A-11 | NE DOIT PAS | Flux OAuth retirés |
| EXIG-A2A-12 | DOIT | Notifications push durcies |
| EXIG-A2A-13 | DOIT | Traçage et corrélation des tâches |
| EXIG-A2A-14 | DOIT | Compatibilité vérifiée avant inscription |
| EXIG-A2A-15 | DEVRAIT | Migration bornée depuis la version 0.3 |
| EXIG-EVT-01 | DEVRAIT | Recours au bus pour l’asynchrone |
| EXIG-EVT-02 | DOIT | Enveloppe CloudEvents complète |
| EXIG-EVT-03 | DOIT | Contrat AsyncAPI au catalogue |
| EXIG-EVT-04 | DOIT | Attributs de gouvernance présents et vérifiés |
| EXIG-EVT-05 | NE DOIT PAS | Aucun renseignement personnel dans les attributs |
| EXIG-EVT-06 | DOIT | Compteur de sauts et coupure des boucles |
| EXIG-EVT-07 | DOIT | Autorisation fondée sur l’identité, pas sur les attributs |
| EXIG-EVT-08 | DOIT | Effets réels protégés par l’idempotence |
| EXIG-EVT-09 | DOIT | Ordre garanti par la clé de partition |
| EXIG-EVT-10 | DOIT | Conservation des entrées et rejeu isolé |
| EXIG-INT-12 | DOIT | Contrat complet avant l’inscription |
| EXIG-INT-13 | DOIT | Versionnage sémantique des contrats |
| EXIG-INT-14 | DOIT | Coexistence d’au moins 60 jours |
| EXIG-INT-15 | DOIT | Dépendances épinglées par version et empreinte |
| EXIG-INT-16 | DOIT | Nouvelle approbation à toute modification |
| EXIG-INT-17 | DOIT | Catalogue unique, source de la découverte |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-INT-18 | DOIT | Consommateurs connus avant tout retrait |
| EXIG-INT-19 | DOIT | Détection automatique des ruptures |
| EXIG-INT-20 | NE DOIT PAS | Qualification « AAIF » vérifiée |
| EXIG-INT-21 | DOIT | Pilotes AGNTCY subordonnés au catalogue |
| EXIG-INT-22 | DOIT | Paiements initiés par un agent |
| EXIG-INT-23 | DOIT | Signal de révision inscrit au catalogue |
| EXIG-ORC-01 | DOIT | Configuration la plus simple justifiée |
| EXIG-ORC-02 | DOIT | Preuve mesurée avant le multiagent |
| EXIG-ORC-03 | DOIT | Patron déclaré au registre |
| EXIG-ORC-04 | NE DOIT PAS | Délégation limitée à deux niveaux |
| EXIG-ORC-05 | DOIT | Boucle évaluateur-optimiseur bornée |
| EXIG-ORC-06 | DOIT | Clavardage de groupe encadré |
| EXIG-ORC-07 | DOIT | Fusion déclarée et écrivain unique en parallèle |
| EXIG-ORC-08 | DOIT | Chorégraphie sous propriétaire et saga |
| EXIG-ORC-09 | DOIT | Surcharge d’outils traitée avant de scinder |
| EXIG-ORC-10 | DEVRAIT | Découpage par frontières de contexte |
| EXIG-ORC-11 | DOIT | Persistance après chaque transition |
| EXIG-ORC-12 | DOIT | Reprise sans double effet |
| EXIG-ORC-13 | DOIT | Magasin de points de contrôle protégé |
| EXIG-ORC-14 | DEVRAIT | Déploiement sans interruption des exécutions longues |
| EXIG-ORC-15 | DOIT | Saga pour toute écriture multisystème |
| EXIG-ORC-16 | DOIT | Journal de compensation tenu avant l’action |
| EXIG-ORC-17 | DOIT | Compensations idempotentes et métier, après réessais |
| EXIG-ORC-18 | DOIT | Escalade après deux échecs d’une compensation |
| EXIG-ORC-19 | DOIT | Isolation sémantique des sagas concurrentes |
| EXIG-ORC-20 | DOIT | Quatre tests d’injection de fautes |
| EXIG-ORC-21 | DOIT | Clé d’idempotence sur toute écriture |
| EXIG-ORC-22 | DOIT | Vérification de la clé par le service visé |
| EXIG-ORC-23 | DOIT | Contexte de délégation minimal et structuré |
| EXIG-ORC-24 | DOIT | Retour validé avant toute réutilisation |
| EXIG-ORC-25 | DOIT | Filtrage de sécurité dans chaque agent |
| EXIG-ORC-26 | DOIT | Plafonds sur toute exécution |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-ORC-27 | DOIT | Mécanismes de résilience et repli testé |
| EXIG-ORC-28 | DOIT | Coupe-circuit exercé chaque trimestre |
| EXIG-ORC-29 | NE DOIT PAS | Aucun anti-patron sans dérogation |
| EXIG-ORC-30 | DOIT | Capacités démontrées avant l'inscription d'un produit |
| EXIG-AUT-01 | DOIT | Niveau d'autonomie déclaré et appliqué |
| EXIG-AUT-02 | DOIT | Plafond selon la classe de risque |
| EXIG-AUT-03 | NE DOIT PAS | Autonomie non bornée interdite (NX) |
| EXIG-AUT-04 | DOIT | Domaine de conception opérationnel (ODD), repli et arrêts pour N3 et N4 |
| EXIG-AUT-05 | DOIT | Homologation et réévaluation du niveau |
| EXIG-AUT-06 | DOIT | Classement fondé sur les permissions effectives |
| EXIG-AUT-07 | NE DOIT PAS | Règle d'or : pas d'exécution autonome du risque cumulé |
| EXIG-AUT-08 | DOIT | Palier attribué au catalogue après revue |
| EXIG-AUT-09 | NE DOIT PAS | Aucun outil P3 exécuté seul |
| EXIG-AUT-10 | DOIT | Contrôle calculé à chaque appel |
| EXIG-AUT-11 | DOIT | Échec en mode fermé |
| EXIG-AUT-12 | DOIT | Jeton d'approbation lié à l'action exacte |
| EXIG-AUT-13 | NE DOIT PAS | Ce qui n'est jamais une approbation |
| EXIG-AUT-14 | DEVRAIT | Approbation hors bande normalisée |
| EXIG-AUT-15 | DOIT | Approbateurs habilités et formés |
| EXIG-AUT-16 | DOIT | Boîte de réception persistante |
| EXIG-AUT-17 | DOIT | État persisté et effets après le point d'approbation |
| EXIG-AUT-18 | DOIT | Réautorisation périodique des agents ambiants |
| EXIG-AUT-19 | DOIT | Écran d'approbation fidèle à l'action |
| EXIG-AUT-20 | DOIT | Charge d'approbation maîtrisée |
| EXIG-AUT-21 | DOIT | Mesure de la qualité de la supervision |
| EXIG-AUT-22 | DOIT | Décisions visées par l'article 12.1 |
| EXIG-AUT-23 | DOIT | Révision humaine significative |
| EXIG-IAM-01 | NE DOIT PAS | Aucune confiance implicite |
| EXIG-IAM-02 | DOIT | Une décision à chaque appel |
| EXIG-IAM-03 | DOIT | Identité propre, distincte et non partagée |
| EXIG-IAM-04 | DOIT | Justificatif cryptographique émis par la plateforme |
| EXIG-IAM-05 | NE DOIT PAS | Aucun secret statique partagé |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-IAM-06 | NE DOIT PAS | Justificatifs hors de portée du modèle |
| EXIG-IAM-07 | DOIT | Révocation au retrait et revues périodiques |
| EXIG-IAM-08 | DOIT | Délégation explicite par échange de jetons |
| EXIG-IAM-09 | NE DOIT PAS | Interdiction de l'usurpation |
| EXIG-IAM-10 | DOIT | Portée jamais élargie |
| EXIG-IAM-11 | DOIT | Jeton à audience unique, validé par la cible |
| EXIG-IAM-12 | NE DOIT PAS | Aucun relais de jeton |
| EXIG-IAM-13 | DOIT | Profil OAuth de l'entreprise |
| EXIG-IAM-14 | DOIT | Jetons liés à l'expéditeur |
| EXIG-IAM-15 | DEVRAIT | Durée de vie courte des jetons |
| EXIG-IAM-16 | DOIT | Agents autonomes : identifiants du client et portées par outil |
| EXIG-IAM-17 | DOIT | Passage obligatoire par la passerelle d'agents |
| EXIG-IAM-18 | DOIT | Échec en mode fermé et refus typé |
| EXIG-IAM-19 | DEVRAIT | Justificatifs en aval injectés par la passerelle |
| EXIG-IAM-20 | DOIT | Coupe-circuit propagé et mesuré |
| EXIG-IAM-21 | DOIT | Politique en code, versionnée et testée |
| EXIG-SEC-01 | DOIT | Modélisation des menaces avant la production |
| EXIG-SEC-02 | DOIT | Matrice de traçabilité des menaces |
| EXIG-SEC-03 | DOIT | Présomption d'injection |
| EXIG-SEC-04 | DOIT | Règle de deux par session |
| EXIG-SEC-05 | NE DOIT PAS | Détection jamais seule |
| EXIG-SEC-06 | DOIT | Retrait déterministe des capacités d'exfiltration |
| EXIG-SEC-07 | DOIT | Patron de conception pour les agents de risque élevé |
| EXIG-SEC-08 | DOIT | Technologie d'isolation du code non fiable |
| EXIG-SEC-09 | DOIT | Bac à sable éphémère et minimal |
| EXIG-SEC-10 | DOIT | Charges qui exigent un GPU |
| EXIG-SEC-11 | DEVRAIT | Performance mesurée sur la charge réelle |
| EXIG-SEC-12 | DOIT | Sortie réseau refusée par défaut |
| EXIG-SEC-13 | DOIT | Service de métadonnées infonuagiques |
| EXIG-SEC-14 | NE DOIT PAS | Secrets injectés par le mandataire de sortie |
| EXIG-SEC-15 | DOIT | Délais à trois niveaux |
| EXIG-SEC-16 | DOIT | Journal d'exécution tenu hors du bac à sable |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-SEC-17 | DOIT | Porte de validation du code généré |
| EXIG-SEC-18 | DOIT | Provenance approuvée et intégrité vérifiée à l'exécution |
| EXIG-SEC-19 | DOIT | Signature des cartes d'agent et des artefacts |
| EXIG-SEC-20 | DOIT | Nomenclature de chaque version d'agent |
| EXIG-SEC-21 | DOIT | Chaque serveur, un domaine de sécurité distinct |
| EXIG-SEC-22 | DOIT | Évaluation des tiers et plan de contingence |
| EXIG-SEC-23 | DOIT | Exercice d'équipe rouge propre aux agents |
| EXIG-SEC-24 | DOIT | Suite d'attaques dans la chaîne d'intégration |
| EXIG-SEC-25 | DOIT | Vérification des contrôles déterministes |
| EXIG-SEC-26 | DOIT | Exercice trimestriel de compromission d'agent |
| EXIG-OBS-01 | DOIT | OpenTelemetry obligatoire, conventions épinglées |
| EXIG-OBS-02 | DOIT | Contexte validé, poursuivi ou redémarré aux frontières |
| EXIG-OBS-03 | DOIT | Identifiants métier portés à part |
| EXIG-OBS-04 | DOIT | Hiérarchie de spans normalisée |
| EXIG-OBS-05 | DOIT | Attributs et métriques exigés |
| EXIG-OBS-06 | DOIT | Attributs d'entreprise sous préfixe DNS inversé |
| EXIG-OBS-07 | NE DOIT PAS | Aucun contenu dans la télémétrie de production |
| EXIG-OBS-08 | DOIT | Contenu de débogage hors trace et de courte durée |
| EXIG-OBS-09 | DOIT | Caviardage à la sortie du périmètre |
| EXIG-OBS-10 | NE DOIT PAS | Aucun renseignement personnel dans le bagage |
| EXIG-OBS-11 | DOIT | Journal d'audit distinct et exhaustif |
| EXIG-OBS-12 | DOIT | Enregistrement à cinq éléments, canonisé et signé |
| EXIG-OBS-13 | DOIT | Inaltérabilité et conservation |
| EXIG-EVA-01 | DOIT | Paliers franchis et relancés à chaque changement |
| EXIG-EVA-02 | DOIT | Jeu de référence tenu et versionné |
| EXIG-EVA-03 | DOIT | Évaluations répétées et isolées |
| EXIG-EVA-04 | DOIT | Échantillonnage de la production |
| EXIG-EVA-05 | DOIT | Juge automatisé encadré |
| EXIG-EVA-06 | DOIT | Objectifs de niveau de service et réaction aux écarts |
| EXIG-FIN-01 | DOIT | Comparaison au coût par tâche réussie |
| EXIG-FIN-02 | DOIT | Hypothèses de prix datées et révisées |
| EXIG-FIN-03 | DOIT | Unités SaaS converties et plafonnées |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-FIN-04 | DOIT | Enveloppe appliquée à chaque étape |
| EXIG-FIN-05 | DOIT | Quotas et plafond mensuel par agent |
| EXIG-FIN-06 | DOIT | Plus petit modèle suffisant |
| EXIG-FIN-07 | DOIT | Préfixe stable et cache mesuré |
| EXIG-FIN-08 | DEVRAIT | Lots asynchrones pour les charges non urgentes |
| EXIG-FIN-09 | DOIT | Imputation par centre de coûts |
| EXIG-FIN-10 | DOIT | Indicateurs d'économie unitaire publiés |
| EXIG-GOV-01 | DOIT | Responsables nommés pour chaque agent |
| EXIG-GOV-02 | DOIT | Comité d'architecture et des risques agentiques |
| EXIG-GOV-03 | NE DOIT PAS | Séparation des fonctions |
| EXIG-GOV-04 | DOIT | Un seul A, des personnes nommées |
| EXIG-GOV-05 | DOIT | Socle commun obligatoire |
| EXIG-GOV-06 | DEVRAIT | Conformité par construction |
| EXIG-GOV-07 | DOIT | Inventaire complet |
| EXIG-GOV-08 | NE DOIT PAS | Sans fiche, aucun justificatif |
| EXIG-GOV-09 | DOIT | Fiche à jour ou agent suspendu |
| EXIG-GOV-10 | DOIT | Détection des agents hors registre |
| EXIG-GOV-11 | DOIT | Points de contrôle consignés |
| EXIG-GOV-12 | DOIT | Réévaluation sur changement significatif |
| EXIG-GOV-13 | DOIT | Attestation périodique du parrain |
| EXIG-GOV-14 | DOIT | Retrait vérifiable |
| EXIG-GOV-15 | DOIT | Demande et décision écrites |
| EXIG-GOV-16 | DOIT | Durée bornée |
| EXIG-GOV-17 | NE DOIT PAS | Exigences non dérogeables |
| EXIG-GOV-18 | DOIT | Révision trimestrielle du catalogue |
| EXIG-GOV-19 | DOIT | Critères d'admission d'un standard |
| EXIG-GOV-20 | DOIT | Veille désignée et usage encadré |
| EXIG-CON-01 | DOIT | Classe de risque attribuée avant l'inscription |
| EXIG-CON-02 | DOIT | Plafond d'autonomie par classe |
| EXIG-CON-03 | DOIT | Réévaluation à chaque changement significatif |
| EXIG-CON-04 | DOIT | EFVP avant tout projet d'agent impliquant des RP |
| EXIG-CON-05 | DOIT | Cartographie des lieux de traitement |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-CON-06 | DOIT | Finalité vérifiée avant toute réutilisation |
| EXIG-CON-07 | DOIT | Avis et explication des décisions automatisées |
| EXIG-CON-08 | NE DOIT PAS | Aucune approbation nominale |
| EXIG-CON-09 | DOIT | Conservation des éléments de décision |
| EXIG-CON-10 | DOIT | Durée de vie des mémoires et des traces |
| EXIG-CON-11 | DOIT | Régimes applicables inscrits à la fiche |
| EXIG-CON-12 | DOIT | Arrimage à E-23 pour les institutions financières fédérales |
| EXIG-CON-13 | DOIT | Applicabilité du RIA déterminée par l'usage des sorties |
| EXIG-CON-14 | NE DOIT PAS | Aucun usage interdit |
| EXIG-CON-15 | DOIT | Revue de requalification en fournisseur |
| EXIG-CON-16 | DOIT | Obligations du déployeur d'un agent à haut risque |
| EXIG-CON-17 | DOIT | Déclaration de tolérance au risque |
| EXIG-CON-18 | DOIT | Base de preuves unique |
| EXIG-CON-19 | DOIT | Divulgation de l'interaction avec un agent |
| EXIG-CON-20 | DOIT | Identification des contenus produits par un agent |
| EXIG-CON-21 | DOIT | Explication intelligible et canal de révision |
| EXIG-CON-22 | DOIT | Vérification humaine du contenu juridique |
| EXIG-CON-23 | DOIT | Réponse en cinq temps et gel des preuves |
| EXIG-CON-24 | DOIT | Registre et avis des incidents de confidentialité |
| EXIG-CON-25 | DOIT | Règle la plus exigeante entre régimes de notification |
| EXIG-CON-26 | DOIT | Évaluation d'impact unifiée par agent de classe élevée |
| EXIG-APP-01 | DOIT | Analyse de réversibilité avant tout engagement |
| EXIG-APP-02 | NE DOIT PAS | Aucune dépendance à une extension non approuvée |
| EXIG-APP-03 | DOIT | Preuves de conformité protocolaire |
| EXIG-APP-04 | DOIT | Mesures de performance reproductibles |
| EXIG-APP-05 | DOIT | Télémétrie et données de coûts ouvertes |
| EXIG-APP-06 | DOIT | Identité et arrêt sous le contrôle de l'entreprise |
| EXIG-APP-07 | DOIT | Clause 1 — Interopérabilité ouverte et portabilité des cartes |
| EXIG-APP-08 | DOIT | Clause 2 — Conformité MCP et délégation d'identité |
| EXIG-APP-09 | DOIT | Clause 3 — Télémétrie exportable et explicabilité |
| EXIG-APP-10 | DOIT | Clause 4 — Usage limité au mandat et interdiction d'entraînement |
| EXIG-APP-11 | DOIT | Clause 5 — Résidence, transferts et lois étrangères |

| Identifiant | Force | Exigence |
|---|---|---|
| EXIG-APP-12 | DOIT | Clause 6 — Notification d’incident |
| EXIG-APP-13 | DOIT | Clause 7 — Audit, sécurité et transparence des changements |
| EXIG-APP-14 | DOIT | Clause 8 — Réversibilité et sortie |
| EXIG-APP-15 | DOIT | Clause 9 — Accord écrit au sens de l’article 25(4) du RIA |
| EXIG-APP-16 | DOIT | Clause 10 — Révocation des identités non humaines |
| EXIG-APP-17 | DOIT | Application de la grille |

# E Glossaire

Ce glossaire réunit, par ordre alphabétique, les termes et les sigles du cadre, avec leur équivalent anglais d'usage courant et une définition brève qui renvoie à la section où chacun est traité. Les définitions reprennent le sens que le document donne à chaque terme; lorsqu'un terme vient d'une norme ou d'un texte de loi, la source est indiquée, et ce que le cadre y ajoute est signalé comme un choix du cadre. En cas d'écart entre une définition abrégée et le corps du document, le corps du document prévaut.

## Conventions

- **Classement.** Les entrées suivent l'ordre alphabétique du terme français, sans tenir compte des accents, des apostrophes ni du contenu des parenthèses. Un sigle d'usage courant suit le terme entre parenthèses; les sigles et les noms propres sans équivalent français (par exemple A2A, AAIF, CIBA, CloudEvents, FinOps, MCP, OAuth, OBO, OpenTelemetry, SPIFFE) sont classés tels quels.
- **Typographie.** L'équivalent anglais figure en italique. Les noms de champs, de méthodes, d'en-têtes et d'attributs sont en police à chasse fixe.
- **Force normative.** Le glossaire ne crée aucune exigence. Les mots doit, devrait et peut gardent le sens fixé à la section 1.4, et les définitions normatives des termes de base figurent à la section 3.1.

**Tableau 65 — Glossaire des termes et des sigles du cadre**

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **A2A** (protocole Agent2Agent) | *Agent2Agent (A2A) protocol* | Protocole ouvert d'intégration horizontale qui relie un agent à un autre agent autonome, potentiellement opaque, qui raisonne et conserve un état sur plusieurs tours. Projet de l'AAIF, annoncé publiquement le 17 août 2026, il est retenu par le cadre dans sa version de protocole 1.0, avec trois liaisons standard (JSON-RPC, gRPC, HTTP+JSON) et l'en-tête `A2A-Version` à chaque requête[5, 68]. Voir la section 6.6. |
| **AAIF** | *Agentic AI Foundation* | Fonds dirigé de la Linux Foundation, créé le 9 décembre 2025 et cofondé par Anthropic, Block et OpenAI, qui héberge des projets agentiques sous gouvernance neutre, dont MCP, A2A, agentgateway et Agent Router; il en compte dix au 22 octobre 2026[4, 130, 193]. Un projet n'est un « standard AAIF » qu'une fois son admission approuvée et annoncée. Voir la section 6.9. |
| **Agent** | *AI agent* | Selon ISO/IEC 22989:2022 (3.1.1), entité automatisée qui perçoit son environnement, y réagit et agit pour atteindre ses buts[59]. Dans le cadre : système logiciel qui poursuit un objectif en dirigeant lui-même sa boucle « raisonner, agir, observer » (ReAct) au moyen d'un modèle, d'outils et d'un état, sous un niveau d'autonomie déclaré[84]. Un agent n'est ni une personne, ni un compte d'utilisateur, ni un principal de service partagé; une personne nommée en répond. Voir les sections 3.1 et 3.4. |
| **Agent ambiant** | *ambient agent* | Agent qui écoute un flux d'événements et agit en conséquence, éventuellement sur plusieurs événements à la fois, sans être nécessairement entièrement autonome (définition de LangChain)[86]. Il travaille en arrière-plan, à la différence d'un agent interactif, sollicité par une personne qui attend sa réponse, et rejoint les personnes par une boîte de réception persistante (notifier, questionner, réviser). Voir les sections 3.3 et 8.6. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Analyse d'impact sur les droits fondamentaux** (AIDF) | *fundamental rights impact assessment (FRIA)* | Analyse que l'article 27 du RIA exige de certains déployeurs de systèmes à haut risque avant la première utilisation; elle peut renvoyer aux sections pertinentes de l'analyse d'impact relative à la protection des données (AIPD) du Règlement général sur la protection des données (RGPD) ou en intégrer des parties[58, 61]. Le cadre l'intègre à l'évaluation d'impact unifiée de chaque agent de classe élevée. Voir la section 12.9. |
| **Annotation d'outil** | *tool annotation* | Métadonnée qu'un serveur MCP déclare sur un outil : un titre (`title`) et quatre indices (`readOnlyHint`, `destructiveHint`, `idempotentHint`, `openWorldHint`). La spécification demande aux clients de tenir les annotations pour non fiables, sauf si elles proviennent de serveurs de confiance[197]. Le palier, le seuil et la compensation d'un outil se lisent au catalogue d'entreprise, jamais dans ses annotations. Voir la section 6.5. |
| **Approbation humaine** | *human approval* | Décision explicite d'une personne habilitée qui autorise une action précise avant son exécution. Dans le cadre, elle prend la forme d'un jeton d'approbation signé, lié à l'action exacte et vérifié par la passerelle d'agents. Un acquiescement dans la conversation, un résumé rédigé par l'agent ou une confirmation locale dans son interface n'en sont jamais une. Voir la section 8.5. |
| **Approbation machinale** | *rubber-stamping* | Approbation donnée sans examen réel, sous l'effet du volume, de la fatigue ou du biais d'automatisation, soit la tendance à se fier excessivement à une sortie automatisée. L'OWASP (Open Worldwide Application Security Project) range la saturation délibérée des approbateurs parmi les menaces (T10, *Overwhelming Human in the Loop*)[87]. Le cadre la prévient par des files priorisées selon le risque et par la mesure du taux d'approbation sans modification. Voir la section 8.7. |
| **AsyncAPI** | *AsyncAPI* | Spécification ouverte qui décrit de façon lisible par machine les canaux, les opérations d'envoi (`send`) ou de réception (`receive`) et les messages d'une application asynchrone. Le cadre retient la version 3.x (3.0.0 du 5 décembre 2023; 3.1.0 du 31 janvier 2026, version mineure sans rupture) pour le contrat de chaque sujet du bus d'événements[174, 249]. Voir la section 6.7. |
| **Bac à sable** | *sandbox* | Environnement d'exécution isolé, éphémère et sans privilèges où s'exécute le code qu'un agent génère ou reçoit d'une source non fiable : microVM (Firecracker, Kata Containers), gVisor ou WebAssembly (WASI), jamais un conteneur à noyau partagé (choix du cadre). Il démarre sans accès réseau, ne contient aucun secret, applique des délais à trois niveaux et est journalisé de l'extérieur. Voir la section 9.7. |
| **Bloc de construction d'architecture** (ABB) et **de solution** (SBB) | *architecture building block; solution building block* | Notions de TOGAF : l'ABB capture les exigences d'architecture et oriente le développement des SBB; le SBB est le produit ou le composant qui met en œuvre la fonction et dépend du fournisseur[121]. Dans le cadre, la passerelle d'agents est un ABB neutre et durable; le produit qui la réalise est un SBB remplaçable. Voir la section 5.4. |
| **Bus d'événements** | *event bus; event broker* | Courtier qui transporte des événements entre producteurs et consommateurs qui s'ignorent, par exemple Apache Kafka. Il découple les échanges dans le temps, admet plusieurs abonnés et permet le rejeu des entrées, mais Kafka livre par défaut « au moins une fois »[140] : un effet réel n'est protégé que par l'idempotence du consommateur et du système cible. Voir la section 6.7. |
| **Cadriciel** | *framework; agent framework* | Bibliothèque logicielle qui structure la logique d'un agent ou d'une orchestration, par exemple LangGraph, Microsoft Agent Framework, Google ADK ou OpenAI Agents SDK. Le cadre le traite comme un bloc de solution remplaçable : entre agents, seuls les contrats publiés font foi. Voir la section 7.10. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Carte d'agent** | *Agent Card* | Document JSON par lequel un agent A2A déclare son identité, ses compétences, ses interfaces et ses exigences de sécurité. En A2A 1.0, elle compte huit champs obligatoires (`name`, `description`, `supportedInterfaces`, `version`, `capabilities`, `defaultInputModes`, `defaultOutputModes`, `skills`), et un agent exposé la publie à `/.well-known/agent-card.json`[68]. Le cadre exige qu'elle soit signée (JWS sur la carte canonisée JCS), versionnée selon SemVer et inscrite au registre. Voir la section 6.6 et l'annexe C. |
| **Catalogue d'entreprise** | *enterprise catalog* | Source unique de ce qu'un agent peut joindre : outils, serveurs MCP, cartes d'agent et contrats d'événements, chacun avec sa version et son empreinte approuvées, son palier, son seuil, sa compensation et son propriétaire. La passerelle d'agents en tire sa liste d'autorisation; un élément absent du catalogue est injoignable. Le registre répond à « qui, quoi, pourquoi et avec quel risque », le catalogue à « par quel contrat et dans quelle version ». Voir les sections 6.8 et 11.4. |
| **Catalogue des protocoles** | *protocol and standards catalog* | Liste des protocoles et standards admis par le cadre, avec leur version de référence et l'un de quatre statuts : Adopter (usage par défaut), Évaluer (pilotes encadrés), Surveiller (veille, hors production) ou Contenir (existant toléré derrière un adaptateur, sans nouvel usage). Le comité le révise au moins chaque trimestre. Voir les sections 6.3 et 11.7. |
| **Chorégraphie** | *choreography* | Coordination décentralisée dans laquelle chaque agent réagit aux événements d'un bus et publie les siens, sans composant central qui dirige le flux. Le cadre l'assortit d'un propriétaire de bout en bout, d'une saga explicite, d'un contexte de trace et d'un compteur de sauts. Voir les sections 6.7 et 7.2. |
| **CIBA** | *Client-Initiated Backchannel Authentication* | Spécification finale de l'OpenID Foundation (CIBA Core 1.0) qui découple l'appareil où s'exécute le client de celui où la personne s'authentifie; un court `binding_message`, affiché sur les deux appareils, rattache la demande à l'action[310]. Le cadre la recommande pour l'approbation hors bande, notamment des actions P3 et des agents sans interface. Voir la section 8.5. |
| **Classe de risque** | *risk class* | Mesure de ce qui arrive si l'agent se trompe : faible, modérée ou élevée. La classe retenue est la plus élevée dont un critère est rempli, jamais une moyenne. Elle fixe le plafond d'autonomie : N2 pour la classe élevée, qui comprend les systèmes à haut risque du RIA et les décisions visées par l'article 12.1 de la Loi sur le privé; N3 pour les classes modérée et faible; N4 pour la classe faible, sur décision du comité. Voir les sections 8.1 et 12.1. |
| **CloudEvents** | *CloudEvents* | Spécification de la Cloud Native Computing Foundation (CNCF) qui normalise l'enveloppe d'un événement. Le cadre retient la version 1.0 (révision 1.0.2), dont les quatre attributs requis sont `id`, `source`, `specversion` et `type`[248]. Le contrat de chaque sujet se décrit en AsyncAPI 3.x, et le cadre ajoute des extensions de gouvernance (contexte de trace, mandant, classification, compteur de sauts). Voir la section 6.7. |
| **Comité d'architecture et des risques agentiques** | *agentic architecture and risk committee* | Instance décisionnelle du cadre, dotée d'un mandat écrit. Le comité approuve les agents de classe élevée et tout niveau N4, accorde les dérogations, approuve le catalogue des protocoles et révise le cadre chaque semestre; ses décisions sont motivées et consignées au registre. Voir la section 11.1. |
| **Commission d'accès à l'information** (CAI) | *Commission d'accès à l'information (nom officiel)* | Organisme québécois chargé de surveiller l'application des lois sur l'accès à l'information et sur la protection des renseignements personnels. Elle reçoit les avis d'incidents de confidentialité présentant un risque de préjudice sérieux et peut imposer des sanctions administratives pécuniaires[317]. Le cadre recommande son guide d'EFVP. Voir les sections 12.2 et 12.8. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Compensation** | *compensating transaction* | Action métier qui neutralise ou corrige l'effet d'une étape déjà exécutée lorsqu'une saga ne peut aboutir : remboursement, avis rectificatif, libération de stock. Elle ne rétablit pas forcément l'état initial. Le cadre exige qu'elle soit déclarée au catalogue, idempotente, journalisée avant l'action qu'elle couvre et déclenchée seulement après l'épuisement des réessais. Voir la section 7.5. |
| **Compétence** | *skill* | Capacité qu'un agent publie dans sa carte d'agent; en A2A 1.0, chaque compétence exige `id`, `name`, `description` et `tags` et peut porter ses propres exigences de sécurité[192]. Le cadre associe une portée OAuth dédiée à chaque compétence. Le terme désigne aussi les paquets de compétences d'agents, traités comme des composants de la chaîne d'approvisionnement. Voir les sections 6.6 et 9.8. |
| **Compteur de sauts** | *hop count* | Extension CloudEvents propre au cadre (`xagenthopcount`, avec le plafond `xagentmaxhops`, fixé à 4 par défaut) qui compte les publications d'agents dans une chaîne causale. Un agent qui reçoit un événement ayant atteint le plafond ne le traite pas, le dirige vers la file de lettres mortes et lève une alerte : les boucles entre agents sont coupées de façon déterministe. Voir la section 6.7. |
| **Confiance zéro** | *zero trust* | Modèle de sécurité défini par la publication NIST SP 800-207 (août 2020) : aucune confiance implicite n'est accordée selon l'emplacement réseau, et l'authentification et l'autorisation précèdent l'accès à chaque ressource[112]. Le cadre va au-delà de l'accès par session : chaque appel d'un agent est authentifié et autorisé individuellement. Voir la section 9.1. |
| **Contenu non fiable** | *untrusted content* | Tout contenu qui ne provient ni du mandant authentifié ni de la configuration approuvée de l'agent : pages Web, courriels, documents téléversés, champs libres des systèmes d'enregistrement, réponses d'outils, entrées de mémoire, messages et cartes d'autres agents. Il est traité comme une donnée, jamais comme une instruction; sa lecture entraîne le retrait des outils d'envoi externe et des outils P3 pour le reste de la session. Voir la section 9.6. |
| **Contrat** | *contract* | Description lisible par machine qui fait foi entre un agent ou un outil et ses consommateurs : définition d'outil MCP, carte d'agent, contrat AsyncAPI ou OpenAPI. Le contrat d'agent précise en outre les entrées, les sorties, les limites, le niveau d'autonomie et les niveaux de service. Tout contrat est versionné, épinglé et inscrit au catalogue; la description d'un outil en fait partie. Voir la section 6.8 et l'annexe C. |
| **Coupe-circuit** | *kill switch* | Mécanisme qui, en une seule action, suspend un agent, un outil, un serveur MCP ou une catégorie d'actions sur toutes les passerelles, désactive l'identité de l'agent et diffuse la révocation aux systèmes raccordés, par exemple au moyen des événements du Continuous Access Evaluation Profile (CAEP) du Shared Signals Framework[344]. Son délai de bout en bout est mesuré lors d'un exercice au moins trimestriel (choix du cadre). Voir les sections 7.8 et 9.4. |
| **Décision fondée exclusivement sur un traitement automatisé** | *decision based exclusively on automated processing* | Décision concernant une personne fondée exclusivement sur un traitement automatisé de ses RP (art. 12.1 de la Loi sur le privé; art. 65.2 de la Loi sur l'accès). La personne en est informée au plus tard au moment de la décision, peut obtenir les RP utilisés et les principaux facteurs et paramètres, et présenter ses observations à un membre du personnel en mesure de réviser la décision[160]. Selon l'interprétation gouvernementale de l'article 65.2 (organismes publics), une intervention humaine mineure ne retire pas ce caractère; la CAI n'a pas publié de critères pour le secteur privé, et le cadre applique cette interprétation par analogie à l'article 12.1. Voir les sections 8.8 et 12.2. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Délégation** | *delegation* | Transfert, borné en portée et en durée, du droit d'agir d'un mandant vers un agent, ou d'une tâche d'un agent vers un autre. Au sens de la RFC 8693, l'acteur conserve une identité distincte de celle du sujet pour lequel il agit; dans l'usurpation d'identité *(impersonation)*, l'acteur devient indiscernable du sujet[69]. Le cadre interdit l'usurpation et exige la délégation explicite. Voir la section 9.3. |
| **Déployeur** | *deployer* | Selon l'article 3(4) du RIA, personne ou organisme qui utilise un système d'IA sous sa propre autorité[61]. Un déployeur devient fournisseur s'il appose son nom ou sa marque sur un système à haut risque déjà mis sur le marché, s'il y apporte une modification substantielle ou s'il modifie la destination d'un système non classé à haut risque de sorte qu'il le devienne (art. 25(1)). Voir la section 12.4. |
| **Dérogation** | *waiver; exception* | Exception écrite, temporaire et compensée à une exigence du cadre, accordée pour un agent ou un composant précis par le comité (ou, par délégation, par l'architecture d'entreprise pour un agent de classe faible, alors pour 90 jours au plus), pour six mois au plus et renouvelable une seule fois. Aucune dérogation n'est possible pour le niveau NX, une action P3 sans approbation humaine, l'usurpation d'identité, un agent sans fiche ni parrain, le dépassement du plafond d'autonomie ou une obligation légale. Voir la section 11.6. |
| **Domaine de conception opérationnel** (ODD), aussi appelé « domaine d'exploitation » dans le cadre | *operational design domain* | Notion de la conduite automatisée des véhicules routiers, empruntée par analogie; la taxonomie SAE J3016 est une pratique recommandée et non une norme de sécurité[304]. Dans le cadre, périmètre documenté (systèmes, données, outils, seuils, volumes, plages horaires) hors duquel un agent s'arrête en état sûr, compense ou escalade. Il est exigé aux niveaux N3 et N4; le niveau N4 suppose un ODD certifié. Voir la section 8.1. |
| **Échec en mode fermé** | *fail-closed* | Comportement par lequel un composant refuse ou suspend plutôt que d'agir lorsqu'il ne peut pas obtenir une décision valide : service de politiques ou d'approbation indisponible, politique absente, doute. La passerelle d'agents n'ouvre jamais le passage par défaut, et l'orchestrateur suspend la tâche dans un état reprenable. Voir les sections 8.4 et 9.4. |
| **Empoisonnement d'outil** | *tool poisoning* | Attaque qui cache des instructions malveillantes dans la description, le schéma ou les valeurs de retour d'un outil. L'ombrage *(tool shadowing)*, variante voisine, laisse la description d'un serveur malveillant modifier l'usage des outils d'un autre serveur[221]. Le cadre y répond par l'épinglage des définitions par empreinte et par l'isolement de chaque serveur. Voir les sections 6.5 et 9.8. |
| **Empreinte** | *digest; fingerprint* | Condensé cryptographique, par exemple SHA-256, calculé sur un contenu canonisé selon la RFC 8785 (JCS), RFC informative de la filière indépendante[236]. Le cadre s'en sert pour épingler les définitions approuvées des outils et des cartes, tout écart bloquant l'appel jusqu'à une nouvelle approbation, et pour lier une approbation à l'action exacte : h = SHA-256(identifiant de l'outil ‖ arguments canonisés). Voir les sections 6.8 et 8.5. |
| **Entreprise agentique** | *agentic enterprise* | Organisation où des agents exécutent une part croissante des processus, aux côtés des personnes et des systèmes existants, sous une supervision humaine proportionnée au risque. Voir la section 2.1. |
| **Enveloppe budgétaire** | *task budget envelope* | Ensemble des plafonds attribués à une tâche à son ouverture (jetons, coût, appels d'outils, itérations, durée d'exécution et durée totale), transmis avec les montants restants à chaque appel descendant. L'atteinte d'un plafond arrête la boucle en état sûr et déclenche l'escalade prévue; elle n'est jamais rapportée comme un succès. Voir les sections 7.8 et 10.6. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Équipe rouge** | *red team* | Équipe indépendante de l'équipe de développement qui attaque un agent comme le ferait un adversaire : détournement d'objectif, exfiltration, empoisonnement d'outil et de mémoire, abus de délégation. Le cadre l'exige avant la mise en production des agents de classe modérée ou élevée, puis au moins chaque année. Voir la section 9.9. |
| **Évaluation continue** | *continuous evaluation* | Mesure répétée de la qualité, de la sécurité et du coût d'un agent, avant et pendant la production, en trois paliers : tests de contrats, jeux de trajectoires, y compris adverses, et échantillon du trafic réel. Elle est relancée à chaque changement de modèle, d'invite système ou d'outil, et ses résultats conditionnent l'homologation. Voir la section 10.4. |
| **Évaluation des facteurs relatifs à la vie privée** (EFVP) | *privacy impact assessment (PIA)* | Évaluation exigée par la Loi sur le privé pour tout projet d'acquisition, de développement ou de refonte d'un système d'information impliquant des RP (art. 3.3) et avant toute communication de RP hors du Québec, autres provinces comprises (art. 17)[160]. Le cadre l'exige terminée avant le pilote, avec un inventaire des RP par outil, par délégation et par mémoire. Voir la section 12.2. |
| **Exécutant** | *worker; subagent* | Agent auquel un orchestrateur délègue une sous-tâche et qui rend une synthèse conforme au schéma de retour déclaré, ses livrables volumineux étant transmis par référence. Le cadre limite la délégation à deux niveaux : un exécutant ne délègue pas à son tour sans dérogation. Voir les sections 7.2 et 7.7. |
| **Exécution durable** | *durable execution* | Mode d'exécution dans lequel un moteur persiste l'état d'une tâche hors du processus après chaque transition, de sorte qu'elle reprend où elle s'était arrêtée après une panne, un redéploiement ou une longue attente d'approbation. La persistance n'empêche pas, à elle seule, qu'une action soit répétée : les effets doivent aussi être idempotents. Voir la section 7.4. |
| **FinOps** | *FinOps* | Pratique de gestion financière qui maximise la valeur d'affaires de la technologie et rend les coûts imputables; le cadre FinOps cite la dépense d'IA agentique (par exemple pour la productivité des développeurs) comme pouvant former un périmètre de dépenses *(Scope)* distinct[406, 469]. La spécification FOCUS normalise les données de facturation, pas les indicateurs par agent : le coût par tâche réussie se calcule en joignant ces données à la télémétrie et aux résultats métier. Voir les sections 10.5 et 10.6. |
| **Flux déterministe** | *deterministic workflow* | Séquence prédéterminée (graphe ou machine à états) dont le code fixe le chemin; certaines étapes peuvent appeler un modèle ou un agent borné pour traiter de l'information non structurée, ce qu'on appelle aussi un flux de travail assisté par IA. Anthropic distingue de même les flux de travail, orchestrés par des chemins de code prédéfinis, des agents, où le modèle dirige son propre processus[65]. C'est le patron par défaut du cadre. Voir les sections 3.2 et 7.2. |
| **Garde-fou** | *guardrail* | Contrôle automatisé qui filtre ou valide les entrées, les sorties ou les actions d'un agent : validation de schéma, détection d'injection, masquage des RP et des secrets. Il s'applique à l'entrée, aux appels d'outils, aux réponses d'outils et à la sortie finale. Un garde-fou probabiliste réduit le risque sans l'éliminer et ne remplace jamais un contrôle déterministe. Voir les sections 7.7 et 9.6. |
| **Homologation** | *go-live approval* | Décision consignée au registre qui autorise la mise en production d'un agent à un niveau d'autonomie donné, sur la foi de preuves : rapport d'évaluation, tests de sécurité, EFVP au besoin et grille d'homologation de l'annexe A. Le responsable technique d'un agent ne peut pas l'homologuer. Voir la section 11.5 et l'annexe A. |
| **Humain dans la boucle** (HITL) | *human in the loop* | Mode de supervision dans lequel une personne approuve chaque action en écriture avant son exécution, au moyen d'une approbation liée à l'action exacte; il caractérise le niveau N2. Voir les sections 8.1 et 8.5. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Humain sur la boucle** (HOTL) | *human on the loop* | Mode de supervision dans lequel l'agent agit seul sous des seuils déclarés, tandis qu'une personne supervise par exception, traite les escalades, peut interrompre et revoit a posteriori un échantillon des actions; il caractérise le niveau N3. Au niveau N4, la personne est hors de la boucle d'exécution, mais reste sur la boucle de gouvernance. Voir la section 8.1. |
| **IA fantôme** | *shadow AI* | Usage de l'IA hors de la gouvernance de l'entreprise. Un agent fantôme est un agent créé ou exploité hors du registre, sans propriétaire nommé ni moyen de révocation; le cadre le détecte par un rapprochement mensuel du registre avec des sources indépendantes et le place en quarantaine jusqu'à son inscription ou son retrait. Voir les sections 2.1 et 11.4. |
| **Idempotence** | *idempotency* | Propriété d'une opération dont l'exécution répétée produit le même effet qu'une exécution unique. Le cadre exige, pour toute écriture P2 ou P3, une clé d'idempotence dérivée des identifiants de la tâche et de l'étape, réutilisée à chaque réessai et vérifiée par le service visé; l'en-tête `Idempotency-Key` n'est encore qu'un brouillon de l'IETF (Internet Engineering Task Force)[78]. Voir la section 7.6. |
| **Identité non humaine** | *non-human identity (NHI)* | Identité attribuée à une charge de travail, à un service ou à un agent plutôt qu'à une personne. Dans le cadre, chaque agent possède la sienne, fondée sur un justificatif cryptographique de courte durée émis par la plateforme, jamais partagée ni utilisée par une personne. L'OWASP Non-Human Identities Top 10 (2025) en recense les dix risques principaux, de NHI1 à NHI10[470]. Voir la section 9.2. |
| **Injection d'instructions** | *prompt injection* | Attaque par laquelle un texte placé par un tiers dans un contenu que lit le modèle (page Web, document, réponse d'outil, message d'agent) est interprété comme une consigne; elle est dite indirecte lorsqu'elle n'arrive pas par la personne qui utilise l'agent. Le cadre présume l'injection possible dès qu'un modèle lit du contenu non fiable, comme le recommande le NIST[97]. Voir la section 9.6. |
| **Interopérabilité** | *interoperability* | Capacité de systèmes et d'agents hétérogènes à échanger de l'information et à l'utiliser correctement sans adaptation propre à chaque paire. Le cadre l'examine aux quatre niveaux du Cadre européen d'interopérabilité (EIF, 2017) : juridique, organisationnel, sémantique et technique, sous une gouvernance intégrée[157]. Voir la section 6.1. |
| **Invite** | *prompt* | Texte d'instructions et de contexte fourni à un modèle. L'invite système d'un agent relève de sa mémoire procédurale et se gère comme du code : revue, version, évaluation avant déploiement. Dans MCP, une invite est aussi une primitive serveur, soit un gabarit réutilisable obtenu par `prompts/get`. Voir les sections 5.5 et 6.5. |
| **Jeton** (unité de texte) | *token* | Unité de texte que lit ou produit un modèle de langage; elle sert d'unité de mesure de la consommation et de la facturation de l'inférence. À ne pas confondre avec le jeton d'accès OAuth, qui porte des droits. Voir les sections 10.5 et 10.6. |
| **Jeton contraint à l'émetteur** | *sender-constrained token* | Jeton d'accès lié à une clé ou à un certificat que seul son détenteur légitime peut présenter : mTLS (RFC 8705, revendication `cnf` « `x5t#S256` ») dans le maillage de services, ou DPoP (RFC 9449, preuve JWT à chaque requête) hors du maillage. La RFC 9700 recommande cette contrainte[175]; le cadre l'exige pour tout jeton qui donne accès à un outil P2 ou P3 ou que détient un agent de classe élevée. Voir la section 9.3. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Jeton d'approbation** | *approval token* | Jeton signé par le service d'approbation adossé au fournisseur d'identité, qui contient au minimum l'empreinte de l'action approuvée, l'identifiant pseudonymisé de l'approbateur, les identifiants de la tâche et de l'agent, une date d'expiration et un identifiant à usage unique. La passerelle recalcule l'empreinte avant l'exécution; le cadre en limite la validité à 15 minutes. Voir la section 8.5 et l'annexe C. |
| **Jeton délégué** | *delegated token* | Jeton d'accès obtenu à chaque saut par échange de jetons (RFC 8693); le cadre l'exige de courte durée et à audience unique. Il désigne le mandant ( `sub` ) et l'agent courant ( `act` ), avec un `act` imbriqué par acteur antérieur[70]. Sa portée ne dépasse jamais les droits effectifs, soit droits du mandant ∩ portée de l'agent ∩ portée de la tâche (choix du cadre), intersection appliquée par le serveur d'autorisation à chaque échange. Voir la section 9.3 et l'annexe C. |
| **Journal d'audit** | *audit log* | Enregistrement inaltérable et signé, distinct des traces, de chaque action d'agent : mandant, agent et version, outil et empreinte de ses arguments, modèle et version, approbation, identifiants de tâche et de trace, règle appliquée par la passerelle. Il sert à la preuve, à l'explication des décisions et à l'enquête. Voir la section 10.3. |
| **Loi 25** | *Law 25; Act to modernize legislative provisions as regards the protection of personal information* | Loi modernisant des dispositions législatives en matière de protection des renseignements personnels (L.Q. 2021, c. 25), en vigueur dans son ensemble depuis le 22 septembre 2024, dernière étape (droit à la portabilité)[7, 56]. Elle modifie la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1, « Loi sur le privé ») et la Loi sur l'accès aux documents des organismes publics et sur la protection des renseignements personnels (RLRQ, c. A-2.1, « Loi sur l'accès »). Voir la section 12.2. |
| **Mandant** | *principal* | Personne, application ou agent au nom duquel une tâche est exécutée; pour un déclencheur système, identité du service et de son propriétaire nommé. Le mandant est établi à l'entrée, transporté dans chaque appel par le jeton délégué et consigné au journal d'audit; les droits d'un agent ne dépassent jamais les siens. Voir les sections 5.2 et 9.3. |
| **MCP** (Model Context Protocol) | *Model Context Protocol* | Protocole ouvert d'intégration verticale qui relie un agent à des outils, à des ressources et à des invites exposés par des serveurs; l'hôte, soit l'application d'IA, crée un client MCP par serveur. Annoncé par Anthropic le 25 novembre 2024 et confié à l'AAIF le 9 décembre 2025, il est versionné par date[20, 34]. Le cadre retient la révision 2026-07-28, sans état, exposée par Streamable HTTP en environnement serveur (choix du cadre). Voir la section 6.5. |
| **Mémoire d'agent** | *agent memory* | Ce qu'un agent conserve au-delà d'un appel au modèle. La taxonomie CoALA distingue une mémoire de travail et trois mémoires à long terme : épisodique (expériences passées), sémantique (connaissances) et procédurale (savoir-faire) [100]; le cadre limite cette dernière aux invites système, aux contrats de compétences et aux flux d'outils validés. Le contexte du modèle n'est pas une mémoire, et la mémoire procédurale se gère comme du code. Voir la section 5.5. |
| **Modèle** | *model; large language model (LLM)* | Composant probabiliste, le plus souvent un grand modèle de langage, qui produit une sortie à partir d'une invite. Un agent désigne ses modèles par un alias logique et ne les appelle que par la passerelle de modèles; la version réellement servie est consignée dans la télémétrie, et tout changement de modèle déclenche une réévaluation. Voir les sections 5.2 et 11.5. |
| **Moindre agence** | *least agency* | Principe de l'OWASP selon lequel les outils et l'autonomie d'un agent se limitent à ce que la tâche exige : un comportement agentique déployé sans nécessité élargit la surface d'attaque sans ajouter de valeur[28]. Il complète le moindre privilège dans le principe PRIN-03. Voir les sections 4.1 et 8.1. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Niveau d'autonomie** | *autonomy level* | Plafond déclaré au registre, de N0 à N4, qui fixe le rôle de la personne et ce que l'agent peut faire sans approbation : N0 automatisation déterministe, sans modèle; N1 consultatif, sans écriture; N2 exécution approuvée (HITL); N3 autonomie bornée et supervisée (HOTL); N4 autonomie étendue sous ODD certifié. NX, l'autonomie non bornée, est interdite. Le niveau ne dépend ni du nombre d'agents ni de la capacité du modèle. Voir la section 8.1. |
| **OAuth 2.0** et **OAuth 2.1** | *OAuth 2.0; OAuth 2.1* | Cadre d'autorisation de l'IETF. Le cadre se réfère à OAuth 2.0 profilé par la RFC 9700 (BCP 240, janvier 2025). OAuth 2.1 reste un Internet-Draft, dont la version -16 date de septembre 2026[175, 176] : le cadre s'aligne sur son profil (PKCE, ni octroi implicite ni octroi par mot de passe) sans le présenter comme une norme publiée. Voir les sections 6.3 et 9.3. |
| **OBO** | *On-Behalf-Of* | Patron de délégation par lequel un service obtient un jeton pour agir au nom d'un utilisateur; ce n'est pas une norme. Le flux OBO de Microsoft Entra, par exemple, repose sur l'octroi `jwt-bearer` et non sur la RFC 8693[326], que le cadre retient comme référence normative en profilant au catalogue les variantes des fournisseurs. Voir la section 9.3. |
| **OpenTelemetry** | *OpenTelemetry (OTel)* | Projet de la CNCF qui normalise la production et l'export des traces, des métriques et des journaux (API, SDK, protocole OTLP). Ses conventions sémantiques GenAI, qui nomment les spans et les attributs des modèles, des agents et des outils, sont au niveau de stabilité Development : un nom peut y changer sans processus de dépréciation[181, 188]. Le cadre en épingle donc une version. Voir la section 10.1. |
| **Orchestrateur** | *orchestrator* | Composant déterministe, agentique ou hybride qui décompose une demande, affecte les tâches à des agents ou à des outils, suit l'état, gère la reprise et consolide les résultats. Il choisit un chemin, mais n'accorde ni n'élargit aucun droit. Voir les sections 5.2 et 7.2. |
| **Outil** | *tool* | Capacité exposée à un agent (fonction, requête, action), décrite par un contrat d'entrée et de sortie et exécutée par un serveur MCP ou un adaptateur; un outil n'a aucune autonomie de décision. Règle du cadre : une cible aux entrées et aux sorties définies est un outil, même si elle emploie un modèle en interne. Chaque outil reçoit un palier au catalogue. Voir les sections 6.2 et 6.5. |
| **OWASP Top 10 agentique** (ASI) | *OWASP Top 10 for Agentic Applications* | Référentiel de menaces publié le 9 décembre 2025 par l'OWASP GenAI Security Project, de ASI01 (détournement de l'objectif de l'agent) à ASI10 (agents dévoyés)[28]. Le cadre en fait la base de la modélisation des menaces, obligatoire pour les agents de classe modérée ou élevée. Voir la section 9.5. |
| **Palier d'outil** | *tool risk tier* | Classement d'un outil selon l'effet de ses appels : P0 lecture publique; P1 lecture interne ou sensible; P2 écriture réversible ou compensable, avec approbation au-delà d'un seuil; P3 action critique, externe ou irréversible, jamais exécutée seule par un agent. Le palier est attribué au catalogue après revue, jamais déduit des annotations du serveur; un outil d'écriture sans compensation déclarée est classé P3. Voir la section 8.3. |
| **Passage de jeton** (ou relais de jeton) | *token passthrough* | Fait de retransmettre tel quel à un autre service un jeton reçu. La spécification d'autorisation MCP l'interdit[209], et le cadre étend l'interdiction à tout agent, outil ou serveur : chaque audience exige un nouveau jeton, obtenu par échange de jetons. Voir les sections 6.5 et 9.3. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Passerelle d'agents** | *agent gateway* | Mandataire inverse placé devant tous les serveurs MCP et tous les pairs A2A, pour le trafic entrant comme sortant, qui sert de point d'application des politiques. À chaque appel, elle authentifie l'agent et le mandant, vérifie le catalogue, autorise, applique les garde-fous, vérifie l'approbation, limite le budget, injecte les justificatifs en aval, filtre la sortie, puis trace et journalise. Voir les sections 5.2 et 9.4. |
| **Passerelle de modèles** | *model gateway; LLM gateway* | Point de passage obligatoire de tout appel d'inférence : elle centralise les identifiants des fournisseurs, résout les alias logiques, assure le routage, le repli, le cache et les quotas de jetons, et impute les coûts. Aucun agent ne détient de clé de fournisseur de modèles ni n'appelle un fournisseur directement. Voir la section 5.2. |
| **Patron d'orchestration** | *orchestration pattern* | Topologie de coordination déclarée au registre parmi les huit patrons autorisés : flux déterministe, chaîne séquentielle, routage et transfert, parallélisation, orchestrateur et exécutants, évaluateur-optimiseur, chorégraphie événementielle et agent unique outillé; le clavardage de groupe en est une variante encadrée. Le patron est distinct du niveau d'autonomie. Voir les sections 7.2 et 7.3. |
| **Plan transversal** | *cross-cutting plane* | Ensemble de services communs fournis à toutes les couches de l'architecture de référence : A Identité et sécurité; B Observabilité, évaluation et FinOps; C Gouvernance et registre. L'équipe plateforme les fournit une fois; un projet n'en déploie pas d'équivalent parallèle sans dérogation. Voir la section 5.3. |
| **Point d'application des politiques** (PEP) | *policy enforcement point* | Composant logique de la confiance zéro qui ouvre, surveille et termine les connexions selon la décision du moteur de politiques (PE), l'administrateur de politiques (PA) établissant ou coupant le chemin[112]. Dans le cadre, la passerelle d'agents et la passerelle de modèles sont des PEP, et le service de politiques tient le rôle de PE. Voir la section 9.1. |
| **Point de contrôle** | *checkpoint; gate* | (1) Instantané persistant de l'état complet d'une tâche, pris à chaque transition par le moteur d'exécution durable; il constitue une frontière de confiance et se protège comme une donnée de production. (2) Porte du cycle de vie d'un agent, de la proposition au retrait, dont le franchissement est consigné au registre avec ses preuves. Voir les sections 7.4 et 11.5. |
| **Propriétaire métier** (parrain) | *business owner; sponsor* | Personne nommée qui répond de la finalité, des résultats, des effets et du retrait d'un agent; elle demande son niveau d'autonomie, le finance et atteste au moins tous les 12 mois, tous les 6 mois pour la classe élevée, qu'il est encore requis. Ce n'est jamais une équipe ni un fournisseur. Le rôle reprend la notion de parrain de Microsoft Entra Agent ID, sans dépendre du produit. Voir la section 11.1. |
| **Registre d'entreprise** | *enterprise agent registry* | Inventaire faisant autorité des agents et des serveurs MCP qui agissent dans le périmètre de l'entreprise, qu'ils soient internes, intégrés à un logiciel-service ou exploités par un partenaire. Chacun y a une fiche (propriétaires, finalité, classe de risque, niveau d'autonomie, outils et paliers, modèles, données, état du cycle de vie); sans fiche complète, aucun justificatif de production. Il est distinct du registre officiel MCP, en préversion, qui ne prend pas en charge les serveurs privés[43]. Voir la section 11.4 et l'annexe B. |
| **Règlement européen sur l'IA** (RIA) | *EU Artificial Intelligence Act (AI Act)* | Règlement (UE) 2024/1689, en vigueur depuis le 1er août 2024 et modifié par le règlement (UE) 2026/1744, qui reporte au 2 décembre 2027 les obligations des systèmes à haut risque de l'annexe III et au 2 août 2028 celles de l'annexe I[58, 61]. Il vise aussi les fournisseurs et les déployeurs établis hors de l'Union lorsque les sorties du système y sont utilisées. Voir la section 12.4. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Renseignements personnels** (RP) | *personal information* | Renseignements qui concernent une personne physique et permettent de l'identifier, au sens de la Loi sur le privé et de la Loi sur l'accès; un renseignement dépersonnalisé demeure un renseignement personnel. Le cadre traite comme des RP les inférences qu'un agent produit sur une personne et les plongements vectoriels *(embeddings)* calculés à partir de RP. Voir la section 12.2. |
| **Responsable de la protection des renseignements personnels** (RPRP) | *person in charge of the protection of personal information* | Fonction exercée par la personne ayant la plus haute autorité dans l'entreprise, qui peut la déléguer par écrit (art. 3.1 de la Loi sur le privé)[160]. Le cadre le consulte dès le début de tout projet d'agent impliquant des RP et lui confie l'encadrement des EFVP et des incidents de confidentialité. Voir la section 11.1. |
| **Ressource** | *resource* | Primitive MCP : donnée contextuelle adressée par URI, lue par `resources/read` et pouvant être mise en cache; pour le cadre, cette lecture n'a aucun effet de bord. Elle convient lorsque l'entité à charger est connue d'avance; une recherche, un calcul ou une écriture relèvent d'un outil. Voir la section 6.5. |
| **Saga** | *saga* | Patron défini par Garcia-Molina et Salem en 1987[284], qui remplace une transaction globale par une suite de transactions locales, chacune appariée à une compensation; les étapes compensables précèdent le pivot, point de non-retour, que suivent des étapes réessayables[67]. Le cadre l'exige pour toute tâche qui écrit dans plusieurs systèmes d'enregistrement sans transaction commune. Voir la section 7.5. |
| **Serveur MCP** | *MCP server* | Programme qui expose des outils, des ressources et des invites par MCP; c'est un adaptateur sans état cognitif, qui ne raisonne pas. Dans l'entreprise, tout serveur MCP est inscrit au registre et au catalogue, publié derrière la passerelle d'agents et traité comme un domaine de sécurité distinct. Voir les sections 6.5 et 11.4. |
| **SPIFFE**, **SPIRE** et **SVID** | *Secure Production Identity Framework For Everyone; SPIFFE Runtime Environment; SPIFFE Verifiable Identity Document* | Standard et mise en œuvre de référence de l'identité de charge de travail, projets diplômés de la CNCF. Un SPIFFE ID prend la forme `spiffe://domaine-de-confiance/chemin` ; le justificatif, ou SVID, existe en X.509-SVID, à privilégier et renouvelé automatiquement, et en JWT-SVID, de courte durée et redemandé au besoin; la Workload API délivre les deux sans secret préalable[322, 471]. Voir la section 9.2. |
| **Substitution après approbation** | *rug pull* | Attaque par laquelle l'éditeur d'un serveur ou d'un outil en modifie les définitions une fois celui-ci approuvé, par exemple pour y glisser de nouvelles consignes. La passerelle d'agents la neutralise en comparant à chaque appel l'empreinte des définitions présentées à celle qui est épinglée au catalogue. Voir les sections 6.5 et 9.8. |
| **Système de management de l'IA** (SMIA) | *AI management system* | Système de management dont ISO/IEC 42001:2023 spécifie les exigences selon la structure harmonisée des normes de systèmes de management (articles 4 à 10), complétée par 38 mesures en annexe A; la norme est certifiable par tierce partie (ISO/IEC 42006:2025)[450, 451]. À ne pas confondre avec le brouillon IETF WIMSE « AI Identity Management System » (AIMS), qui porte sur l'identité des agents. Voir la section 12.5. |
| **Système d'enregistrement** | *system of record* | Système qui fait foi pour une donnée de l'entreprise : ERP, CRM, système de dossiers, entrepôt de données, logiciel-service. Un agent n'y écrit que par une interface qui applique les contrôles métier de ce système, jamais par un accès direct aux tables. Voir la section 5.2. |
| **Système d'IA** | *AI system* | Selon l'article 3(1) du RIA, système automatisé conçu pour fonctionner à différents niveaux d'autonomie, qui peut faire preuve d'adaptabilité après son déploiement et qui déduit, à partir des entrées qu'il reçoit, la manière de générer des sorties (prédictions, contenus, recommandations ou décisions) pouvant influencer des environnements physiques ou virtuels[61]. Le cadre considère tout agent comme un système d'IA. Voir la section 12.4. |

| Terme (sigle) | Équivalent anglais | Définition |
|---|---|---|
| **Tâche** (A2A) | *task* | Unité de travail A2A créée par l'agent serveur, qui lui attribue son identifiant (`taskId`); `contextId` regroupe les tâches et les messages d'une même interaction. Une tâche suit une machine à huit états de cycle de vie (l'énumération compte neuf valeurs avec `TASK_STATE_UNSPECIFIED`), dont deux états interrompus (`INPUT_REQUIRED`, `AUTH_REQUIRED`) et quatre états terminaux, et produit des artefacts composés de parties *(Part)*[68]. Voir la section 6.6. |
| **Traçage** | *distributed tracing* | Reconstitution de bout en bout du chemin d'une demande au moyen de traces OpenTelemetry, faites de spans reliés par un même contexte W3C Trace Context (en-tête `traceparent`), défini pour HTTP; le cadre exige de le propager aussi dans le champ `_meta` de MCP, dans A2A et dans l'extension CloudEvents Distributed Tracing[103, 162, 253]. Le `traceparent` n'est pas un identifiant métier, et la trace ne remplace pas le journal d'audit. Voir la section 10.1. |
| **Transfert** | *handoff* | Cession explicite du contrôle d'une session, avec son contexte utile, d'un agent source vers un agent cible mieux qualifié; l'agent source se retire. Le transfert vise une liste fermée de destinataires et porte le mandant, pas tout l'historique. Voir la section 7.2. |
| **Triade létale** | *lethal trifecta* | Combinaison, nommée par Simon Willison, de l'accès à des données privées, de l'exposition à du contenu non fiable et de la capacité de communiquer vers l'extérieur, qui rend l'exfiltration possible[354]. La « règle de deux » de Meta en tire une règle de session : au plus deux des trois propriétés sans supervision[307]. Voir la section 9.6. |

# F Validation des sources et des ébauches

Cette annexe rend compte de la vérification qui fonde la version 1.0 : comment les 121 références de la recherche documentaire ont été validées, ce que la vérification a révélé, et quelles affirmations des ébauches ont été corrigées ou retirées. Elle permet à tout lecteur de retracer l'origine d'un fait et le degré de confiance qu'on peut lui accorder.

## F.1 Méthode

La vérification s'est déroulée en trois passes, les 27 et 28 octobre 2026.

1. **Validation référence par référence.** Chacune des 121 références de la recherche documentaire a fait l'objet d'une tentative d'ouverture; pour les 13 pages bloquées, payantes ou redirigées, on s'est limité au résumé public ou à une source primaire. On a consigné son accessibilité, son éditeur, sa date et sa catégorie de crédibilité, puis confronté chaque affirmation qui la citait au contenu réel de la page (427 liens affirmation-source au total). Lorsqu'une page n'appuyait pas une affirmation, une source primaire a été recherchée pour la confirmer ou la réfuter.
2. **Vérification thématique.** Onze vérifications ont confronté les affirmations des quatre ébauches aux textes primaires : MCP; A2A et protocoles connexes; plateformes et fondations; identité; sécurité; observabilité, contrats et événements; orchestration; autonomie; droit québécois et canadien; référentiels internationaux; économie et données de marché. Elles ont aussi recueilli les faits complémentaires intégrés au cadre.
3. **Audit final.** Le 28 octobre 2026, chacune des 428 références alors citées dans le corps du cadre a été rouverte à sa source et confrontée, affirmation par affirmation, aux passages qui s'y appuient (1 409 affirmations examinées). L'identité de chaque référence (auteurs, titre, date, éditeur), sa catégorie et son statut à cette date ont été contrôlés, et les écarts les plus graves ont été recontrôlés par un second examinateur indépendant, qui a réfuté plusieurs reclassements proposés. En parallèle, tous les chapitres et annexes ont été relus pour la cohérence interne, l'exactitude factuelle et juridique, la formulation des exigences et la langue. Les corrections retenues ont été intégrées au texte; 49 sources ont été ajoutées au registre, et le texte des exigences, les échelles et les renvois ont été harmonisés. Après l'intégration de ces corrections, l'annexe G compte 473 références, toutes citées dans le corps du cadre. Les arbitrages d'architecture et de gouvernance relevés lors de cet audit ont également été tranchés et intégrés à la présente version.

**Tableau 66 — Catégories de crédibilité des sources**

| Catégorie | Définition | Usage dans le cadre |
|---|---|---|
| A | Source primaire ou officielle : organismes de normalisation et leurs dépôts (IETF, W3C, ISO, NIST, OWASP, CNCF, OpenTelemetry, Linux Foundation et sites des projets), textes législatifs et organismes de réglementation, documentation officielle d'un éditeur sur son propre produit, articles scientifiques d'auteurs identifiables, communiqués des firmes d'analystes. | Appui de toute exigence et de tout fait. |
| B | Source secondaire reconnue : grande presse spécialisée, cabinets juridiques, experts reconnus. | Appui d'un fait de contexte, jamais seul pour une exigence. |
| C | Blogue de positionnement, agrégateur, site inconnu ou contenu généré en série. | Jamais cité; remplacé par une source A ou B, ou fait retiré. |

## F.2 Bilan chiffré

Les décomptes ci-dessous portent sur les 121 références et sur les 427 liens affirmation-source de la recherche documentaire.

**121**
références validées une à une, dont 108 accessibles et 13 bloquées, payantes ou redirigées

**61**
références de catégorie C (50 %), dont 33 présentant les marques d'un contenu généré en série

**88**
références remplacées (71) ou retirées (17); 33 conservées comme sources A ou B

**705**
sources admissibles (A ou B) recensées pour la version finale, dont 632 de catégorie A (primaires ou officielles); 49 ont été ajoutées lors de l'audit final

**Tableau 67 — Verdicts sur les 427 liens affirmation-source de la recherche documentaire**

| Verdict | Nombre | Part | Signification |
|---|---|---|---|
| Appuyée | 125 | 29 % | La source citée confirme l'affirmation telle qu'écrite. |
| Partiellement appuyée | 214 | 50 % | Le fond est juste, mais un détail (date, chiffre, version, portée) diffère : l'énoncé a été corrigé. |
| Non appuyée | 55 | 13 % | La source ne contient pas l'affirmation : source primaire trouvée ou fait retiré. |
| Contredite | 14 | 3 % | La source ou une source primaire dit le contraire : fait corrigé. |
| Invérifiable | 19 | 4 % | Aucune source crédible trouvée : fait retiré ou présenté comme choix interne du cadre. |

**À RETENIR**

Le fond technique des ébauches était solide, mais plus de sept affirmations sur dix (302 sur 427) exigeaient une correction de détail, une meilleure source ou un retrait. Les erreurs récurrentes : versions de protocoles dépassées, chiffres de marché attribués à la mauvaise firme, obligations légales mal rattachées à un article, allégations commerciales présentées comme des normes et seuils chiffrés sans source.

## F.3 Principales corrections apportées aux ébauches

Le tableau suivant recense les corrections les plus importantes. Les sources indiquées appuient la version retenue.

**Tableau 68 — Principales corrections factuelles**

| # | Affirmation des ébauches | Version retenue dans le cadre |
|---|---|---|
| 1 | MCP 2026-07-28 « impose » OAuth 2.1, norme publiée. | L'autorisation est facultative dans MCP; le cadre la rend obligatoire. OAuth 2.1 reste un Internet-Draft de l'IETF; on exige OAuth 2.0 selon la RFC 9700, aligné sur le profil OAuth 2.1[176, 209]. |
| 2 | Champs `x-enterprise-*` dans les annotations d'un outil MCP. | Hors du schéma (cinq propriétés seulement, dont quatre indices non fiables). Le palier, le seuil d'approbation et la compensation sont inscrits au catalogue d'entreprise (choix du cadre, non prescrit par le schéma MCP) [201]. |
| 3 | La passerelle doit supprimer tout champ `_meta`. | La version du protocole et les capacités du client y sont obligatoires, et `traceparent`, `tracestate` et `baggage` y sont réservés au contexte de trace; on conserve ces clés, on filtre les clés non reconnues et on ne fonde aucune autorisation sur `_meta` [162]. |

| # | Affirmation des ébauches | Version retenue dans le cadre |
|---|---|---|
| 4 | Quatre vecteurs d'attaque selon Akamai; rejet 400/403 en cas d'écart d'en-têtes. | L'analyse d'Akamai décrit cinq zones de risque; la concordance en-têtes/corps est déjà exigée par la spécification (HTTP 400, erreur -32020) [190, 203]. |
| 5 | MCP exige des jetons liés (mTLS ou DPoP) de 5 à 15 minutes. | MCP utilise des jetons porteurs[209]; la liaison à l'émetteur et la durée courte sont une politique du cadre fondée sur les RFC 8705[328] et 9449[213]. |
| 6 | Carte d'agent à `/.well-known/agent.json`, champs `url` et `authentication`, méthode `tasks/sendSubscribe`. | Formes antérieures à la version 1.0. A2A 1.0 : `agent-card.json`, `supportedInterfaces`, `securitySchemes`, `SendStreamingMessage`, états `TASK_STATE_*` [68]. |
| 7 | Spécification A2A « gelée » le 12 mars 2026. | Version 1.0.0 publiée le 12 mars 2026, correctif 1.0.1 le 28 mai 2026 (release GitHub du projet); A2A annoncé comme projet de l'AAIF le 17 août 2026 (billet du projet du 27 août 2026)[5, 29, 472]. |
| 8 | AGNTCY fait partie de la pile de l'AAIF; SLIM est résistant au quantique. | AGNTCY est un projet de la Linux Foundation dont la candidature à l'AAIF est ouverte; la proposition qualifie SLIM de « quantum-safe » sans nommer de suite MLS post-quantique (SLIM met en œuvre MLS, RFC 9420), de sorte que son caractère post-quantique n'est pas démontré[37, 269]. |
| 9 | Copilot Studio : MCP en disponibilité générale visée en octobre 2026. | MCP est en disponibilité générale dans Copilot Studio depuis le 29 mai 2025[300]. |
| 10 | Une passerelle ajoute moins de 5 ms; le coupe-circuit confine « en millisecondes ». | Allégations commerciales divergentes (TrueFoundry : « typiquement » moins de 5 ms dans sa FAQ, +7 à +12 ms à son propre banc d'essai); aucun seuil chiffré n'est retenu sans mesure interne (P50/P99, politiques actives)[143, 144]. |
| 11 | Délégation limitée à un niveau et sept sous-agents : règles générales. | Contraintes du produit Agentforce; la profondeur maximale de deux niveaux est un choix du cadre[49]. |
| 12 | Attribut `gen_ai.agent_version` ; opération `handoff` ; contenu jamais dans les attributs de span. | Nom exact `gen_ai.agent.version` (ajouté en v1.40.0); aucune valeur `handoff` dans `gen_ai.operation.name` (v1.41.0); contenu en attributs facultatifs (*opt-in*) depuis la version 1.37.0; conventions au niveau « Development », à épingler[119, 180]. |
| 13 | Indicateurs d'agent « au format FOCUS ». | FOCUS normalise les données de facturation (version 1.4); aucune de ses colonnes ne porte d'indicateur par agent, que l'organisation calcule par jointure avec sa propre télémétrie[410, 463]. |
| 14 | Le traitement exactement une fois de Kafka empêche les doubles paiements. | La garantie vaut entre sujets Kafka; pour tout effet externe, le système cible doit coopérer, par exemple au moyen d'une clé d'idempotence qu'il vérifie[140]. |
| 15 | Un bus d'événements réduit la latence de coordination de 70 à 90 %. | Chiffre sans source primaire : retiré; seul l'avantage qualitatif de l'abonnement sur l'interrogation est retenu[262]. |
| 16 | Multiagent : +81 % et −70 % (Google), 3 à 10 fois plus de jetons. | +80,9 % (Finance-Agent), −39 % à −70 % (PlanCraft), amplification des erreurs de 17,2× sans vérification centrale; 3 à 10× par rapport à l'agent unique et environ 15× par rapport à une conversation sont deux mesures distinctes[17, 273, 275]. |
| 17 | Firecracker : environ 100 000 lignes, six périphériques virtio. | Environ 50 000 lignes de Rust (2020), quatre types de périphériques émulés (réseau et bloc virtio, port série, contrôleur de clavier i8042 partiel), moins de 5 Mio par microVM, démarrage sous 125 ms[363]. |
| 18 | gVisor impose un surcoût d'E/S de 10 à 30 %. | Aucune fourchette publiée; le coût dépend des appels système : mesurer sur la charge réelle[361]. |

| # | Affirmation des ébauches | Version retenue dans le cadre |
|---|---|---|
| 19 | Taux de réussite de 84 % du détournement d'objectif. | Chiffre d'un banc d'essai précis (Agent Security Bench, 84,30 %), cité seulement dans ce contexte[359]. |
| 20 | Les identités non humaines dépassent les humaines de 20 contre 1. | Enquête de fournisseur la mieux documentée : 82 identités machines par humain (CyberArk, 2025); chaque organisation mesure son propre ratio[11]. |
| 21 | Loi 25 : avis à la CAI en 72 heures (art. 3.2 ou 3.5). | Avis « avec diligence » en cas de risque de préjudice sérieux (art. 3.5 de la Loi sur le privé); registre (art. 3.8) conservé cinq ans selon le règlement; 72 heures n'est qu'une cible interne[56, 460]. |
| 22 | Décisions automatisées au secteur public : article 63.1. | Article 65.2 de la Loi sur l'accès[318]; l'article 63.1 porte sur les mesures de sécurité[56]. |
| 23 | Amendes pénales de 1 000 à 10 000 $ pour une personne; amendes de plus de 500 000 $ déjà prononcées; sanction de 5 000 $ en vertu de la Loi 25. | De 5 000 à 100 000 $ pour une personne physique (art. 91 de la Loi sur le privé); aucune amende de plus de 500 000 $ n'est confirmée; les 5 000 $ visent une décision de la Cour supérieure (art. 342 C.p.c.) sur des citations inventées par l'IA[458]. |
| 24 | Article 17 : « analyse d'impact relative au transfert »; protection « équivalente ». | EFVP et entente écrite; critère de protection « adéquate »; « hors Québec » s'entend de tout lieu extérieur au Québec, y compris, selon l'interprétation du cadre, les autres provinces[416]. |
| 25 | Règlement européen : haut risque applicable le 2 août 2026; s'applique dès qu'un agent « touche » des utilisateurs de l'UE. | Échéances reportées par le règlement (UE) 2026/1744 (annexe III : 2 décembre 2027; annexe I : 2 août 2028); critère de l'article 2 : utilisation des sorties dans l'Union[58, 61]. |
| 26 | NIST MANAGE 3.1 et 3.2 couvrent le coupe-circuit; MEASURE 2.7 la surveillance des hallucinations. | Coupe-circuit : MANAGE 2.4; déclassement : GOVERN 1.7; MEASURE 2.7 porte sur la sécurité et la résilience; la surveillance en production relève de MEASURE 2.4[74]. |
| 27 | « Seulement 13 % ont la gouvernance adéquate » attribué à McKinsey; 150 000 agents par entreprise attribués à un blogue. | Les deux chiffres proviennent de Gartner (communiqué du 28 avril 2026)[2]. |
| 28 | Les dépenses d'IA des entreprises ont bondi de 320 %. | Chiffre sans source, qui semble provenir d'une lecture erronée du facteur 3,2 (environ +220 %) : 37 G$ US en 2025 contre 11,5 G$ US en 2024 (Menlo Ventures, 9 décembre 2025)[16]. |
| 29 | Petits modèles 10 à 30 fois moins coûteux (arXiv 2506.02142); Phi-3.5 « 98 % de calcul en moins ». | Référence exacte : arXiv 2506.02153 (coût de calcul, non prix facturé); le « 98 % » est introuvable et retiré[403, 473]. |
| 30 | Trois échelles d'autonomie incompatibles (L0–L5, N0–N4, L0–L4) et seuils chiffrés (60 s, 5 min, 1 h). | Échelle unique N0 à N4 et niveau NX interdit, fondée sur Feng et al., Gartner, AWS et l'IMDA (Infocomm Media Development Authority, Singapour); les seuils deviennent des paramètres internes approuvés par le comité[76, 83]. |
| 31 | Saga : un plantage entre la journalisation et l'action ne déclenche aucune compensation. | Une étape à l'état incertain est traitée comme possiblement exécutée; sa compensation, idempotente, doit pouvoir s'exécuter sans risque[286]. |
| 32 | Mémoire à quatre niveaux « inspirée de Tulving ». | Taxonomie à quatre types (travail, épisodique, sémantique, procédurale) issue de CoALA, qui la reprend de l'architecture Soar[100]. |

## F.4 Registre des 121 références de la recherche documentaire

Légende des verdicts : ✓ appuyée · ◐ partiellement appuyée · *X* non appuyée ou contredite · ? invérifiable · — aucune affirmation associée à la référence. La colonne *n* reprend le numéro de la référence dans la recherche documentaire. Décision : *conservée* = source A ou B citée là où elle appuie un fait; *remplacée* = remplacée par une source primaire; *retirée* = sans valeur probante pour le cadre.

**Tableau 69 — Registre de validation des références de la recherche documentaire**

| n | Source (titre réel, éditeur) | Cat. | Accès | Affirmations | Décision |
|---|---|---|---|---|---|
| 1 | Enterprise Agentic AI Architecture Design Guidance (Part 1)<br>Architecture & Governance Magazine | B | accessible | ✓5 ◐10 ✗3 | conservée |
| 2 | Enterprise Agentic AI Reference Architecture (2026)<br>Triotech Systems | C | accessible | ✓2 ◐2 | retirée |
| 3 | A Framework for Architecting Agent Control Plane<br>MuleSoft | B | accessible | ✓3 ◐3 ✗3 | conservée |
| 4 | Microsoft Copilot Studio vs. Salesforce Agentforce: Which AI Agent Platform is Better for Enterprises?<br>Artic Consulting | C | accessible | ◐4 | remplacée |
| 5 | Agentic AI Architecture Framework for Enterprises: The Complete 2026 Design and Governance Guide<br>NextAgile | C | accessible | ◐4 ✗1 ?9 | remplacée |
| 6 | AI FinOps Explained: AI Cost Optimization Guide for 2026<br>AvePoint | C | accessible | ✓1 ◐5 ✗2 | remplacée |
| 7 | Governing AI Agents Across Multiple Platforms<br>TrueFoundry | B | accessible | ✓2 ◐8 ✗3 | remplacée |
| 8 | Designing agentgateway: A Unified High-Performance Gateway for AI and API Traffic<br>agentgateway.dev | A | accessible | ✓1 ◐2 | conservée |
| 9 | Agent Communication Protocol (ACP) Explained: What It Is and Why It Matters<br>Boldare | C | accessible | ✓1 ◐6 | remplacée |
| 10 | What the Linux Foundation and AAIF Mean for MCP and Agentic AI<br>Blck Alpaca | C | accessible | ✓1 ◐3 ✗2 | remplacée |
| 11 | The next generation of MCP<br>Cloudflare | B | accessible | ✓12 ◐6 ✗2 | remplacée |
| 12 | Specification - Model Context Protocol (MCP)<br>ModelContextProtocol.Info | C | accessible | ✓1 | remplacée |
| 13 | Architecture overview (documentation MCP, révision 2026-07-28)<br>Model Context Protocol | A | accessible | ✓5 ◐1 | conservée |
| 14 | #17: What is A2A and why is it – still! – underappreciated?<br>Turing Post | B | accessible | ✓2 ◐1 | remplacée |
| 15 | All About the A2A Protocol, Now Part of the Agentic AI Foundation<br>rohitghumare.com | C | accessible | ✓10 ◐6 ✗3 ?1 | remplacée |
| 16 | [Project Proposal] AGNTCY #57 (dépôt aaif/project-proposals)<br>GitHub | A | accessible | ✓5 ◐6 | remplacée |
| 17 | AGNTCY: the open standard set to structure the Internet of Agents<br>Splunk | B | accessible | ✓2 ◐2 | remplacée |
| 18 | Autonomous Agentic Event-Driven Systems Architecture<br>Confluent | A | accessible | ✓4 ◐6 | conservée |

| n | Source (titre réel, éditeur) | Cat. | Accès | Affirmations | Décision |
|---|---|---|---|---|---|
| 19 | Event-Driven Architecture for AI Agents (Patterns and Benefits)<br>Atlan | C | accessible | ◐3 | remplacée |
| 20 | The 6 Levels of AI Autonomy (2026): A Practical Framework<br>Agentys | C | accessible | ◐8 ✗10 | remplacée |
| 21 | AI Agent Risk Assessment: What Organizations Need to Evaluate<br>Global AI Certification Council | C | accessible | ✓2 ◐5 ✗4 | remplacée |
| 22 | When to use multi-agent systems (and when not to)<br>Anthropic | A | accessible | ✓6 ◐8 ✗1 | conservée |
| 23 | Single-Agent vs Multi-Agent AI: When to Scale Your Dev Workflow<br>Augment Code | C | accessible | ✓1 | remplacée |
| 24 | The Saga Pattern for Multi-Agent Transactions: Compensating Actions<br>RedLineSoft | C | accessible | ✓11 ◐2 ✗1 | remplacée |
| 25 | AI Agent Orchestration Frameworks: A 2026 Guide<br>Levelop | C | accessible | ✓2 ◐8 ✗2 | remplacée |
| 26 | OWASP Top 10 for Agentic Applications (2026) — fiche de cadre Modulos (MFF-14)<br>Modulos AG | B | accessible | ✓7 ◐5 ✗2 | remplacée |
| 27 | Authentication for AI Agents: OAuth Patterns for Non-Human Identity<br>guptadeepak.com | B | accessible | ✓2 ◐6 ✗2 | remplacée |
| 28 | ISO 42001 vs NIST AI RMF: Which Do You Need in 2026?<br>Fruggr | C | accessible | ◐3 | remplacée |
| 29 | How to sandbox AI agents in 2026: MicroVMs, gVisor & isolation strategies<br>Northflank | B | accessible | ✓1 ◐5 ✗1 | remplacée |
| 30 | Conformité à l'IA et à la Loi 25 du Québec : le guide complet 2026<br>Augure | C | accessible | ◐11 ✗9 ?1 | remplacée |
| 31 | Enterprise Architecture 2030: Navigating Agentic AI Scenarios<br>Gartner | A | payante | ✓1 | conservée |
| 32 | The best AI agent frameworks in 2026<br>LangChain | B | accessible | ◐4 ✗2 | remplacée |
| 33 | Best Agentic AI Platforms for Enterprise Operations (2026 Guide)<br>Shadow Inc. | C | accessible | ✓1 ◐1 ✗2 | remplacée |
| 34 | Multi-Agent AI News - Week of May 19-25, 2026 - Enterprise Orchestration Platforms<br>Suprmind | C | accessible | ◐2 ✗1 ?1 | remplacée |
| 35 | Agentic Integration with SAP, ServiceNow, and Salesforce<br>Microsoft Community Hub | B | accessible | — | retirée |
| 36 | Implement 3 Layers of Oversight for Scaled Agentic AI Architectures (titre non vérifié)<br>Gartner | A | bloquée | ?1 | retirée |
| 37 | AI Agent Sandbox: How to Safely Run Autonomous Agents in 2026<br>Firecrawl | B | accessible | ✓3 ◐1 | conservée |

| n | Source (titre réel, éditeur) | Cat. | Accès | Affirmations | Décision |
|---|---|---|---|---|---|
| 38 | MCP (Model Context Protocol) in 2026: the complete guide for engineering teams<br>Jacar Systems | C | accessible | ✓2 ◐3 ✗1 | remplacée |
| 39 | Multi-Agent Orchestration Patterns: A Production Guide (2026)<br>explainx.ai | C | accessible | ✓2 ◐5 ✗1 | remplacée |
| 40 | Agentforce Interoperability Guide (The Architect's Guide to Agentforce Interoperability)<br>Salesforce | A | accessible | ◐2 | conservée |
| 41 | Levels of Autonomy for AI Agents<br>arXiv | A | bloquée | ✓1 | remplacée |
| 42 | The Five Working Levels of AI Agent Autonomy, and How to Choose Among Them<br>The Inteq Group | C | accessible | ✓1 ◐1 | remplacée |
| 43 | Building Blocks (TOGAF 9.1, Partie IV, chapitre 37)<br>QualiWare Center of Excellence | B | accessible | ◐1 | remplacée |
| 44 | Architecture Building Blocks (ABBs) vs Solution Building Blocks (SBBs)<br>Boldo | C | accessible | — | remplacée |
| 45 | SAP Enterprise Architects' Guide: Using TOGAF® ABBs and SBBs to Deliver Successful SAP S/4HANA Implementations<br>Insight Arc | C | accessible | — | retirée |
| 46 | Ambient Agents and the New Agent Inbox ft. Harrison Chase<br>Inference by Sequoia | B | accessible | ◐7 | remplacée |
| 47 | Introducing ambient agents<br>LangChain | A | accessible | ✓2 ◐2 | conservée |
| 48 | Confluent: The Real-Time Backbone for Agentic Systems<br>Confluent | A | accessible | ◐2 | conservée |
| 49 | Best Code Execution Sandboxes for AI Agents in 2026<br>E2B | A | accessible | ✓1 | conservée |
| 50 | MCP Is Growing Up: The 2026 Roadmap Takes Shape<br>Obot AI | B | accessible | ✓1 ◐1 | remplacée |
| 51 | 5 Best Code Execution Sandboxes for AI Agents<br>Blaxel | C | accessible | — | retirée |
| 52 | TRiSM for Agentic AI: A Review of Trust, Risk, and Security Management in LLM-based Agentic Multi-Agent Systems<br>arXiv | A | accessible | ◐1 | remplacée |
| 53 | AI Agent Protocols: MCP, A2A, ACP, and the Interop Stack<br>AIPrompt20 | C | accessible | ✓1 | remplacée |
| 54 | The AI Agent Memory Architecture Deep Dive: Building Agents That Remember Across Sessions, Devices, and Tools<br>AI Magicx | C | accessible | ✓1 ◐4 ✗1 | remplacée |
| 55 | GraphRAG, AI Agents, and Memory: How Graph Databases Power the Next Wave of AI in 2026<br>FalkorDB | B | accessible | ◐3 | remplacée |

| n | Source (titre réel, éditeur) | Cat. | Accès | Affirmations | Décision |
|---|---|---|---|---|---|
| 56 | Agent Memory Architectures: Vector vs Graph vs Episodic<br>Digital Applied | C | accessible | — | retirée |
| 57 | New in Confluent Intelligence: A2A, Multivariate Anomaly Detection, Vector Search for Cosmos DB, Amazon S3 Vectors, and More<br>Confluent | A | accessible | ◐1 | conservée |
| 58 | Cheap Tokens, Expensive Agents: The 2026 Inference Economics Reckoning<br>Socradata | C | accessible | ◐2 ✗1 ?1 | remplacée |
| 59 | OpenTelemetry GenAI Semantic Conventions: A Practical Guide<br>OpenObserve | C | accessible | ◐4 ✗3 | remplacée |
| 60 | Agent Memory Systems: How AI Agents Remember, Learn, and Stay Coherent Across Time<br>Tresslers Group | C | accessible | ◐1 | remplacée |
| 61 | Avoid Governance Mismatch: Classify AI Agents by Autonomy Level<br>Gartner | A | bloquée | ✓1 ◐1 | conservée |
| 62 | From autonomous cars to autonomous agents: the five levels of AI agent autonomy (titre non confirmé)<br>MIT Media Lab | B | bloquée | ?3 | remplacée |
| 63 | The 5 Levels of Agentic AI (And Why Most Businesses Need Less Autonomy Than They Think) (titre non confirmé)<br>Medium | C | bloquée | — | retirée |
| 64 | The 5 Levels of AI Agent Autonomy: From Copilot to Fully Autonomous (And Where to Start)<br>Pickaxe | C | accessible | ◐1 | remplacée |
| 65 | The Six Levels of Agentic Behavior<br>Vellum | C | accessible | — | retirée |
| 66 | The Top Agentic AI Security Threats You Need to Know in 2026<br>Lasso Security | B | accessible | ◐1 | remplacée |
| 67 | Ambient agents explained: Applications, architecture, and building with ZBrain<br>ZBrain | C | accessible | — | retirée |
| 68 | LIVE: Ambient Agents and the New Agent Inbox ft. Harrison Chase<br>Sequoia Capital | B | accessible | ✓2 | conservée |
| 69 | UX for Agents, Part 2: Ambient<br>LangChain | B | accessible | — | conservée |
| 70 | Why Google's Agent2Agent Protocol Needs Apache Kafka<br>Medium | B | bloquée | — | remplacée |
| 71 | MCP (Model Context Protocol) for Business: The USB-C of AI Agents and Why It Changes Your Stack in 2026<br>NAXIA | C | accessible | — | retirée |
| 72 | The New MCP Specification: What Security Teams Must Prepare For<br>Akamai Security Research | B | accessible | ✓4 ◐3 | conservée |
| 73 | Agent Card Explained: A2A Protocol, JSON & Use Cases<br>AI Growth Agent | C | accessible | ✓2 ◐2 ✗1 | remplacée |

| n | Source (titre réel, éditeur) | Cat. | Accès | Affirmations | Décision |
|---|---|---|---|---|---|
| 74 | Agent communication protocols: A2A vs ACP vs MCP (2026)<br>crystl | C | accessible | — | retirée |
| 75 | What's New in A2A Protocol v1.0<br>A2A Project | A | accessible | — | conservée |
| 76 | A2A v1.0: a builder's guide, part 2 - migration, security, and production<br>Agentic AI Foundation | A | accessible | — | conservée |
| 77 | A2A Agent Card: Structure, Discovery, and Signing<br>Agent2Agent.Info | C | redirigée | ✓1 | remplacée |
| 78 | A2A v1.0 Agent Card Specification Explorer<br>A2A Registry | C | accessible | — | remplacée |
| 79 | AGNTCY Documentation<br>AGNTCY | A | accessible | — | conservée |
| 80 | Beyond Context Sharing: A Unified Agent Communication Protocol (ACP) for Secure, Federated, and Autonomous Agent-to-Agent (A2A) Orchestration<br>arXiv | A | accessible | — | retirée |
| 81 | Four Design Patterns for Event-Driven, Multi-Agent Systems<br>Confluent | A | accessible | ✓1 ◐1 | conservée |
| 82 | MCP vs. REST/HTTP API vs. Kafka: The Architect's Guide to Agentic AI Integration<br>kai-waehner.de | B | accessible | ✓2 ◐5 ✗1 | conservée |
| 83 | Building effective agents<br>Anthropic | A | accessible | ◐1 | conservée |
| 84 | Single Agent vs Multi-Agent: When to Build a Multi-Agent System (titre non confirmé : page inaccessible)<br>Towards Data Science | B | bloquée | — | remplacée |
| 85 | How to Decide When to Use a Single Agent vs a Multi-Agent Team<br>MindStudio | C | accessible | ✓1 | remplacée |
| 86 | Multi-Agent AI Orchestration: A CTO's 2026 Guide<br>KGT Solutions | C | accessible | ✓1 ?1 | remplacée |
| 87 | Top Agent Frameworks To Use in 2026: A Comparison<br>Splunk | C | accessible | ✓2 ◐2 | remplacée |
| 88 | How and when to build multi-agent systems<br>LangChain | B | accessible | — | conservée |
| 89 | Top 9 AI Agent Frameworks in 2026 (titre de la bibliographie; page non lue)<br>Medium | C | bloquée | — | retirée |
| 90 | Conformité Loi 25 – Microsoft, hébergé au Canada (io4 Technologies)<br>io4 Technologies | C | accessible | ✓1 ◐1 | remplacée |
| 91 | Salesforce Agentforce vs Microsoft Copilot Studio: 2026 Comparison<br>Smartbridge LLC | C | accessible | — | retirée |
| 92 | AI Agent Memory Architectures: From Context Windows to Persistent Knowledge<br>Zylos Research | C | accessible | — | retirée |

| n | Source (titre réel, éditeur) | Cat. | Accès | Affirmations | Décision |
|---|---|---|---|---|---|
| 93 | Memory Systems for AI Agents: Practical Implementations (2025-2026)<br>GitHub Gist | C | accessible | — | retirée |
| 94 | SYNAPSE: Empowering LLM Agents with Episodic-Semantic Memory via Spreading Activation<br>arXiv | A | accessible | — | conservée |
| 95 | Architecture – Solo Enterprise for agentgateway docs<br>Solo.io | A | accessible | — | remplacée |
| 96 | OAuth 2.0 Token Exchange: When One Token Isn't the Token You Need (titre non confirmé)<br>Medium | C | bloquée | ?1 | remplacée |
| 97 | OAuth's On-Behalf-Of flow for AI agents<br>WorkOS | B | accessible | ◐2 | remplacée |
| 98 | OAuth 2.0 Extension: On-Behalf-Of User Authorization for AI Agents (brouillon -01)<br>IETF | A | accessible | ◐1 | remplacée |
| 99 | On-Behalf-Of Token Exchange<br>Auth0 | A | accessible | — | conservée |
| 100 | OAuth 2.0 Extension: On-Behalf-Of User Authorization for AI Agents (brouillon -00)<br>IETF | A | accessible | ◐1 | remplacée |
| 101 | AI Agent Code Execution Sandboxes: Isolation from Containers to MicroVMs (titre non confirmé)<br>Medium | C | bloquée | — | remplacée |
| 102 | OWASP Top 10 for Agentic Applications 2026: Key Takeaways & How to Take Action<br>Teleport | B | accessible | — | remplacée |
| 103 | OWASP Non-Human Identities Top 10<br>OWASP Foundation | A | accessible | — | conservée |
| 104 | OWASP Agentic Skills Top 10<br>OWASP Foundation | A | accessible | — | conservée |
| 105 | OWASP GenAI Security Project Releases Top 10 Risks and Mitigations for Agentic AI Security<br>OWASP GenAI Security Project | A | accessible | — | conservée |
| 106 | AI TRiSM: Understanding Gartner's View on Agentic AI Trust<br>Sweet Security | C | accessible | ◐1 ✗1 | remplacée |
| 107 | OpenTelemetry GenAI Semantic Conventions: What's Stable<br>Praesidia | C | accessible | — | remplacée |
| 108 | Semantic Conventions for GenAI agent and framework spans<br>OpenTelemetry | A | accessible | — | conservée |
| 109 | Loi 25 et IA au Québec : guide PME 2026 (« Loi 25 et IA. Les gestes qui comptent. »)<br>Margence inc. | C | accessible | ◐1 | remplacée |

| n | Source (titre réel, éditeur) | Cat. | Accès | Affirmations | Décision |
|---|---|---|---|---|---|
| 110 | Conseil et formation IA — conformité Loi 25 et IA responsable au Québec \| DictIA<br>DictIA Inc. | C | accessible | ✓1 ✗2 | remplacée |
| 111 | Principaux changements aux lois sur la protection des renseignements personnels<br>Commission d’accès à l’information du Québec | A | accessible | — | conservée |
| 112 | Décisions automatisées et Loi 25 : préparer l’information et la révision humaine<br>extensio.ai | C | accessible | ◐1 | remplacée |
| 113 | Mesures applicables lors de l’utilisation de l’intelligence artificielle générative (indication d’application IA-RI-2025-003-OP)<br>Gouvernement du Québec | A | accessible | — | conservée |
| 114 | AI Governance in 2026: A Practical Framework for NIST AI RMF, EU AI Act, and ISO 42001<br>Enterprise Architecture Blog | C | accessible | — | remplacée |
| 115 | NIST AI RMF Continuous Monitoring 2026<br>Bitsight | C | bloquée | — | remplacée |
| 116 | NIST AI RMF: 8-Step Implementation Guide<br>NeuralTrust | C | accessible | — | remplacée |
| 117 | A Guide to AI TRiSM: Trust, Risk, and Security Management<br>Palo Alto Networks | B | accessible | — | conservée |
| 118 | NIST AI RMF Implementation: A Clear 8-Step Plan for 2026<br>Governance Docs LLC | C | accessible | — | remplacée |
| 119 | AI FinOps Became a Real Discipline in 2026. Here's What It Requires.<br>Larridin | C | accessible | — | retirée |
| 120 | AI FinOps 2026: The Definitive Guide to Costs and Value<br>Compresr | C | accessible | ◐2 ✗1 | remplacée |
| 121 | FinOps for AI: How to Control LLM Token Spend Before It Controls Your Budget<br>Varcio | C | accessible | — | remplacée |

# G Références

Liste des sources citées, numérotées dans l'ordre de leur première citation. Toutes sont de catégorie A (primaires ou officielles) ou B (secondaires reconnues) et ont été consultées ou vérifiées au 27 octobre 2026. Les versions des spécifications évoluant rapidement, le catalogue d'entreprise fait foi pour les versions applicables.


[1] Gartner (2025, 26 août). Gartner Predicts 40% of Enterprise Apps Will Feature Task-Specific AI Agents by 2026, Up from Less Than 5% in 2025 [communiqué]. Gartner.
https://www.gartner.com/en/newsroom/press-releases/2025-08-26-gartner-predicts-40-percent-of-enterprise-apps-will-feature-task-specific-ai-agents-by-2026-up-from-less-than-5-percent-in-2025

[2] Gartner (2026, 28 avril). Gartner Identifies Six Steps to Manage AI Agent Sprawl [communiqué]. Gartner.
https://www.gartner.com/en/newsroom/press-releases/2026-04-28-gartner-identifies-six-steps-to-manage-artificial-intelligence-agent-sprawl

[3] Gartner (2025, 25 juin). Gartner Predicts Over 40% of Agentic AI Projects Will Be Canceled by End of 2027 [communiqué]. Gartner.
https://www.gartner.com/en/newsroom/press-releases/2025-06-25-gartner-predicts-over-40-percent-of-agentic-ai-projects-will-be-canceled-by-end-of-2027

[4] Linux Foundation (9 décembre 2025). Linux Foundation Announces the Formation of the Agentic AI Foundation (AAIF), Anchored by New Project Contributions Including Model Context Protocol (MCP), goose and AGENTS.md. Linux Foundation.
https://www.linuxfoundation.org/press/linux-foundation-announces-the-formation-of-the-agentic-ai-foundation

[5] A2A Project (27 août 2026). A New Chapter for A2A: Joining the Agentic AI Foundation.
https://a2a-protocol.org/latest/blog/2026/08/27/a-new-chapter-for-a2a-joining-the-agentic-ai-foundation

[6] Anthropic (Erik S. et Zhang, B.) (19 décembre 2024). Building effective agents. Anthropic. Note de l'éditeur : l'outillage décrit a changé depuis décembre 2024; les principes cités demeurent.
https://www.anthropic.com/engineering/building-effective-agents

[7] Commission d'accès à l'information du Québec (s. d.). Principaux changements aux lois sur la protection des renseignements personnels. CAI.
https://www.cai.gouv.qc.ca/protection-renseignements-personnels/sujets-et-domaines-dinteret/principaux-changements-loi-25

[8] Bureau du surintendant des institutions financières (2025). Ligne directrice E-23 – Gestion du risque de modélisation (2027). BSIF.
https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/guideline-e-23-model-risk-management-2027

[9] Microsoft (2026). AI agent orchestration patterns. Azure Architecture Center.
https://learn.microsoft.com/en-us/azure/architecture/ai-ml/guide/ai-agent-design-patterns

[10] FinOps Foundation (2026). State of FinOps 2026. Linux Foundation.
https://data.finops.org/

[11] CyberArk (23 avril 2025). Machine Identities Outnumber Humans by More Than 80 to 1: New Report Exposes the Exponential Threats of Fragmented Identity Security [communiqué]. Business Wire (reproduit par Silicon UK).
https://www.silicon.co.uk/press-release/machine-identities-outnumber-humans-by-more-than-80-to-1-new-report-exposes-the-exponential-threats-of-fragmented-identity-security

[12] McKinsey & Company (2025, 5 novembre). The state of AI in 2025: Agents, innovation, and transformation. QuantumBlack, AI by McKinsey.
https://www.mckinsey.com/capabilities/quantumblack/our-insights/the-state-of-ai

[13] Shaw, F. X. (2025, 19 mai). Microsoft Build 2025: The age of AI agents and building the open agentic web. Microsoft.
https://blogs.microsoft.com/blog/2025/05/19/microsoft-build-2025-the-age-of-ai-agents-and-building-the-open-agentic-web

[14] Soria Parra, D. (2025). MCP joins the Agentic AI Foundation. Model Context Protocol Blog.
https://blog.modelcontextprotocol.io/posts/2025-12-09-mcp-joins-agentic-ai-foundation

[15] Linux Foundation (2026). A2A Protocol Surpasses 150 Organizations, Lands in Major Cloud Platforms, and Sees Enterprise Production Use in First Year. Communiqué, 9 avril 2026.
https://www.linuxfoundation.org/press/a2a-protocol-surpasses-150-organizations-lands-in-major-cloud-platforms-and-sees-enterprise-production-use-in-first-year

[16] Menlo Ventures (2025, 9 décembre). 2025: The State of Generative AI in the Enterprise. Menlo Ventures. https://menlovc.com/perspective/2025-the-state-of-generative-ai-in-the-enterprise

[17] Hadfield, J., Zhang, B., Lien, K., Scholz, F., Fox, J. et Ford, D. (2025, 13 juin). How we built our multi-agent research system. Anthropic. https://www.anthropic.com/engineering/multi-agent-research-system

[18] IBM (2025, 30 juillet). IBM Report: 13% Of Organizations Reported Breaches Of AI Models Or Applications, 97% Of Which Reported Lacking Proper AI Access Controls [communiqué; Cost of a Data Breach Report 2025, Ponemon Institute]. IBM. https://newsroom.ibm.com/2025-07-30-ibm-report-13-of-organizations-reported-breaches-of-ai-models-or-applications,-97-of-which-reported-lacking-proper-ai-access-controls

[19] IBM et Ponemon Institute (2026). Cost of a Data Breach Report 2026. IBM. https://www.ibm.com/reports/data-breach

[20] Anthropic (25 novembre 2024). Introducing the Model Context Protocol. Anthropic. https://www.anthropic.com/news/model-context-protocol

[21] Google (9 avril 2025). Announcing the Agent2Agent Protocol (A2A). Google for Developers Blog. https://developers.googleblog.com/en/a2a-a-new-era-of-agent-interoperability

[22] Linux Foundation (23 juin 2025). Linux Foundation Launches the Agent2Agent Protocol Project to Enable Secure, Intelligent Communication Between AI Agents. Linux Foundation. https://www.linuxfoundation.org/press/linux-foundation-launches-the-agent2agent-protocol-project-to-enable-secure-intelligent-communication-between-ai-agents

[23] Linux Foundation (29 juillet 2025). Linux Foundation Welcomes the AGNTCY Project to Standardize Open Multi-Agent System Infrastructure and Break Down AI Agent Silos. https://www.linuxfoundation.org/press/linux-foundation-welcomes-the-agntcy-project-to-standardize-open-multi-agent-system-infrastructure-and-break-down-ai-agent-silos

[24] LF AI & Data Foundation (29 août 2025). ACP Joins Forces with A2A. https://lfaidata.foundation/communityblog/2025/08/29/acp-joins-forces-with-a2a-under-the-linux-foundations-lf-ai-data

[25] Soria Parra, D., Jones, A., Antanavicius, T., Padilla, T. et Chu, T. (2025). Introducing the MCP Registry. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/2025-09-08-mcp-registry-preview

[26] Google Cloud (16 septembre 2025). Powering AI commerce with the new Agent Payments Protocol (AP2). Google Cloud Blog. https://cloud.google.com/blog/products/ai-machine-learning/announcing-agents-to-payments-ap2-protocol

[27] Stripe (29 septembre 2025). Stripe powers Instant Checkout in ChatGPT and releases Agentic Commerce Protocol co-developed with OpenAI. Stripe. https://stripe.com/newsroom/news/stripe-openai-instant-checkout

[28] OWASP GenAI Security Project (2025). OWASP Top 10 for Agentic Applications for 2026. OWASP Foundation. https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026

[29] A2A Project (12 mars 2026). A2A Protocol Ships v1.0: Production-Ready Standard for Agent-to-Agent Communication. https://a2a-protocol.org/latest/blog/2026/03/12/a2a-protocol-ships-v10-production-ready-standard-for-agent-to-agent-communication

[30] A2A Project (2025-2026). Releases (v0.3.0, v1.0.0, v1.0.1). GitHub a2aproject/A2A. https://github.com/a2aproject/A2A/releases

[31] Agentic AI Foundation (2026). agentgateway Joins AAIF as an Open Gateway for Agentic AI Infrastructure. AAIF, 4 juin 2026. https://aaif.io/blog/agentgateway-joins-aaif-as-an-open-gateway-for-agentic-ai-infrastructure

[32] Linux Foundation (2025). Linux Foundation Welcomes agentgateway Project to Accelerate AI Agent Adoption While Maintaining Security, Observability and Governance. Communiqué, 25 août 2025. https://linuxfoundation.org/press/linux-foundation-welcomes-agentgateway-project-to-accelerate-ai-agent-adoption-while-maintaining-security-observability-and-governance

[33] Soria Parra, D. et Delimarsky, D. (2026). The 2026-07-28 Specification. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/2026-07-28

[34] Model Context Protocol (2026). Versioning. https://modelcontextprotocol.io/specification/versioning

[35] Agentic AI Foundation (2026). A2A joins AAIF's open agentic stack. AAIF, 17 août 2026. https://aaif.io/blog/a2a-joins-aaif

[36] Agentic AI Foundation (9 septembre 2026). Envoy AI Gateway becomes Agent Router and joins AAIF. Agentic AI Foundation (AAIF). https://aaif.io/blog/agent-router-joins-aaif

[37] Cisco (Parello, J.) (12 octobre 2026). [Project Proposal] AGNTCY, issue no 57. GitHub, aaif/project-proposals (Agentic AI Foundation). https://github.com/aaif/project-proposals/issues/57

[38] Linux Foundation (2026). Agentic AI Foundation Announces Four New Projects: Agent Skills, Open Responses, OpenEnv, and OpenSandbox. Communiqué, 22 octobre 2026. https://www.linuxfoundation.org/press/agentic-ai-foundation-announces-four-new-projects-agent-skills-open-responses-openenv-and-opensandbox

[39] A2A Project (s. d.). A2A and MCP. https://a2a-protocol.org/latest/topics/a2a-and-mcp

[40] Agentic AI Foundation (s. d.). Home (section « Working groups that matter »). Agentic AI Foundation (AAIF). https://aaif.io/

[41] Parikh, S. (28 avril 2026). We're donating Agent Payments Protocol to the FIDO Alliance to support the future of secure, agentic payments. Google. https://blog.google/products-and-platforms/platforms/google-pay/agent-payments-protocol-fido-alliance

[42] Agentic AI Foundation (2026). Project Proposals (processus d'admission). GitHub. https://github.com/aaif/project-proposals

[43] Model Context Protocol (2026). The MCP Registry. https://modelcontextprotocol.io/registry/about

[44] TrueFoundry (2026). *Governing AI Agents Across Multiple Platforms*. https://www.truefoundry.com/blog/cross-platform-ai-agent-governance

[45] Dhimate, Y. (2026). A Framework for Architecting Agent Control Plane. MuleSoft Blog, 12 août 2026. https://blogs.mulesoft.com/agentic-perspectives/a-framework-for-architecting-agent-control-plane

[46] Shah, N., Lefferts, R. et Roszak, J. (2026). Microsoft Agent 365, now generally available, expands capabilities and integrations. Microsoft Security Blog, 1er mai 2026. https://www.microsoft.com/en-us/security/blog/2026/05/01/microsoft-agent-365-now-generally-available-expands-capabilities-and-integrations

[47] ServiceNow (2026). ServiceNow expands AI Control Tower to discover, observe, govern, secure, and measure AI deployed across any system in the enterprise. Communiqué, 5 mai 2026. https://newsroom.servicenow.com/press-releases/details/2026/ServiceNow-expands-AI-Control-Tower-to-discover-observe-govern-secure-and-measure-AI-deployed-across-any-system-in-the-enterprise/default.aspx

[48] Microsoft (2026). What's new in Copilot Studio. Microsoft Learn. https://learn.microsoft.com/en-us/microsoft-copilot-studio/whats-new

[49] Salesforce (s. d.). Agentforce Interoperability Guide. Salesforce. https://www.salesforce.com/agentforce/resources/interoperability-guide

[50] ServiceNow (5 mai 2026). ServiceNow turns enterprise AI chaos into control with the platform for governed, autonomous work. ServiceNow. https://newsroom.servicenow.com/press-releases/details/2026/ServiceNow-turns-enterprise-AI-chaos-into-control-with-the-platform-for-governed-autonomous-work/default.aspx

[51] ServiceNow (6 mai 2025). ServiceNow Launches AI Control Tower, a Centralized Command Center to Govern, Manage, Secure, and Realize Value From Any AI Agent, Model, and Workflow. ServiceNow. https://newsroom.servicenow.com/press-releases/details/2025/ServiceNow-Launches-AI-Control-Tower-a-Centralized-Command-Center-to-Govern-Manage-Secure-and-Realize-Value-From-Any-AI-Agent-Model-and-Workflow/default.aspx

[52] Gartner (2026). Implement 3 Layers of Oversight for Scaled Agentic AI Architectures (document 8214461, accès réservé aux clients). Gartner. https://www.gartner.com/en/documents/8214461

[53] Microsoft (2026). Billing rates and management – Microsoft Copilot Studio. Microsoft Learn. https://learn.microsoft.com/en-us/microsoft-copilot-studio/requirements-messages-management

[54] Salesforce (2026, 26 août). Salesforce Delivers Record Second Quarter Fiscal 2027 Results [communiqué]. Salesforce. https://www.salesforce.com/news/press-releases/2026/08/26/fy27-q2-earnings

[55] Salesforce (2026). Agentforce Pricing. Salesforce. https://www.salesforce.com/agentforce/pricing

[56] Québec (2021). Loi modernisant des dispositions législatives en matière de protection des renseignements personnels, L.Q. 2021, c. 25 (projet de loi no 64), sanctionnée le 22 septembre 2021. Éditeur officiel du Québec. https://www.publicationsduquebec.gouv.qc.ca/fileadmin/Fichiers_client/lois_et_reglements/LoisAnnuelles/fr/2021/2021C25F.PDF

**[57]** Commission européenne (2026). Timeline for the implementation of the EU AI Act. AI Act Service Desk.
https://ai-act-service-desk.ec.europa.eu/en/ai-act/timeline/timeline-implementation-eu-ai-act

**[58]** Union européenne (2026). Règlement (UE) 2026/1744 du Parlement européen et du Conseil du 8 juillet 2026 modifiant les règlements (UE) 2024/1689, (UE) 2018/1139 et (UE) 2023/1230 en ce qui concerne la simplification de la mise en œuvre des règles harmonisées concernant l'intelligence artificielle (train de mesures omnibus numérique sur l'IA). Journal officiel de l'Union européenne, L, 24.7.2026.
https://eur-lex.europa.eu/eli/reg/2026/1744/oj

**[59]** ISO/IEC (19 juillet 2022). ISO/IEC 22989:2022, Information technology — Artificial intelligence — Artificial intelligence concepts and terminology (fiche catalogue, édition 1). Standards Norway.
https://online.standard.no/en/isoiec-22989-2022-3

**[60]** oneM2M (5 juin 2026). TR-0081 — AI Agent Interworking, v0.2.0, section 5.1. oneM2M.
https://specifications.onem2m.org/tr/tr-0081/latest/5.1

**[61]** Union européenne (2024). Règlement (UE) 2024/1689 du Parlement européen et du Conseil du 13 juin 2024 établissant des règles harmonisées concernant l'intelligence artificielle, art. 2, 3, 12, 14, 25, 26, 27 et 113. Journal officiel de l'Union européenne.
https://eur-lex.europa.eu/eli/reg/2024/1689/oj

**[62]** Future of Life Institute (2026). *Article 3: Definitions*.
https://artificialintelligenceact.eu/article/3

**[63]** Model Context Protocol (2026). Architecture overview.
https://modelcontextprotocol.io/docs/learn/architecture

**[64]** Model Context Protocol (2026). Understanding MCP servers (documentation, rév. 2026-07-28). Model Context Protocol.
https://modelcontextprotocol.io/docs/2026-07-28/learn/server-concepts

**[65]** Anthropic (Erik S. et Zhang, B.) (19 décembre 2024). Building effective agents. Anthropic. Note de l'éditeur : l'outillage décrit a changé depuis décembre 2024; les principes cités demeurent.
https://www.anthropic.com/research/building-effective-agents

**[66]** OpenAI (2025). A practical guide to building agents. OpenAI.
https://cdn.openai.com/business-guides-and-resources/a-practical-guide-to-building-agents.pdf

**[67]** Microsoft (2025). Saga design pattern. Azure Architecture Center.
https://learn.microsoft.com/en-us/azure/architecture/patterns/saga

**[68]** A2A Project (2026). Agent2Agent (A2A) Protocol Specification, version 1.0 (correctif 1.0.1 du 28 mai 2026). Linux Foundation / Agentic AI Foundation.
https://a2a-protocol.org/latest/specification

**[69]** IETF / RFC Editor (2020-01). *RFC 8693 — OAuth 2.0 Token Exchange, §1.1*.
https://www.rfc-editor.org/rfc/rfc8693.html#section-1.1

**[70]** IETF / RFC Editor (2020-01). *RFC 8693 – OAuth 2.0 Token Exchange (§4.1 act claim)*.
https://www.rfc-editor.org/rfc/rfc8693.html

**[71]** IETF (2020). RFC 8707 — Resource Indicators for OAuth 2.0. RFC Editor.
https://www.rfc-editor.org/rfc/rfc8707.html

**[72]** IETF / RFC Editor (2021-10). *RFC 9068 — JWT Profile for OAuth 2.0 Access Tokens*.
https://www.rfc-editor.org/rfc/rfc9068.html

**[73]** Rose, S., Borchert, O., Mitchell, S. et Connelly, S. (2020). Zero Trust Architecture, NIST SP 800-207. NIST.
https://doi.org/10.6028/NIST.SP.800-207

**[74]** NIST (2023-01). *Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1*.
https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf

**[75]** Amazon Web Services (21 novembre 2025). Securing Agentic AI: The Agentic AI Security Scoping Matrix. AWS.
https://aws.amazon.com/ai/security/agentic-ai-scoping-matrix

**[76]** Infocomm Media Development Authority (2026). Model AI Governance Framework for Agentic AI, version 1.5. IMDA, Singapour.
https://www.imda.gov.sg/-/media/imda/files/about/emerging-tech-and-research/artificial-intelligence/mgf-for-agentic-ai.pdf

**[77]** Microsoft (2026). Compensating Transaction pattern. Azure Architecture Center.
https://learn.microsoft.com/en-us/azure/architecture/patterns/compensating-transaction

**[78]** Jena, J., Dalal, S. et Tishkin, D. (22 octobre 2026). The Idempotency-Key HTTP Header Field, draft-ietf-httpapi-idempotency-key-header-08 (Internet-Draft). IETF.
https://datatracker.ietf.org/doc/draft-ietf-httpapi-idempotency-key-header

[79] Temporal Technologies (s. d.). What is a Temporal Activity? Temporal Documentation. https://docs.temporal.io/activities

[80] Temporal Technologies (s. d.). What is Temporal? (section « Durable Execution »). Temporal Documentation. https://docs.temporal.io/temporal

[81] Temporal Technologies (s. d.). Temporal Workflow Execution overview. Temporal Documentation. https://docs.temporal.io/workflow-execution

[82] LangChain (s. d.). LangGraph – Interrupts (documentation). LangChain. https://docs.langchain.com/oss/python/langgraph/interrupts

[83] Feng, K. J. K., McDonald, D. W. et Zhang, A. X. (2025). Levels of Autonomy for AI Agents. arXiv:2506.12469 (v2); Knight First Amendment Institute, série « AI and Democratic Freedoms ». https://arxiv.org/abs/2506.12469

[84] Yao, S., Zhao, J., Yu, D., Du, N., Shafran, I., Narasimhan, K. et Cao, Y. (2023). ReAct: Synergizing Reasoning and Acting in Language Models. ICLR 2023 (arXiv:2210.03629). https://arxiv.org/abs/2210.03629

[85] Microsoft Learn (2026-10-23). *Microsoft Agent Framework Overview*. https://learn.microsoft.com/en-us/agent-framework/overview

[86] Chase, H. (2025). Introducing ambient agents. LangChain. https://www.langchain.com/blog/introducing-ambient-agents

[87] OWASP Agentic Security Initiative (2025). Agentic AI – Threats and Mitigations, version 1.1. OWASP Foundation. https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations

[88] Anthropic (2026). Batch processing. Claude Platform Docs. https://platform.claude.com/docs/en/build-with-claude/batch-processing

[89] OpenAI (2026). Batch API. OpenAI API Docs. https://developers.openai.com/api/docs/guides/batch

[90] Microsoft (2026). Fundamental concepts in Microsoft Entra Agent ID. Microsoft Learn. https://learn.microsoft.com/en-us/entra/agent-id/key-concepts

[91] OWASP (2025). OWASP Non-Human Identities Top 10 – 2025. OWASP Foundation. https://owasp.github.io/www-project-non-human-identities-top-10/2025

[92] Microsoft (2026). Best practices for Microsoft Entra Agent ID. Microsoft Learn. https://learn.microsoft.com/en-us/entra/agent-id/best-practices-agent-id

[93] Kasselman, P., Lombardo, J., Rosomakho, Y., Campbell, B., Steele, N. et Parecki, A. (15 septembre 2026). AI Identity Management System (AIMS), draft-ietf-wimse-aims-00. IETF, groupe de travail WIMSE. https://www.ietf.org/archive/id/draft-ietf-wimse-aims-00.html

[94] Future of Life Institute (2026). Article 26: Obligations of Deployers of High-Risk AI Systems. https://artificialintelligenceact.eu/article/26

[95] Gartner (2026). Gartner Says Applying Uniform Governance Across AI Agents Will Lead to Enterprise AI Agent Failure (communiqué, 26 mai 2026). Gartner. https://www.gartner.com/en/newsroom/press-releases/2026-05-26-gartner-says-applying-uniform-governance-across-ai-agents-will-lead-to-enterprise-ai-agent-failure

[96] Microsoft (2025). Develop delegated permissions strategy. Microsoft Learn. https://learn.microsoft.com/en-us/security/zero-trust/develop/developer-strategy-delegated-permission

[97] Vassilev, A., Oprea, A., Fordyce, A., Anderson, H., Davies, X. et Hamin, M. (2025). Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations (NIST AI 100-2 E2025). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/ai/100/2/e2025/final

[98] National Cyber Security Centre (2025). Prompt injection is not SQL injection (it may be worse). NCSC (Royaume-Uni). https://www.ncsc.gov.uk/blog-post/prompt-injection-is-not-sql-injection

[99] National Institute of Standards and Technology (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1. NIST. https://doi.org/10.6028/NIST.AI.100-1

[100] Sumers, T. R., Yao, S., Narasimhan, K. et Griffiths, T. L. (2024). Cognitive Architectures for Language Agents. Transactions on Machine Learning Research (arXiv:2309.02427). https://arxiv.org/abs/2309.02427

**[101]** Debenedetti, E., Shumailov, I., Fan, T., Hayes, J., Carlini, N., Fabian, D., Kern, C., Shi, C., Terzis, A. et Tramèr, F. (2025). Defeating Prompt Injections by Design. arXiv:2503.18813.
https://arxiv.org/abs/2503.18813

**[102]** Amazon Web Services (2026). What is Amazon Bedrock AgentCore? Developer Guide.
https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/what-is-bedrock-agentcore.html

**[103]** W3C (2021). Trace Context, W3C Recommendation, 23 novembre 2021.
https://www.w3.org/TR/trace-context

**[104]** Amazon Web Services (2026). Choosing workflow type in Step Functions. Developer Guide.
https://docs.aws.amazon.com/step-functions/latest/dg/choosing-workflow-type.html

**[105]** Microsoft (2026). Microsoft Agent Framework Workflows — Checkpoints. Microsoft Learn.
https://learn.microsoft.com/en-us/agent-framework/workflows/checkpoints

**[106]** Agent Router project (2026-09-09). *Envoy AI Gateway is becoming Agent Router, an Agentic AI Foundation project*.
https://theagentrouter.ai/blog/envoy-ai-gateway-is-now-agent-router

**[107]** Microsoft (2026). Azure API Management policy reference – llm-token-limit. Microsoft Learn.
https://learn.microsoft.com/en-us/azure/api-management/llm-token-limit-policy

**[108]** Microsoft (2026). Overview of MCP servers in Azure API Management. Microsoft Learn.
https://learn.microsoft.com/en-us/azure/api-management/mcp-server-overview

**[109]** Microsoft (2026). Import an A2A Agent API — Azure API Management. Microsoft Learn.
https://learn.microsoft.com/en-us/azure/api-management/agent-to-agent-api

**[110]** Amazon Web Services (2026). Amazon Bedrock AgentCore Gateway: A secure AI gateway for agents, tools, and models. Developer Guide.
https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/gateway.html

**[111]** Kong Inc (2026). *AI A2A Proxy — Plugin*.
https://developer.konghq.com/plugins/ai-a2a-proxy

**[112]** Rose, S., Borchert, O., Mitchell, S. et Connelly, S. (2020). Zero Trust Architecture (NIST SP 800-207). NIST.
https://csrc.nist.gov/pubs/sp/800/207/final

**[113]** IBM (2026). ContextForge (mcp-context-forge), projet libre parrainé par IBM, dont la migration hors de l'organisation IBM est annoncée. GitHub.
https://github.com/IBM/mcp-context-forge

**[114]** Anthropic (Aizawa, K.) (11 septembre 2025). Writing effective tools for agents — with agents. Anthropic.
https://www.anthropic.com/engineering/writing-tools-for-agents

**[115]** OpenAI (s. d.). Function calling. OpenAI API Documentation.
https://developers.openai.com/api/docs/guides/function-calling

**[116]** Cloud Native Computing Foundation (consultée le 27 octobre 2026). SPIFFE (page du projet; niveau « Graduated » depuis le 23 août 2022). CNCF.
https://www.cncf.io/projects/spiffe

**[117]** Cloud Native Computing Foundation (consultée le 27 octobre 2026). SPIRE (page du projet; niveau « Graduated » depuis le 22 août 2022). CNCF.
https://www.cncf.io/projects/spire

**[118]** IETF (janvier 2020). RFC 8693 — OAuth 2.0 Token Exchange. IETF Datatracker.
https://datatracker.ietf.org/doc/rfc8693

**[119]** OpenTelemetry (CNCF) (2026). Semantic conventions for generative client AI spans (v1.41.0).
https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/gen-ai-spans.md

**[120]** OpenTelemetry (CNCF) (2026). *Semantic conventions for GenAI agent and framework spans (v1.41.0)*.
https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/gen-ai-agent-spans.md

**[121]** The Open Group (2022). The TOGAF Standard, 10th Edition. The Open Group.
https://www.opengroup.org/togaf

**[122]** Davis, C. (30 juillet 2025, mis à jour le 23 mars 2026). Production-ready agents with the OpenAI Agents SDK + Temporal. Temporal Blog.
https://temporal.io/blog/announcing-openai-agents-sdk-integration

**[123]** Runkle, S. et équipe OSS LangChain (2025). LangChain and LangGraph Agent Frameworks Reach v1.0 Milestones. LangChain, 22 octobre 2025.
https://www.langchain.com/blog/langchain-langgraph-1dot0

**[124]** LangChain (documentation LangGraph) (s. d.). LangGraph — Persistence.
https://docs.langchain.com/oss/python/langgraph/persistence

**[125]** Henry, S. (3 avril 2026). Microsoft Agent Framework Version 1.0. Microsoft DevBlogs.
https://devblogs.microsoft.com/agent-framework/microsoft-agent-framework-version-1-0

**[126]** Google (2026). Agent Development Kit (ADK). Documentation.
https://adk.dev/

**[127]** OpenAI (2026). OpenAI Agents SDK. Documentation.
https://openai.github.io/openai-agents-python

**[128]** Liguori, C. (2025). Introducing Strands Agents, an Open Source AI Agents SDK. AWS Open Source Blog, 16 mai 2025.
https://aws.amazon.com/blogs/opensource/introducing-strands-agents-an-open-source-ai-agents-sdk

**[129]** Strands Agents (s. d.). Agent-to-Agent (A2A) Protocol. Strands Agents Documentation.
https://strandsagents.com/latest/documentation/docs/user-guide/concepts/multi-agent/agent-to-agent

**[130]** Agentic AI Foundation (s. d.). Projects. Agentic AI Foundation (AAIF).
https://aaif.io/projects

**[131]** agentgateway / Agentic AI Foundation (LF Projects) (2026). *agentgateway (site officiel)*.
https://agentgateway.dev/

**[132]** Kong Inc. (2026). Kong AI Gateway. Documentation.
https://developer.konghq.com/ai-gateway

**[133]** Projet Firecracker (s. d.). Firecracker – Secure and fast microVMs for serverless computing.
https://firecracker-microvm.github.io/

**[134]** Projet gVisor (s. d.). gVisor Documentation – What is gVisor?, Performance Guide et GPU Support. Google.
https://gvisor.dev/docs

**[135]** OpenInfra Foundation (s. d.). Kata Containers.
https://katacontainers.io/

**[136]** WASI Subgroup, WebAssembly Community Group (s. d.). Introduction. WASI.dev.
https://wasi.dev/

**[137]** Kubernetes SIG Apps (2026). agent-sandbox. GitHub kubernetes-sigs.
https://github.com/kubernetes-sigs/agent-sandbox

**[138]** Salesforce (2025). Salesforce Launches MuleSoft Agent Fabric to Orchestrate and Govern Any AI Agent Across the Agentic Enterprise. 25 septembre 2025.
https://www.salesforce.com/news/stories/mulesoft-agent-fabric-announcement

**[139]** Cloudflare (2026). MCP server portals. Cloudflare One docs.
https://developers.cloudflare.com/cloudflare-one/access-controls/ai-controls/mcp-portals

**[140]** Apache Software Foundation (2026). Apache Kafka 4.4 Documentation – Design (Message Delivery Semantics).
https://kafka.apache.org/44/design/design

**[141]** OpenTelemetry (2026). Redaction processor, OpenTelemetry Collector Contrib.
https://github.com/open-telemetry/opentelemetry-collector-contrib/tree/main/processor/redactionprocessor

**[142]** Sun, L. (4 juin 2026). Designing agentgateway: A Unified High-Performance Gateway for AI and API Traffic. AAIF (republié sur agentgateway.dev).
https://agentgateway.dev/blog/2026-06-04-designing-agentgateway-unified-gateway

**[143]** TrueFoundry (2026). *Introduction to AI Gateway*.
https://www.truefoundry.com/docs/ai-gateway/intro-to-llm-gateway

**[144]** TrueFoundry (2026). TrueFoundry AI Gateway Plane Architecture. Documentation.
https://www.truefoundry.com/docs/platform/gateway-plane-architecture

**[145]** OpenAI (2026). GPT-6.1 Sol — Model. OpenAI API Documentation.
https://developers.openai.com/api/docs/models/gpt-6.1-sol

**[146]** OpenAI (2026). GPT-5.5 — Model. OpenAI API Documentation.
https://developers.openai.com/api/docs/models/gpt-5.5

**[147]** Google (2025). A new era of intelligence with Gemini 3. Google Blog.
https://blog.google/products/gemini/gemini-3

**[148]** Liu, N. F., Lin, K., Hewitt, J., Paranjape, A., Bevilacqua, M., Petroni, F. et Liang, P. (2024). Lost in the Middle: How Language Models Use Long Contexts. Transactions of the ACL, 12, 157–173.
https://aclanthology.org/2024.tacl-1.9

**[149]** Anthropic (Rajasekaran, P., Dixon, E., Ryan, C. et Hadfield, J.) (29 septembre 2025). Effective context engineering for AI agents. Anthropic.
https://www.anthropic.com/engineering/effective-context-engineering-for-ai-agents

**[150]** Hong, K., Troynikov, A. et Huber, J. (2025). Context Rot: How Increasing Input Tokens Impacts LLM Performance. Chroma.
https://www.trychroma.com/research/context-rot

**[151]** LangChain (s. d.). Memory overview. Documentation LangChain.
https://docs.langchain.com/oss/python/concepts/memory

**[152]** Anthropic (s. d.). Memory tool. Claude Platform Docs.
https://platform.claude.com/docs/en/agents-and-tools/tool-use/memory-tool

**[153]** Packer, C., Wooders, S., Lin, K., Fang, V., Patil, S. G., Stoica, I. et Gonzalez, J. E. (2023). MemGPT: Towards LLMs as Operating Systems. arXiv:2310.08560.
https://arxiv.org/abs/2310.08560

**[154]** Letta (2024-09-23). *MemGPT is now part of Letta*.
https://www.letta.com/blog/memgpt-and-letta

**[155]** Rasmussen, P., Paliychuk, P., Beauvais, T., Ryan, J. et Chalef, D. (2025). Zep: A Temporal Knowledge Graph Architecture for Agent Memory. arXiv:2501.13956.
https://arxiv.org/abs/2501.13956

**[156]** Edge, D., Trinh, H., Cheng, N. et al. (2024). From Local to Global: A Graph RAG Approach to Query-Focused Summarization. arXiv:2404.16130.
https://arxiv.org/abs/2404.16130

**[157]** Commission européenne (2017). New European Interoperability Framework — Promoting seamless services and data flows for European public administrations. Office des publications de l'Union européenne. doi:10.2799/78681.
https://ec.europa.eu/isa2/sites/default/files/eif_brochure_final.pdf

**[158]** Commission européenne — Interoperable Europe Portal (s. d.). The European Interoperability Framework in detail.
https://interoperable-europe.ec.europa.eu/collection/nifo-national-interoperability-framework-observatory/european-interoperability-framework-detail

**[159]** Commission européenne — Interoperable Europe Portal (s. d.). Interoperable Europe Act.
https://interoperable-europe.ec.europa.eu/interoperable-europe/interoperable-europe-act

**[160]** Québec (2023). Loi sur la protection des renseignements personnels dans le secteur privé, RLRQ c. P-39.1, art. 12.1. LégisQuébec.
https://www.legisquebec.gouv.qc.ca/fr/document/lc/P-39.1

**[161]** A2A Project (s. d.). Enterprise Implementation of A2A.
https://a2a-protocol.org/latest/topics/enterprise-ready

**[162]** Model Context Protocol (2026). Base Protocol — Overview (_meta, statelessness, error codes).
https://modelcontextprotocol.io/specification/2026-07-28/basic/index

**[163]** JSON Schema (s. d.). Spécification JSON Schema, dialecte 2020-12 (Core et Validation). JSON Schema.
https://json-schema.org/specification

**[164]** AG-UI Protocol (s. d.). AG-UI Overview.
https://docs.ag-ui.com/introduction

**[165]** AG-UI Protocol (s. d.). Events (documentation AG-UI).
https://docs.ag-ui.com/concepts/events

**[166]** AG-UI Protocol (2026). *ag-ui-protocol/ag-ui*.
https://github.com/ag-ui-protocol/ag-ui

**[167]** Waehner, K. (2026). MCP vs. REST/HTTP API vs. Kafka: The Architect's Guide to Agentic AI Integration, 10 avril 2026.
https://www.kai-waehner.de/blog/2026/04/10/mcp-vs-rest-http-api-vs-kafka-the-architects-guide-to-agentic-ai-integration

**[168]** Model Context Protocol (2026). Key Changes — 2026-07-28 (journal des modifications).
https://modelcontextprotocol.io/specification/2026-07-28/changelog

**[169]** Model Context Protocol (2026). Extensions Overview.
https://modelcontextprotocol.io/docs/extensions/overview

**[170]** OpenAPI Initiative (2026). OpenAPI Specification v3.2.1, 10 septembre 2026. Linux Foundation.
https://spec.openapis.org/oas/v3.2.1.html

**[171]** Nottingham, M., Wilde, E. et Dalal, S. (2023). RFC 9457 – Problem Details for HTTP APIs. IETF.
https://www.rfc-editor.org/rfc/rfc9457.html

**[172]** OpenAPI Initiative (2026). Arazzo Specification 1.1.0, 17 mai 2026. Linux Foundation. https://spec.openapis.org/arazzo/latest.html

**[173]** CloudEvents (2022). CloudEvents Specification, version 1.0.2 (publication ce@v1.0.2). CNCF. https://github.com/cloudevents/spec/releases

**[174]** AsyncAPI Initiative (2026). AsyncAPI Spec 3.1.0 Release Notes, 31 janvier 2026. Linux Foundation. https://www.asyncapi.com/blog/release-notes-3.1.0

**[175]** IETF / RFC Editor (2025-01). *RFC 9700 — Best Current Practice for OAuth 2.0 Security (BCP 240)*. https://www.rfc-editor.org/rfc/rfc9700.html

**[176]** Hardt, D., Parecki, A. et Lodderstedt, T. (2026). The OAuth 2.1 Authorization Framework, draft-ietf-oauth-v2-1-16 (Internet-Draft, travail en cours). IETF. https://datatracker.ietf.org/doc/draft-ietf-oauth-v2-1

**[177]** Parecki, A., McGuinness, K. et Campbell, B. (2026). Identity Assertion JWT Authorization Grant, draft-ietf-oauth-identity-assertion-authz-grant-04 (Internet-Draft). IETF. https://datatracker.ietf.org/doc/draft-ietf-oauth-identity-assertion-authz-grant

**[178]** Model Context Protocol (2026). Enterprise-Managed Authorization (extension). https://modelcontextprotocol.io/extensions/auth/enterprise-managed-authorization

**[179]** IETF (2026-07-30). *Transaction Tokens (draft-ietf-oauth-transaction-tokens-11), §6*. https://www.ietf.org/archive/id/draft-ietf-oauth-transaction-tokens-11.html

**[180]** OpenTelemetry (2026). Semantic Conventions – CHANGELOG (v1.37.0 à v1.44.0). CNCF. https://github.com/open-telemetry/semantic-conventions/blob/main/CHANGELOG.md

**[181]** OpenTelemetry (2026). Semantic Conventions for Generative AI (dépôt semantic-conventions-genai, statut Development). CNCF. https://github.com/open-telemetry/semantic-conventions-genai

**[182]** AGNTCY (2026). Documentation AGNTCY (OASF, Directory, SLIM, Identity, SHADI, Observe, CSIT). https://docs.agntcy.org/

**[183]** OpenAI et Stripe (2025-2026). Agentic Commerce Protocol (spécification, bêta). GitHub. https://github.com/agentic-commerce-protocol/agentic-commerce-protocol

**[184]** Google (11 janvier 2026). Under the hood: Universal Commerce Protocol (UCP). Google for Developers Blog. https://developers.googleblog.com/en/under-the-hood-universal-commerce-protocol-ucp

**[185]** ANP Community (2026). Agent Network Protocol. GitHub. https://github.com/agent-network-protocol/AgentNetworkProtocol

**[186]** Chang, G., Lin, E., Yuan, C., Cai, R., Chen, B., Xie, X., Zhang, Y. et ANP Open Source Technology Community (2025). Agent Network Protocol Technical White Paper. arXiv:2508.00007. https://arxiv.org/html/2508.00007v1

**[187]** CloudEvents (CNCF) (2026). CloudEvents Extension Attributes. CNCF. https://github.com/cloudevents/spec/blob/main/cloudevents/extensions/README.md

**[188]** OpenTelemetry (2026). Versioning and stability for OpenTelemetry clients. https://opentelemetry.io/docs/specs/otel/versioning-and-stability

**[189]** Model Context Protocol (2026). Documentation Index (llms.txt). Model Context Protocol. https://modelcontextprotocol.io/llms.txt

**[190]** Model Context Protocol (2026). Transports — Streamable HTTP (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/basic/transports/streamable-http

**[191]** Model Context Protocol (2026). Tasks (extension). https://modelcontextprotocol.io/extensions/tasks/overview

**[192]** A2A Project (2026). a2a.proto — définition normative Protocol Buffers. GitHub a2aproject/A2A. https://github.com/a2aproject/A2A/blob/main/specification/a2a.proto

**[193]** Anthropic (9 décembre 2025). Donating the Model Context Protocol and establishing the Agentic AI Foundation. Anthropic. https://www.anthropic.com/news/donating-the-model-context-protocol-and-establishing-of-the-agentic-ai-foundation

**[194]** Soria Parra, D. et Delimarsky, D. (2026). The 2026-07-28 MCP Specification Release Candidate. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/2026-07-28-release-candidate

**[195]** Soria Parra, D. et Delimarsky, D. (2026). The New MCP Roadmap. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/mcp-roadmap

**[196]** Model Context Protocol (2026). Deprecated Features (registre des fonctionnalités dépréciées). https://modelcontextprotocol.io/specification/2026-07-28/deprecated

**[197]** Model Context Protocol (2026). Server Features — Tools (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/server/tools

**[198]** Model Context Protocol (2026). Specification — révision 2026-07-28. Agentic AI Foundation / Linux Foundation. https://modelcontextprotocol.io/specification/2026-07-28

**[199]** Model Context Protocol (2026). Server Utilities — Caching (rév. 2026-07-28). Model Context Protocol. https://modelcontextprotocol.io/specification/2026-07-28/server/utilities/caching

**[200]** Model Context Protocol (2026). Multi Round-Trip Requests. https://modelcontextprotocol.io/specification/2026-07-28/basic/patterns/mrtr

**[201]** Model Context Protocol (2026). Schema Reference (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/schema

**[202]** Model Context Protocol (2026). MCP Apps (extension). https://modelcontextprotocol.io/extensions/apps/overview

**[203]** Zavodchik, M., Fogel, S. et Meiri, G. (2026). The New MCP Specification: What Security Teams Must Prepare For. Akamai Security Research. https://www.akamai.com/blog/security-research/new-mcp-specification-security-teams-must-prepare

**[204]** Model Context Protocol (2026). Client Best Practices. https://modelcontextprotocol.io/docs/2026-07-28/develop/clients/client-best-practices

**[205]** Anthropic (Wu, B.) (24 novembre 2025). Introducing advanced tool use on the Claude Developer Platform. Anthropic. https://www.anthropic.com/engineering/advanced-tool-use

**[206]** Model Context Protocol (2025-03-26). *Key Changes — 2025-03-26*. https://modelcontextprotocol.io/specification/2025-03-26/changelog

**[207]** Model Context Protocol (2026-07-28). *Transports — Overview (MCP 2026-07-28)*. https://modelcontextprotocol.io/specification/2026-07-28/basic/transports

**[208]** Model Context Protocol (2026). Security Best Practices (rév. 2026-07-28). https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

**[209]** Model Context Protocol (2026). Authorization — Specification 2026-07-28. https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization

**[210]** Hardt, D., Parecki, A. et Lodderstedt, T. (28 mai 2025). The OAuth 2.1 Authorization Framework, draft-ietf-oauth-v2-1-13 (Internet-Draft, version remplacée par la -16). IETF. https://datatracker.ietf.org/doc/html/draft-ietf-oauth-v2-1-13

**[211]** IETF (avril 2025). RFC 9728 — OAuth 2.0 Protected Resource Metadata. IETF Datatracker. https://datatracker.ietf.org/doc/html/rfc9728

**[212]** Meyer zu Selhausen, K. et Fett, D. (mars 2022). RFC 9207 — OAuth 2.0 Authorization Server Issuer Identification. IETF. https://datatracker.ietf.org/doc/html/rfc9207

**[213]** IETF / RFC Editor (2023-09). *RFC 9449 — OAuth 2.0 Demonstrating Proof of Possession (DPoP)*. https://www.rfc-editor.org/rfc/rfc9449.html

**[214]** Model Context Protocol (2026). Client Registration (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/client-registration

**[215]** Model Context Protocol (25 novembre 2025). Key Changes — 2025-11-25. https://modelcontextprotocol.io/specification/2025-11-25/changelog

**[216]** IETF (6 juillet 2026). OAuth Client ID Metadata Document (draft-ietf-oauth-client-id-metadata-document-02). IETF. https://www.ietf.org/archive/id/draft-ietf-oauth-client-id-metadata-document-02.html

**[217]** Model Context Protocol (28 juillet 2026). MCP Authorization Extensions (ext-auth) : Enterprise-Managed Authorization et OAuth Client Credentials, extensions stables, révision 2026-07-28. GitHub. https://github.com/modelcontextprotocol/ext-auth

**[218]** Model Context Protocol (2026-07-28). *Enterprise-Managed Authorization (2026-07-28)*. https://raw.githubusercontent.com/modelcontextprotocol/ext-auth/main/specification/stable/enterprise-managed-authorization/2026-07-28/enterprise-managed-authorization.mdx

**[219]** OpenTelemetry (2026). Semantic conventions for Model Context Protocol (MCP). OpenTelemetry (GitHub). https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/mcp.md

**[220]** Beurer-Kellner, L. et Fischer, M. (2025). MCP Security Notification: Tool Poisoning Attacks. Invariant Labs. https://invariantlabs.ai/blog/mcp-security-notification-tool-poisoning-attacks

**[221]** OWASP (2026). MCP Security Cheat Sheet. OWASP Cheat Sheet Series.
https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

**[222]** OWASP (2025). OWASP MCP Top 10 (édition 2025, bêta). OWASP Foundation.
https://owasp.org/www-project-mcp-top-10

**[223]** Model Context Protocol (2026). Client Features — Elicitation (rév. 2026-07-28).
https://modelcontextprotocol.io/specification/2026-07-28/client/elicitation

**[224]** Hou, X., Zhao, Y., Wang, S. et Wang, H. (2025). Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions. arXiv:2503.23278.
https://arxiv.org/abs/2503.23278

**[225]** Model Context Protocol (GitHub) (2026). *MCP Conformance Test Framework*.
https://github.com/modelcontextprotocol/conformance

**[226]** Model Context Protocol (2026). @modelcontextprotocol/conformance (métadonnées du paquet : 0.1.16 courante, 0.2.0-alpha.12 du 1er octobre 2026). Registre npm.
https://registry.npmjs.org/@modelcontextprotocol/conformance

**[227]** Model Context Protocol (2026). Server Features — Resources (rév. 2026-07-28). Model Context Protocol.
https://modelcontextprotocol.io/specification/2026-07-28/server/resources

**[228]** Google Cloud (31 juillet 2025). Announcing a complete developer toolkit for scaling A2A agents on Google Cloud. Google Cloud Blog.
https://cloud.google.com/blog/products/ai-machine-learning/agent2agent-protocol-is-getting-an-upgrade

**[229]** A2A Project (30 juillet 2025). Release v0.3.0. GitHub a2aproject/A2A.
https://github.com/a2aproject/A2A/releases/tag/v0.3.0

**[230]** i-am-bee (IBM Research) (25 août 2025). ACP Joins Forces with A2A Under the Linux Foundation (discussion no 5). GitHub.
https://github.com/orgs/i-am-bee/discussions/5

**[231]** A2A Project (s. d.). SDKs.
https://a2a-protocol.org/latest/sdk

**[232]** Agent2Agent (A2A) Project (consulté le 27 octobre 2026). a2aproject (organisation GitHub). GitHub.
https://github.com/a2aproject

**[233]** AGNTCY (2026). agntcy/acp-spec — Agent Connect Protocol (dépôt archivé). GitHub.
https://github.com/agntcy/acp-spec

**[234]** Zed Industries (2026). Agent Client Protocol. Zed.
https://zed.dev/acp

**[235]** A2A Project (2026). What's New in A2A Protocol v1.0. GitHub a2aproject/A2A.
https://github.com/a2aproject/A2A/blob/main/docs/whats-new-v1.md

**[236]** Rundgren, A., Jordan, B. et Erdtman, S. (juin 2020). RFC 8785 – JSON Canonicalization Scheme (JCS). RFC Editor (soumission indépendante).
https://www.rfc-editor.org/rfc/rfc8785.html

**[237]** A2A Project (s. d.). Agent Discovery.
https://a2a-protocol.org/latest/topics/agent-discovery

**[238]** A2A Project (s. d.). Extensions in A2A.
https://a2a-protocol.org/latest/topics/extensions

**[239]** AGNTCY (2026). A2A over SLIM. AGNTCY, a Series of LF Projects, LLC.
https://slim.agntcy.org/latest/slim/integrations/a2a

**[240]** A2A Project (Linux Foundation) (2026). *What's New in A2A Protocol v1.0*.
https://a2a-protocol.org/latest/whats-new-v1

**[241]** OpenTelemetry (2026). Semantic conventions for Agent2Agent Protocol (A2A) (statut Development, branche main). GitHub, open-telemetry/semantic-conventions-genai.
https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/a2a.md

**[242]** Ghumare, R. (1er septembre 2026). A2A v1.0: a builder's guide, part 2 - migration, security, and production. Agentic AI Foundation (AAIF).
https://aaif.io/blog/a2a-v1-0-a-builder-s-guide-part-2-migration-security-and-production

**[243]** A2A Project (s. d.). A2A Technology Compatibility Kit (a2a-tck). GitHub.
https://github.com/a2aproject/a2a-tck

**[244]** A2A Project (1er octobre 2026). Meet the A2A CLI: discover, message, and manage agents from your terminal.
https://a2a-protocol.org/latest/blog/2026/10/01/introducing-a2a-cli

**[245]** A2A Project (2026). a2a-cli, versions publiées (v0.2.0 du 9 septembre 2026 à v0.3.1 du 16 octobre 2026). GitHub a2aproject/a2a-cli. https://github.com/a2aproject/a2a-cli/releases

**[246]** Waehner, K. (s. d.). About. kai-waehner.de. https://kai-waehner.de/about

**[247]** Cloud Native Computing Foundation (25 janvier 2024). Cloud Native Computing Foundation Announces the Graduation of CloudEvents. CNCF. https://www.cncf.io/announcements/2024/01/25/cloud-native-computing-foundation-announces-the-graduation-of-cloudevents

**[248]** CloudEvents (6 février 2022). CloudEvents – Version 1.0.2 (spécification, balise ce@v1.0.2). CNCF. https://github.com/cloudevents/spec/blob/ce@v1.0.2/cloudevents/spec.md

**[249]** AsyncAPI Initiative (2023). AsyncAPI 3.0.0 Release Notes, 5 décembre 2023. Linux Foundation. https://www.asyncapi.com/blog/release-notes-3.0.0

**[250]** CloudEvents (6 février 2022). Kafka Protocol Binding for CloudEvents, version 1.0.2 (balise ce@v1.0.2). CNCF. https://github.com/cloudevents/spec/blob/ce@v1.0.2/cloudevents/bindings/kafka-protocol-binding.md

**[251]** CloudEvents (6 février 2022). CloudEvents – Documented Extensions, version 1.0.2 (balise ce@v1.0.2). CNCF. https://github.com/cloudevents/spec/blob/ce@v1.0.2/cloudevents/documented-extensions.md

**[252]** CloudEvents (2026). Auth Context. CNCF. https://github.com/cloudevents/spec/blob/main/cloudevents/extensions/authcontext.md

**[253]** CloudEvents (2026). Distributed Tracing Extension. CNCF. https://github.com/cloudevents/spec/blob/main/cloudevents/extensions/distributed-tracing.md

**[254]** OpenTelemetry (2026). Semantic conventions for messaging spans. https://opentelemetry.io/docs/specs/semconv/messaging/messaging-spans

**[255]** CloudEvents (2026). Data Classification Extension. CNCF. https://github.com/cloudevents/spec/blob/main/cloudevents/extensions/data-classification.md

**[256]** Apache Software Foundation (2017). KIP-98 – Exactly Once Delivery and Transactional Messaging. https://cwiki.apache.org/confluence/display/KAFKA/KIP-98+-+Exactly+Once+Delivery+and+Transactional+Messaging

**[257]** Apache Software Foundation (2026). *Apache Kafka 4.4 – Introduction*. https://kafka.apache.org/44/getting-started/introduction

**[258]** Apache Software Foundation (2026). KIP-932: Queues for Kafka. https://cwiki.apache.org/confluence/display/KAFKA/KIP-932%3A+Queues+for+Kafka

**[259]** Apache Software Foundation (2025). Apache Kafka 4.0.0 Release Announcement, 18 mars 2025. https://kafka.apache.org/blog/2025/03/18/apache-kafka-4.0.0-release-announcement

**[260]** Apache Software Foundation (2026). Apache Kafka 4.2.0 Release Announcement, 17 février 2026. https://kafka.apache.org/blog/2026/02/17/apache-kafka-4.2.0-release-announcement

**[261]** Apache Software Foundation (2026). Apache Kafka 4.4.0 Release Announcement, 22 octobre 2026. https://kafka.apache.org/blog/2026/10/22/apache-kafka-4.4.0-release-announcement

**[262]** Confluent (2026-05-25). *Autonomous Agentic Event-Driven Systems Architecture*. https://www.confluent.io/blog/autonomous-agentic-event-driven-systems-architecture

**[263]** Agentic AI Foundation (2026). Project Proposal Process. GitHub aaif/technical-committee. https://github.com/aaif/technical-committee/blob/main/project_proposal_process.md

**[264]** AGNTCY (2026). *Open Agentic Schema Framework*. https://docs.agntcy.org/oasf/open-agentic-schema-framework

**[265]** AGNTCY (2026). Directory — Import. AGNTCY, a Series of LF Projects, LLC. https://dir.agntcy.org/latest/dir/dir-component-import

**[266]** AGNTCY (2026). *Directory — Store*. https://dir.agntcy.org/latest/dir/dir-component-store

**[267]** AGNTCY (2026). CLI Reference — Agent Directory Service. Agntcy, a Series of LF Projects, LLC. https://dir.agntcy.org/latest/dir/dir-cli-reference

**[268]** AGNTCY (2026). Introduction — SLIM. AGNTCY, a Series of LF Projects, LLC. https://slim.agntcy.org/latest/slim/slim-overview

**[269]** Barnes, R. et al. (2023). RFC 9420 — The Messaging Layer Security (MLS) Protocol. IETF. https://www.rfc-editor.org/rfc/rfc9420.html

**[270]** AGNTCY (2026). Identity — Introduction. AGNTCY.
https://spec.identity.agntcy.org/docs/intro

**[271]** Muscariello, L. et Polic, R. (2026). Agent Directory Service, draft-mp-agntcy-ads-02. IETF (soumission individuelle).
https://datatracker.ietf.org/doc/draft-mp-agntcy-ads

**[272]** Muscariello, L., Papalini, M., Sardara, M. et Betts, S. (2026). Secure Low-Latency Interactive Messaging (SLIM), draft-mpsb-agntcy-slim-02. IETF (soumission individuelle).
https://datatracker.ietf.org/doc/draft-mpsb-agntcy-slim

**[273]** Kim, Y. et Liu, X. (2026, 28 janvier). Towards a science of scaling agent systems: When and why agent systems work. Google Research. https://research.google/blog/towards-a-science-of-scaling-agent-systems-when-and-why-agent-systems-work/ (article : arXiv:2512.08296).
https://research.google/blog/towards-a-science-of-scaling-agent-systems-when-and-why-agent-systems-work

**[274]** Kim, Y., Gu, K., Park, C. et al. (2025). Towards a Science of Scaling Agent Systems. arXiv:2512.08296 (v3, 2026).
https://arxiv.org/abs/2512.08296

**[275]** Phillips, C. (2026, 23 janvier). Building multi-agent systems: When and how to use them. Anthropic.
https://claude.com/resources/articles/building-multi-agent-systems-when-and-how-to-use-them

**[276]** Yan, W. (2025). Don't Build Multi-Agents. Cognition.
https://cognition.com/blog/dont-build-multi-agents

**[277]** Chase, H. (2025). How and when to build multi-agent systems. LangChain Blog.
https://www.langchain.com/blog/how-and-when-to-build-multi-agent-systems

**[278]** Microsoft (2026). Microsoft Agent Framework Workflows Orchestrations – Magentic. Microsoft Learn.
https://learn.microsoft.com/en-us/agent-framework/workflows/orchestrations/magentic

**[279]** Fourney, A., Bansal, G., Mozannar, H. et al. (2024). Magentic-One: A Generalist Multi-Agent System for Solving Complex Tasks. arXiv:2411.04468.
https://arxiv.org/abs/2411.04468

**[280]** Papadopoulos, V., Shah, M., Zimmerman, S. et Lindsey, J. (2026). Mind Viruses: Self-Propagating Ideas in Multi-Agent LLM Systems. arXiv:2608.10218.
https://arxiv.org/abs/2608.10218

**[281]** Anthropic (s. d.). Tool search tool. Claude Platform Docs.
https://platform.claude.com/docs/en/agents-and-tools/tool-use/tool-search-tool

**[282]** LangChain (s. d.). LangGraph – Checkpointers (documentation). LangChain.
https://docs.langchain.com/oss/python/langgraph/checkpointers

**[283]** LangChain (documentation LangGraph) (s. d.). Use time-travel.
https://docs.langchain.com/oss/python/langgraph/use-time-travel

**[284]** Garcia-Molina, H. et Salem, K. (1987). Sagas. Proceedings of the 1987 ACM SIGMOD International Conference on Management of Data, p. 249–259. ACM.
https://doi.org/10.1145/38713.38742

**[285]** Garcia-Molina, H. et Salem, K. (janvier 1987). SAGAS (rapport technique TR-070-87). Princeton University, Department of Computer Science.
https://www.cs.princeton.edu/research/techreps/598

**[286]** Temporal Technologies (s. d.). Saga Pattern. Temporal Documentation.
https://docs.temporal.io/design-patterns/saga-pattern

**[287]** Chang, E. Y. et Geng, L. (2025). SagaLLM: Context Management, Validation, and Transaction Guarantees for Multi-Agent LLM Planning. Proceedings of the VLDB Endowment, 18(12), 4874–4886.
https://www.vldb.org/pvldb/vol18/p4874-chang.pdf

**[288]** Chang, E. Y. et Geng, L. (2025). SagaLLM: Context Management, Validation, and Transaction Guarantees for Multi-Agent LLM Planning. Proceedings of the VLDB Endowment, 18(12), 4874-4886; prépublication arXiv:2503.11951 (v3).
https://arxiv.org/abs/2503.11951

**[289]** Yan, W. (22 avril 2026). Multi-Agents: What's Actually Working. Cognition.
https://cognition.com/blog/multi-agents-working

**[290]** Future of Life Institute (2026). Article 14: Human Oversight.
https://artificialintelligenceact.eu/article/14

**[291]** Shavit, Y., Agarwal, S., Brundage, M., et al. (2023). Practices for Governing Agentic AI Systems. OpenAI.
https://cdn.openai.com/papers/practices-for-governing-agentic-ai-systems.pdf

**[292]** Cemri, M., Pan, M. Z., Yang, S. et al. (2025). Why Do Multi-Agent LLM Systems Fail? arXiv:2503.13657. https://arxiv.org/abs/2503.13657

**[293]** Microsoft (GitHub) (2026-04-02). *Release python-1.0.0 · microsoft/agent-framework*. https://github.com/microsoft/agent-framework/releases/tag/python-1.0.0

**[294]** Microsoft Learn (2026-02-12). *Workflow orchestrations in Agent Framework*. https://learn.microsoft.com/en-us/agent-framework/workflows/orchestrations

**[295]** Microsoft (2026). Observability — Microsoft Agent Framework. Microsoft Learn. https://learn.microsoft.com/en-us/agent-framework/agents/observability

**[296]** CrewAI (s. d.). Introduction — CrewAI Documentation. https://docs.crewai.com/en/introduction

**[297]** Google (s. d.). Template agent workflows. Agent Development Kit (ADK). https://adk.dev/agents/workflow-agents

**[298]** Microsoft (19 mai 2025). Multi-agent orchestration, maker controls, and more: Microsoft Copilot Studio announcements at Microsoft Build 2025. Microsoft Copilot Blog. https://www.microsoft.com/en-us/microsoft-copilot/blog/copilot-studio/multi-agent-orchestration-maker-controls-and-more-microsoft-copilot-studio-announcements-at-microsoft-build-2025

**[299]** Chopra, N. (2026). New and improved: Multi-agent orchestration, connected experiences, and faster prompt iteration. Microsoft Copilot Blog, 1er avril 2026. https://www.microsoft.com/en-us/copilot/blog/copilot-studio/new-and-improved-multi-agent-orchestration-connected-experiences-and-faster-prompt-iteration

**[300]** Desai, Z. (2025). Model Context Protocol (MCP) is now generally available in Microsoft Copilot Studio. Microsoft Copilot Blog, 29 mai 2025. https://www.microsoft.com/en-us/microsoft-copilot/blog/copilot-studio/model-context-protocol-mcp-is-now-generally-available-in-microsoft-copilot-studio

**[301]** Salvi, A. (13 octobre 2022). Operational Design Domain – Narrow frame provides safety. SAFE INTELLIGENCE, Fraunhofer IKS. https://safe-intelligence.fraunhofer.de/en/articles/odd-narrow-frame-provides-safety

**[302]** Morris, M. R., Sohl-Dickstein, J., Fiedel, N., Warkentin, T., Dafoe, A., Faust, A., Farabet, C. et Legg, S. (2024). Position: Levels of AGI for Operationalizing Progress on the Path to AGI. Proceedings of ICML 2024 (PMLR 235, p. 36308-36321); arXiv:2311.02462 (v5, 2025). https://arxiv.org/abs/2311.02462

**[303]** Mitchell, M., Ghosh, A., Luccioni, A. S. et Pistilli, G. (2025). Fully Autonomous AI Agents Should Not be Developed. arXiv:2502.02649 (v3). https://arxiv.org/abs/2502.02649

**[304]** SAE International (2026). J3016_202609 – Taxonomy and Definitions for Terms Related to Driving Automation Systems for On-Road Motor Vehicles. SAE International. https://saemobilus.sae.org/standards/j3016_202609-taxonomy-definitions-terms-related-driving-automation-systems-road-motor-vehicles

**[305]** ITPro (Emma Woollacott) (2026-05-27). *'One-size-fits-all' agent governance sets enterprises up to fail*. https://www.itpro.com/technology/artificial-intelligence/one-size-fits-all-agent-governance-sets-enterprises-up-to-fail

**[306]** Parasuraman, R., Sheridan, T. B. et Wickens, C. D. (2000). A model for types and levels of human interaction with automation. IEEE Transactions on Systems, Man, and Cybernetics – Part A, 30(3), 286–297. https://doi.org/10.1109/3468.844354

**[307]** Meta AI (2025). Agents Rule of Two: A Practical Approach to AI Agent Security. Meta. https://ai.meta.com/blog/practical-ai-agent-security

**[308]** Rundgren, A., Jordan, B. et Erdtman, S. (juin 2020). RFC 8785 — JSON Canonicalization Scheme (JCS). Filière indépendante de la série des RFC (non endossée par l'IETF), IETF Datatracker. https://datatracker.ietf.org/doc/rfc8785

**[309]** Kasselman, P., Lombardo, J., Rosomakho, Y., Campbell, B., Steele, N. et Parecki, A. (2026). AI Identity Management System, draft-ietf-wimse-aims-00 (Internet-Draft). IETF. https://datatracker.ietf.org/doc/draft-ietf-wimse-aims

**[310]** Fernandez Rodriguez, G., Walter, F., Nennker, A., Tonge, D. et Campbell, B. (2021). OpenID Connect Client-Initiated Backchannel Authentication Flow — Core 1.0. OpenID Foundation. https://openid.net/specs/openid-client-initiated-backchannel-authentication-core-1_0.html

[311] South, T. et al. (2025). Identity Management for Agentic AI: The new frontier of authorization, authentication, and security for an AI agent world. OpenID Foundation / arXiv:2510.25819.
https://arxiv.org/abs/2510.25819

[312] IETF (2023-05). *RFC 9396 — OAuth 2.0 Rich Authorization Requests*.
https://datatracker.ietf.org/doc/rfc9396

[313] LangChain (2026). agent-inbox [dépôt GitHub, archivé le 20 septembre 2026]. GitHub.
https://github.com/langchain-ai/agent-inbox

[314] Parasuraman, R. et Manzey, D. H. (2010). Complacency and Bias in Human Use of Automation: An Attentional Integration. Human Factors, 52(3), 381–410.
https://doi.org/10.1177/0018720810376055

[315] Future of Life Institute (2026). EU Artificial Intelligence Act – Article 113 : Entry into Force and Application (texte annoté des modifications). Future of Life Institute.
https://artificialintelligenceact.eu/article/113

[316] Commission d'accès à l'information du Québec (s. d.). Utilisation et communication de renseignements personnels – Informer les personnes concernant les décisions automatisées. CAI.
https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/utilisation-communication-renseignements-personnels

[317] Commission d'accès à l'information du Québec (s.d.). Sanctions et Cadre général d'application des sanctions administratives pécuniaires. CAI.
https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/sanctions-entreprises-poursuites

[318] Gouvernement du Québec (2025). Décision fondée exclusivement sur un traitement automatisé. Québec.ca.
https://www.quebec.ca/gouvernement/travailler-gouvernement/normes-gouvernance-pratiques-internes/protection-des-renseignements-personnels/technologie-et-droit-a-la-protection-des-renseignements-personnels/decision-traitement-automatise

[319] Groupe de travail « Article 29 » (2018). Guidelines on Automated individual decision-making and Profiling for the purposes of Regulation 2016/679 (WP251rev.01). Commission européenne.
https://ec.europa.eu/newsroom/article29/items/612053

[320] Chandramouli, R. et Butcher, Z. (2023). A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments (NIST SP 800-207A). NIST.
https://csrc.nist.gov/pubs/sp/800/207/a/final

[321] Cloud Native Computing Foundation (2022). SPIFFE and SPIRE Projects Graduate from Cloud Native Computing Foundation Incubator. CNCF.
https://www.cncf.io/announcements/2022/09/20/spiffe-and-spire-projects-graduate-from-cloud-native-computing-foundation-incubator

[322] SPIFFE (s. d.). SPIFFE Concepts. Cloud Native Computing Foundation.
https://spiffe.io/docs/latest/spiffe-about/spiffe-concepts

[323] Schwenkschuster, A. et Rosomakho, Y. (2026). Workload Identity Practices, draft-ietf-wimse-workload-identity-practices-07 (Internet-Draft soumis à l'IESG). IETF.
https://datatracker.ietf.org/doc/draft-ietf-wimse-workload-identity-practices

[324] Microsoft (14 avril 2026). What is Microsoft Entra Agent ID? Microsoft Learn.
https://learn.microsoft.com/en-us/entra/agent-id/what-is-microsoft-entra-agent-id

[325] OpenID Foundation (2025-10-07). *New whitepaper tackles AI agent identity challenges*.
https://openid.net/new-whitepaper-tackles-ai-agent-identity-challenges

[326] Microsoft Learn (2025-01-04). *Microsoft identity platform and OAuth 2.0 On-Behalf-Of flow*.
https://learn.microsoft.com/en-us/entra/identity-platform/v2-oauth2-on-behalf-of-flow

[327] Hardt, D., Parecki, A. et Lodderstedt, T. (3 septembre 2026). The OAuth 2.1 Authorization Framework, draft-ietf-oauth-v2-1-16. IETF.
https://www.ietf.org/archive/id/draft-ietf-oauth-v2-1-16.html

[328] IETF / RFC Editor (2020-02). *RFC 8705 — OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens*.
https://www.rfc-editor.org/rfc/rfc8705.html

[329] IETF (2022-03). *RFC 9207 — OAuth 2.0 Authorization Server Issuer Identification*.
https://datatracker.ietf.org/doc/rfc9207

[330] IETF (2025-04). *RFC 9728 — OAuth 2.0 Protected Resource Metadata*.
https://datatracker.ietf.org/doc/rfc9728

**[331]** Microsoft (2026). Configurable token lifetimes in the Microsoft identity platform. Microsoft Learn. https://learn.microsoft.com/en-us/entra/identity-platform/configurable-token-lifetimes

**[332]** Tulshibagwale, A., Fletcher, G. et Kasselman, P. (2026). Transaction Tokens, draft-ietf-oauth-transaction-tokens-11 (Internet-Draft). IETF. https://datatracker.ietf.org/doc/draft-ietf-oauth-transaction-tokens

**[333]** Schwenkschuster, A., Kasselman, P., Burgin, K., Jenkins, M., Campbell, B. et Parecki, A. (2026). OAuth Identity and Authorization Chaining Across Domains, draft-ietf-oauth-identity-chaining-17 (Internet-Draft, file de l'éditeur des RFC). IETF. https://datatracker.ietf.org/doc/draft-ietf-oauth-identity-chaining

**[334]** Schwenkschuster, A., Kasselman, P., Rose, S., Thorgersen, S. et Cam-Winget, N. (2026). OAuth SPIFFE Client Authentication, draft-ietf-oauth-spiffe-client-auth-02 (Internet-Draft). IETF. https://datatracker.ietf.org/doc/draft-ietf-oauth-spiffe-client-auth

**[335]** Senarath, T. S. et Dissanayaka, A. (26 août 2025). OAuth 2.0 Extension: On-Behalf-Of User Authorization for AI Agents, draft-oauth-ai-agents-on-behalf-of-user-02 (Internet-Draft individuel, expiré). IETF. https://datatracker.ietf.org/doc/draft-oauth-ai-agents-on-behalf-of-user

**[336]** IETF (2026-10). *WIMSE WG documents*. https://datatracker.ietf.org/wg/wimse/documents

**[337]** Booth, H., Fisher, B., Galluzzo, R. et Roberts, J. (2026). Accelerating the Adoption of Software and AI Agent Identity and Authorization (document de réflexion, ébauche). NIST NCCoE. https://www.nccoe.nist.gov/sites/default/files/2026-02/accelerating-the-adoption-of-software-and-ai-agent-identity-and-authorization-concept-paper.pdf

**[338]** NIST (2026-09-29). *Comments on Software and Agentic AI Identity Concept Paper*. https://www.nist.gov/news-events/news/2026/09/comments-software-and-agentic-ai-identity-concept-paper

**[339]** agentgateway (2026). agentgateway — dépôt de code source. GitHub. https://github.com/agentgateway/agentgateway

**[340]** Mohamed, P. (2025). Introducing Governance for Agent Interactions With Support for A2A & MCP. MuleSoft Blog, 28 mai 2025. https://blogs.mulesoft.com/news/mulesoft-governance-for-agent-interactions

**[341]** MuleSoft (s. d.). Omni Gateway Overview (anciennement Flex Gateway). MuleSoft Documentation. https://docs.mulesoft.com/runtime-manager/flex-gateway-about

**[342]** Vercel (16 septembre 2026). Sandbox firewall. Vercel Documentation. https://vercel.com/docs/sandbox/concepts/firewall

**[343]** Tulshibagwale, A., Cappalli, T., Scurtescu, M., Backman, A., Bradley, J. et Miel, S. (2025). OpenID Shared Signals Framework Specification 1.0. OpenID Foundation. https://openid.net/specs/openid-sharedsignals-framework-1_0-final.html

**[344]** Cappalli, T. et Tulshibagwale, A. (2025). OpenID Continuous Access Evaluation Profile 1.0. OpenID Foundation. https://openid.net/specs/openid-caep-1_0-final.html

**[345]** OWASP GenAI Security Project (2025-12-09). *OWASP Top 10 for Agentic Applications – The Benchmark for Agentic Security in the Age of Autonomous AI*. https://genai.owasp.org/2025/12/09/owasp-top-10-for-agentic-applications-the-benchmark-for-agentic-security-in-the-age-of-autonomous-ai

**[346]** OWASP Gen AI Security Project (août 2026). OWASP Top 10 for LLM Applications 2026. OWASP Foundation. https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026

**[347]** OWASP Gen AI Security Project (17 novembre 2024). OWASP Top 10 for LLM Applications 2025. OWASP Foundation. https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025

**[348]** OWASP GenAI Security Project (17 novembre 2024). OWASP Top 10 for LLM Applications 2025. OWASP Foundation. https://genai.owasp.org/llm-top-10

**[349]** OWASP Foundation (2025). OWASP Top 10 Non-Human Identities Risks – 2025. https://owasp.org/www-project-non-human-identities-top-10/2025/top-10-2025

**[350]** OWASP Foundation (2026). OWASP Agentic Skills Top 10 (projet Incubator, version 1.0-2026). https://owasp.org/www-project-agentic-skills-top-10

**[351]** Huang, K. (2025). Agentic AI Threat Modeling Framework: MAESTRO. Cloud Security Alliance. https://cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro

**[352]** MITRE (2026-09-14). *mitre-atlas/atlas-data – CHANGELOG*. https://github.com/mitre-atlas/atlas-data/blob/main/CHANGELOG.md

[353] Gouvernement du Canada (2026). Guide on the Use of Agentic Artificial Intelligence. https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/generative-ai/guide-use-agentic-artificial-antelligence.html

[354] Willison, S. (2025). The lethal trifecta for AI agents: private data, untrusted content, and external communication. simonwillison.net. https://simonwillison.net/2025/Jun/16/the-lethal-trifecta

[355] Hines, K., Lopez, G., Hall, M., Zarfati, F., Zunger, Y. et Kiciman, E. (2024). Defending Against Indirect Prompt Injection Attacks With Spotlighting. arXiv:2403.14720. https://arxiv.org/abs/2403.14720

[356] Microsoft (2026). Prompt Shields in Azure AI Content Safety. Microsoft Learn. https://learn.microsoft.com/en-us/azure/ai-services/content-safety/concepts/jailbreak-detection

[357] Beurer-Kellner, L., Buesser, B., Creţu, A.-M., Debenedetti, E., Dobos, D., Fabian, D., Fischer, M., Froelicher, D., Grosse, K., Naeff, D., Ozoani, E., Paverd, A., Tramèr, F. et Volhejn, V. (2025). Design Patterns for Securing LLM Agents against Prompt Injections. arXiv:2506.08837. https://arxiv.org/abs/2506.08837

[358] Willison, S. (2023). The Dual LLM pattern for building AI assistants that can resist prompt injection. simonwillison.net. https://simonwillison.net/2023/Apr/25/dual-llm-pattern

[359] Zhang, H., Huang, J., Mei, K., Yao, Y., Wang, Z., Zhan, C., Wang, H. et Zhang, Y. (2025). Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents. ICLR 2025. arXiv:2410.02644. https://arxiv.org/abs/2410.02644

[360] Agache, A., Brooker, M., Florescu, A., Iordache, A., Liguori, A., Neugebauer, R., Piwonka, P. et Popa, D.-M. (2020). Firecracker: Lightweight Virtualization for Serverless Applications. 17th USENIX Symposium on Networked Systems Design and Implementation (NSDI '20), p. 419-434. https://www.usenix.org/conference/nsdi20/presentation/agache

[361] Projet gVisor (s. d.). gVisor – Performance Guide. Google. https://gvisor.dev/docs/architecture_guide/performance

[362] gVisor (s. d.). Compatibility. gVisor. https://gvisor.dev/docs/user_guide/compatibility

[363] Agache, A., Brooker, M., Florescu, A., Iordache, A., Liguori, A., Neugebauer, R., Piwonka, P. et Popa, D.-M. (2020). Firecracker: Lightweight Virtualization for Serverless Applications. 17th USENIX Symposium on Networked Systems Design and Implementation (NSDI '20), p. 419-434. https://www.usenix.org/system/files/nsdi20-paper-agache.pdf

[364] WebAssembly Community Group (s. d.). WebAssembly. webassembly.org. https://webassembly.org/

[365] WebAssembly Community Group (s. d.). Security. WebAssembly.org. https://webassembly.org/docs/security

[366] Blaxel (s. d.). Sandboxes – Documentation. https://docs.blaxel.ai/Sandboxes/Overview

[367] E2B (s. d.). Sandbox persistence. E2B Documentation. https://docs.e2b.dev/sandbox/persistence

[368] Projet gVisor (s. d.). gVisor – GPU Support. Google. https://gvisor.dev/docs/user_guide/gpu

[369] Modal (s. d.). Sandboxes. Modal Documentation. https://modal.com/docs/guide/sandboxes

[370] Firecracker Project (s. d.). Firecracker Specification (SPECIFICATION.md). GitHub. https://github.com/firecracker-microvm/firecracker/blob/main/SPECIFICATION.md

[371] Amazon Web Services (s. d.). Use the Instance Metadata Service to access instance metadata. Amazon EC2 User Guide. https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/configuring-instance-metadata-service.html

[372] MacCárthaigh, C. (2019). Add defense in depth against open firewalls, reverse proxies, and SSRF vulnerabilities with enhancements to the EC2 Instance Metadata Service. AWS Security Blog. https://aws.amazon.com/blogs/security/defense-in-depth-open-firewalls-reverse-proxies-ssrf-vulnerabilities-ec2-instance-metadata-service

[373] The Kubernetes Authors (s. d.). Runtime Class. Kubernetes Documentation. https://kubernetes.io/docs/concepts/containers/runtime-class

**[374]** OWASP Foundation (2026). *The Top 10 Risks — Visual Overview (AST10)*. https://owasp.github.io/www-project-agentic-skills-top-10/top10

**[375]** Future of Life Institute (2026). *Article 25: Responsibilities Along the AI Value Chain*. https://artificialintelligenceact.eu/article/25

**[376]** National Cyber Security Centre, CISA et al. (2023). Guidelines for secure AI system development. NCSC (Royaume-Uni). https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development

**[377]** OWASP GenAI Security Project (2025). Securing Agentic Applications Guide 1.0. OWASP Foundation. https://genai.owasp.org/resource/securing-agentic-applications-guide-1-0

**[378]** Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M. et Tramèr, F. (2024). AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. arXiv:2406.13352. https://arxiv.org/abs/2406.13352

**[379]** Ministère de la Cybersécurité et du Numérique du Québec (2025). Énoncé de principes pour une utilisation responsable de l'intelligence artificielle par les organismes publics, édition 2025. MCN. https://cdn-contenu.quebec.ca/cdn-contenu/adm/min/cybersecurite_numerique/Publications/Strategie_IA/Enonce_IA.pdf

**[380]** OpenTelemetry (CNCF) (2026). Semantic conventions for generative AI client inference. GitHub, open-telemetry/semantic-conventions-genai. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/client-inference.md

**[381]** OpenTelemetry (CNCF) (2026-06-12). *Release v1.42.0 - open-telemetry/semantic-conventions*. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.42.0

**[382]** OpenTelemetry (CNCF) (2026). Semantic conventions for generative AI metrics (branche main). GitHub, open-telemetry/semantic-conventions-genai. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/gen-ai-metrics.md

**[383]** OpenTelemetry (11 mai 2026). Release v1.41.1 – open-telemetry/semantic-conventions. CNCF. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.41.1

**[384]** OpenTelemetry (28 avril 2026). Release v1.41.0 – open-telemetry/semantic-conventions. CNCF. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.41.0

**[385]** OpenTelemetry (2026). OpenTelemetry Python - OpenAI Instrumentation. OpenTelemetry (opentelemetry-python-contrib). https://opentelemetry-python-contrib.readthedocs.io/en/latest/instrumentation-genai/openai.html

**[386]** OpenTelemetry (2026). Semantic conventions for Model Context Protocol (v1.41.0). CNCF. https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/mcp.md

**[387]** OpenTelemetry (CNCF) (2025-08-25). *Release v1.37.0*. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.37.0

**[388]** OpenTelemetry (CNCF) (2026). Semantic conventions for generative AI metrics (v1.41.0). https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/gen-ai-metrics.md

**[389]** OpenTelemetry (2026). Semantic conventions for GenAI inference token metrics (statut Development). OpenTelemetry / CNCF. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/gen-ai-token-metrics.md

**[390]** OpenTelemetry (2026). Naming. OpenTelemetry. https://opentelemetry.io/docs/specs/semconv/general/naming

**[391]** OpenTelemetry (29 octobre 2025). Release v1.38.0 – open-telemetry/semantic-conventions. CNCF. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.38.0

**[392]** OpenTelemetry (2026). *GenAI spans – Content capture configuration (semantic-conventions-genai)*. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/gen-ai-spans.md

**[393]** W3C (2024). Propagation format for distributed context: Baggage, Candidate Recommendation Snapshot, 30 mai 2024. https://www.w3.org/TR/baggage

**[394]** Future of Life Institute (2026). *Article 12: Record-Keeping*. https://artificialintelligenceact.eu/article/12

**[395]** ISO/IEC (2023). ISO/IEC 42001:2023 — Technologies de l'information — Intelligence artificielle — Système de management. ISO. https://www.iso.org/standard/81230.html

**[396]** OpenTelemetry (CNCF) (2026). Semantic conventions for Generative AI events (v1.41.0). https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/gen-ai-events.md

**[397]** Stanford Institute for Human-Centered Artificial Intelligence (2025). The 2025 AI Index Report. Stanford University. https://hai.stanford.edu/ai-index/2025-ai-index-report

[398] Cottier, B., Snodin, B., Owen, D. et Adamczewski, T. (2025, 12 mars). LLM inference prices have fallen rapidly but unequally across tasks. Epoch AI.
https://epoch.ai/data-insights/llm-inference-price-trends

[399] Anthropic (2026). Pricing. Claude Platform Docs.
https://platform.claude.com/docs/en/about-claude/pricing

[400] Anthropic (s. d.). Data residency. Claude Developer Platform Documentation.
https://platform.claude.com/docs/en/manage-claude/data-residency

[401] Anthropic (2026). Prompt caching. Claude Platform Docs.
https://platform.claude.com/docs/en/build-with-claude/prompt-caching

[402] OpenAI (2026). Prompt caching. OpenAI API Docs.
https://developers.openai.com/api/docs/guides/prompt-caching

[403] Belcak, P., Heinrich, G., Diao, S., Fu, Y., Dong, X., Muralidharan, S., Lin, Y. C. et Molchanov, P. (2025). Small Language Models are the Future of Agentic AI (arXiv:2506.02153). NVIDIA Research; Georgia Institute of Technology.
https://arxiv.org/abs/2506.02153

[404] Amazon Web Services (s. d.). GENCOST05-BP01 Create stopping conditions to control long-running workflows. AWS Well-Architected Framework, Generative AI Lens.
https://docs.aws.amazon.com/wellarchitected/latest/generative-ai-lens/gencost05-bp01.html

[405] Amazon Web Services (s.d.). Generative AI Lens – Cost optimization (GENCOST01 à GENCOST05). AWS Well-Architected Framework.
https://docs.aws.amazon.com/wellarchitected/latest/generative-ai-lens/cost-optimization.html

[406] FinOps Foundation (s. d.). FinOps Framework – Scopes. FinOps Foundation.
https://www.finops.org/framework/scopes

[407] FinOps Foundation (2026). FinOps for AI Overview (mis à jour le 17 février 2026). FinOps Foundation.
https://www.finops.org/wg/finops-for-ai-overview

[408] FinOps Foundation (Linux Foundation) (2026-06-04). *FOCUS Specification v1.4 – Service Category*.
https://focus.finops.org/docs/specification/v1-4/columns/cost-and-usage/service-category

[409] FinOps Foundation (Linux Foundation) (2026). *FOCUS v1.4 – Consumed Unit*.
https://focus.finops.org/docs/specification/v1-4/columns/cost-and-usage/consumed-unit

[410] FinOps Foundation (s. d.). FOCUS Specification v1.4 – Introduction. FinOps Foundation.
https://focus.finops.org/docs/specification/v1-4/sections/introduction

[411] NIST Center for AI Standards and Innovation (2026, 17 février). Announcing the "AI Agent Standards Initiative" for Interoperable and Secure Innovation. NIST.
https://www.nist.gov/news-events/news/2026/02/announcing-ai-agent-standards-initiative-interoperable-and-secure

[412] Commission européenne (2024). *AI Act — Article 14 : Human oversight*.
https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-14

[413] Commission d'accès à l'information du Québec (2024). Réaliser une évaluation des facteurs relatifs à la vie privée : guide d'accompagnement à la démarche et à sa documentation, version 3.1. CAI.
https://www.cai.gouv.qc.ca/uploads/pdfs/CAI_GU_EFVP.pdf

[414] Commission d'accès à l'information du Québec (s.d.). Incidents de confidentialité et mesures de sécurité. CAI.
https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/incidents-confidentialite-mesures-securite-entreprises

[415] Commission d'accès à l'information du Québec (2021). Intelligence artificielle et protection des renseignements personnels : retour sur la consultation sur les principes en intelligence artificielle. CAI.
https://www.cai.gouv.qc.ca/uploads/pdfs/CAI_DOC_Reflex_IA_RP.pdf

[416] Gouvernement du Québec (1er avril 2026). Communication ou réalisation d'une tâche qui concerne des renseignements personnels à l'extérieur du Québec. Québec.ca.
https://www.quebec.ca/gouvernement/travailler-gouvernement/normes-gouvernance-pratiques-internes/protection-des-renseignements-personnels/communication-de-renseignements-personnels/communication-realisation-tache-exterieur-quebec

[417] États-Unis (2018). 18 U.S.C. § 2713, ajouté par le CLOUD Act, Pub. L. 115-141, div. V, 23 mars 2018. Legal Information Institute.
https://www.law.cornell.edu/uscode/text/18/2713

[418] Gouvernement du Canada (2025). Digital Sovereignty: A Framework to improve digital readiness of the Government of Canada.
https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/cloud-services/digital-sovereignty/digital-sovereignty-framework-improve-digital-readiness.html

[419] Commission d'accès à l'information du Québec (s.d.). Consentement des personnes concernées. CAI. https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/consentement-personnes-entreprises

[420] Commission d'accès à l'information du Québec (s. d.). Conservation et destruction des renseignements personnels. CAI. https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/conservation-destruction-renseignements-personnels

[421] Ministère de la Cybersécurité et du Numérique du Québec (2025). Indication d'application IA-RI-2025-003-OP : mesures applicables lors de l'utilisation de l'intelligence artificielle générative. MCN. https://cdn-contenu.quebec.ca/cdn-contenu/adm/min/cybersecurite_numerique/Publications/Strategie_IA/Indication_app_IAG.pdf

[422] Ministère de la Cybersécurité et du Numérique du Québec (2026). Énoncé de politique de souveraineté numérique et d'approvisionnement en technologie de l'information. MCN. https://cdn-contenu.quebec.ca/cdn-contenu/adm/min/cybersecurite_numerique/Publications/Enonce_politique_souveraineté_numerique.pdf

[423] Gouvernement du Québec (23 avril 2026). Outils en matière de protection des renseignements personnels. Québec.ca. https://www.quebec.ca/gouvernement/travailler-gouvernement/normes-gouvernance-pratiques-internes/protection-des-renseignements-personnels/outils

[424] Commission d'accès à l'information du Québec (2025). Rapport annuel d'activités et de gestion 2024-2025. CAI. https://www.cai.gouv.qc.ca/uploads/pdfs/CAI_RAAG-2024-2025.pdf

[425] Commission d'accès à l'information du Québec (2026). Transparence et vie privée : protéger la démocratie à l'ère numérique, rapport quinquennal 2026 (communiqué du 11 juin 2026). CAI. https://www.cai.gouv.qc.ca/uploads/pdfs/CAI_Communique_RQ_2026.pdf

[426] Commissariat à la protection de la vie privée du Canada (2025). Ce que vous devez savoir sur la déclaration obligatoire des atteintes aux mesures de sécurité. CPVP. https://www.priv.gc.ca/en/privacy-topics/business-privacy/breaches-and-safeguards/privacy-breaches-at-your-business/gd_pb_201810

[427] Gouvernement du Canada (s. d.). Personal Information Protection and Electronic Documents Act (S.C. 2000, c. 5), art. 10.1. Site Web de la législation (Justice). https://laws-lois.justice.gc.ca/eng/acts/p-8.6/FullText.html

[428] Parlement du Canada (6 janvier 2025). Projet de loi C-27 (44-1), Loi de 2022 sur la mise en œuvre de la Charte du numérique. LEGISinfo. https://www.parl.ca/legisinfo/en/bill/44-1/c-27

[429] Bureau du Conseil privé (14 mars 2025). Opening of new parliamentary session, dans Opening Parliament, livret d'information pour le premier ministre du Canada. Canada.ca. https://www.canada.ca/en/privy-council/corporate/transparency/briefing-documents/prime-minister-2025/opening-parliament.html

[430] Parlement du Canada (15 juin 2026). Projet de loi C-36 (45-1), Loi visant à protéger la vie privée et les données des consommateurs, première lecture le 15 juin 2026. LEGISinfo. https://www.parl.ca/legisinfo/en/bill/45-1/c-36

[431] Parlement du Canada (15 juin 2026). Projet de loi C-36 (45-1), première lecture – Loi sur la protection de la vie privée et des données des consommateurs. Parlement du Canada. https://www.parl.ca/DocumentViewer/en/45-1/bill/C-36/first-reading

[432] Secrétariat du Conseil du Trésor du Canada (15 septembre 2026). Algorithmic Impact Assessment. Canada.ca. https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/automated-decision-making/algorithmic-impact-assessment.html

[433] Gouvernement du Canada (2026). Guide on the Scope of the Directive on Automated Decision-Making. https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/guide-scope-directive-automated-decision-making.html

[434] Bureau du surintendant des institutions financières (2021). Signalement des incidents liés à la technologie et à la cybersécurité (préavis). BSIF. https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-security-incident-reporting

[435] Bureau du surintendant des institutions financières (2022). Ligne directrice B-13 : Gestion du risque lié aux technologies et du cyberrisque. BSIF. https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management

[436] Bureau du surintendant des institutions financières (13 juillet 2022). OSFI releases final Guideline B-13 – Technology and Cyber Risk Management – Letter. BSIF.
https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/osfi-releases-final-guideline-b-13-technology-cyber-risk-management-letter-2022

[437] Innovation, Sciences et Développement économique Canada (2023). Code de conduite volontaire visant un développement et une gestion responsables des systèmes d'IA générative avancés. ISDE.
https://ised-isde.canada.ca/site/ised/en/voluntary-code-conduct-responsible-development-and-management-advanced-generative-ai-systems

[438] Commissariat à la protection de la vie privée du Canada et homologues provinciaux et territoriaux (2023). Principes pour des technologies d'IA générative responsables, dignes de confiance et respectueuses de la vie privée. CPVP.
https://www.priv.gc.ca/en/privacy-topics/technology/artificial-intelligence/gd_principles_ai

[439] Parlement du Canada (LEGISinfo) (2026-06-15). *C-8 (45-1) – An Act respecting cyber security*.
https://www.parl.ca/legisinfo/en/bill/45-1/c-8

[440] Parlement du Canada (LEGISinfo) (2026). *Bills – 45th Parliament, 1st Session*.
https://www.parl.ca/legisinfo/en/bills?parlsession=45-1&page=2

[441] Commission européenne (2024). *AI Act — Article 2 : Scope*.
https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-2

[442] Commission européenne (2024). *AI Act — Annex III : High-risk AI systems referred to in Article 6(2)*.
https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

[443] Commission européenne (2026). AI Act. Shaping Europe's digital future.
https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai

[444] Future of Life Institute (2026). *Article 9: Risk Management System*.
https://artificialintelligenceact.eu/article/9

[445] Future of Life Institute (2026). *Article 13: Transparency and Provision of Information to Deployers*.
https://artificialintelligenceact.eu/article/13

[446] Future of Life Institute (2026). Article 72: Post-Market Monitoring by Providers and Post-Market Monitoring Plan for High-Risk AI Systems.
https://artificialintelligenceact.eu/article/72

[447] Commission européenne (AI Act Service Desk) (2024). *AI Act — Article 26 : Obligations of deployers of high-risk AI systems*.
https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-26

[448] NIST (2026). *AI Risk Management Framework*.
https://www.nist.gov/itl/ai-risk-management-framework

[449] National Institute of Standards and Technology (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1. NIST.
https://doi.org/10.6028/NIST.AI.600-1

[450] ISO/IEC (18 décembre 2023). ISO/IEC 42001:2023, Information technology — Artificial intelligence — Management system (fiche catalogue, édition 1). Standards Norway.
https://online.standard.no/en/isoiec-42001-2023-4

[451] ISO/IEC (2025). ISO/IEC 42006:2025 — Exigences pour les organismes procédant à l'audit et à la certification des systèmes de management de l'IA. ISO.
https://online.standard.no/en/isoiec-42006-2025

[452] ISO/IEC (2025). ISO/IEC 42005:2025 — Technologies de l'information — Intelligence artificielle — Évaluation de l'impact des systèmes d'IA. ISO.
https://online.standard.no/en/isoiec-42005-2025

[453] ISO/IEC (2023). ISO/IEC 23894:2023 — Technologies de l'information — Intelligence artificielle — Recommandations relatives au management du risque. ISO.
https://online.standard.no/en/isoiec-23894-2023

[454] Raza, S., Sapkota, R., Karkee, M. et Emmanouilidis, C. (2025). TRiSM for Agentic AI: A Review of Trust, Risk, and Security Management in LLM-based Agentic Multi-Agent Systems. arXiv:2506.04133.
https://arxiv.org/abs/2506.04133

[455] National Institute of Standards and Technology (20 octobre 2026). SP 800-53 Control Overlays for Super Intelligence Systems (COSIS; anciennement Control Overlays for Securing AI Systems, COSAiS). NIST CSRC.
https://csrc.nist.gov/projects/cosais

[456] National Institute of Standards and Technology (2026, 7 avril). Concept Note: AI RMF Profile on Trustworthy AI in Critical Infrastructure. NIST.
https://www.nist.gov/document/concept-note-artificial-intelligence-risk-management-framework-trustworthy-ai-critical

[457] Commission européenne (2024). AI Act — Article 50 : Transparency obligations for providers and deployers of certain AI systems.
https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-50

[458] Badran, M. et Bonsange-Basia, V. (19 novembre 2025). Specter Aviation Limited c. Laprade : une première sanction judiciaire au Québec liée à l'usage de l'intelligence artificielle. Gowling WLG.
https://gowlingwlg.com/fr/insights-resources/articles/2025/specter-aviation-v-laprade-qc-first-judicial-sanction-ai

[459] Future of Life Institute (2026). *Article 73: Reporting of Serious Incidents*.
https://artificialintelligenceact.eu/article/73

[460] Québec (2022). Règlement sur les incidents de confidentialité, RLRQ, c. A-2.1, r. 3.1 (décret 1761-2022, G.O.Q. 2022.II.6819, 14 décembre 2022). Éditeur officiel du Québec.
https://www.publicationsduquebec.gouv.qc.ca/fileadmin/gazette/pdf_encrypte/lois_reglements/2022F/78638.pdf

[461] Future of Life Institute (2026). Article 27: Fundamental Rights Impact Assessment for High-Risk AI Systems.
https://artificialintelligenceact.eu/article/27

[462] OpenTelemetry (5 mai 2026). Move GenAI semantic conventions to its own dedicated repository (demande de tirage nº 3696). GitHub, open-telemetry/semantic-conventions.
https://github.com/open-telemetry/semantic-conventions/issues/3696

[463] FinOps Foundation (2026). *FOCUS v1.4 Changelog*.
https://focus.finops.org/docs/specification/v1-4/changelog

[464] Alpay, S. et Cowsert, M. (10 juin 2026). Introducing FOCUS 1.4: Invoice Reconciliation, Commitment Details, and Specification Maturity. FinOps Foundation.
https://www.finops.org/insights/introducing-focus-1-4

[465] FinOps Foundation (octobre 2026). FOCUS 1.5 Release Scope: Confirmed, In Review and Deferred. FinOps Foundation.
https://focus.finops.org/focus-1-5-release-scope

[466] South, T. (dir.) (octobre 2025). Identity Management for Agentic AI: The new frontier of authorization, authentication, and security for an AI agent world (livre blanc, PDF). OpenID Foundation.
https://openid.net/wp-content/uploads/2025/10/Identity-Management-for-Agentic-AI.pdf

[467] Computerworld (2026, 30 avril). Gartner sees untamed growth in agentic AI. Foundry.
https://www.computerworld.com/article/4165686/gartner-sees-untamed-growth-in-agentic-ai.html

[468] Apache Software Foundation (2026). *Apache Kafka — Introduction*.
https://kafka.apache.org/intro

[469] FinOps Foundation (s. d.). What is FinOps? FinOps Foundation.
https://www.finops.org/introduction/what-is-finops

[470] OWASP (2025). OWASP Non-Human Identities Top 10 – 2025. OWASP Foundation.
https://owasp.org/www-project-non-human-identities-top-10/2025

[471] SPIFFE Project (s. d.). SPIFFE Workload API (spécification). SPIFFE / CNCF.
https://github.com/spiffe/spiffe/blob/main/standards/SPIFFE_Workload_API.md

[472] A2A Project (28 mai 2026). Release v1.0.1 (dépôt a2aproject/A2A). GitHub.
https://github.com/a2aproject/A2A/releases/tag/v1.0.1

[473] Abdin, M. et coll. (2024). Phi-3 Technical Report: A Highly Capable Language Model Locally on Your Phone (arXiv:2404.14219). Microsoft.
https://arxiv.org/abs/2404.14219